GRC360 Documentation

User guide, administration and technical reference

Strativu
October 2026 release

Contents

About this guide
- GRC360 Documentation

Part 0 — Introduction
- What is GRC360
- Key concepts
- Navigation and layout
- Working with registers
- Permissions and access

Part 1 — Getting started
- Signing in and sessions
- Your profile, account, notifications and support
- First-time setup for a new organisation

Part 2 — Module reference
- Command Center
- Governance Hub
- Coverage
- Issues
- Objectives
- Organization Hub
- Users
- Departments
- Groups
- Third Parties
- Vendors
- Service Agreements
- Asset Management
- Assets
- Data Flows
- Control Center
- Controls
- Policies & Standards
- Policy Exceptions
- Continuity Plans
- Risk Management
- Asset Risks
- Third Party Risks
- Business Risks
- Risk Exceptions
- Compliance Hub
- Compliance Packages
- Compliance Analysis
- Obligations
- Compliance Exceptions
- External Audit Findings
- Operations Center
- Projects
- Security Incidents
- Trust Center
- Integrations & Automation

Settings
Authentication
About System
System Health
Updates
System Log
Clear Data

Part 3 — How the modules work together
Relationship map
Scenario: a risk assessment cycle
Scenario: preparing for an ISO/IEC 27001 audit
Scenario: onboarding a new vendor
Scenario: handling a security incident
Scenario: the annual policy review
Scenario: business continuity planning and testing

Part 4 — Administration
Administration guide
Users, groups and permissions
Authentication and SSO
E-mail, webhooks and notifications
Sessions and security
System maintenance

Part 5 — Technical reference
Technical reference
Architecture
Installation and deployment
REST API
Data model
Security
Operations
Development

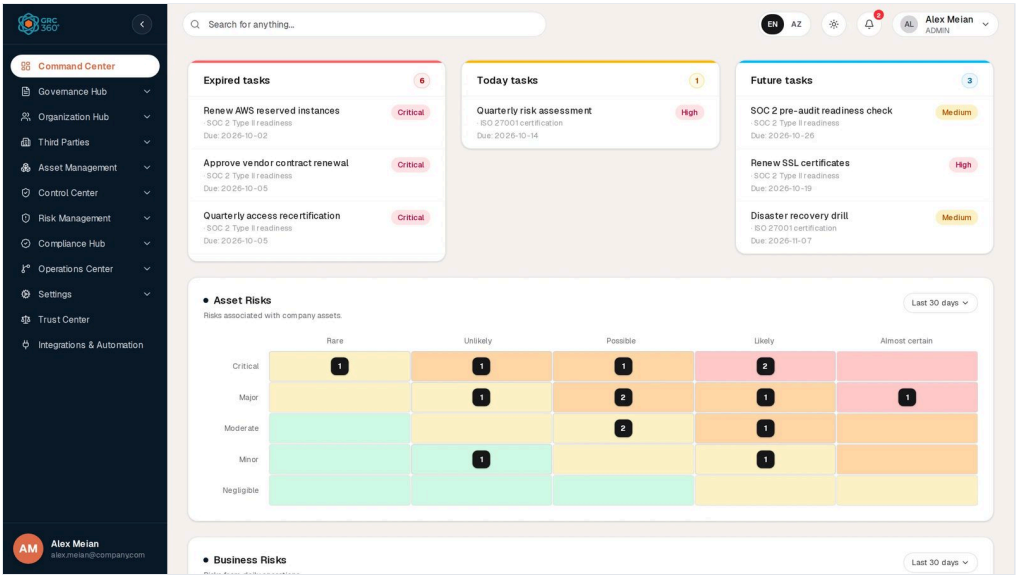
Appendices
Glossary
Permission keys
Status and Dynamic Status rules
Notifications and scheduled jobs
CSV import and export
Known issues

About this guide

GRC360 Documentation

GRC360 is Strativu's platform for governance, risk and compliance. One system holds the organisation's assets, risks, controls, policies, compliance obligations, third parties, projects and incidents, and links them to each other, so a risk can be traced to the control that treats it, the policy behind that control and the framework requirement it satisfies.

This guide describes the product as built in the October 2026 release (frontend `GRC_Frontend_Code` main, backend `GRC_Backend_Code` develop). Every screen, field and rule in it was taken from the code and checked against a running instance. All screenshots use fictional demo data.



GRC360 Command Center

Who should read what

You are	Start with	Then
New to GRC360	What is GRC360	Key concepts, Signing in
A risk, compliance or control owner	Working with registers	The module you work in under Module reference
Setting up GRC360 for your organisation	First-time setup	Administration
An auditor	Relationship map	Preparing for an audit, System Log
A developer or installer	Technical reference	Installation and deployment

Contents

Part 0 — Introduction

1. What is GRC360
2. Key concepts
3. Navigation and layout
4. Working with registers
5. Permissions and access, from the user's side

Part 1 — Getting started

1. Signing in and sessions
2. Your profile, account, notifications and support
3. First-time setup for a new organisation

Part 2 — Module reference

Module	Pages
Command Center	Dashboard
Governance Hub	Coverage · Issues · Objectives (+ Audits)
Organization Hub	Users · Departments · Groups
Third Parties	Vendors · Service Agreements
Asset Management	Assets (+ Reviews) · Data Flows
Control Center	Controls (+ Audits, Issues, Maintenances) · Policies & Standards (+ Reviews) · Policy Exceptions · Continuity Plans (+ Audits, Tasks)
Risk Management	Asset Risks · Third Party Risks · Business Risks (each + Reviews) · Risk Exceptions
Compliance Hub	Compliance Packages (+ Items) · Compliance Analysis · Obligations · Compliance Exceptions · External Audit Findings
Operations Center	Projects (+ Tasks, Expenses) · Security Incidents (+ Stages)
Trust Center	Public security posture
Integrations & Automation	Built and planned integrations
Settings	Authentication · About System · System Health · Updates · System Log · Clear Data

Part 3 — How the modules work together

1. Relationship map
2. Scenario: a risk assessment cycle
3. Scenario: preparing for an ISO/IEC 27001 audit
4. Scenario: onboarding a new vendor
5. Scenario: handling a security incident
6. Scenario: the annual policy review
7. Scenario: business continuity planning and testing

Part 4 — Administration

Administration guide: users, groups and permissions; authentication and SSO; e-mail, webhooks and notifications; sessions and security; system maintenance.

Part 5 — Technical reference

Technical reference: architecture, installation and deployment, API, data model, security, operations, development.

Appendices

- Glossary
- Permission keys
- Status and Dynamic Status rules
- Notifications and scheduled jobs
- CSV import and export
- Known issues

Keeping this guide current

The screenshots and demo data are reproducible. With a local frontend and backend running:

```
cd doc/guide/tools
python3 seed_demo.py                      # fictional demo data, safe to run repeatedly
node screens.cjs --out /tmp/grc-shots     # every screenshot in this guide (needs Playwright)
python3 convert.py /tmp/grc-shots ../images
python3 check_links.py                    # every link and image resolves
```

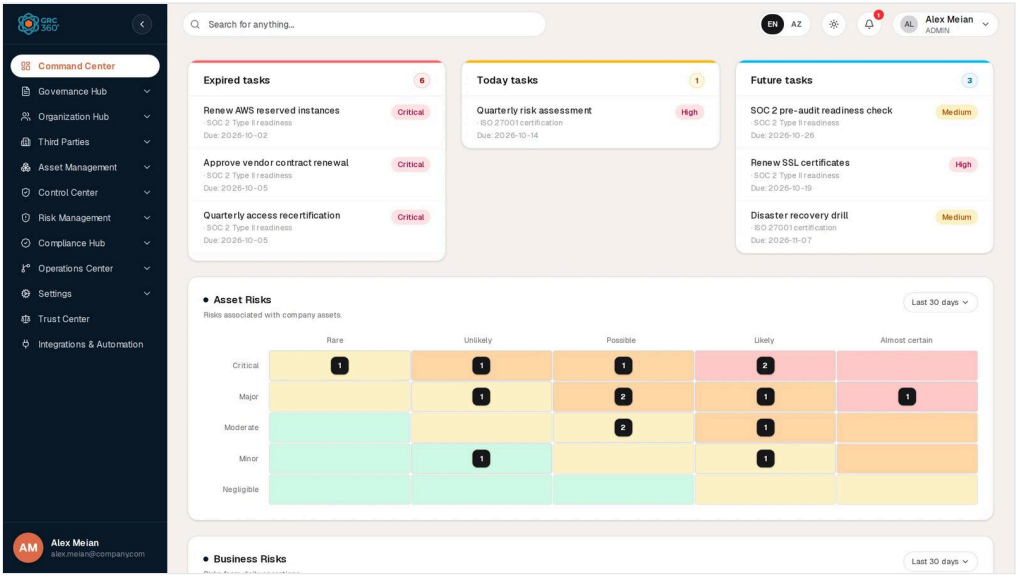
Each page follows the same template, so a changed screen means updating one page and re-running the scripts.

Part 0 — Introduction

What is GRC360

GRC360 is a web application for running an organisation's governance, risk and compliance (GRC) programme in one place. It replaces the usual mix of spreadsheets, shared folders and e-mail threads with linked registers: each asset, risk, control, policy, compliance requirement, vendor, project and incident is a record, and records point to each other.

The method follows the ERAMBA model of GRC registers: a risk is treated by controls, policies, projects or exceptions; a control satisfies requirements in one or more compliance packages; and every register keeps its own reviews, audits and history.



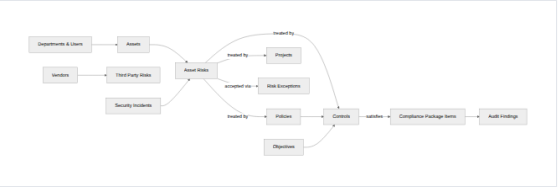
The GRC360 workspace

What you can do with it

Area	What GRC360 gives you	Module
Overview	Your expired, today's and upcoming tasks, and heat maps of asset, business and third-party risks	Command Center
Scope and direction	What the programme covers, its objectives with periodic audits, and governance issues	Governance Hub
People	Users, departments and groups, with permissions per page and per action	Organization Hub
Suppliers	Vendors and their service agreements, with expiry warnings	Third Parties
Assets	The asset inventory, periodic asset reviews and data flows, including GDPR questions	Asset Management
Controls	Internal controls with scheduled audits, issues and maintenances; policies and standards with reviews; policy exceptions; business continuity plans	Control Center
Risk	Asset, third-party and business risk registers, scored on a likelihood × impact matrix against your risk appetite, with treatments and exceptions	Risk Management

Area	What GRC360 gives you	Module
Compliance	Compliance packages (frameworks and their requirement items), compliance analysis, legal obligations, compliance exceptions and external audit findings	Compliance Hub
Delivery	Security projects with tasks and expenses; security incidents with stages	Operations Center
Transparency	A public page describing your security practices	Trust Center
Platform	Sign-in (local passwords or LDAP / Active Directory), e-mail, system health, the system log	Settings, Integrations & Automation

How the pieces fit



The full map, with every link and where it is shown, is in How the modules work together.

Principles you will notice

- **One record, many uses.** A control is written once and linked to every risk it treats and every requirement it satisfies. Counts in the grids (for example **Asset Risks: 15** on a control) are clickable and show the linked records.
- **The system computes what it can.** Besides the **Status** you choose, most records show a **Dynamic Status** the system works out from dates and linked records, such as an expired review or a risk above appetite. See Key concepts.
- **Every change is recorded.** Each record has an **Activity Log** that merges comments with the history of who changed which field, and the System Log records actions across the tenant.
- **Buttons stay visible.** If you lack a permission, the button is shown locked and clicking it lets you request access. See Permissions and access.
- **Two languages.** The interface can be switched between English and Azerbaijani at any time.

Deployment models

GRC360 runs as a multi-tenant cloud service, where every customer organisation is an isolated *tenant*, and can also be installed on the customer's own servers with Docker Compose. See Installation and deployment.

About this guide

All screenshots show fictional demo data in a demo tenant with the users Alex Meian (Admin), Sara Johnson, Mike Brown and Olivia Reed (Read Only). Names of companies and people in the examples are invented.

Key concepts

This page defines the terms used throughout GRC360 and this guide. The full list is in the Glossary.

Tenant

A **tenant** is one customer organisation. Every record belongs to exactly one tenant, and users of one tenant can never see another tenant's data. Your tenant identifier is shown on your Profile page. In a cloud installation each organisation is a separate tenant; an on-premise installation usually holds one.

Register and record

A **register** is a list of records of one kind, for example the Asset Risks register or the Controls register. Each register is a page in the sidebar. A **record** is one row in a register: one risk, one control, one vendor.

Some registers have **tabs** (sections) that hold child records. For example, a control has **Audits**, **Issues** and **Maintenances**; a project has **Tasks** and **Expenses**. Tabs carry their own permissions. See Working with registers.

Modules

The sidebar groups registers into **modules**:

Module	Registers (tabs in brackets)
Command Center	Dashboard
Governance Hub	Coverage · Issues · Objectives (Audits)
Organization Hub	Users · Departments · Groups
Third Parties	Vendors · Service Agreements
Asset Management	Assets (Reviews) · Data Flows
Control Center	Controls (Audits, Issues, Maintenances) · Policies & Standards (Reviews) · Policy Exceptions · Continuity Plans (Audits, Tasks)
Risk Management	Asset Risks (Reviews) · Third Party Risks (Reviews) · Business Risks (Reviews) · Risk Exceptions
Compliance Hub	Compliance Packages (Items) · Compliance Analysis · Obligations · Compliance Exceptions · External Audit Findings
Operations Center	Projects (Tasks, Expenses) · Security Incidents (Stages)
Settings	Authentication · About System · System Health · Updates · System Log · Clear Data
Trust Center	Public security page
Integrations & Automation	Overview of integrations

Status and Dynamic Status

Most registers show two different kinds of status. They are never interchangeable, and a column heading always tells you which one it shows.

	Status	Dynamic Status
Who sets it	You, in the Add or Edit form	The system
Stored	Yes	Worked out every time the record is read (risk registers also keep a copy saved with the record, used by some summaries)
Changes when	Someone edits the record	Time passes or linked records change

	Status	Dynamic Status
Example	A policy is **Published**	The policy's review date has passed, so it shows **Review Expired**

Because Dynamic Status is calculated when you open the page, a date-based value such as *Expired* appears without anyone doing anything. A risk register can show several Dynamic Status flags at once, for example *Review Expired* and *Above Appetite*.

Statuses are shown as coloured pills. The colours are the same everywhere:

Colour	Meaning	Examples
Green	Done, healthy, compliant	Active, Completed, Approved, Compliant, Published, Low
Amber	In progress or needs attention	In Progress, Pending, Under Review, Review Expired, Partial, Expiring, Medium
Red	Failed, overdue, above limit	Expired, Overdue, Failed, Rejected, Not Compliant, Above Appetite, High, Critical
Blue	Open or planned	Open, New, Planned, Scheduled, Assigned
Grey	Inactive or not applicable	Draft, Inactive, Archived, Cancelled, Revoked, and any value the system does not recognise
`--`	No value	

The complete list of values per register is in Status and Dynamic Status rules.

Risk terms

Term	Meaning in GRC360
Risk	An uncertain event that could harm the organisation. GRC360 keeps three registers: **Asset Risks** (tied to assets), **Third Party Risks** (tied to vendors) and **Business Risks** (tied to processes and business units).
Likelihood and **Impact**	The two scales used to analyse a risk. Each has five levels by default: Rare, Unlikely, Possible, Likely, Almost certain; and Negligible, Minor, Moderate, Major, Critical.
Inherent risk score	The score before treatment, from likelihood × impact (for example Likely 4 × Critical 5 = 20).
Residual risk score	The score after treatment, reduced by the **Residual Percentage Coefficient** chosen on the risk. Scores are calculated when the risk is saved.
Risk appetite / threshold	The level of risk the organisation accepts, set in the risk settings. A risk whose residual score is above the numerical appetite is flagged **Above Appetite**. Check the appetite value against your scale: with the default 5 × 5 matrix the highest score is 25.
Risk treatment	What is done about a risk: **Mitigate**, **Accept**, **Transfer** or **Avoid**, with the controls, policies, projects or exceptions that carry it out.
Risk exception	A formal, time-limited acceptance of a risk, with a requester, a contact and an expiry date, linked to the risks it covers.

See Risk Management for the full scoring model with worked examples.

Control and compliance terms

Term	Meaning in GRC360
Control (internal control)	A safeguard the organisation operates, such as multi-factor authentication. A control can be audited on a schedule, can have open issues and planned maintenances, and can be linked to risks, policies, projects and compliance packages.
Policy / Standard	A governing document with a version, publication date and review date. Policies can be reviewed periodically and linked to controls and risks.
Policy exception	Approved, time-limited permission to deviate from a policy.
Continuity plan	A business continuity or disaster recovery plan with step-by-step tasks and periodic audits (tests).
Compliance package	A framework, law or standard (for example ISO/IEC 27001:2022 or the Azerbaijani Law on Personal Data). GRC360 does not ship framework content: packages and their requirement items are created by your team or imported.
Compliance package item	One requirement of a package (for example A.8.5 Secure authentication), grouped by chapter.
Compliance analysis	The assessment of a package item by item, showing which controls and policies cover each requirement and what is missing.
Obligation	A legal or regulatory duty from a named act and article, with the authority, responsible team and review date.
Compliance exception	Approved, time-limited non-compliance with a requirement.
External audit finding	A finding raised by an external auditor, with severity, owner and due date.

Governance terms

Term	Meaning
Coverage	What the GRC programme covers: a region, business unit, process or IT system.
Objective	A goal of the programme with a target date, progress and periodic audits.
Issue	A governance issue found in an audit, a gap assessment or reported manually, with a severity.

People and access terms

Term	Meaning
User	A person who signs in. Every user belongs to a department and to one or more groups.
Department	An organisational unit. Assets, risks and users can be linked to departments.
Group	A set of permissions given to users (shown in the sidebar as **Groups**). Built-in groups are Admin, Read Only and Third Party; any other group, such as Respondent in the demo data, is created by the organisation.
Access level	What a group may do on one page or tab: **No Access**, **View**, **Manage** or **Full Control**.
Can Assign / Can Reassign	Group-wide rights to name other people in owner and contact fields, or to change who is named.
Contact	A person or group named on a record, such as Risk GRC Contact or Control Operator Contact. Contact fields accept users and groups.

Term	Meaning
Request Access	The flow a user follows when a button is locked: they explain why they need the right, and administrators approve or reject it.

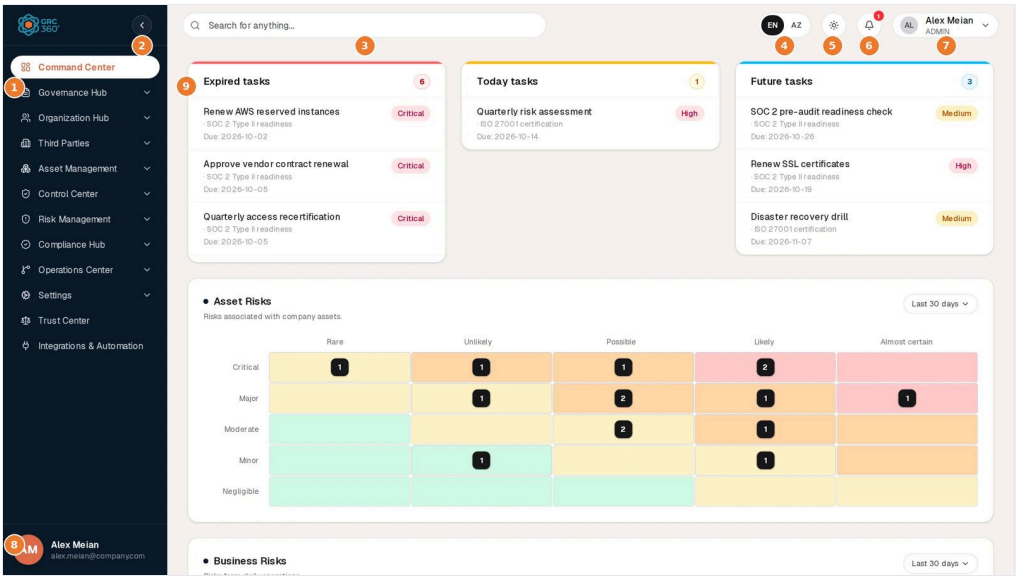
See Permissions and access and the administration guide.

History terms

Term	Meaning
Activity Log	The per-record timeline of comments, attachments and changes (who changed which field from what to what).
System Log	The tenant-wide log of actions, kept under Settings and available to administrators.
Notification	A message in the bell menu, for example an access request or a service agreement about to expire.

Navigation and layout

Every page after sign-in has the same frame: the **sidebar** on the left, the **top bar** across the top and the page content in the middle.



GRC360 layout

#	Element
1	Sidebar: modules and pages
2	Collapse or expand the sidebar
3	Global search
4	Language: English or Azerbaijani
5	Theme: light, dark or system
6	Notifications
7	Profile menu
8	Your name and e-mail
9	Page content (here the Command Center)

Sidebar

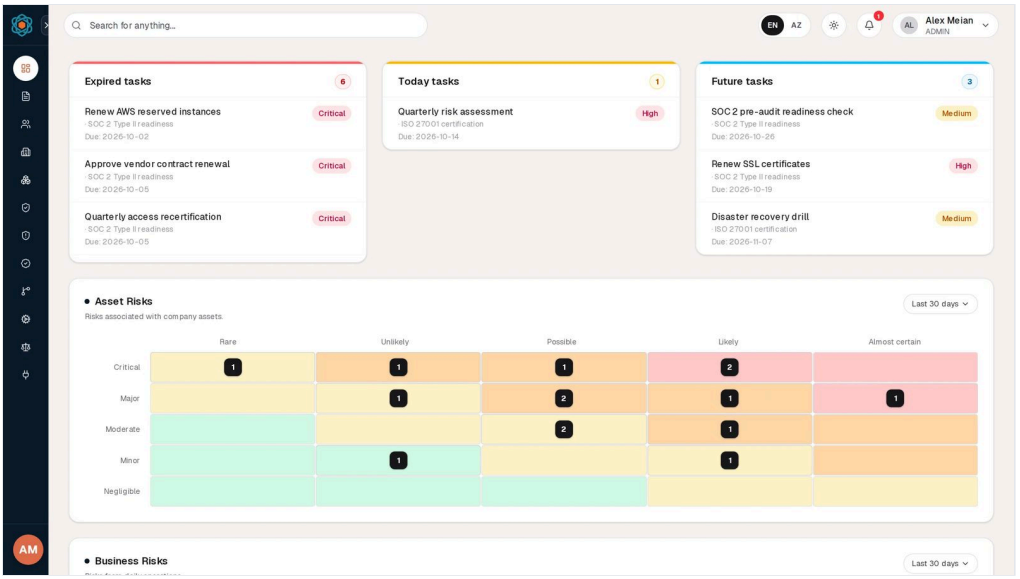
The sidebar lists the modules in this order: Command Center, Governance Hub, Organization Hub, Third Parties, Asset Management, Control Center, Risk Management, Compliance Hub, Operations Center, Settings, Trust Center, Integrations & Automation.

Opening a page

- Clicking a **module name** (for example **Risk Management**) opens the first page of that module you are allowed to see. It does not just expand the list.
- The small **chevron** on the right of a module expands or collapses its page list without navigating.
- A module opens expanded when you are on one of its pages.

Where you are. The current module shows as a white pill with orange text, and the current page inside it is shown in orange.

Collapsing the sidebar. The round arrow button at the top of the sidebar shrinks it to icons only. Hovering an icon shows its name; clicking a module icon opens its first page. The sidebar returns to full width when you reload the page.

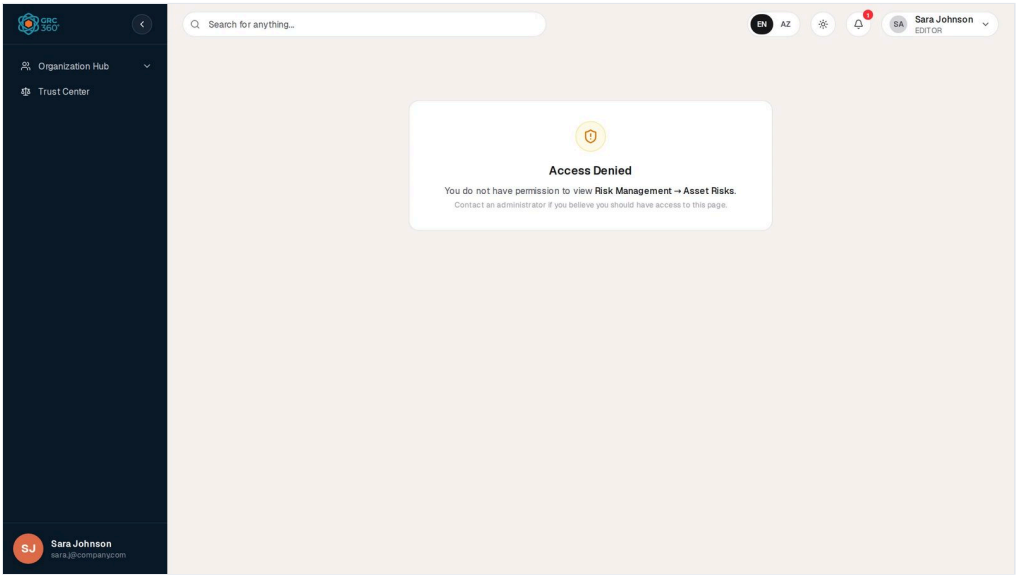


Collapsed sidebar

What you see depends on your permissions.

- Pages you cannot open are **not shown** in the sidebar.
- A module with no page you can open disappears entirely.
- **Settings** appears only for members of the Admin group.
- **Trust Center** is always shown. It opens in a new browser tab.

Compare an administrator's sidebar above with the sidebar of a user who may open only a few pages:



Sidebar of a user with limited access

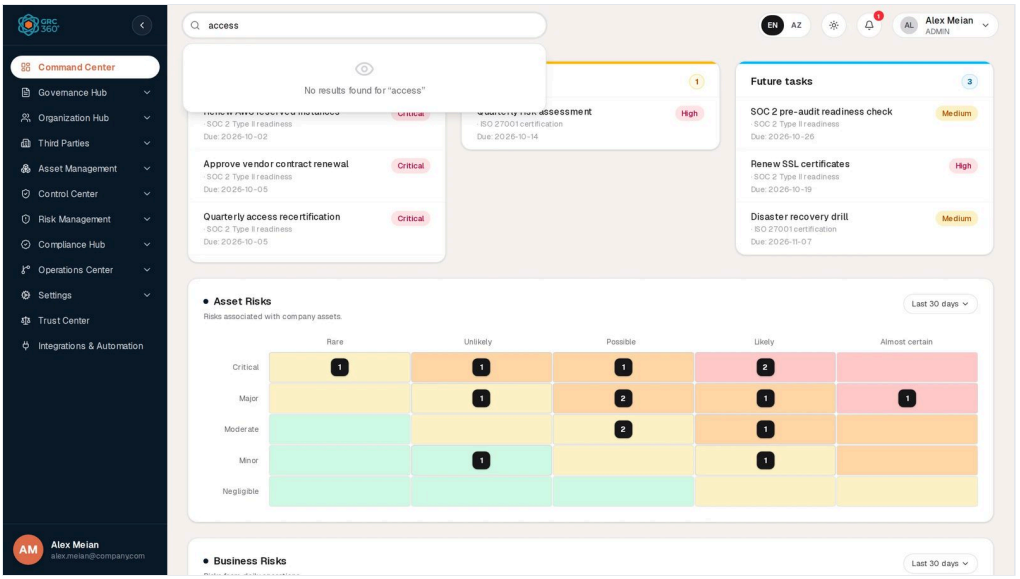
Your name. The bottom of the sidebar shows your initials, name and e-mail address.

Top bar

From left to right: global search, language switch, theme switch, notifications, and your profile menu.

Global search

Type at least two characters in **Search for anything…**. Results appear after a short pause.



Global search

What is searched. Names, titles and descriptions of these records:

- assets
- the three risk registers
- controls
- policies
- vendors
- security incidents
- projects
- issues
- objectives
- compliance packages
- users (by first name, last name and e-mail)

How results show.

- Up to five matches per type, grouped by module.
- Each result shows its type and status.

Opening a result. Clicking a result opens the **register** the record belongs to. It does not open the record itself: use the register's search box to find it there.

Language (EN / AZ)

The **EN / AZ** switch changes the interface between English and Azerbaijani. Your choice is remembered in this browser. The same switch is on the sign-in page.

What is translated: interface text, such as labels, buttons and messages built into the product.

What stays as typed or sent:

- your data;
- messages generated by the server, such as notification titles and some error messages;
- field names in the Activity Log.

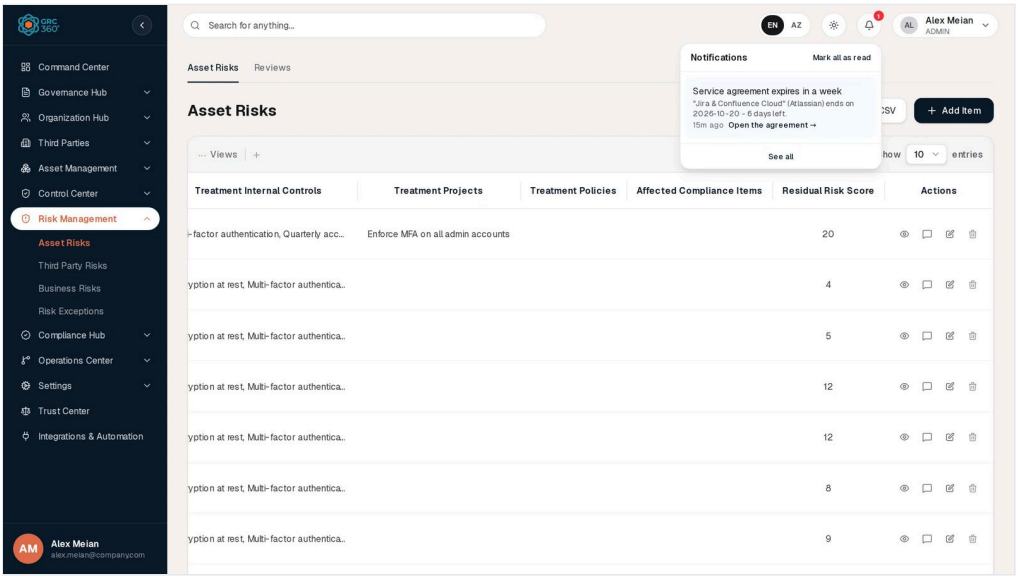
Dates follow your browser's language settings, not this switch.

Theme

The sun or moon button opens a menu with **Light**, **Dark** and **System**. **System** follows your operating system's setting and changes with it. The choice is remembered in this browser.

Notifications

The bell shows a red badge with the number of unread notifications (**9+** above nine). Clicking it opens the ten most recent:



Notifications menu

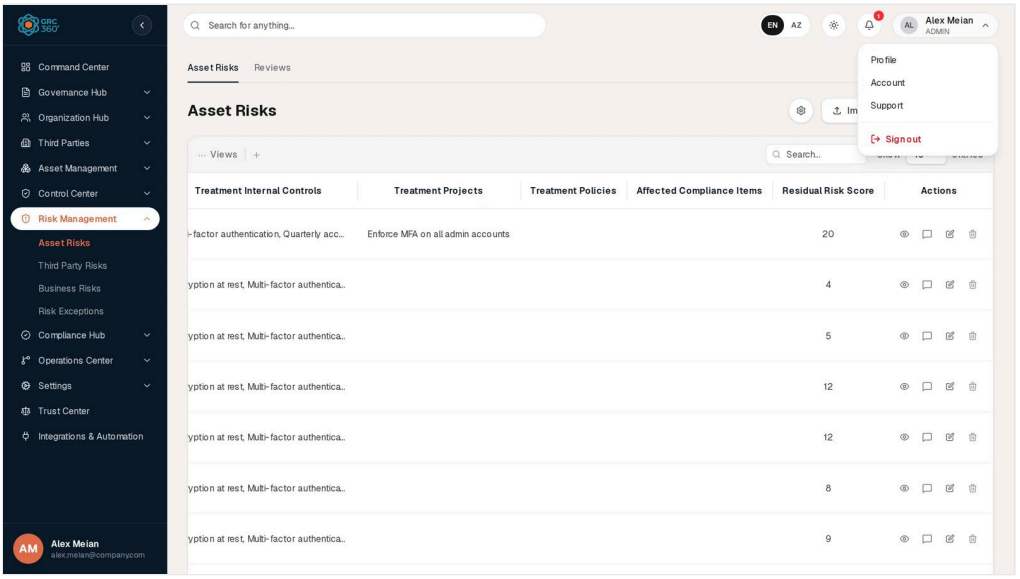
- Unread notifications have a light blue background.
- Clicking a notification marks it as read and, if it links somewhere, opens that page. For example, a service agreement notice opens the agreement.
- **Mark all as read** appears while there are unread notifications.
- **See all** opens the full Notifications page.

The badge updates by itself about every ten seconds.

Which notifications GRC360 sends today is listed in Notifications and scheduled jobs.

Profile menu

The pill on the right shows your name and your first group. It opens a menu:



Profile menu

Item	Opens
Profile	Your details as the organisation holds them

Item	Opens
Account	The pages you can open, and the browsers you are signed in on
Support	How to contact Strativu support
Sign out	Ends your session and returns you to the sign-in page

These pages are described in Your profile, account, notifications and support.

Page content

Most pages are **registers**: a title, buttons such as **Import CSV** and **Add Item**, a toolbar and a table. How to work with them is described in Working with registers.

Some pages have a row of **tabs** under the top bar, for example **Asset Risks | Reviews**. Each tab is its own register.

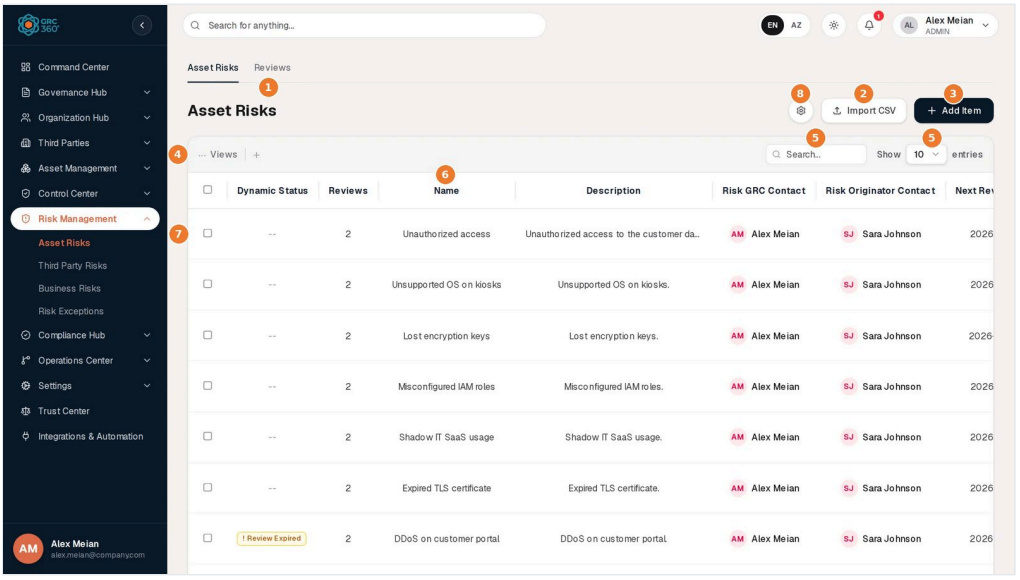
Changes by other people

GRC360 refreshes open pages by itself:

- Changes you make in one tab appear immediately in your other tabs.
- Changes made by other users appear within about ten to twelve seconds.
- You do not need to reload the page.

Working with registers

Almost every page in GRC360 is a register built on the same table, forms and dialogs. This page describes them once; the module pages only describe what is specific to each register.



A register: Asset Risks

#	Element	What it does
1	Title and tabs	The register's name. Tabs, when present, switch to child registers such as **Reviews**.
2	**Import CSV**	Imports records from a file. See Importing from CSV.
3	**Add Item**	Opens the form for a new record.
4	**… Views**	Chooses which columns are visible. Smaller registers also show a status filter and view chips here.
5	**Search…** and **Show *n* entries**	Searches the register and sets rows per page (10, 25 or 50).
6	Column headings	Click to sort; click again to reverse.
7	Row checkbox	Selects a row; its **View**, **Edit** and **Delete** buttons then appear in the toolbar. The same buttons, with **Activity Log**, are at the end of each row.
8	Page-specific buttons	Here the gear opens the risk scoring settings. Each module page describes its own.

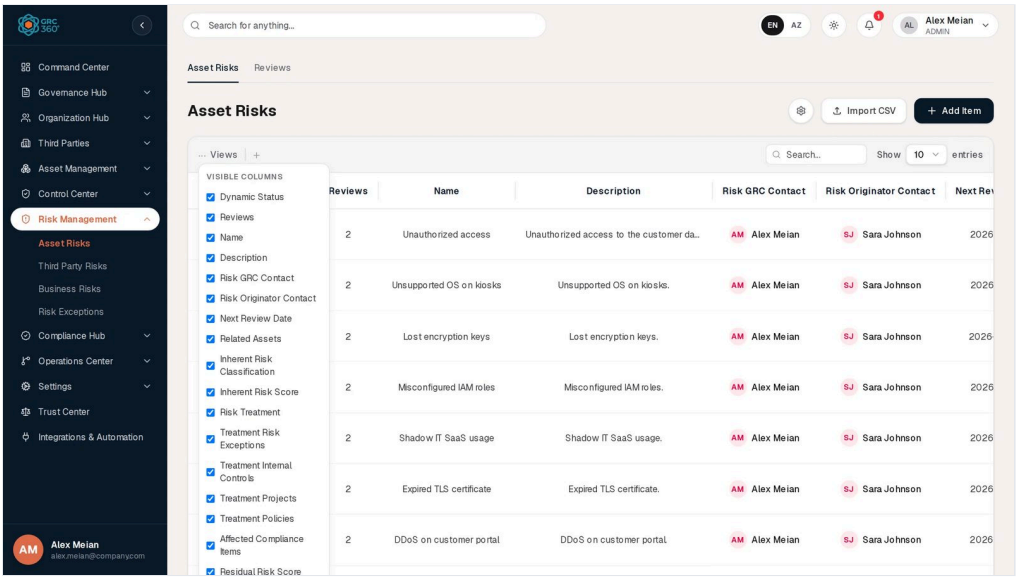
The paging bar ("Showing 1–10 of 15" and page buttons) is under the last row.

The toolbar

The grey bar above the table holds, from left to right:

- **Status filter** (button with a table icon, showing **All items**). Lists every Status value found in the register and shows only rows with the chosen value. It filters on the user-chosen **Status**, not on Dynamic Status, and shows the values as stored (for example `IN_PROGRESS`).
- **View chips** (Projects and Security Incidents only). Ready-made filters with a live count, such as **Expired Tasks 2**. Click a chip to turn it on or off.

- **… Views**. Despite its name, this chooses which **columns** are visible. Untick a column to hide it. Your choice lasts until you leave the page.
- **+**. A shortcut for **Add Item**.
- **Search…** Finds rows containing the typed text in any column.
- **Show 10 / 25 / 50 entries**. Rows per page.



Choosing visible columns

Large registers. These registers are searched, sorted and paged by the server, so they stay fast with thousands of rows:

- Assets, Data Flows
- Controls, Policies & Standards
- the three risk registers and Risk Exceptions
- Vendors, Service Agreements
- Compliance Analysis, Obligations, Compliance Exceptions, External Audit Findings
- Security Incidents, Users
- Notifications, System Log

On these pages the status filter and view chips are not shown, and the search runs about a third of a second after you stop typing.

The table

Sorting. Click a column heading to sort by it (an arrow shows the direction); click again to reverse. When no column is chosen, the newest records come first. Dynamic Status columns cannot be sorted on the large registers listed above, because their values are calculated.

Long values. Cells do not wrap. Long text is cut with an ellipsis; hover over it to read all of it.

Clickable counts. A number in a relation column (for example **15** under Asset Risks on a control) is a link when it is above zero. Hovering it lists the linked records; clicking it opens a panel with each linked record's details. The panel has **Open register** and **Open in new tab** buttons, which open the linked register.

Clicking a row. On most registers a row click does nothing; use the row actions. A few registers open something on row click:

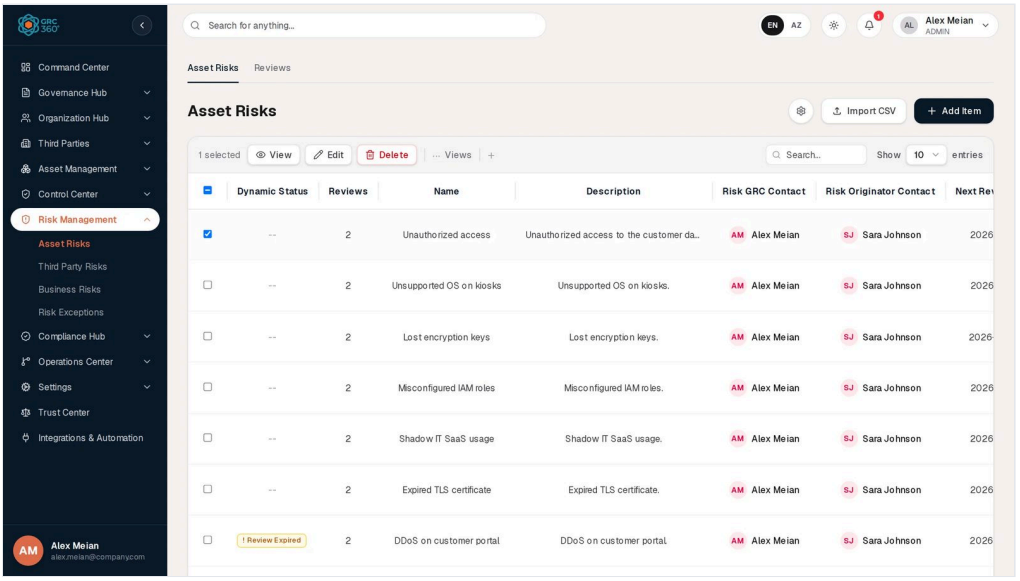
- **Assets**: the asset's reviews.
- **Compliance Packages**: the package's requirement items.
- **Notifications**: marks the notification as read and follows its link.

Row actions

The **Actions** column at the end of each row has up to four buttons:

Button	Does
Eye — **View**	Opens the record read-only in the **View item** dialog.
Speech bubble — **Activity Log**	Opens the record's comments and change history. A red badge shows the number of comments.
Pencil — **Edit**	Opens the record's form with its current values.
Bin — **Delete**	Deletes the record after confirmation.

Wide registers push the Actions column off-screen. Tick a row's checkbox instead: **View**, **Edit** and **Delete** buttons appear in the toolbar for that row.



A selected row with its actions in the toolbar

Selecting several rows

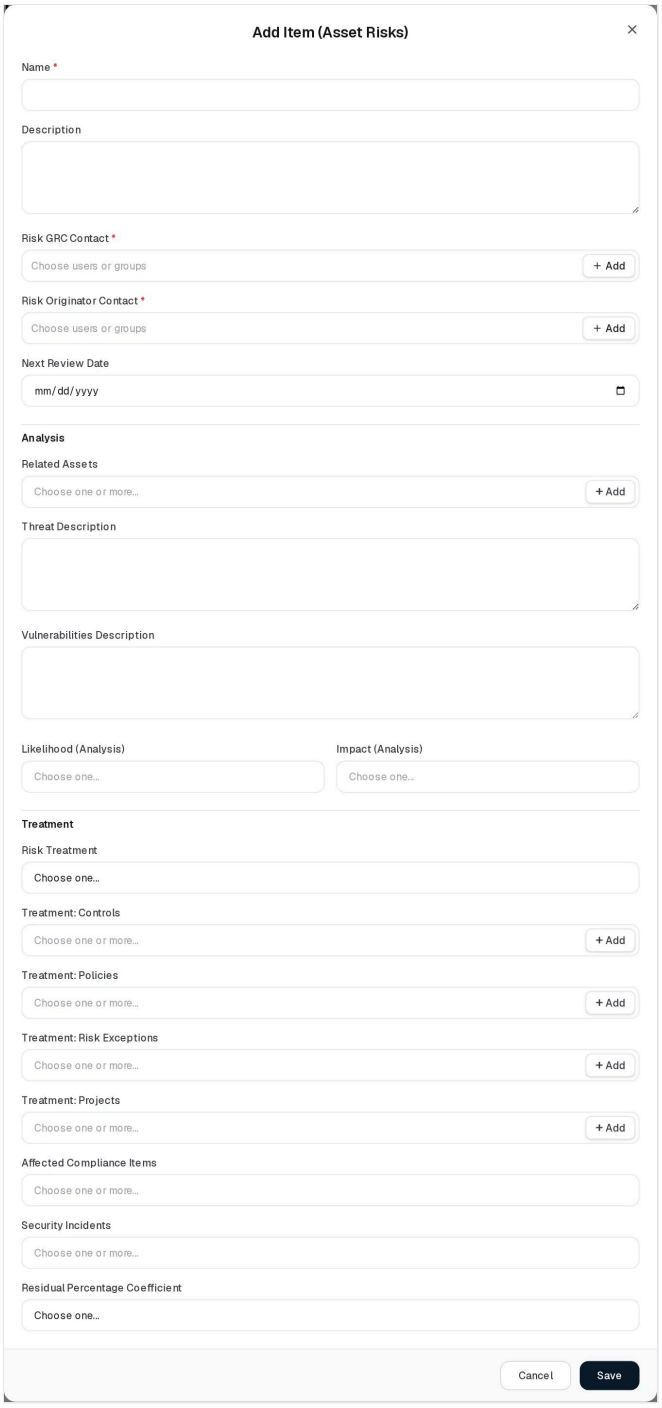
Tick the checkboxes of several rows (the heading checkbox ticks every row on the page). A red bin button with the number of selected rows appears in the toolbar; clicking it deletes them all after one confirmation. The selection is kept when you move between pages, so check the count before deleting.

Viewing a record

View opens a read-only list of every column of the register, including columns you have hidden. Empty values show as `-`. Some registers open their own, richer view instead. The module pages show each one.

Adding and editing a record

Add Item and **Edit** open the same form in a dialog. Fields marked with a red ***** are required. The **Cancel** and **Save** buttons stay at the bottom while you scroll through long forms.



An Add form

When a form will not save

- Each field with a problem is outlined in red, with the reason underneath.
- Most forms also show a message listing every problem, under the heading *This form cannot be saved yet.*
- Typing in a field clears its error.

Closing without saving. Pressing **Escape** or clicking outside the dialog closes the form **without asking**, and what you typed is lost.

Choosing related records

Fields that link to other records (for example **Treatment: Controls** on a risk) open a list under the field when clicked:

- Type to filter the list.
- Tick one or more entries. In single-choice fields, one click picks the entry and closes the list.

- Picked records show as chips; the **x** on a chip removes it, and the **x** at the end of the field clears all.
- Multi-choice lists end with **Clear all**, the number selected and **Done**.

Choosing people

Owner and contact fields (for example **Risk GRC Contact**) accept **users and groups** in one list:

- Users are listed first.
- Groups follow under a **Groups** heading, each with its number of members.

Assignment rights. If your group lacks **Can Assign** or **Can Reassign**, owner fields on these registers may only name yourself:

- Assets
- Asset Risks, Third Party Risks, Business Risks
- Controls, Policies
- Vendors, Service Agreements
- Objectives

A note under the field explains which right is missing and lets you request it. See Permissions and access.

Creating a related record on the spot (+ Add)

Many link fields have a **+ Add** button. It opens the full Add form of the other register in a second dialog; when you save it, the new record is created and selected in the field you came from. For example, while adding a risk you can create the control that treats it without leaving the form.

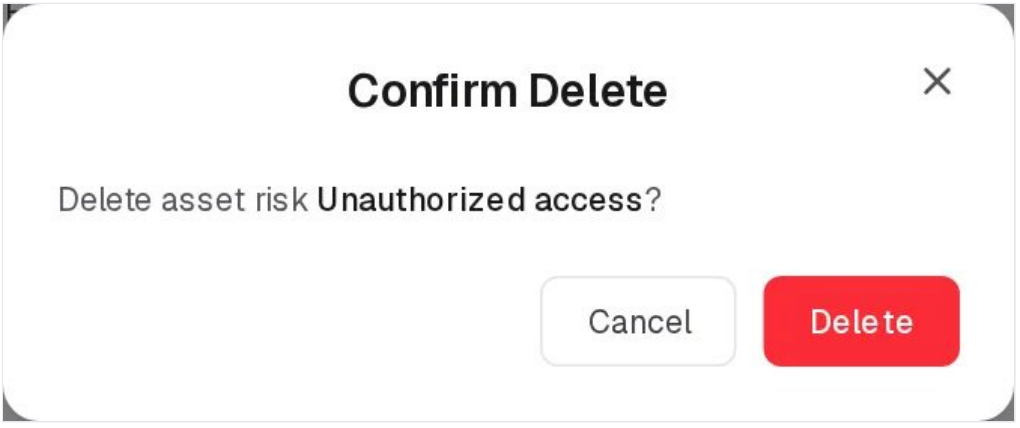
+ Add can create these record types:

- users and departments
- vendors and assets
- the three kinds of risk, and risk exceptions
- controls and policies
- compliance packages
- projects, coverages and issues

The button appears only if you may create that kind of record. It is not offered inside a form that was itself opened with **+ Add**.

Deleting

Delete asks for confirmation (*Delete **name**?*). If the record cannot be deleted, for example because other records depend on it, the dialog stays open and explains why, and **Delete** becomes **Try Again**.

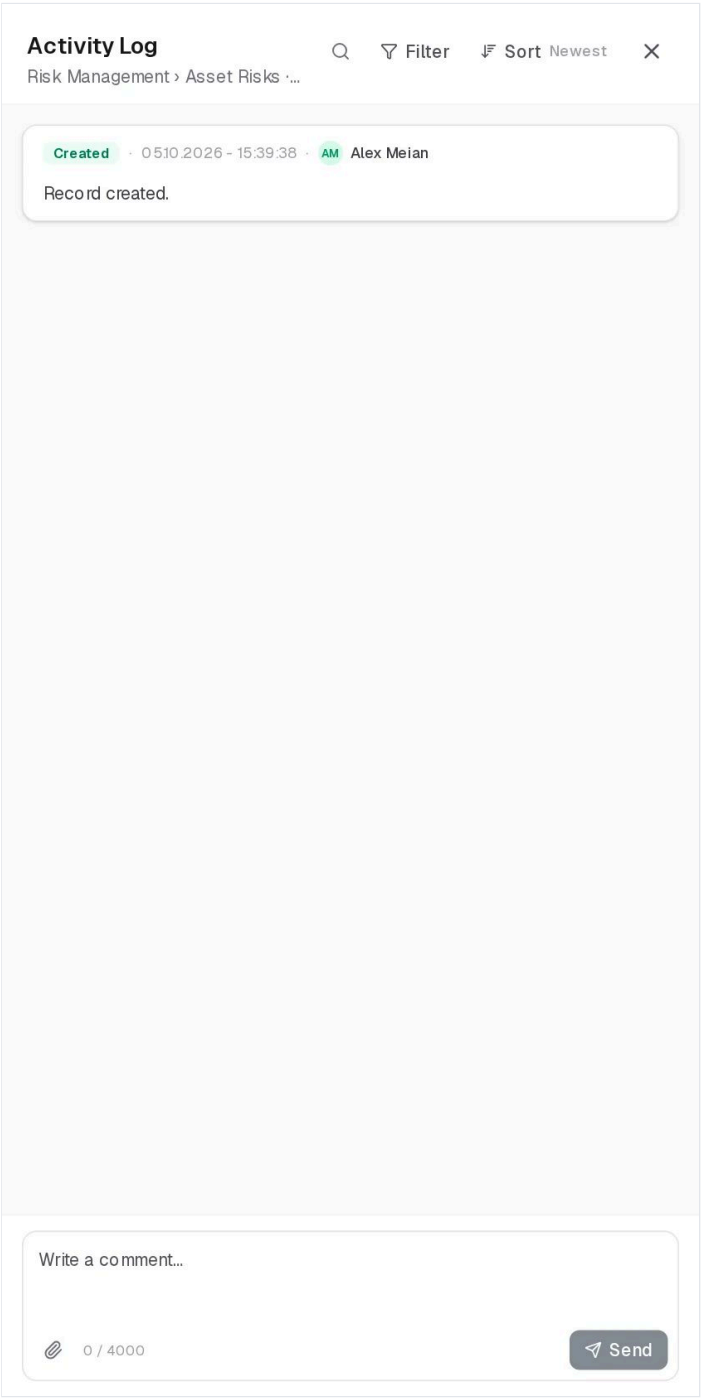


Delete confirmation

Activity Log: comments, attachments and history

The speech-bubble button opens the **Activity Log** for one record, in a panel on the right. It merges two things on one timeline:

- **Comments**, with attachments and replies.
- **Change history**:
  - **Created** and **Deleted** entries;
  - **Updated** entries listing each changed field as *old value → new value*, with who made the change and when.



Activity Log

Finding entries. The panel has a search box, a **Filter** (Comment, Created, Updated, Deleted) and a **Sort** switch (Newest or Oldest).

Writing a comment

- Comments can be up to 4,000 characters.
- Attach files with the paperclip: up to 25 MB per file and 30 MB per comment.
- Send with **Send** or Ctrl/Cmd+Enter.

Replies. Click **Comments & Attachments** on a comment to open its thread. Replies are one level deep.

Deleting comments. You can delete your own comments. Deleting other people's needs the *Manage* comment right.

Counts. The badge on the row button counts all comments, including replies. It is the same for everyone and does not change when you read the thread.

Visibility. Someone who cannot see a record cannot see its Activity Log either.

Not logged. Passwords and other secrets are never recorded in the history.

There are no @mentions in comments.

Tabs

Registers with child records show tabs at the top, for example **Controls | Audits | Issues | Maintenances**.

- Each tab is a full register with its own Add form and its own permissions.
- A tab you are not allowed to open is shown with a lock; clicking it lets you request access.
- A tab lists the child records of **all** parent records. On the Assets page, clicking an asset row opens the **Reviews** tab filtered to that asset, with **‹ Show All Reviews** to remove the filter.

Importing from CSV

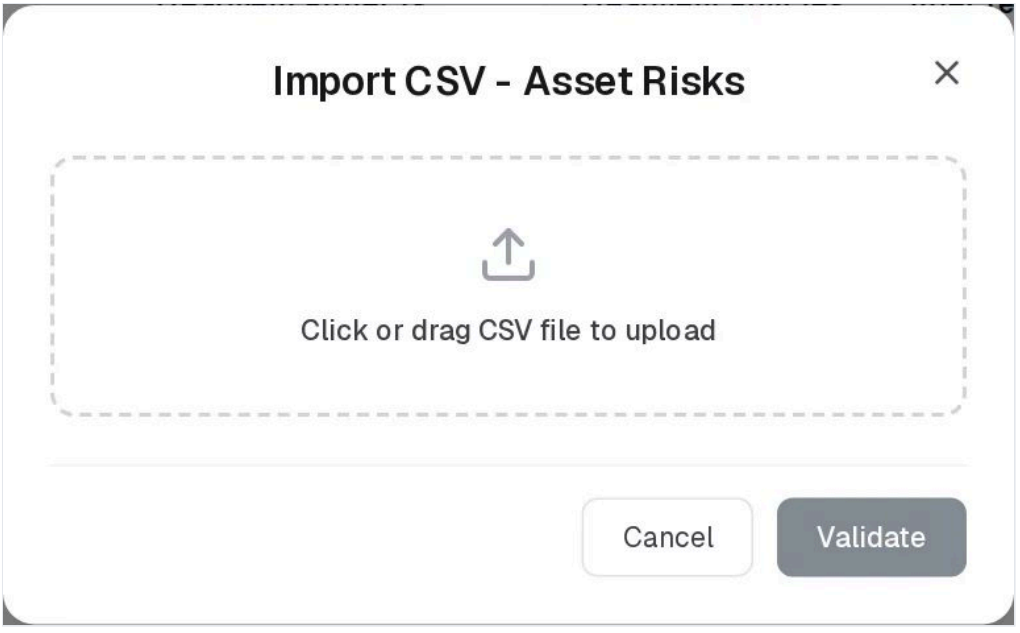
Import CSV is shown on every register.

The message you see first. In this release, clicking it always first shows the message *CSV Import (register name): the import structure is not ready yet.*

Registers where import works. On these, the import dialog then works:

- Users (imports straight away, without the validation preview)
- Compliance Package Items, on the page of one package
- Compliance Analysis (updates the compliance strategy of existing rows)
- Obligations
- Compliance Exceptions
- External Audit Findings
- Projects, with their Tasks and Expenses
- Security Incidents, and the stage definitions under the incidents' Settings

How it works. 1. Choose or drop a `.csv` file of up to 10 MB. 2. Click **Validate** to check it without saving. The result shows how many rows are valid, with the errors per row. 3. Click **Import *n* rows**.



CSV import

On every other register the dialog opens but cannot validate a file yet. See CSV import and export for the state of each register and the file formats.

Exporting. Export CSV downloads the register as a file. It is available on Compliance Package Items, Obligations, Compliance Exceptions, External Audit Findings, Projects, Security Incidents and the System Log.

Messages

Pop-up messages. Confirmations and errors appear briefly at the bottom right. They close by themselves after 4 seconds, or 8 seconds for errors; click **x** to close one sooner.

Problems inside a form or dialog are shown in a box inside it, so the message stays next to what it is about.

Permissions and access

This page explains what you see when you lack a permission and how to ask for it. How administrators set permissions is described in Users, groups and permissions and Groups.

How permissions are organised

Where permissions come from. Permissions are given to **groups**, never directly to a user, except for temporary grants approved through an access request. Your rights are everything your groups allow, combined. One group cannot take away what another group gives.

What a group sets. For each page and each tab, a group has one **access level**:

Level	What you can do on that page or tab
No Access	Nothing. The page is hidden from your sidebar.
View	Open the page, view records, export.
Manage	View, plus create, edit, import, and record audit and maintenance results.
Full Control	Manage, plus delete, change the page's settings, and grant access to others.

Rights that apply across the group. Two further settings apply to the whole group:

- **Comments & Attachments** controls the Activity Log:
  - **None**: no Activity Log.
  - **View**: read comments and history.
  - **Contribute**: also write comments.
  - **Manage**: also delete other people's comments.
- **Assignment Management**: **Can Assign** and **Can Reassign** (see below).

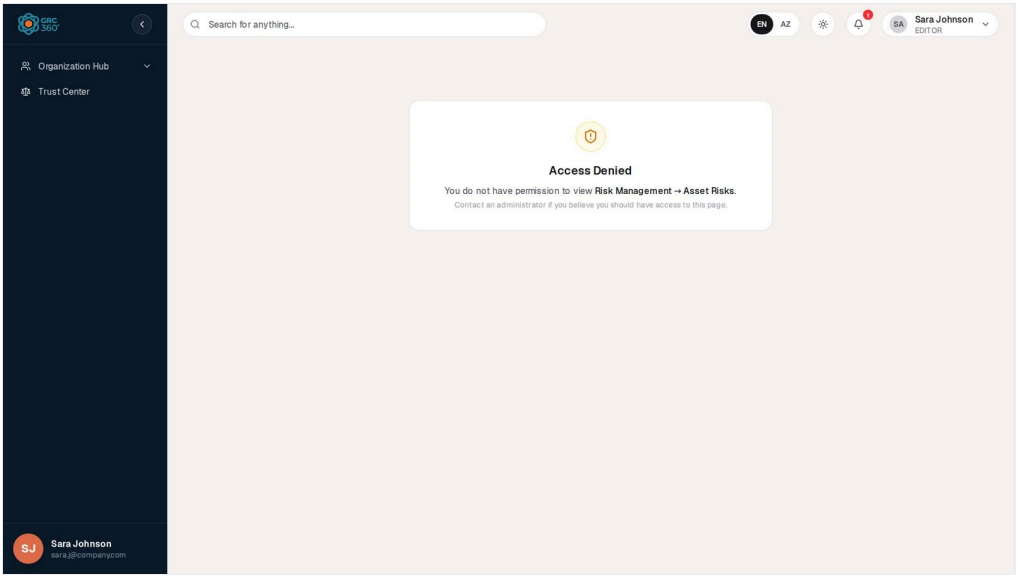
Settings belongs to the **Admin** group only. It cannot be given to any other group or requested.

What you see without a permission

A page you cannot open

In the sidebar. The page is not listed.

If you open its address directly (for example from a link someone sent you), GRC360 shows **Access Denied**: *"You do not have permission to view Risk Management → Asset Risks. Contact an administrator if you believe you should have access to this page."*



Access Denied

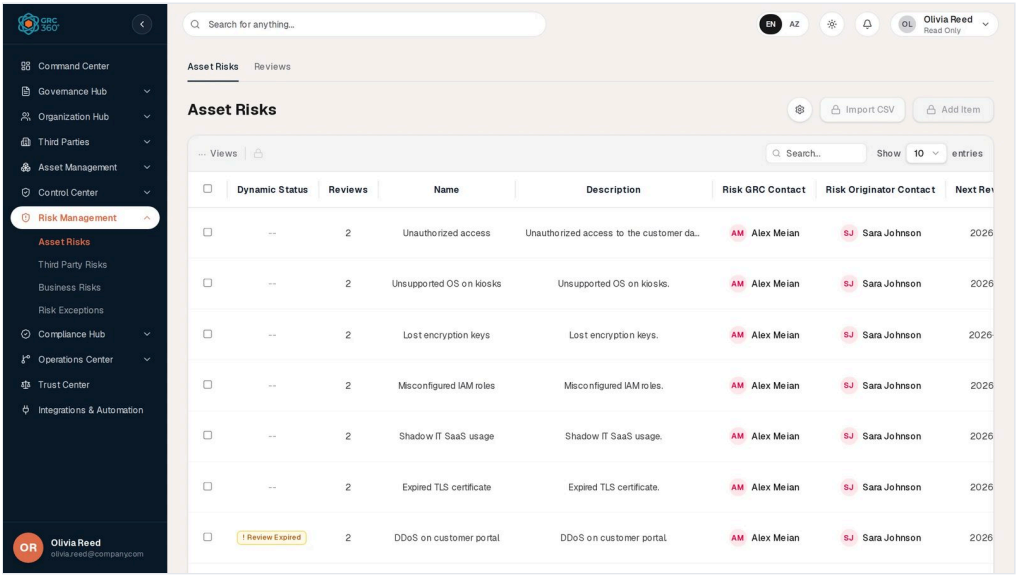
This panel has no request button. Ask an administrator, or use a locked button on a page you can open, as described next.

A button you cannot use

GRC360 keeps buttons visible even when you may not use them, so you can see what the page offers. A button you lack the right for is grey and shows a **lock**. Its tooltip reads *“Requires permission — click to request access”*.

This applies to:

- **Add Item**, **Edit** and **Delete**
- **Import CSV** and **Export CSV**
- tabs
- the Activity Log button and the comment box



Locked buttons for a Read Only user

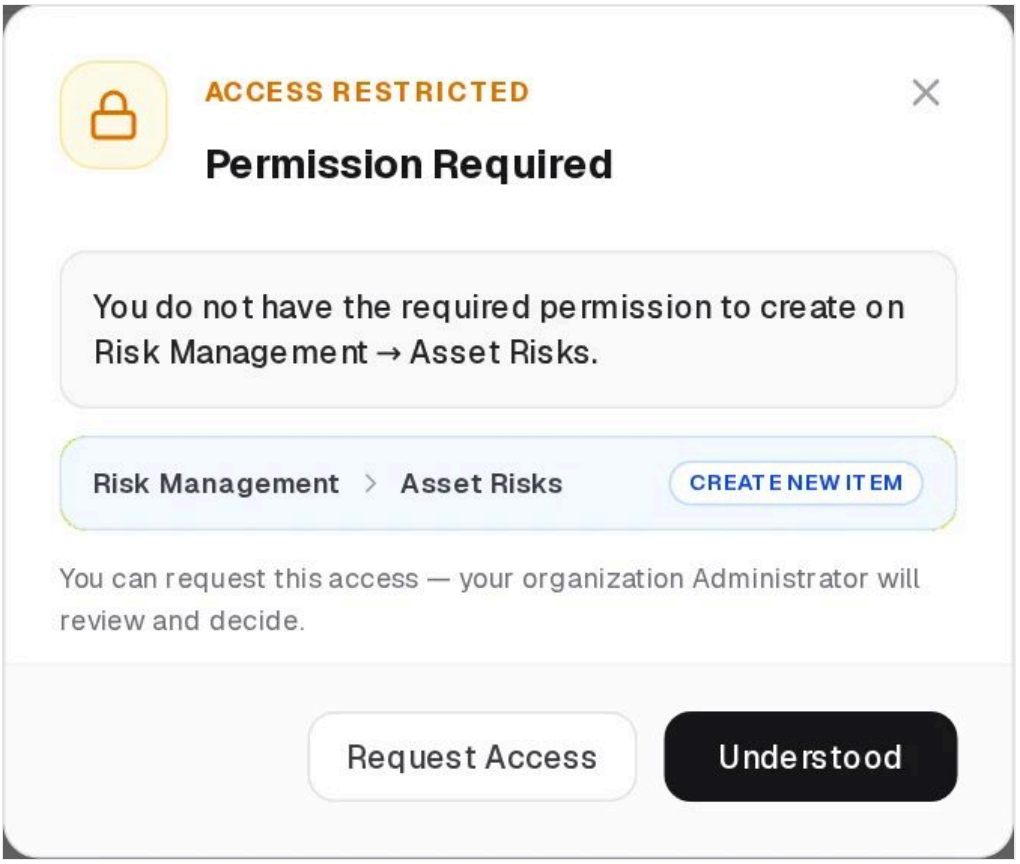
Two exceptions are hidden rather than locked.

- Sidebar entries.
- The **+ Add** buttons inside forms.

Requesting access

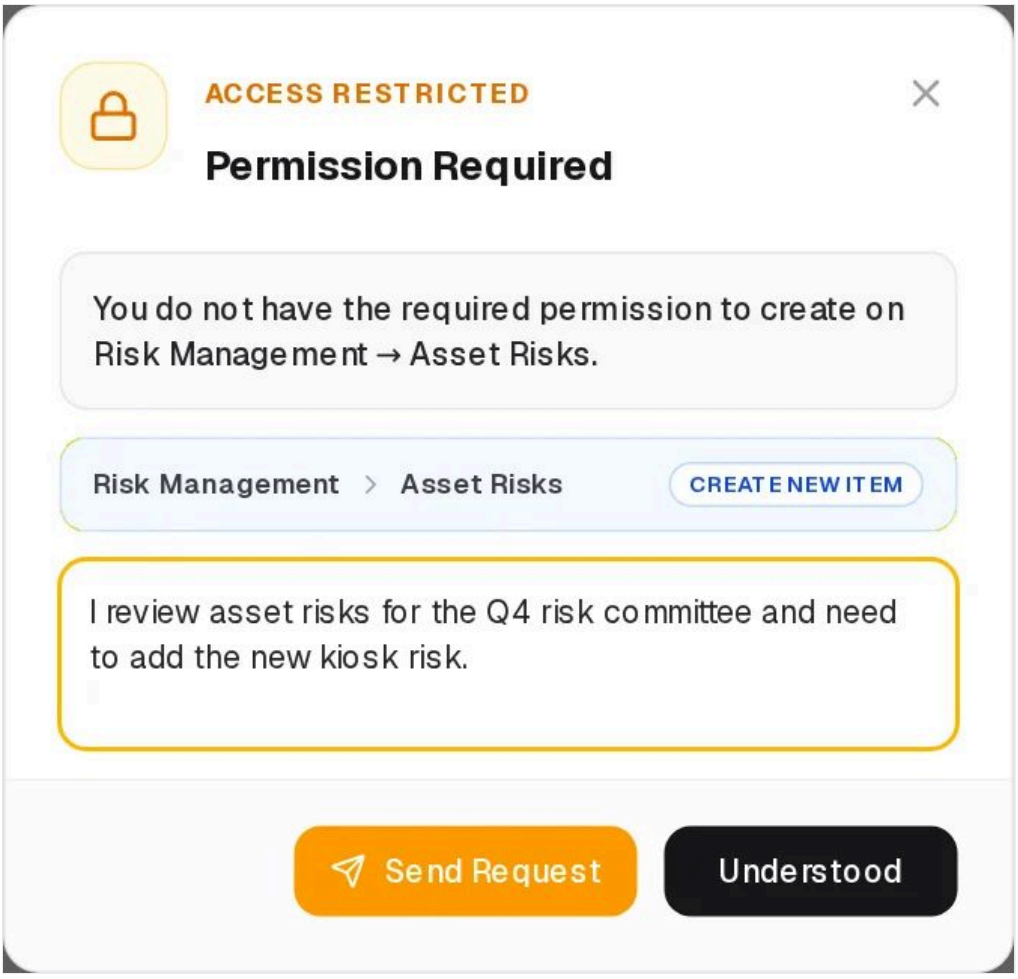
Click any locked button. The **Permission Required** dialog shows:

- what you tried to do, for example *Create New Item*;
- where, for example *Risk Management › Asset Risks*.



Request access

1. Click **Request Access**.
2. Explain why you need it. This is required, up to 2,000 characters, and the administrator reads it.
3. Click **Send Request**.



Writing the justification

After you send it. Every administrator receives a notification. You receive a notification when your request is approved or rejected; a rejection includes the administrator's note.

When access is granted. The locked buttons unlock within about ten seconds. You do not need to sign in again.

How an administrator can grant it.

- **To you only**, for 7 days, 30 days, 90 days or permanently.
- **To one of your groups**. Everyone in that group then receives it.

When there is no request form. If the server refuses an action without saying which permission is missing, the dialog says so and asks you to contact your administrator instead.

Assigning people

Which fields are affected. Owner and contact fields on these registers follow the two assignment rights:

- Assets
- Asset Risks, Third Party Risks, Business Risks
- Controls, Policies
- Vendors, Service Agreements
- Objectives

The two rights.

Situation when you opened the form	What you need to change the field
The field was empty or named only you	**Can Assign** to add anyone else
The field named someone else	**Can Reassign** to change it at all

Without the right.

- The list offers only you.
- Other people's chips cannot be removed.
- **+ Add** is hidden.
- A grey note under the field explains which right is missing; clicking it starts an access request.

Which records you see

A group can see either **All Records** or **Assigned Records Only** in a register. With *Assigned Records Only* you see only the records where you, or a group you belong to, are named in an owner or contact field.

Records you cannot see are left out everywhere:

- in the register itself;
- in linked-record counts;
- in the Activity Log;
- in most global search results.

Checking your own access

Open **Account** from the profile menu. It lists:

- your groups;
- every module and page you can open;
- the devices you are signed in on.

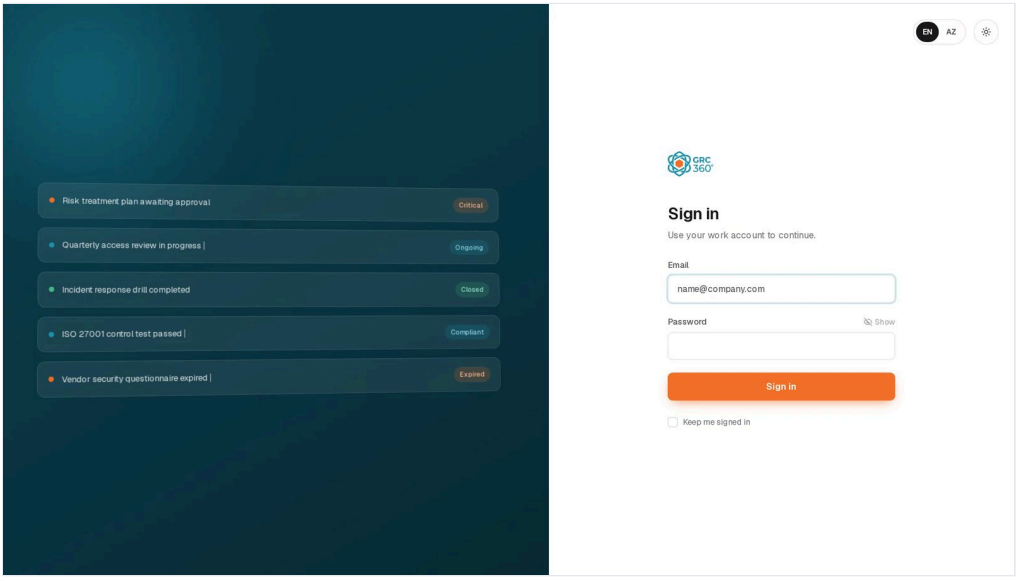
See Your profile and account.

Part 1 — Getting started

Signing in and sessions

Signing in

Open your organisation's GRC360 address. If you are not signed in, every page sends you to the sign-in page.



Sign-in page

1. Enter your work **Email** and **Password**. Use the eye icon (**Show / Hide**) to check what you typed.
2. Optionally tick **Keep me signed in** (under the **Sign in** button). See Session length.
3. Click **Sign in**.

After signing in. You arrive at the page you were trying to open, or at the **Command Center**.

Before signing in. The **EN / AZ** and theme switches in the top-right corner are already available.

If sign-in fails. A red message above the fields shows the reason, for example *Invalid credentials or server error. Please try again.*

What the sign-in page does not offer:

- **Single sign-on buttons.** If your organisation connects GRC360 to its directory (LDAP or Active Directory), you still type your usual directory e-mail and password here; GRC360 checks them against the directory. See Authentication and SSO.
- **"Forgot password" link.** Ask your administrator to set a new password in Users.
- **Self-registration.** Accounts are created by administrators.

Session length

	Normal sign-in	With Keep me signed in
Signed out after inactivity	30 minutes	12 hours
Signed out at the latest	8 hours after sign-in	7 days after sign-in

What counts as activity. Clicking, typing, scrolling with the wheel and touching the screen. Moving the mouse alone does not count.

Several tabs. Activity in any GRC360 tab of the same browser keeps all tabs signed in.

Behind the scenes. Your sign-in is kept in a secure cookie that page scripts cannot read. Reloading the page does not sign you out.

“Still there?”

One minute before an inactivity sign-out, this dialog appears:

> **Still there?** You have been inactive for a while. For security, this session will end in 60s.

- **Stay signed in** continues the session.
- **Sign out now** ends it.

Clicking elsewhere on the page does not dismiss the dialog; answer it with one of the buttons.

If no one answers, the session ends and the dialog changes to **Your session has ended**. Click **Go to sign in** and sign in again. In this release you then land on the Command Center, not on the page you were on.

The same *session has ended* message appears if your session was ended from another device or by an administrator.

Signing out

Signing out of this browser. Open the profile menu (your name, top right) and choose **Sign out**. This signs out every GRC360 tab in that browser.

Signing out other devices. On the Account page you can sign out:

- one specific device;
- every device except this one;
- every device including this one.

Limits

Devices. One user can be signed in on up to 10 browsers or devices at the same time.

Password rules.

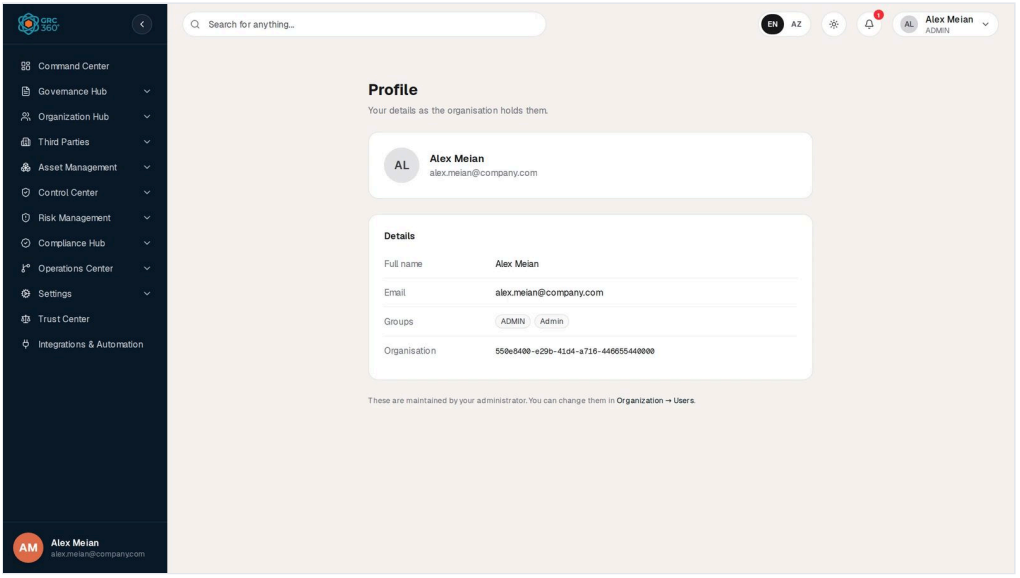
- At least 8 characters.
- When an administrator sets a password, it must be typed twice.

Your profile, account, notifications and support

These pages are personal: every signed-in user can open them, whatever their permissions. Profile, Account and Support are in the profile menu (your name, top right). Notifications is reached from the bell's **See all** link.

Profile

Profile shows your details as your organisation holds them. Nothing on this page is editable by you; your administrator maintains these details.



Profile

What it shows

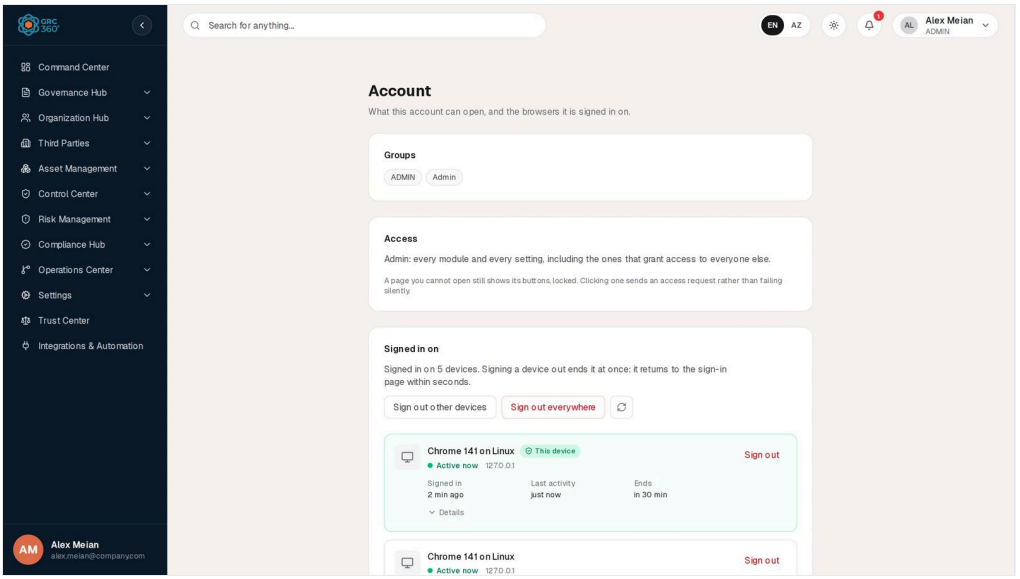
- **Full name**
- **Email**
- **Groups**, or *No groups assigned*
- **Organisation**: the identifier of your tenant

If something is wrong

- Administrators see a link to **Organization** → **Users** to correct it.
- Other users are asked to contact an administrator.

Account

Account shows what your account can open and where it is signed in.



Account

Groups. The groups you belong to.

Access. Every module you can reach, with the pages you can read in it. This is the same list the sidebar is built from.

- Administrators see *Admin: every module and every setting*.
- A user with no readable pages sees a note explaining how to request access.

Signed in on. One row per browser or device where you are currently signed in.

Shown	Meaning
Device name	The browser and operating system
This device	The browser you are using now
Remembered	Signed in with **Keep me signed in**
IP address	Where the session was last used from
Signed in · Last activity · Ends	When the session started, was last used, and will end. Hover for the exact time.
Details	More technical information about the session
Sign out	Ends that one session

Buttons above the list

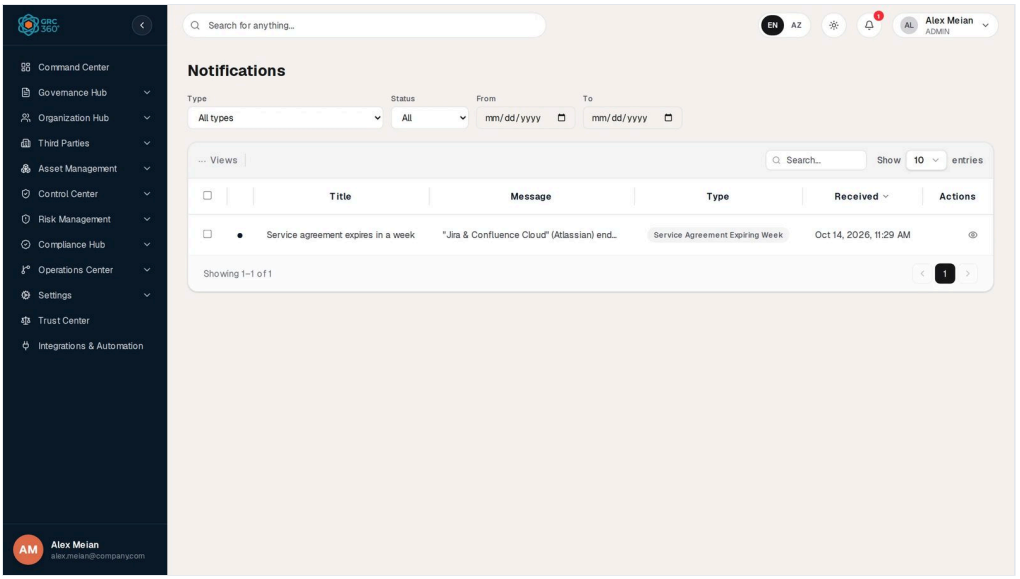
- **Sign out other devices**: ends every session except this one.
- **Sign out everywhere**: ends all sessions, including this one, so you return to the sign-in page.
- A refresh icon.

The list updates by itself every 30 seconds. Ended sessions are listed underneath, five at a time, with **Show more**.

Use this page if you signed in on a shared computer or think someone else is using your account.

Notifications

The **Notifications** page lists every notification you have received, newest first.



Notifications page

Filters

- **Type**: one notification type, or all.
- **Status**: **All**, **Unread only** or **Read only**.
- **From** and **To**: a date range.

Columns

Column	Content
(dot)	Blue while unread
Title	The notification's subject
Message	The details
Type	The notification type, for example `ACCESS_REQUEST`
Received	Date and time

Working with notifications

- Clicking a row marks it read and opens the page it refers to, if it has one.
- Tick rows to use **Mark as read**, **Mark as unread** or delete them.

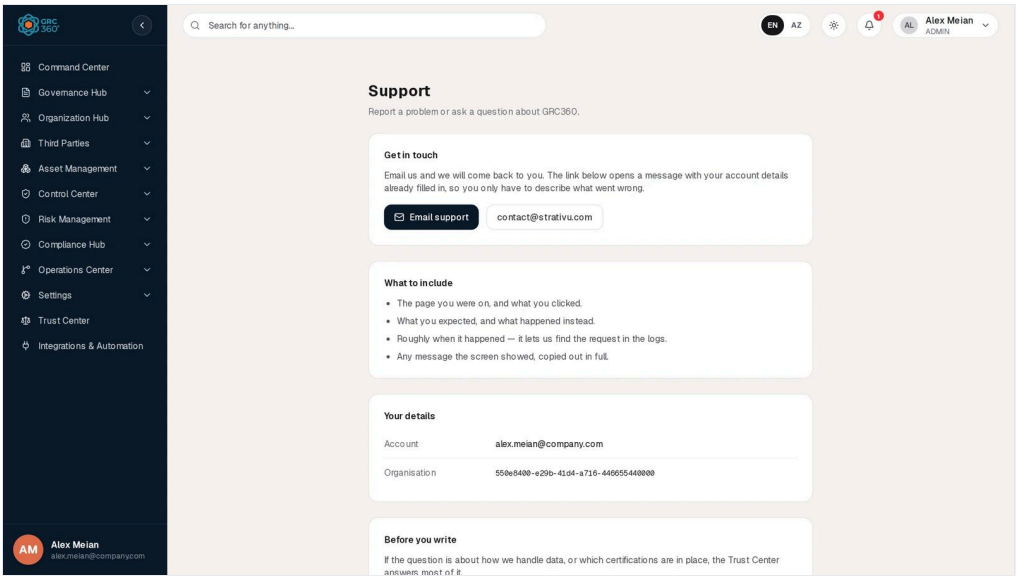
Which notifications exist. GRC360 currently sends notifications for:

- access requests and their decisions;
- being named in a continuity plan task;
- service agreements expiring in 7 days, in 3 days and on the end day.

The full list, with who receives each one, is in Notifications and scheduled jobs.

Support

Support explains how to report a problem or ask a question.



Support

Email support opens a new e-mail to `contact@strativu.com`. It is pre-filled with:

- your account and organisation;
- the time;
- three prompts: what you were doing, what you expected, and what happened instead.

The page also lists:

- what to include in your message, such as screenshots and the page address;
- your details to quote in the message;
- a link to the Trust Center for security and data-handling questions.

First-time setup for a new organisation

Records in GRC360 point to each other, so the order in which you enter them matters. A risk names its asset, owner and treating controls. A control names its policies and compliance packages. An asset names its department. If you enter records in the order below, every link you need already exists when you reach the form that uses it. You can still create a missing record on the spot with **+ Add**, but working in this order is faster and avoids half-filled records.

The steps marked **Admin** need the Admin group.

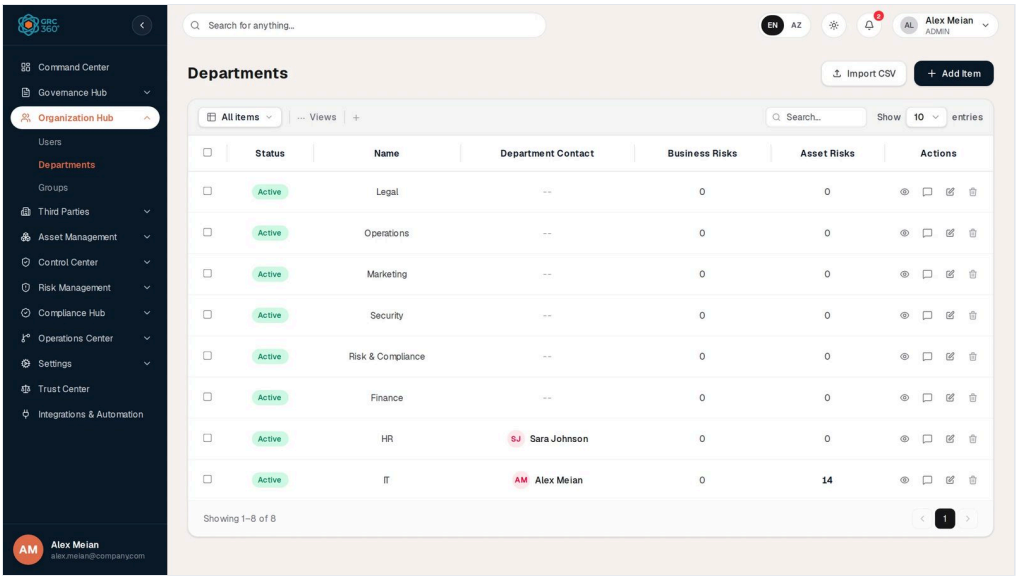
1. Platform settings (Admin)

Task	Where
Choose how users sign in: local passwords or LDAP / Active Directory (OAuth and SAML connectors can be stored, but sign-in through them is not available in this release)	Settings › Authentication
Set up outgoing e-mail so invitations and notices can be sent	Integrations & Automation, E-mail, webhooks and notifications
Check that the database, storage and other services are healthy	Settings › System Health

2. Departments

Create your organisational units first; users, assets and risks refer to them.

- **Where:** Organization Hub › Departments.
- **What to enter:** one record per unit, for example IT, Finance, HR, Legal, Operations, Risk & Compliance.
- **Contact:** set each department’s contact once the users exist (step 4).



Departments

3. Groups and permissions (Admin)

GRC360 comes with three built-in groups: **Admin**, **Read Only** and **Third Party**. Create your own groups for the way your team works. Typical groups:

Group	Typical access
Risk owners	Manage on the risk registers; View on assets and controls
Control operators	Manage on Controls and their Audits and Maintenances; View on policies
Compliance team	Manage on Compliance Hub and Policies & Standards; View on everything else
Auditors	View on everything; Comments & Attachments: View

- **Where:** Organization Hub › Groups.
- **For each group, decide:**
  - the access level per page and tab;
  - Comments & Attachments;
  - whether members may assign other people (**Can Assign / Can Reassign**);
  - whether they see all records or only those assigned to them.

4. Users

Add each person with their department and group.

- **Where:** Organization Hub › Users.
- **If you sign in with LDAP:** users still need a GRC360 user record with the same e-mail address.

5. Coverage and objectives

Record what the programme covers and what it aims to achieve.

- **Coverage:** regions, business units, processes and IT systems in scope. See Governance Hub › Coverage.
- **Objectives:** for example *Achieve ISO 27001 certification*, with a target date and a periodic audit. See Governance Hub › Objectives.

6. Vendors and service agreements

- **Where:**

    - Third Parties › Vendors
    - Third Parties › Service Agreements
- **What to enter:** the suppliers that hold your data or run your services, then their agreements with start and end dates.
- **Why the end date matters:** contacts named on an agreement are notified 7 days and 3 days before it ends, and on its end day.

7. Assets and data flows

- **Where:**
    - Asset Management › Assets
    - Data Flows
- **What to enter:**
    - Systems, data sets, applications and hardware, each with its owner, department and criticality.
    - Where personal data moves between assets and vendors. Data flows include the GDPR questions.

8. Risk scales and appetite

- **Where:** the gear button on the Asset Risks page. See Risk Management.
- **What to check:**
    - the likelihood and impact scales;
    - the calculation method;
    - your risk appetite thresholds.
- **Why before any risk:** every risk score and the *Above Appetite* flag depend on these.

9. Compliance packages and obligations

GRC360 does not include framework texts. For each framework, law or standard you follow:

1. Create a **compliance package** (for example *ISO/IEC 27001:2022*).
2. Add its requirement items by chapter, or import them from CSV. See Compliance Packages.
3. Record the legal duties under Obligations, for example the Law on Personal Data or Central Bank regulations.

10. Policies, controls and continuity plans

1. Policies & Standards: your governing documents, with version and review dates.
2. Controls: each safeguard, linked to its policies and the compliance packages it satisfies, with an audit schedule.
3. Continuity Plans: your recovery plans with their steps and tests.

11. Risks and exceptions

Now each risk can point to everything it needs:

- its assets or vendors;
- its owners;
- its likelihood and impact;
- the controls, policies and projects that treat it.

Where: Asset Risks, Third Party Risks, Business Risks.

Accepting a risk. Record a formal acceptance in Risk Exceptions.

12. Compliance analysis

Assess each package item by item. See Compliance Analysis.

13. Projects and incident stages

- **Projects:** create projects for the improvements your risks and findings call for. See Projects.

- **Incident stages:** define the stages your incident response follows, for example Detection, Containment, Eradication, Recovery and Lessons learned. See Security Incidents › Stages.

Bringing in existing data

Where import works today. Import from CSV is available for:

- Users
- Compliance Package Items (inside a package), which is how framework requirements are usually loaded
- Obligations
- Compliance Exceptions
- External Audit Findings
- Projects, with their Tasks and Expenses
- Security Incidents and incident stage definitions

Other registers. Enter records through the forms, or ask your Strativu contact about a bulk load through the API.

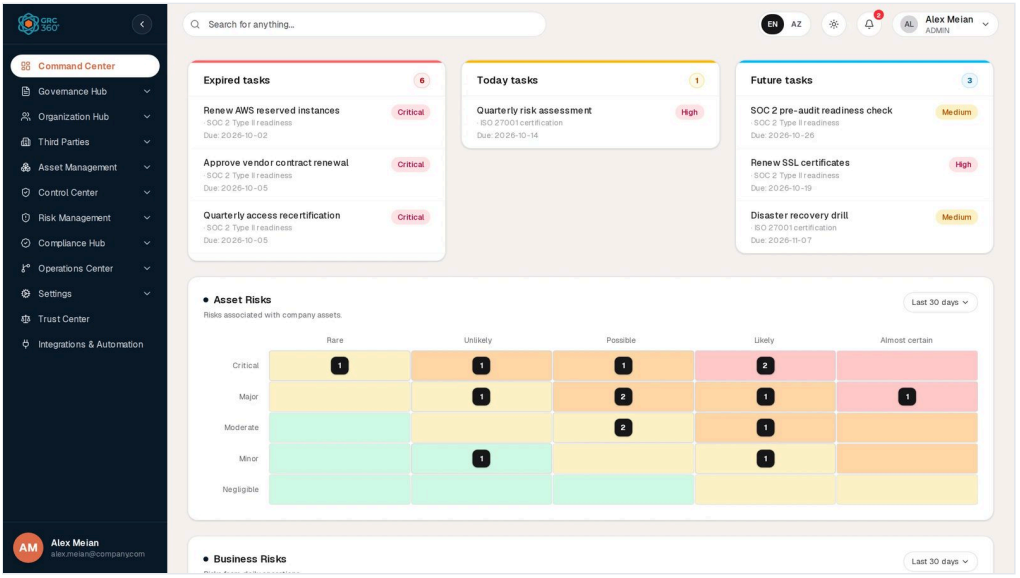
See CSV import and export.

Part 2 — Module reference

Command Center

> **Module:** Command Center › Command Center (dashboard) · **Route:** `/command-center` · **Permission key:** `command_center.dashboard`

The Command Center is the landing page after sign-in. It is a read-only dashboard: it shows the project tasks that are overdue, due today and due later, three risk heat maps (Asset Risks, Business Risks, Third Party Risks), the progress of each compliance package, and the overall progress of projects. Nothing is entered here. Every number is computed by the server from the registers each time the page loads, and every widget leads back to a register where the underlying records are maintained.



Command Center

At a glance

A record is	None. The page has no records of its own; it aggregates other registers.
Typical owner	Everyone with access; administrators see all task cards, other users see only their own.
Links to	Operations Center › Projects (Tasks tab), Risk Management › Asset Risks, Business Risks, Third Party Risks, Compliance Hub › Compliance Packages and Compliance Analysis
Linked from	The login page sends every user here after sign-in (unless the login URL carried another target).
Tabs	None
Automations	Live refresh (about every 10 to 12 seconds when another user changes a feeding register). No caching and no scheduled job is involved; see Automations.

The dashboard (list view)

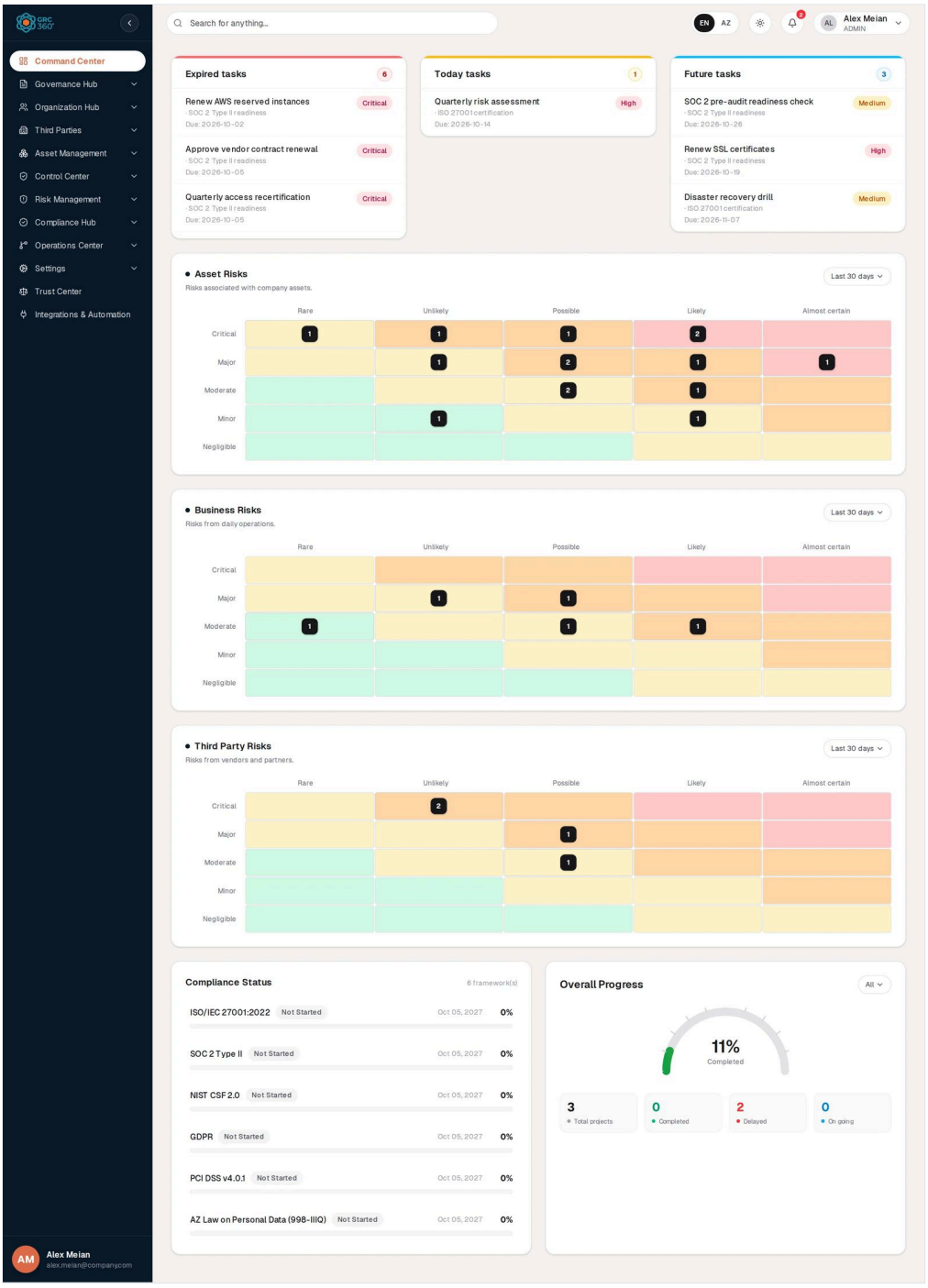
The page is not a register grid, so the shared grid behaviour in Working with registers does not apply. From top to bottom it shows:

1. Three task columns: **Expired tasks**, **Today tasks**, **Future tasks**.
2. Three heat maps: **Asset Risks**, **Business Risks**, **Third Party Risks**, each with its own period selector.

3. Two panels side by side: **Compliance Status** and **Overall Progress**.

While the data loads the page shows “Loading dashboard…”. If the request fails it shows “Failed to load dashboard” in red.

The full page with the demo data looks like this (all three heat maps, then Compliance Status and Overall Progress at the bottom):



Command Center, full page

Task columns: Expired tasks, Today tasks, Future tasks

Each column is a card with a coloured top bar (red for Expired, amber for Today, blue for Future) and a count badge in the header. When a column is empty it reads “No tasks to show here”. A column shows about three tasks and scrolls inside the card when it holds more: in the demo **Expired tasks** has the badge 6 but shows three rows until you scroll it.

Which records feed the columns. The only source is the **Tasks** tab of **Operations Center › Projects** (project tasks). No other register (control maintenances, continuity plan tasks, objective audits, reviews) appears here. For each project task that is not deleted:

Condition	Column
The task has no **Deadline**	The task is not shown in any column.
Deadline is before today	**Expired tasks**
Deadline is today	**Today tasks**
Deadline is after today	**Future tasks**

“Today” is the server’s date. The columns do not look at **Completion Rate**: a task that is 100 % complete but whose deadline has passed still appears under **Expired tasks**. Tasks are listed in the order the server reads them, not sorted by date.

What one task row shows.

Element	Source
Title (first line)	The task’s **Description**
Second line, before the dot	The name of the linked **Task Owner** account (full name, or the e-mail address when the account has no name). When no account is linked, the legacy owner text is used; when that is empty too, nothing is shown before the dot.
Second line, after the dot	The **Name** of the project the task belongs to
Due:	The task’s **Deadline** (YYYY-MM-DD)
Badge on the right	A priority computed from the deadline (see below). It is not a field on the task.

Priority badge	Rule
Critical	Deadline before today (every task in **Expired tasks**)
High	Deadline today or within the next 7 days
Medium	Deadline 8 to 30 days ahead
Normal	Deadline more than 30 days ahead

Rows highlight on hover but are not links: clicking a task does not open it. To work on a task, open **Operations Center › Projects**, open the project and use its **Tasks** tab.

Administrator view versus everyone else.

Who	What the three columns contain
A user whose sign-in token carries the system role ADMIN or SUPER_ADMIN (for example the demo administrator Alex Meian, or a break-glass super-admin account)	Every dated project task in the organisation.
Everyone else	Only the tasks whose **Task Owner** is linked to their own user account. Tasks with only a typed owner name, or no owner, are not shown to them.

In the demo data the project tasks carry no linked owner, so a non-administrator sees three empty columns.

Risk heat maps: Asset Risks, Business Risks, Third Party Risks

Three cards with the same layout. Each has a title, a one-line description, a period selector on the right and a 5 × 5 grid.

Card	Description shown	Register counted
Asset Risks	“Risks associated with company assets.”	Risk Management › Asset Risks
Business Risks	“Risks from daily operations.”	Risk Management › Business Risks
Third Party Risks	“Risks from vendors and partners.”	Risk Management › Third Party Risks

Axes. Rows are impact, from top to bottom **Critical**, **Major**, **Moderate**, **Minor**, **Negligible**. Columns are likelihood, from left to right **Rare**, **Unlikely**, **Possible**, **Likely**, **Almost certain**.

How a risk is placed in a cell. The server reads two fields from every risk that is not deleted: **Likelihood (Analysis)** and **Impact (Analysis)**. These fields hold a classification chosen from the risk settings of that register; the server looks up the numeric **value** of that classification in the organisation's own classification scale and maps it as follows:

Classification value	Likelihood column	Impact row
5 or more	Almost certain	Critical
4	Likely	Major
3	Possible	Moderate
2	Unlikely	Minor
1	Rare	Negligible

A risk is counted in a cell only when both values are set and greater than zero. A risk with only one of the two analysis fields filled is not shown in the grid. Each risk counts once, in exactly one cell. Treatment (residual) values are not used: the heat maps show the analysis (inherent) position.

What a cell shows. A cell holding at least one risk shows a dark chip with the count. Empty cells show no number. Hovering a cell shows a tooltip such as "Major × Possible: 2". Cells are not clickable.

Cell colours. The colour depends only on the cell's position, not on the count. With the row counted 0 (Critical) to 4 (Negligible) and the column 0 (Rare) to 4 (Almost certain), the score is `(4 − row) + column`:

Score	Colour
7 or 8	Red
5 or 6	Orange
3 or 4	Amber
0 to 2	Green

These bands are fixed in the dashboard and are independent of the risk appetite or analysis matrix configured in Risk Management settings.

Period selector. The selector offers **Last 7 days**, **Last 30 days** (default) and **Last 90 days**. It keeps only risks *created* within that many days before now; a risk without a creation timestamp is always counted. The three cards share one selection: changing the period on any card changes it on all three and reloads the page data. The selection is not remembered when you leave the page.

In the demo data, with **Last 30 days**:

Card	Scored risks	Cells holding risks (impact × likelihood: count)
Asset Risks	15	Critical × Rare 1, Critical × Unlikely 1, Critical × Possible 1, Critical × Likely 2; Major × Unlikely 1, Major × Possible 2, Major × Likely 1, Major × Almost certain 1; Moderate × Possible 2, Moderate × Likely 1; Minor × Unlikely 1, Minor × Likely 1
Business Risks	5	Major × Unlikely 1, Major × Possible 1; Moderate × Rare 1, Moderate × Possible 1, Moderate × Likely 1
Third Party Risks	4	Critical × Unlikely 2; Major × Possible 1; Moderate × Possible 1

Compliance Status

The left panel at the bottom is headed **Compliance Status**, with “N framework(s)” in small grey text on the right. It lists every active compliance package as one row: the package name followed by its status badge, then on the right the date and the percentage in bold, and under the row a full-width progress bar. With no active packages it reads “No frameworks yet”. The percentages and bars fill with a short animation when the page loads.

Element	Rule
Package name	The package’s name from Compliance Hub › Compliance Packages. Inactive and deleted packages are left out.
Status badge	**Completed** at 100 %, **In Progress** above 0 %, **Not Started** at 0 %.
Date on the right	The package’s creation date plus one year, shown as “Oct 05, 2027”. Packages have no audit date of their own; this date is a placeholder, not a scheduled audit.
Percentage and bar	`(items judged Compliant + half of the items judged Partially Compliant) ÷ all items of the package × 100`, rounded. Items are the package’s requirement items as assessed in Compliance Analysis. A package without items shows 0 %.
Bar colour	Green at 80 % or more, amber at 50 % to 79 %, red below 50 %.

In the demo data the header reads “6 framework(s)” and the rows are **ISO/IEC 27001:2022**, **SOC 2 Type II**, **NIST CSF 2.0**, **GDPR**, **PCI DSS v4.0.1** and **AZ Law on Personal Data (998-IIIQ)**. Each shows a grey **Not Started** badge, the date “Oct 05, 2027”, **0%** and an empty bar, because no requirement item has been judged yet.

Overall Progress

The right panel, headed **Overall Progress** with the scope selector (showing **All**) on the right, counts projects from Operations Center › Projects. It shows a half-circle gauge with the percentage in large type and “Completed” under it (the arc is coloured from green through amber to orange as it fills), and below the gauge four tiles side by side: **Total projects** (grey dot), **Completed** (green), **Delayed** (red) and **On going** (blue), each with its number above the label.

Element	Rule
Gauge, “% Completed”	The average of every counted project’s progress. A project’s progress is the average **Completion Rate** of its tasks (0 when it has no tasks).
Total projects	Every counted project that is not deleted.
Completed	Projects whose Dynamic Status is Closed (the owner closed it, or every task is at 100 %).
Delayed	Projects whose Dynamic Status is Expired (project deadline passed) or Task Expired (a task’s deadline passed).
On going	Projects whose Dynamic Status is Ongoing.

Projects in the Planned state (no active tasks) count only in **Total projects**, so the three coloured tiles do not always add up to the total.

Scope selector. The selector in the panel header offers **All** (default), **Asset Risks**, **Business Risks** and **Third Party Risks**. Choosing a register keeps only the projects that at least one risk of that register names in **Treatment: Projects**. The choice is not remembered when you leave the page.

In the demo data, with **All**, the gauge reads **11%** Completed and the tiles read 3 **Total projects**, 0 **Completed**, 2 **Delayed** and 0 **On going** (the third project is Planned and so appears only in the total).

Creating a record

None. The dashboard has no Add button and no forms. Tasks, risks, packages and projects are created in their own registers.

Viewing and editing a record

None. No widget opens a record. Use the sidebar to open the register behind a widget.

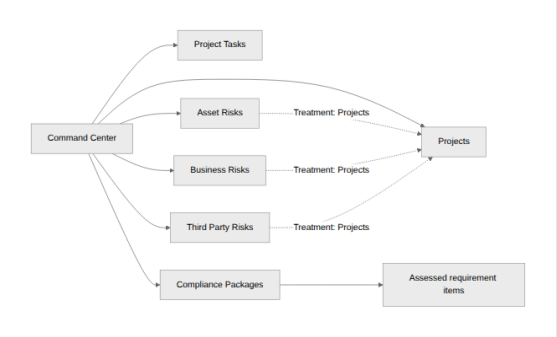
Statuses

Value	Set by	Meaning
Critical / High / Medium / Normal (task badge)	System	Urgency computed from the task deadline, see Task columns.
Completed / In Progress / Not Started (Compliance Status badge)	System	Computed from the package percentage.
Completed / Delayed / On going (Overall Progress tiles)	System	Grouping of project Dynamic Status values Closed; Expired and Task Expired; Ongoing.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Project task	Read	Every dated, non-deleted task	Task columns
Project	Read	Task's project name; project progress and Dynamic Status	Task row second line; Overall Progress
Asset / Business / Third Party Risk	Read	Likelihood (Analysis) and Impact (Analysis) values, creation date	Heat maps
Risk → Project	Read	Treatment: Projects on the risk	Overall Progress scope filter
Compliance package and its items	Read	Item judgement (Compliant, Partially Compliant)	Compliance Status

None of these counts is clickable.

Automations and notifications

- **Computed on every load.** The server recalculates the whole dashboard on each request. There is no stored snapshot and no cache in this release (the application cache is configured off, and the dashboard result is not cached).
- **Live refresh.** While the page is open it reloads silently when another user or tab changes risks, project tasks, incidents, compliance assessments, internal controls or governance objectives. The change feed is polled about every 10 to 12 seconds.
- **DashboardCacheScheduler.** The code contains an hourly job that clears all caches. It is implemented but not active in this release: scheduled jobs are not enabled in the backend, and the job is also only created when a Redis cache is configured. It has no visible effect.

- **Dashboard notification helpers.** The code contains helpers for “Critical Risk Detected”, “Audit Date Approaching” and similar dashboard alerts, but nothing calls them and they only write a server log line. No notification is raised by the dashboard.
- Each dashboard request is recorded in the server’s application log (operation DASHBOARD_ACCESS). It does not appear in Settings › System Log.

Permissions

Action	Needed access
See the page and its sidebar entry	**View** on Command Center › Command Center (`command_center_dashboard_read`). The Groups dialog offers only **No Access** and **View** for this page.
See every task in the task columns	A sign-in token with the system role ADMIN or SUPER_ADMIN. Membership of the Admin group alone is not what the server checks.
See only own tasks	Any user with View access.
Create / Edit / Delete	Not applicable.
Comment / Assign	Not applicable (the dashboard has no comment thread).

The heat maps, Compliance Status and Overall Progress are not filtered by the user’s own permissions on the source registers, by the group’s **Data visibility** (All Records or Assigned Records Only) or by department. A user with View on the dashboard sees organisation-wide counts even for registers they cannot open. The server computes a department scope for the user but does not apply it to any widget.

A user without View on the dashboard still lands on `/command-center` after sign-in and sees the **Access Denied** panel (“You do not have permission to view Command Center → Command Center.”). They can continue from the sidebar.

How to

See which tasks are overdue

1. Open **Command Center**.
2. Read the **Expired tasks** column. In the demo data it shows 6 tasks, for example “Renew AWS reserved instances” (SOC 2 Type II readiness, Due: 2026-10-02).
3. To update one, open **Operations Center › Projects**, open the project named after the dot (here “SOC 2 Type II readiness”) and go to its **Tasks** tab.

Compare the risk picture over different periods

1. On the **Asset Risks** card, open the selector that reads **Last 30 days**.
2. Choose **Last 90 days**. All three heat maps reload with risks created in the last 90 days.
3. Hover a cell (for example **Critical × Likely**) to read its count in the tooltip.

Check how far treatment projects for business risks have got

1. In **Overall Progress**, open the selector that reads **All**.
2. Choose **Business Risks**. The gauge and tiles now count only projects named in **Treatment: Projects** on at least one business risk.
3. A high **Delayed** count means those projects have a passed project or task deadline; open **Operations Center › Projects** and use the **Expired Tasks** view to find them.

Find out why a compliance package shows 0 %

1. In **Compliance Status**, note the package name, for example “ISO/IEC 27001:2022”.
2. Open **Compliance Hub › Compliance Analysis** and filter on that package.
3. Judge its requirement items. Each item judged Compliant raises the percentage; Partially Compliant counts half.

CSV import

None. The dashboard has no import or export.

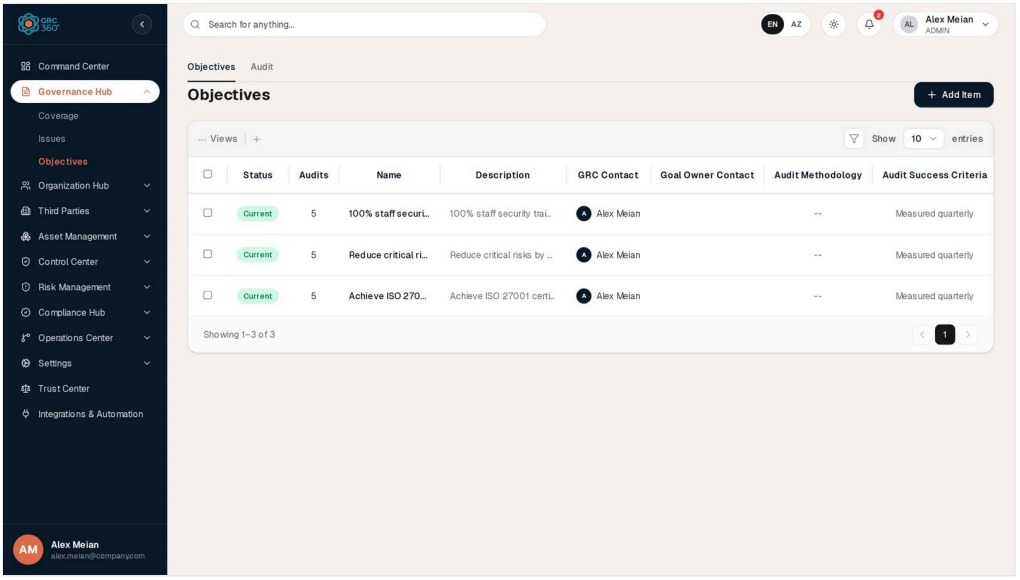
Limitations and known issues

- Completed tasks (Completion Rate 100 %) are still listed under **Expired tasks**, **Today tasks** or **Future tasks** according to their deadline.
- Only project tasks feed the task columns; continuity plan tasks, maintenances, audits and reviews are not shown.
- Task rows are not clickable and do not link to the task.
- The full-administrator task view depends on the system role ADMIN in the sign-in token. A user who was put in the Admin group through Organization Hub › Users does not get that system role, so (from the code) they see only their own tasks like any other user.
- The three heat maps share a single period selection.
- The heat maps, Compliance Status and Overall Progress ignore department scope, row visibility (Assigned Records Only) and the user’s permissions on the source registers.
- The heat-map colour bands are fixed and do not follow the risk appetite settings.
- The date beside each compliance package is the creation date plus one year, not a real audit date.
- After sign-in every user is sent here, including users without access to the dashboard, who see the Access Denied panel.

Governance Hub

> **Module:** Governance Hub · **Route:** `/governance` (opens **Coverage**) · **Permission module:** `governance`

The Governance Hub frames the GRC programme itself: what it covers (**Coverage**), what is wrong with it (**Issues**) and what it is trying to achieve (**Objectives**). Objectives are the centre of the module. Each goal can be audited on a schedule, linked to the projects, controls, risks, policies and issues it depends on, and marked *Achieved*, which closes out the linked work.



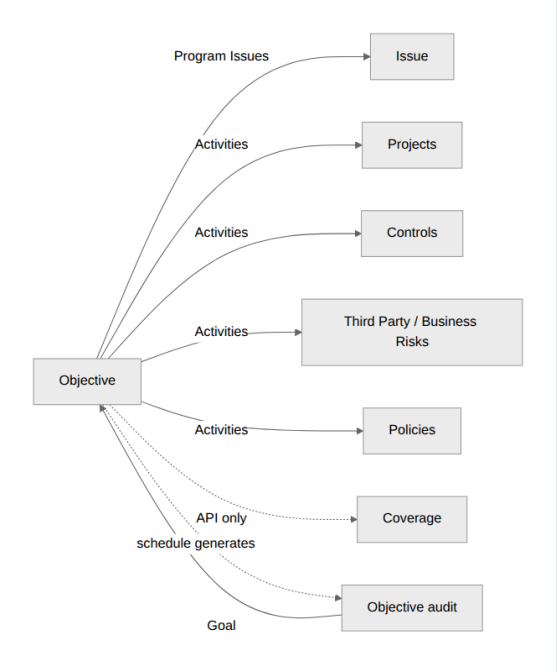
Objectives register

Pages

Page (sidebar label)	Route	Permission key	What it holds
Coverage	`/governance/coverage`	`governance.coverage`	The scope of the programme: regions, business units, processes and IT systems, with a version and a GRC contact.
Issues	`/governance/issues`	`governance.issues`	Governance issues found in the programme, with a GRC contact, an issue contact and a source (Internal, External).
Objectives	`/governance/objectives`	`governance.objectives`	Goals of the programme with their audit schedule and linked work.
Objectives › Audit	same route, **Audit** tab	`governance.objectives_audits`	The audits of all goals, generated from each goal's schedule or added by hand, with results and evidence.

Opening `/governance` without a page redirects to **Coverage**.

How the records fit together



- An **objective** points at the work it depends on. All links are made on the objective's form (tabs **Activities** and **Issues**); the linked records do not show the objective.
- An **objective audit** always belongs to one objective. Most are generated from the goal's **Audits** tab (Specific dates or a Periodical schedule); others are added by hand on the **Audit** tab.
- **Coverage** records stand alone in the UI. The backend can link objectives to coverages, but no screen does.
- **Issues** are linked to objectives only. Control issues in the Control Center are a separate register.

Statuses at a glance

Register	Status a person sets	Computed by the system
Coverage	DRAFT, ACTIVE, ARCHIVED, SUPERSEDED offered; only DRAFT is actually stored	None shown
Issues	Current, Discarded, Draft	A hidden workflow state (Open, Resolved, …) set by the objective automation
Objectives	Draft, Current, Discarded, Achieved	Audits count; a progress percentage (not shown)
Objective audits	Audit Result (Failed, Passed, In review, or your own options)	Dynamic Status Pass, Fail or In Progress, derived from the result

Automations

- **Audit schedule**: saving a goal with *Audits required* creates its audit rows (each Specific date plus the same date a year later, or a Periodical series up to one year after the first date; past dates dropped) and removes generated rows that no longer fit and have no result.
- **Goal achieved**: saving a goal as *Achieved* sets its linked issues to *Discarded* (workflow *Resolved*), its controls to *Production*, its third party risks to *Closed* and its business risks to *Mitigated*. Projects are not changed.
- **Progress**: calculated on every read from the share of linked work that is finished. Returned by the API, not shown on screen.
- **Reminders**: the daily *ObjectiveAlertScheduler* job (09:00) that would send *Objective Audit Due* and *Objective Target Overdue* notifications is implemented but not active in this release, because scheduled jobs are not enabled in the backend. The Governance Hub sends no notifications.

Permissions

Each page, and the **Audits** section of Objectives, has its own access level in the group settings (No Access, View, Manage, Full Control), plus the group's Comments & Attachments level. Recording an audit result needs the *Audit Results* right, which is part of Manage on Objectives › Audits. Objectives is an assignment register: naming other people as GRC Contact, Goal Owner Contact, Audit Owners or Audit Evidence Owners needs **Can Assign** (and **Can Reassign** to change people already named), and a group set to *Assigned Records Only* sees only the goals that name its members. See Permissions and access.

CSV import and export

None of the three pages has Import or Export CSV. The **Audit** tab of Objectives shows **Import CSV**, but it opens a demo dialog that cannot import. See CSV import and export.

Shared behaviour

Coverage, Issues and the Objectives tab draw their own tables, with **… Views**, a search box behind the funnel button and **Show 10 / 25 / 50 entries**. The Audit tab uses the shared grid. Comments, the Activity Log, the View dialog and the delete confirmation work as described in Working with registers.

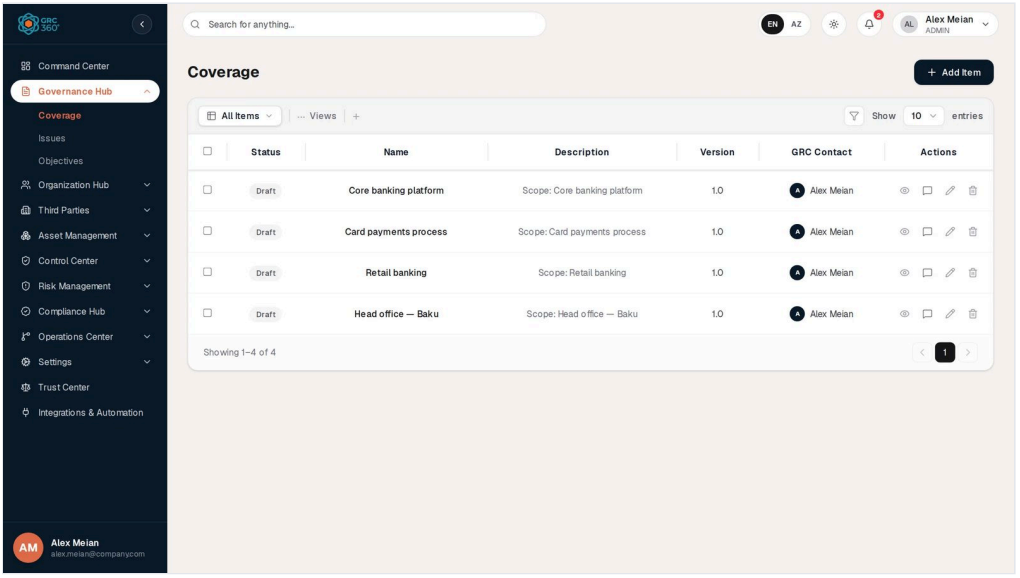
Related pages

- Projects, Controls, Policies & Standards, Third Party Risks, Business Risks: the records an objective links to.
- Status and Dynamic Status rules, Notifications and scheduled jobs.

Coverage

> **Module:** Governance Hub › Coverage · **Route:** `/governance/coverage` · **Permission key:** `governance.coverage`

The Coverage register describes the scope of your GRC programme: the regions, business units, processes and IT systems that the programme covers. One record is one scope element, with a version and the GRC contact who answers for it. The register is normally kept by the GRC or compliance office when the programme scope is defined or reviewed, for example before a certification audit.



Coverage register

At a glance

A record is	One scope element of the GRC programme (a region, business unit, process or IT system)
Typical owner	GRC manager or compliance officer
Links to	Users and groups (**GRC Contact**)
Linked from	Objectives (in the backend only; the Objectives form has no Coverage field, see Relationships)
Tabs	None
Automations	None

The register (list view)

Coverage draws its own table rather than the shared grid, so a few things differ from Working with registers:

- The toolbar has an **All Items** drop-down that filters the list by **Status**. It lists only the status values that occur in the register (in the demo data, only *DRAFT*).
- **… Views** opens **Visible Columns**, where you switch columns on and off.
- The **+** next to **… Views** opens the same Add form as **Add Item**.
- The funnel button on the right shows or hides a **Search…** box. Search matches any field of the record, as you type.
- **Show 10 / 25 / 50 entries** sets the page size. Paging, filtering and search all work on the full list in your browser.
- There is no **Import CSV** and no **Export CSV** button.
- Rows are listed newest first.

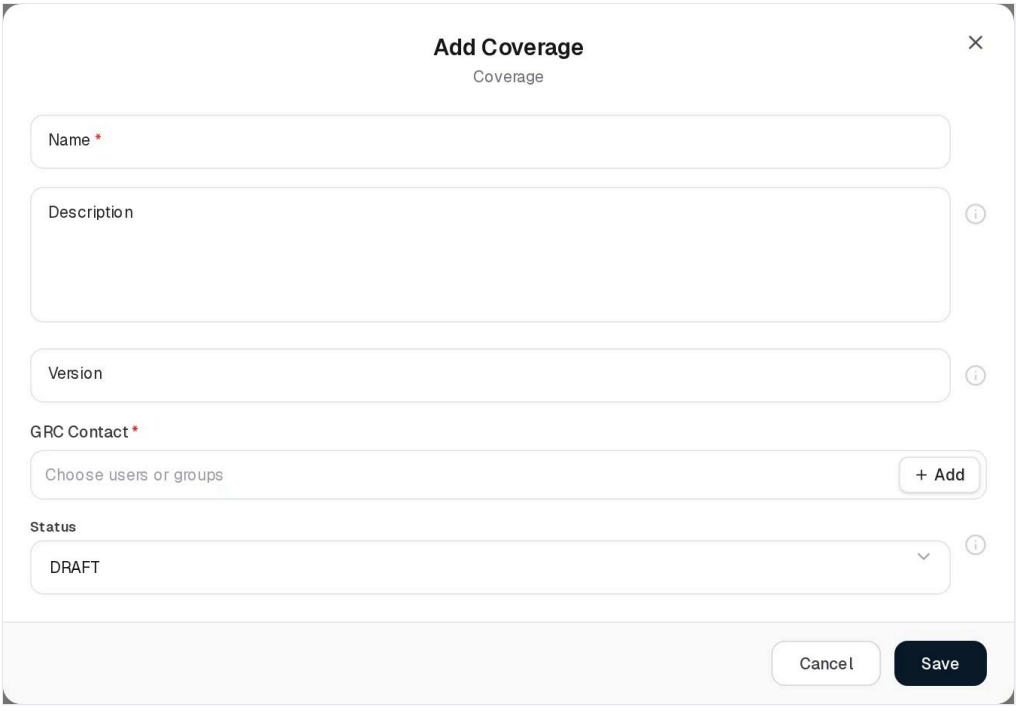
Column	What it shows	Source
Status	The status chosen on the form, as a badge (*Draft*)	Entered
Name	Name of the scope element	Entered
Description	Description, cut to one line	Entered
Version	Version text. A record saved without a version shows **1.0**	Entered
GRC Contact	The people or groups named as GRC contact, with an initial avatar	Entered
Actions	**View** (eye), **Activity Log** (speech bubble), **Edit** (pencil), **Delete** (bin)	

There is no **Dynamic Status** column on this register.

Ticking one or more rows shows a red bin button with the number of selected rows. It deletes them after the confirmation *Delete N selected items? This cannot be undone.*

Creating a record

Click **Add Item**. The form opens in a dialog titled **Add Coverage**.



Add Coverage

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Message *Name is required* when empty. The server refuses more than 150 characters (*Name must not exceed 150 characters*).	Core banking platform
Description	Text area	No	Up to 1,000 characters (*Description must not exceed 1000 characters*).	Scope: Core banking platform

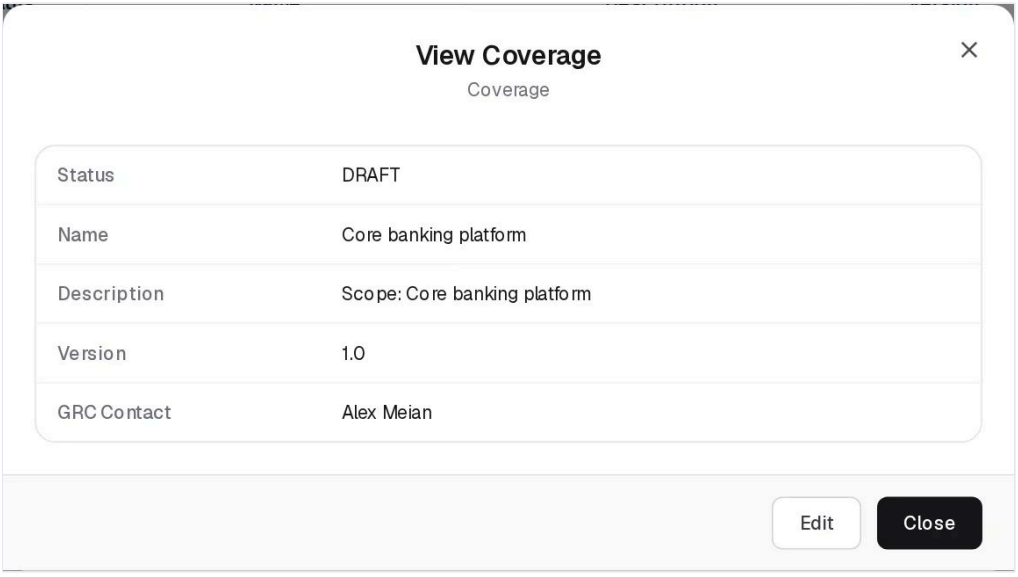
Field	Type	Required	Rules and allowed values	Example
Version	Text	No	Up to 20 characters (*Version must not exceed 20 characters*). If left empty, the register shows **1.0** and that value is saved the next time the record is edited.	1.0
GRC Contact	Users or groups, several allowed	Yes	Message *GRC Contact is required* when empty. **+ Add** in the field creates a new user (shown only with Manage access to Organization Hub › Users). See Choosing people.	Alex Meian
Status	Drop-down	No	**DRAFT**, **ACTIVE**, **ARCHIVED**, **SUPERSEDED**. Default **DRAFT**. Only *DRAFT* is actually stored, see Statuses.	DRAFT

The fields with a grey **i** icon (Description, Version, Status) show no help text when clicked.

Saving shows the message *Coverage added.*

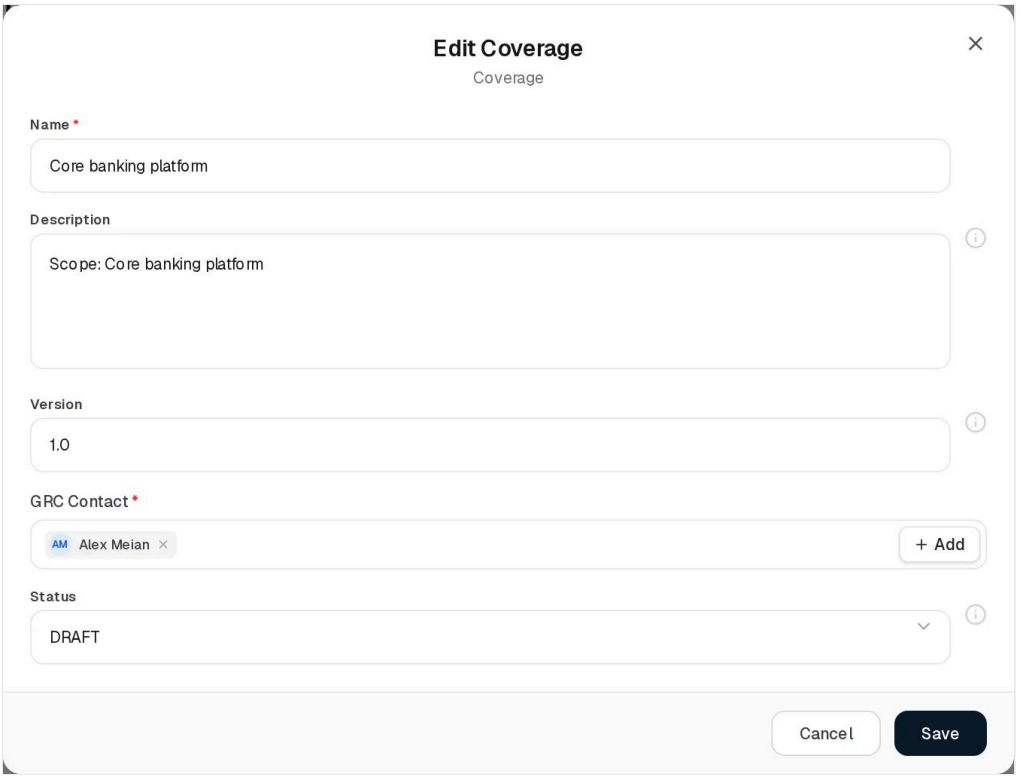
Coverage type. The backend also stores a **type** for each record: *REGION*, *BUSINESS_UNIT*, *PROCESS* or *IT_SYSTEM*. The demo data uses all four (Head office — Baku is a region, Retail banking a business unit, Card payments process a process, Core banking platform an IT system). The form has no field for it and the register does not show it. A record created from this page always gets the type *BUSINESS_UNIT*. The type is only visible through the API (`GET /api/v1/governance/coverages` , field `type`), where it can also be used as a filter (`?type=IT_SYSTEM`).

Viewing and editing a record



View Coverage

View opens **View Coverage**, a read-only list of **Status**, **Name**, **Description**, **Version** and **GRC Contact**. The status is shown as the stored value (*DRAFT*), not as a badge. **Edit** at the bottom switches to the Edit form; **Close** closes the dialog.



Edit Coverage

Edit Coverage has the same fields as the Add form. Saving shows *Coverage updated.*

Saving an edit also resets values that the form does not show. The record's **type** goes back to *BUSINESS_UNIT* and its department link is cleared. For example, editing *Core banking platform* changes its type from *IT_SYSTEM* to *BUSINESS_UNIT*.

Statuses

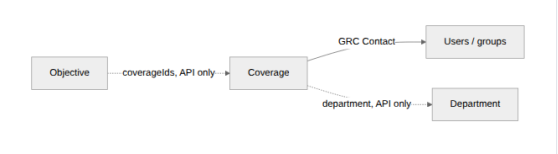
Value	Set by	Meaning
DRAFT	User	The scope element is being prepared. This is the only status that is stored from this form.
ACTIVE, ARCHIVED, SUPERSEDED	User (offered on the form)	Offered in the drop-down, but the server does not recognise these values and saves the record as *DRAFT*.
CURRENT, DISCARDED	Server only	Accepted by the API (`status: "CURRENT"` or `"DISCARDED"`), not offered on the form. A record holding one of them shows it in the grid.

The backend also keeps a stored dynamic status (*ACTIVE*, *PENDING*, *ARCHIVED*, default *ACTIVE*). It is not computed, is reset to *ACTIVE* on every save from this page, and is not shown anywhere in the UI.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Users and groups	Coverage → people, many	**GRC Contact** field. The names are stored as text; the first picked user is also stored as a user link.	**GRC Contact** column and View dialog
Objectives	Objective → Coverage, many to many	Only through the API (`coverageIds` on `POST/PUT /api/v1/governance/objectives`). The Objectives form has no Coverage field, and an unknown coverage id is refused.	Not shown in the UI. The API returns the coverages inside each objective (`coverages`).
Department	Coverage → Department, one	Only through the API (`departmentId`). Cleared when the record is edited from this page.	Not shown in the UI

A **+ Add** shortcut that opens the **Add Coverage** form from another register exists in the product, but no form in this release has a Coverage field that uses it.

When a user is deleted, the user link on their coverages is removed and their name is kept in the **GRC Contact** text.

Automations and notifications

None. Coverage records have no dates, no computed status and no notifications. Every change is recorded in the record's Activity Log history.

Permissions

Access is set per group on **Governance Hub › Coverage** (No Access, View, Manage, Full Control). See Permissions and access.

Action	Needed access
See the page	View on Governance Hub › Coverage. Without it the sidebar item is hidden.
Create / Edit	Manage on Governance Hub › Coverage
Delete (one or several)	Full Control on Governance Hub › Coverage
Comment / attach files	The group's Comments & Attachments level (View to read, Contribute to add, Manage to delete other people's)
Assign	No assignment rights on this register; any user or group can be named as GRC Contact.

Buttons you may not use stay visible with a lock; clicking one opens **Request Access**. All users of a group with View see all coverage records; there is no row-level filter on this register.

How to

Record a new scope element

1. Open **Governance Hub › Coverage** and click **Add Item**.
2. Enter a **Name**, for example *Mobile banking app*, and a **Description** such as *Scope: customer mobile banking channel*.
3. Enter the **Version**, for example *1.0*.
4. In **GRC Contact**, pick *Alex Meian*.
5. Leave **Status** on **DRAFT** and click **Save**. The record appears at the top of the list.

Find the coverage records a person is responsible for

1. Click the funnel button on the toolbar.
2. Type the person's name, for example *Alex*. The list keeps only records where any field contains the text, including **GRC Contact**.

Hide columns you do not need

1. Click **… Views**.
2. Untick **Description** and **Version**. The choice lasts until you leave the page.

Remove several records at once

1. Tick the rows, for example the two older demo entries *Retail banking* and *Head office — Baku*.
2. Click the red bin button showing **2** and confirm with **Delete**.

CSV import

Not available. The Coverage page has no **Import CSV** or **Export CSV** button, and the permission catalogue gives this page no import or export right. The backend has no CSV endpoint for coverages.

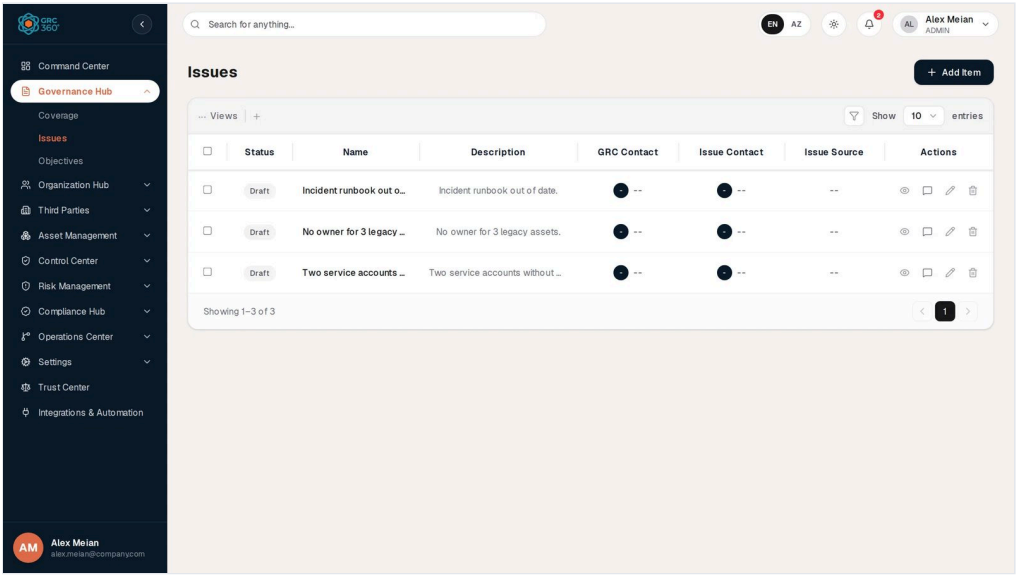
Limitations and known issues

- **Only DRAFT is saved.** The Status drop-down offers ACTIVE, ARCHIVED and SUPERSEDED, but the server does not know these values and stores *DRAFT* instead, without an error.
- **Editing resets the coverage type** to *BUSINESS_UNIT* and clears the department link, because the form does not send these values.
- **The type is invisible.** The four coverage types exist only in the backend and the API.
- **No link from Objectives in the UI.** Objectives can be linked to coverages only through the API.
- **Version shows 1.0 when empty**, and that value is written back on the next edit.
- **Load errors are not shown.** If the list cannot be loaded (for example a permission error), the table simply shows *No records found.*; while the list loads it also shows *No records found.*

Issues

> **Module:** Governance Hub › Issues · **Route:** `/governance/issues` · **Permission key:** `governance.issues`

The Issues register records governance problems found in the GRC programme: a gap, a weakness or a piece of work that is missing, such as an outdated runbook or service accounts without MFA. One record is one issue, with the GRC contact who follows it up, the contact on the business side and where it came from. Issues are usually raised by the GRC team and linked to the objectives they threaten (**Program Issues** on an objective).



Issues register

At a glance

A record is	One governance issue found in the GRC programme
Typical owner	GRC manager (GRC Contact) with a business-side Issue Contact
Links to	Users and groups (**GRC Contact**, **Issue Contact**)
Linked from	Objectives (**Program Issues**, on the objective's **Issues** tab)
Tabs	None
Automations	Achieving an objective discards and resolves its linked issues (see Automations)

Control issues (Control Center › Controls › **Issues** tab) are a different register and are not shown here.

The register (list view)

Issues draws its own table rather than the shared grid, so a few things differ from Working with registers:

- There is no status drop-down on the toolbar. Only **… Views** (column visibility) and **+** (opens the Add form) are on the left.
- The funnel button shows or hides a **Search…** box. Search runs on the server and matches the issue **Name** only (not the description or the contacts).
- **Show 10 / 25 / 50 entries** sets the page size; paging is done by the server. Rows are listed newest first.
- There is no **Import CSV** and no **Export CSV** button.

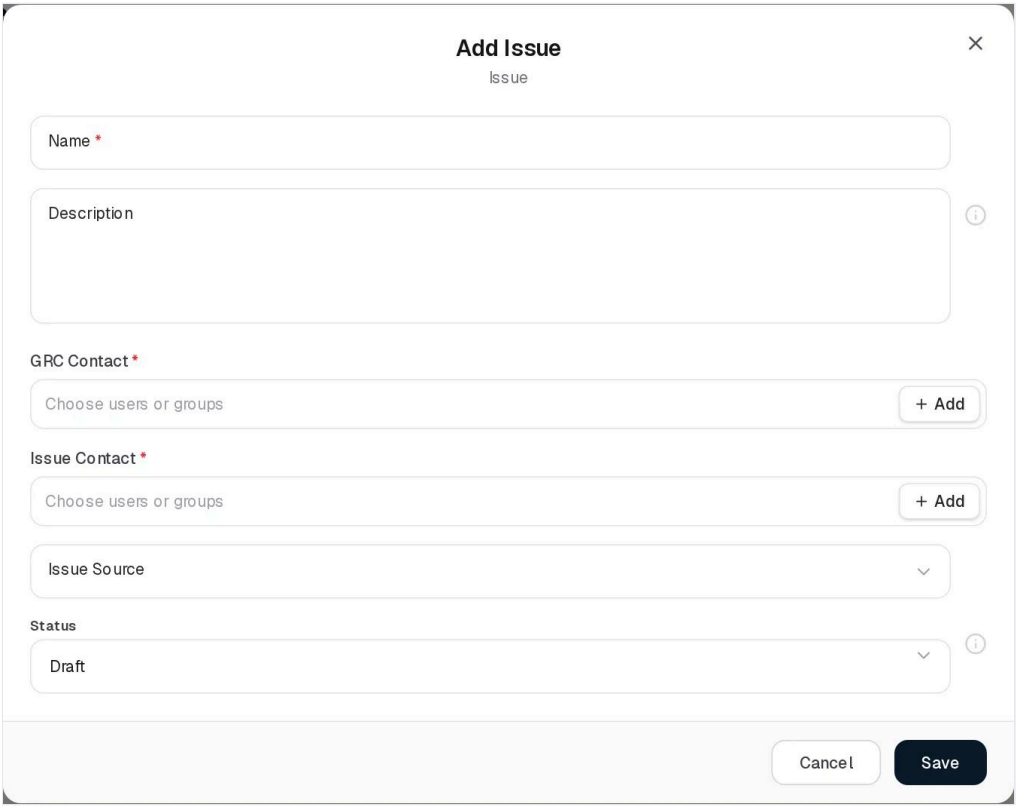
Column	What it shows	Source
Status	The status chosen on the form as a badge: *Current*, *Discarded* or *Draft*	Entered

Column	What it shows	Source
Name	Issue name, cut to one line	Entered
Description	Description, cut to one line	Entered
GRC Contact	People or groups named as GRC contact, with an initial avatar. `--` when empty	Entered
Issue Contact	People or groups named as issue contact. `--` when empty	Entered
Issue Source	*Internal* or *External*. `--` when not set	Entered
Actions	**View**, **Activity Log**, **Edit**, **Delete**	

There is no **Dynamic Status** column on this register. Ticking rows shows a red bin button with the number selected, which deletes them after confirmation (*Delete N selected items? This cannot be undone.*).

Creating a record

Click **Add Item**. The form opens in a dialog titled **Add Issue**.



Add Issue

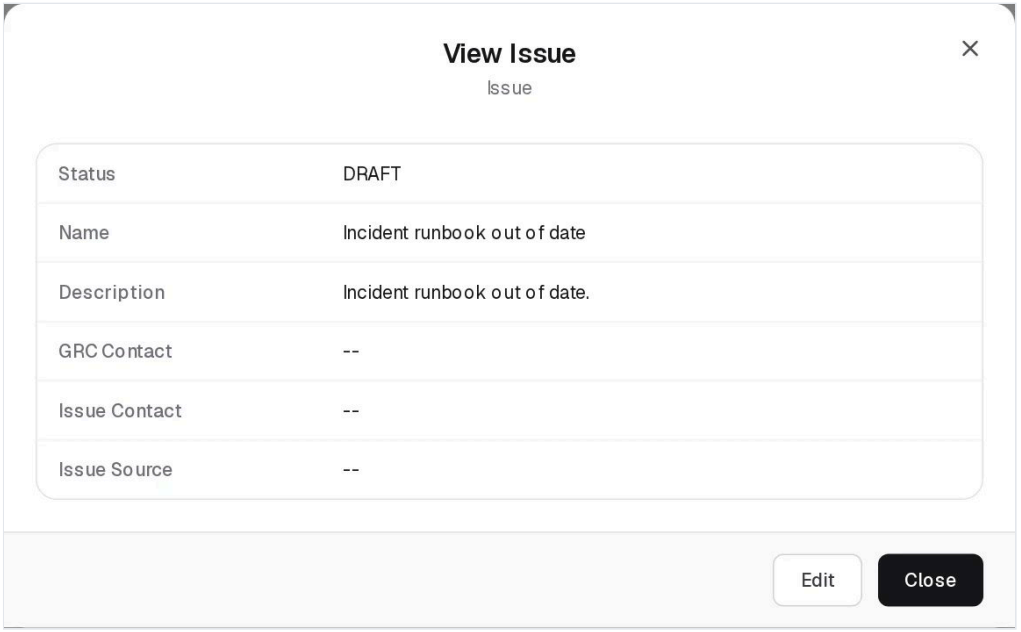
Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Message *Title is required* when empty. The server refuses more than 200 characters (*Name must not exceed 200 characters*).	Two service accounts without MFA
Description	Text area	No	Up to 2,000 characters (*Description must not exceed 2000 characters*).	Two service accounts without MFA.
GRC Contact	Users or groups, several allowed	Yes	Message *GRC Contact is required*. **+ Add** creates a new user.	Alex Meian

Field	Type	Required	Rules and allowed values	Example
Issue Contact	Users or groups, several allowed	Yes	Message *Issue Contact is required*.	Sara Johnson
Issue Source	Drop-down	No	**Internal**, **External**. Empty by default.	Internal
Status	Drop-down	No	**Current**, **Discarded**, **Draft**. Default **Draft**.	Draft

Saving shows *Issue added.* The new issue gets the workflow state *Open* in the background (see Statuses).

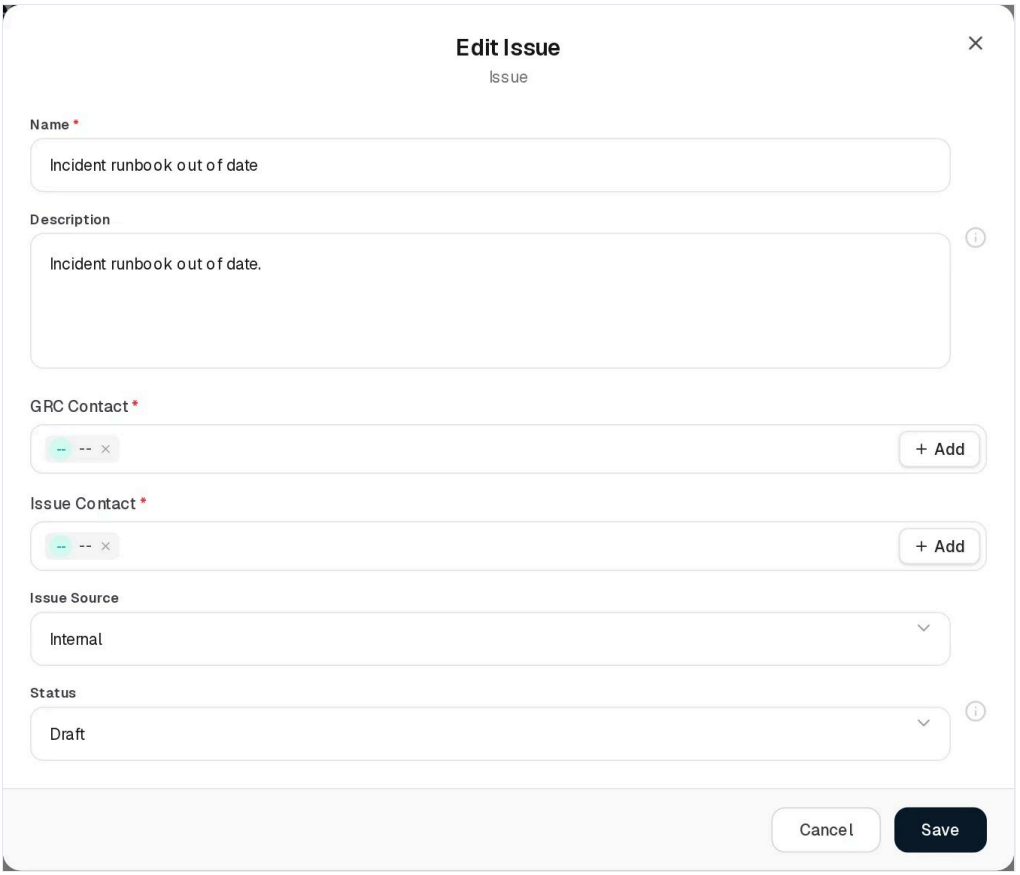
The same form opens from an objective's **Issues** tab: **+ Add** on the **Program Issues** field creates the issue and links it to the objective you are editing.

Viewing and editing a record



View Issue

View opens **View Issue** with **Status**, **Name**, **Description**, **GRC Contact**, **Issue Contact** and **Issue Source**. The status is shown as the stored value (*DRAFT*). Empty values show `--`. **Edit** switches to the Edit form.



Edit Issue

Edit Issue has the same fields as the Add form. Saving shows *Issue updated.* Be aware of three display problems in this dialog (also listed under Limitations):

- An empty contact opens as a chip reading `--`. Remove it and pick a person, or `--` is saved as the contact's name.
- **Issue Source** always opens showing **Internal**, whatever is stored. If you do not pick a value, the stored value is kept for issues that have one, and the field stays empty for issues that had none.
- The issue's priority, linked objective, risk, control, policy, assignee and due date (values held by the backend but not shown on any screen) are cleared or reset to their defaults when you save.

Statuses

An issue holds two statuses. Only the first is visible.

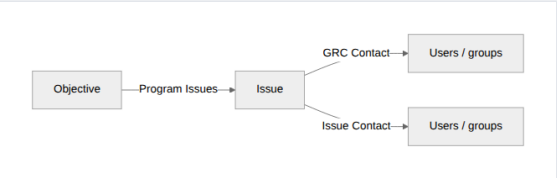
Value	Set by	Meaning
Draft	User	Default. The issue is recorded but not yet confirmed.
Current	User	The issue is confirmed and being worked on.
Discarded	User, or the system when a linked objective is achieved	The issue is no longer relevant.
Open	System	Workflow state of every new issue. Not shown on any screen.
Resolved	System	Set, with today's resolved date, when an objective the issue is linked to becomes *Achieved*. Not shown on any screen.
In progress, Closed, Blocked, Deferred	API only	Other workflow states the backend accepts. Not used by the UI.

The workflow state matters in two places even though you cannot see it: an objective's progress counts a linked issue as done when its workflow state is *Resolved* or *Closed*, and editing an issue from this page keeps its workflow state unchanged.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Objectives	Objective → Issue, many to many	**Program Issues** on the objective's **Issues** tab (Edit Objective)	Objectives register, **Issues** column (names, not clickable). Not shown on the Issues register.
Users and groups	Issue → people, many	**GRC Contact** and **Issue Contact**. Names are stored as text; the first picked user is also stored as a user link.	Grid and View dialog

The backend issue record also has fields for a department, objective, risk, control, policy, priority (*Low*, *Medium*, *High*, *Critical*, default *Medium*), assignee, due date and resolved date. No screen shows or sets them, and saving from this page resets them.

When a user is deleted, their user link on issues is removed and the name stays in the contact text.

Automations and notifications

- **Objective achieved.** When an objective is saved with status *Achieved* (or created as *Achieved*), every issue linked to it under **Program Issues** is updated at once: its Status becomes *Discarded* (unless it already is) and its workflow state becomes *Resolved* with today's date (unless it is already *Resolved* or *Closed*). Each change is written to the system audit log as an *OBJECTIVE_STATUS_AUTOMATION* entry.
- **Objective progress.** An objective's calculated progress counts each linked issue; it counts as finished when its workflow state is *Resolved* or *Closed*.
- **Notifications.** None. Issues send no notification.
- Every change is recorded in the record's Activity Log history.

Permissions

Access is set per group on **Governance Hub › Issues** (No Access, View, Manage, Full Control). See Permissions and access.

Action	Needed access
See the page	View on Governance Hub › Issues
Create / Edit	Manage on Governance Hub › Issues. Creating an issue with **+ Add** from an objective also needs it.
Delete (one or several)	Full Control on Governance Hub › Issues
Comment / attach files	The group's Comments & Attachments level
Assign	No assignment rights on this register

All users with View see all issues; there is no row-level filter on this register.

How to

Raise an issue

1. Open **Governance Hub › Issues** and click **Add Item**.
2. Enter the **Name**, for example *Incident runbook out of date*, and a **Description**.
3. Pick *Alex Meian* as **GRC Contact** and the owner on the business side as **Issue Contact**.
4. Set **Issue Source** to **Internal** and leave **Status** on **Draft**.
5. Click **Save**.

Confirm an issue

1. Click the pencil on the issue, for example *No owner for 3 legacy assets*.
2. If a contact shows a `--` chip, remove it with its **x** and pick the right person.
3. Set **Issue Source** explicitly (the field always opens on **Internal**).
4. Change **Status** to **Current** and click **Save**.

Link an issue to an objective

1. Open **Governance Hub › Objectives** and click the pencil on *Achieve ISO 27001 certification*.
2. Open the **Issues** tab and click the **Program Issues** field.
3. Tick *Two service accounts without MFA* and click **Done**, then **Save**.
4. The objective's **Issues** column now names the issue.

Find an issue by name

1. Click the funnel button and type part of the name, for example *runbook*. Only the **Name** is searched.

CSV import

Not available. The Issues page has no **Import CSV** or **Export CSV** button, the permission catalogue gives it no import or export right, and the backend has no CSV endpoint for governance issues.

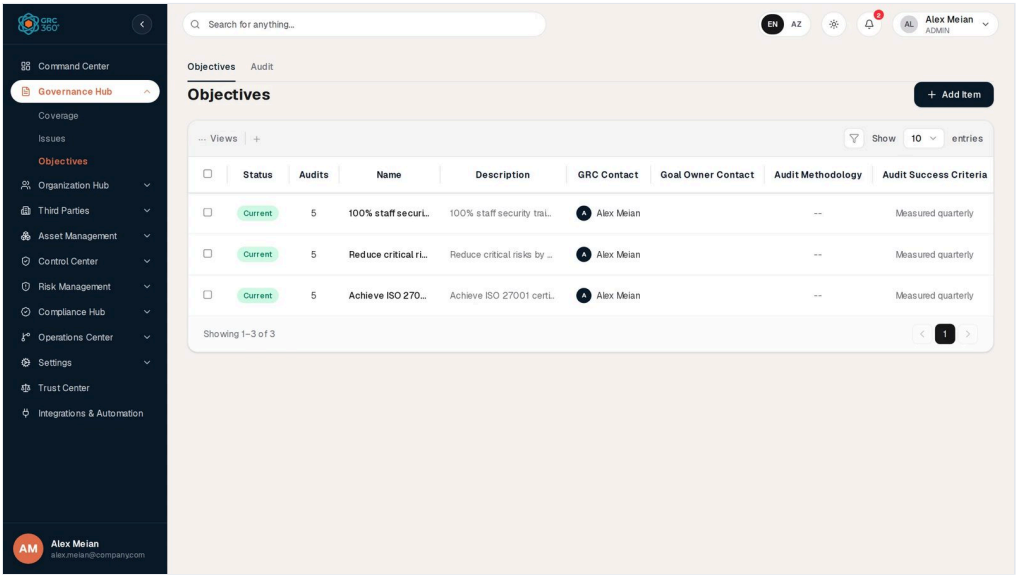
Limitations and known issues

- **Empty contacts open as `--`.** Editing an issue without contacts shows a `--` chip in **GRC Contact** and **Issue Contact**, and saving without replacing it stores `--` as the contact name. The demo issues all have empty contacts.
- **Issue Source always opens on Internal** in the Edit dialog, even for *External* issues or issues without a source.
- **Hidden fields are wiped on save.** Priority returns to *Medium* and the linked objective, risk, control, policy, department, assignee and due date are cleared, because the form does not send them.
- **The workflow state is invisible.** Whether an issue is *Open* or *Resolved* cannot be seen or changed on screen, yet it drives objective progress.
- **Search covers the name only.**
- **A second, separate issue store exists in the backend** (`/api/v1/issues`, with severity *Low* to *Critical* and source types *AUDIT*, *GAP_ASSESSMENT*, *MANUAL*). No screen uses it, and its records never appear on this page. It is governed by the same Governance Hub › Issues permission.

Objectives

> **Module:** Governance Hub › Objectives · **Route:** `/governance/objectives` · **Permission key:** `governance.objectives` (tab **Audit**: `governance.objectives_audits`)

The Objectives register holds the goals of the GRC programme, such as *Achieve ISO 27001 certification* or *100% staff security training*. One record is one goal: who owns it, how and how often it is audited, and which projects, controls, risks, policies and issues it depends on. The page has a second tab, **Audit**, which lists the audits of every goal, most of them generated from the goal's audit schedule. Goals are usually set by the CISO or GRC manager; audit owners record the audit results.



Objectives register

At a glance

A record is	One goal of the GRC programme, with its audit schedule and the work it depends on
Typical owner	CISO or GRC manager (GRC Contact) and a business goal owner (Goal Owner Contact)
Links to	Projects, Controls, Third Party Risks, Business Risks, Policies, Issues, users and groups
Linked from	Objective audits (each audit belongs to one goal)
Tabs	**Objectives**, **Audit**
Automations	Audit rows generated from the schedule on every save; *Achieved* closes linked issues, controls and risks; calculated progress

The register (list view)

The Objectives tab draws its own table, so a few things differ from Working with registers:

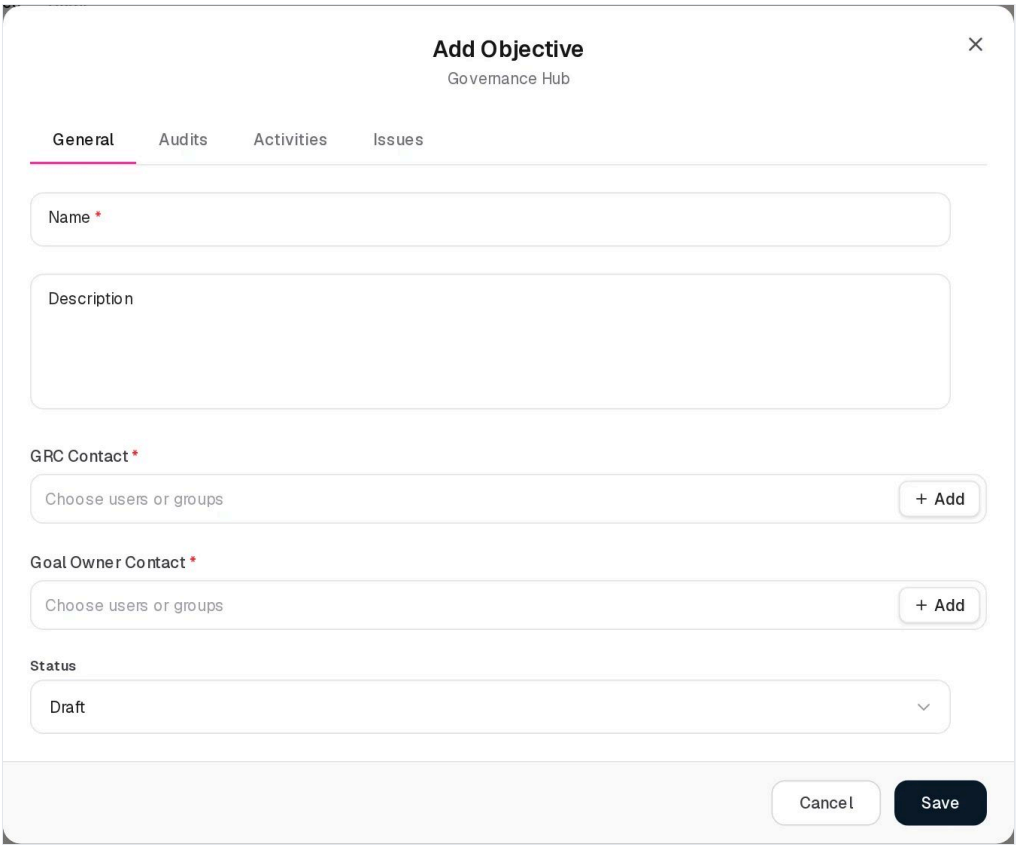
- The toolbar has **… Views** (column visibility) and **+** (opens the Add form). There is no status drop-down.
- The funnel button shows a **Search…** box. Search runs on the server and matches the objective **Name** only.
- **Show 10 / 25 / 50 entries**; paging is done by the server; newest first.
- There is no **Import CSV** or **Export CSV** button on this tab.

Column	What it shows	Source
Status	The goal's status as a badge: *Current*, *Discarded*, *Draft*, *Achieved*	Entered
Audits	Number of audits the **Audit** tab holds for this goal (generated and manual)	Computed by the system
Name	Goal name	Entered
Description	Description, cut to one line	Entered
GRC Contact	People named as GRC contact, one avatar chip per name	Entered
Goal Owner Contact	People named as goal owner	Entered
Audit Methodology	How the goal is audited (from the form's **Audits** tab)	Entered
Audit Success Criteria	What counts as success	Entered
Projects	Names of linked projects	Linked
Controls	Names of linked controls	Linked
Third Party Risk	Number of linked third party risks. Click a non-zero number to open the linked risks.	Linked
Business Risk	Number of linked business risks, clickable the same way	Linked
Policy	Names of linked policies	Linked
Issues	Names of linked issues (**Program Issues**)	Linked
Actions	**View**, **Activity Log**, **Edit**, **Delete**	

There is no **Dynamic Status** column. The backend calculates a progress percentage for each goal (see Automations), but the page does not show it.

Creating a record

Click **Add Item**. The dialog **Add Objective** (subtitle *Governance Hub*) has four tabs: **General**, **Audits**, **Activities**, **Issues**. If a required field is missing on another tab, saving switches to that tab and outlines the field.



Add Objective

General

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	*The field is required* under the field (the message box says *Name is required*). The server refuses more than 150 characters.	Achieve ISO 27001 certification
Description	Text area	No	Up to 2,000 characters.	Achieve ISO 27001 certification.
GRC Contact	Users or groups, several allowed	Yes	*GRC Contact is required*. Subject to **Can Assign** / **Can Reassign** (see Permissions).	Alex Meian
Goal Owner Contact	Users or groups, several allowed	Yes	*Goal Owner Contact is required*. Up to 1,000 characters of names. Subject to the assignment rights.	Alex Meian
Status	Drop-down	No	**Current**, **Discarded**, **Draft**, **Achieved**. Default **Draft**.	Current

Audits

Field	Type	Required	Rules and allowed values	Example
Audit Dates	Radio buttons	Yes	**No audits required** (default) or **Audits required**. With *No audits required* nothing else on this tab is shown or checked.	Audits required

Field	Type	Required	Rules and allowed values	Example
Occurrence type	Switch	When audits are required	**Specific** (default) or **Periodical**	Periodical
Audit date rows	Date, one per row	Specific: at least one	**Add new +** adds a row; the bin removes one. Message *Pick at least one audit date*.	2026-11-30
First audit date	Date	Periodical: yes	*The field is required*	2026-10-29
Frequency	Drop-down	Periodical: yes	**Weekly**, **Monthly**, **Quarterly**, **Twice a Year**, **Yearly**	Quarterly
Audit Methodology	Text area	When audits are required	Up to 2,000 characters. Becomes the **Audit Metric** of every generated audit.	Review of the ISMS evidence pack
Audit Success Criteria	Text area	When audits are required	Up to 1,000 characters. Copied to every generated audit.	Measured quarterly
Audit Owners	Users or groups, several allowed	When audits are required	Copied to every generated audit. Subject to the assignment rights.	Alex Meian
Audit Evidence Owners	Users or groups, several allowed	When audits are required	Copied to every generated audit. Subject to the assignment rights.	Sara Johnson

Activities

Field	Type	Required	Rules	Example
Projects	Pick list of Operations Center projects, several	No	**+ Add** opens the full **Add Item (Projects)** form	ISO 27001 certification
Controls	Pick list of Control Center controls, several	No	**+ Add** opens the Add Control form	
Third Party Risks	Pick list, several	No	**+ Add** available	
Business Risks	Pick list, several	No	**+ Add** available	
Policies	Pick list of Policies & Standards, several	No	**+ Add** available	

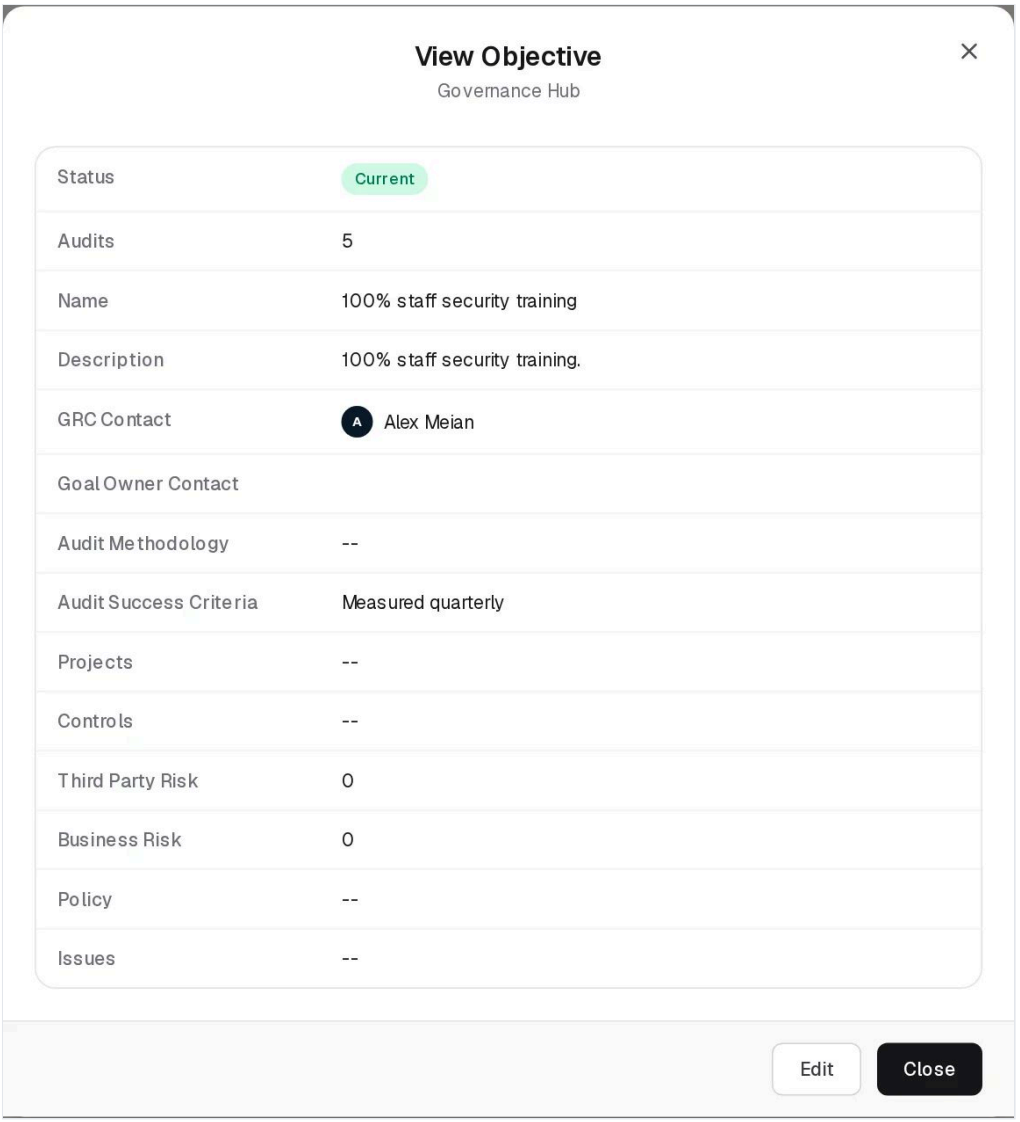
Issues

Field	Type	Required	Rules	Example
Program Issues	Pick list of Governance Hub issues, several	No	**+ Add** opens the **Add Issue** form	Two service accounts without MFA

Pick lists work as described in Choosing related records. A record whose name is shown but which no longer exists stays as text and is not linked.

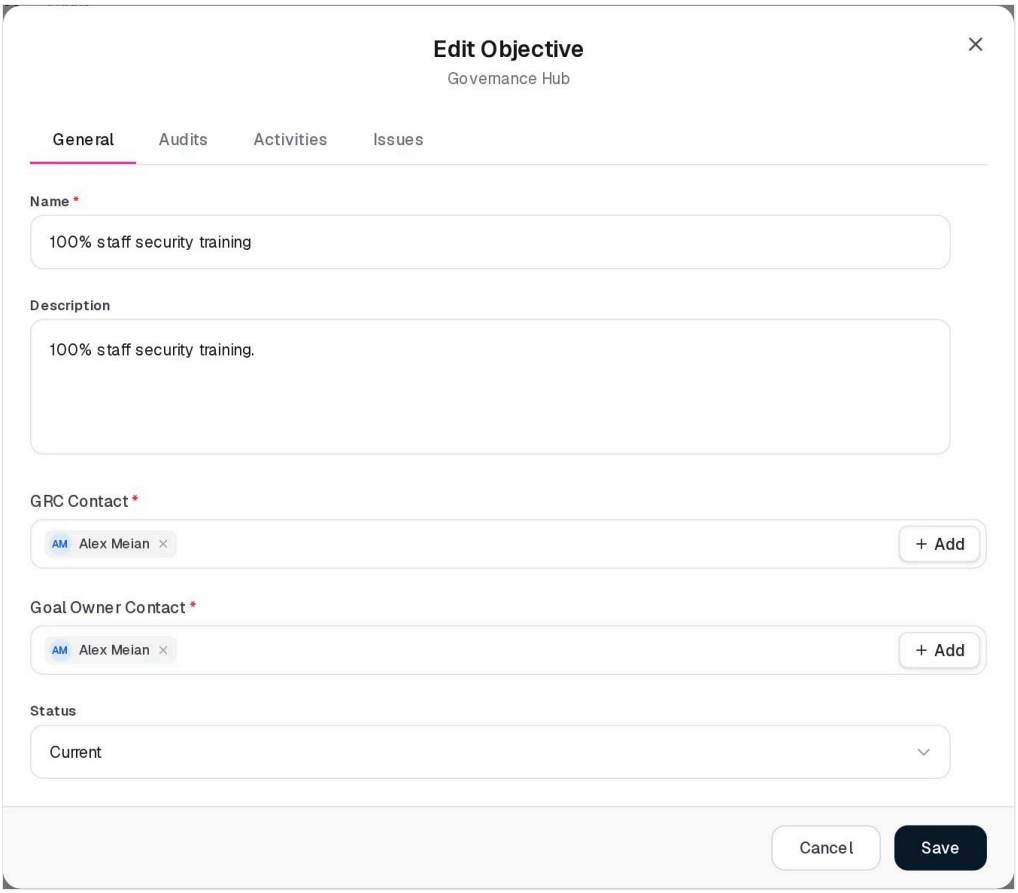
Saving shows *Objective added.* and, when audits are required, creates the goal's audit rows at once (see The audit schedule).

Viewing and editing a record



View Objective

View opens **View Objective** with every grid column. **Third Party Risk** and **Business Risk** show the counts; a non-zero count opens the linked risks on top of the dialog. **Edit** switches to the Edit form.



Edit Objective

Edit Objective has the same tabs and fields as the Add form. Saving shows *Objective updated.* and re-synchronises the audit schedule.

Saving also clears values that only the API can set and the form does not send: the goal's **target date**, its owner and internal user links and its manual progress percentage. The demo goals have target dates (for example *Achieve ISO 27001 certification*: 11 February 2027); editing one from this page removes it.

Statuses

Value shown	Stored value	Set by	Meaning
Draft	DRAFT	User	Default for a new goal
Current	ACTIVE	User	The goal is being pursued
Discarded	ABANDONED	User	The goal was dropped
Achieved	ACHIEVED	User	The goal is met. Saving a goal into *Achieved* triggers the automation below.

The status is never changed by the system. Finishing all linked work does not make a goal *Achieved*; only a person sets it.

The audit schedule

When **Audits required** is selected, every save of the goal brings its generated audits in line with the schedule:

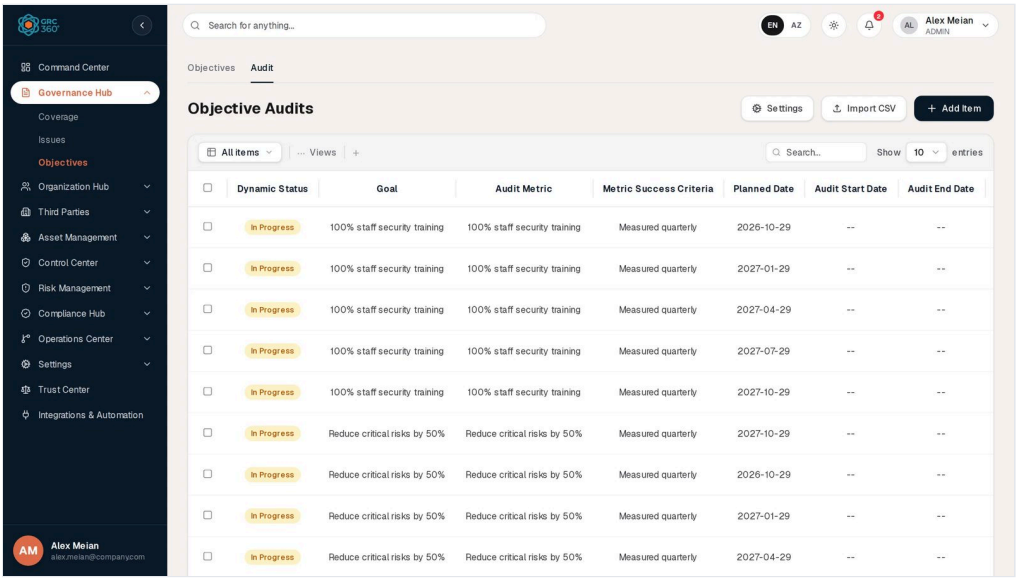
- **Specific**: each picked date yields two planned audits, the date itself and the same day one year later.
- **Periodical**: the first audit date and then one audit per frequency step (weekly, monthly, every 3 months, every 6 months, yearly), up to and including one year after the first date. A quarterly schedule starting 29 October 2026 therefore yields 5 audits: 29 Oct 2026, 29 Jan, 29 Apr, 29 Jul and 29 Oct 2027. This is what the demo goals show.
- Dates before today are dropped.

- Each generated audit gets the planned date, **Audit Methodology** as its **Audit Metric** (the goal name when the methodology is empty), **Audit Success Criteria**, **Audit Owners** and **Audit Evidence Owners**.
- When the schedule changes, generated audits that no longer fit are deleted, but only if nobody has recorded an **Audit Result** on them. Audits added by hand on the **Audit** tab and audits with a result are never removed.
- Switching to **No audits required** removes the generated audits that have no result.

Tabs

Audit

The **Audit** tab lists the audits of all goals you can see. It is a register of its own with its own permission (**Objectives › Audits** in the group settings).



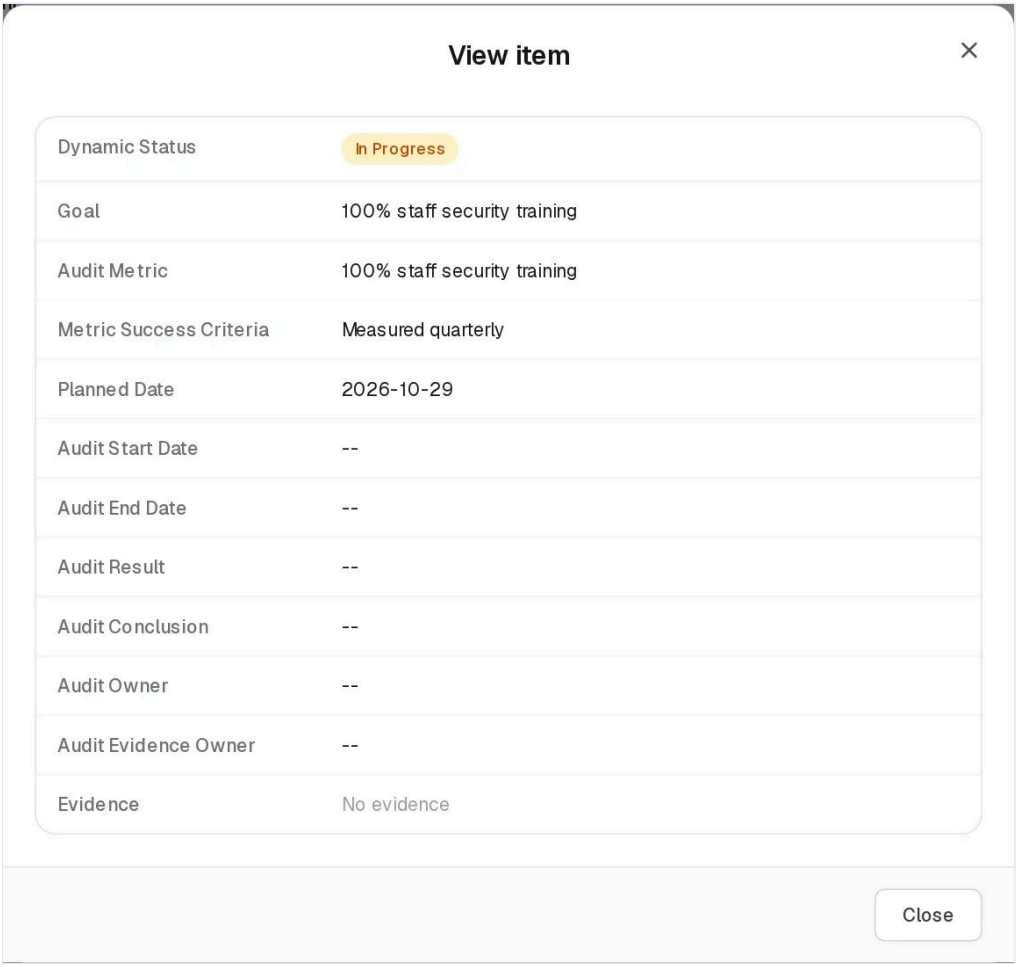
Objective Audits

The register is titled **Objective Audits** and uses the shared grid: **All items** filters by Dynamic Status, and there is a **Search…** box. The header has **Settings** (audit result options), **Import CSV** and **Add Item**. In the demo data every goal has five generated audits, all *In Progress* with no result yet.

Column	What it shows	Source
Dynamic Status	*Pass*, *Fail* or *In Progress*, derived from the **Audit Result** (rule below)	Computed by the system
Goal	Name of the objective	Linked
Audit Metric	What is measured	Entered or generated
Metric Success Criteria	Success criteria	Entered or generated
Planned Date	When the audit is due	Entered or generated
Audit Start Date, Audit End Date	When the audit actually ran	Entered
Audit Result	The chosen result option	Entered
Audit Conclusion	Free text	Entered
Audit Owner, Audit Evidence Owner	People, one chip per name	Entered or generated
Evidence	Attached files; click a file name to download it	Uploaded

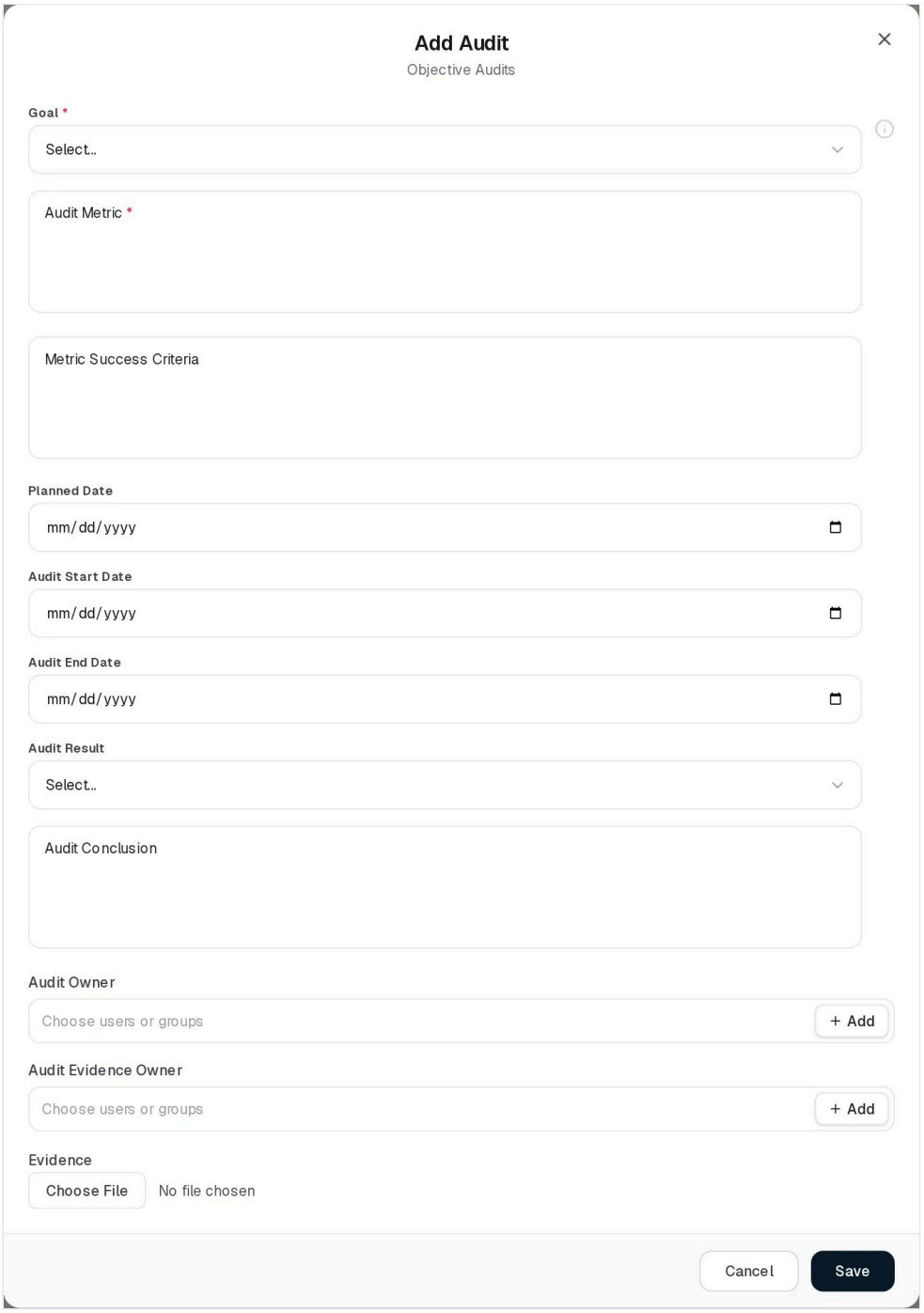
Dynamic Status rule. No result: *In Progress*. Otherwise the outcome configured for the result option of that name (*Failed* = Fail, *Passed* = Pass, *In review* = In Progress by default). If the name matches no current option (it was renamed or deleted later), a result containing “fail” reads *Fail*, one containing “pass” reads *Pass*, anything else *In Progress*. Colours: Pass green, Fail red, In Progress amber.

View opens the shared **View item** dialog with all twelve columns; empty values show `--` and an audit without files shows *No evidence* under **Evidence**.



View objective audit

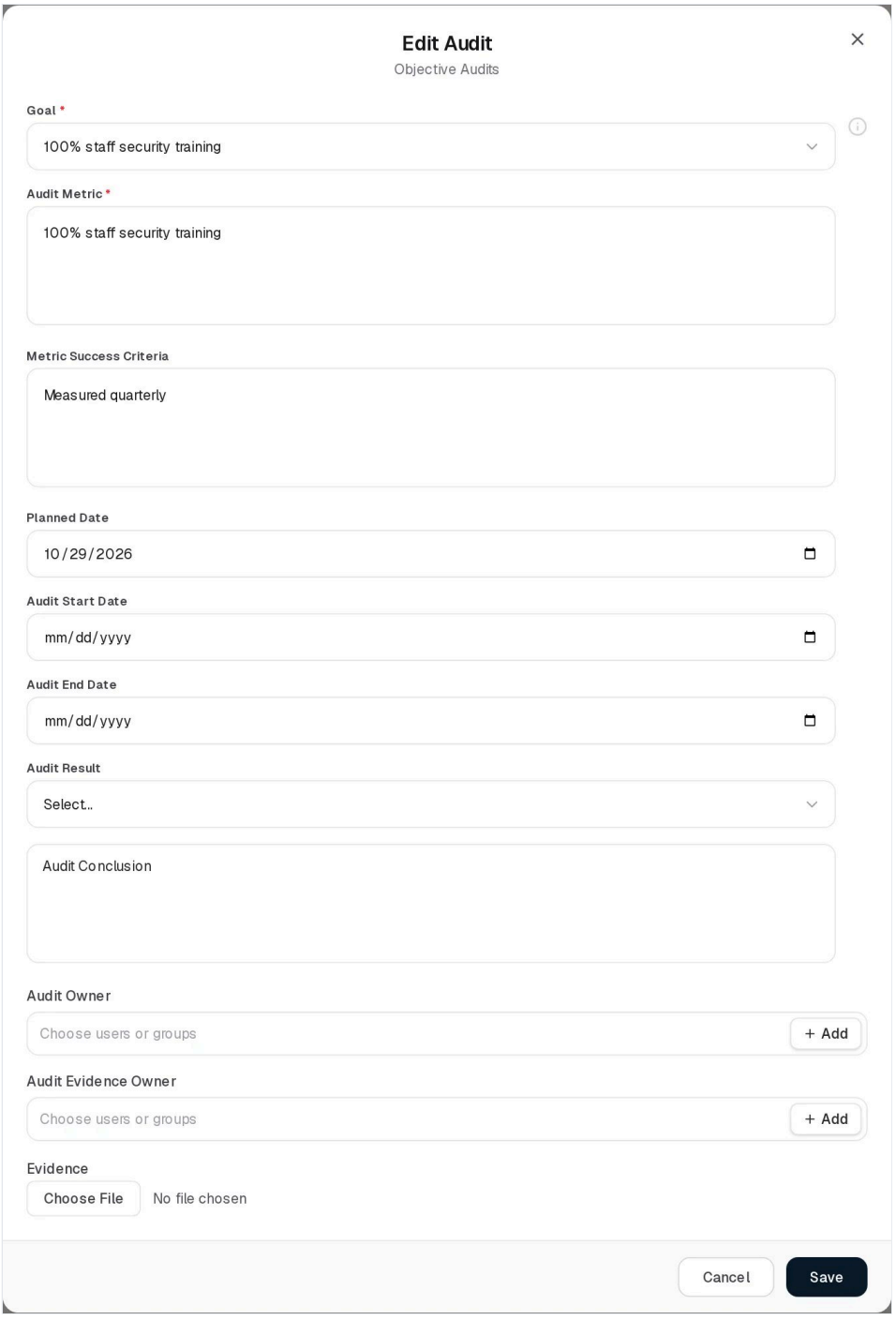
Add Audit / Edit Audit (subtitle *Objective Audits*). Both forms have the same fields; Edit opens with the stored values, for example a generated audit of *100% staff security training* with Planned Date 2026-10-29 and Metric Success Criteria *Measured quarterly*.



Add Audit

Field	Type	Required	Rules and allowed values	Example
Goal	Drop-down of all objectives you can see	Yes	*The field is required*. Changing it on Edit moves the audit to another goal.	Achieve ISO 27001 certification
Audit Metric	Text area	Yes	*The field is required*	Achieve ISO 27001 certification
Metric Success Criteria	Text area	No		Measured quarterly
Planned Date	Date	No		2026-10-29
Audit Start Date	Date	No		2026-10-29
Audit End Date	Date	No		2026-10-30

Field	Type	Required	Rules and allowed values	Example
Audit Result	Drop-down of the result options	No	Options from **Settings**; default list **Failed**, **Passed**, **In review**. Up to 255 characters.	Passed
Audit Conclusion	Text area	No		Evidence pack complete
Audit Owner	Users or groups, several	No	Names, up to 255 characters	Alex Meian
Audit Evidence Owner	Users or groups, several	No	Names, up to 255 characters	Sara Johnson
Evidence	File upload (**Choose File**)	No	One file per pick, **Remove** to delete. Files up to 25 MB. On a new audit the files are uploaded after the audit is saved; a failed upload shows *Could not attach file name.*	iso-evidence.pdf



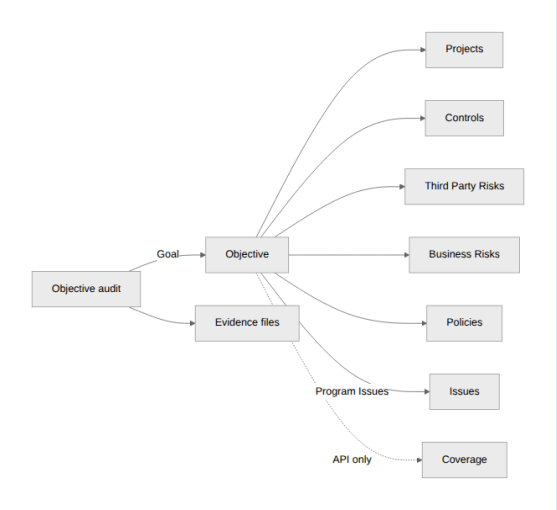
Edit Audit

The **Goal** and **Audit Result** drop-downs show *Select…* until a value is picked; the **i** icon next to **Goal** shows no help text. Messages: *Audit added.*, *Audit updated.*, *Audit deleted.* Deleting asks *Delete audit (metric)?*.

Settings: Audit Result Options. The **Settings** button opens a list of result options with **Type to filter…**, a **Title** column and **Edit** / **Delete** per row. **Add New** opens a **New entry** box with **Save** and **Cancel**. The note under the list reads *Removing an entry only stops it being offered — records that already carry it keep their value.*

- The three default options are created the first time anyone opens the list.
- A name must be unique (*An audit result named 'X' already exists*).
- An option that any audit uses cannot be deleted (*Cannot delete this audit result because it is currently used by objective audits*).
- New options always get the outcome *In Progress*, and the outcome cannot be changed on screen. So an audit with a new option named, for example, *Passed with remarks* reads *In Progress*, not *Pass*.

Relationships



Related record	Direction	How the link is made	Where it shows
Projects	Objective → Project, many to many	**Activities › Projects**	**Projects** column (names, not clickable). Not shown on the project.
Controls	Objective → Control, many to many	**Activities › Controls**	**Controls** column (names)
Third Party Risks	Objective → risk, many to many	**Activities › Third Party Risks**	**Third Party Risk** column, count, clickable
Business Risks	Objective → risk, many to many	**Activities › Business Risks**	**Business Risk** column, count, clickable
Policies	Objective → Policy, many to many	**Activities › Policies**	**Policy** column (names)
Issues	Objective → Issue, many to many	**Issues › Program Issues**	**Issues** column (names)
Coverage	Objective → Coverage, many to many	API only (`coverageIds`)	Not shown
Objective audits	Audit → Objective, many to one	**Goal** on the audit, or generated by the schedule	**Audits** count column; **Goal** column on the Audit tab
People	Objective → users/groups	GRC Contact, Goal Owner Contact, Audit Owners, Audit Evidence Owners	Grid columns; these people also decide who sees the goal (see Permissions)

Deleting a goal deletes all its audits. Deleting a linked record elsewhere leaves its name in the goal's text column but removes the link.

Automations and notifications

- **Audit schedule** (on every save of a goal): see The audit schedule.
- **Audits count**: recalculated whenever an audit is added, moved to another goal or deleted, and on every save of the goal.
- **Goal achieved** (when a goal is saved into *Achieved*, or created as *Achieved*):
  - linked issues: Status *Discarded* and workflow state *Resolved* with today's date;
  - linked controls: lifecycle status *Production* (their Dynamic Status then follows from their own audits, issues and maintenances);
  - linked third party risks: status *Closed* (unless already Closed or Archived);
  - linked business risks: status *Mitigated* (unless already Mitigated or Closed);
  - linked projects: unchanged. Each change is written to the system audit log (*OBJECTIVE_STATUS_AUTOMATION*).
- **Calculated progress** (on every read): the share of linked issues, controls, projects, third party risks and business risks that are finished, each counting the same, rounded to a whole percent. Finished means: issue *Resolved* or *Closed*; control Dynamic Status *Compliant*; project status *Completed* or every task at 100%; third party risk *Closed* or *Archived*; business risk

Mitigated or *Closed*. With nothing linked the manual percentage applies (0 from this page). The value is returned by the API but not shown on screen.

- **Reminders**: an *ObjectiveAlertScheduler* job (daily at 09:00) that would send *Objective Audit Due* (`OBJECTIVE_AUDIT_DUE` , next audit date reached) and *Objective Target Overdue* (`OBJECTIVE_TARGET_OVERDUE` , target date passed and goal not Achieved) notifications is implemented but not active in this release, because scheduled jobs are not enabled in the backend. No objective notification is sent.

Permissions

Each of **Governance Hub › Objectives** and **Objectives › Audits** has its own access level (No Access, View, Manage, Full Control). See Permissions and access.

Action	Needed access
See the Objectives tab	View on Objectives
Create / Edit a goal	Manage on Objectives
Delete a goal	Full Control on Objectives
Name other people in GRC Contact, Goal Owner Contact, Audit Owners, Audit Evidence Owners	**Can Assign** on Objectives; changing or removing people already named needs **Can Reassign**. Without them the fields offer only yourself.
Open the Audit tab	View on Objectives › Audits (the tab shows a lock otherwise)
Add an audit	Manage on Objectives › Audits
Change an audit's dates, metric, owners or goal	Manage on Objectives › Audits (Edit)
Record **Audit Result** or **Audit Conclusion**	The *Audit Results* right, part of Manage on Objectives › Audits
Delete an audit	Full Control on Objectives › Audits
Open **Settings** (result options)	The button needs Manage on Objectives; adding an option needs Manage on Objectives › Audits and deleting one Full Control on Objectives › Audits
Comment / attach to a goal or audit	The group's Comments & Attachments level

Which goals you see. A group set to *Assigned Records Only* sees only the goals where the user (or a group they belong to) is named as GRC Contact, Goal Owner Contact, Audit Owner or Audit Evidence Owner. The Audit tab then shows only the audits of those goals, and the **Goal** drop-down offers only those goals.

How to

Set up a goal with quarterly audits

1. Open **Governance Hub › Objectives** and click **Add Item**.
2. On **General**, enter *Reduce phishing click rate below 5%*, pick *Alex Meian* as **GRC Contact** and **Goal Owner Contact**, and set **Status** to **Current**.
3. On **Audits**, choose **Audits required**, switch **Occurrence type** to **Periodical**, set **First audit date** and **Frequency Quarterly**.
4. Fill **Audit Methodology**, **Audit Success Criteria**, **Audit Owners** and **Audit Evidence Owners**.
5. On **Activities**, pick the project *SOC 2 Type II readiness*.
6. Click **Save**. The **Audits** column shows the number of generated audits.

Record the result of an audit

1. Open the **Audit** tab.
2. Tick the audit of *Achieve ISO 27001 certification* planned for 2026-10-29 and click **Edit**.
3. Enter **Audit Start Date** and **Audit End Date**, choose **Audit Result Passed** and write the **Audit Conclusion**.
4. Under **Evidence**, attach the evidence file.
5. Click **Save**. The **Dynamic Status** becomes *Pass*.

Mark a goal as achieved

1. Edit *100% staff security training* and set **Status** to **Achieved**.
2. Click **Save**. Linked issues become *Discarded*, linked controls move to *Production*, linked third party risks close and linked business risks become *Mitigated*.

Add a result option

1. On the **Audit** tab, click **Settings**, then **Add New**.
2. Type the name, for example *Not tested*, and click **Save**. It reads *In Progress* as Dynamic Status when used.

CSV import

- **Objectives tab**: no **Import CSV** or **Export CSV** button. The backend has no CSV endpoint for objectives.
- **Audit tab**: **Import CSV** is shown. It first shows *CSV Import (Objective Audits): the import structure is not ready yet.* and then opens a demo dialog that cannot validate a file. Import of objective audits is not available in this release. There is no **Export CSV**.

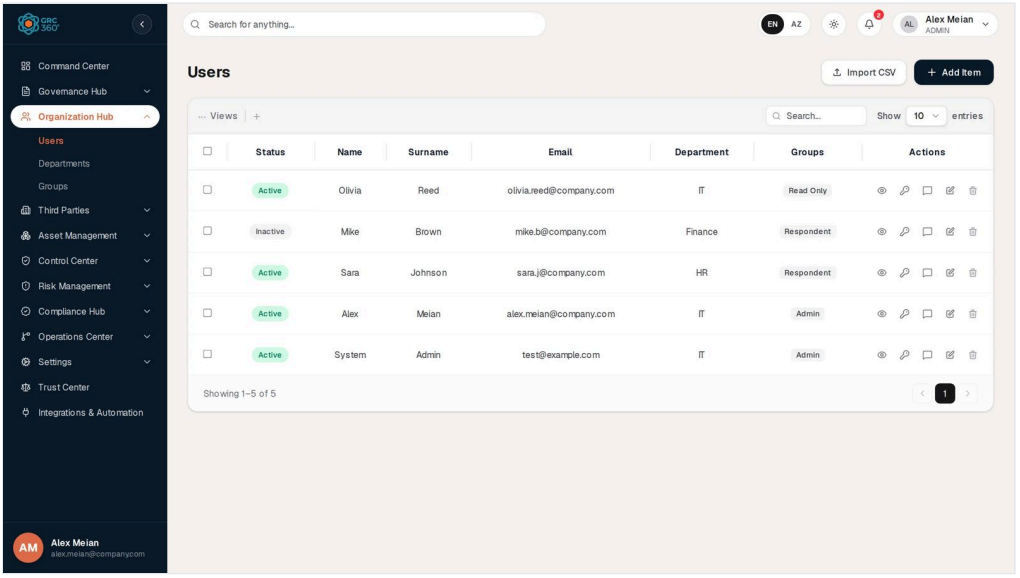
Limitations and known issues

- **The Audit tab is labelled "Audit"** on the page but **Audits** in the sidebar's permission settings.
- **Editing a goal removes its target date** (and its owner/internal user links and manual progress), because the form does not have or send these fields.
- **Objective reminders are not sent.** The scheduled job exists but scheduled jobs are not enabled.
- **Progress is not visible** even though the backend calculates it.
- **Coverage cannot be linked from the form.** The backend supports objective–coverage links; the form has no field for them.
- **New result options always read In Progress**, because their outcome is fixed at creation and cannot be edited on screen.
- **Goal Owner Contact may show only in Edit.** On demo goals created through the API, the View dialog and the grid show an empty Goal Owner Contact while the Edit form shows a chip, because the form reads the stored person links and the grid reads the stored names.
- **Settings is checked against the Objectives page right**, not against Objectives › Audits, in the browser. Renaming a result option needs only View on Objectives › Audits on the server.
- **Import CSV on the Audit tab does not work** (demo dialog).

Organization Hub

> **Module:** Organization Hub · **Route:** `/organization` (opens **Users**) · **Permission module:** `organization`

The Organization Hub holds the people who use GRC360 and the structure they work in: the user accounts, the departments of the organisation, and the groups that decide what each person may open and change. Everything else in GRC360 refers back to this module. Every “contact”, “owner” or “reviewer” picker in the other registers offers the users and groups kept here, departments are named on assets, business risks and data flows, and the access level of every page is set on a group.



Users register

Pages

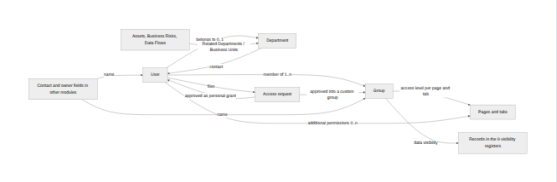
Page (sidebar label)	Route	Permission key	What it holds
Users	`/organization/users`	`organization.users`	One record per person who can sign in: name, email, department, group membership, status and REST API access. Also the place where an administrator gives a person an individual, time-limited permission (**Additional Permissions**).
Departments	`/organization/departments`	`organization.departments`	The organisation’s departments, each with a department contact and two computed counts: the business risks and asset risks that concern it.
Groups	`/organization/roles`	`organization.roles`	The groups (called roles in the code and in the permission codes) that carry permissions: one access level per page and tab, a comments level, the assignment rights and the data visibility. Also the queue of **Access Requests**.

Opening `/organization` without a page redirects to **Users**.

The sidebar label **Groups** is a label only. The route stays `/organization/roles` and the permission codes stay `organization_roles_*`, so a group that could open “Roles” in an earlier release still opens **Groups** today.

How the three pages relate

- A **user** belongs to at most one **department** and to one or more **groups**. The Add/Edit User form picks one group; a user who already holds several keeps them as long as the Groups field is not changed (see Users).
- A user's rights are the combination of every group they belong to, plus any active **additional permission** granted to them personally. Nothing can take a right away: there is no "deny".
- A **department** names one or more contacts, picked from users and groups. The first picked *user* is also stored as a link to that user record.
- A **group** decides which pages a member can open (access levels) and which records they find there (data visibility). Groups are also offered as contacts in every user-and-group picker, so a record can name a whole group as its GRC contact or reviewer.
- **Access requests** connect the three: a user who meets a locked button asks for the missing permission, members of the **Admin** group are notified, and a decision either adds a personal grant to the user or adds the permission to one of the user's groups.



Built-in groups at a glance

Every organisation starts with three built-in groups. They are marked **Default** in the Groups table and cannot be deleted or renamed. Full details are on the Groups page.

Group	Starting permissions	Data visibility	Can be edited
Admin	Everything in the catalogue, Settings included	All Records	No. It is locked and rewritten from the catalogue at every server start.
Read Only	View on every page and tab except Settings	All Records	Yes
Third Party	Read and edit on Vendors, Service Agreements, Third Party Risks and Compliance Analysis	Assigned Records Only	Yes

The demo data also contains a group called **Respondent**. It was a built-in group in earlier releases; the current release demotes it to an ordinary group, so it carries no **Default** badge and can be edited and deleted like any group created by hand.

Permissions for the module

Page	What View allows	What Manage adds	What Full Control adds
Users	See the users list and each user's details	Add and edit users, import users from CSV	Delete users
Departments	See the departments list	Add and edit departments	Delete departments
Groups	See the groups, their access and their members	Add a group with no access set, and edit a group's name and description	Delete groups, **set or change a group's access and data visibility**, clone a group that has permissions, give individual permissions, decide access requests

Changing what a group may do, or giving a person an individual permission, requires the right shown in the code as **Manage Access Control** (`organization_roles_manage-access`). It is part of **Full Control** on **Organization Hub › Groups**. A user who has only Manage on Groups can create a group and edit its name and description, but every change to its access is refused.

Automations and notifications

What	When	Who is told
`ACCESS_REQUEST` notification	A user files an access request	Every member of the group named exactly **Admin**, except the requester. The notification links to `/organization/roles?accessRequests=1`, which opens the Access Requests queue.
`ACCESS_APPROVED` / `ACCESS_REJECTED` notification	An administrator decides a request	The requester
Permission refresh in open sessions	A group's permissions, a user's groups or an individual grant change	Every signed-in user of the organisation picks up the change within about 10 seconds, without signing in again
Expiry of individual grants	The grant's end date passes	No job runs. A grant is simply no longer counted after its end date, and the Users page shows it under **History** as **EXPIRED**.
Permission catalogue sync	Every server start	The catalogue of pages and actions is rewritten, the **Admin** group receives every permission again, and Settings permissions are removed from every other group

CSV import

Only **Users** has a working CSV import. On **Departments** and **Groups** the **Import CSV** button shows the message *"CSV Import (Departments): the import structure is not ready yet."* (or *Groups*) and then opens a demonstration upload dialog whose validation fails, because no import exists behind it. See Working with registers.

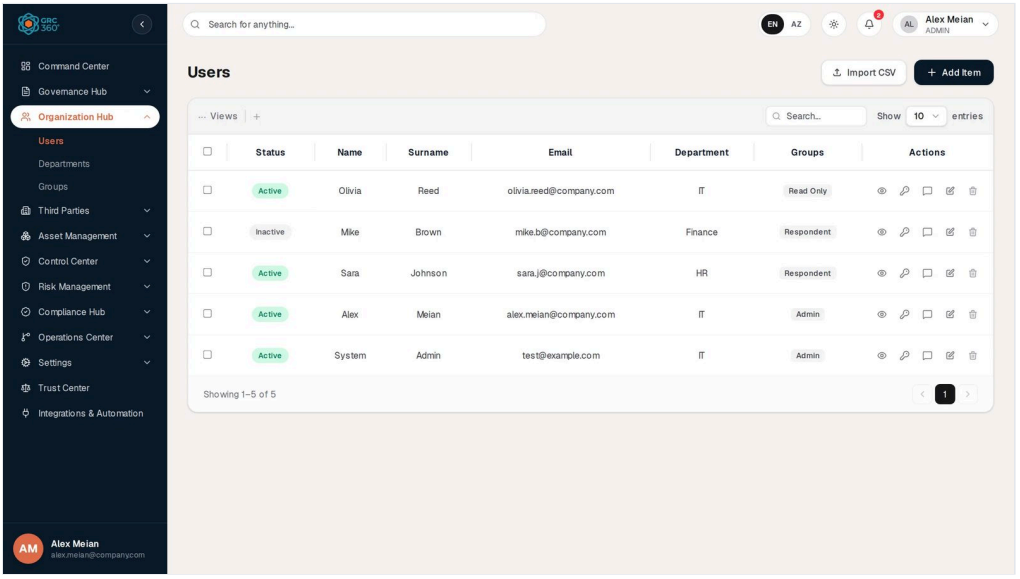
See also

- Permissions and access: what a user sees without a permission and how to request it.
- Working with registers: the toolbar, Views, search, paging, row actions, Activity Log and pickers shared by every page in this module.

Users

> **Module:** Organization Hub › Users · **Route:** `/organization/users` · **Permission key:** `organization.users`

The Users register lists every person who can sign in to GRC360 in your organisation. A record holds the person's name and email (the email is also the sign-in name), their department, the groups that give them their permissions, whether the account is active, and whether the person may use the REST API. Creating a user here also creates the sign-in account, with the password you enter. Administrators and whoever handles joiners and leavers work in this page; everyone else mostly meets these records as names in the contact pickers of other registers.



Users register

At a glance

A record is	One person who can sign in, with their sign-in account
Typical owner	GRC360 administrator, HR or IT onboarding
Links to	Department (0..1), Groups (one or more), individual permission grants
Linked from	Every user-and-group picker in GRC360 (GRC Contact, Reviewers, Data Owner and similar), Department Contact, access requests
Tabs	None
Automations	None on the record. Changes to a user's groups reach that user's open session within about 10 seconds.

The register (list view)

The grid is paged on the server and opens newest first (by creation date). The shared grid behaviour (search, Views, paging, selection, Activity Log) is described in Working with registers.

Column	What it shows	Source
Status	**Active** (green) when the account status is `ACTIVE`; **Inactive** (grey) for every other stored status (`INACTIVE`, `PASSIVE`, `SUSPENDED`, `PENDING`)	Entered
Name	First name	Entered
Surname	Last name	Entered

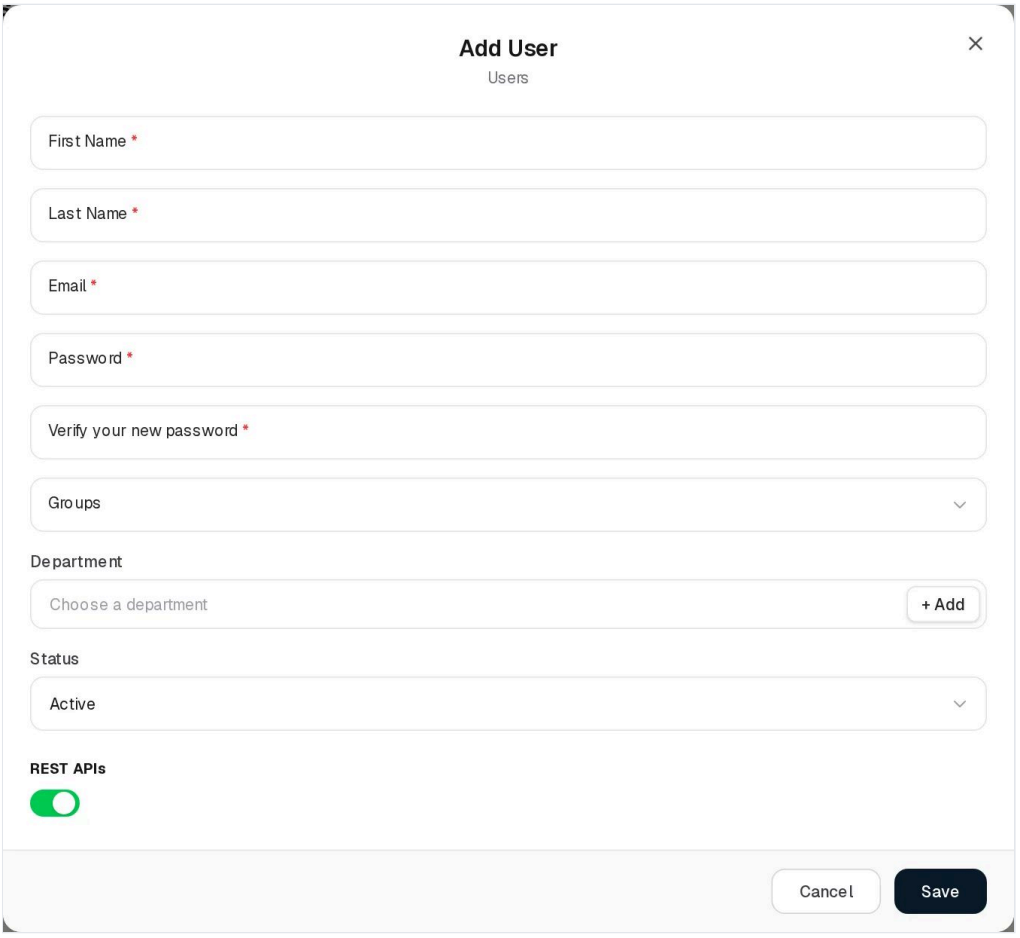
Column	What it shows	Source
Email	Email address, also the sign-in name	Entered
Department	The department's name, or `-`	Linked
Groups	One grey chip per group the user belongs to, or `-`	Linked

Row actions. Besides the shared View, Activity Log, Edit and Delete buttons, each row has a key icon, **Additional Permissions**. It is shown only to users who hold **Manage Access Control** on Groups (part of **Full Control** on **Organization Hub › Groups**); without that right the icon is not drawn at all.

Who is listed. A user whose groups include any group with "admin" anywhere in its name (for example **Admin**, or a group someone called "IT Admins") is hidden from the list for viewers who are not themselves in such a group. The page total counts only the rows you may see.

Creating a record

Click **Add Item**. The **Add User** dialog opens.



Add User

Field	Type	Required	Rules and allowed values	Example
First Name	Text	Yes	Must not be blank (*"First name is required"*). Up to 100 characters.	Olivia
Last Name	Text	Yes	Must not be blank (*"Last name is required"*). Up to 100 characters.	Reed

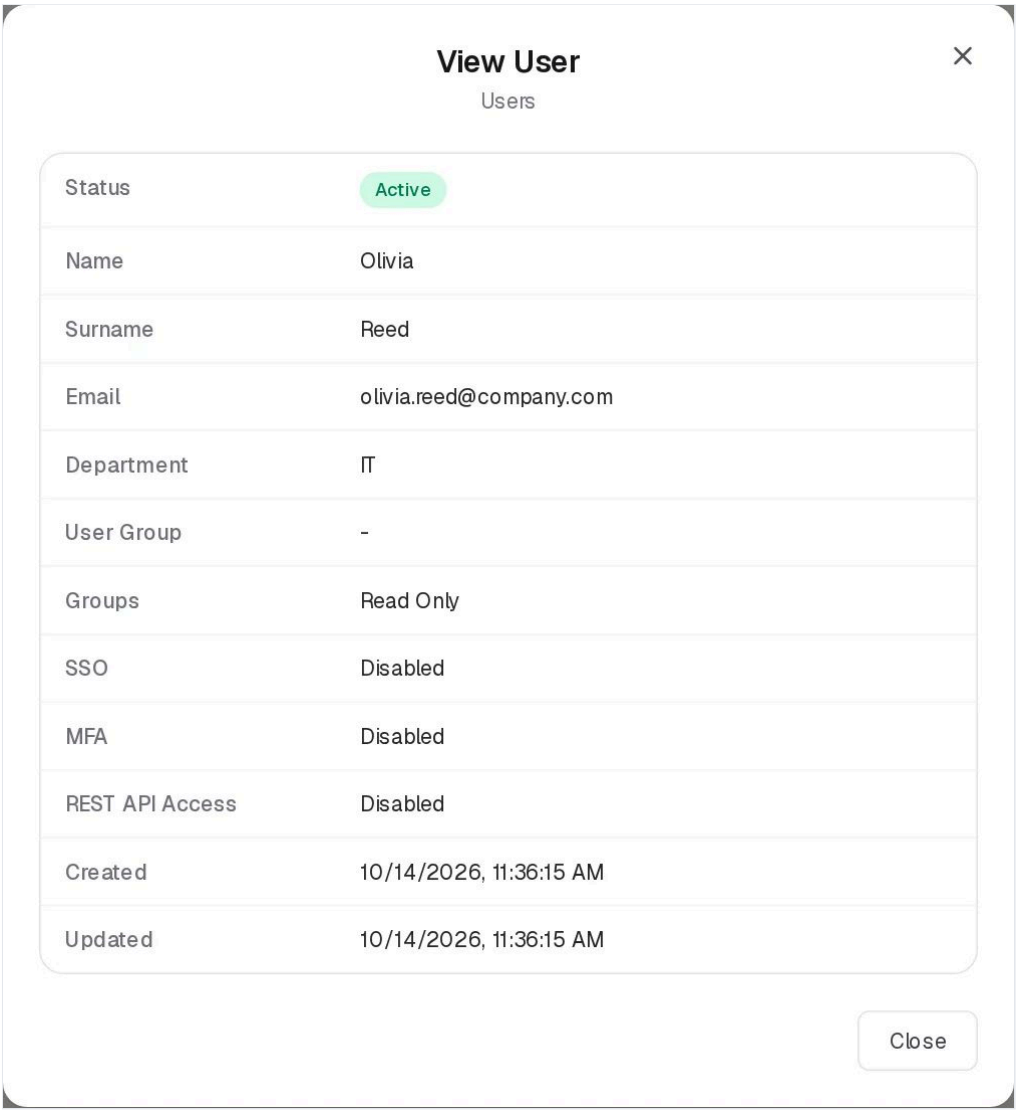
Field	Type	Required	Rules and allowed values	Example
Email	Text	Yes	Must look like an email address (*"Invalid email"*). Up to 255 characters. Must be unique in the organisation (*"User with this email already exists"*).	olivia.reed@company.com
Password	Password	Yes on Add	At least 8 characters (*"Password must be at least 8 characters"*).	(not shown)
Verify your new password	Password	Yes on Add	Must equal Password (*"Passwords do not match"*).	(not shown)
Groups	Drop-down	No	One group from the **Groups** register. The list shows every group, built-in ones included.	Read Only
Department	Picker with **+ Add**	No	One department. Clicking the field opens a searchable list; clicking the picked department again, or the chip's **×**, clears it. **+ Add** opens the Add Department form and selects the new department.	IT
Status	Drop-down	No	**Active** or **Inactive**. Default **Active**.	Active
REST APIs	Switch	No	On allows the user to call the REST API with their own credentials. Default on for a new user.	Off

Click **Save**. The user can sign in immediately with the email and password you entered if the status is **Active**.

Rules applied when you save (the server's message is shown at the bottom of the form):

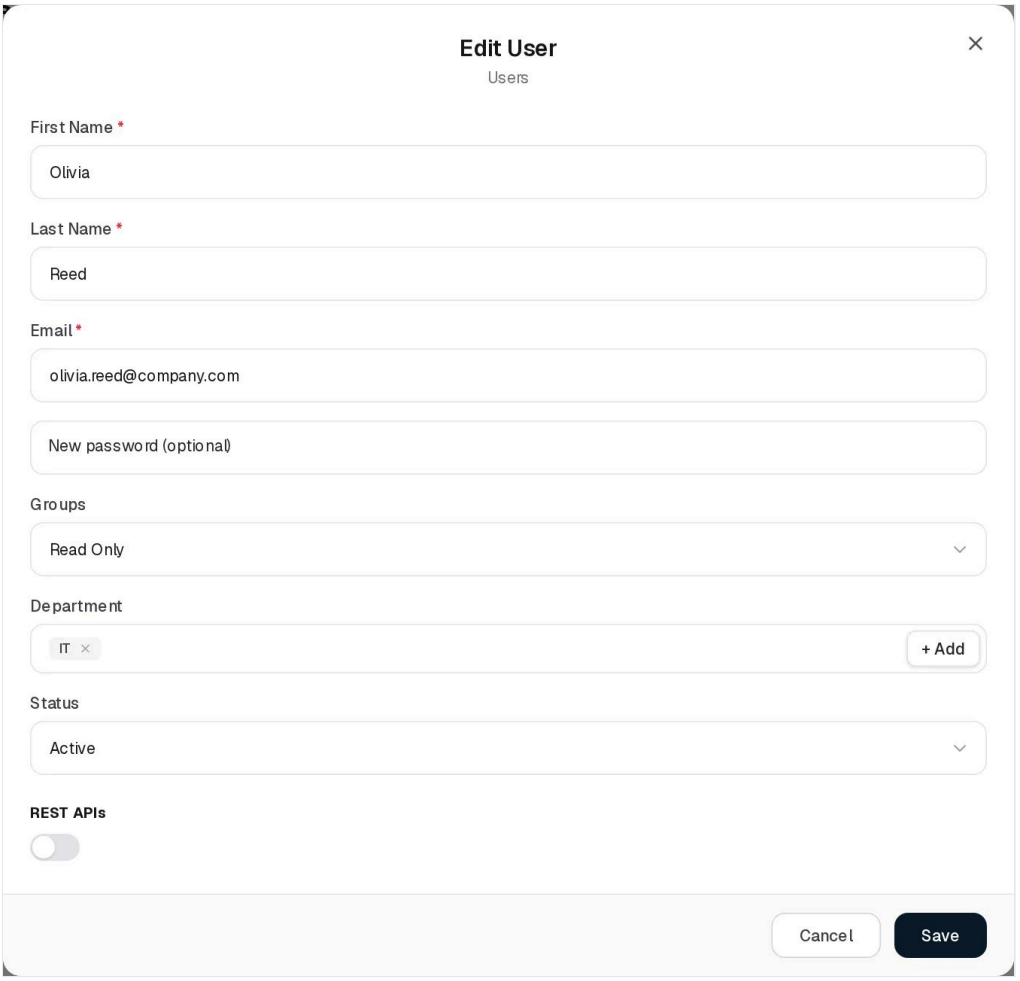
- You cannot put anyone into the **Admin** group, or take anyone out of it, unless you are an administrator yourself: *"Only an administrator can add people to the Admin group or remove them from it."*
- You cannot change your own groups: *"You cannot change your own group membership. Ask an administrator."*
- The last member of **Admin** cannot be taken out of it: *"Cannot remove the Admin role. At least 1 Admin must remain in the system."*

Viewing and editing a record



View User

View User lists Status, Name, Surname, Email, Department, User Group, Groups, SSO, MFA, REST API Access, Created and Updated. **User Group** is an older field that the form no longer sets; it shows `-` for users created in this release. **SSO** and **MFA** are read-only here: MFA is turned on by each user for their own account.



Edit User

Edit User has the same fields as Add, with two differences:

- The password field is **New password (optional)**. Leave it empty to keep the current password. When you type one, **Verify your new password** appears and both rules above apply.
- The labels sit above the filled-in fields.

Changing the email also changes the sign-in name. Changing the status to **Inactive** stops the person from signing in.

Statuses

Value	Set by	Meaning
Active	User (Status field)	The person can sign in.
Inactive	User (Status field)	The person cannot sign in. The record, its group membership and every reference to the person stay.
Inactive (shown for `PASSIVE`, `SUSPENDED`, `PENDING`)	System or API	Other stored states. The grid shows them all as **Inactive**. Opening Edit on such a user shows **Inactive**, and saving writes `INACTIVE`.

There is no Dynamic Status on this page.

Additional Permissions

An additional permission (an individual grant) gives one person one permission on top of their groups, usually for a limited time. It does not change the person's groups. Open it with the key icon on the user's row.

Element	What it does
Grant a permission drop-down	Every permission of the catalogue, grouped as *Module → Page* (or *Module → Page → Tab*), each named *Page: action*, for example *Departments: Create New Item*. Settings is not offered.
Duration	**7 days**, **30 days (recommended)** (default), **90 days**, **Permanent**
Reason	Free text, up to 1,000 characters, shown in the audit trail
Grant	Saves the grant
Active (n)	Current grants: permission name, *Until* date or *Permanent*, who granted it, the reason, an **ACTIVE** badge and a **Revoke** button
History (n)	Revoked and expired grants with a **REVOKED** (red) or **EXPIRED** (grey) badge

Rules:

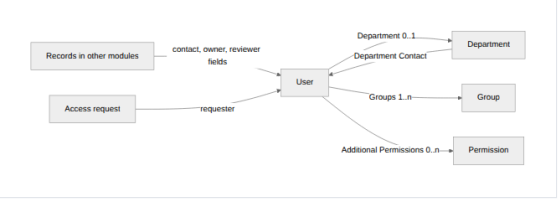
- If the permission is not a *Section Index* (read) permission, the read permission of the same page is granted with it, with the same end date and the reason *"Read prerequisite of …"*. For a tab, the read permission of the parent page is added as well.
- Revoking a page's read grant also revokes the person's other active grants on that page and on its tabs.
- You cannot grant to yourself (*"You cannot grant a permission to yourself"*), grant something the person already has through a group (*"The user already has this permission through their roles"*) or already holds as an active grant, or grant a permission you do not hold yourself unless you are an administrator (*"You cannot give permissions you do not hold yourself."*).
- An end date must be in the future. Expiry needs no job: the grant stops counting at that moment.
- Approving an access request with **Grant to this user only** creates the same kind of grant, with the reason *"Approved access request: …"*. In the demo data, approving Olivia Reed's pending request for *Asset Risks: Create New Item* would add that grant to her row. See Groups › Access requests, which shows the queue.

Individual grants use the permission names of the catalogue (*Section Index*, *Create New Item*, *Edit Accessible Items* and so on), not the access levels of the Groups page. A person given *Create New Item* on Vendors by grant does not automatically get **Can Assign**; it must be granted separately.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Department	User → Department, many to one	**Department** field on the form	**Department** column and View
Group	User → Group, many to many	**Groups** field on the form; CSV import; access request approval does not change it	**Groups** column; the **Users** count and **Assigned Users** tab of the Groups page
Individual grant	User → Permission, one to many	**Additional Permissions** dialog or an approved access request	**Additional Permissions** dialog only
Department Contact	Department → User	**Department Contact** on the Departments form (the first picked user)	Departments grid
Contact fields of other registers	Other record → User	Every user-and-group picker (GRC Contact, Asset Reviewer Contact, Reviewers, Data Owner and so on)	The other register's columns

Deleting a user. The **Delete** button removes the person for good, together with their sign-in account. Before the row goes, every module that names the person as a contact, owner or assignee drops its link but keeps the displayed name, and departments that had the person as contact stop naming a linked user. The last member of **Admin** cannot be deleted: *“Cannot delete the last Admin. At least 1 Admin must remain in the system.”* The confirmation reads *“Delete user Olivia Reed? This cannot be undone.”*

Automations and notifications

None for the user record itself. When a user’s groups or individual grants change, every open session of that user receives the new permission list within about 10 seconds, without signing in again.

Permissions

Action	Needed access
See the page	View on **Organization Hub › Users**
Create a user, import users	Manage on **Organization Hub › Users**
Edit a user	Manage on **Organization Hub › Users**
Delete a user	Full Control on **Organization Hub › Users**
Fill the **Groups** and **Department** pickers	The pickers read the Groups and Departments lists; a user who cannot read them still gets a usable form, with empty lists
Put someone into or out of **Admin**	Membership of **Admin**
Additional Permissions (view, grant, revoke)	**Full Control** on **Organization Hub › Groups** (the Manage Access Control right)
Activity Log	The group’s **Comments & Attachments** level (View, Contribute, Manage)
Assign / Reassign	Not used on this page

How to

Add a new colleague with read-only access

1. Open **Organization Hub › Users** and click **Add Item**.
2. Enter **First Name** *Olivia*, **Last Name** *Reed*, **Email** *olivia.reed@company.com*, and a password of at least 8 characters in both password fields.
3. In **Groups** choose **Read Only**. In **Department** click the field and pick **IT**.
4. Switch **REST APIs** off unless the person needs the API.
5. Click **Save**. The new row appears at the top of the list with status **Active**.

Stop someone from signing in without deleting them

1. Find **Mike Brown** in the list (use the search box).
2. Click **Edit**, set **Status** to **Inactive**, click **Save**.
3. The row shows **Inactive**. Every record that names Mike Brown keeps doing so.

Give one person temporary extra access

1. On the row of **Sara Johnson**, click the key icon (**Additional Permissions**).
2. In **Grant a permission** choose *Organization Hub → Departments › Departments: Create New Item*.
3. Keep **30 days (recommended)**, type a reason such as *Covering for the HR lead*, click **Grant**.
4. The grant appears under **Active** together with *Departments: Section Index*, which was added automatically. Sara’s open session picks it up within about 10 seconds.

Reset a user’s password

1. Click **Edit** on the user.

2. Type the new password in **New password (optional)** and again in **Verify your new password**.
3. Click **Save** and give the person the new password through a safe channel.

CSV import

Import CSV works on this page. Clicking it first shows the general message *“CSV Import (Users): the import structure is not ready yet.”* and then opens a file chooser; the chosen file is imported immediately, without a preview.

Column header (any letter case)	Required	Meaning
`firstname`	Yes	First name
`lastname`	Yes	Last name
`email`	Yes	Email and sign-in name
`password`	No	Password. If blank, a random 12-character password is set that nobody is told, so the person cannot sign in until an administrator sets a password through **Edit**.
`department`	No	Department name, matched exactly. An unknown name is ignored.
`role`	No	Group name, matched exactly. An unknown name is ignored. One group only.

Every imported user is **Active**. Values are split on commas with no quoting, so a value cannot contain a comma. Rows go through the same checks as the form (unique email, Admin group rules). The server reports per-row errors, but the page only shows *“Users imported.”* even when some rows failed, so check the list afterwards.

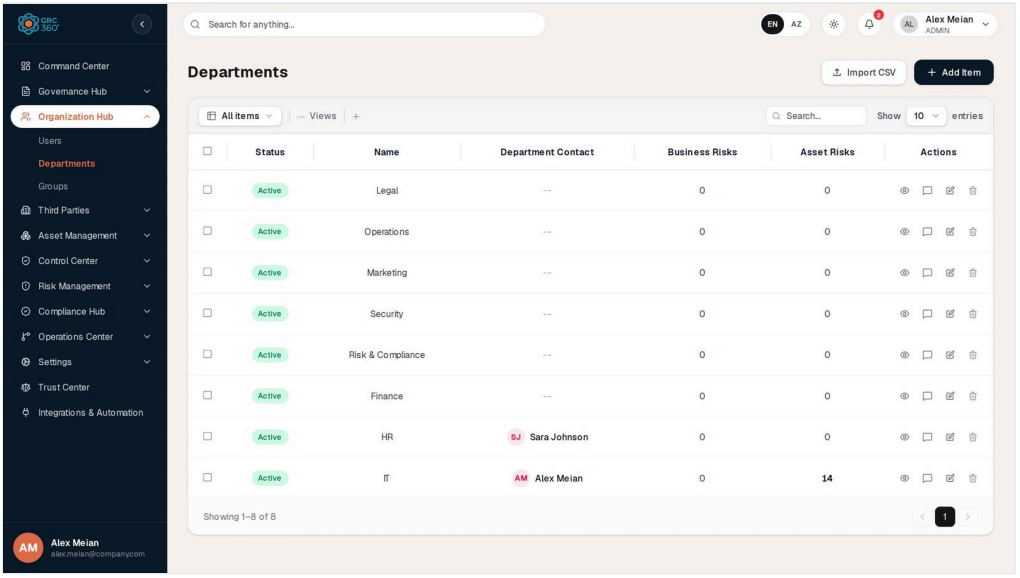
Limitations and known issues

- **One group in the form.** The **Groups** field picks a single group. A user who holds several groups keeps all of them as long as you do not touch the field; choosing another group in it replaces all of them with the one chosen.
- **“Admin” by substring.** Users in any group whose name contains “admin” are hidden from non-administrators in this list, although permissions treat only the group named exactly **Admin** as the administrator group.
- **CSV import feedback.** The page shows *“Users imported.”* even when rows were rejected, and the “not ready yet” message appears before every import.
- **Statuses collapsed.** `PASSIVE`, `SUSPENDED` and `PENDING` all show as **Inactive**, and saving such a user writes `INACTIVE`.
- **User Group** in the View dialog belongs to an older model and cannot be set from the UI.

Departments

> **Module:** Organization Hub › Departments · **Route:** `/organization/departments` · **Permission key:** `organization.departments`

The Departments register lists the organisation's departments (business units). A record is one department with its name, a description and one or more department contacts. Departments are the organisational dimension of GRC360: users belong to one, assets are booked against one or more, business risks name the business units they apply to, and data flows name the departments they pass through. The grid shows, for each department, how many business risks and asset risks concern it. Administrators maintain the list; risk and asset owners use it through pickers.



Departments register

At a glance

A record is	One department or business unit
Typical owner	GRC360 administrator or the organisation's GRC lead
Links to	Department Contact (users and groups)
Linked from	Users (Department), Assets (Related Departments), Business Risks (applicable business units), Data Flows (Departments)
Tabs	None
Automations	The **Business Risks** and **Asset Risks** counts are computed on every read

The register (list view)

The whole list is loaded at once (no server paging) and refreshes when departments, business risks, asset risks or assets change anywhere in GRC360. Shared grid behaviour is described in Working with registers.

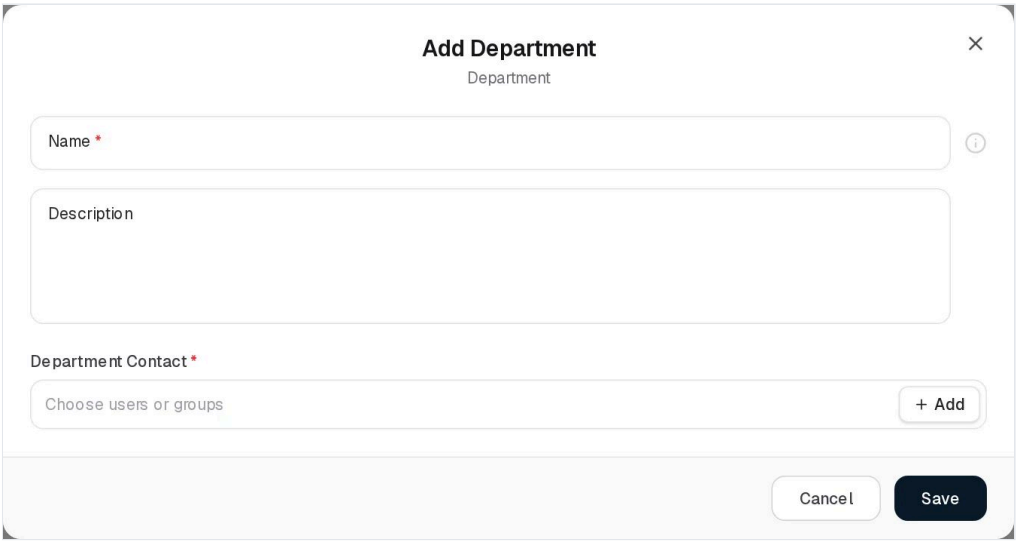
Column	What it shows	Source
Status	**Active** (green). See Statuses.	Stored
Name	Department name	Entered
Department Contact	Avatar and name of each contact, or `--`	Entered

Column	What it shows	Source
Business Risks	Number of business risks that name this department as an applicable business unit. A number above 0 is a link: clicking it opens the list of those risks.	Computed
Asset Risks	Number of asset risks whose assets are booked against this department (through the asset's **Related Departments**). A number above 0 is a link that opens the risks.	Computed

In the demo data, **IT** shows 15 asset risks (the assets booked against IT carry them) and Alex Meian as contact; **HR** has Sara Johnson as contact.

Creating a record

Click **Add Item**. The **Add Department** dialog opens.



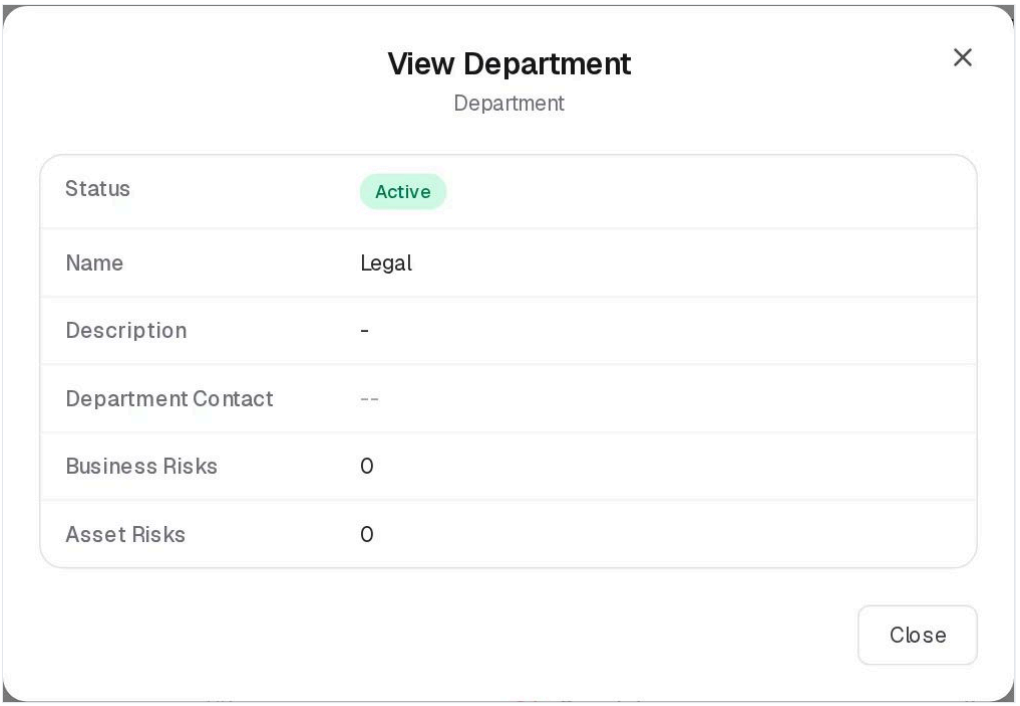
Add Department

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Must not be blank (*"The field is required"*). Up to 255 characters. Must be unique in the organisation (*"Department with this name already exists"*).	Risk & Compliance
Description	Text area	No	Up to 1,000 characters	Second-line risk and compliance function
Department Contact	User-and-group picker, several allowed, with **+ Add**	Yes	At least one user or group (*"Department Contact is required"*). **+ Add** creates a new user on the spot.	Alex Meian

How the contact is stored: the names of everyone picked are saved together, and the first picked **user** (not group) is also saved as a link to that user record. If you pick only groups, the department has contacts but no linked user.

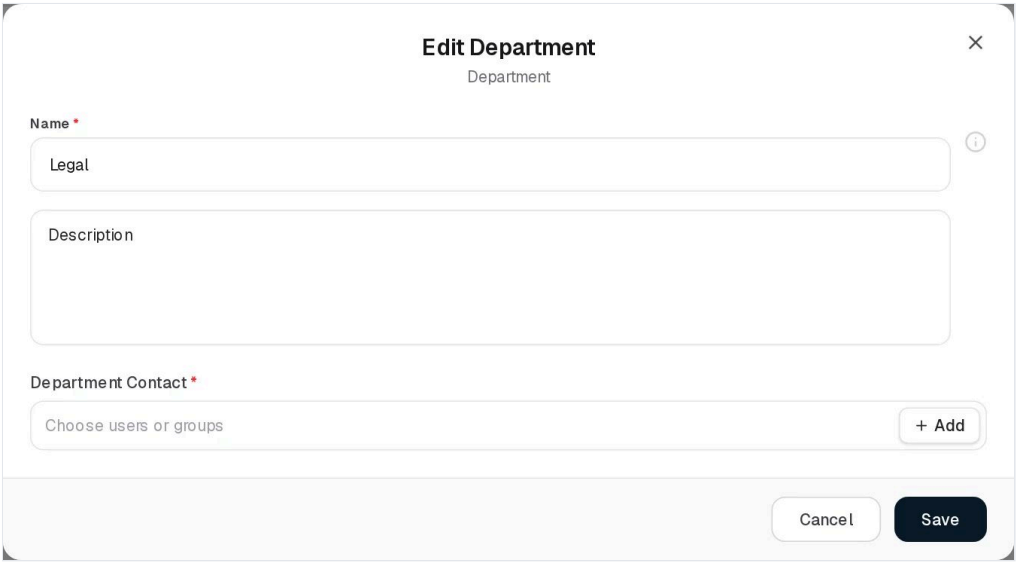
Click **Save**; the message *"Department added."* confirms it.

Viewing and editing a record



View Department

View Department shows Status, Name, Description, Department Contact, Business Risks and Asset Risks. The counts are plain numbers in this dialog; they are clickable only in the grid.



Edit Department

Edit Department has the same three fields as Add. The contact is required on Edit too, so a department imported or created without a contact (such as **Legal** in the demo data) cannot be saved until a contact is picked.

Renaming a department also renames it on every asset that lists it in **Related Departments**, so the asset counts keep working.

Statuses

Value	Set by	Meaning
Active	System (every new department)	The department is in use.

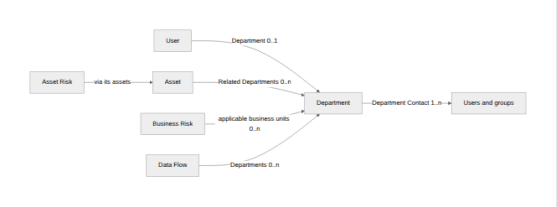
The backend also knows a deactivated state (`PASSIVE`), but the page offers no way to set it: there is no Status field and **Delete** removes the department outright. A department deactivated through the API still shows **Active** in this grid.

There is no Dynamic Status on this page.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Users and groups (contact)	Department → people, one to many	**Department Contact** on this form	**Department Contact** column
Users	User → Department, many to one	**Department** on the Add/Edit User form	Users grid **Department** column
Assets	Asset → Department, many to many	**Related Departments** on the asset form	Assets grid; feeds this page's **Asset Risks** count
Business Risks	Business risk → Department, many to many	The risk's applicable business units field in Risk Management	**Business Risks** count (clickable)
Asset Risks	Asset risk → Asset → Department	Indirect, through the assets the risk applies to	**Asset Risks** count (clickable)
Data Flows	Data flow → Department, many to many	**Departments** on the data flow form	Data Asset Flows grid

Automations and notifications

None. The two risk counts are recalculated each time the list is read.

Permissions

Action	Needed access
See the page	View on **Organization Hub › Departments**
Create / Edit	Manage on **Organization Hub › Departments**
Delete	Full Control on **Organization Hub › Departments**
Create a department from the **+ Add** button in another form (for example the Department field of Add User)	Manage on **Organization Hub › Departments**; without it the **+ Add** button is hidden
Open the risks behind a count	View on the risk register concerned
Activity Log	The group's **Comments & Attachments** level
Assign / Reassign	Not used on this page

Deleting. Delete removes the department permanently, and is refused while anything still uses it:

- *"Cannot delete department: 3 user(s) are still assigned to it"*
- *"Cannot delete department: 2 asset(s) are still assigned to it"*
- *"Cannot delete department: 1 risk(s) are still assigned to it"*

The reason is shown inside the confirmation dialog. Move the users or assets to another department first. The risk check counts records of an older, generic risk table that the current risk registers do not use; business risks that name the department as a business unit do **not** block the deletion, and keep the deleted department's id.

How to

Add a department and its contact

1. Open **Organization Hub › Departments**, click **Add Item**.
2. **Name**: *Internal Audit*. **Description**: *Third-line assurance*.
3. In **Department Contact** pick **Alex Meian**. Add a group as well if the whole team should be named.
4. Click **Save**.

Give the Legal department a contact

1. Click **Edit** on **Legal**.
2. Pick a user in **Department Contact** (the field is required, and Legal has none in the demo data).
3. Click **Save**. The contact's avatar appears in the grid.

See which asset risks concern IT

1. In the **IT** row, click the number **15** in **Asset Risks**.
2. The panel lists those asset risks; open any of them from there.

Remove a department that is no longer used

1. Click **Delete** on the department and confirm.
2. If the dialog reports users, assets or risks still assigned, reassign them (for example change the users' **Department** on the Users page) and try again.

CSV import

Not available. **Import CSV** shows *"CSV Import (Departments): the import structure is not ready yet."* and opens a demonstration dialog whose validation fails, because there is no department import behind it.

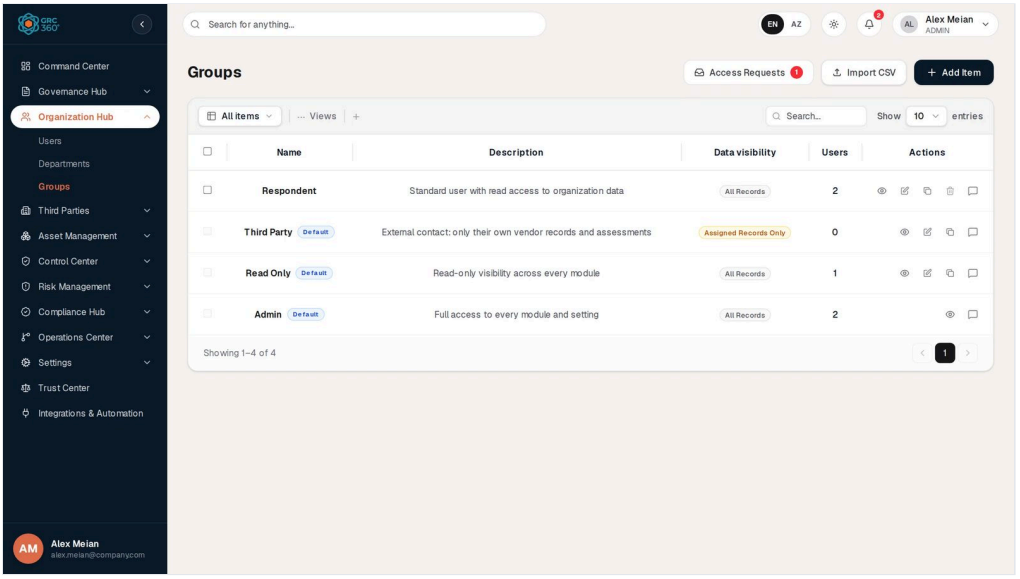
Limitations and known issues

- Departments cannot be deactivated from the page, only deleted; a department deactivated through the API still shows **Active**.
- The **Department Contact** is required in the form, while the backend accepts a department without one. Departments created by other means can therefore show `--` and must get a contact before their next save.
- A department contact that is a group is stored as a name only; only the first picked user is stored as a link.
- Deleting a department is not blocked by the business risks that name it as an applicable business unit; those risks keep pointing at a department that no longer exists.

Groups

> **Module:** Organization Hub › Groups · **Route:** `/organization/roles` · **Permission key:** `organization.roles`

A group is a set of permissions that users are members of. Permissions in GRC360 are given to groups, never directly to a role-less user (individual, usually time-limited grants are the one exception, see Users › Additional Permissions). This page lists the groups, lets administrators define for each group which pages and tabs its members can reach and what they may do there, which records they find, how they may use comments and attachments, and whether they may assign records to other people. It also holds the queue of **access requests** filed by users who met a locked button. The code and the permission codes call groups “roles”; the screen says **Groups**.



Groups register

At a glance

A record is	One group: a name, a description, a data visibility mode and a set of permissions
Typical owner	GRC360 administrator (members of **Admin**)
Links to	Permissions (the catalogue of pages, tabs and actions)
Linked from	Users (Groups), every user-and-group picker in GRC360, access requests, vendors (Vendor Role, set before this release)
Tabs	None on the page. The View dialog has **Assigned Users** and **Access**.
Automations	At every server start the permission catalogue is synchronised and the **Admin** group rewritten. Permission changes reach open sessions within about 10 seconds. Access requests notify the Admin group.

How the permission model works

The four layers

Layer	Set where	Decides
Access level per page and per tab	Groups › Access columns	Whether a member sees the page or tab at all, and which record actions it allows

Layer	Set where	Decides
Comments & Attachments	Groups, once per group	Whether a member can read, add or delete comments and attachments in the Activity Log of the pages the group opens
Assignment Management	Groups, once per group	Whether a member may name other people on a record (**Can Assign**) and change people already named (**Can Reassign**) on the nine assignable registers
Data visibility	Groups, once per group	Which records of the nine visibility registers a member finds on the pages they can open

A user's effective rights are the union of all their groups plus their active individual grants. Nothing removes a right that another group gives.

Access levels

Every page of the sidebar is a permission unit, and so is every tab that carries its own permissions (for example **Assets › Reviews**). For each unit a group has exactly one level.

Level	Description shown in the form	Permission codes it grants on the unit
No Access	*The user cannot see or open this section.*	None. The page disappears from the sidebar; opening its address shows **Access Denied**.
View	*The user can only read the section and the records they may see.*	`read` (**Section Index**), `export` (**View Reports**)
Manage	*View, plus creating new records and editing existing ones.*	View, plus `create` (**Create New Item**), `edit` (**Edit Accessible Items**), `import` (**Manage Import Tool**), `audit-results` (**Audit Results**), `maintenance-results` (**Maintenance Results**)
Full Control	*View, plus create, edit and delete.*	Manage, plus `delete` (**Delete Accessible Items**), `manage-settings` (**Manage Section Settings**), `manage-access` (**Manage Access Control**). Any action added to the catalogue later and not yet mapped also falls under Full Control.

A level grants only the codes the unit actually has. Where two levels would grant the same thing, the higher one is not offered. Examples:

Unit	Levels offered	Notes
Command Center (dashboard)	No Access, View	The dashboard can only be read
A register page such as **Third Parties › Vendors**	No Access, View, Manage, Full Control	
Risk Management › Asset Risks	All four	Full Control also gives **Manage Section Settings** (the risk calculation settings)
Organization Hub › Groups	All four	Full Control also gives **Manage Access Control**, the right to change groups' access, give individual grants and decide access requests
A tab such as **Asset Management › Assets › Reviews**	All four	View = read; Manage = create, edit; Full Control = delete
Control Center › Controls › Audits	All four	Manage includes **Audit Results** (writing the audit result and conclusion)
Control Center › Controls › Maintenances	All four	Manage includes **Maintenance Results**

Unit	Levels offered	Notes
Settings (all pages)	Not shown	Settings belongs to **Admin** alone and cannot be given to any other group, grant or request

Tabs and their page. Setting a tab above No Access raises its page to at least View, because a tab cannot be opened on a closed page. Setting a page to No Access sets all its tabs to No Access. The server applies the same rule: any permission on a unit brings the unit's `read`, and a tab's permission also brings its page's `read`.

Comments & Attachments

One choice per group, applied to every page and tab the group can open (View or higher) that has an Activity Log.

Choice	Description in the form	Codes
None	*Comments and attachments are not shown.*	none
View	*Can see comments and attachments.*	`view-comments` (**View List of Comments and Attachments**)
Contribute	*Can see and add comments and attachments.*	plus `create-comments` (**Create Comments and Attachments**)
Manage	*Can see, add and delete comments and attachments.*	plus `delete-comments` (**Delete Comments and Attachments**)

The author of a comment can always delete their own comment. The change history of a record comes with the page's View level, not with this choice. The dashboard, Settings and Integrations & Automation have no Activity Log. When the group's pages hold different comment rights (possible for groups created before this editor), the form shows *"Sections differ today — choose one to apply it to all of them."* and the View dialog shows **Mixed**.

Assignment Management

Two checkboxes per group: **Can Assign** (*Can assign a record to other users.*) and **Can Reassign** (*Can change an existing assignment.*). They apply to the nine assignable registers on which the group has **Manage** or **Full Control**: Assets, Asset Risks, Third Party Risks, Business Risks, Controls, Policies & Standards, Vendors, Service Agreements and Objectives. The form notes: *"Applies to the registers this group can manage. Without these rights a user can still assign themselves."*

The rule is applied field by field to each people field of a record (for example **GRC Contact** and **Asset Reviewer Contact** on an asset). The person saving never counts:

What happens to the other people in the field	Right needed
Unchanged, or the user only added or removed themselves	None
The field named nobody else before (always the case on a new record) and now names someone	**Can Assign**
The field named someone else before and the set of other people changes (replaced, added to, removed, cleared)	**Can Reassign**

Without the right, the picker switches to "only me" mode: it offers only the user themselves, keeps the chips of people already named, and its lock hint (*"Assigning other people requires Can Assign — click to request access"* or *"Changing who is assigned requires Can Reassign — click to request access"*) opens the access request dialog. The server refuses a save that breaks the rule with the usual access-request offer. The fields covered per register are listed in Permissions and access. Fields of tab records (review reviewers, audit and maintenance owners) are not covered.

If a checkbox is checked on some of the group's registers and not on others, it shows as indeterminate; clicking it applies it to all.

Data visibility

Choice	Description in the form	Effect
All Records	*Sees every record in the sections this group can open.*	No narrowing. Default for a new group.

Choice	Description in the form	Effect
Assigned Records Only	*Sees only the records they are assigned to or created, and records assigned to no one.*	On the nine visibility registers (Assets, Asset Risks, Third Party Risks, Business Risks, Controls, Policies & Standards, Vendors, Service Agreements, Objectives), a member finds only records that name them or one of their groups in a people field, records they created, and records that name nobody. Tab records (reviews, audits, issues, maintenances, data flows) follow their parent record.
Their department	*Sees the records of their own department.*	Shown only on a group that already has this mode. It narrows only Assets today, so it is no longer offered for new choices.

A member of several groups gets the widest visibility of them. Data visibility does not affect pages outside the nine registers (for example Policy Exceptions, Projects or Compliance Hub pages), and the Command Center figures are always organisation-wide.

External contacts. A group set as a vendor's *Vendor Role* (possible in earlier releases; the field is no longer on the Vendors form) confines its members to records linked to that vendor whatever the visibility choice, and its members cannot create, edit or delete vendors or service agreements.

Rules that stop people widening their own access

Every change to a group's access, a user's groups or an individual grant passes four checks. Administrators (members of the group named exactly **Admin**) are exempt from rules 2 to 4.

#	Rule	Message when broken
1	A group's permissions and data visibility change only with **Manage Access Control** (Full Control on Groups). With Manage you can still change name and description.	The access request dialog for **Organization Hub › Groups › Manage Access Control**
2	Nobody may change the permissions or data visibility of a group they belong to.	*"You cannot change the permissions or data visibility of a group you belong to. Ask an administrator."*
3	Only an administrator adds people to **Admin** or removes them; nobody changes their own group membership.	*"Only an administrator can add people to the Admin group or remove them from it."* / *"You cannot change your own group membership. Ask an administrator."*
4	Nobody gives a group, a clone or a person a permission they do not hold themselves. Removing permissions is always allowed.	*"You cannot give permissions you do not hold yourself."* followed by the permission codes

Rule 4 does not apply to membership: someone allowed to edit users may put a new colleague into a group with more rights than their own (except **Admin**).

Built-in groups

Group	Description	Data visibility	Starting permissions	Edit	Delete / rename
Admin	*Full access to every module and setting*	All Records	Every permission in the catalogue, including Settings and Manage Access Control: Full Control everywhere, comments **Manage**, **Can Assign** and **Can Reassign**	No: no Edit or Clone button. The group is rewritten from the catalogue at every server start, so it can never lose a right.	No

Group	Description	Data visibility	Starting permissions	Edit	Delete / rename
Read Only	*Read-only visibility across every module*	All Records	**View** (read only, without export) on every page and tab except Settings; comments **None**; no assignment rights	Yes	No
Third Party	*External contact: only their own vendor records and assessments*	Assigned Records Only	Read and edit on **Vendors**, **Service Agreements**, **Third Party Risks** and **Compliance Analysis**; nothing else. Because read plus edit without create matches no level, these four pages show **Manage** with a purple **Custom** chip. Comments **None**. In a new organisation no assignment rights.	Yes	No

- The starting permissions of **Read Only** and **Third Party** are written once, when the group is first created. After that they belong to your organisation: changes you make survive restarts.
- All three keep the **Default** badge, cannot be selected for bulk delete (*"Built-in groups cannot be deleted"*), and their **Name** field is disabled on Edit. Renaming a built-in group is refused by the server.
- Settings permissions are removed from every group other than **Admin** at each server start.
- **Respondent**, **Analyst**, **Approver**, **Domain manager** and **Department Manager** were built-in in earlier releases. An organisation that has them keeps them as ordinary groups with their members and permissions; they lose the **Default** badge and can be edited and deleted. In the demo data **Respondent** (*"Standard user with read access to organization data"*) has View on Users, Departments and Groups only and two members (Sara Johnson, Mike Brown). Its View dialog shows **Custom Role**.
- In the demo data the **Third Party** group also holds **Can Assign** and **Can Reassign** on Vendors, Service Agreements and Third Party Risks. These were inherited once when the assignment rights were introduced (every group that could create or edit a register received **Can Assign**, and every group that could edit it **Can Reassign**). A new organisation's Third Party group does not get them.

The register (list view)

The whole list is loaded at once. Shared grid behaviour is described in Working with registers.

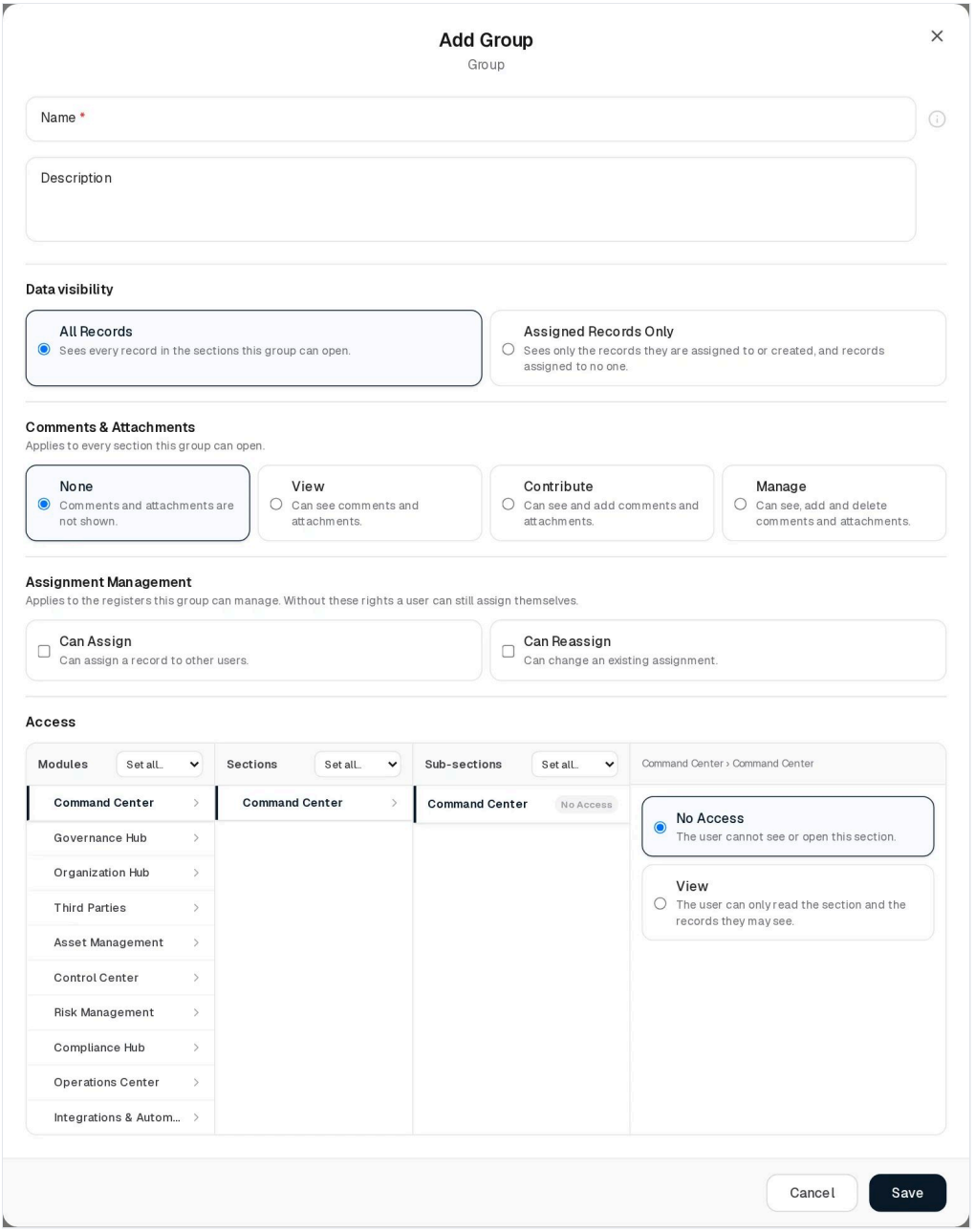
Column	What it shows	Source
Name	Group name, with a blue **Default** badge on built-in groups	Entered
Description	Description, or `- -`	Entered
Data visibility	**All Records** (grey) or **Assigned Records Only** / **Their department** (amber)	Entered
Users	Number of members. Clicking it opens a small panel listing the members (*"Show the group's users"*), searchable.	Computed

Row actions: **View** (eye), **Edit Group & Permissions**, **Clone Group**, **Delete Group**, and the Activity Log. **Admin** shows only View and the Activity Log; the other built-in groups have no Delete. Without the right, Edit, Clone and Delete stay visible with a lock and open the access request dialog.

Header: **Access Requests** (only for holders of Manage Access Control; a red badge shows the number of pending requests, **9+** above nine), **Import CSV** and **Add Item**.

Creating a record

Click **Add Item**. The **Add Group** dialog opens. It is one long form.



Add Group

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Must not be blank (“*The field is required*”). Up to 100 characters. Unique among groups (“*Group with this name already exists*”).	Risk Owners
Description	Text area	No	Up to 500 characters	Business owners of asset and business risks
Data visibility	Choice cards	Yes (one is always selected)	**All Records** (default), **Assigned Records Only**; **Their department** only on a group that already has it	All Records

Field	Type	Required	Rules and allowed values	Example
Comments & Attachments	Choice cards	No	**None**, **View**, **Contribute**, **Manage**. A new group starts at **None**.	Contribute
Assignment Management	Two checkboxes	No	**Can Assign**, **Can Reassign**	Can Assign
Access	Four columns	No	See below	Risk Management › Asset Risks: Full Control

The Access columns. From left to right:

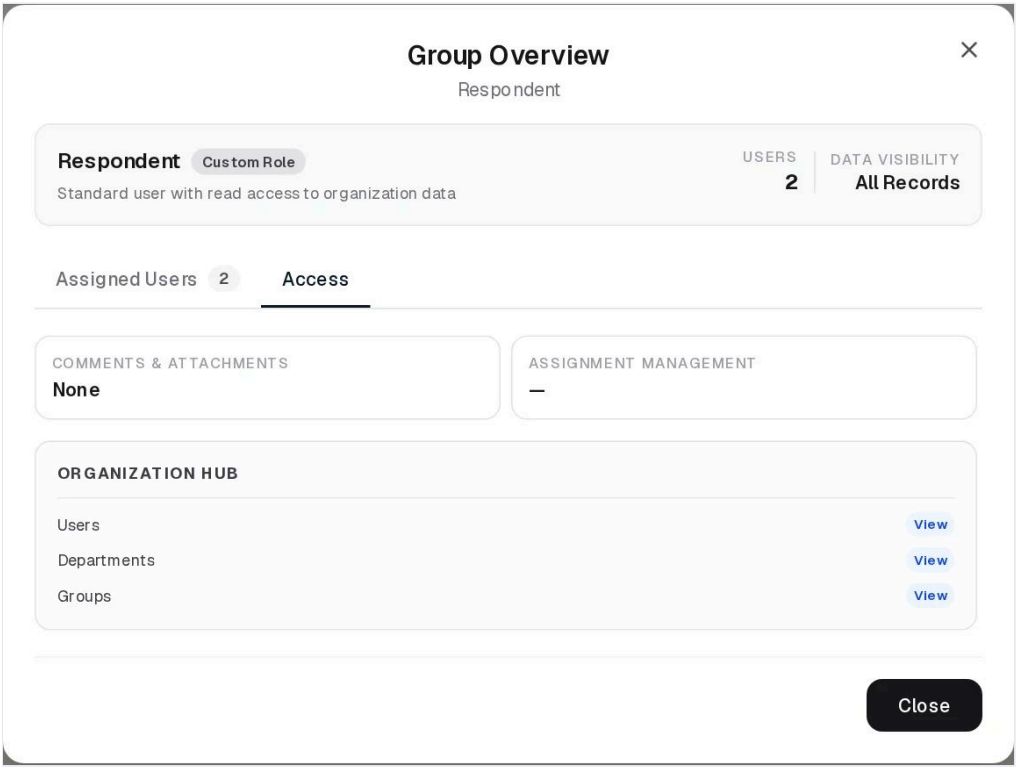
1. **Modules**: the sidebar modules, Settings excluded. A small dot marks modules where the group has any access.
2. **Sections**: the pages of the selected module (for a single-page module such as Command Center, the module itself).
3. **Sub-sections**: the selected page itself, followed by its tabs (indented). Each row shows its current level as a chip: **No Access** (grey), **View** (blue), **Manage** (amber), **Full Control** (green), plus **Custom** (purple) for rights that match no level.
4. The level cards of the selected unit, headed with its path (for example *Asset Management › Assets › Reviews*).

Each of the first three column headers has a **Set all…** drop-down that applies one level to everything in that column's scope (all modules, all pages of the module, or the page and its tabs). Each unit gets the highest offered level not above the one chosen.

When you open a group whose rights on a unit match no level, the level column says *"This section has a custom set of rights from the earlier editor. Choosing a level replaces it."* A unit you do not touch keeps exactly the permissions it had, so opening and saving an older group changes nothing you did not change.

Click **Save**. *"Group added."* confirms it. A rejected save keeps the dialog open with the server's reason at the top.

Viewing and editing a record



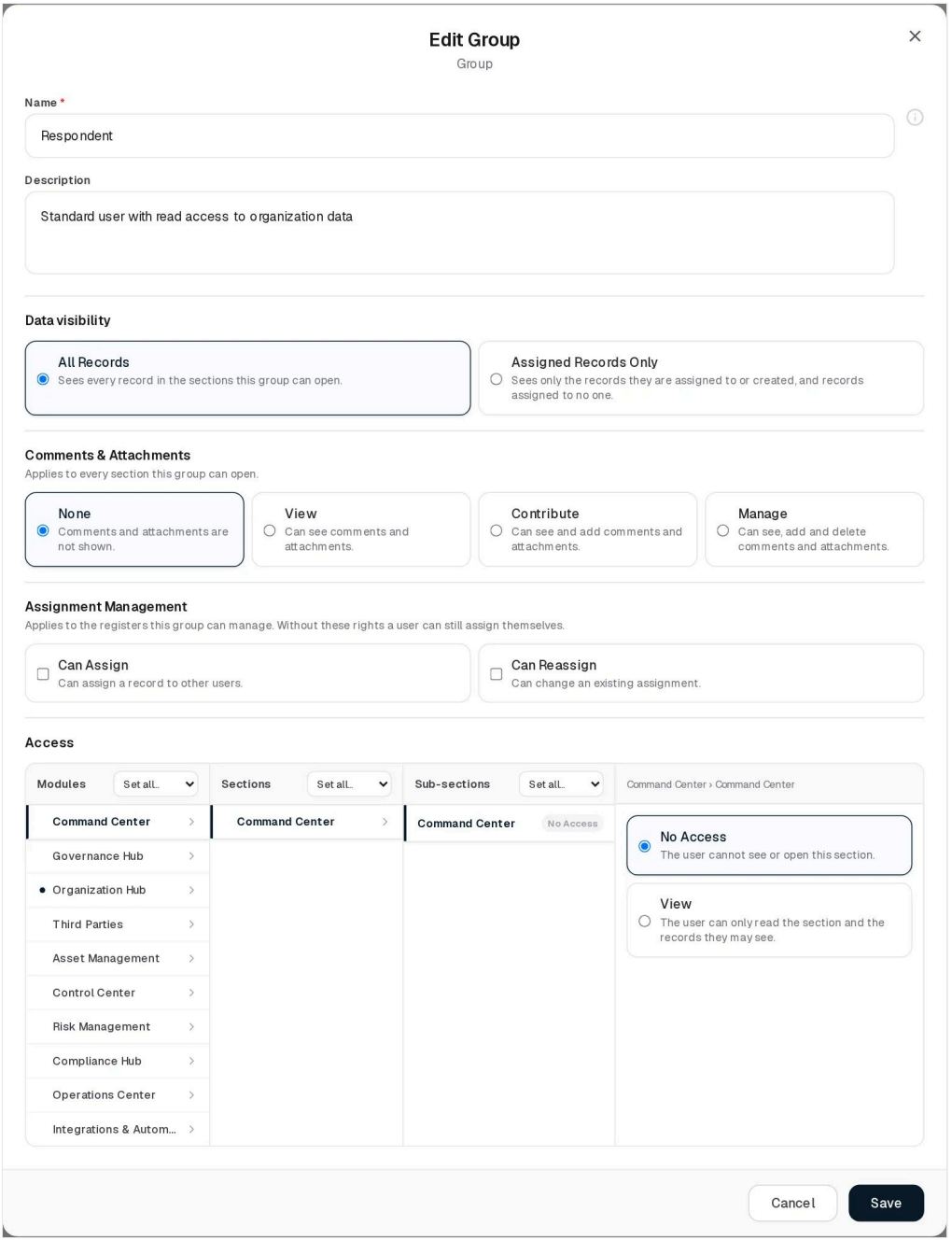
Group Overview

View opens **Group Overview** with the group name as subtitle. The header shows the name, a **System Default** or **Custom Role** badge, the description, the number of **Users** and the **Data visibility**. Two tabs follow:

- **Access** (opens first): the group's **Comments & Attachments** level (or **Mixed**), its **Assignment Management** rights (or **—**), and, per module, one line per page and tab the group can reach with its level chip. The Admin group's Settings pages are listed here too.

- **Assigned Users (n)**: each member with initials, name, email, department and status. *“No users assigned to this group yet.”* when empty.

Edit Group & Permissions opens **Edit Group** (subtitle *Group*) with the same form as Add, filled in. On built-in groups the Name is greyed out.



Edit Group

The example is **Respondent**: **All Records**, comments **None**, neither assignment right, and a dot beside **Organization Hub** in the Modules column, the only module where the group has access (View on Users, Departments and Groups).

Clone Group is meant to create a copy named *“ (Copy)”* with the same permissions and description; see Limitations.

Delete Group asks *“Delete group Respondent?”*. The server refuses:

- a built-in group: *“Cannot modify or delete default/system group: Third Party”*
- a group with members: *“Cannot delete group”Respondent”: it is assigned to 2 users. Remove it from all members first.”*
- a group used as a vendor’s Vendor Role: *“Role”…” is assigned as a vendor’s Vendor Role. Clear it on the vendor before deleting the role.”*

Bulk delete sends all selected groups at once and reports each refusal in an amber banner: *"Deleted 1 of 3 roles."* followed by one line per refused group with its reason.

Statuses

Groups have no user-visible status and no Dynamic Status. Access requests have three states:

Value	Set by	Meaning
PENDING	System, when the request is filed	Waiting in the **Access Requests** queue
APPROVED	Administrator	Granted as a personal grant or added to a group
REJECTED	Administrator	Refused, optionally with a note sent to the requester

Access requests

How a request is filed

When a user clicks a locked button (or the server refuses an action), the **Access Restricted / Permission Required** dialog names the missing right as *Module › Page › Tab* with the action label, for example *Organization Hub › Departments* · **CREATE NEW ITEM**. **Request Access** opens a text box (*"Why do you need this access? The administrator will see this justification."*, required, up to 2,000 characters); **Send Request** files it and shows *"Request sent. Administrators have been notified and you will receive a notification once it is decided."* The request always names exactly one permission code. See Permissions and access › Requesting access.

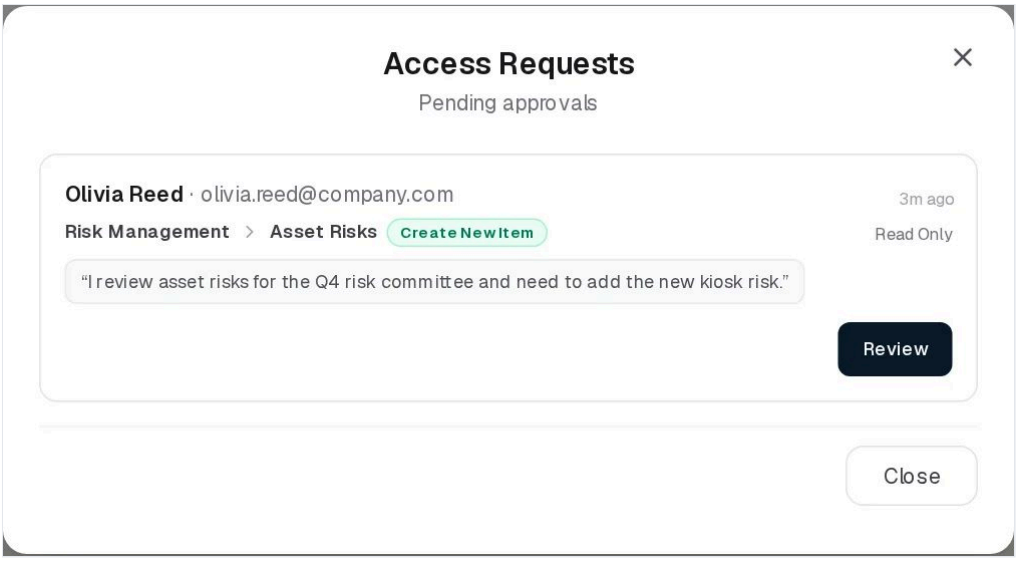
The server refuses a request when:

- the permission belongs to Settings (the dialog says *"Only the Admin group can access Settings. It cannot be granted to other groups or requested."* and offers no button);
- the user already has it: *"You already have this permission"*;
- the same request is already pending: *"You already have a pending request for this permission"*;
- the signed-in account has no user record in Organization Hub: *"Your account has no organization profile, so access requests cannot be filed"*.

Every member of the group named exactly **Admin** except the requester receives an `ACCESS_REQUEST` notification, *"Access request from Olivia Reed"*, with a **Review request** link to this page that opens the queue. Users cannot see a list of their own requests in the UI; they learn the outcome from the notification.

Deciding a request

Click **Access Requests** in the page header. The **Access Requests** dialog (*Pending approvals*) lists pending requests, newest first, or *"No pending access requests."* Each card shows the requester's name and email, the requested *Module › Page › Tab* and action, the justification in quotes, how long ago it was filed, and the requester's groups (or *No groups*).



Access Requests

In the demo data, **Olivia Reed** (member of **Read Only**) has asked for *Risk Management › Asset Risks* · **Create New Item** with the justification *"I review asset risks for the Q4 risk committee and need to add the new kiosk risk."* The header button shows the badge **1**. Because Olivia holds only a built-in group, the only possible approval is **Grant to this user only**.

Click **Review**:

Element	Meaning
Grant to this user only (default)	Creates an individual grant for the requester. Duration **7 days**, **30 days (recommended)** (default), **90 days** or **Permanent**. The grant carries the reason *"Approved access request: "* and, like any grant, brings the page's read permission with it.
Add to one of their groups	Adds the permission to one of the requester's **non-built-in** groups (drop-down). A warning shows the reach: *"⚠ 2 users hold this group — all of them will receive this permission."* Disabled with *"Not available — the requester only holds system default groups, which cannot be edited."* when the requester has only built-in groups.
Decision note	Optional, up to 1,000 characters. *"Decision note (optional — sent to the requester on reject)"*.
Cancel / **Reject** / **Approve**	Close the card without deciding / refuse / grant

Rules: you cannot decide your own request (*"You cannot approve your own access request"* / *"You cannot decide your own access request"*); a request already decided cannot be decided again (*"This request has already been decided"*); adding to a group goes through the same four escalation rules as editing the group (so you cannot add to a group you belong to, or add a permission you do not hold yourself, unless you are an administrator). Adding a single code to a group can make that page show **Custom** in the group's Access columns.

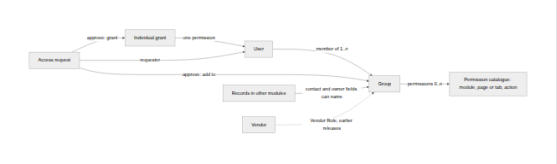
The requester receives `ACCESS_APPROVED` (*"Your request for"Departments: Create New Item" was approved — granted to you until ."*, *"… granted to you permanently."* or *"… added to your role""."*) or `ACCESS_REJECTED` (*"Your request for"…" was rejected:

"*). Their permissions in open sessions refresh within about 10 seconds.

Tabs

None on the page. The View dialog's **Access** and **Assigned Users** tabs are described above.

Relationships



Related record	Direction	How the link is made	Where it shows
Users	User → Group, many to many	**Groups** field on the Users form	**Users** count (clickable), **Assigned Users** tab
Permissions	Group → Permission, many to many	Access columns, Comments & Attachments, Assignment Management	**Access** tab of Group Overview
Access requests	Request → Group	**Add to one of their groups** on approval	The requester's notification
Records in other registers	Record → Group	Every user-and-group picker; the group's members then count as named for data visibility	The other register's contact columns
Vendors	Vendor → Group	*Vendor Role*, no longer editable in the UI	Blocks deleting the group

Automations and notifications

What	When	Effect
Catalogue sync	Every server start	The permission catalogue is rewritten from the code, obsolete permissions are removed from all groups, **Admin** gets every permission again, Settings is withdrawn from every other group, and a group that was built-in in an earlier release is demoted to an ordinary group
One-time inheritance	The first start after a new permission is added to the catalogue	Groups receive the new permission if they held what it was carved from (a new tab inherits its page's matching action; **Can Assign** comes from create or edit, **Can Reassign** from edit). Individual grants are not widened.
Session refresh	Any change to a group's permissions, a user's groups or an individual grant	Open sessions of the organisation reload their permission list within about 10 seconds
`ACCESS_REQUEST`	A request is filed	Members of **Admin**, except the requester
`ACCESS_APPROVED` / `ACCESS_REJECTED`	A request is decided	The requester

Permissions

Action	Needed access
See the page and open Group Overview	View on **Organization Hub › Groups**
Add a group without access, edit name and description	Manage on **Organization Hub › Groups**
Set or change access levels, comments, assignment rights or data visibility	Full Control on **Organization Hub › Groups** (Manage Access Control), and not being a member of that group (unless administrator)
Clone a group	Manage, plus Manage Access Control when the source group has permissions
Delete a group	Full Control on **Organization Hub › Groups**
See **Access Requests** and decide them	Full Control on **Organization Hub › Groups** (Manage Access Control)

Action	Needed access
Give **Admin** membership, change Settings	Membership of **Admin**
Activity Log	The group's **Comments & Attachments** level
Assign / Reassign	Not used on this page

How to

Create a group for risk owners

1. Click **Add Item**. **Name**: *Risk Owners*. **Description**: *Business owners of asset and business risks*.
2. **Data visibility**: **Assigned Records Only**, so each owner finds the risks that name them.
3. **Comments & Attachments**: **Contribute**. **Assignment Management**: leave both unchecked, so owners can name only themselves.
4. In **Modules** click **Risk Management**, in **Sections** click **Asset Risks**, in **Sub-sections** click **Asset Risks** and choose **Manage**. Click **Reviews** and choose **Manage**.
5. Do the same for **Business Risks**. Optionally give **View** on **Asset Management › Assets**.
6. Click **Save**, then add members on the Users page.

Give an existing group read access to a whole module

1. Click **Edit Group & Permissions** on the group.
2. Click the module in **Modules**; in the **Sections** header choose **Set all…** › **View**.
3. Click **Save**. Members see the new pages within about 10 seconds.

Decide an access request

1. Open the notification *"Access request from Olivia Reed"* and click **Review request**, or click **Access Requests** (badge **1**) on this page.
2. Read the justification (*"I review asset risks for the Q4 risk committee…"*) and click **Review**.
3. Keep **Grant to this user only** with **30 days (recommended)**: Olivia needs to add one risk for one committee. (**Add to one of their groups** is disabled for her, because **Read Only** is built-in; for a requester in a custom group, choose it only when every member of that group should have the right.)
4. Click **Approve**. Olivia receives *"Your request for"Asset Risks: Create New Item" was approved — granted to you until …"*, and the grant appears (no read grant is added, because Read Only already gives her *Asset Risks: Section Index*) under her **Additional Permissions** on the Users page. To refuse, type a note and click **Reject**.

Check what a group can do

1. Click the eye icon on **Third Party**.
2. The **Access** tab lists Third Parties › Vendors, Service Agreements, Risk Management › Third Party Risks and Compliance Hub › Compliance Analysis, each **Manage** with a **Custom** chip, comments **None**, and the data visibility **Assigned Records Only** in the header.

CSV import

Not available. **Import CSV** shows *"CSV Import (Groups): the import structure is not ready yet."* and opens a demonstration dialog whose validation fails.

Limitations and known issues

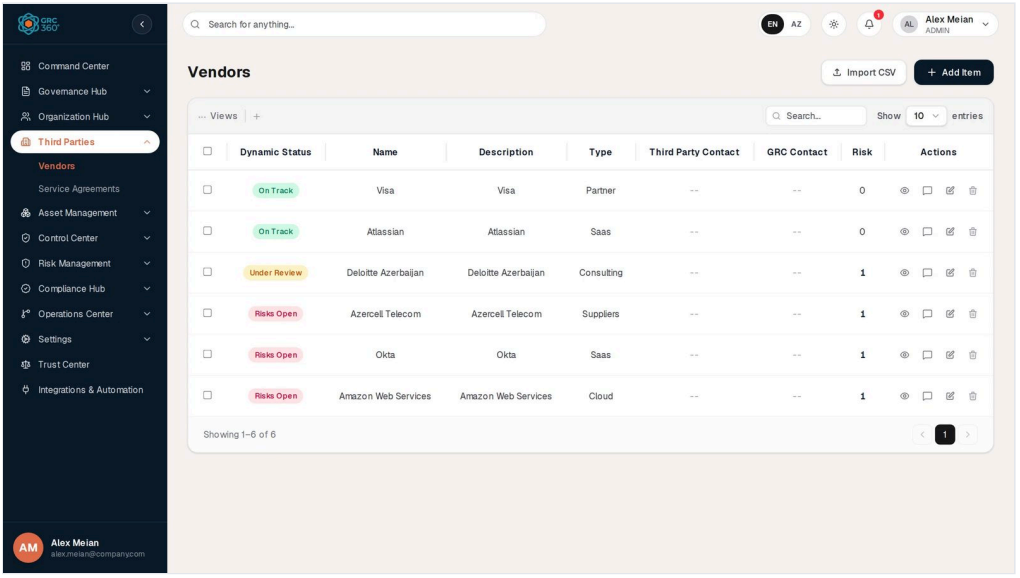
- **Clone does not work.** The page sends the new name in a field (`newName`) that the server does not read; the server requires `name` (its validation message is *"New role name is required"*), so every clone is refused and the page shows the server's error as a toast. This follows from the code; it was not exercised on the read-only demo. Create the group with **Add Item** instead. Even if it worked, a clone would not copy the source group's data visibility (a new group is **All Records**).
- **Renaming to an existing name** is not checked on Edit (only on Add and Clone), so two groups can end up with the same name.

- **Full Control is more than delete.** Its description says *“View, plus create, edit and delete.”*, but on Groups it also gives Manage Access Control and on the risk registers Manage Section Settings.
- **View without export.** Built-in **Read Only** holds read but not export; it still shows plain **View**.
- **Individual grants and access requests use action names**, not levels: approving a request for *Create New Item* adds one code, and the page may then show **Custom**.
- **No list of one’s own requests** in the UI; the requester relies on the notification.
- **Assigned Users** reads the Users list, which hides members of groups containing “admin” from non-administrators, so it can show fewer people than the **Users** count.

Third Parties

> **Module:** Third Parties · **Route:** `/third-parties` (opens **Vendors**) · **Permission module:** `third_parties`

The Third Parties module is the register of outside organisations your organisation deals with (suppliers, customers and regulators) and of the service agreements in force with them. It answers two questions for third-party risk management: who are our third parties and who looks after each relationship, and which contracts do we hold with them, for how much and until when. The risk side (what can go wrong with a third party) lives in Risk Management › Third Party Risks, which points back at the vendors here.



Vendors register

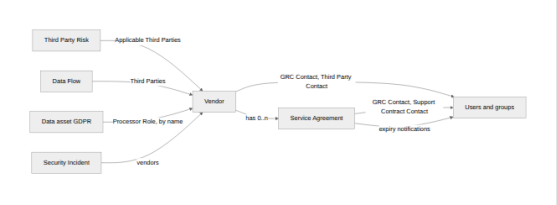
Pages

Page (sidebar label)	Route	Permission key	What it holds
Vendors	`/third-parties/vendors`	`third_parties.vendors`	One record per third party: name, description, type, our GRC contact and their contact. A computed Dynamic Status and a count of the third-party risks that name the vendor.
Service Agreements	`/third-parties/service-agreements`	`third_parties.service_agreements`	One record per contract with a vendor: contacts, supplier, service value, start and end dates. A Dynamic Status computed from the dates, and expiry notifications to the contacts.

Opening `/third-parties` without a page redirects to **Vendors**.

How the pages relate

- Every **service agreement** belongs to exactly one **vendor** (its **Support Contract Supplier**). A vendor can have any number of agreements.
- **Third party risks** list the vendors they apply to (**Applicable Third Parties** in Risk Management). The vendor's **Risk** column counts them, and a vendor named by at least one such risk reads **Risks Open**.
- **Data flows** in Asset Management name the third parties that data passes to, and a data asset's GDPR **Processor Role** is picked from the vendors.
- **Security incidents** in the Operations Center can name the vendors involved.
- A vendor cannot be deleted while service agreements or third-party risks still point at it.



Who sees what

Both pages are among the nine registers where a group's **data visibility** applies and where **Can Assign** / **Can Reassign** govern the contact fields (see Groups). A group set to **Assigned Records Only** finds the vendors and agreements that name its members (or the group) as a contact, the ones its members created, and the ones that name nobody. Service agreements are not included in the global search.

The built-in **Third Party** group is meant for external contacts: it can read and edit vendors and service agreements but not create or delete them, and starts with **Assigned Records Only**.

Automations and notifications

What	Schedule	Effect
Vendor Dynamic Status	On every read	Computed from the vendor's stored status and the third-party risks that name it
Service Agreement Dynamic Status	On every read	Computed from today's date and the agreement's start and end dates
Expiry notifications `SERVICE_AGREEMENT_EXPIRING_WEEK`, `SERVICE_AGREEMENT_EXPIRING_SOON`, `SERVICE_AGREEMENT_EXPIRES_TODAY`	Daily notification sweep at 08:00 server time, the first time each day someone in the organisation opens their notifications, and whenever an agreement is saved	The agreement's GRC and support-contract contacts are told 7 days before, 3 days before and on the end date. Details in Service Agreements.
Nightly update of the stored agreement status to Expiring / Expired	Implemented (daily at 01:00) but **not active in this release**: scheduled jobs are not enabled on the server	None. The Dynamic Status shows Expiring and Expired anyway, because it is computed on read.

CSV import

Not available on either page. **Import CSV** shows *"CSV Import (Vendors): the import structure is not ready yet."* (or *Service Agreements*) and then opens a demonstration dialog whose validation fails, because no import exists behind it. See Working with registers.

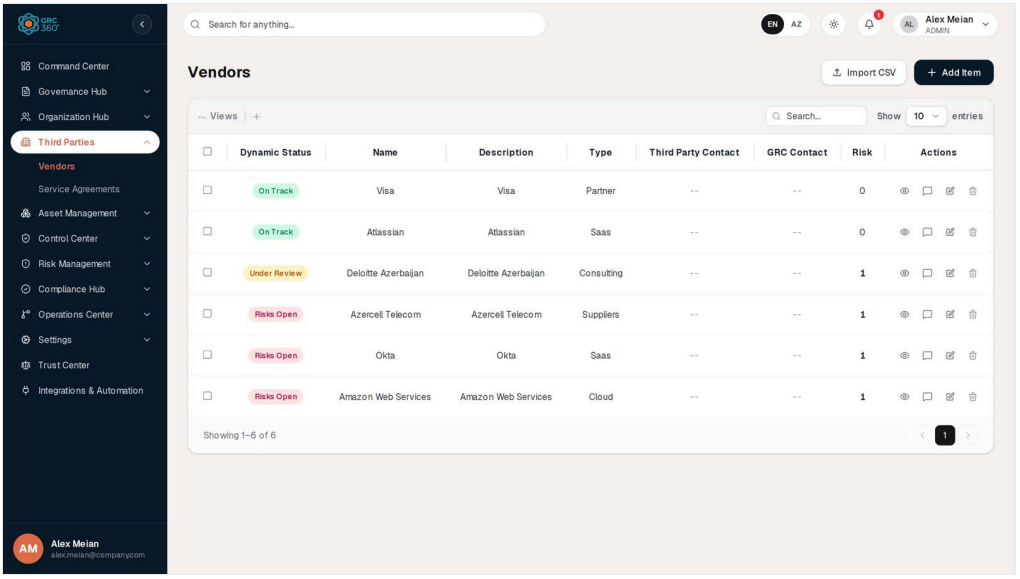
See also

- Risk Management › Third Party Risks
- Asset Management › Data Flows
- Working with registers

Vendors

> **Module:** Third Parties › Vendors · **Route:** `/third-parties/vendors` · **Permission key:** `third_parties.vendors`

The Vendors register lists the outside organisations your organisation works with: suppliers, customers and regulators. A record is one third party, with a short description, its type, the person or team on your side who owns the relationship (**GRC Contact**) and the contact on the third party's side (**Third Party Contact**). The register also shows how many third-party risks name the vendor and turns that into a Dynamic Status. Procurement, vendor managers and the GRC team maintain it; risk owners pick vendors from it in Third Party Risks and Data Flows.



Vendors register

At a glance

A record is	One third party (supplier, customer or regulator)
Typical owner	Vendor manager or GRC team
Links to	GRC Contact and Third Party Contact (users and groups)
Linked from	Service Agreements (Support Contract Supplier), Third Party Risks (Applicable Third Parties), Data Flows (Third Parties), data assets (Processor Role, by name), Security Incidents
Tabs	None
Automations	Dynamic Status and the **Risk** count are computed on every read

The register (list view)

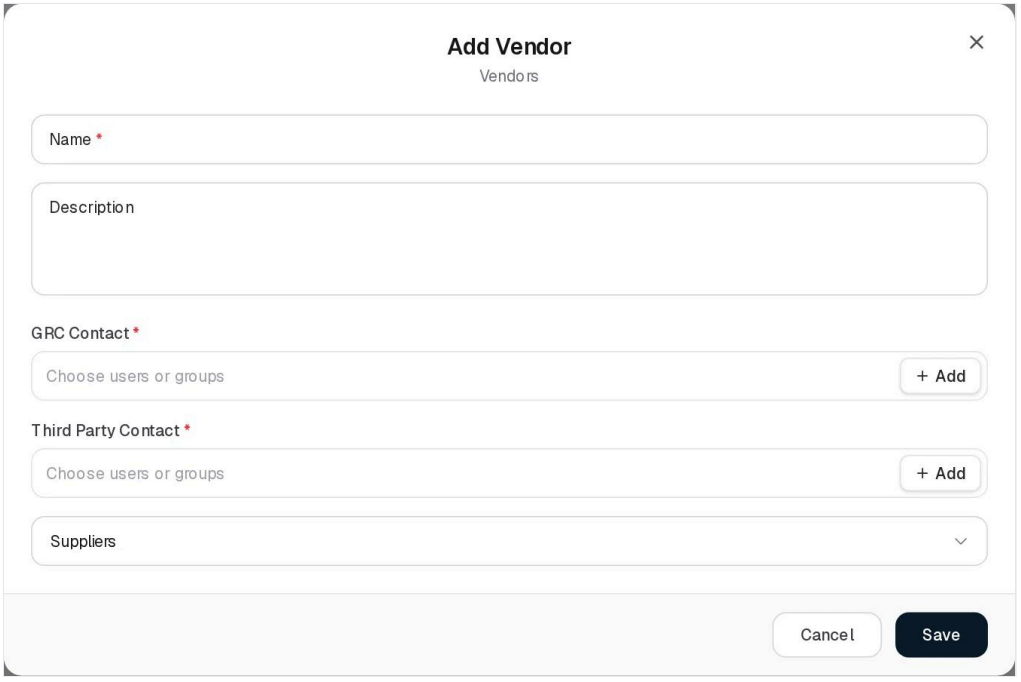
The grid is paged on the server and opens newest first. It refreshes when vendors or third-party risks change anywhere. Shared grid behaviour is described in Working with registers.

Column	What it shows	Source
Dynamic Status	**On Track**, **Risks Open**, **Under Review** or **Inactive**; see Statuses	Computed by the system
Name	Vendor name	Entered
Description	First part of the description; the full text is the tooltip. `-` when empty.	Entered

Column	What it shows	Source
Type	**Customers**, **Regulators**, **Suppliers**; vendors created in earlier releases can show an older type such as **Partner**, **Saas**, **Cloud** or **Consulting**	Entered
Third Party Contact	Avatar and name of each contact on the vendor's side, or `--`	Entered
GRC Contact	Avatar and name of each contact on your side, or `--`	Entered
Risk	Number of live third-party risks that list this vendor under **Applicable Third Parties**. A number above 0 is a link that opens those risks. Not sortable.	Computed

Creating a record

Click **Add Item**. The **Add Vendor** dialog opens.



Add Vendor

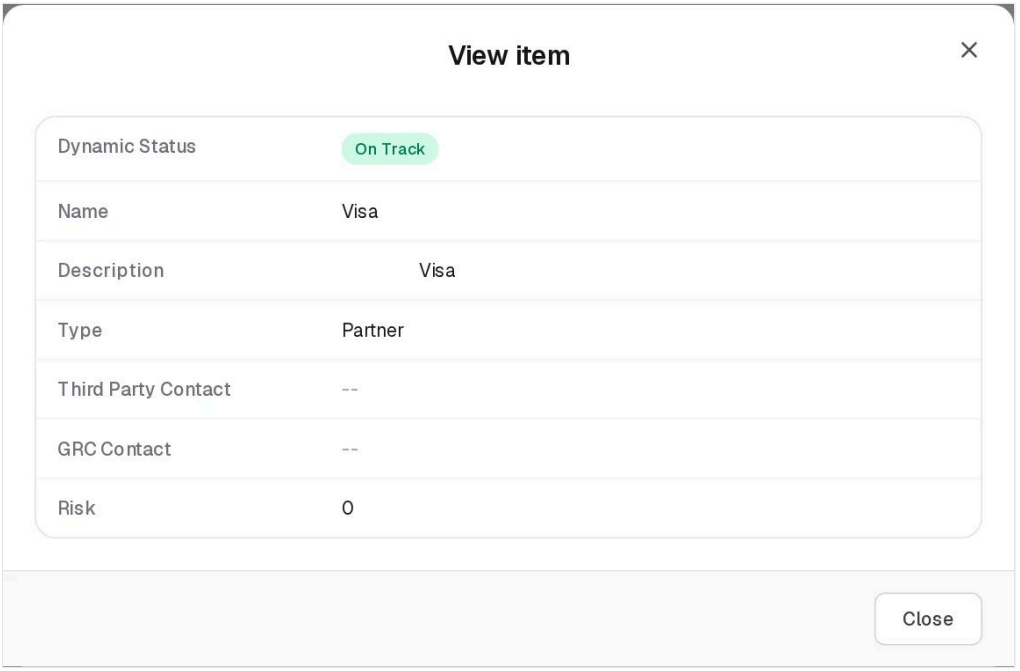
Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Must not be blank (*"Required"*). Up to 200 characters. Unique in the organisation (*"Vendor with this name already exists"*).	Amazon Web Services
Description	Text area	No	Up to 500 characters	Cloud hosting for production workloads
GRC Contact	User-and-group picker, several allowed, with **+ Add**	Yes	At least one (*"Required"*). Subject to **Can Assign** / **Can Reassign**.	Alex Meian
Third Party Contact	User-and-group picker, several allowed, with **+ Add**	Yes	At least one (*"Required"*). Subject to **Can Assign** / **Can Reassign**.	Sara Johnson

Field	Type	Required	Rules and allowed values	Example
Type	Drop-down	Yes	**Customers**, **Regulators**, **Suppliers**. Default **Suppliers**.	Suppliers

The contact pickers offer the users and groups of the Organization Hub; **+ Add** creates a user on the spot. The vendor's own staff appear here only if they have a user account. Click **Save**; *"Vendor added."* confirms it.

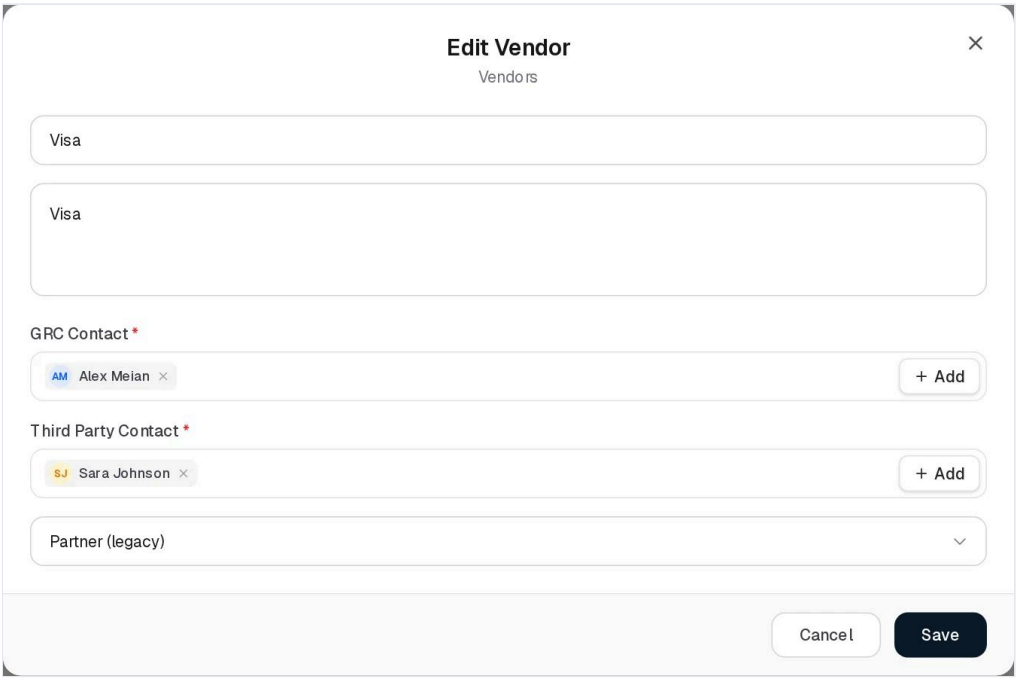
Assignment rule. Naming anyone other than yourself in an empty contact field needs **Can Assign** on Vendors; changing who else is named in a field needs **Can Reassign**. Without the right the picker only offers you. See Groups › Assignment Management.

Viewing and editing a record



View Vendor

View opens the generic **View item** dialog with the grid's columns: Dynamic Status, Name, Description, Type, Third Party Contact, GRC Contact and Risk (a plain number here).



Edit Vendor

Edit Vendor has the same fields as Add. Text fields that already hold a value show no label (the label is a placeholder). A vendor with an older type shows it as **(legacy)**, for example **Partner (legacy)**, so saving keeps it; once you pick one of the three current types the legacy one is no longer offered.

Fields that are not on the form are kept as they are on save, in particular the vendor's stored status and its Vendor Role (see Limitations).

Statuses

The form has no status field. Each vendor has a stored status (`ACTIVE` by default; `INACTIVE`, `UNDER_REVIEW` and `TERMINATED` exist and can only come from data loaded by other means). The Dynamic Status is computed on every read, first matching rule wins:

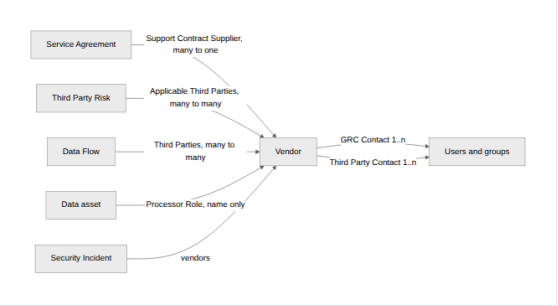
Value	Set by	Rule	Colour
Inactive	System	Stored status is `INACTIVE` or `TERMINATED`	Grey
Under Review	System	Stored status is `UNDER_REVIEW`	Amber
Risks Open	System	At least one live (not deleted) third-party risk lists the vendor under Applicable Third Parties, whatever that risk's own status or treatment	Red
On Track	System	None of the above	Green

In the demo data **Deloitte Azerbaijan** is **Under Review**; **Azercell Telecom**, **Okta** and **Amazon Web Services** are **Risks Open** with one risk each; **Visa** and **Atlassian** are **On Track**.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Users and groups	Vendor → people	**GRC Contact** and **Third Party Contact** on this form	The two contact columns
Service Agreements	Agreement → Vendor, many to one	**Support Contract Supplier** on the agreement form (with a **+ Add** that creates a vendor)	Service Agreements grid; blocks deleting the vendor
Third Party Risks	Risk → Vendor, many to many	**Applicable Third Parties** on the risk	**Risk** count (clickable) and Dynamic Status; blocks deleting the vendor
Data Flows	Flow → Vendor, many to many	**Third Parties** on the data flow form. Picking a vendor there adds its third-party risks to the flow, and picking a risk adds its vendors.	Data Asset Flows grid

Related record	Direction	How the link is made	Where it shows
Data assets	Data asset → Vendor	**Processor Role** in a data asset's GDPR analysis, picked from vendors but stored as the name	Data Assets grid
Security Incidents	Incident → Vendor	The incident form in Operations Center	Incidents; the link is removed when the vendor is deleted, the incident stays

Automations and notifications

None for vendors. The Dynamic Status and **Risk** count are recalculated on every read, so a risk saved in Risk Management changes them at once.

Permissions

Action	Needed access
See the page	View on **Third Parties › Vendors**
Create / Edit	Manage on **Third Parties › Vendors**
Delete	Full Control on **Third Parties › Vendors**
Name other people as contacts	**Can Assign** (empty field) / **Can Reassign** (field already naming others), on a group with Manage or Full Control on Vendors
Open the risks behind a count	View on **Risk Management › Third Party Risks**
Activity Log	The group's **Comments & Attachments** level

Members of a group used as a vendor's Vendor Role (external contacts) can only read their own vendor; creating, editing and deleting vendors is refused for them.

Deleting. The vendor is removed permanently. The server refuses while anything still depends on it and names all of it at once, for example *"Cannot delete vendor"Okta": it is still referenced by 1 service agreement, 1 third-party risk. Remove these references first."* Data flows that hold the vendor in an older vendor field also block deletion. Links from security incidents are removed; the incidents stay. The reason appears inside the confirmation dialog (*"Delete vendor Okta?"*).

How to

Register a new supplier

1. Open **Third Parties › Vendors**, click **Add Item**.
2. **Name**: *Microsoft*. **Description**: *Office 365 and Azure AD*.
3. **GRC Contact**: **Alex Meian**. **Third Party Contact**: the account of Microsoft's account manager, or a group that represents the vendor.
4. **Type**: **Suppliers**. Click **Save**.
5. Record its contract in Service Agreements and its risks in Third Party Risks.

Find the risks that make a vendor "Risks Open"

1. In the **Okta** row, click **1** in the **Risk** column.
2. The panel lists the third-party risks that name Okta; open one to review its analysis and treatment.

Retire a vendor

1. Delete or reassign its service agreements on the Service Agreements page.
2. Remove the vendor from the **Applicable Third Parties** of its third-party risks (or delete those risks).
3. Click **Delete** on the vendor and confirm.

CSV import

Not available. **Import CSV** shows *“CSV Import (Vendors): the import structure is not ready yet.”* and opens a demonstration dialog whose validation fails.

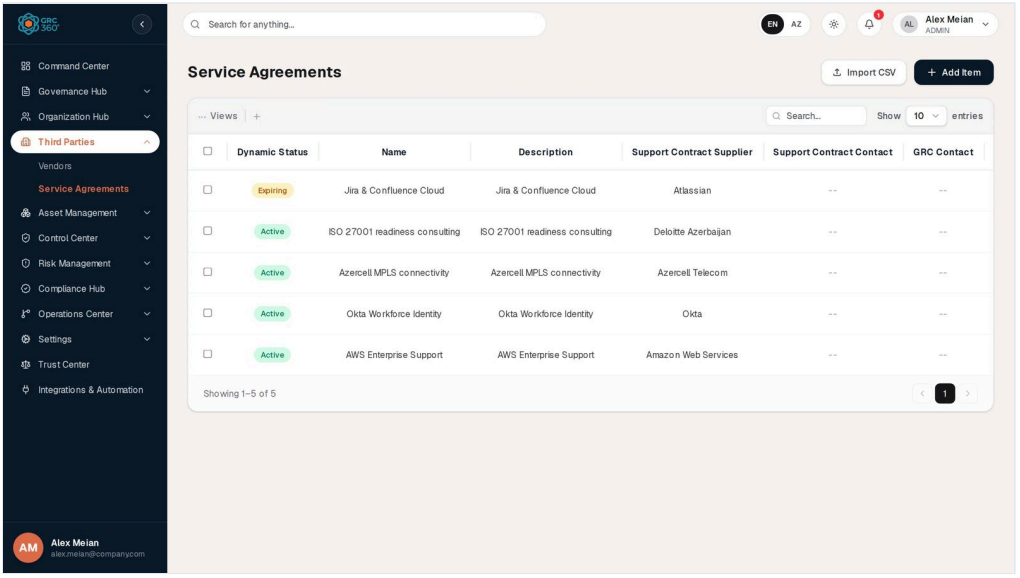
Limitations and known issues

- **No status field.** Under Review, Inactive and Terminated can only come from data loaded by other means, so a vendor created in the UI is always **On Track** or **Risks Open**.
- **Risks Open counts every live risk**, including risks that are treated, accepted or closed.
- **Vendor Role is not on the form.** The field that confined a group to one vendor still exists and is kept on save, but can no longer be set or cleared in the UI. A group used as a Vendor Role cannot be deleted until it is cleared.
- **Contacts shown in the form but not in the grid.** In the demo data the vendors carry contact ids without stored names: the grid shows `--`, while Edit shows Alex Meian and Sara Johnson. Saving such a vendor without touching the contacts fails with *“Required”*, because the form checks the single first-contact field, which is empty; remove and re-pick the contacts, then save.
- **No labels on filled text fields** in Edit (Name, Description): the label is a placeholder that disappears once a value is present.

Service Agreements

> **Module:** Third Parties › Service Agreements · **Route:** `/third-parties/service-agreements` · **Permission key:** `third_parties.service_agreements`

The Service Agreements register holds the contracts your organisation has with its vendors: support contracts, subscriptions, consulting engagements, connectivity and similar. A record is one agreement with one vendor (the **Support Contract Supplier**), its value, its validity window (start and end date), the GRC contact who follows it and the contact responsible for the support contract. GRC360 works out from the dates whether each agreement is upcoming, active, expiring or expired, and warns the contacts a week before, three days before and on the end date. Vendor managers and contract owners work in this page.



Service Agreements register

At a glance

A record is	One contract with one vendor
Typical owner	Vendor manager or contract owner
Links to	Vendor (Support Contract Supplier), GRC Contact and Support Contract Contact (users and groups)
Linked from	Vendors (an agreement blocks deleting its vendor)
Tabs	None
Automations	Dynamic Status computed from the dates on every read; expiry notifications `SERVICE_AGREEMENT_EXPIRING_WEEK`, `SERVICE_AGREEMENT_EXPIRING_SOON`, `SERVICE_AGREEMENT_EXPIRES_TODAY`

The register (list view)

The grid is paged on the server and opens newest first. It refreshes when agreements or vendors change. Shared grid behaviour is described in Working with registers.

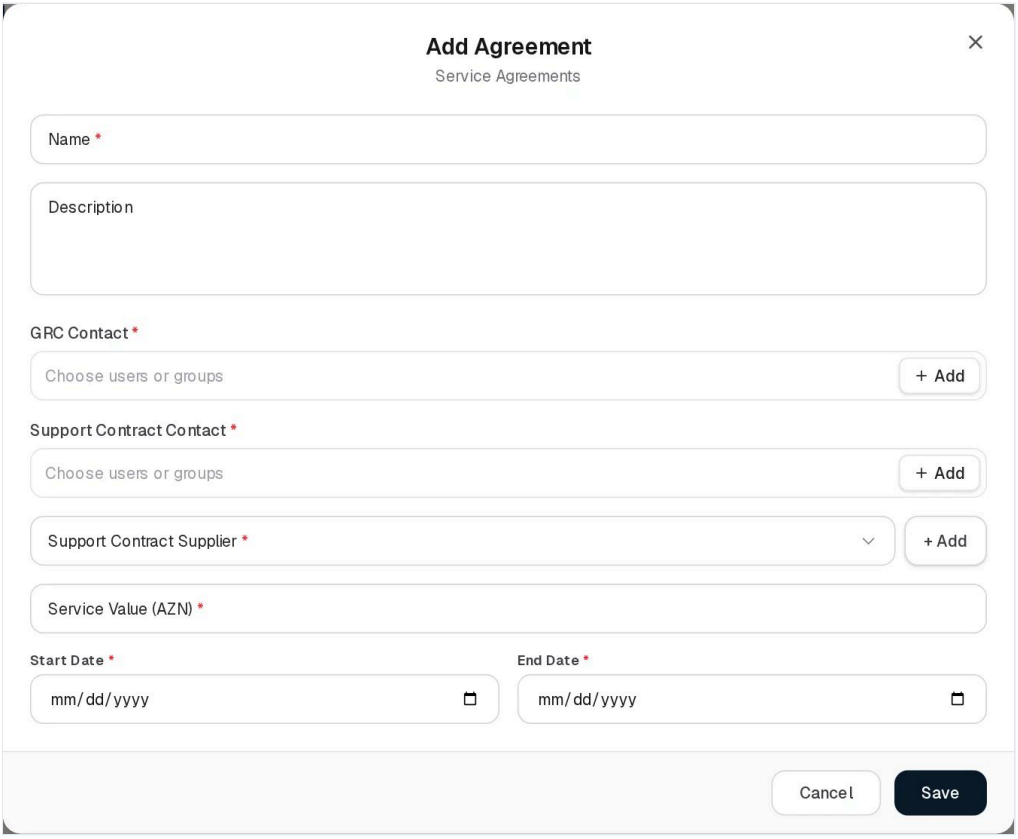
Column	What it shows	Source
Dynamic Status	**Draft**, **Terminated**, **Expired**, **Upcoming**, **Expiring** or **Active**; see Statuses	Computed by the system
Name	Agreement name	Entered

Column	What it shows	Source
Description	Description	Entered
Support Contract Supplier	The vendor’s name	Linked
Support Contract Contact	Avatar and name of each contact, or `--`	Entered
GRC Contact	Avatar and name of each contact, or `--`	Entered
Service Value	Amount and currency, for example *9800 USD*	Entered
Start Date	First day of the agreement (YYYY-MM-DD)	Entered
End Date	Last day of the agreement (YYYY-MM-DD)	Entered

The grid is wider than the screen; scroll sideways for Service Value and the dates, or hide columns with **Views**.

Creating a record

Click **Add Item**. The **Add Agreement** dialog opens.



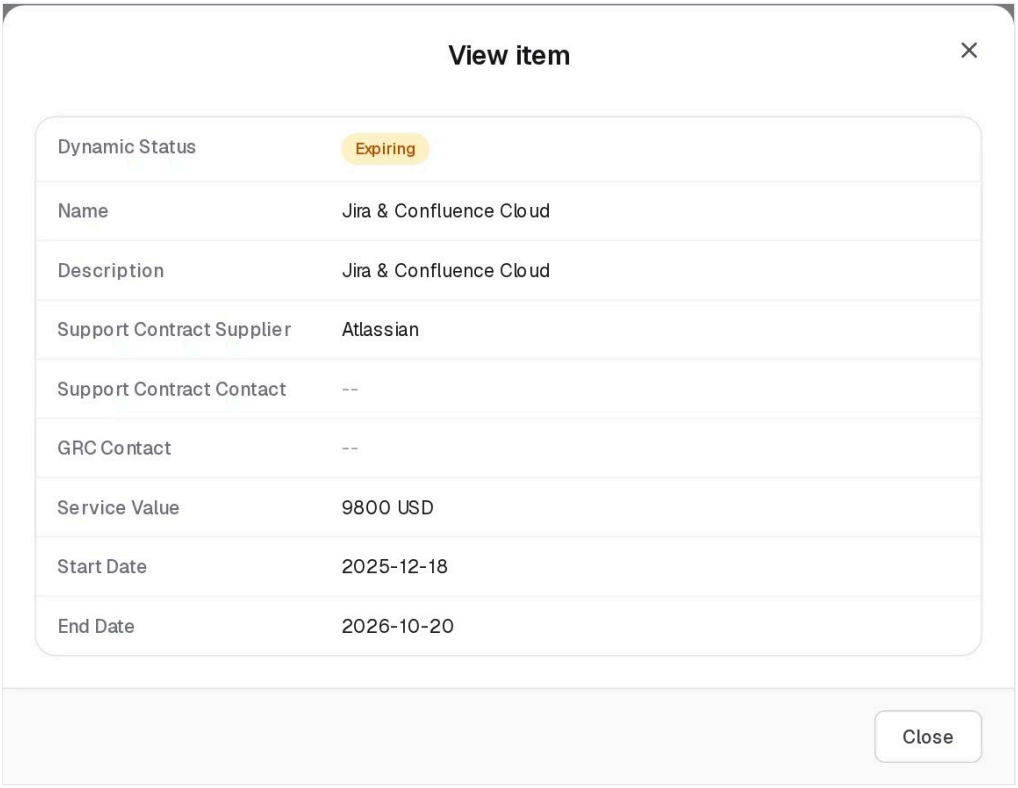
Add Agreement

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Must not be blank (*“Required”*). Up to 200 characters.	AWS Enterprise Support
Description	Text area	No	Up to 1,000 characters	24x7 enterprise support plan
GRC Contact	User-and-group picker, several allowed, with **+ Add**	Yes	At least one (*“Required”*). Subject to **Can Assign** / **Can Reassign**.	Alex Meian
Support Contract Contact	User-and-group picker, several allowed, with **+ Add**	Yes	At least one (*“Required”*). Subject to **Can Assign** / **Can Reassign**.	Sara Johnson

Field	Type	Required	Rules and allowed values	Example
Support Contract Supplier	Drop-down with **+ Add**	Yes	One vendor from the Vendors register (*"Required"*). **+ Add** opens the Add Vendor form and selects the new vendor. You must be able to see the vendor.	Amazon Web Services
Service Value (AZN)	Number	Yes	Must not be blank (*"Required"*). The currency in the label is the record's currency: **AZN** for new agreements; an existing agreement keeps its own (the demo agreements are in USD). There is no currency picker.	48000
Start Date	Date	Yes	*"Required"*	2026-03-28
End Date	Date	Yes	*"Required"*; must not be before the Start Date (*"End date must be after the start date"*). The same day is accepted.	2027-03-28

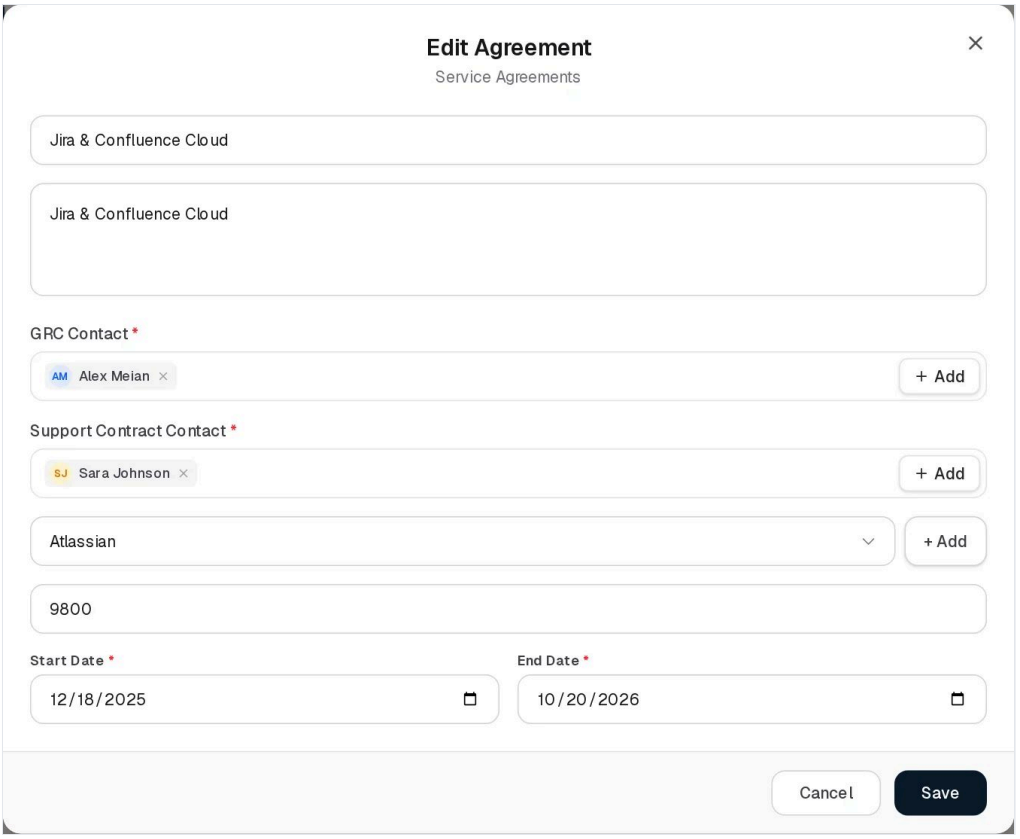
Click **Save**; *"Service agreement added."* confirms it. If the agreement ends within the next seven days, the expiry notification for the current milestone is sent at once (see below).

Viewing and editing a record



View Agreement

View opens the generic **View item** dialog with the grid's columns: Dynamic Status, Name, Description, Support Contract Supplier, Support Contract Contact, GRC Contact, Service Value, Start Date and End Date. Clicking **Open the agreement** in an expiry notification opens the same information as **View Agreement**, read from the server even if the agreement is not on the page you are looking at.



Edit Agreement

Edit Agreement has the same fields as Add. The labels of filled text fields (Name, Description, Service Value) are not shown once a value is present. Changing the supplier to another vendor requires that you can see that vendor.

Statuses

The form has no status field: an agreement's stored status is **Active** from creation (`DRAFT` , `EXPIRING` , `EXPIRED` and `TERMINATED` exist but cannot be set in the UI). The Dynamic Status is computed on every read from today's date, first matching rule wins:

Value	Set by	Rule	Colour
Draft	System	Stored status is `DRAFT`	Grey
Terminated	System	Stored status is `TERMINATED`	Grey
Expired	System	End Date is before today	Red
Upcoming	System	Start Date is after today	Amber
Expiring	System	End Date is today or within the next 30 days	Amber
Active	System	Otherwise: started, and ending more than 30 days from today	Green

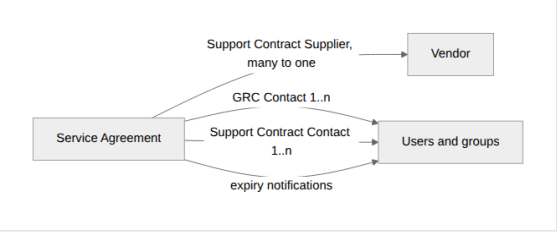
On 14 October 2026, *Jira & Confluence Cloud* (Atlassian, ending 2026-10-20) is **Expiring**; the other four demo agreements are **Active**.

A nightly job that would also move the stored status to `EXPIRING` and `EXPIRED` (daily at 01:00) exists in the code but is **not active in this release**, because scheduled jobs are not enabled on the server. This does not affect what you see: the Dynamic Status is computed on read.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Vendor	Agreement → Vendor, many to one, required	**Support Contract Supplier**	**Support Contract Supplier** column. The vendor cannot be deleted while it has agreements.
Users and groups	Agreement → people	**GRC Contact** and **Support Contract Contact**	The two contact columns; recipients of the expiry notifications

The agreement is not shown on the vendor's own row or View; filter this grid by the vendor name with the search box to see a vendor's agreements.

Who sees an agreement. Under **Assigned Records Only**, an agreement is visible to the people and groups named in its two contact fields, to its creator, and to everyone when it names nobody. Members of a group set as the vendor's Vendor Role also see the vendor's agreements.

Automations and notifications

GRC360 tells an agreement's contacts that it is about to run out.

Notification type	Title	When
`SERVICE_AGREEMENT_EXPIRING_WEEK`	*Service agreement expires in a week*	4 to 7 days left
`SERVICE_AGREEMENT_EXPIRING_SOON`	*Service agreement expires in 3 days*	1 to 3 days left
`SERVICE_AGREEMENT_EXPIRES_TODAY`	*Service agreement expires today*	The End Date is today (priority High)

- **Message.** The real number of days is given, for example *"Jira & Confluence Cloud" (Atlassian) ends on 2026-10-20 - 6 days left.*, or *… reaches its end date today, 2026-10-20.* The link **Open the agreement** opens the agreement read-only.
- **Recipients.** Every user named in **GRC Contact** and **Support Contract Contact**. A group named there is expanded to its members.
- **Which agreements.** Those whose stored status is Active (or Expiring) and whose End Date falls between today and seven days ahead. Agreements in Draft or Terminated are not warned.
- **When it runs.**
  - A daily sweep at 08:00 server time (configurable by the installer).
  - The first time each day that anyone in the organisation opens their notifications.
  - Every time an agreement is saved.
- **No duplicates.** Each milestone is sent once per agreement and recipient. A later milestone is still sent to someone who received an earlier one. A milestone whose window has passed before the first check is skipped: an agreement entered two days before its end gets only the 3-day and the end-day notices.

In the demo data, Alex Meian has received *"Service agreement expires in a week"* for *Jira & Confluence Cloud*.

Permissions

Action	Needed access
See the page	View on **Third Parties › Service Agreements**
Create / Edit	Manage on **Third Parties › Service Agreements**; the supplier must be a vendor you can see

Action	Needed access
Delete	Full Control on **Third Parties › Service Agreements**
Name other people as contacts	**Can Assign** / **Can Reassign** on a group with Manage or Full Control on Service Agreements
Fill the supplier list	View on **Third Parties › Vendors**
Create a vendor with the supplier **+ Add**	Manage on **Third Parties › Vendors**
Activity Log	The group's **Comments & Attachments** level

External contacts (members of a vendor's Vendor Role group) can read their vendor's agreements but cannot create, edit or delete any. Deleting an agreement has no other restriction; the confirmation reads *"Delete AWS Enterprise Support?"*.

How to

Record a new contract

1. Open **Third Parties › Service Agreements**, click **Add Item**.
2. **Name**: *Okta Workforce Identity*. **Support Contract Supplier**: **Okta**.
3. **GRC Contact**: **Alex Meian**. **Support Contract Contact**: **Sara Johnson**.
4. **Service Value (AZN)**: *22000*. **Start Date** 2025-11-18, **End Date** 2026-11-18.
5. Click **Save**. The agreement shows **Active** until 30 days before the end date, then **Expiring**.

Renew an expiring agreement

1. Open the **Service agreement expires in a week** notification and click **Open the agreement**, or find **Jira & Confluence Cloud** (status **Expiring**).
2. Click **Edit** on its row and move **End Date** to the new end, for example 2027-10-20.
3. Click **Save**. The Dynamic Status returns to **Active**. If the date later comes within seven days again, new notices are sent for the new date only if their milestones were not already sent for this agreement and recipient.

See all contracts with one vendor

1. Type the vendor's name, for example *Okta*, in the grid's search box.
2. Check the **Support Contract Supplier** column of the rows found.

CSV import

Not available. **Import CSV** shows *"CSV Import (Service Agreements): the import structure is not ready yet."* and opens a demonstration dialog whose validation fails.

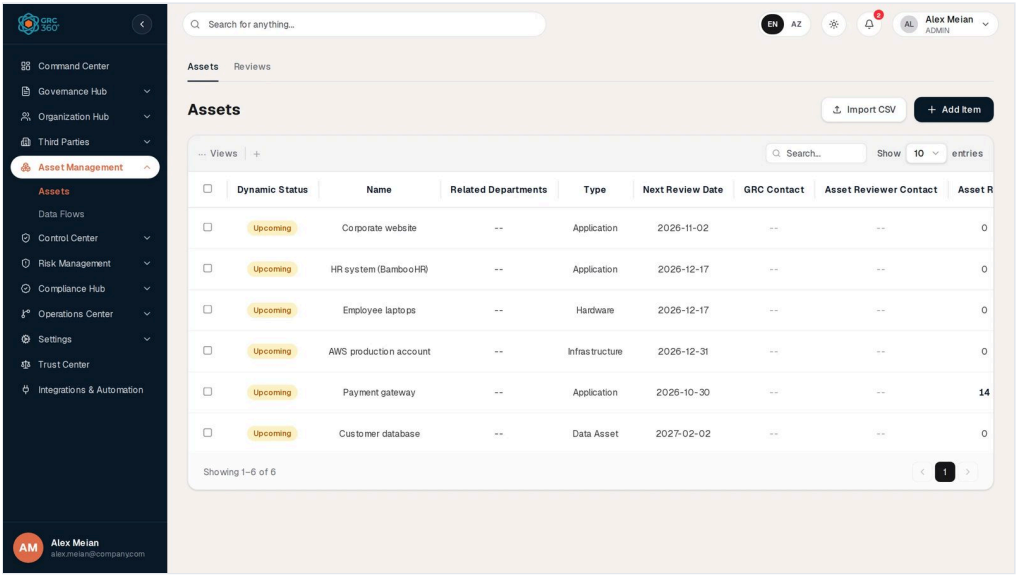
Limitations and known issues

- **No status field.** Draft and Terminated exist but cannot be set, so an agreement ended early still reads **Active**, **Expiring** or **Expired** by its dates. Shorten the End Date to reflect an early termination.
- **Renewal notices.** The "already sent" record is kept per agreement, milestone and recipient, not per end date, so moving an agreement's end date after its notices went out does not produce a second set of the same milestones.
- **Currency.** New agreements are always in AZN; there is no way to choose another currency.
- **Contact names missing in the grid** for the demo agreements, which carry contact ids without stored names: the grid shows `--`, Edit shows the people, and saving without re-picking the contacts fails with *"Required"*.
- **Agreement documents.** The backend has fields for an attached contract document (URL, name, type, size), but the page offers no way to set or see them.
- **Search.** Service agreements are not included in the global search.
- The nightly status job is implemented but not active in this release (see Statuses).

Asset Management

> **Module:** Asset Management · **Route:** `/asset-management` (opens **Assets**) · **Permission module:** `asset_management`

Asset Management is the inventory of what your organisation needs to protect: applications, data, hardware, infrastructure, facilities, people and services. Every asset has an owner on the GRC side, a reviewer and a review cycle, and is the anchor for the asset risks and third-party risks recorded in Risk Management. For assets that hold data, the **Data Flows** page records the GDPR analysis of the data asset and how its data is collected, stored, modified, moved and deleted.



Assets register

Pages

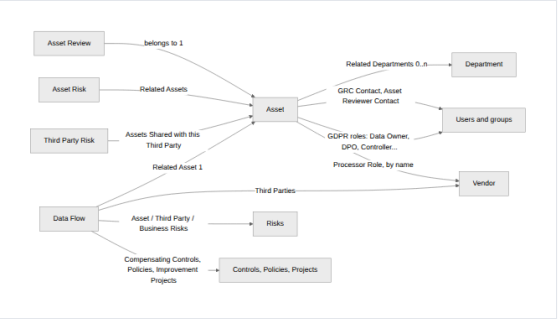
Page (sidebar label)	Route	Permission key	What it holds
Assets	`/asset-management/assets`	`asset_management.assets`	The asset register: departments, name, type, contacts, next review date, and counts of linked risks, reviews and data flows.
Assets › Reviews	same route, **Reviews** tab	`asset_management.assets_reviews`	Planned and completed reviews of each asset, partly generated from the asset's Next Review Date.
Data Flows	`/asset-management/data-movement`	`asset_management.data_movement`	Two tabs: **Data Assets** (the GDPR analysis of assets of type *Data Asset*) and **Data Asset Flows** (each step in the life of an asset's data, with its GDPR questions, risks and controls).

Opening `/asset-management` without a page redirects to **Assets**. The sidebar label **Data Flows** is a label only: the route stays `/asset-management/data-movement` and the permission codes stay `asset_management_data_movement_*`.

How the pages relate

- An **asset** is created and edited only on the Assets page. The Data Flows page never creates an asset; its **Data Assets** tab is a filtered view of the same register (assets whose **Type** is exactly *Data Asset*) where the GDPR analysis is filled in.
- A **review** belongs to one asset. Saving an asset with a **Next Review Date** creates two planned reviews (that date and the same day a year later).
- A **data flow** belongs to one asset (its **Related Asset**). The asset's **Data Asset Flows** count shows how many flows it has. Whether a flow is asked GDPR questions depends on its asset's GDPR switch.

- Risks are linked from the risk side: an asset risk names its **Related Assets**, a third-party risk its **Assets Shared with this Third Party**. The asset grid counts them.



Who sees what

Assets is one of the nine registers where a group's **data visibility** applies, and where **Can Assign** / **Can Reassign** govern the people fields (GRC Contact, Asset Reviewer Contact, and the Data Owner, DPO Role, Controller Role and Controller Representative of the GDPR analysis). Reviews and data flows follow their asset: a person who cannot see an asset does not see its reviews or flows either. See Groups.

Automations and notifications

What	When	Effect
Asset Dynamic Status	Every read	Computed from the Next Review Date
Review Dynamic Status	Every read	Computed from the review's planned and actual dates
Review generation	Every save of an asset	Planned reviews are created for the Next Review Date and one year later, dates in the past are skipped, and untouched generated reviews for an old date are removed
Review and flow counters	Every read / every review save	The **Reviews** and **Data Asset Flows** counts on the asset

No notifications are sent by this module.

CSV import

Not available on any page of the module. **Import CSV** shows *"CSV Import (): the import structure is not ready yet."* and opens a demonstration dialog whose validation fails. See Working with registers.

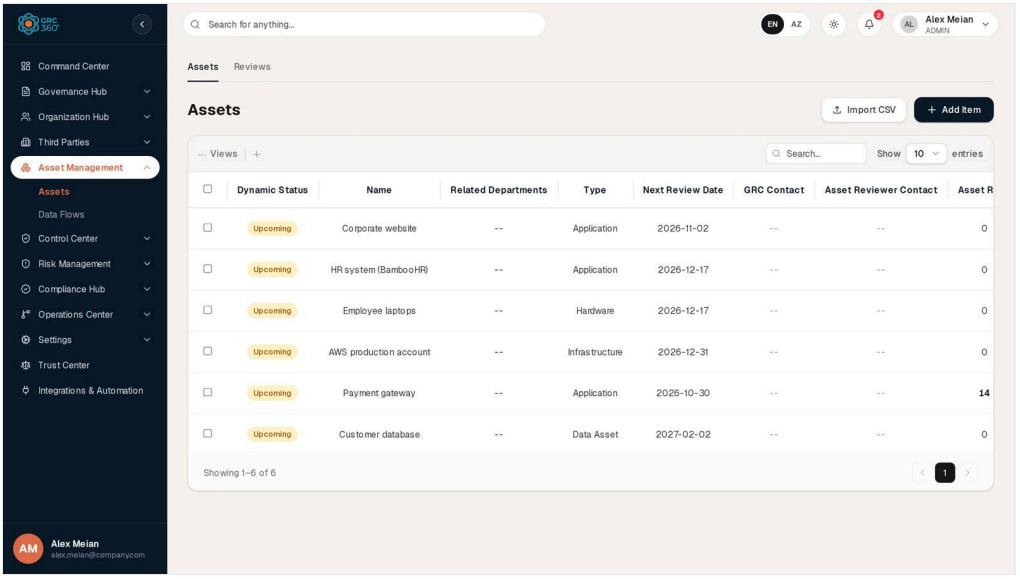
See also

- Risk Management › Asset Risks and Third Party Risks
- Third Parties › Vendors
- Working with registers

Assets

> **Module:** Asset Management › Assets · **Route:** `/asset-management/assets` · **Permission key:** `asset_management.assets` (Reviews tab: `asset_management.assets_reviews`)

The Assets register is the inventory of what your organisation must protect. A record is one asset, for example an application, a database, a fleet of laptops or a cloud account, with the departments it serves, its type, the GRC contact responsible for it, the person who reviews it and the date of its next review. The grid also shows how many asset risks and third-party risks concern the asset, how many reviews and data flows it has, and a Dynamic Status that tells whether the review cycle is on time. The **Reviews** tab holds the planned and completed reviews of every asset. Asset owners and the GRC team maintain it; risk owners pick assets in the risk registers.



Assets register

At a glance

A record is	One asset to protect
Typical owner	Asset owner (GRC Contact) and the GRC team
Links to	Departments (Related Departments), GRC Contact and Asset Reviewer Contact (users and groups)
Linked from	Asset Risks (Related Assets), Third Party Risks (Assets Shared with this Third Party), Asset Reviews, Data Flows (Related Asset), Departments (Asset Risks count)
Tabs	**Reviews**
Automations	Dynamic Status computed from the Next Review Date; planned reviews generated from the Next Review Date on every save

The register (list view)

The grid is paged on the server and opens newest first. It refreshes when assets, asset risks or third-party risks change. Shared grid behaviour is described in Working with registers.

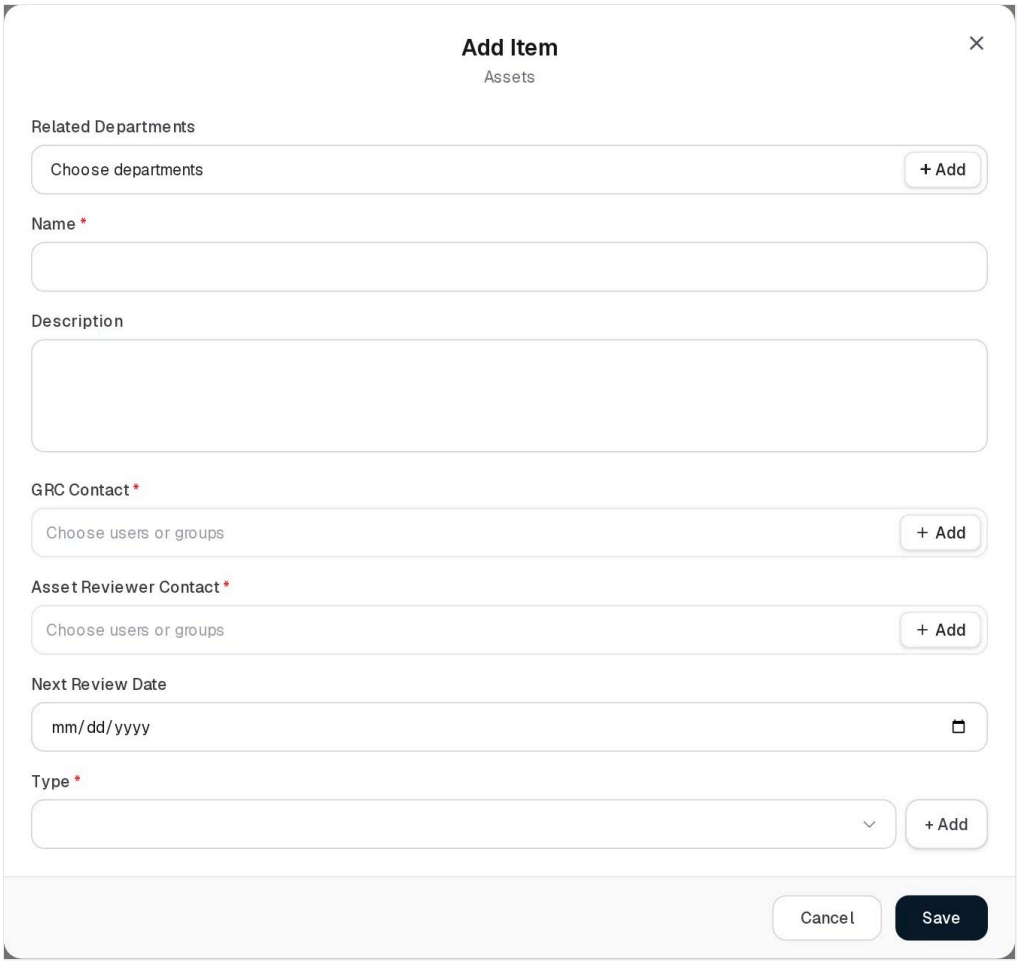
Clicking a row (not one of its buttons) switches to the **Reviews** tab filtered to that asset.

Column	What it shows	Source
Dynamic Status	**Upcoming**, **Expired** or **Missing Date**; see Statuses	Computed by the system
Name	Asset name	Entered
Related Departments	Department names, or `--`	Linked
Type	Asset type, or `--`	Entered
Next Review Date	YYYY-MM-DD, or `--`	Entered
GRC Contact	Avatar and name of each contact, or `--`	Entered
Asset Reviewer Contact	Avatar and name of each reviewer, or `--`	Entered
Asset Risks	Number of asset risks that list the asset under **Related Assets**. A number above 0 is a link that opens those risks; hovering shows their names. Not sortable.	Computed
Third Party Risk	Number of third-party risks that list the asset under **Assets Shared with this Third Party**. Clickable like Asset Risks. Not sortable.	Computed
Reviews	Number of reviews of the asset (generated and manual)	Computed
Data Asset Flows	Number of data flows whose Related Asset is this asset. Not sortable.	Computed
Status	**Active** (green). There is no field to change it.	Stored

In the demo data, **Payment gateway** has 14 asset risks and **Customer database** (type **Data Asset**, so it also appears on the Data Flows page) has 4 third-party risks and 1 data flow; every asset has two generated reviews.

Creating a record

Click **Add Item**. The **Add Item** dialog (subtitle *Assets*) opens.



Add asset

Field	Type	Required	Rules and allowed values	Example
Related Departments	Department picker, several allowed, with **+ Add**	No	Departments from Organization Hub. **+ Add** creates a department. Up to 500 characters of names.	IT, Finance
Name	Text	Yes	*"Required"*. Up to 255 characters. Names do not have to be unique.	Payment gateway
Description	Text area	No	Up to 1,000 characters	Card payment processing service
GRC Contact	User-and-group picker, several allowed, with **+ Add**	Yes	*"GRC Contact is required"*. Subject to **Can Assign** / **Can Reassign**. The names are stored in a 200-character field.	Alex Meian
Asset Reviewer Contact	User-and-group picker, several allowed, with **+ Add**	Yes	*"Asset Reviewer Contact is required"*. Subject to **Can Assign** / **Can Reassign**. 200-character field.	Sara Johnson
Next Review Date	Date	No	Any date. Drives the Dynamic Status and the generated reviews.	2026-10-30

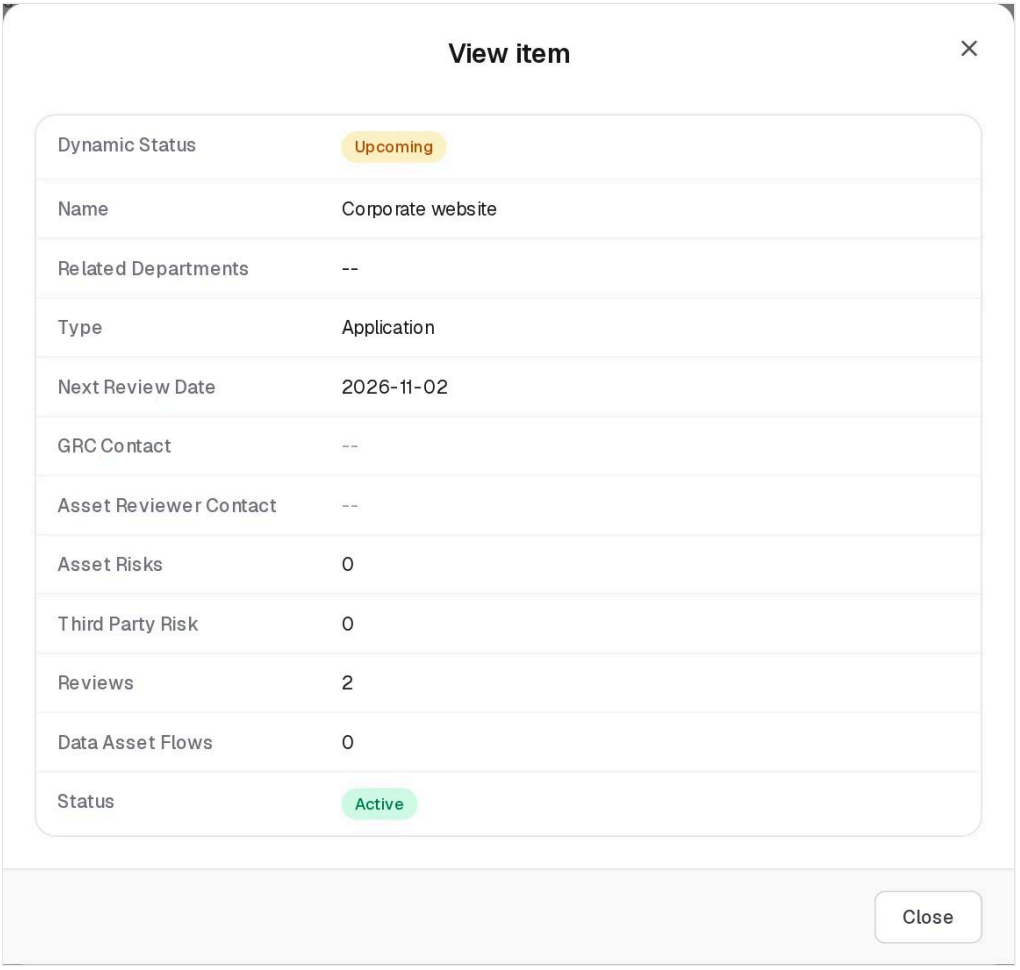
Field	Type	Required	Rules and allowed values	Example
Type	Drop-down with **+ Add**	Yes	*"Required"*. The list holds Data Asset, Facilities, Financial, Hardware, IT Service, Network, People, Software, every type used by the assets on the page currently shown, and types added in this session, sorted alphabetically. **+ Add** replaces the drop-down with a **New Type** box and **Save** / **Cancel**. Up to 100 characters.	Software

Choose **Data Asset** as the Type for an asset whose data you want to analyse on the Data Flows page; only assets of that exact type appear there.

Click **Save**; *"Asset added."* confirms it. Saving with a Next Review Date creates the planned reviews at once (see Reviews).

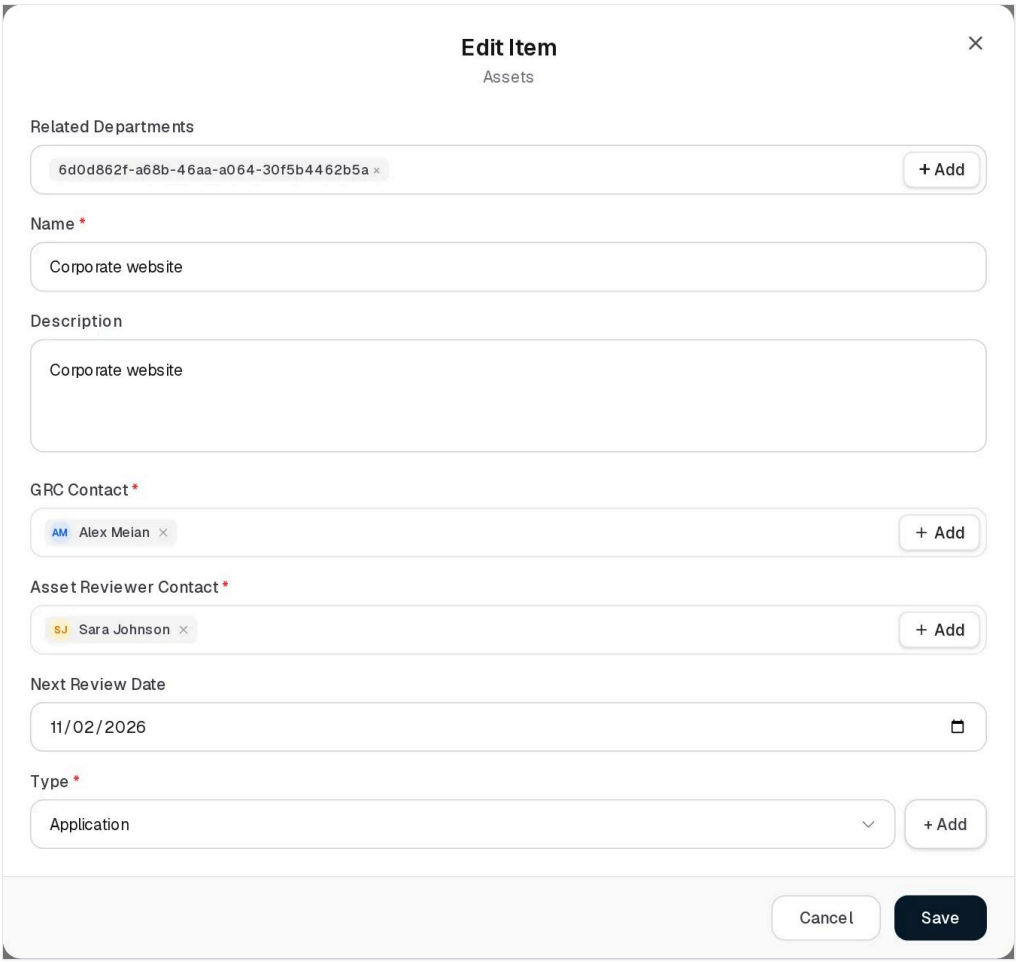
Fields the form does not show are filled by the system: the category takes the Type, the owner text takes the GRC Contact names, criticality is **Medium**, status is **Active**, and the creator is recorded as the asset's owner for data visibility.

Viewing and editing a record



View asset

View opens the generic **View item** dialog with every grid column; counts are plain numbers there.



Edit asset

Edit Item has the same fields as Add. Saving keeps the asset's risk links (they are owned by the risk registers), its GDPR analysis (owned by the Data Flows page), its criticality and status. Changing the Next Review Date regenerates the planned reviews.

Deleting an asset (confirmation *"Delete asset Payment gateway?"*) also deletes, without further warning:

- all its reviews;
- all its data flows (projects that listed those flows lose them);
- its links from asset risks and third-party risks, and from security incidents (the risks and incidents remain).

Statuses

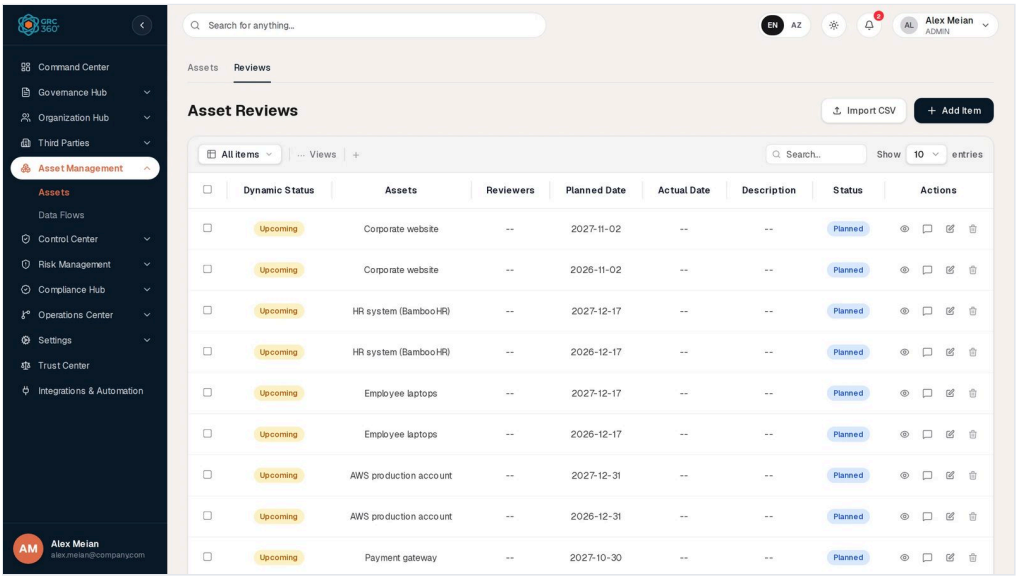
Value	Set by	Rule	Colour
Missing Date	System	The asset has no Next Review Date	Amber
Expired	System	The Next Review Date is before today	Red
Upcoming	System	The Next Review Date is today or later	Amber
Active (Status column)	System	Every asset created in the UI; there is no field to change it	Green

The Dynamic Status looks only at the Next Review Date, not at whether the reviews in the Reviews tab were carried out.

Tabs

Reviews

The **Reviews** tab (permission key `asset_management.assets_reviews`) lists the reviews of all assets, titled **Asset Reviews**. After clicking an asset row it shows only that asset's reviews, titled **Reviews for** , with a **Show All Reviews** link and *Filtering for:* above the grid. If your group has No Access on the tab, the tab is shown with a lock and clicking it opens the access request dialog.

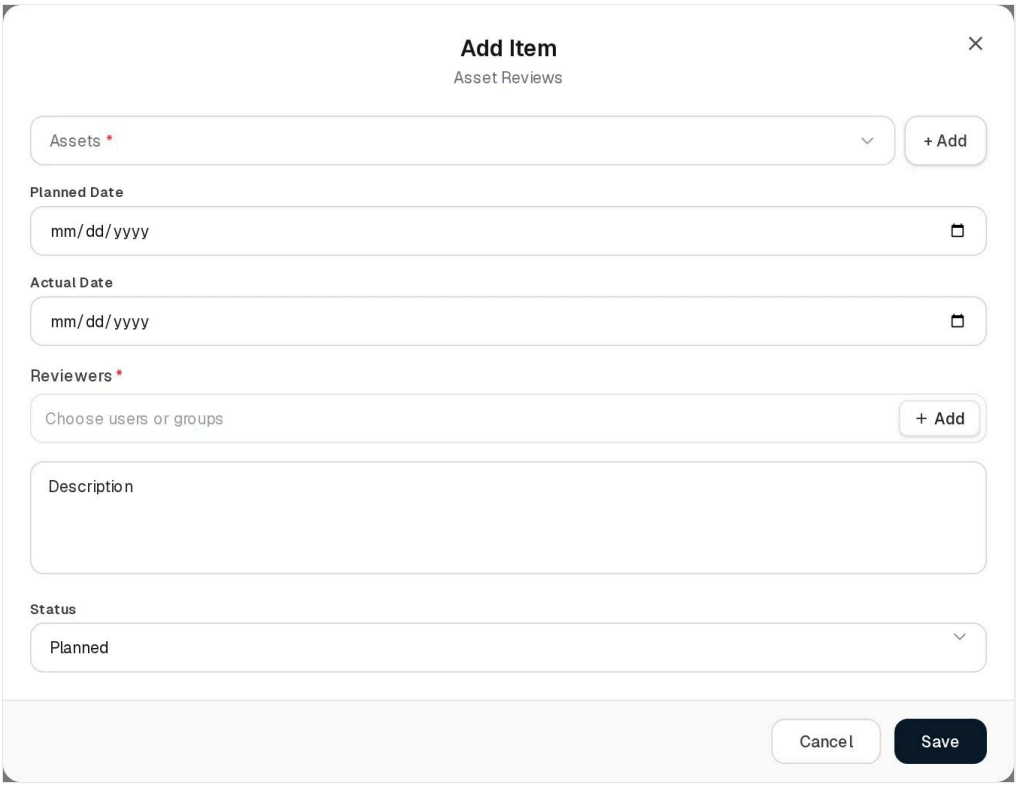


Asset Reviews

Column	What it shows	Source
Dynamic Status	**Completed**, **Missing Date**, **Expired** or **Upcoming**; see below	Computed by the system
Assets	The asset reviewed	Linked
Reviewers	Reviewer names, or `--`	Entered
Planned Date	YYYY-MM-DD, or `--`	Entered
Actual Date	YYYY-MM-DD, or `--`	Entered
Description	Text, or `--`	Entered
Status	**Planned** (blue), **In Progress** (amber), **Completed** (green), **Expired** (red)	Entered

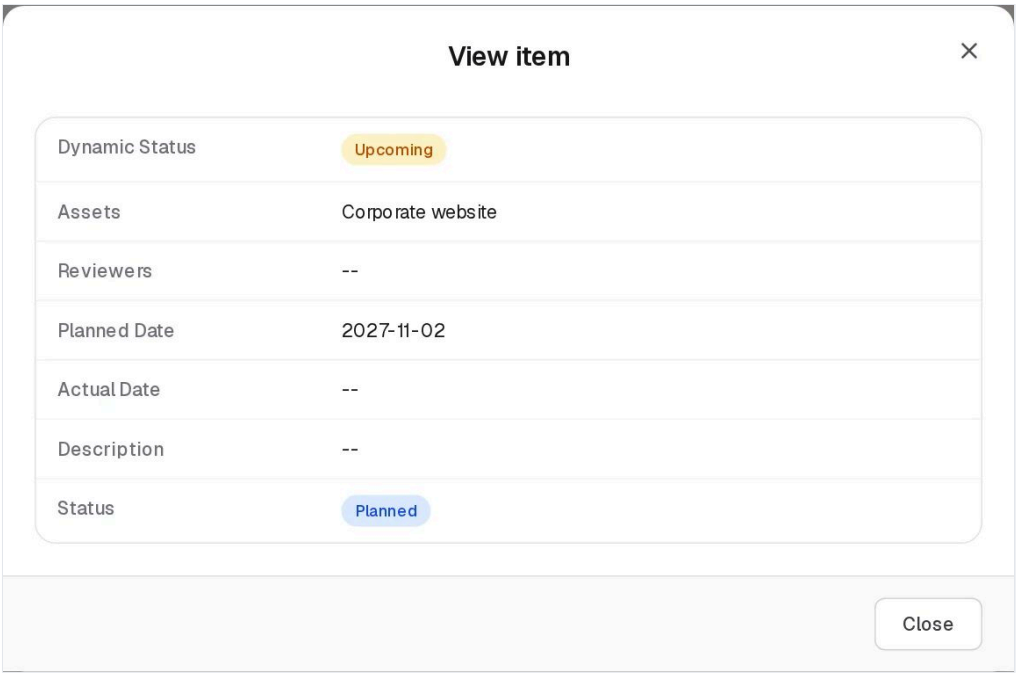
Adding a review

Click **Add Item** on the tab. The **Add Item** dialog (subtitle *Asset Reviews*) opens; when the tab is filtered, the asset is pre-filled.



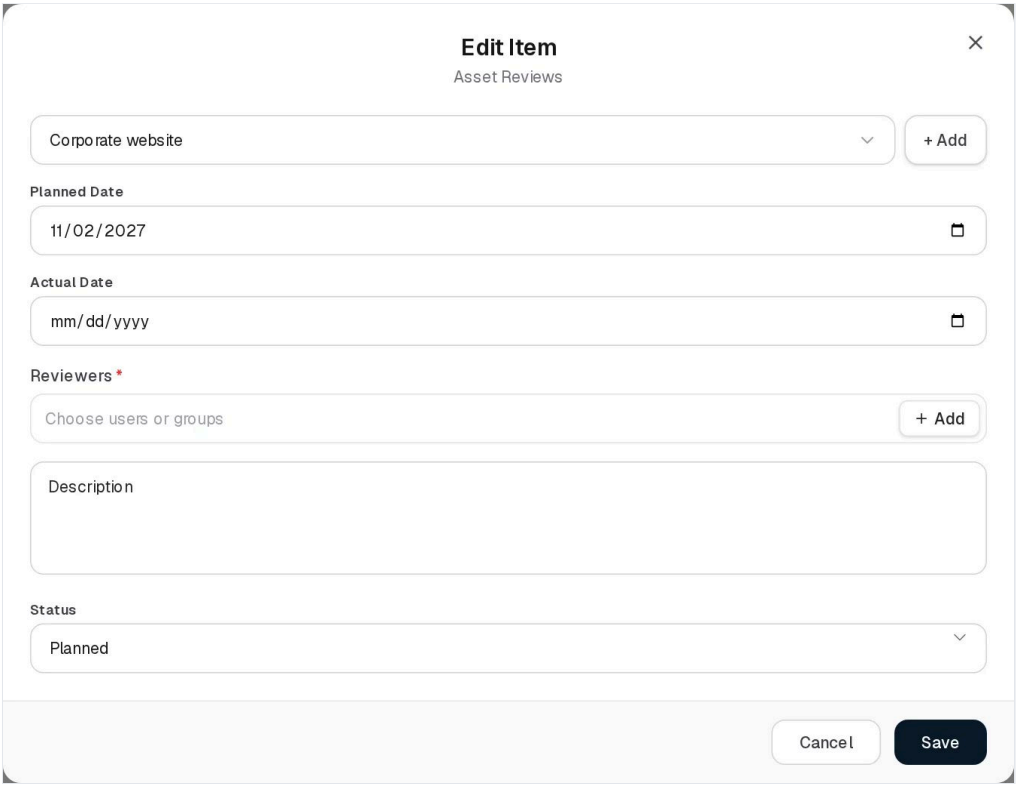
Add review

Field	Type	Required	Rules and allowed values	Example
Assets	Searchable list (*Search for items*) with **+ Add**	Yes	One asset (“*Required*”). **+ Add** creates an asset.	Corporate website
Planned Date	Date	No		2026-11-02
Actual Date	Date	No	Filling it marks the review **Completed** in Dynamic Status	2026-11-05
Reviewers	User-and-group picker, several allowed, with **+ Add**	Yes	*“Required”*. Stored as names only (up to 500 characters); not subject to the assignment rights.	Sara Johnson
Description	Text area	No	Up to 1,000 characters	Annual access review of the CMS
Status	Drop-down	No	**Planned** (default), **In Progress**, **Completed**, **Expired**	Planned



View review

View shows the review's columns in the generic **View item** dialog. **Edit** opens the same form as Add:



Edit review

Review statuses

Value	Set by	Rule	Colour
Completed	System	The review has an Actual Date	Green
Missing Date	System	No Actual Date and no Planned Date	Amber

Value	Set by	Rule	Colour
Expired	System	No Actual Date and the Planned Date is before today	Red
Upcoming	System	No Actual Date and the Planned Date is today or later	Amber
Planned / In Progress / Completed / Expired	User (Status field)	The reviewer's own statement; it does not change the Dynamic Status	Blue / amber / green / red

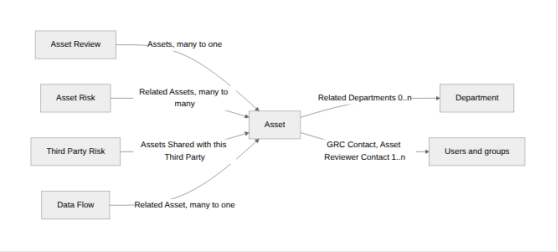
Generated reviews

Every time an asset is saved, GRC360 aligns its generated reviews with the Next Review Date:

1. The target dates are the Next Review Date and the same day one year later; a target already in the past is dropped.
2. A missing target date gets a new review: status **Planned**, Reviewers = the asset's **Asset Reviewer Contact** names at that moment.
3. Generated reviews that were not carried out (no Actual Date) and whose date is no longer a target are deleted.
4. Reviews added by hand and generated reviews that have an Actual Date are never removed.

Example from the demo data: **Corporate website** has Next Review Date 2026-11-02, so the tab holds reviews planned for 2026-11-02 and 2027-11-02. Their Reviewers are `--` because the asset had no reviewer names when they were generated; editing the reviewer later does not update existing reviews.

Relationships



Related record	Direction	How the link is made	Where it shows
Departments	Asset → Department, many to many	**Related Departments**	**Related Departments** column; the department's **Asset Risks** count
Users and groups	Asset → people	**GRC Contact**, **Asset Reviewer Contact**	The contact columns
Asset Reviews	Review → Asset, many to one	**Assets** on the review form, or generated from the Next Review Date	**Reviews** count; row click opens them
Asset Risks	Risk → Asset, many to many	**Related Assets** on the asset risk (Risk Management)	**Asset Risks** count (clickable)
Third Party Risks	Risk → Asset, many to many	**Assets Shared with this Third Party** on the third-party risk	**Third Party Risk** count (clickable)
Data Flows	Flow → Asset, many to one	**Related Asset** on the data flow form	**Data Asset Flows** count; Data Flows page

Automations and notifications

No notifications. The Dynamic Status of assets and reviews is computed on every read; reviews are generated on every save of an asset; the Reviews count is kept up to date on every review save and delete.

Permissions

Action	Needed access
See the page	View on **Asset Management › Assets**
Create / Edit an asset	Manage on **Asset Management › Assets**
Delete an asset	Full Control on **Asset Management › Assets**
Name other people as GRC Contact or Asset Reviewer Contact	**Can Assign** (empty field) / **Can Reassign** (field already naming others)
Open the Reviews tab	View on **Asset Management › Assets › Reviews** (and View on Assets)
Add / Edit a review	Manage on **Assets › Reviews**
Delete a review	Full Control on **Assets › Reviews**
Open the risks behind a count	View on the risk register concerned
Activity Log (assets and reviews)	The group's **Comments & Attachments** level

Under **Assigned Records Only**, a person sees the assets that name them or one of their groups in a people field (contacts, reviewer, GDPR roles), the assets they created, and assets that name nobody; reviews follow their asset. Under **Their department** they also see assets booked against their department.

How to

Register a new application

1. Open **Asset Management › Assets**, click **Add Item**.
2. **Related Departments**: **IT**. **Name**: *HR system (BambooHR)*. **Type**: **Software** (or add *Application* with **+ Add**).
3. **GRC Contact**: **Alex Meian**. **Asset Reviewer Contact**: **Sara Johnson**.
4. **Next Review Date**: 2026-12-17. Click **Save**.
5. Open the **Reviews** tab: reviews planned for 2026-12-17 and 2027-12-17 have been created with Sara Johnson as reviewer.

Record a completed review

1. Click the row of **Corporate website**; the Reviews tab opens filtered to it.
2. Click **Edit** on the review planned for 2026-11-02.
3. Fill **Actual Date**, set **Status** to **Completed**, add a **Description** of the outcome, click **Save**.
4. The review's Dynamic Status becomes **Completed**. To move the cycle on, edit the asset and set the next **Next Review Date**.

Find the risks attached to an asset

1. In the **Payment gateway** row, click **14** in **Asset Risks**.
2. The panel lists the 14 asset risks; open any of them from there.

Prepare an asset for GDPR analysis

1. Edit the asset, for example **HR system (BambooHR)**, and set **Type** to **Data Asset** (as was done for **Customer database** in the demo data).
2. Open Data Flows; the asset now appears in the **Data Assets** tab, where its GDPR analysis is filled in.

CSV import

Not available. **Import CSV** (on both tabs) shows *"CSV Import (Assets): the import structure is not ready yet."* (or *Asset Reviews*) and opens a demonstration dialog whose validation fails.

Limitations and known issues

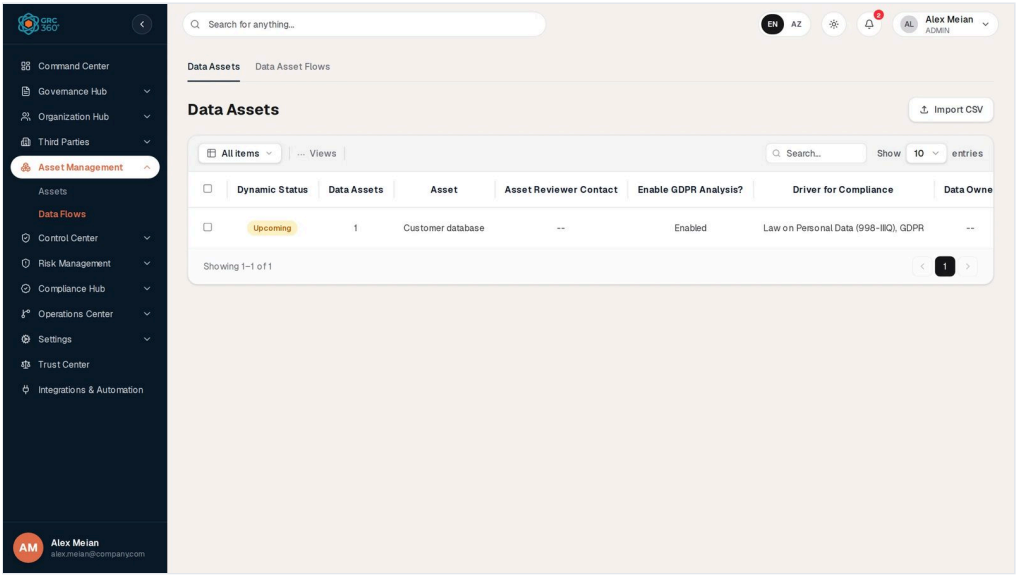
- **Deleting an asset deletes its reviews and data flows** without saying so in the confirmation.

- **Type list.** Types already used by assets on other pages of the grid are not offered unless you are on that page; types added with **+ Add** last only for the session until an asset uses them. In the demo data the types are Application, Hardware, Infrastructure and Data Asset; only **Customer database** is a *Data Asset* and therefore the only row of the Data Flows page's Data Assets tab.
- **Status** is always **Active**; there is no way to retire an asset other than deleting it.
- **Generated reviews keep the reviewer names of the moment they were created.** Changing the Asset Reviewer Contact later does not update them.
- **Dynamic Status ignores the reviews.** An asset whose review was completed still reads **Expired** once its Next Review Date has passed, until the date is moved.
- **Contact length.** GRC Contact and Asset Reviewer Contact names are stored in 200 characters; very long selections are refused by the server.
- **Demo data.** The demo assets carry a GRC Contact id without a stored name, so the grid shows `--` while Edit shows the person. Saving keeps the id but not a name; re-pick the contact if the grid should show it.

Data Flows

> **Module:** Asset Management › Data Flows · **Route:** `/asset-management/data-movement` · **Permission key:** `asset_management.data_movement`

The Data Flows page is where the data protection analysis of your data assets is recorded. It has two tabs. **Data Assets** lists the assets whose type is *Data Asset* and holds each one's GDPR analysis: who owns the data, whether GDPR applies, who is DPO, processor, controller and controller representative, and which supervisory authority is competent. **Data Asset Flows** lists the steps in the life of a data asset's data (collected, stored, modified, in transit, deleted), each with its departments, third parties, risks, mitigating controls and, when the asset is under GDPR, the GDPR questions for that stage. Data protection officers, privacy and GRC teams work in this page. The sidebar label is **Data Flows**; the route and permission codes keep the older name *data movement*.



Data Flows, Data Assets tab

At a glance

A record is	On **Data Assets**: one asset of type *Data Asset* (the same record as on the Assets page). On **Data Asset Flows**: one step in the life of an asset's data.
Typical owner	Data protection officer, privacy or GRC team
Links to	Data asset → people (Data Owner, DPO Role, Controller Role, Controller Representative), Processor Role (vendors, by name). Flow → Related Asset, Departments, Third Parties, Asset Risks, Third Party Risks, Business Risks, Compensating Controls, Improvement Projects, Policies.
Linked from	Assets (**Data Asset Flows** count)
Tabs	**Data Assets** (default), **Data Asset Flows**. They are views of one page and share its permission key.
Automations	Dynamic Status of data assets computed from the Next Review Date; Third Parties and Third Party Risks of a flow kept consistent with each other

The register

The page has two tabs, each with its own grid.

Data Assets tab

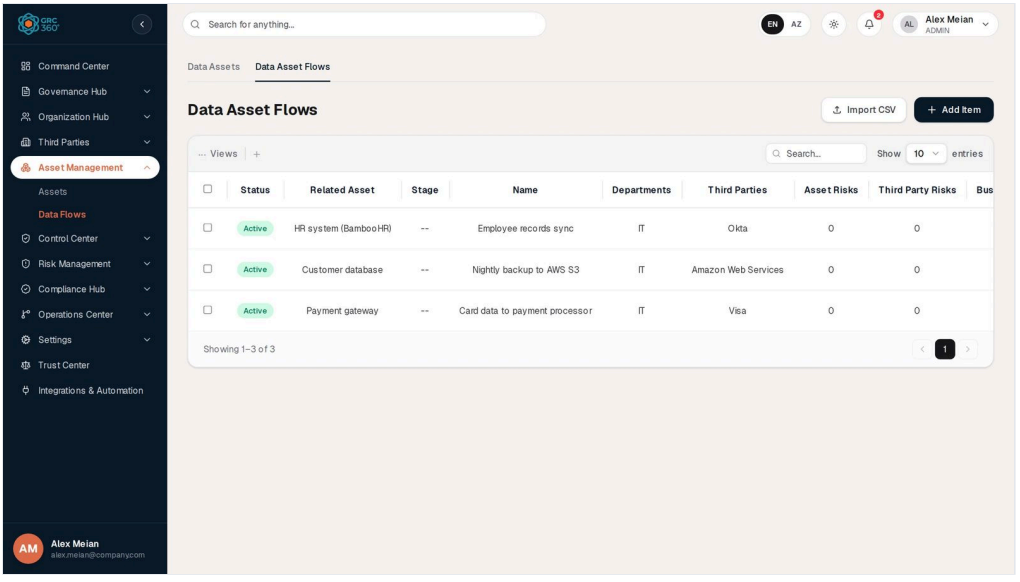
The grid lists every asset whose **Type** is exactly *Data Asset* (letter case and surrounding spaces ignored), newest first. Assets of any other type are not shown. There is no **Add Item** button: data assets are created on the Assets page. When none exist, the grid says *“No data assets yet. Create an asset of type”Data Asset” in Asset Management → Assets.”*. Shared grid behaviour is described in Working with registers.

Column	What it shows	Source
Dynamic Status	**Upcoming**, **Expired** or **Missing Date**, from the asset’s Next Review Date (same rule as Assets)	Computed by the system
Data Assets	Number of data flows whose Related Asset is this asset (despite the heading, a count of flows)	Computed
Asset	Asset name	From the asset
Asset Reviewer Contact	Names, or `--`	From the asset
Enable GDPR Analysis?	**Enabled**, or blank when off	Entered here
Driver for Compliance	Text, or `--`	Entered here
Data Owner	Names, or `--`	Entered here
DPO Role	Names, **Not applicable**, or `--`	Entered here
Processor Role	Vendor names, **Not applicable**, or `--`	Entered here
Controller Role	Names, **Not applicable**, or `--`	Entered here
Controller Representative	Names, **Not applicable**, or `--`	Entered here
Supervisory Authority	Country, or `--`	Entered here

In the demo data the tab holds one row, **Customer database**: **Upcoming**, **1** flow, **Enabled**, Driver for Compliance *Law on Personal Data (998-IIIQ), GDPR*, Processor Role **Amazon Web Services**, Controller Representative **Not applicable**.

Data Asset Flows tab

The grid is paged on the server, newest first, and refreshes when flows or assets change. In the demo data it holds three flows (*Employee records sync* on HR system (BambooHR), *Nightly backup to AWS S3* on Customer database, *Card data to payment processor* on Payment gateway), all in department IT, with Okta, Amazon Web Services and Visa as third parties and no stage.



Data Asset Flows tab

Column	What it shows	Source
Status	**Active** (green); there is no field to change it	Stored
Related Asset	The asset the flow belongs to	Linked
Stage	Collected, Deleted, Modified, Stored or Transit, or `--`	Entered
Name	Flow name, or `--`	Entered
Departments	Department names, or `--`	Linked
Third Parties	Vendor names, or `--`	Linked
Asset Risks	Count of linked asset risks; above 0 it opens the risks. Not sortable.	Linked
Third Party Risks	Count of linked third-party risks; clickable. Not sortable.	Linked
Business Risks	Count of linked business risks; clickable. Not sortable.	Linked
Improvement Projects	Project names, or `--`	Linked
Compensating Controls	Control names, or `--`	Linked
Policies	Policy names, or `--`	Linked

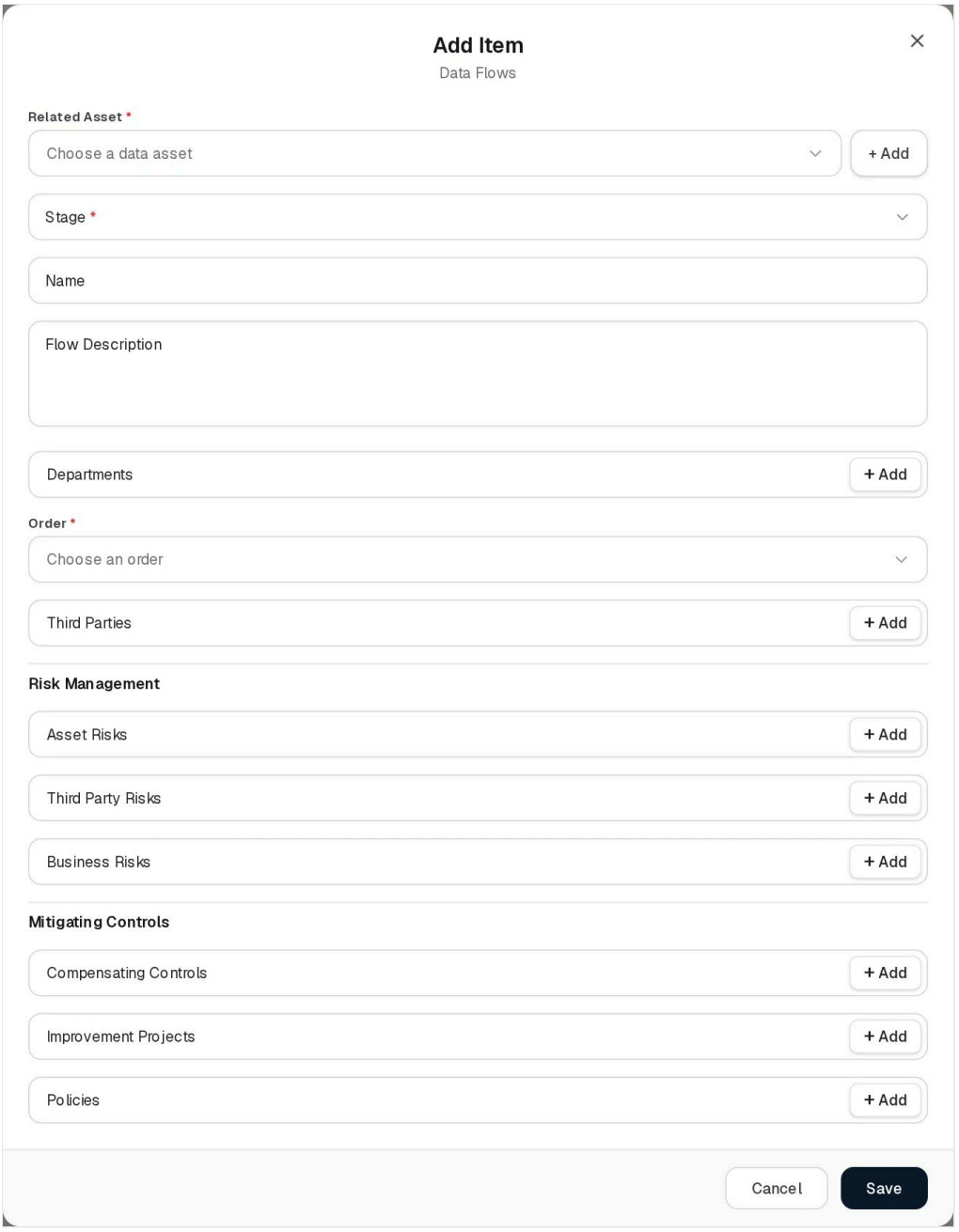
The flow's **Order** and its GDPR answers are not shown in the grid; open **Edit** to see them.

Creating a record

Data assets are not created here: create an asset of type *Data Asset* on the Assets page and it appears on the **Data Assets** tab. Data flows are created on the **Data Asset Flows** tab.

Adding a data flow

Click **Add Item** on the tab. The **Add Item** dialog (subtitle *Data Flows*) opens. It is one scrolling form with the headings **Risk Management**, **Mitigating Controls** and, when applicable, **GDPR**.



Add data flow

Field	Type	Required	Rules and allowed values	Example
Related Asset	Searchable list with **+ Add**	Yes	*“Asset is required”*. Lists only assets of type *Data Asset* (the type is shown beside each name), plus the flow’s current asset when editing an older flow. Empty list: *“No data assets found. Create an asset of type”Data Asset” in Asset Management → Assets.”* **+ Add** creates an asset. Picking an asset links it only; nothing is copied from it. In the demo data the list offers only **Customer database**.	Customer database

Field	Type	Required	Rules and allowed values	Example
Stage	Drop-down	Marked with an asterisk, but not enforced	**Collected**, **Deleted**, **Modified**, **Stored**, **Transit**. Decides the GDPR questions.	Transit
Name	Text	No	Up to 255 characters	Nightly backup to AWS S3
Flow Description	Text area	No	Up to 1,000 characters	Encrypted database dump copied to S3 every night
Departments	Department picker, several allowed, with **+ Add**	No	Departments from Organization Hub	IT
Order	Searchable list	Yes	*"Order is required"*. The position of this flow among the asset's flows: **1** to one more than the asset's other flows (first flow: only **1**; second: **1–2**; and so on). Filled with the next position as soon as the asset is chosen; before that the list says *"Choose the related asset first."* Positions are not renumbered and two flows may share one.	2
Third Parties	Vendor picker, several allowed, with **+ Add**	No	Vendors from **Third Parties › Vendors**. Picking a vendor also adds the third-party risks that name it; removing one removes the risks no remaining vendor accounts for.	Amazon Web Services
Risk Management				
Asset Risks	Risk picker, several allowed	No	From **Risk Management › Asset Risks** (first 200)	Database backup corruption
Third Party Risks	Risk picker, several allowed	No	From **Third Party Risks** (first 200). Picking a risk also adds the vendors it applies to.	Cloud provider regional outage
Business Risks	Risk picker, several allowed	No	From **Business Risks** (first 200)	
Mitigating Controls				
Compensating Controls	Control picker, several allowed	No	From **Control Center › Controls**	Encryption at rest
Improvement Projects	Project picker, several allowed	No	From **Operations Center › Projects**	Enforce MFA on all admin accounts
Policies	Policy picker, several allowed	No	From **Control Center › Policies & Standards**	Data Retention Standard
GDPR			See GDPR questions	

The GDPR section appears only when the Related Asset has **GDPR Fields** switched on in the Data Assets tab and the Stage has questions. Its introduction reads *"Asked because has its GDPR analysis switched on. The questions follow the stage — change it and this section changes with it."*

Click **Save**; *"Data movement added."* confirms it. Every relation is stored by reference: a renamed vendor, risk or control shows its new name in the flow. The server checks every picked record exists in your organisation and, like the form, keeps Third Parties and Third Party Risks consistent. Edit (**Edit Item**) has the same form; *"Data movement updated."* Deleting asks *"Delete data flow ?"*; projects that listed the flow simply lose it.

GDPR questions

All answers are optional. Text answers are free text; list answers allow several choices.

Collected

Question	Answer type and options
Type of Data	List: Child's Data, Criminal Offences, Other, Personal Data, Pseudonymous Data, Sensitive Data, Special Category
Purpose	Text
Right To be Informed	Text
Data Subject	Text
Collection Method	List: Automated, Manual
Volume	Text
What exact data is received?	Text
What is the lawful base?	List: Consent, Contractual Obligation, Legal Obligation, Legitimate Interest, Public Interest, Vital Interest
Applicable Contracts, Code of Conducts and Privacy Notes	Text

Deleted: no GDPR questions; the section does not appear.

Modified

Question	Answer type
Stakeholders	Text
Right to Restrict	Text
Right to Access	Text
Right to Rectification	Text
Rights related to automated decision making and profiling	Text
Right to Object	Text

Stored

Question	Answer type and options
Retention	Text
Encryption	Text
Right to erasure	Text
Archiving Drivers	List: Historical, Public Interest, Scientific, Statistical Purposes. Followed by an **Archiving Drivers Not applicable** switch that clears and disables the list.

Transit

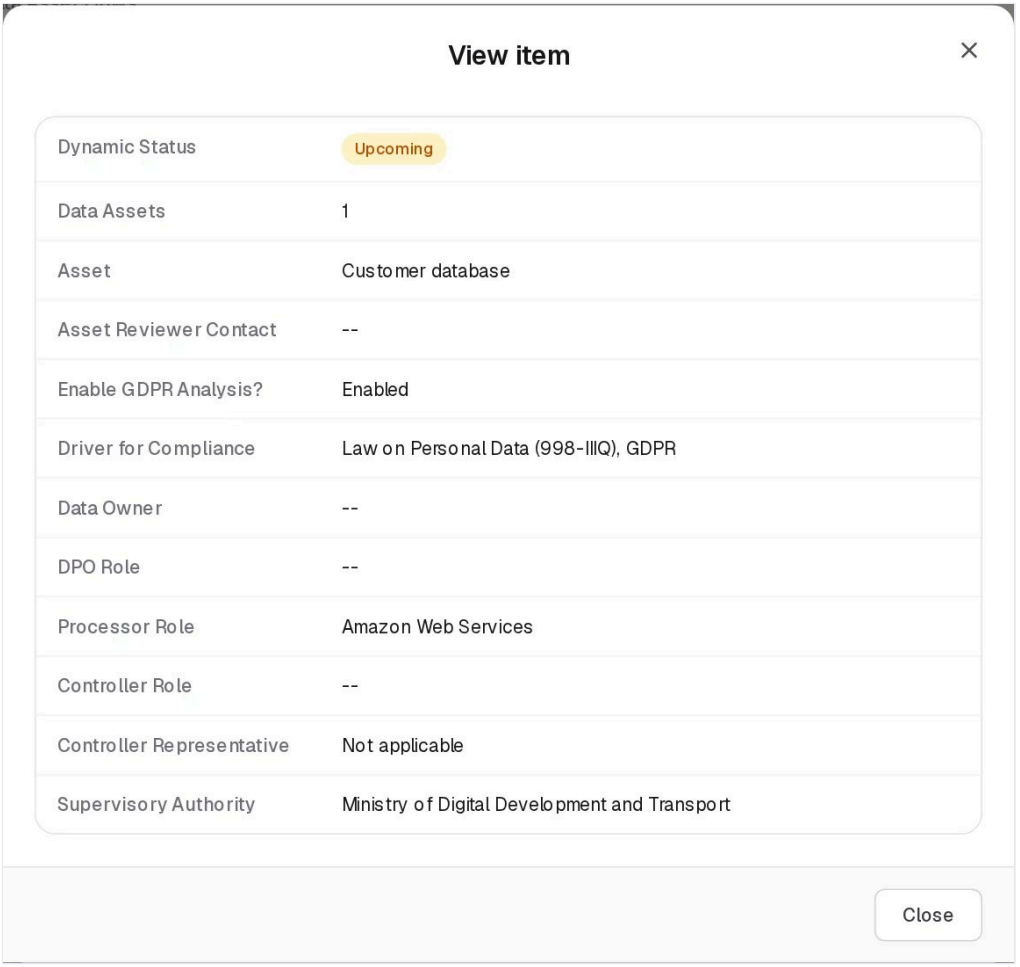
Question	Answer type and options	Rule
Origin	Text	
Destination	Text	
Data Transfers outside the EEA?	Switch	Unlocks the next three questions
Third Party Countries Involved	List of all countries of the world	Disabled and empty while the transfer switch is off, and while **Anywhere in the world** is on

Question	Answer type and options	Rule
Anywhere in the world	Switch	Disabled while the transfer switch is off. Turning it on clears the country list.
Lawful Base for Transfers outside EEA	List: Ad-Hoc Contracts, Administrative Arrangements, Binding Corporate Rules (BCR), Certifications, Code of Conduct, Contracts in between Data Subject and Controller, Controller Compelling Legitimate Interest, Court Judgements, Data Subject Consent, DPA Clauses, Interest of the Data Subject, Legal Proceedings, Model Clauses, Public Interest, Registers, Transfers in between Public Authorities, Vital Interests	Disabled while the transfer switch is off
Security	Text	
Right to Data Portability	Text	

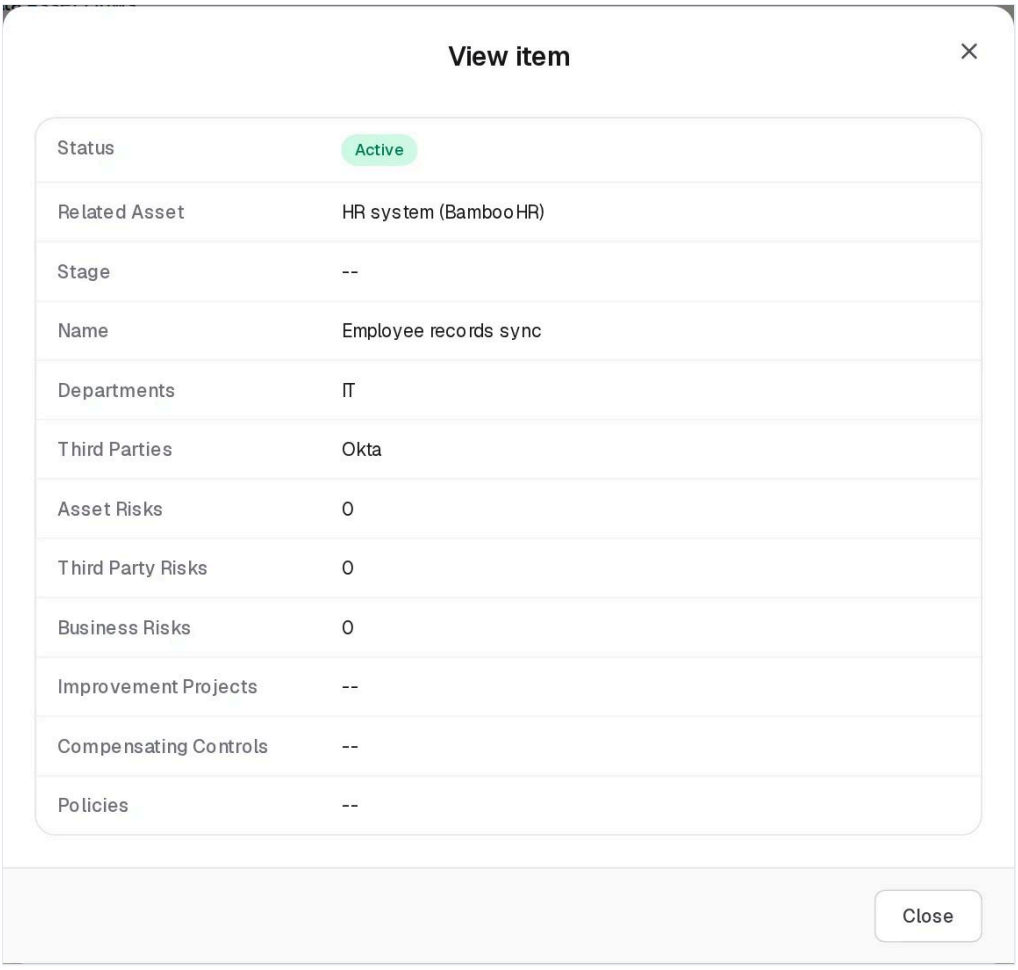
Turning **Data Transfers outside the EEA?** off clears the countries, **Anywhere in the world** and the transfer lawful base, so no hidden answer is saved. Answers are stored per question; answers of another stage stay stored when the stage is changed but are not shown.

Viewing and editing a record

On both tabs the eye button opens the generic **View item** dialog with the grid's columns.

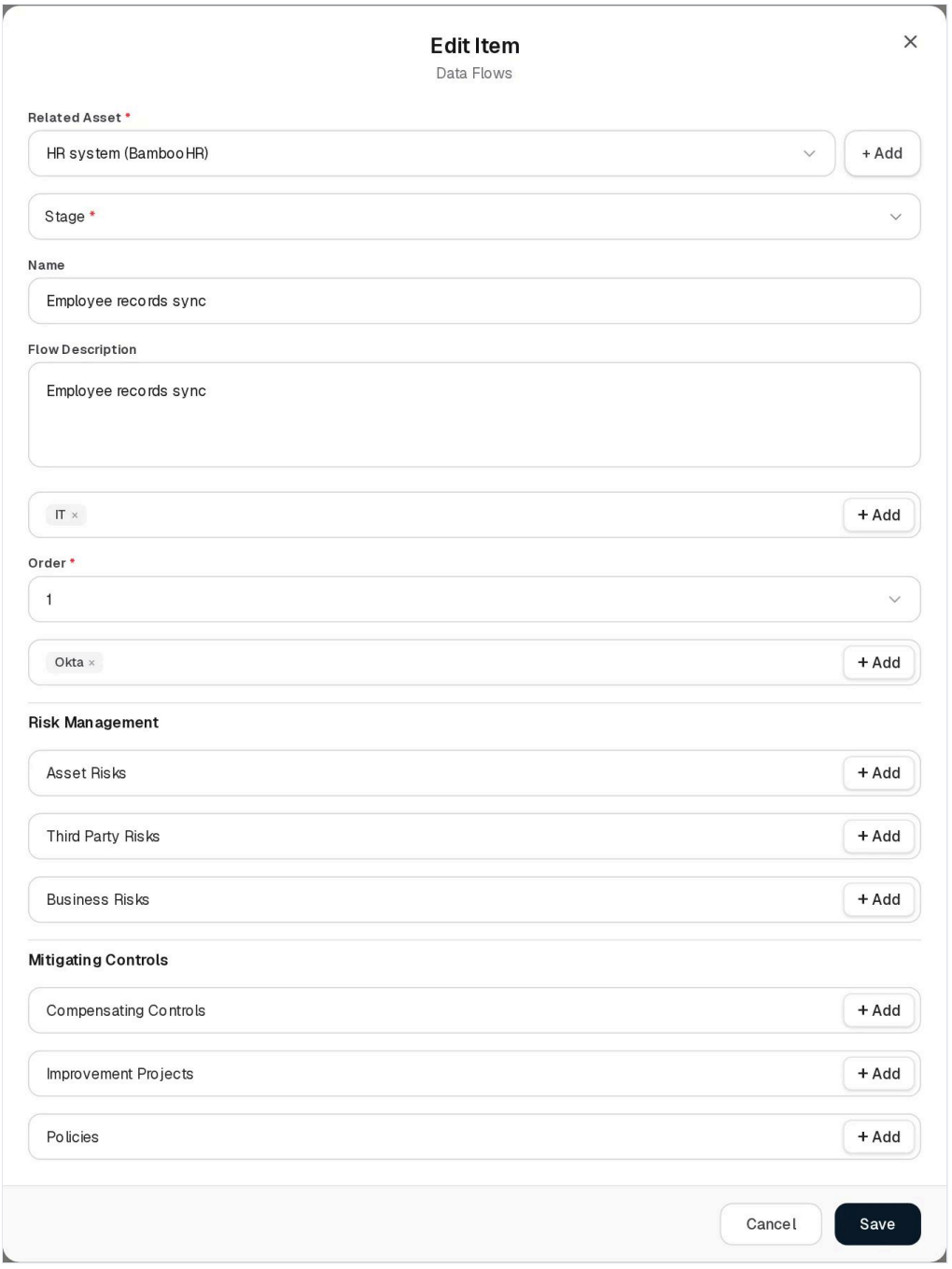


View data asset



View data flow

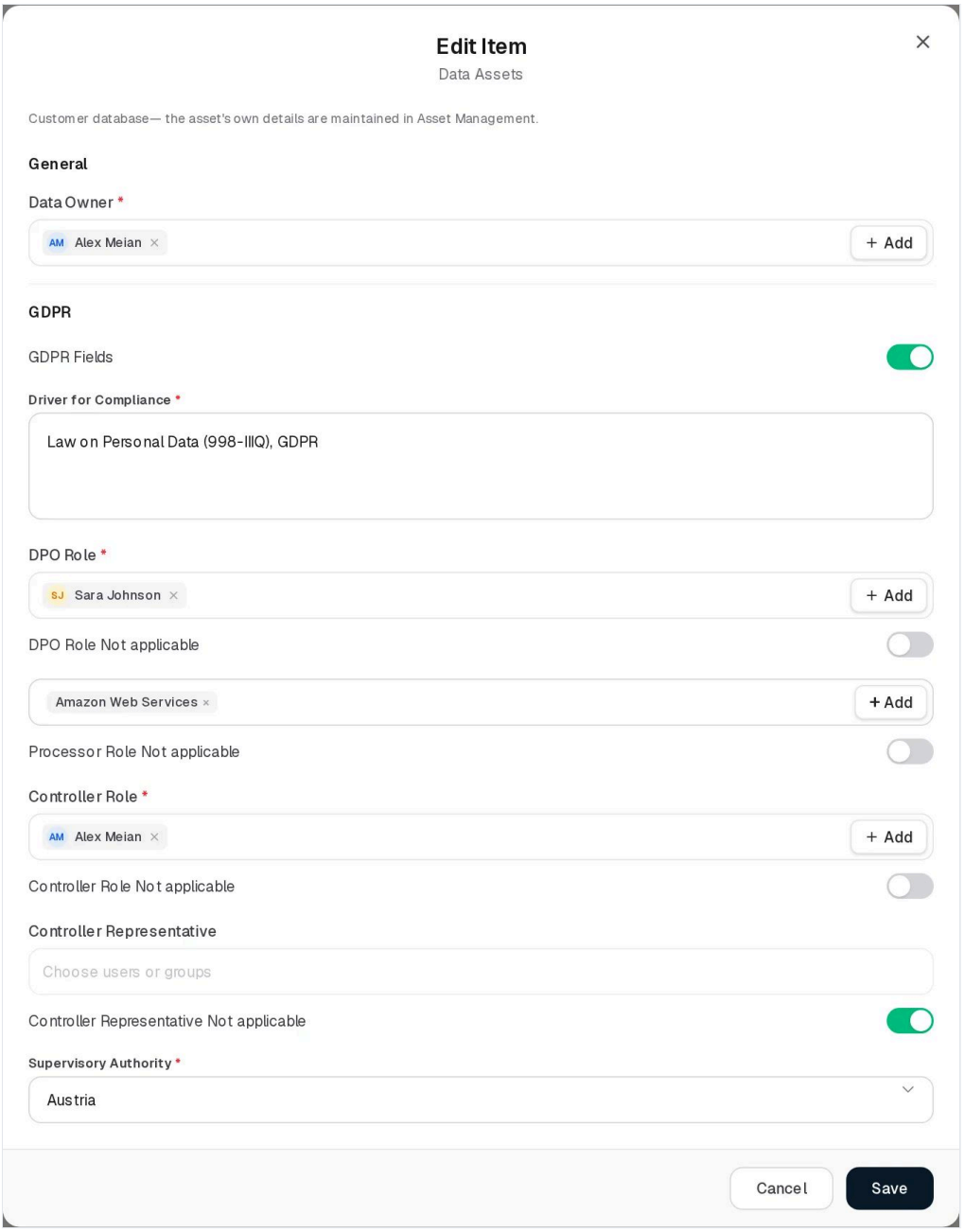
A flow's **Edit** opens the same form as Add (title **Edit Item**); its Order list excludes the flow's own position from the count of other flows. The example below is *Employee records sync*: its Related Asset **HR system (BambooHR)** is not a data asset but stays selected because the flow already points at it; **Stage** is empty, so no GDPR section is shown. Filled relation fields (Departments, Third Parties) lose their label once they hold a value.



Edit data flow

Editing the GDPR analysis of a data asset

Click **Edit** on a row. The **Edit Item** dialog (subtitle *Data Assets*) opens with the line *“ — the asset’s own details are maintained in Asset Management.”* Name, type, contacts and review date are not editable here.



Edit data asset

Field	Type	Required	Rules and allowed values	Example
General				
Data Owner	User-and-group picker, several allowed	Yes, always	*"The field is required"*. Subject to **Can Assign** / **Can Reassign** on Assets. Up to 500 characters of names.	Alex Meian
GDPR				
GDPR Fields	Switch	No	Off by default. When on, the fields below appear and become required. Its value is the grid's **Enable GDPR Analysis?** and decides whether the asset's flows are asked GDPR questions.	On

Field	Type	Required	Rules and allowed values	Example
Driver for Compliance	Text area	Yes when GDPR is on	*"The field is required"*. Up to 500 characters.	Law on Personal Data (998-IIIQ), GDPR
DPO Role	User-and-group picker, several allowed	Yes when GDPR is on, unless waived	Subject to Can Assign / Can Reassign	Sara Johnson
DPO Role Not applicable	Switch	No	Turning it on clears and disables DPO Role, and makes it optional	Off
Processor Role	Vendor picker (from **Third Parties › Vendors**), several allowed	Yes when GDPR is on, unless waived	Stored as vendor names	Amazon Web Services
Processor Role Not applicable	Switch	No	As for DPO	Off
Controller Role	User-and-group picker, several allowed	Yes when GDPR is on, unless waived	Subject to Can Assign / Can Reassign	Alex Meian
Controller Role Not applicable	Switch	No	As for DPO	Off
Controller Representative	User-and-group picker, several allowed	Yes when GDPR is on, unless waived	Subject to Can Assign / Can Reassign	Alex Meian
Controller Representative Not applicable	Switch	No	As for DPO	On
Supervisory Authority	Drop-down	Yes when GDPR is on	One of the 30 EEA countries: Austria, Belgium, Bulgaria, Croatia, Cyprus, Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Iceland, Ireland, Italy, Latvia, Liechtenstein, Lithuania, Luxembourg, Malta, Netherlands, Norway, Poland, Portugal, Romania, Slovakia, Slovenia, Spain, Sweden	Ireland

Not applicable means "answered, and the answer is none". Turning a waiver on erases the names and the stored people behind them; turning it off does not bring them back. If other people are named in a role and you lack **Can Reassign** on Assets, the waiver switch is disabled, because waiving would remove them. Switching **GDPR Fields** off hides the section and clears its error messages; the answers already saved stay stored.

Click **Save**: the asset is updated through the Assets register, so **Manage** on **Asset Management › Assets** is what the server checks.

Delete on this tab deletes the asset itself: *"Delete data asset ? This removes it from Asset Management too."* Its reviews and data flows are deleted with it.

Statuses

Value	Set by	Rule	Colour
Missing Date (data asset)	System	The asset has no Next Review Date	Amber
Expired (data asset)	System	The Next Review Date is before today	Red
Upcoming (data asset)	System	The Next Review Date is today or later	Amber

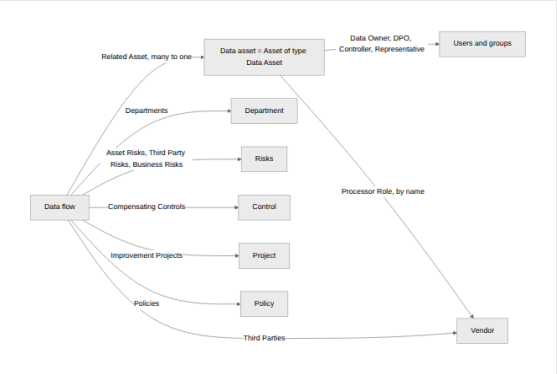
Value	Set by	Rule	Colour
Active (flow Status)	System	Every flow; there is no field to change it	Green

Tabs

Tab	Default	Grid	Add	Edit	Delete
Data Assets	Yes	Assets of type *Data Asset* with their GDPR analysis	No (create on the Assets page)	The GDPR analysis	The asset itself, with its reviews and flows
Data Asset Flows	No	Data flows of all data assets the user can see	Yes	Yes	The flow only

Both tabs belong to the page's single permission key; neither can be locked on its own.

Relationships



Related record	Direction	How the link is made	Where it shows
Asset	Flow → Asset, many to one, required	**Related Asset**	**Related Asset** column; the asset's **Data Asset Flows** count and the Data Assets tab's **Data Assets** count
People	Data asset → users and groups	Data Owner, DPO Role, Controller Role, Controller Representative	Data Assets columns; they also count as named for data visibility
Vendors	Data asset → Vendor (name only); Flow → Vendor, many to many	**Processor Role**; **Third Parties**	Data Assets and flows grids
Departments	Flow → Department, many to many	**Departments**	**Departments** column
Risks	Flow → risk, many to many	**Asset Risks**, **Third Party Risks**, **Business Risks**	Three clickable counts
Controls, Projects, Policies	Flow → record, many to many	**Compensating Controls**, **Improvement Projects**, **Policies**	Name columns

Automations and notifications

None. The data asset Dynamic Status is computed on every read. When a flow is saved, the server adds to it the vendors of its third-party risks and the third-party risks of its vendors.

Permissions

Action	Needed access
See the page and the Data Asset Flows tab	View on **Asset Management › Data Flows**
See the Data Assets tab and the Related Asset list	View on **Asset Management › Assets** as well
Add / Edit a flow	Manage on **Asset Management › Data Flows**
Delete a flow	Full Control on **Asset Management › Data Flows**
Edit a data asset's GDPR analysis	Manage on **Asset Management › Assets** (checked by the server)
Delete a data asset	Full Control on **Asset Management › Assets** (checked by the server)
Name other people as Data Owner, DPO, Controller, Representative	**Can Assign** / **Can Reassign** on **Assets**
Fill the pickers of the flow form	View on the register each picker reads (Departments, Vendors, the three risk registers, Controls, Projects, Policies & Standards)
Activity Log	The group's **Comments & Attachments** level

Flows follow their asset for data visibility: under **Assigned Records Only** you see a flow only if you can see its asset.

How to

Start the GDPR analysis of a data asset

1. On **Asset Management › Assets**, set the asset's **Type** to **Data Asset** (for example edit **HR system (BambooHR)**; **Customer database** is already one in the demo data).
2. Open **Data Flows**; on the **Data Assets** tab click **Edit** on the asset.
3. Pick the **Data Owner**, switch **GDPR Fields** on, fill **Driver for Compliance**, the four roles (or switch their **Not applicable** on) and the **Supervisory Authority**.
4. Click **Save**. **Enable GDPR Analysis?** shows **Enabled**.

Record how data leaves the EEA

1. Open the **Data Asset Flows** tab and click **Edit** on *Nightly backup to AWS S3* (Related Asset **Customer database**, whose GDPR analysis is on).
2. Set **Stage** to **Transit**. The **GDPR** section appears.
3. **Third Parties** already holds **Amazon Web Services**; picking it again after removing it would add its third-party risks automatically.
4. In **GDPR**, fill **Origin** and **Destination**, switch **Data Transfers outside the EEA?** on, choose the countries (or **Anywhere in the world**) and the **Lawful Base for Transfers outside EEA**, for example **Model Clauses**.
5. Add the compensating controls and policies, then **Save**.

Map the life cycle of one asset's data

1. Add one flow per stage for the same Related Asset: **Collected** (Order 1), **Stored** (Order 2), **Transit** (Order 3), **Deleted** (Order 4).
2. The asset's **Data Asset Flows** count on the Assets page, and the **Data Assets** count on this page, show 4.

CSV import

Not available on either tab. **Import CSV** shows *"CSV Import (Data Assets): the import structure is not ready yet."* (or *Data Asset Flows*) and opens a demonstration dialog whose validation fails.

Limitations and known issues

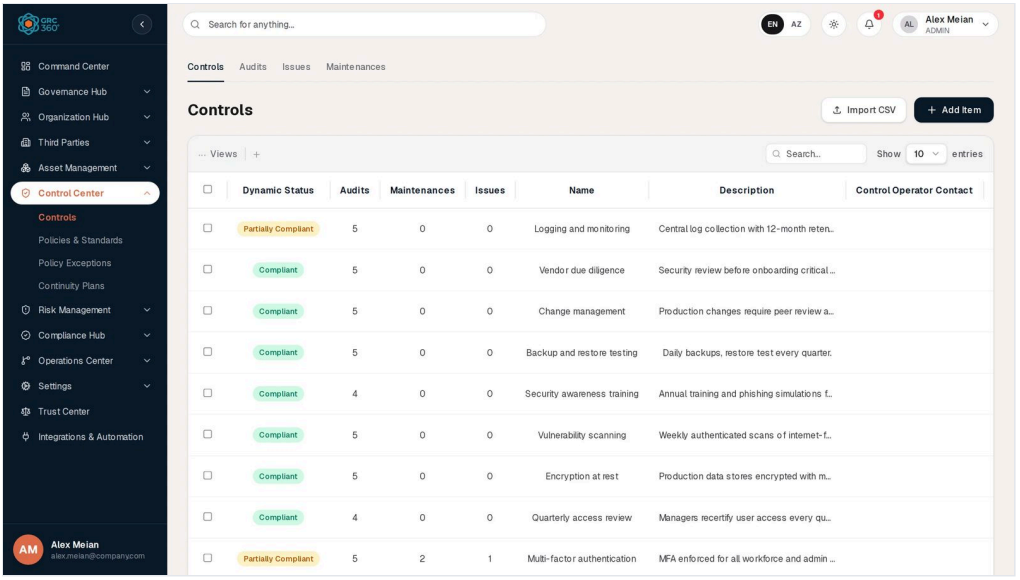
- **Two permissions behind one page.** The Data Assets tab reads and writes the Assets register, so its Edit and Delete are checked by the server against **Assets** rights, while the buttons show locks according to **Data Flows** rights. A user with Manage on Data Flows but only View on Assets sees an unlocked Edit that the server refuses, and the reverse.

- **Stage is marked required but not checked**; a flow can be saved without a stage, and then has no GDPR section.
- **Data Owner is always required**, even with GDPR switched off.
- **“Data Assets” column** on the Data Assets tab is the number of flows, not of assets.
- **Order** is not shown in the grid, is not renumbered when flows are deleted, and two flows can hold the same position.
- **Pickers stop at 200 records** for the three risk registers.
- **Flow status** is always **Active**.
- **Supervisory Authority outside the list.** A value that is not one of the 30 EEA countries (the demo’s **Customer database** holds *Ministry of Digital Development and Transport*, loaded through the API) is shown in the grid and View, but the Edit drop-down displays **Austria**, the first option, because the stored value is not among its choices. Saving without touching the field keeps the stored value; choosing a country replaces it.
- **People shown in Edit but `--` in the grid.** The demo data asset stores Data Owner, DPO Role and Controller Role as people without names, so the grid and View show `--` while Edit shows Alex Meian, Sara Johnson and Alex Meian. Re-pick them and save to store the names.
- **Labels of filled relation fields** (Processor Role on the data asset form, Departments and Third Parties on the flow form) disappear once a value is present.
- **Demo flows have no stage**, so none of them shows GDPR questions until a stage is chosen.

Control Center

> **Module key:** `control_center` · **Route:** `/control-center` (opens **Controls**)

The Control Center holds the organisation's internal controls, the policies and standards those controls implement, the approved deviations from those policies, and the business continuity plans that keep operations running when something fails. It is the "how we manage it" half of GRC360: risks in Risk Management and requirements in the Compliance Hub point at the records kept here.



Controls register

Pages

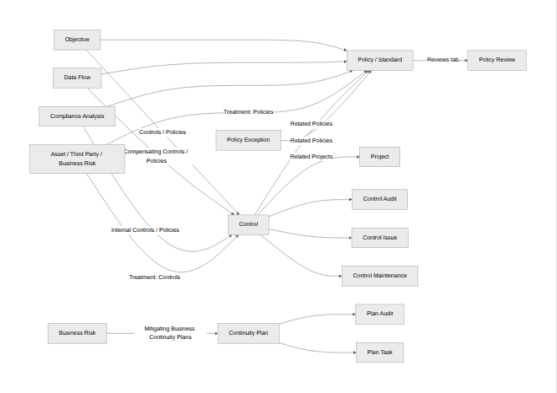
Page (sidebar label)	Route	Permission key	Tabs	What a record is
Controls	`/control-center/controls`	`control_center.controls`	Audits, Issues, Maintenances	One internal control, with its audit and maintenance plan
Policies & Standards	`/control-center/policies-standards`	`control_center.policies_standards`	Reviews	One policy, standard or procedure document
Policy Exceptions	`/control-center/exceptions`	`control_center.exceptions`	None	One time-limited deviation from one or more policies
Continuity Plans	`/control-center/continuity-recovery`	`control_center.continuity_recovery`	Audits, Tasks	One business continuity or recovery plan

Opening `/control-center` redirects to `/control-center/controls`. The keys `exceptions` and `continuity_recovery` are kept from earlier versions of the product: only the sidebar labels changed ("Policy Exceptions", "Continuity Plans"), so roles that already had those pages keep them.

Each tab is a permission unit of its own, keyed under its page: `controls_audits`, `controls_issues`, `controls_maintenances`, `policies_standards_reviews`, `continuity_recovery_audits`, `continuity_recovery_tasks`. A tab you have no access to is shown with a lock and opens the Request Access dialog. See Permissions and access.

The grid, toolbar, View dialog, pickers, Activity Log and Confirm Delete behave as described in Working with registers. The module pages only describe what is specific to them.

How the records relate



- **Controls implement policies.** A control names its **Related Policies**; the policy's **Internal Controls** column reads the same link back.
- **Policy exceptions deviate from policies.** An exception names its **Related Policies**. Nothing on the policy shows the exceptions against it.
- **Risks are treated by controls and policies.** The risk registers own those links (fields **Treatment: Controls** and **Treatment: Policies**); the Controls grid shows them as the counts **Asset Risks**, **Third Party Risks** and **Business Risks**, and the Policies grid as **Asset Risks Treatment** and **Third Party Risks Treatment**.
- **Compliance packages** are linked to controls and policies from the Compliance Hub (Compliance Analysis); both registers show the result in their **Compliance Package** column.
- **Continuity plans** are linked from Business Risks (**Mitigating Business Continuity Plans**). A control also stores a list of continuity plans, but no screen in this release lets you set it (see Controls).
- **Audits, issues, maintenances, reviews and tasks** belong to exactly one parent record. Control audits, issues and maintenances and continuity plan audits and tasks are deleted with their parent.

Audit and maintenance scheduling

Three records in this module plan their own recurring work: a control plans its **audits** and its **maintenances**, and a continuity plan plans its **audits**. Policies plan their **reviews** from a single date. The plans are entered on the parent's Add/Edit form; the system turns them into individual rows on the corresponding tab.

The schedule panel

On the Control form there is one panel titled **Audits** and one titled **Maintenances** (`SchedulePanel.tsx`). The Continuity Plan form has an equivalent **Audits** section, shown only when the plan's **Status** is **Production**.

Field	Values	Notes
Dates *	**No audits required** / **Audits required** (maintenances: **No maintenance required** / **Maintenance required**)	Default: not required. Stored as `auditsRequired` / `maintenanceRequired`. The asterisk is shown, but either choice is valid.
Occurrence type	**Specific** / **Periodical**	Shown only when required. Default **Specific**.
Dates list (Specific)	One or more date pickers	**Add new +** adds a row, **×** removes one (only when there is more than one row). Saved as a comma-separated list of ISO dates.
First date (Periodical)	Date	Where the series starts. On the Continuity form the label is **First audit date**.
Frequency (Periodical)	**Weekly**, **Monthly**, **Quarterly**, **Twice a Year**, **Yearly**	Placeholder **Choose one…**. Steps: 1 week, 1 month, 3 months, 6 months, 1 year.

Inside the panel, after the schedule, come the fields copied onto every generated row:

Parent	Fields in the panel
Control › Audits	**Audit Methodology**, **Audit Success Criteria**, **Audit Owners**, **Audit Evidence Owners**
Control › Maintenances	**Task Description**, **Maintenance Owners**
Continuity Plan › Audits	**Audit Owners** (the plan's **Audit Methodology** and **Audit Success Metric Criteria** are ordinary plan fields above the panel)

When the plan is switched off, the frontend sends the schedule fields empty, so no stale date can generate a row.

Which rows the system creates

Every time the parent is saved (create or edit), the backend recalculates the plan (`InternalControlScheduleService` , `ContinuityPlanAuditScheduleService` , `PolicyReviewScheduleService`). There is no background job: nothing is generated until somebody saves the parent.

Occurrence	Dates generated
Specific	Each picked date **and the same day one year later**.
Periodical	The first date, then one step of the frequency at a time, up to and including the first date plus one year. Weekly gives 53 dates, Monthly 13, Quarterly 5, Twice a Year 3, Yearly 2.
Policy **Next Review Date**	The date and the same day one year later.

Then, for all three:

1. Dates before today are dropped.
2. A date that already has a row (any row with that **Planned Start** / **Planned Date**, generated or added by hand) is not created again.
3. Each new row is marked as auto-generated and gets its planned date plus the copied fields:
    - control audit: methodology, success criteria, audit owner and evidence owner names from the control;
    - control maintenance: task description and maintenance owner names;
    - continuity plan audit: the plan's **Audit Owners** only. **Audit Metric** and **Audit Success Metric Criteria** are deliberately left empty for the auditor;
    - policy review: the policy's **Policy Reviewer Contact** names, **Version**, and document link/text.
4. A row is withdrawn only if it is auto-generated, its date is no longer in the plan, **and** nothing has been recorded on it: for audits and maintenances an empty **Audit Result** / **Task Result**; for policy reviews an empty **Actual Date**. Rows added by hand from the tabs are never withdrawn.
5. For continuity plans, the schedule applies only while the plan's status is Production. Moving a plan back to **Design** withdraws its blank generated audits.

Example from the demo data: **Multi-factor authentication** has **Audits required**, **Periodical**, first date 2026-10-15, **Quarterly**. Saving it produced audits planned for 2026-10-15, 2027-01-15, 2027-04-15, 2027-07-15 and 2027-10-15, shown on the Audits tab.

What the generated rows mean for status

Generated rows start with status **Planned** (audits) or **Pending** (maintenances). Their Dynamic Status turns **Overdue** the day after the planned date if nobody has completed them, which in turn makes the parent control **Partially Compliant** or the continuity plan **Audit Overdue**. The exact rules are on the Controls and Continuity Plans pages.

Shared settings: result and document type lists

Four drop-down lists in this module are maintained by users rather than fixed in the product. Each is edited from a **Settings** button on a grid (`CatalogOptionsModal.tsx`):

List	Where it is edited	Where it is used	Default entries
Audit Results	Controls › Audits › **Settings**	**Audit Result** on control audits	Failed, Passed

List	Where it is edited	Where it is used	Default entries
Maintenance Results	Controls › Maintenances › **Settings**	**Task Result** on control maintenances	Failed, Passed
Policy Document Types	Policies & Standards › **Settings**	**Document Type** on policies	Policy, Procedure, Standard
Continuity audit results	No Settings button in this release	Not used: the continuity audit form offers a fixed Passed / Failed list	Failed, Passed

The defaults are created per organisation the first time the list is read. The dialog is described on the Controls page.

Evidence and document files

Files can be attached to control audits, control maintenances, continuity plan audits, policies (the document itself) and policy reviews. They are uploaded to the system's object storage (MinIO or another S3-compatible store; the database keeps only the name, size, type, checksum and storage key). One file can be at most 25 MB. Details are on the Controls page.

Automations in this module

What	When	Effect
Dynamic Status of every record	Every time a record is read	Computed from dates, results and status; never stored. Date-based values (Overdue, Needs Review, Expired) appear on their own on the day.
Audit / maintenance / review generation	When the parent record is saved	See above.
Policy **Reviews** count	On every save of a policy or a review	Recounted by the server.
Exception **Start Date** / **Closure Date**	On save of a policy exception	Start Date stamped on creation; Closure Date stamped when the status becomes Closed, cleared when reopened.
Continuity task notification	When a task's **Awareness Role** names a new person or group	In-app notification of type `TASK_ASSIGNED` (see Continuity Plans). This is the only notification the module sends.

No scheduled job touches Control Center records. There are no reminders for upcoming audits, overdue issues, policy reviews or expiring exceptions in this release.

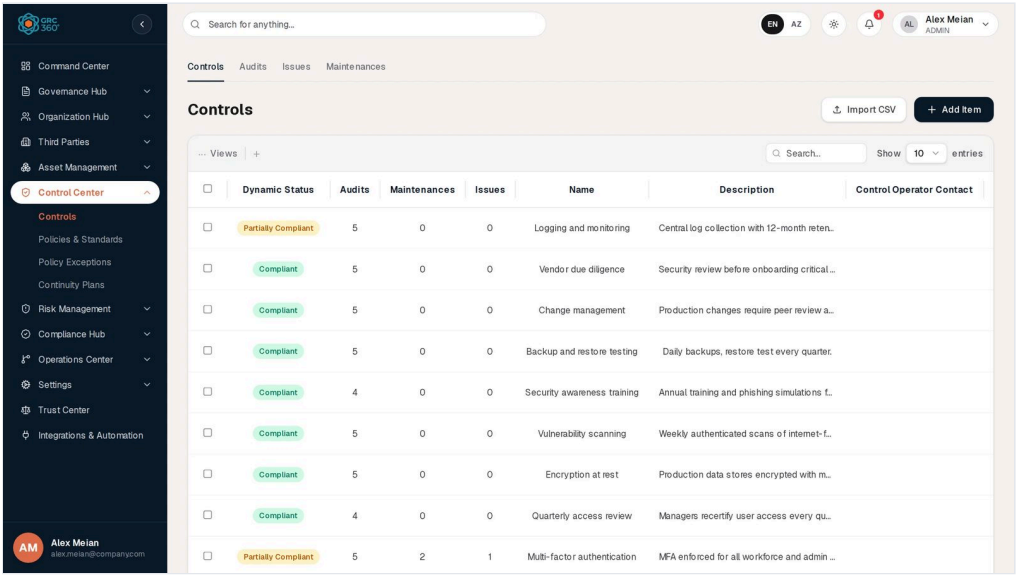
Import and export

Every grid in the module shows **Import CSV**. Clicking it shows the message "CSV Import (*grid title*): the import structure is not ready yet." and then opens a demonstration dialog whose validation fails. The backend has import endpoints for controls, policies and continuity plans, but no screen uses them. There is no Export CSV button on these pages. See CSV import and export.

Controls

> **Module:** Control Center › Controls · **Route:** `/control-center/controls` · **Permission key:** `control_center.controls`

The Controls register is the catalogue of the organisation's internal controls: the safeguards that treat risks and implement policies, such as "Multi-factor authentication" or "Quarterly access review". A record describes one control, who owns and operates it, the policies and projects it relates to, and how often it must be audited and maintained. The page has three further tabs where the individual audits, issues and maintenances of every control are recorded. Control owners, GRC staff and internal auditors work here.



Controls register

At a glance

A record is	One internal control, with its audit plan and maintenance plan
Typical owner	GRC Contact (GRC side) and Control Operator Contact (runs it day to day)
Links to	Policies & Standards (Related Policies), Projects (Related Projects)
Linked from	Asset Risks, Third Party Risks, Business Risks (Treatment: Controls), Compliance Analysis (Internal Controls), Data Flows (Compensating Controls), Objectives (Controls), Projects (Internal Controls column)
Tabs	Audits, Issues, Maintenances
Automations	Computed Dynamic Status on controls, audits, issues and maintenances; audits and maintenances generated from the control's plan on save

The register (list view)

The **Controls** tab is a server-paged grid, newest first. The toolbar, search, **… Views**, paging and selection are described in Working with registers.

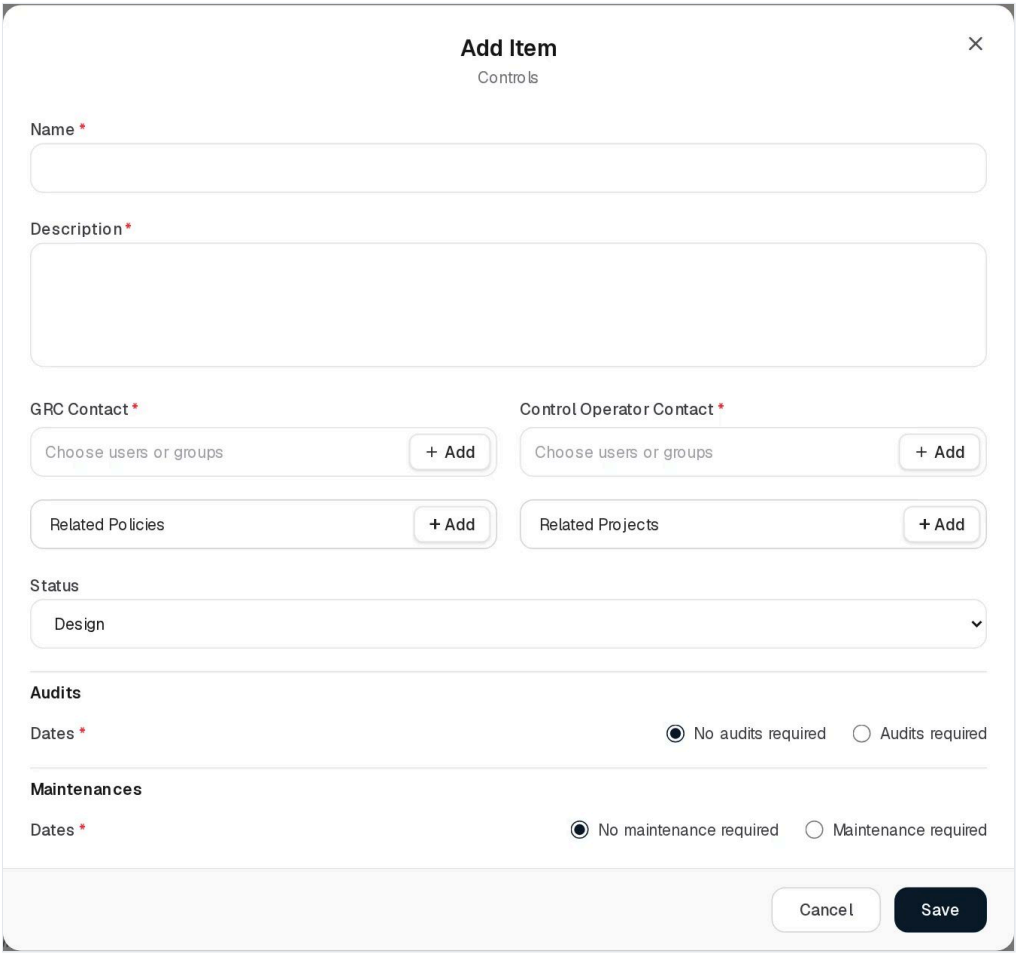
Column	What it shows	Source
Dynamic Status	**Compliant**, **Partially Compliant** or **Not Compliant** (rules under Statuses)	Computed by the system
Audits	Number of audits recorded against the control (generated and manual)	Computed
Maintenances	Number of maintenances	Computed

Column	What it shows	Source
Issues	Number of issues	Computed
Name	Control name	Entered
Description	What the control does	Entered
Control Operator Contact	Names of the operator(s), with an initial avatar	Entered
Related Policies	Names of the linked policies, comma-separated	Linked (chosen on this form)
Related Projects	Names of the linked projects	Linked (chosen on this form)
Asset Risks	Number of asset risks whose **Treatment: Controls** names this control. A non-zero count is a link: click it to open the list of those risks. Hovering shows the names.	Linked (owned by the risk)
Third Party Risks	Same, for third party risks	Linked (owned by the risk)
Business Risks	Same, for business risks	Linked (owned by the risk)
Compliance Package	Names of the compliance packages linked from Compliance Analysis	Linked (set in Compliance Hub)
Status	**Design** or **Production**	Entered

The **Audits**, **Maintenances** and **Issues** counts are plain numbers; to see the rows, open the matching tab.

Creating a record

Click **Add Item**. The form **Add Item** (subtitle **Controls**) opens in a dialog.



Add Control

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	“Name is required.” Max 255 characters. Must be unique in the organisation; otherwise the server refuses with “Internal Control with this name already exists”.	Multi-factor authentication
Description	Long text	Yes	“Description is required.”	MFA enforced for all workforce and admin accounts.
GRC Contact	Users or groups, several allowed, **+ Add**	Yes	“GRC Contact is required.” Who owns the control on the GRC side.	Sara Johnson
Control Operator Contact	Users or groups, several allowed, **+ Add**	Yes	“Control Operator Contact is required.” Who operates the control day to day.	Alex Meian
Related Policies	Picker of Policies & Standards records, **+ Add** creates a policy	No	Empty hint “No policies defined yet.”	Incident Response Plan, Vendor Management Policy
Related Projects	Picker of Operations Center projects, **+ Add**	No	Empty hint “No projects defined yet.”	None in demo data
Status	Drop-down	No	**Design** (default), **Production**. Only a Production control is meant to be linked to risks and requirements; the product does not enforce this.	Production
Audits panel	Schedule	Shown (Dates *)	**No audits required** (default) / **Audits required**. When required: **Occurrence type Specific** (date list, **Add new +**) or **Periodical** (**First date**, **Frequency**: Weekly, Monthly, Quarterly, Twice a Year, Yearly).	Audits required, Periodical, 2026-10-15, Quarterly
Audit Methodology	Long text (inside the Audits panel)	No	Copied onto each generated audit.	Sample 25 admin accounts and verify MFA enrolment
Audit Success Criteria	Long text (Audits panel)	No	Copied onto each generated audit.	100% of admin accounts enrolled
Audit Owners	Users or groups (Audits panel)	No	Names copied onto each generated audit as **Audit Owner**.	
Audit Evidence Owners	Users or groups (Audits panel)	No	Names copied as **Audit Evidence Owner**.	
Maintenances panel	Schedule	Shown (Dates *)	**No maintenance required** (default) / **Maintenance required**, then the same occurrence fields.	No maintenance required
Task Description	Long text (Maintenances panel)	No	Copied onto each generated maintenance.	
Maintenance Owners	Users or groups (Maintenances panel)	No	Names copied onto each generated maintenance.	

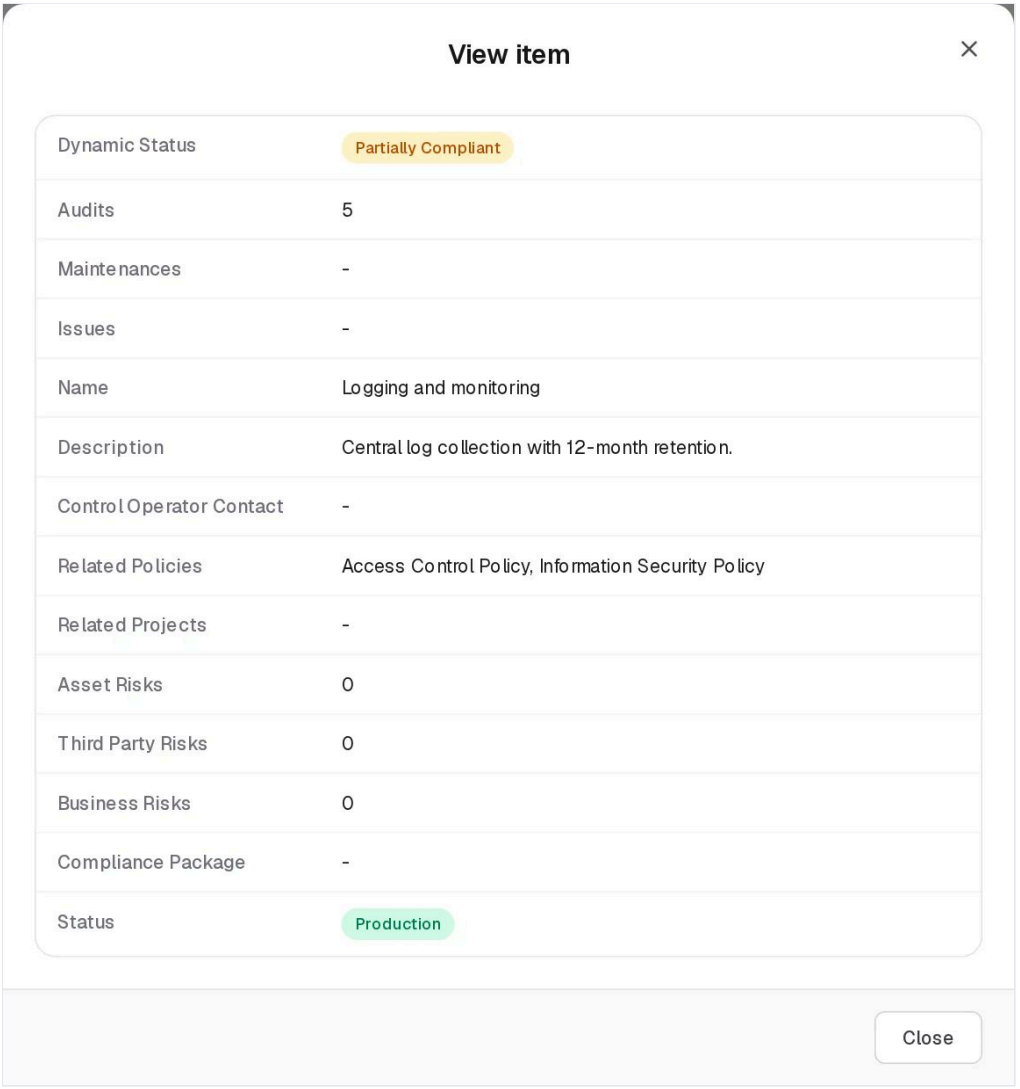
The panel fields appear only when the corresponding “required” option is selected. How the plan becomes rows on the Audits and Maintenances tabs is explained in the module overview: Audit and maintenance scheduling. In short, a **Specific** date produces that date and the same day a year later; a **Periodical** plan produces dates from the first date up to one year after it; past dates are skipped and nothing already recorded is removed.

On save the message “Control added.” (or “Control updated.”) appears. A failed save is shown in a red banner above the tabs.

The people fields are subject to **Can Assign** and **Can Reassign** on Controls: without them you can only add or remove yourself. See Assigning people.

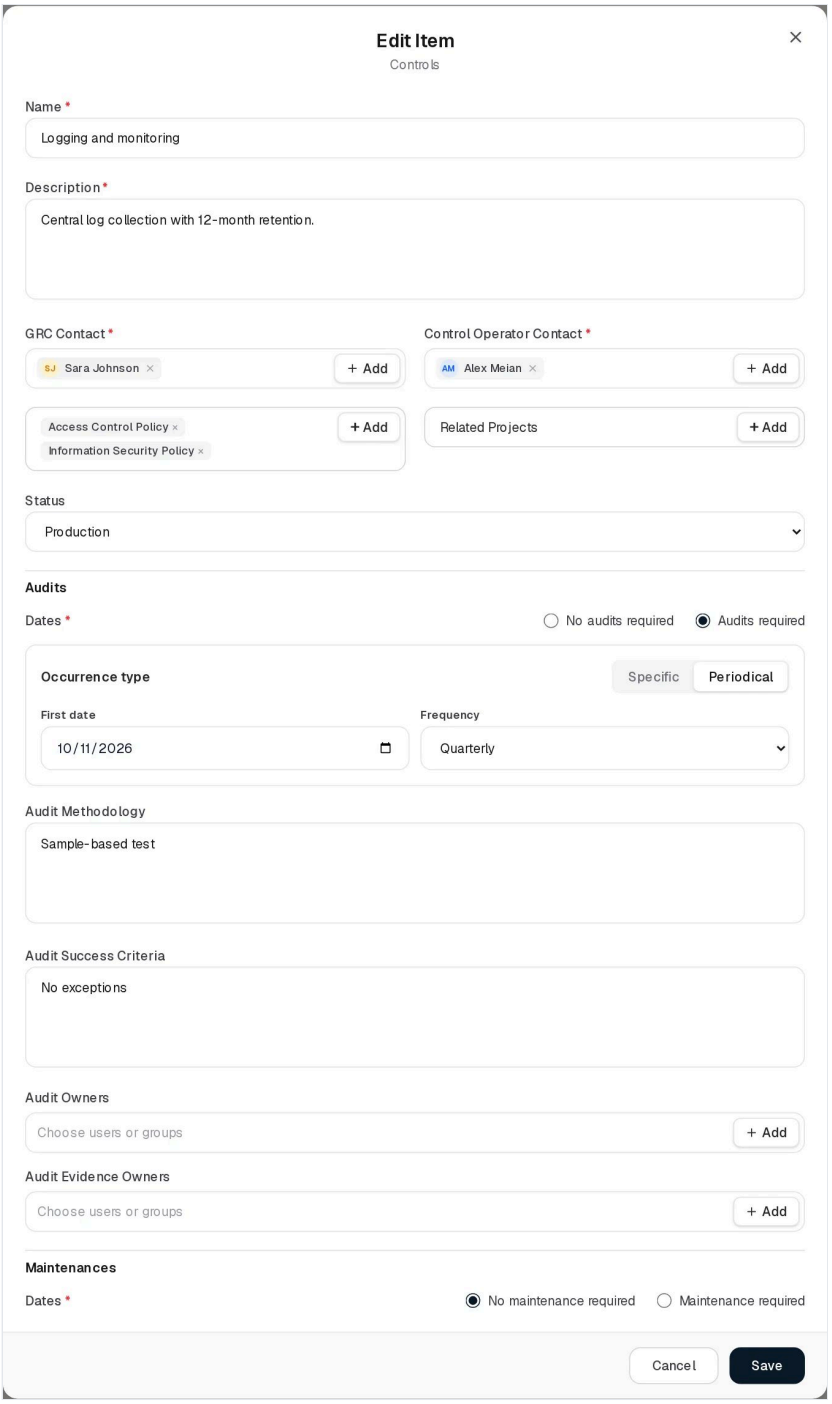
Viewing and editing a record

The eye button opens **View item**, which lists every grid column for the record. Counts of zero for Maintenances and Issues are shown as “-”.



View Control

Edit opens the same form as **Add**, titled **Edit Item**, with the plan as stored. Changing the plan and saving recalculates the generated audits and maintenances immediately.



Edit Control

Deleting a control also deletes all its audits, issues and maintenances, and removes it from projects, incidents and objectives that link to it.

Statuses

Status (chosen on the form)

Value	Set by	Meaning
Design	User	The control is being designed. Default for a new control. Shown amber.
Production	User	The control is live. Shown green.

Dynamic Status of a control (computed on every read from its audits, issues and maintenances; checked in this order)

Value	Colour	Rule
Not Compliant	Red	Any of its audits has Dynamic Status **Fail**, or any of its issues has Dynamic Status **Overdue**.
Partially Compliant	Amber	Otherwise, if the control's Status is **Design**, or any issue is **Open**, or any audit is **Overdue**, or any maintenance is **Overdue**.
Compliant	Green	Everything else: Production, with nothing outstanding.

In the demo data, **Logging and monitoring** is Partially Compliant because its audit planned for 2026-10-11 is overdue, and **Multi-factor authentication** because of its open issue.

Audit (Audits tab)

Field	Values
Status (stored)	Planned (default), In Progress, Completed. The audit form does not offer it: a new audit is Planned and an edit keeps the stored value.
Dynamic Status	If Status is Completed: **Fail** when **Audit Result** is exactly "fail" (any capitalisation), otherwise **Pass**. If not completed: **Overdue** when **Planned Start** is before today, or **Audit End Date** is before today; otherwise **In Progress**.

Issue (Issues tab)

Field	Values
Status	**Open** (default), **Closed**
Dynamic Status	**Closed** if Status is Closed; **Overdue** if **End Date** is before today; otherwise **Open**.

Maintenance (Maintenances tab)

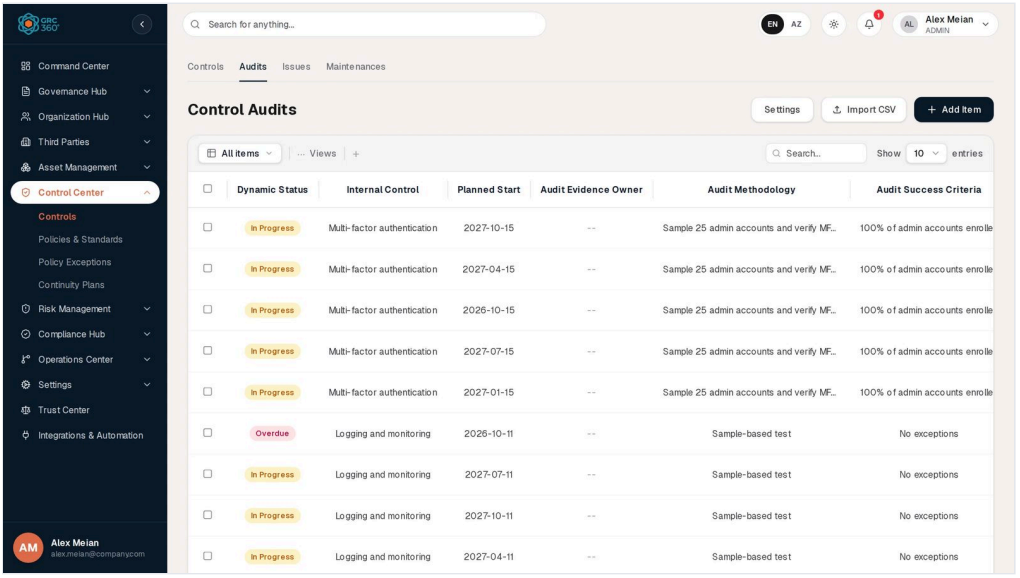
Field	Values
Status (stored)	Pending (default), In Progress, Completed. Not on the form.
Dynamic Status	**Completed** if Status is Completed; **Overdue** if **Planned Start** or **Maintenance End Date** is before today; otherwise **Active**.

Badge colours: green for Compliant, Pass, Completed, Closed, Production; amber for Partially Compliant, In Progress, Pending, Design; red for Not Compliant, Fail, Overdue; blue for Open and Planned.

Tabs

The three tabs list the child rows of **all** controls you can see in one grid, newest first. Each row names its control in **Internal Control**. Every form on these tabs starts with a **Control** * drop-down (pre-filled with the first control, "Control is required.") and a **+ Add** button that creates a new control in place. If no control exists, the form says "Create a control first — audits are recorded against an existing control." (issues and maintenances say the same).

Audits

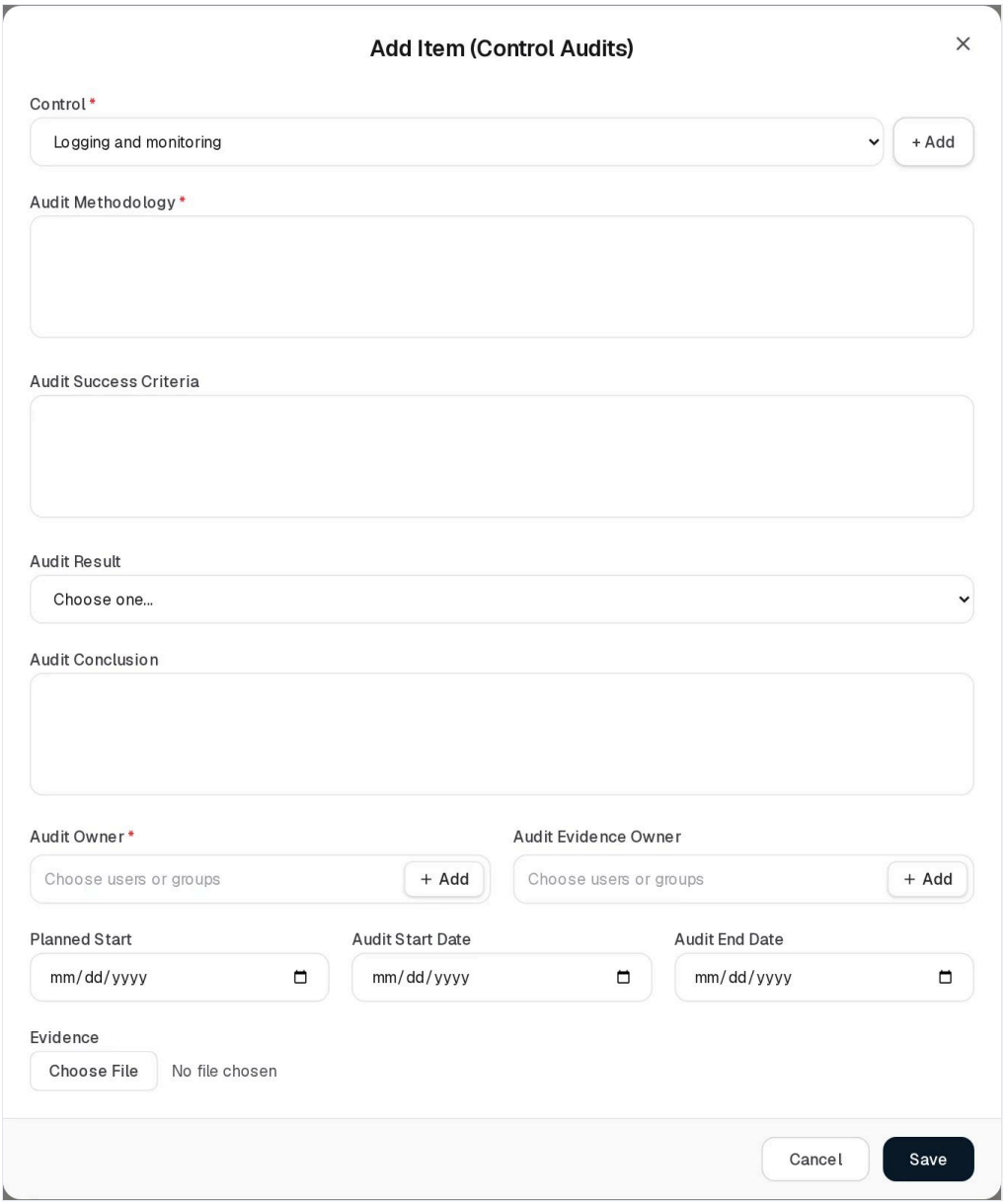


Control Audits

Grid **Control Audits**, with a **Settings** button for the Audit Results list.

Column	Meaning
Dynamic Status	See Statuses
Internal Control	The control the audit belongs to
Planned Start	Planned date (generated audits carry the plan date)
Audit Evidence Owner	Who supplies the evidence
Audit Methodology	How the audit is carried out
Audit Success Criteria	What counts as a pass
Start Date / End Date	When the audit actually ran
Audit Result	Value from the Audit Results list
Audit Conclusion	Free text
Evidence	Attached file names, each a download link, or “No evidence”
Audit Owner	Who carries out the audit
Status	Planned / In Progress / Completed

Add Item opens **Add Item (Control Audits)**:

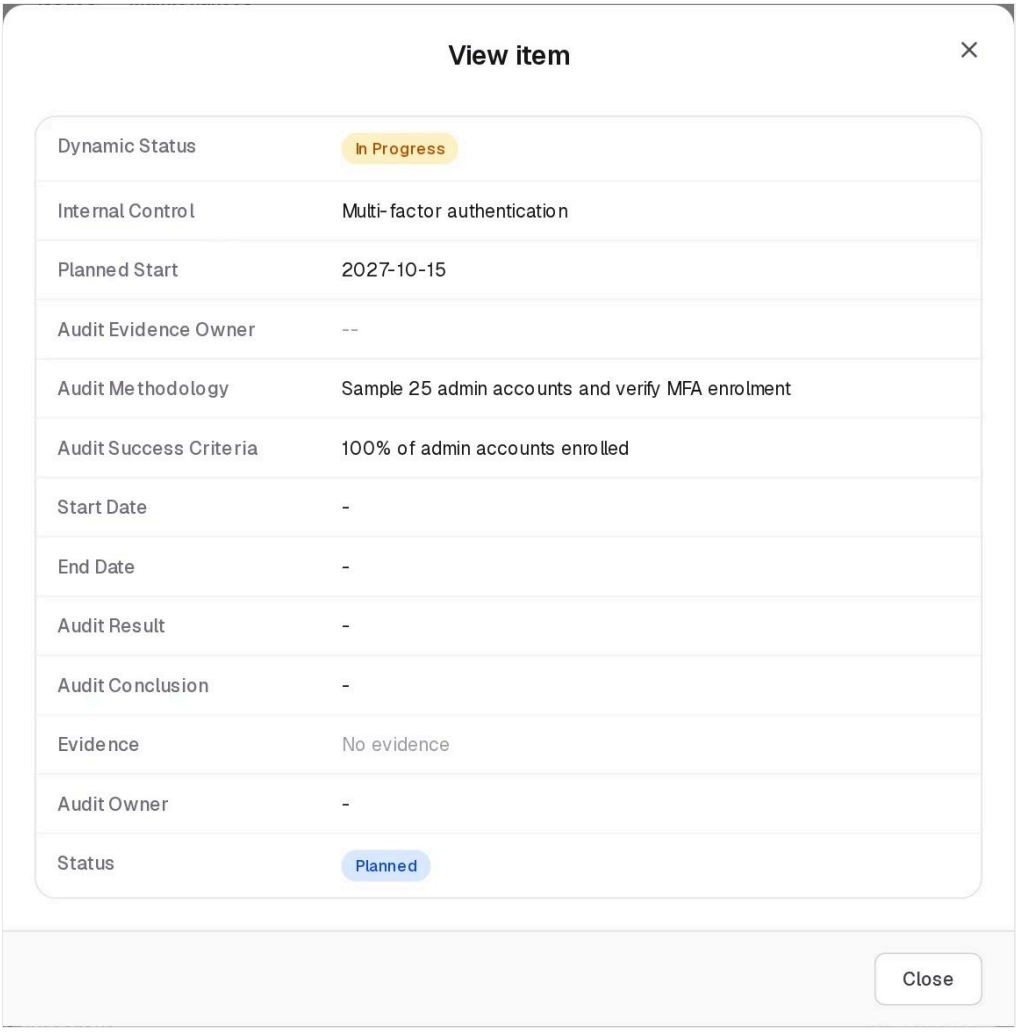


Add Control Audit

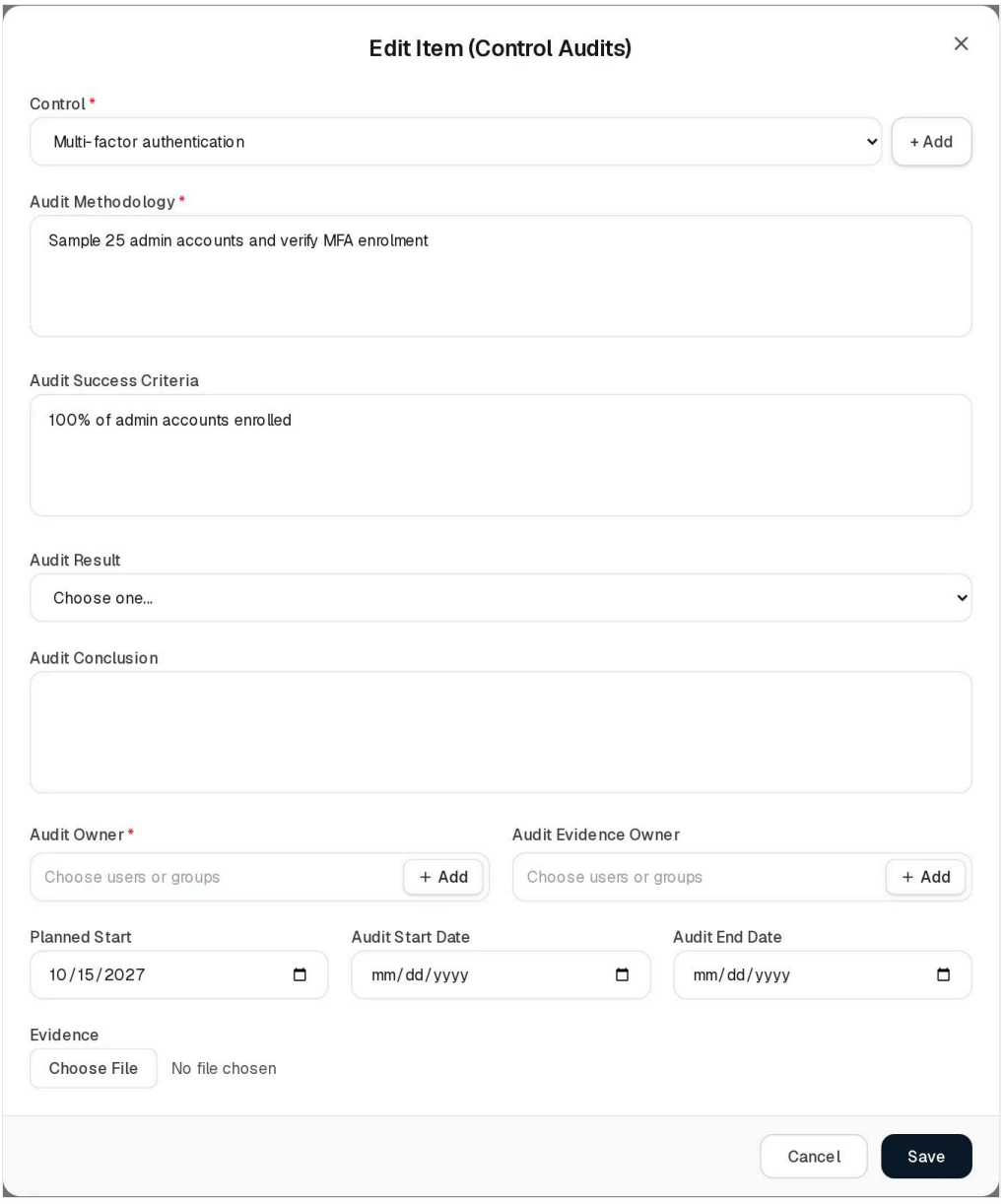
Field	Type	Required	Rules and allowed values	Example
Control	Drop-down + **+ Add**	Yes	“Control is required.”	Multi-factor authentication
Audit Methodology	Long text	Yes	“Required.”	Sample 25 admin accounts and verify MFA enrolment
Audit Success Criteria	Long text	No		100% of admin accounts enrolled
Audit Result	Drop-down	No	Placeholder **Choose one…**; values from the Audit Results list (default Failed, Passed)	
Audit Conclusion	Long text	No		
Audit Owner	Users or groups	Yes	“Required.”	
Audit Evidence Owner	Users or groups	No		
Planned Start	Date	No		2026-10-15
Audit Start Date	Date	No		
Audit End Date	Date	No		

Field	Type	Required	Rules and allowed values	Example
Evidence	File upload	No	One file per pick, any type, max 25 MB. See Evidence.	

The **View item** dialog lists the grid columns; **Edit Item (Control Audits)** is the same form filled in.



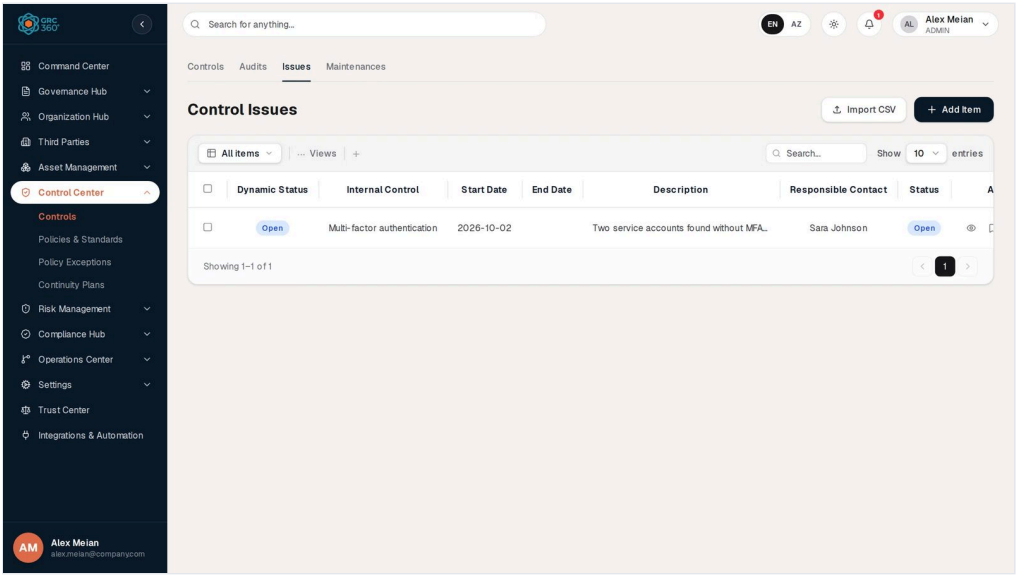
View Control Audit



Edit Control Audit

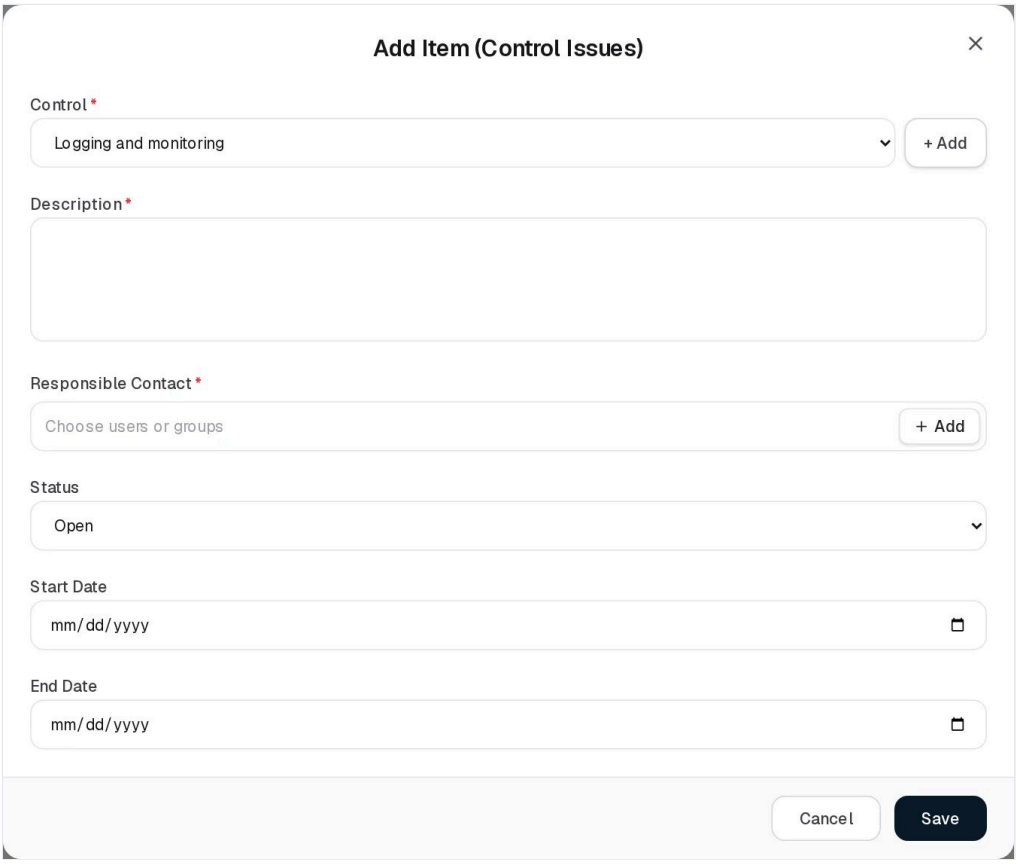
Generated audits have no **Audit Owner** unless the control's plan named one, so the first edit of such an audit asks for it.

Issues



Control Issues

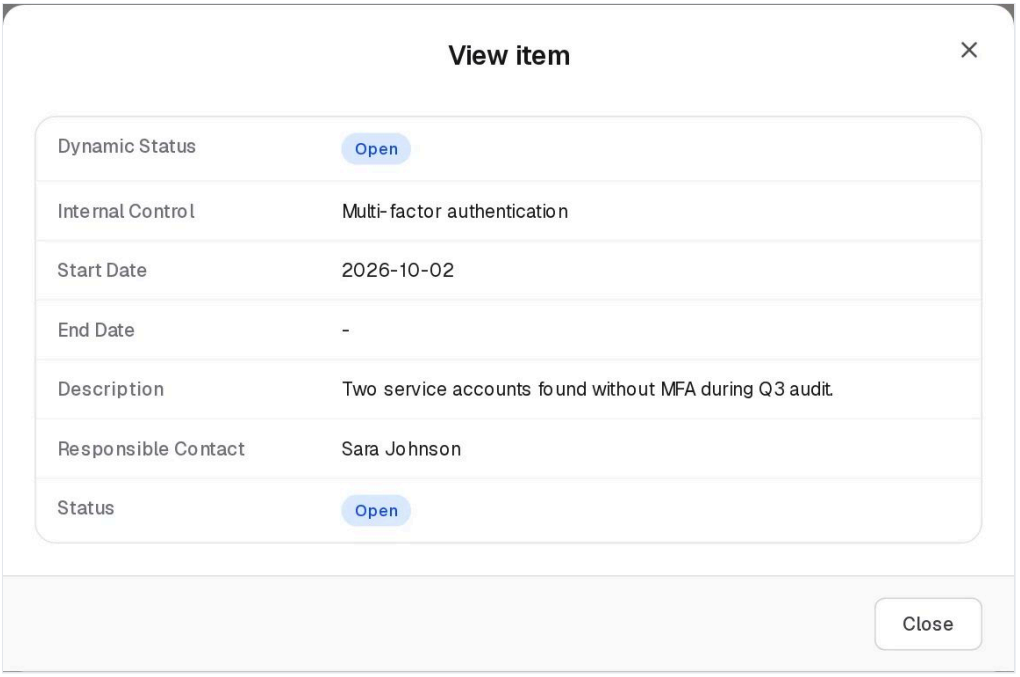
Grid **Control Issues**: **Dynamic Status**, **Internal Control**, **Start Date**, **End Date**, **Description**, **Responsible Contact**, **Status**.



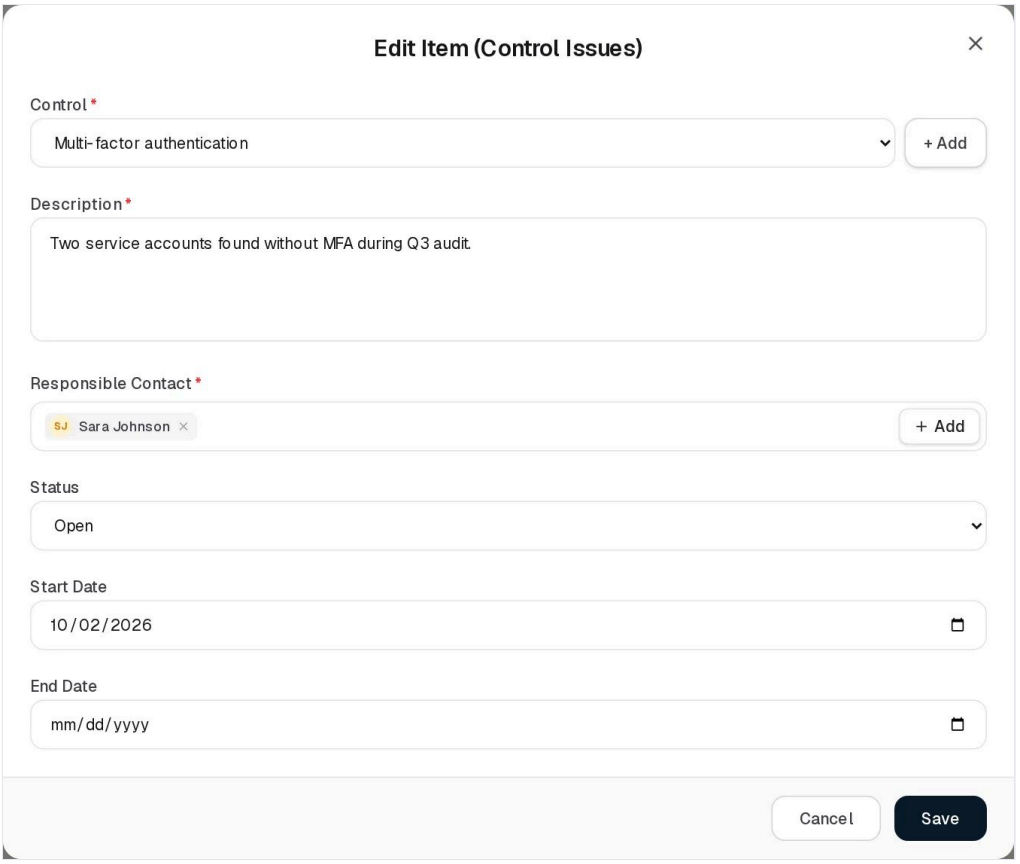
Add Control Issue

Field	Type	Required	Rules and allowed values	Example
Control	Drop-down + **+ Add**	Yes	“Control is required.”	Multi-factor authentication
Description	Long text	Yes	“Required.”	Two service accounts found without MFA during Q3 audit.

Field	Type	Required	Rules and allowed values	Example
Responsible Contact	Users or groups	Yes	“Responsible Contact is required.” Who must close the issue.	Sara Johnson
Status	Drop-down	No	**Open** (default), **Closed**	Open
Start Date	Date	No		2026-10-02
End Date	Date	No	The date the issue should be closed by; once passed while Open, the issue is Overdue and the control becomes Not Compliant.	



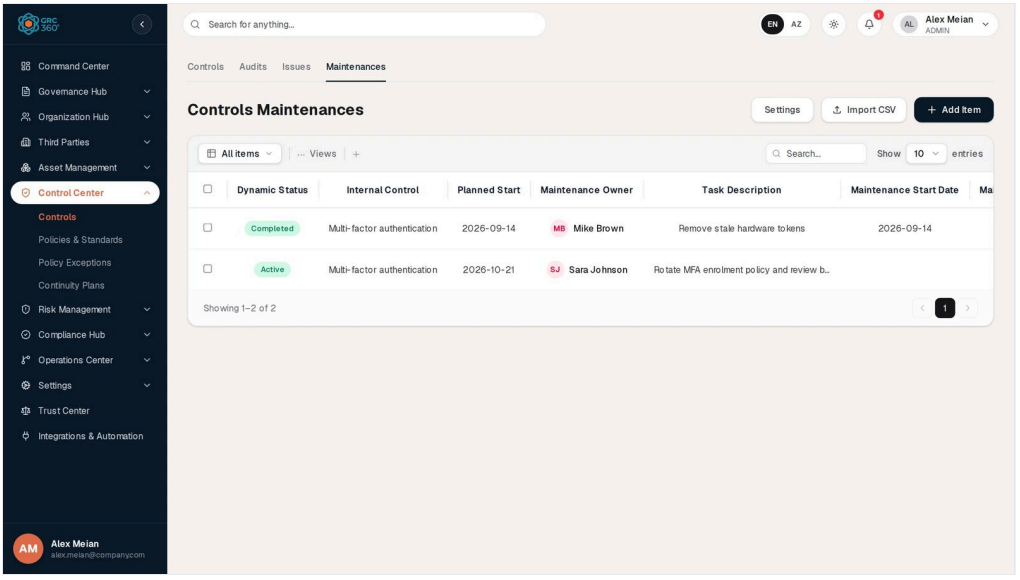
View Control Issue



Edit Control Issue

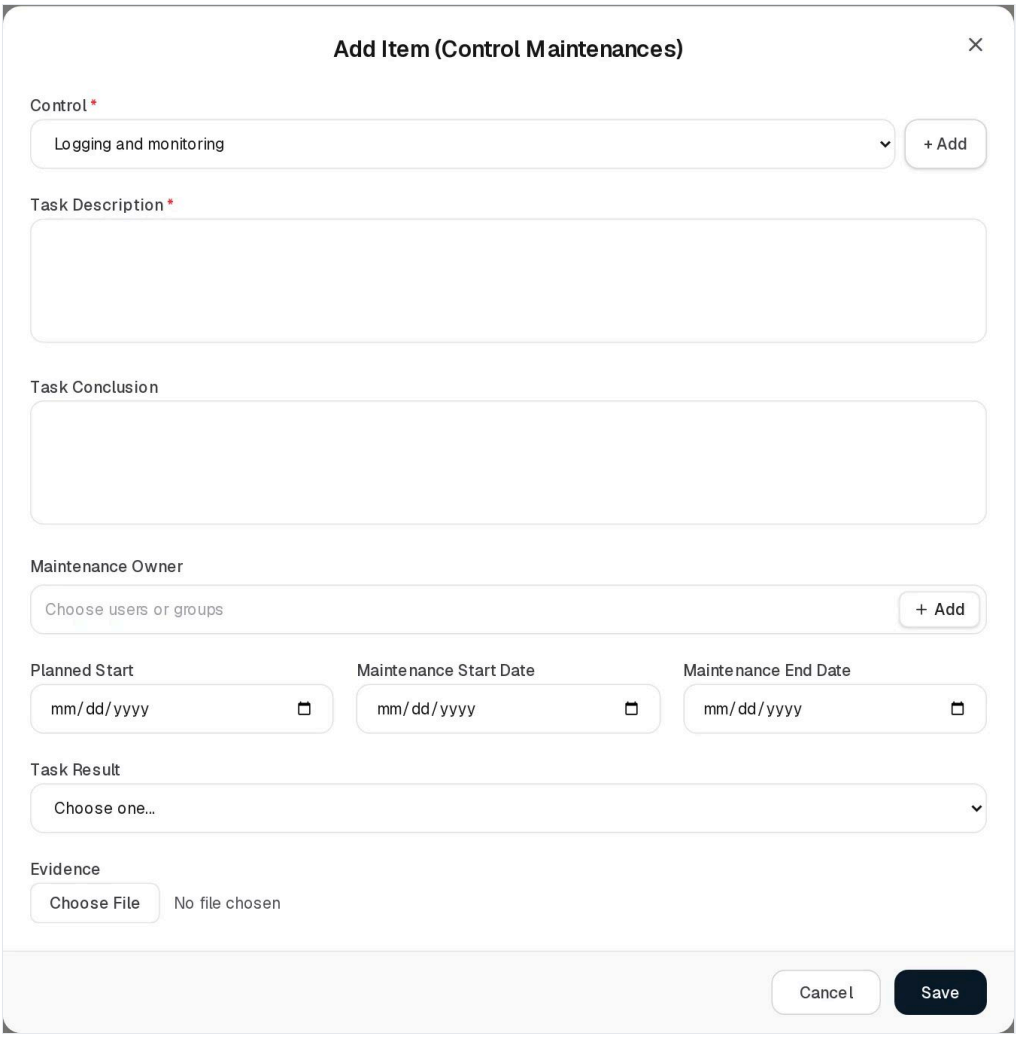
Issues are saved by sending the whole control back to the server (there is no separate issue save on this page), so adding, editing or deleting an issue also re-runs the control's audit and maintenance plan.

Maintenances



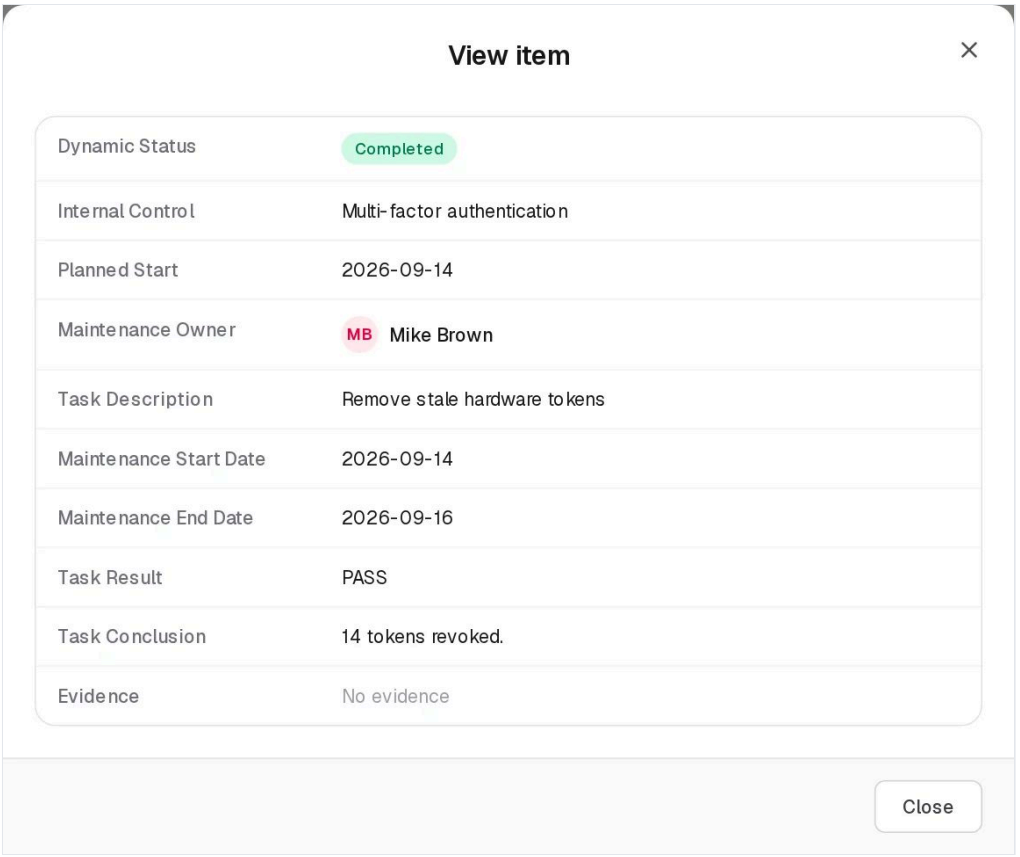
Controls Maintenances

Grid **Controls Maintenances**, with a **Settings** button for the Maintenance Results list. Columns: **Dynamic Status**, **Internal Control**, **Planned Start**, **Maintenance Owner**, **Task Description**, **Maintenance Start Date**, **Maintenance End Date**, **Task Result**, **Task Conclusion**, **Evidence**. The stored Status is not shown as a column.

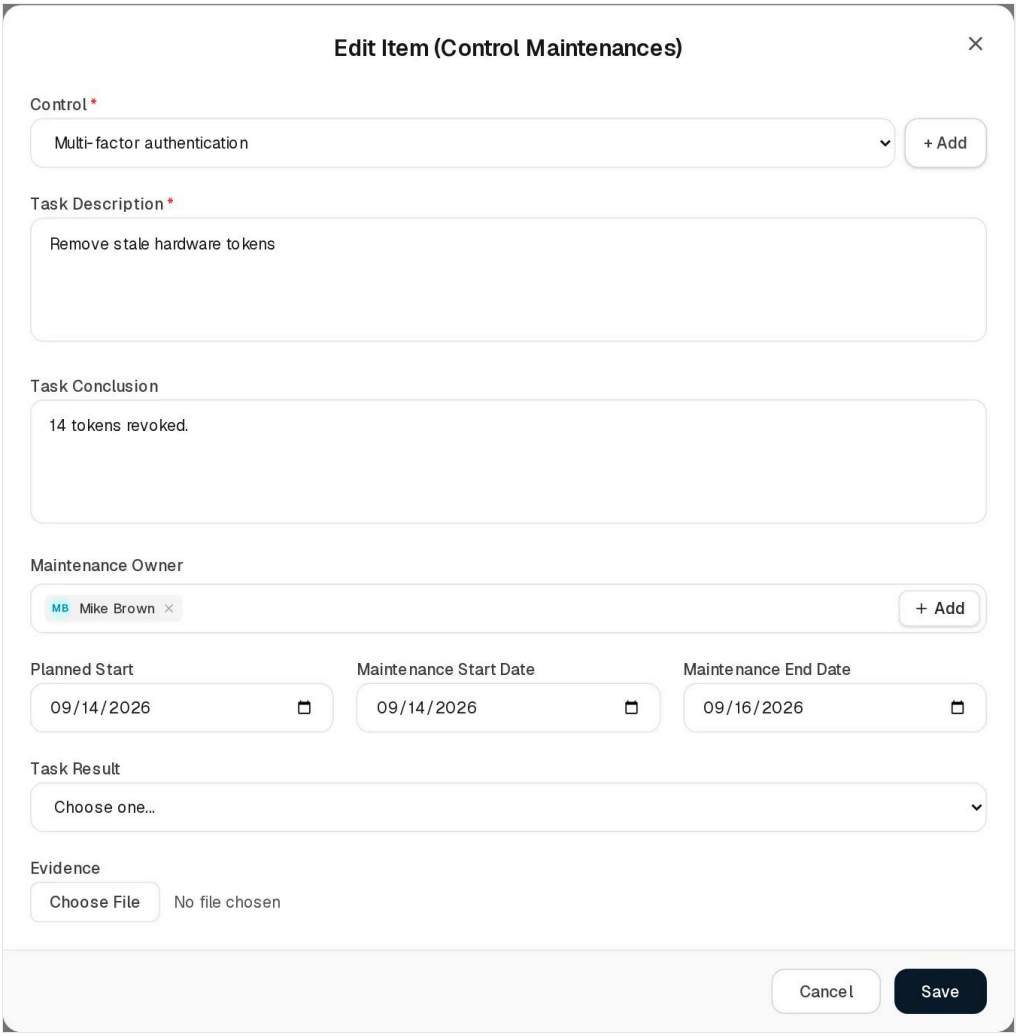


Add Control Maintenance

Field	Type	Required	Rules and allowed values	Example
Control	Drop-down + **+ Add**	Yes	“Control is required.”	Multi-factor authentication
Task Description	Long text	Yes	“Required.”	Rotate MFA enrolment policy and review bypass codes
Task Conclusion	Long text	No		14 tokens revoked.
Maintenance Owner	Users or groups	No		Sara Johnson
Planned Start	Date	No		2026-10-21
Maintenance Start Date	Date	No		
Maintenance End Date	Date	No		
Task Result	Drop-down	No	**Choose one…**; values from the Maintenance Results list	
Evidence	File upload	No	As for audits	



View Control Maintenance



Edit Control Maintenance

Catalog settings (Audit Results and Maintenance Results)

The **Settings** button on the Audits and Maintenances grids opens a dialog titled **Audit Results** or **Maintenance Results**:

- A **Type to filter…** box and a table with **Title** and **Actions**. Each row has **Edit** (rename in place, then **Save** or **Cancel**) and **Delete** (asks “Delete *title*?”).
- **Add New** shows a **New entry** box with **Save** and **Cancel**. A title that already exists (ignoring capitalisation) is refused with “An entry with this title already exists”.
- **Close** closes the dialog. An empty list reads “Nothing defined yet.”
- The note under the table applies: “Removing an entry only stops it being offered — records that already carry it keep their value.”

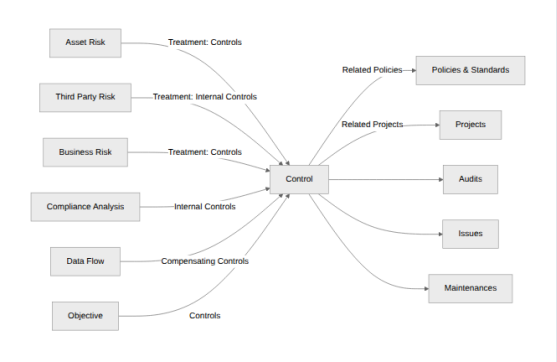
Each organisation starts with **Failed** and **Passed** in both lists, created the first time the list is opened.

Evidence

Audits and maintenances take evidence files through the **Evidence** field (`EvidenceField.tsx`):

- **Choose File** picks one file at a time. On a record that is not saved yet, the file is listed with “uploads on save” and a **Remove** link, and is uploaded right after the record is created. On a saved record the file is uploaded at once (“Working…” shows meanwhile).
- Each stored file is listed with its size; the name is a download link, **Remove** deletes it after confirmation (“Evidence deleted.”).
- The grid’s **Evidence** column lists the file names as download links; “No evidence” when there are none.
- Files go to the system’s object storage (MinIO or another S3-compatible store) under a generated key; the database keeps the file name, size, type and a SHA-256 checksum. The original file name never becomes part of the storage path.
- Limits and errors from the server: a file over 25 MB (or a request over 30 MB) is refused as too large; an empty file is refused (“Evidence file cannot be empty”); if the storage service is unreachable the upload or download fails with a storage-unavailable error; a file whose stored object has gone missing returns “not found” with a request to upload it again. There is no size check in the browser before upload.
- A file is visible and downloadable only to users who can see the control the audit or maintenance belongs to.

Relationships



Related record	Direction	How the link is made	Where it shows
Policies & Standards	Control → many policies	**Related Policies** on the control form	Controls › Related Policies; Policies › **Internal Controls** column
Projects	Control → many projects	**Related Projects** on the control form	Controls › Related Projects; Projects › **Internal Controls** column
Audits / Issues / Maintenances	One control → many	Tabs of this page, or generated from the plan	Counts on the Controls grid (not clickable); the tabs
Asset / Third Party / Business Risks	Many risks → many controls	The risk’s treatment field	Controls › risk count columns (clickable, opens the risks)

Related record	Direction	How the link is made	Where it shows
Compliance packages	Many ↔ many	Compliance Analysis (Compliance Hub)	Controls › **Compliance Package**
Data Flows	Many ↔ many	**Compensating Controls** on the data flow	Data Flows page
Objectives	Many ↔ many	**Controls** on the objective	Objectives page
Continuity plans	Control → many plans	Stored on the control but not editable on any screen	Not shown

Automations and notifications

- Dynamic Status of controls, audits, issues and maintenances is recalculated on every read. A missed planned date shows as Overdue on the next day without any job running.
- Saving a control (from the Controls tab, or indirectly when an issue is saved or an audit, issue or maintenance is deleted) regenerates the planned audits and maintenances. See Audit and maintenance scheduling.
- No notifications or reminders are sent for controls, audits, issues or maintenances.

Permissions

Access is set per page and per tab, as one level: No Access, View, Manage or Full Control. See Permissions and access.

Action	Needed access
See the page and the Controls grid	View on Control Center › Controls
Add or edit a control	Manage on Control Center › Controls
Delete a control	Full Control on Control Center › Controls
Name other people in GRC Contact, Control Operator Contact, Audit Owners, Audit Evidence Owners, Maintenance Owners	Can Assign (new names) and Can Reassign (changing names already there) on Controls
Open the Audits tab	View on Controls › Audits
Add or edit an audit's schedule fields	Manage on Controls › Audits
Record or change **Audit Result** / **Audit Conclusion**	Audit Results right on Controls › Audits (included in Manage)
Delete an audit	The button needs Full Control on Controls › Audits; the save itself is an update of the control, so Manage on Controls is also needed
Open the Issues tab	View on Controls › Issues
Add, edit or delete an issue	The buttons need Manage (add, edit) or Full Control (delete) on Controls › Issues; every issue save is an update of the control, so Manage on Controls is also needed
Open the Maintenances tab, add, edit, delete	As for Audits, on Controls › Maintenances; **Task Result** / **Task Conclusion** need the Maintenance Results right (included in Manage)
Upload evidence / delete evidence	Manage / Full Control on any Control Center page (the evidence service is checked at module level) and visibility of the control
Add, rename or delete entries in the Settings lists	Manage (add, rename) or Full Control (delete) on any Control Center page. The **Settings** button itself is never locked.
Comment and attach files in the Activity Log	The group's Comments & Attachments level

Which controls appear in the grid can be limited to records that name the user: the people counted are the Control Operator Contact, GRC Contact, Audit Owners, Audit Evidence Owners and Maintenance Owners. The Audits, Issues and Maintenances tabs show only the rows of controls you can see.

How to

Add a control with a quarterly audit plan

1. Open **Control Center › Controls** and click **Add Item**.
2. Enter **Name** “Privileged access review” and a **Description**.
3. Choose **Sara Johnson** as **GRC Contact** and **Alex Meian** as **Control Operator Contact**.
4. In **Related Policies**, pick **Access Control Policy**. Set **Status** to **Production**.
5. Under **Audits**, select **Audits required**, choose **Periodical**, set **First date** and **Frequency Quarterly**, and fill **Audit Methodology** and **Audit Success Criteria**.
6. Click **Save**. Open the **Audits** tab: five quarterly audits from the first date onward are listed for the new control (fewer if the first date is in the past).

Record the outcome of an audit with evidence

1. Open the **Audits** tab and find the **Multi-factor authentication** audit planned for 2026-10-15.
2. Click **Edit**. Fill **Audit Owner** (required), **Audit Start Date** and **Audit End Date**.
3. Choose **Audit Result Passed** and write the **Audit Conclusion**.
4. Under **Evidence**, click **Choose File** and pick the export of MFA enrolments. Click **Save**.
5. The row shows the file under **Evidence**. Note that the audit’s Status stays **Planned**, because the form has no Status field (see the known issues below).

Raise an issue against a control

1. Open the **Issues** tab and click **Add Item**.
2. Choose the **Control** (for example **Multi-factor authentication**), write the **Description**, choose the **Responsible Contact** and set an **End Date**.
3. Click **Save**. The control’s Dynamic Status becomes **Partially Compliant** while the issue is open, and **Not Compliant** once the End Date has passed.
4. When fixed, edit the issue and set **Status** to **Closed**.

Add your own audit result value

1. On the **Audits** tab click **Settings**.
2. Click **Add New**, type “Passed with observations” and click **Save**. Click **Close**.
3. The new value is offered in **Audit Result** from now on.

See which risks a control treats

1. On the **Controls** tab, find **Encryption at rest**.
2. Click the number in **Asset Risks** (14 in the demo data). A dialog lists those asset risks.

CSV import

Not available. **Import CSV** on the Controls, Audits, Issues and Maintenances grids shows “CSV Import (*title*): the import structure is not ready yet.” and then opens a demonstration dialog whose validation fails. The backend has an import endpoint for controls (`/control/internal-controls/import-csv`), but no screen uses it. See CSV import and export.

Limitations and known issues

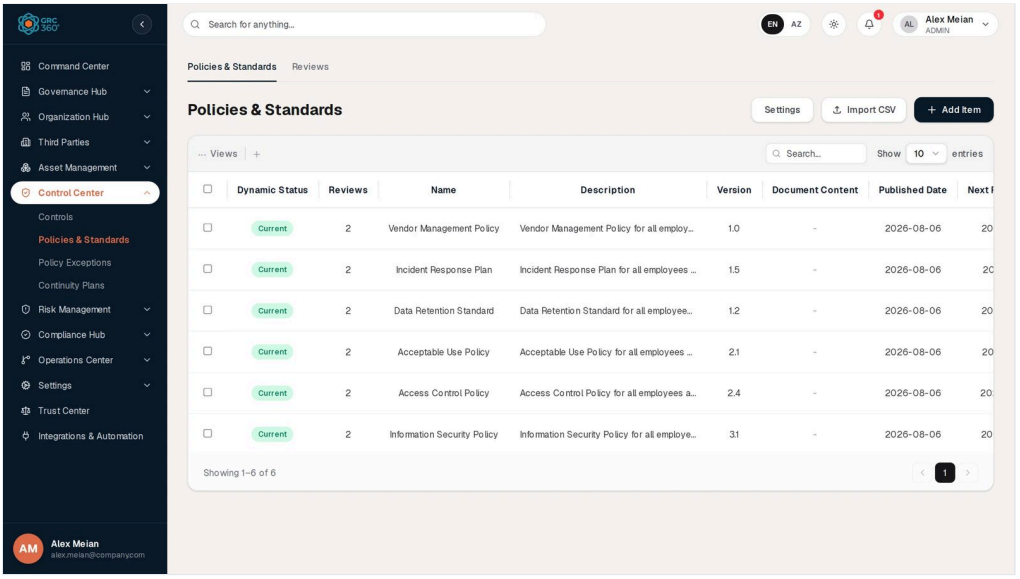
- **Audits and maintenances cannot be marked Completed from the screen.** Neither form has a Status field, so a new audit stays **Planned** and a new maintenance **Pending**. Their Dynamic Status therefore never becomes Pass, Fail or Completed through the UI: it shows **In Progress** / **Active** until the planned date passes and then **Overdue**, even after a result has been recorded. As a consequence a failed audit never makes the control **Not Compliant**, and a recorded audit still counts as overdue.
- **“Failed” is read as a pass.** Even for an audit with Status Completed, Dynamic Status is Fail only when the result is exactly “fail”. The default list entries are “Failed” and “Passed”, so “Failed” produces **Pass**. (Continuity plan audits match “fail” anywhere in the text and do not have this problem.)

- **Deleted generated rows come back.** Deleting an audit or maintenance that the plan generated, while its date is still in the plan and no result is recorded, re-creates it immediately (as a new row), because the delete is a save of the control and every save re-runs the plan. Change the plan instead.
- **Moving an audit, issue or maintenance to another control does not work.** The **Control** drop-down is editable on Edit. For audits and maintenances the server rejects the change (“Audit does not belong to the specified Internal Control” / “Maintenance does not belong to the specified Internal Control”). For an issue, the save adds a copy to the newly chosen control and leaves the original on the old one.
- **Stored values missing from the Settings list are not displayed.** If an audit or maintenance carries a result that is not in the list (for example the demo maintenance with result “PASS”), the drop-down shows **Choose one…** although the value is still stored.
- **Control Operator Contact column can be empty.** The grid shows the names stored as text. Records whose people were set only as user ids (as in the demo data) show an empty column and “-” in the view, although the Edit form shows the people.
- **Saving an issue sends every audit back.** Issues are saved as part of the whole control; the server re-validates all of the control’s audits, and an audit without **Audit Methodology** (possible for audits generated from a plan with an empty methodology) makes the save fail with “Audit methodology is required”.
- **Continuity plans and compliance packages are not editable here.** The control stores continuity plan and compliance package links, but the form offers neither; compliance packages are set from Compliance Analysis, and the continuity plan link cannot be set anywhere in this release.
- **Permission mismatch on Issues and on deletes from tabs.** The Issues tab buttons are governed by the Issues tab permission, but the server checks Edit on the Controls page, so a user with Manage on Issues but only View on Controls sees the button enabled and the save is refused.
- **No reminders.** Nothing notifies owners about upcoming or overdue audits, maintenances or issues.

Policies & Standards

> **Module:** Control Center › Policies & Standards · **Route:** `/control-center/policies-standards` · **Permission key:** `control_center.policies_standards`

The Policies & Standards register holds the organisation's governing documents: policies, standards and procedures. A record carries the document itself (written in place, linked, or attached as a file), its version, publication state and next review date, the people responsible for it, and its links to controls, risks, data flows and compliance packages. The **Reviews** tab records each review of a policy; reviews are also planned automatically from the policy's **Next Review Date**. Policy owners, GRC staff and reviewers work here.



Policies & Standards register

At a glance

A record is	One policy, standard or procedure document
Typical owner	GRC Contact; reviewed by the Policy Reviewer Contact
Links to	Projects (Related Projects); compliance packages (set from Compliance Analysis)
Linked from	Controls (Related Policies), Asset Risks and Business Risks (Treatment: Policies), Third Party Risks (Treatment: Policies), Data Flows (Policies), Policy Exceptions (Related Policies), Objectives (Policies), Compliance Analysis (Policies)
Tabs	Reviews
Automations	Computed Dynamic Status; reviews generated from Next Review Date on save; Reviews count kept by the server

The register (list view)

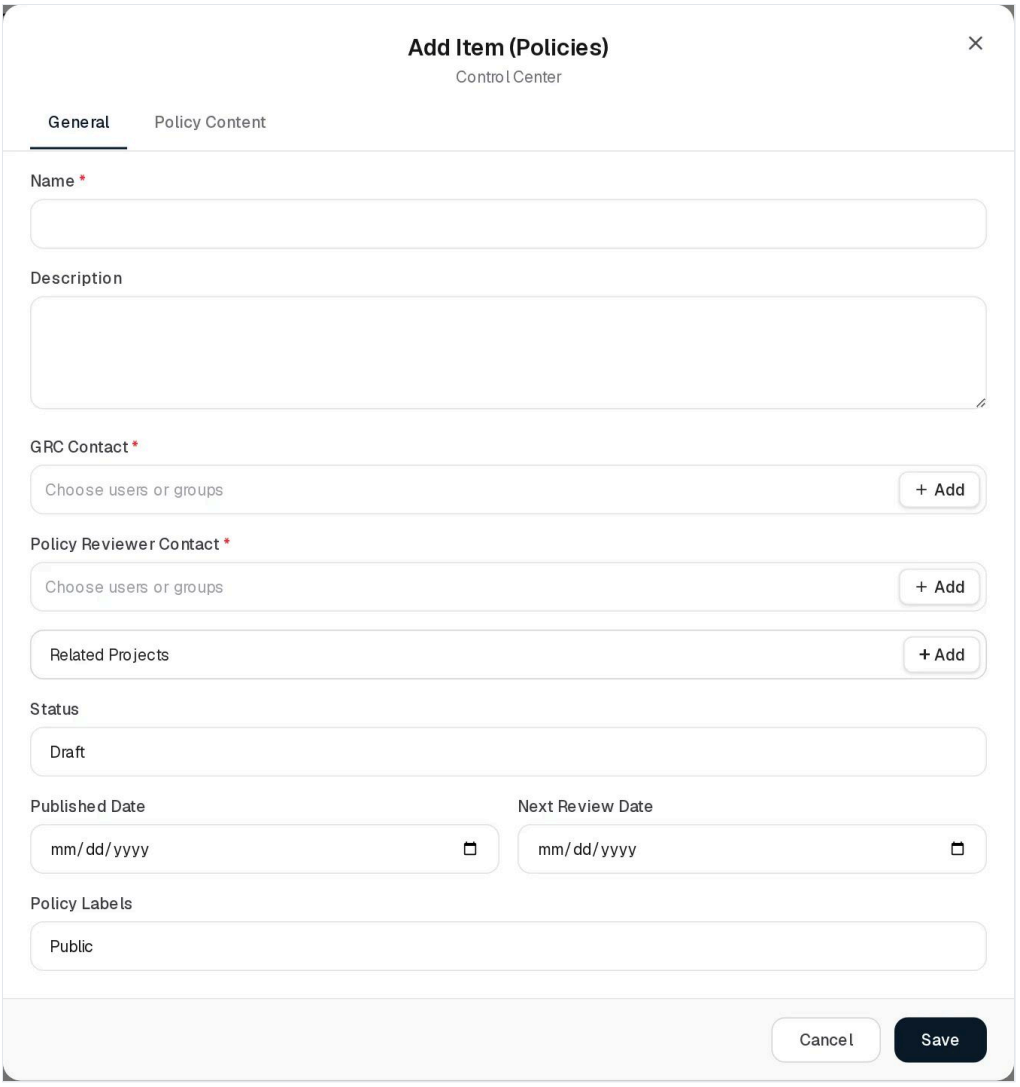
Server-paged grid, newest first, with a **Settings** button for the Document Types list. The shared grid behaviour is described in Working with registers.

Column	What it shows	Source
Dynamic Status	**Current** or **Needs Review** (see Statuses)	Computed by the system
Reviews	Number of reviews recorded for the policy (generated and manual)	Computed by the server

Column	What it shows	Source
Name	Document name	Entered
Description	Purpose and scope	Entered
Version	Version label	Entered
Document Content	The document: the written text (truncated), the link (opens in a new tab), or the attached file (download link). Shows “-” when there is none.	Entered
Published Date	Date of publication	Entered
Next Review Date	When the document is next due for review	Entered
Policy Labels	Confidential, Public or Private, as a grey chip	Entered
Document Type	Value from the Document Types list, as a coloured chip (Policy purple, Standard blue, Procedure cyan, others grey)	Entered
Compliance Package	Names of the compliance packages linked from Compliance Analysis	Linked (set in Compliance Hub)
Asset Risks Treatment	Number of asset risks naming this policy in **Treatment: Policies**. A non-zero count is clickable and opens those risks.	Linked (owned by the risk)
Third Party Risks Treatment	Same for third party risks	Linked (owned by the risk)
Data Asset Flow	Names of data flows naming this policy	Linked (owned by the data flow)
Internal Controls	Names of controls naming this policy in **Related Policies**	Linked (owned by the control)
Related Projects	Names of linked projects	Linked (chosen on this form)
Status	**Draft** or **Published**	Entered

Creating a record

Click **Add Item**. The dialog **Add Item (Policies)** (subtitle **Control Center**) has two tabs, **General** and **Policy Content**. The same form opens from the **+ Add** button of every policy picker in other modules.



Add Policy

General tab

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	“Required” under the field and “Name is required.” in the validation message. Must be unique in the organisation (“Policy Standard with this name already exists”).	Vendor Management Policy
Description	Long text	No		Vendor Management Policy for all employees and contractors.
GRC Contact	Users or groups, several allowed	Yes	“GRC Contact is required.”	Alex Meian
Policy Reviewer Contact	Users or groups, several allowed	Yes	“Policy Reviewer Contact is required.” The names are copied onto generated reviews.	Sara Johnson
Related Projects	Picker of projects, **+ Add**	No	Empty hint “No projects created yet.”	
Status	Drop-down	No	**Draft** (default), **Published**	Published

Field	Type	Required	Rules and allowed values	Example
Published Date	Date	No		2026-08-06
Next Review Date	Date	No	Drives the review schedule and the Dynamic Status.	2027-01-08
Policy Labels	Drop-down	No	**Confidential**, **Public** (default), **Private**	Private

Policy Content tab

Field	Type	Required	Rules and allowed values	Example
Document Type	Drop-down	No	Values from the Document Types list (default Policy, Procedure, Standard). Default for a new record: Policy.	Policy
Version	Text	No	Default “1.0”. Max 50 characters.	1.0
Document Content	Choice of three, see below	No	**Use Content**, **URL Link**, **File Attachment**	

If a required field on **General** is empty when you click **Save**, the form switches back to the **General** tab.

The Document Content field

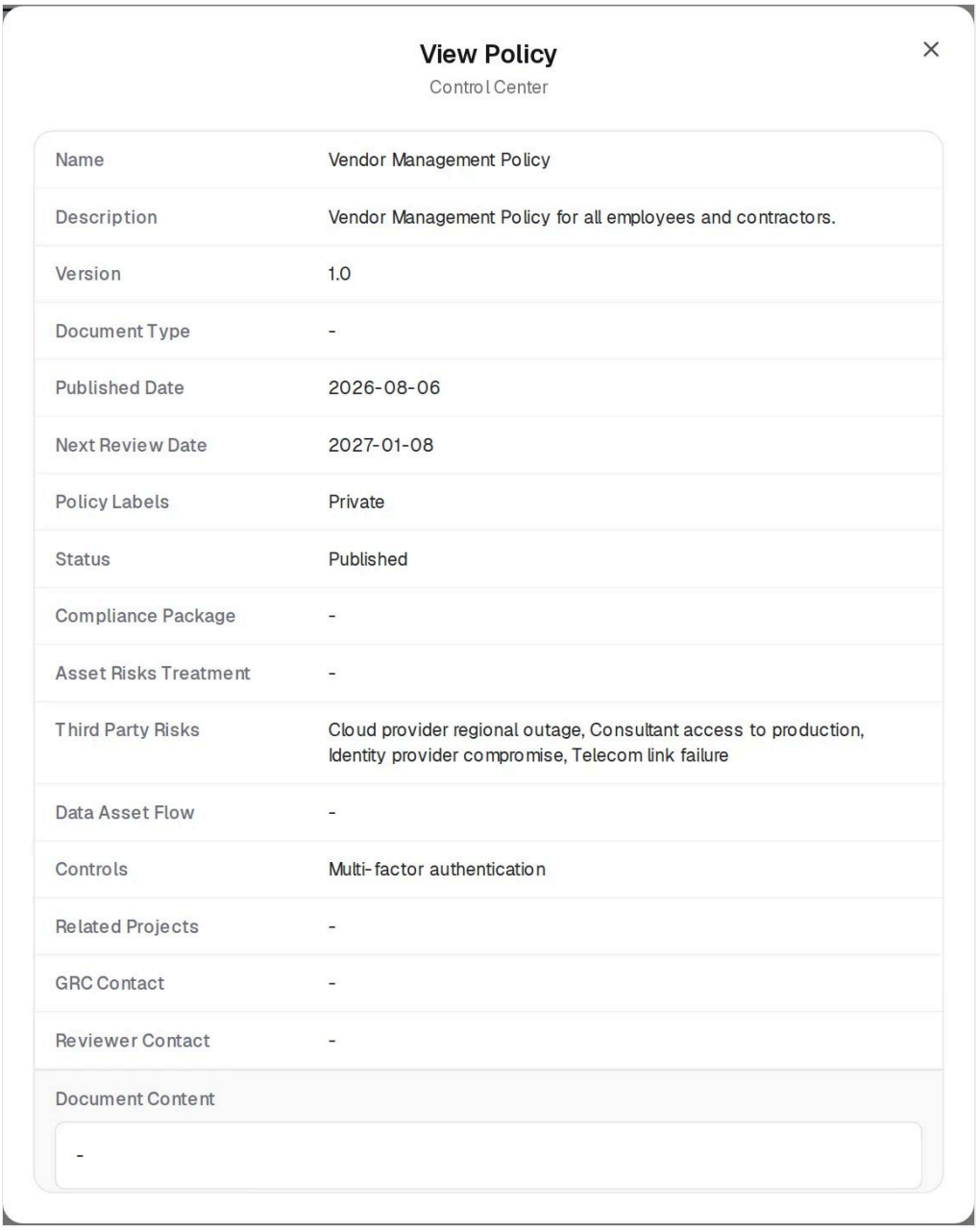
`DocumentContentField.tsx` offers three ways to give the document. Only the chosen one is saved; the other two are cleared on save.

Choice	What you enter	How it is stored and shown
Use Content	Plain text in a large box (“Write the document here.”)	Stored as plain text and always shown as text, never as formatted markup.
URL Link	A link, placeholder “Enter document URL (e.g. Google Docs, SharePoint link)”	Shown as a link that opens in a new tab.
File Attachment	One file via the file picker; **Remove** clears it	The file is uploaded to object storage as evidence of kind POLICY (max 25 MB). On a new policy it shows “uploads on save” and is uploaded right after the policy is created. Only the file name is kept on the policy; the grid and the View dialog offer the file for download.

When a record is reopened, the form shows the choice that holds a value, in the order text, then file, then link. Replacing an attachment uploads a new file; earlier files stay in storage but only the one whose name the policy carries is offered as the document.

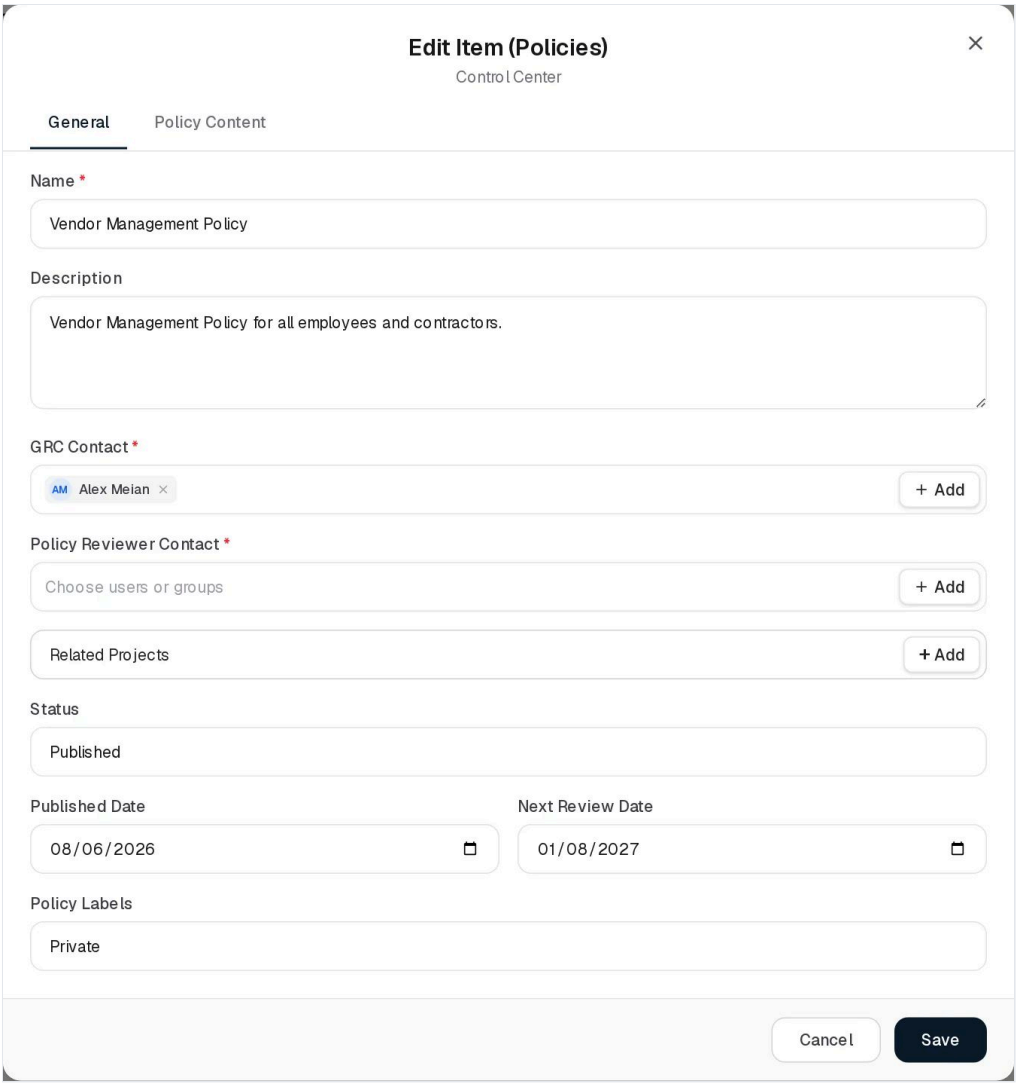
Viewing and editing a record

The eye button opens **View Policy**: **Name**, **Description**, **Version**, **Document Type**, **Published Date**, **Next Review Date**, **Policy Labels**, **Status**, **Compliance Package**, **Asset Risks Treatment**, **Third Party Risks**, **Data Asset Flow**, **Controls**, **Related Projects**, **GRC Contact**, **Reviewer Contact**, and at the bottom **Document Content** (text, link or downloadable file).



View Policy

Edit opens **Edit Item (Policies)**, the same two-tab form. Saving recalculates the generated reviews from the **Next Review Date**.



Edit Policy

Deleting a policy removes it from the controls, asset risks, third party risks and data flows that name it.

Versions, publication and portal permission

- **Version** is a free-text label on the policy, and each review has its own **Version** field. Nothing increments versions automatically, and completing a review does not change the policy's version or document; update the policy yourself after a review.
- **Status Draft** / **Published** is informational. A Draft policy is still linked, reviewed and shown like a Published one, and still generates reviews.
- The policy record has a **portal permission** field (stored on the server, kept unchanged by every save), but no screen in this release shows or edits it.

Statuses

Status (chosen on the form)

Value	Set by	Meaning
Draft	User	Still being written. Default. Shown grey.
Published	User	The version in force. Shown green.

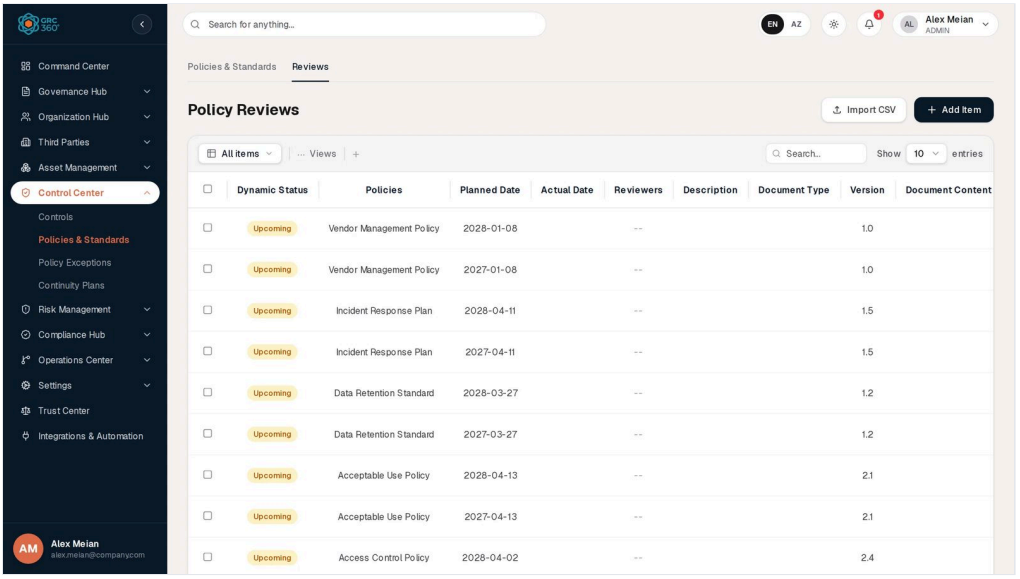
Dynamic Status (computed on every read)

Value	Colour	Rule
Needs Review	Amber	**Next Review Date** is before today.
Current	Green	Otherwise, including when no Next Review Date is set.

Status does not influence Dynamic Status.

Tabs

Reviews



Policy Reviews

Grid **Policy Reviews**, all reviews of all policies you can see, newest first.

Column	Meaning
Dynamic Status	**Completed**, **Missing Date**, **Expired** or **Upcoming** (below)
Policies	The reviewed policy
Planned Date	When the review is due
Actual Date	When it was carried out
Reviewers	Reviewer names
Description	Review notes
Document Type	The policy's current Document Type
Version	The policy's current Version (not the review's own)
Document Content	The review's written text or link, or else the policy's link
URL	The Document Content value when it is a web link
Content Attachment	The policy's attached file name (see known issues)
Status	Planned / Completed (and In Progress, Expired on older rows)

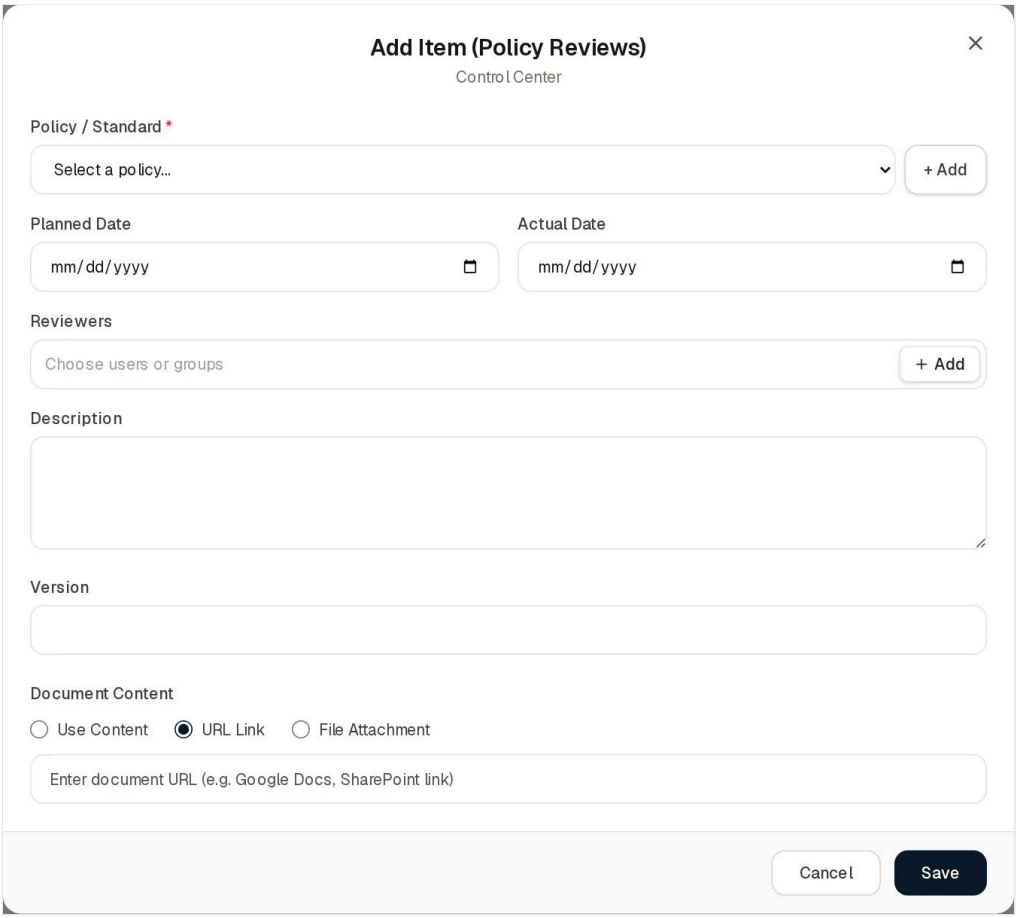
Review **Dynamic Status** (computed on every read):

Value	Colour	Rule
Completed	Green	**Actual Date** is filled in.
Missing Date	Amber	No Actual Date and no Planned Date.

Value	Colour	Rule
Expired	Red	No Actual Date and Planned Date before today.
Upcoming	Amber	No Actual Date and Planned Date today or later.

Review **Status** is not on the form: on save it is set to **Completed** if **Actual Date** is filled and **Planned** otherwise.

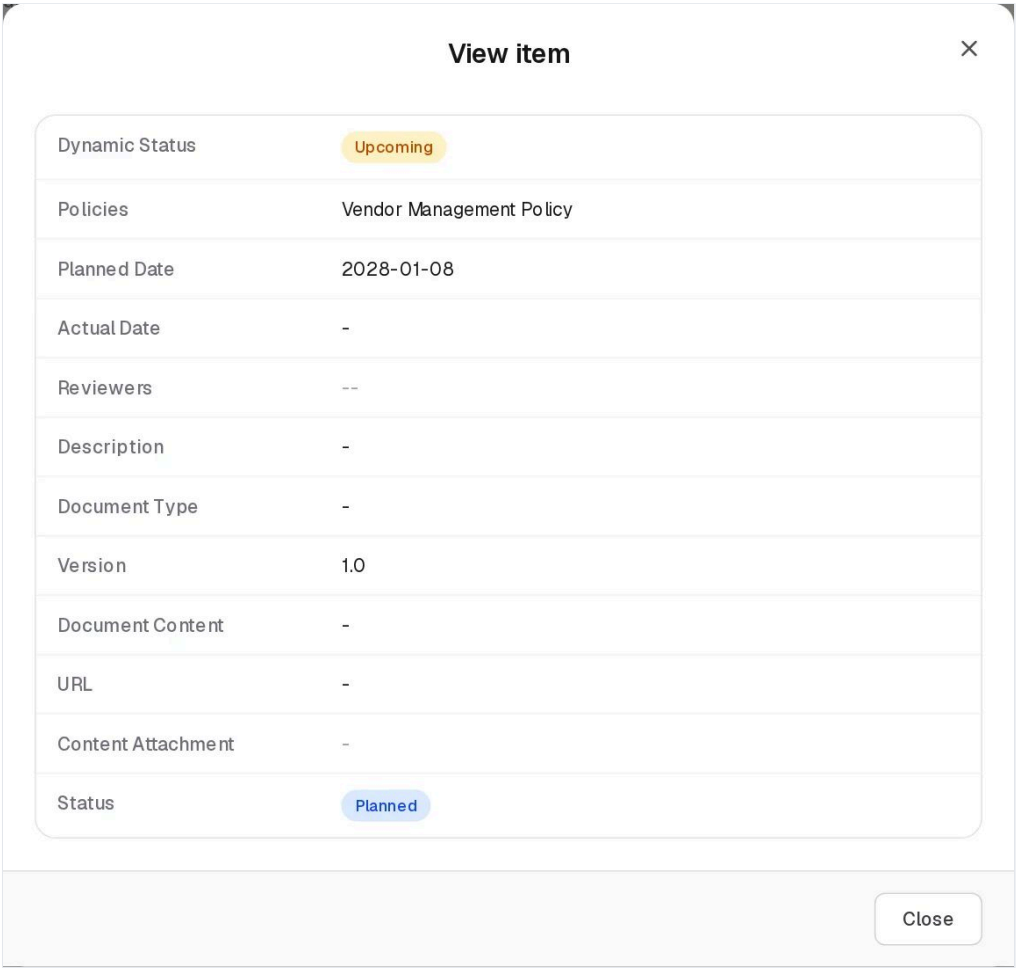
Add Item opens **Add Item (Policy Reviews)**:



Add Policy Review

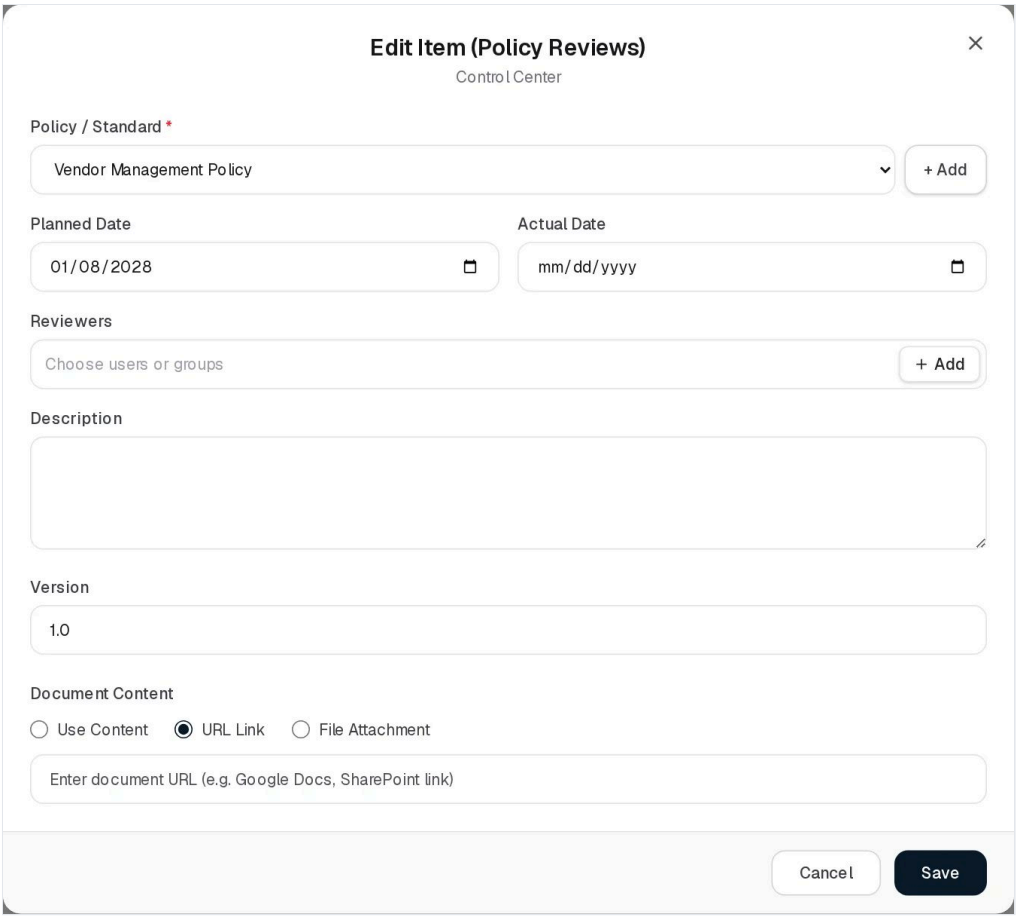
Field	Type	Required	Rules and allowed values	Example
Policy / Standard	Drop-down + **+ Add**	Yes	Placeholder “Select a policy…”; error “Select the policy being reviewed.” If none exist: “Create a policy first — reviews are recorded against an existing policy.”	Vendor Management Policy
Planned Date	Date	No		2027-01-08
Actual Date	Date	No	Filling it completes the review.	
Reviewers	Users or groups	No	Names and ids stored.	Sara Johnson
Description	Long text	No		
Version	Text	No	The version this review records.	1.1
Document Content	**Use Content** / **URL Link** (default for a new review) / **File Attachment**	No	As on the policy; a file is uploaded as evidence of kind POLICY_REVIEW.	

The eye button opens **View item**, which lists the grid columns of the review.



View Policy Review

Editing uses **Edit Item (Policy Reviews)**, the same form.

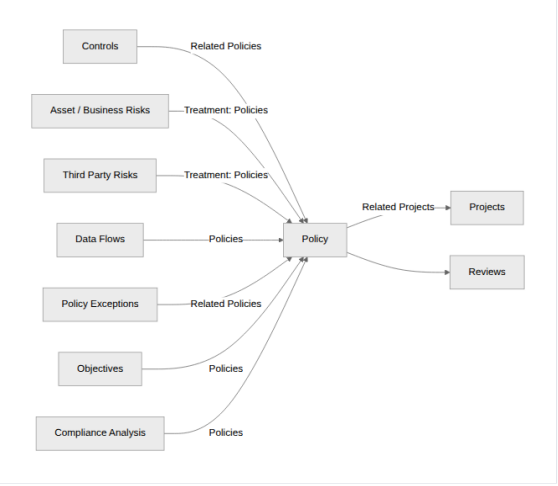


Deleting asks “Delete policy review for *policy name*?”. Adding, editing and deleting a review updates the policy’s **Reviews** count.

Generated reviews

Each save of a policy plans reviews from its **Next Review Date**: one on that date and one a year later, skipping dates already past. A generated review copies the policy’s **Policy Reviewer Contact** names, **Version** and document text or link. Changing the Next Review Date withdraws generated reviews that have no **Actual Date** and creates the new ones; completed reviews and reviews added by hand are kept. In the demo data every policy has two **Upcoming** reviews, for example **Vendor Management Policy** on 2027-01-08 and 2028-01-08.

Relationships



Related record	Direction	How the link is made	Where it shows
Projects	Policy → many	**Related Projects** on the policy form	Related Projects column
Reviews	One policy → many	Reviews tab, or generated from Next Review Date	**Reviews** count (not clickable), Reviews tab
Controls	Many ↔ many	**Related Policies** on the control	**Internal Controls** column, View **Controls**
Asset Risks, Third Party Risks	Many ↔ many	Treatment fields on the risk	Treatment count columns (clickable)
Data Flows	Many ↔ many	**Policies** on the data flow	**Data Asset Flow** column
Business Risks	Many ↔ many	**Treatment: Policies** on the business risk	Business Risks page only; no column here
Compliance packages	Many ↔ many	Compliance Analysis	**Compliance Package** column
Policy Exceptions	Many → many	**Related Policies** on the exception	Policy Exceptions page only
Objectives	Many ↔ many	**Policies** on the objective	Objectives page only

The links owned by other records are kept when the policy is saved: the form sends them back unchanged.

Automations and notifications

- Dynamic Status of policies and reviews is computed on read: a policy turns **Needs Review** and a review **Expired** on the day after the date passes.
- Reviews are generated from **Next Review Date** each time the policy is saved (no background job).
- The **Reviews** count is recalculated by the server on every policy or review save and delete.
- No notifications or reminders are sent for policies or reviews.

Permissions

Action	Needed access
See the page	View on Control Center › Policies & Standards
Add or edit a policy	Manage on Policies & Standards
Delete a policy	Full Control on Policies & Standards
Name other people in GRC Contact or Policy Reviewer Contact	Can Assign / Can Reassign on Policies & Standards
Open the Reviews tab	View on Policies & Standards › Reviews
Add or edit a review	Manage on Reviews, and visibility of the reviewed policy
Delete a review	Full Control on Reviews
Upload or delete the document file	Manage / Full Control on any Control Center page (checked at module level), and visibility of the policy
Edit the Document Types list	Manage (add, rename) / Full Control (delete) on any Control Center page
Comment and attach in the Activity Log	The group's Comments & Attachments level

Which policies appear can be limited to records that name the user as GRC Contact or Policy Reviewer Contact. The Reviews tab shows only reviews of policies you can see (and reviews with no policy).

How to

Publish a new policy with an attached document

1. Click **Add Item**. On **General** enter the **Name**, choose **GRC Contact** and **Policy Reviewer Contact**, set **Status Published**, **Published Date** and **Next Review Date**.

2. Open **Policy Content**, choose **Document Type** and **Version**.
3. Under **Document Content** choose **File Attachment** and pick the PDF. It shows “uploads on save”.
4. Click **Save**. The **Document Content** column shows the file name as a download link, and the **Reviews** tab shows two upcoming reviews.

Record a completed review

1. Open the **Reviews** tab and click **Edit** on the review of **Information Security Policy** planned for 2026-12-20.
2. Fill **Actual Date**, **Reviewers**, **Description** and the new **Version**.
3. Click **Save**. The review’s Dynamic Status becomes **Completed**.
4. Open the policy itself and update its **Version**, document and **Next Review Date**; the next generated reviews follow the new date.

Add a document type

1. On the Policies & Standards grid click **Settings** (dialog **Policy Document Types**).
2. Click **Add New**, type “Guideline”, click **Save** and **Close**.
3. **Guideline** is now offered in **Document Type**.

Find the controls that implement a policy

1. Look at the **Internal Controls** column, or open **View Policy** and read **Controls**. For **Access Control Policy** the demo data lists eight controls, from Backup and restore testing to Vulnerability scanning.

CSV import

Not available. **Import CSV** on both grids shows “CSV Import (*title*): the import structure is not ready yet.” and then opens a demonstration dialog whose validation fails. The backend import endpoint `/control/policies-standards/import-csv` is not used by any screen. See CSV import and export.

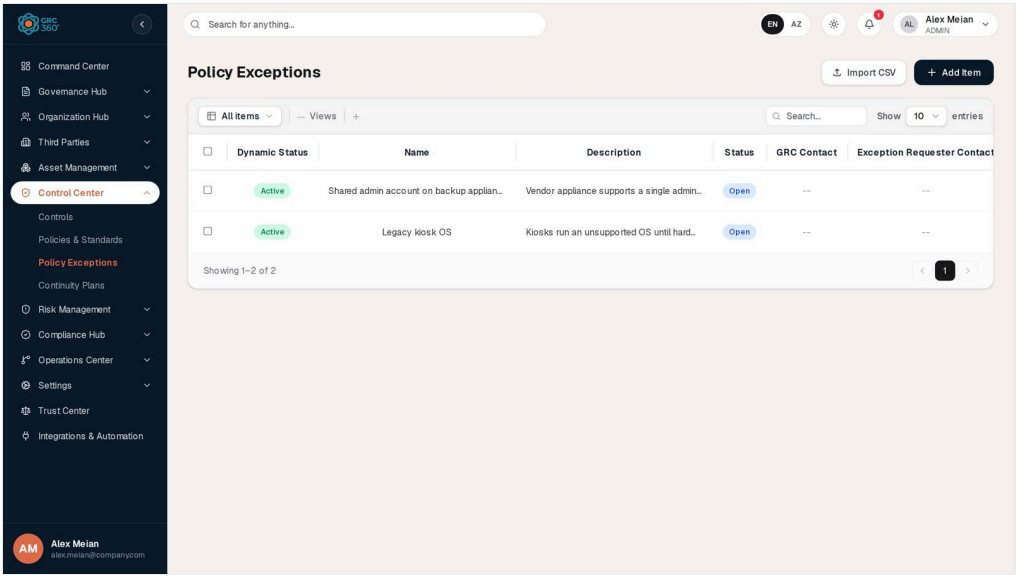
Limitations and known issues

- **A review’s attached file is not remembered.** The review form offers **File Attachment** and uploads the file, but the server does not store the review’s attachment name. The **Content Attachment** column therefore shows the policy’s file instead of the review’s, and reopening the review shows **URL Link** again. The uploaded file stays in storage without being reachable from the screen.
- **Review grid columns show the policy, not the review. Version** and **Document Type** come from the policy as it is now, not from the review.
- **Generated reviews often have no reviewers.** They copy the reviewer names stored as text on the policy; policies whose reviewer was set only by id (as in the demo data) produce reviews with an empty **Reviewers** column.
- **Expired is never shown on a policy.** The policy’s Dynamic Status has three possible values on the server (Current, Needs Review, Expired), but only the first two are ever produced.
- **Linked records are not editable here.** The policy stores links to controls, risks, data flows and compliance packages, but the form offers only **Related Projects**; the others are set from the other records.
- **Portal permission is not exposed** on any screen.
- **No review reminders.** Nothing notifies the reviewer before or after the Next Review Date.

Policy Exceptions

> **Module:** Control Center › Policy Exceptions · **Route:** `/control-center/exceptions` · **Permission key:** `control_center.exceptions`

The Policy Exceptions register records approved deviations from the organisation's policies and standards: a situation where a policy cannot be followed for a limited time, for example a vendor appliance that only supports one shared admin account. A record names who asked for the exception, who owns it on the GRC side, which policies it deviates from, and when it expires. GRC staff maintain it; requesters and policy owners read it.



Policy Exceptions register

At a glance

A record is	One time-limited exception to one or more policies
Typical owner	GRC Contact
Links to	Policies & Standards (Related Policies)
Linked from	Nothing
Tabs	None
Automations	Computed Dynamic Status; Start Date and Closure Date stamped by the server

The page key is `exceptions` for historical reasons; only the label reads "Policy Exceptions". Risk exceptions and compliance exceptions are separate registers in Risk Management and the Compliance Hub.

The register (list view)

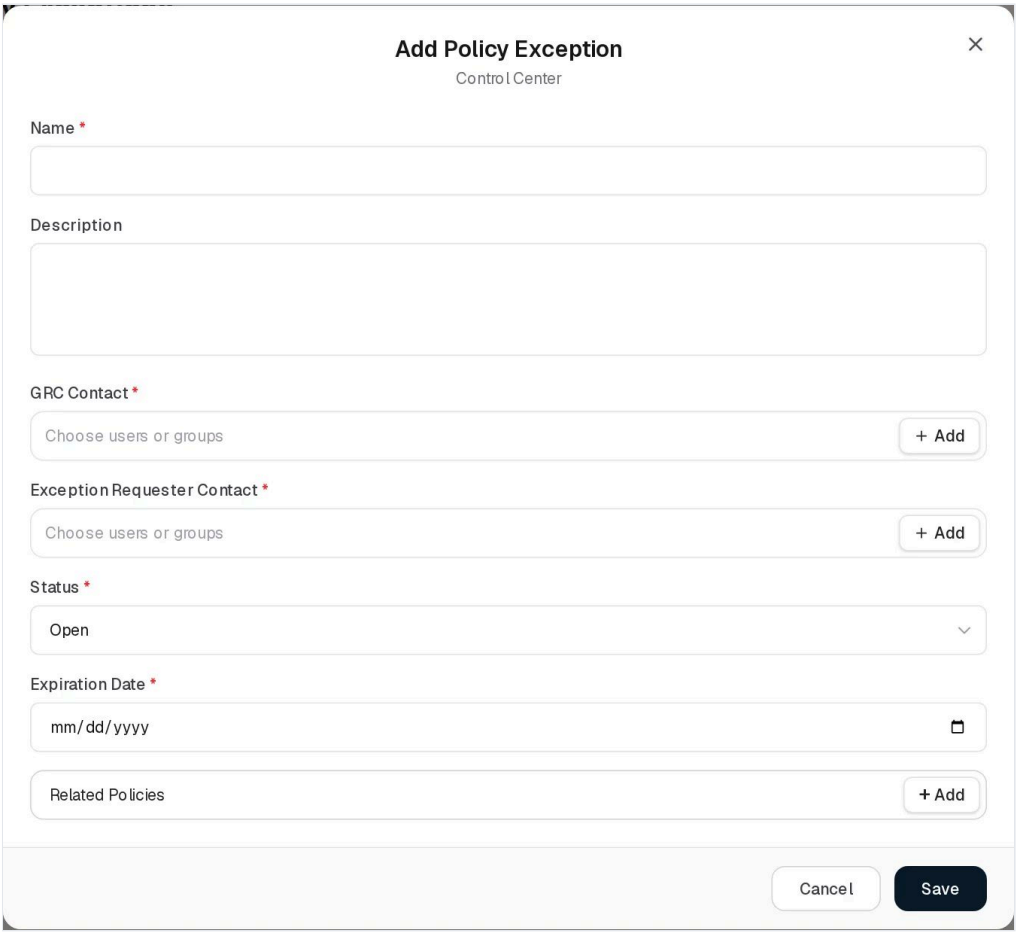
The grid lists every exception of the organisation, newest first (the list is loaded whole, not page by page from the server). The shared grid behaviour is described in Working with registers.

Column	What it shows	Source
Dynamic Status	**Active**, **Pending**, **Expired** or **Closed** (see Statuses)	Computed by the system
Name	Short title of the exception	Entered
Description	Why the exception is needed	Entered

Column	What it shows	Source
Status	**Open** or **Closed**	Entered
GRC Contact	Owner names, with avatar	Entered
Exception Requester Contact	Requester names, with avatar	Entered
Start Date	Day the exception was recorded	Set by the server
Expiration Date	Last day the exception is meant to apply	Entered
Closure Date	Day it was closed	Set by the server
Related Policies	Names of the policies it deviates from	Linked (chosen on this form)

Creating a record

Click **Add Item**. The dialog **Add Policy Exception** (subtitle **Control Center**) opens.



Add Policy Exception

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	“Required”. Max 255 characters. Must be unique in the organisation when created (“Control Exception with this name already exists”).	Shared admin account on backup appliance
Description	Long text	No		Vendor appliance supports a single admin login.
GRC Contact	Users or groups, several allowed, **+ Add**	Yes	“Required”	Alex Meian

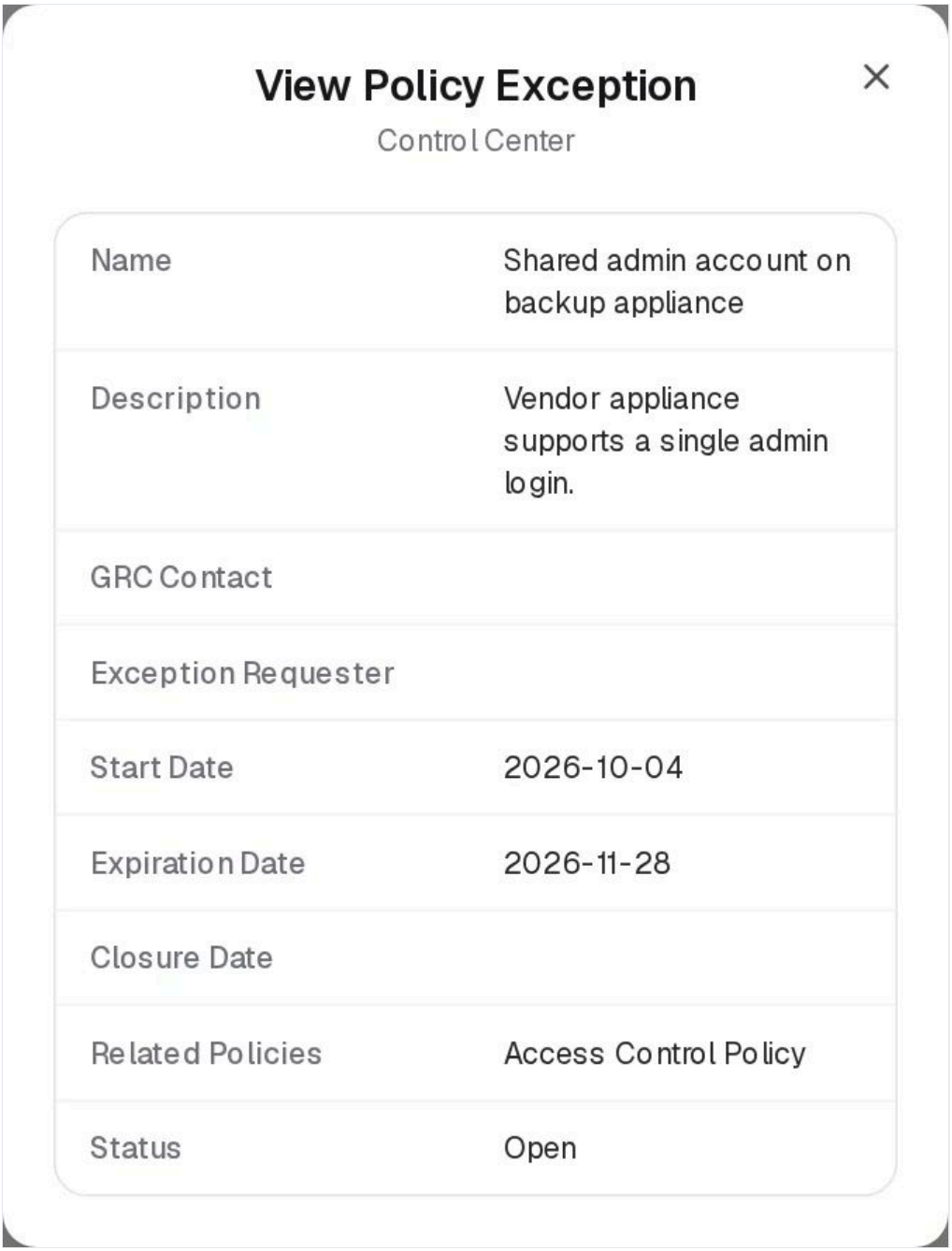
Field	Type	Required	Rules and allowed values	Example
Exception Requester Contact	Users or groups, several allowed, **+ Add**	Yes	“Required”	Mike Brown
Status	Drop-down	Yes (always has a value)	**Open** (default), **Closed**	Open
Expiration Date	Date	Yes	“Required”	2026-11-28
Related Policies	Picker of Policies & Standards, **+ Add**	No	Empty hint “No policies or standards defined yet.” Every chosen policy must exist, otherwise the save is refused.	Access Control Policy

Start Date is not on the form. The server sets it to the day the exception is created and keeps it on later edits. **Closure Date** is also not on the form: it is set to the day the status is changed to **Closed**, and cleared again if the exception is reopened.

On save the message “Exception added.” (or “Exception updated.”) appears; errors are shown in a red banner above the grid.

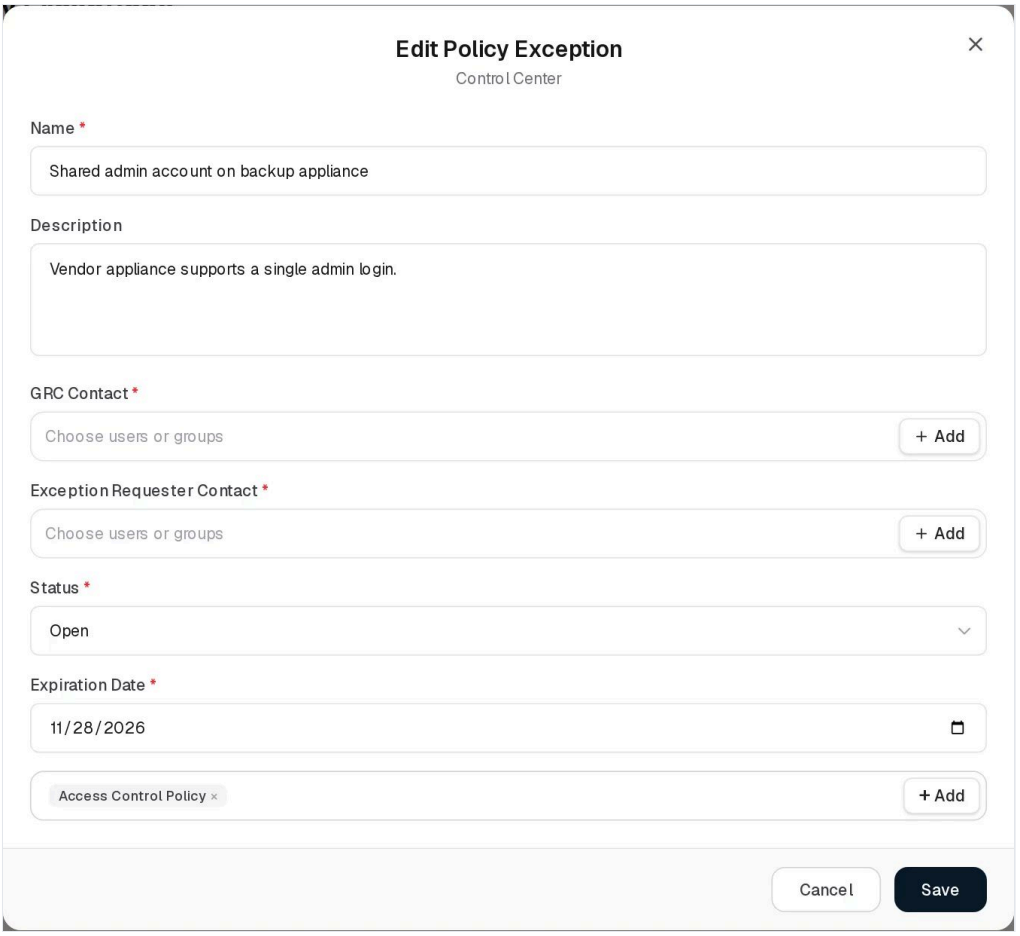
Viewing and editing a record

The eye button opens **View Policy Exception** with **Name**, **Description**, **GRC Contact**, **Exception Requester**, **Start Date**, **Expiration Date**, **Closure Date**, **Related Policies** and **Status**.



View Policy Exception

Edit opens **Edit Policy Exception**, the same form. Delete asks “Delete exception *name*?”.



Edit Policy Exception

Statuses

Status (chosen on the form)

Value	Set by	Meaning
Open	User	The exception is in force (or awaiting closure). Default. Shown blue.
Closed	User	The exception has ended. Sets **Closure Date**. Shown green.

Dynamic Status (computed on every read; “expired” means the **Expiration Date** is before today)

Value	Colour	Rule
Closed	Green	A **Closure Date** is set (always the case when Status is Closed).
Expired	Red	Status is Open and the exception has expired.
Pending	Amber	Status is Open and the exception has not expired. This is what every exception created on this screen shows while it is in force.
Active	Green	Only for records stored with status Approved (possible through the API or older data, not from this form) that have not expired.

The two demo exceptions were created with status Approved, so they show **Active** while their **Status** column reads **Open** (see known issues).

Relationships

Related record	Direction	How the link is made	Where it shows
Policies & Standards	Exception → many policies	**Related Policies** on this form	Related Policies column and View. The policy itself does not show its exceptions.

Automations and notifications

- Dynamic Status is computed on read: an open exception shows **Expired** from the day after its Expiration Date, with no job involved.
- The server stamps **Start Date** on creation and **Closure Date** on closing.
- No scheduled job changes policy exceptions, and no reminder or notification is sent before or after expiry. The exception keeps its **Open** status until someone closes it.

Permissions

Action	Needed access
See the page	View on Control Center › Policy Exceptions
Add or edit an exception	Manage on Policy Exceptions
Delete an exception	Full Control on Policy Exceptions
Comment and attach in the Activity Log	The group's Comments & Attachments level

Policy Exceptions is not a visibility register: everyone who can open the page sees every exception. The people fields are not subject to Can Assign / Can Reassign.

How to

Record a new exception

1. Click **Add Item**.
2. Enter **Name** "Legacy kiosk OS" and a **Description**.
3. Choose **GRC Contact** and **Exception Requester Contact**, set **Expiration Date**, and pick **Access Control Policy** in **Related Policies**.
4. Click **Save**. **Start Date** shows today, Dynamic Status **Pending**.

Close an exception

1. Click **Edit** on the exception, set **Status** to **Closed** and click **Save**.
2. **Closure Date** shows today and Dynamic Status turns **Closed**.

Find exceptions that have run out

1. In the grid, look for Dynamic Status **Expired** (red), or sort by **Expiration Date**.
2. Either close each one or extend its **Expiration Date**.

CSV import

Not available. **Import CSV** shows "CSV Import (Policy Exceptions): the import structure is not ready yet." and then opens a demonstration dialog whose validation fails. The backend import endpoint `/control/exceptions/import-csv` is not used by any screen. See CSV import and export.

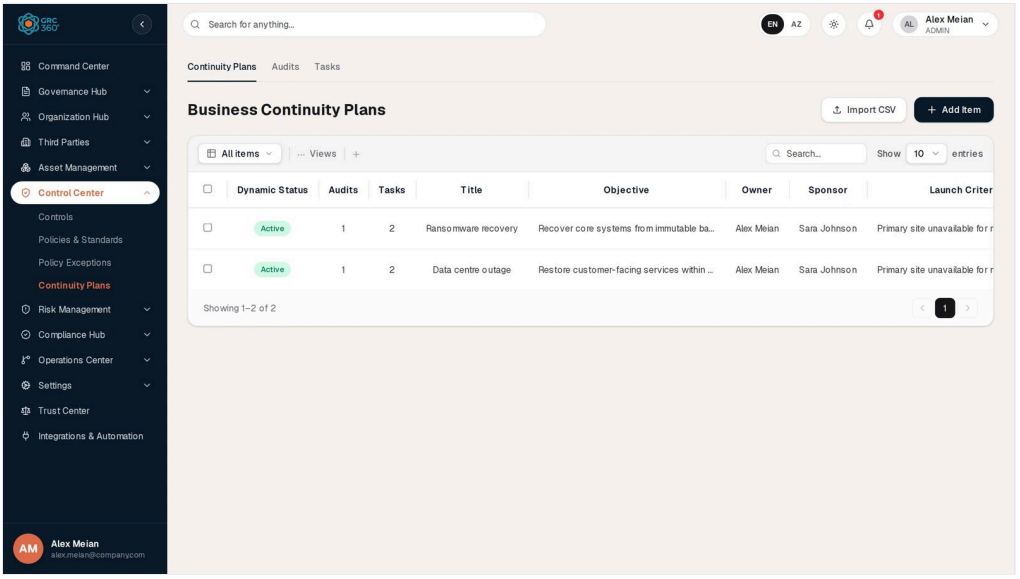
Limitations and known issues

- **Open exceptions read “Pending”, not “Active”.** An exception created on this screen can only be Open or Closed, and Open maps to Dynamic Status **Pending** while in force. **Active** appears only for records stored as Approved.
- **Saving changes Approved to Open.** The form shows any status other than Closed as **Open**. Editing and saving an Approved record (such as the two demo exceptions) stores it as Open, and its Dynamic Status changes from **Active** to **Pending**.
- **Name uniqueness is checked only when creating.** Renaming an exception to an existing name is accepted.
- **GRC Contact and Exception Requester are stored as names.** The demo exceptions carry no names, so both columns show “–” and the View shows empty values.
- **No expiry handling.** Expired exceptions are only flagged by Dynamic Status; nothing closes them or notifies anyone.

Continuity Plans

> **Module:** Control Center › Continuity Plans · **Route:** `/control-center/continuity-recovery` · **Permission key:** `control_center.continuity_recovery`

The Continuity Plans register holds the organisation's business continuity and recovery plans: what is to be achieved when a disruption happens, who owns, sponsors and may launch the plan, what it costs, and how it is tested. Each plan has a list of step-by-step **Tasks** (who does what, when, where and how) and a series of **Audits** that test it, planned from the plan's own audit schedule. Business continuity managers maintain the plans; the people named in tasks are notified of their role.



Business Continuity Plans register

At a glance

A record is	One business continuity or recovery plan
Typical owner	Owner (with a Sponsor and a Launch Initiator)
Links to	Nothing (its tasks and audits belong to it)
Linked from	Business Risks (**Mitigating Business Continuity Plans**)
Tabs	Audits, Tasks
Automations	Computed Dynamic Status; audits generated from the audit schedule on save; in-app notification to people named in a task's Awareness Role

The page key is `continuity_recovery` for historical reasons; the sidebar says "Continuity Plans" and the grid "Business Continuity Plans". The active tab is kept in the address (`?tab=plans` , `?tab=audits` , `?tab=tasks`), so a tab can be bookmarked or linked.

The register (list view)

The **Continuity Plans** tab lists every plan, newest first (loaded whole, not page by page). The shared grid behaviour is described in Working with registers.

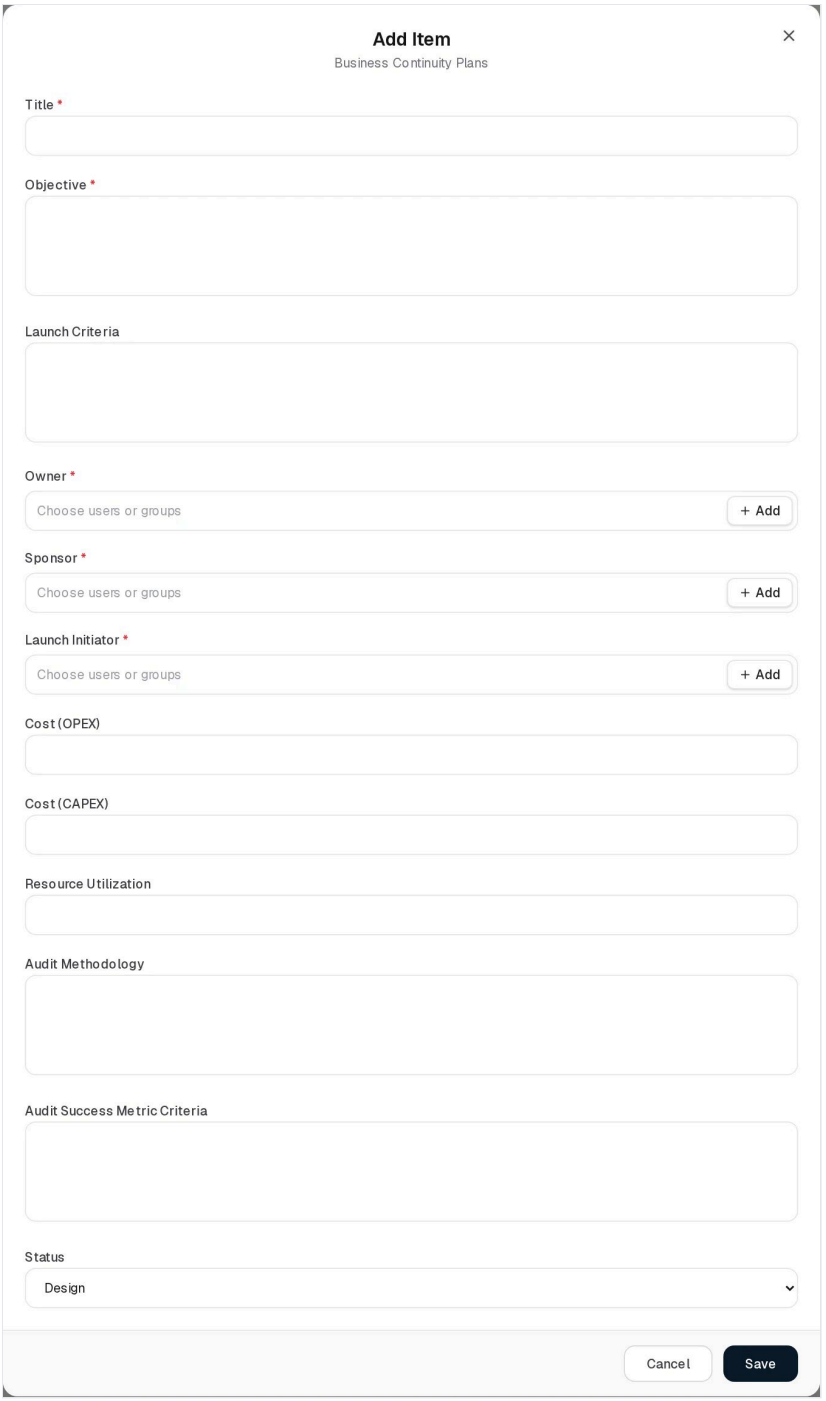
Column	What it shows	Source
Dynamic Status	**Active**, **Audit Overdue**, **Expired** or **Inactive** (see Statuses)	Computed by the system
Audits	Number of audits of the plan	Computed
Tasks	Number of tasks of the plan	Computed

Column	What it shows	Source
Title	Plan name	Entered
Objective	What the plan must achieve	Entered
Owner	Who is responsible for the plan	Entered
Sponsor	Who keeps the plan realistic, communicated and applicable	Entered
Launch Criteria	When the plan is to be launched	Entered
Launch Initiator	Who may launch the plan or declare that it is needed	Entered
Cost (OPEX)	Running cost, free text	Entered
Cost (CAPEX)	Investment cost, free text	Entered
Resource Utilization	Resources the plan uses	Entered
Audit Methodology	How the plan's audits are run	Entered
Audit Success Metric Criteria	Threshold that decides whether an audit passes	Entered, and updated from audits (see below)

The plan's **Status** (Design / Production) is on the form only; it has no column.

Creating a record

Click **Add Item**. The dialog **Add Item** (subtitle **Business Continuity Plans**) opens.



Add Continuity Plan

Field	Type	Required	Rules and allowed values	Example
Title	Text	Yes	“Title is required.” Max 200 characters. Must be unique in the organisation (“Continuity Plan with this name already exists”).	Ransomware recovery
Objective	Long text	Yes	“Objective is required.”	Recover core systems from immutable backups within 24 hours.
Launch Criteria	Long text	No		Primary site unavailable for more than 30 minutes
Owner	Users or groups, several allowed, **+ Add**	Yes	“Owner is required.”	Alex Meian

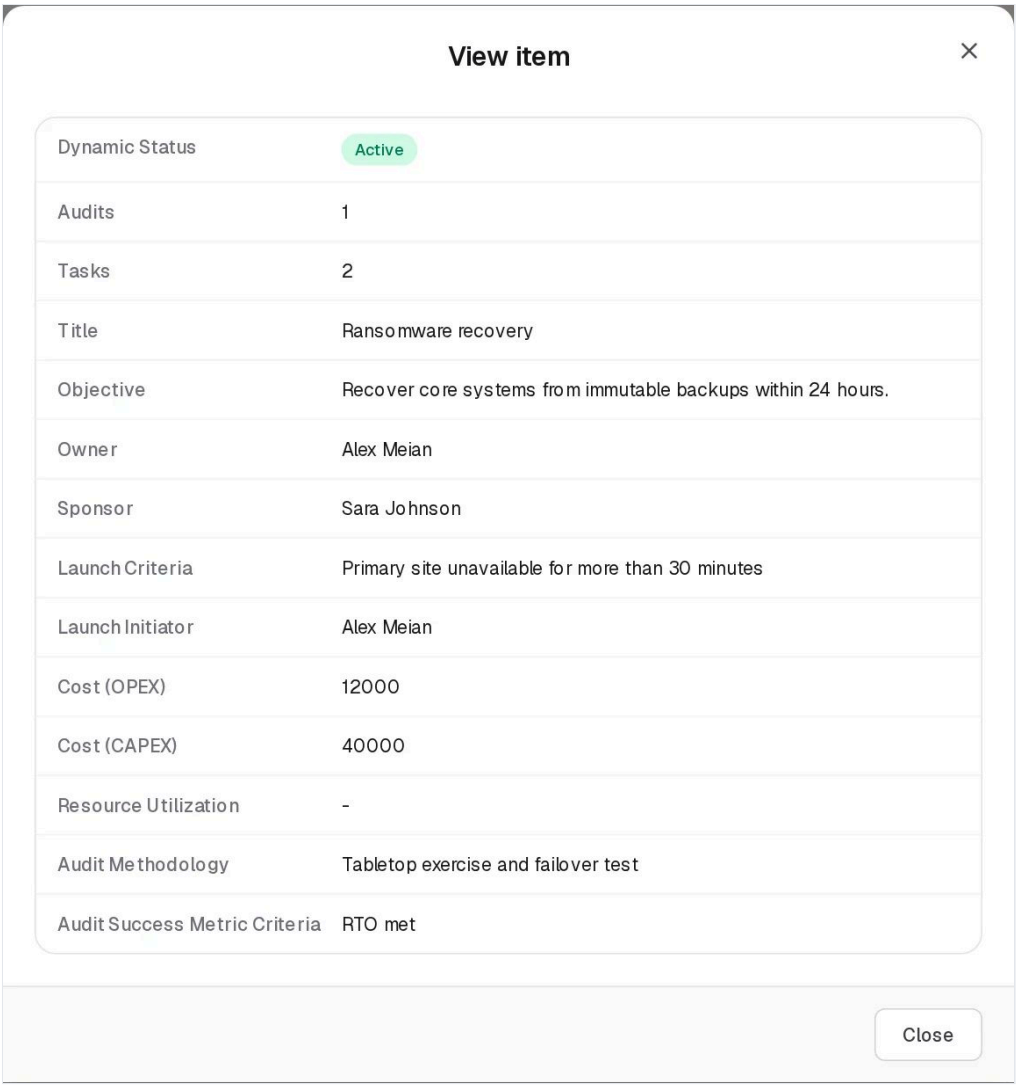
Field	Type	Required	Rules and allowed values	Example
Sponsor	Users or groups, several allowed, **+ Add**	Yes	“Sponsor is required.”	Sara Johnson
Launch Initiator	Users or groups, several allowed, **+ Add**	Yes	“Launch Initiator is required.”	Alex Meian
Cost (OPEX)	Text	No	Max 100 characters	12000
Cost (CAPEX)	Text	No	Max 100 characters	40000
Resource Utilization	Text	No		
Audit Methodology	Long text	No		Tabletop exercise and failover test
Audit Success Metric Criteria	Long text	No	Pre-fills new audits; also updated by audits (see Audits).	RTO met
Status	Drop-down	No	**Design** (default), **Production**	Production
Audits section	Schedule	Shown only when Status is **Production**	**Audit Dates** *: **No audits required** (default) / **Audits required**. When required, a box **Audit** with **Occurrence type Specific** (date list, **Add new +**, **×** to remove) or **Periodical** (**First audit date**, **Frequency**: values WEEKLY, MONTHLY, QUARTERLY, TWICE_A_YEAR, YEARLY).	Audits required, Periodical, 2026-11-03, TWICE_A_YEAR
Audit Owners	Users or groups (in the Audits section)	No	Names copied onto every generated audit as **Audit Owner**.	

Owner, Sponsor and Launch Initiator are mandatory. This was introduced in the latest release: the form refuses to save without all three. The rule is applied by the form only; plans created earlier, or through the API, may lack them, and must be completed the next time they are edited.

The audit schedule follows the rules in Audit and maintenance scheduling: a **Specific** date gives that date and the same day a year later; a **Periodical** schedule gives dates from the first audit date up to one year after it; past dates are skipped. A plan in Design is not audited: the section is hidden, and switching a plan back to Design withdraws its generated audits that have no result yet.

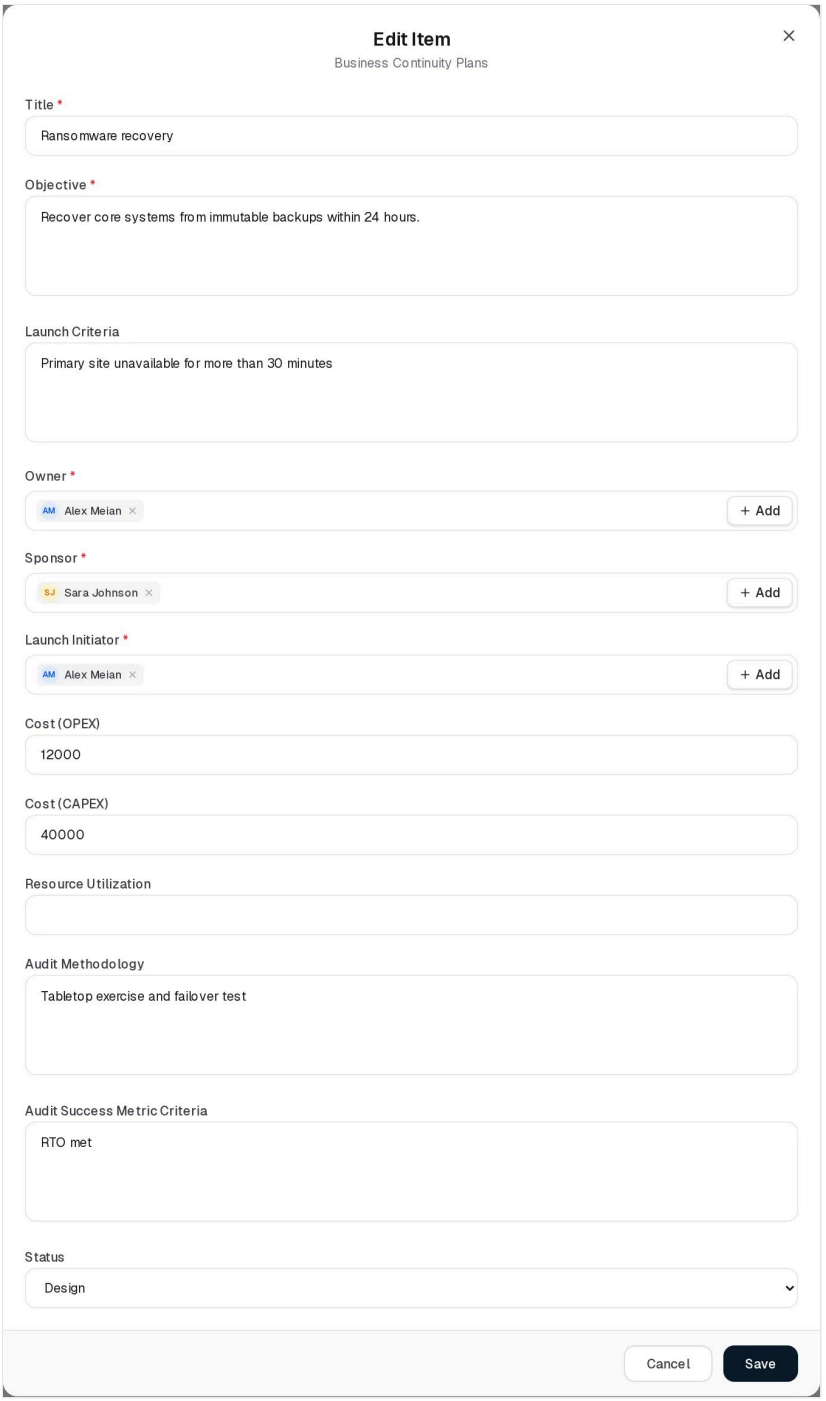
Viewing and editing a record

The eye button opens **View item** with every grid column.



View Continuity Plan

Edit opens **Edit Item**, the same form. Saving re-runs the audit schedule.



Edit Continuity Plan

Deleting a plan deletes its audits and tasks.

Statuses

Status (chosen on the form)

Value	Set by	Meaning
Design	User	The plan is being written. Not in force and not audited. Default.
Production	User	The plan is live; the audit schedule applies.

Dynamic Status of a plan (computed on every read, in this order)

Value	Colour	Rule
Inactive	Grey	Status is Design (or Draft, Archived, Inactive on older or imported records).
Expired	Red	The plan's review date is before today. The review date is not on the form; it exists only on records created through the API or import (the demo plans have 2027-01-12).
Audit Overdue	Red	Any of the plan's audits has Dynamic Status **Overdue**.
Active	Green	Everything else.

Plan audit (Audits tab)

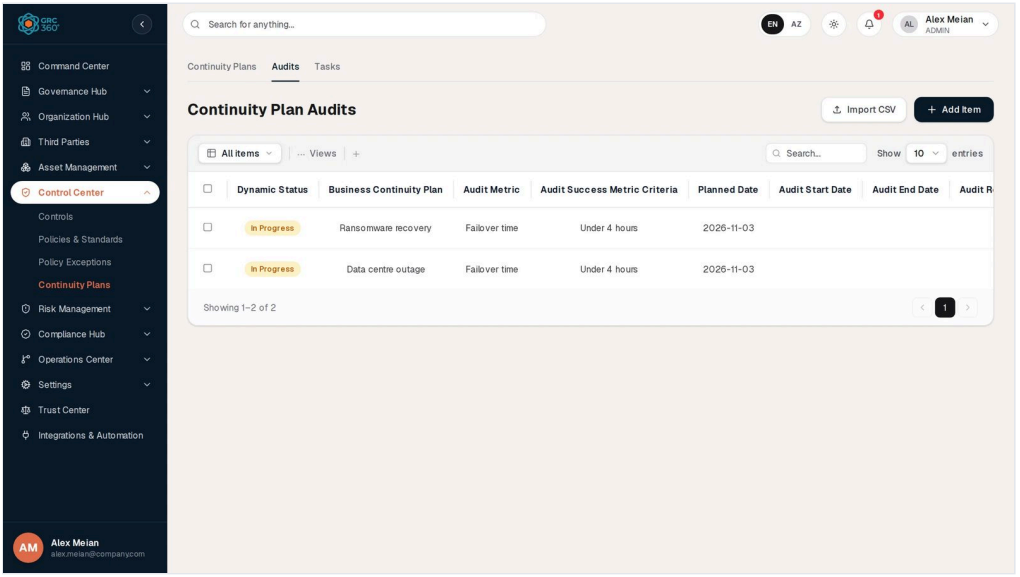
Field	Values
Status	Planned, In Progress, Completed. Not on the form: on save it becomes **Completed** if **Audit End Date** is set, **In Progress** if only **Audit Start Date** is set, otherwise **Planned**.
Dynamic Status	If Completed: **Fail** when **Audit Result** contains "fail", **Pass** when it contains "pass", otherwise **In Progress**. If not completed: **Overdue** when **Planned Date** or **Audit End Date** is before today; otherwise **In Progress**.

Plan task (Tasks tab)

Field	Values
Status	Pending (default), In Progress, Completed. There is no Dynamic Status for tasks.

Tabs

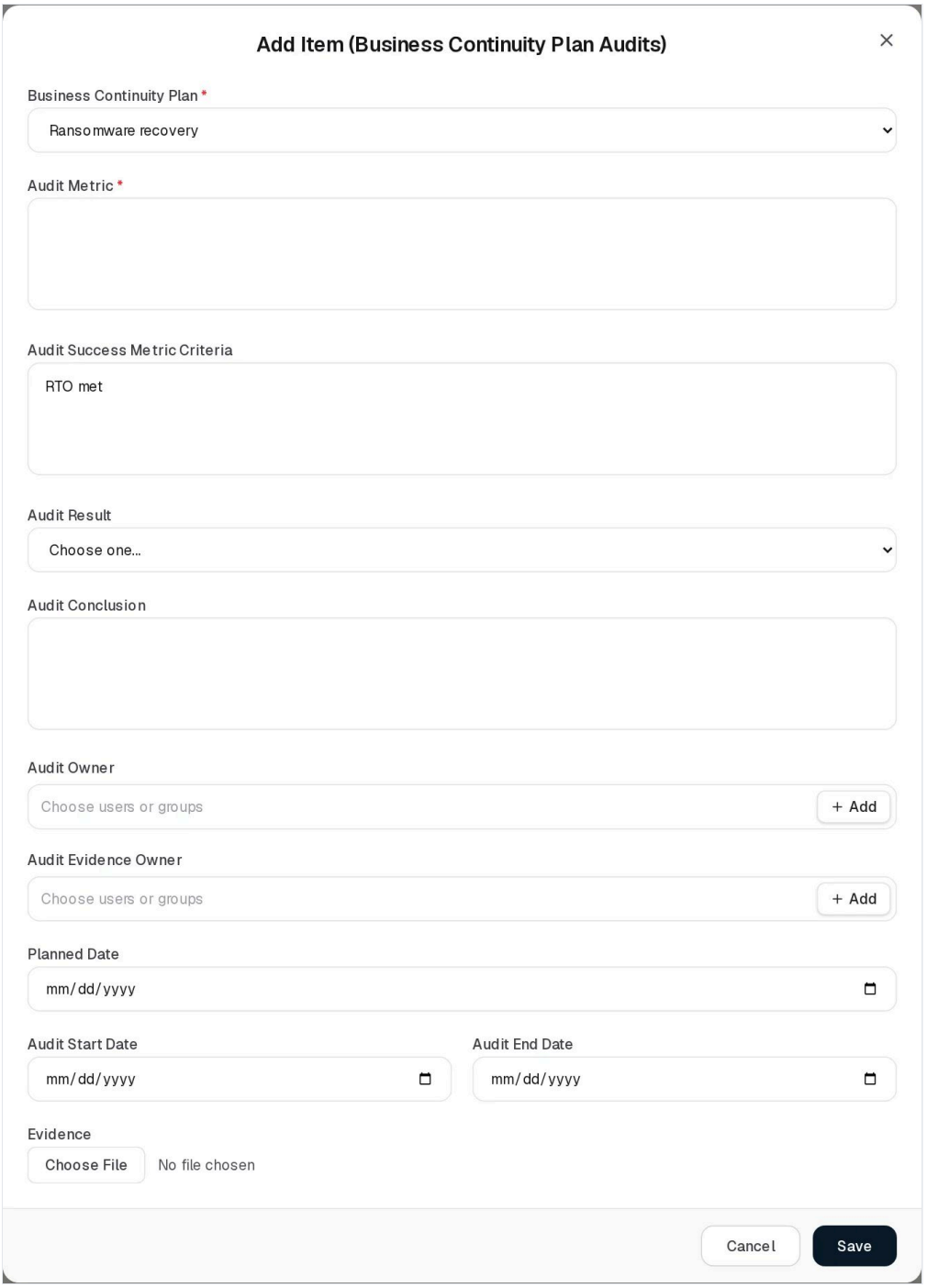
Audits



Continuity Plan Audits

Grid **Continuity Plan Audits**, all audits of all plans. Columns: **Dynamic Status**, **Business Continuity Plan**, **Audit Metric**, **Audit Success Metric Criteria**, **Planned Date**, **Audit Start Date**, **Audit End Date**, **Audit Result**, **Audit Conclusion**, **Evidence** (download links or "No evidence"), **Audit Owner**, **Status**.

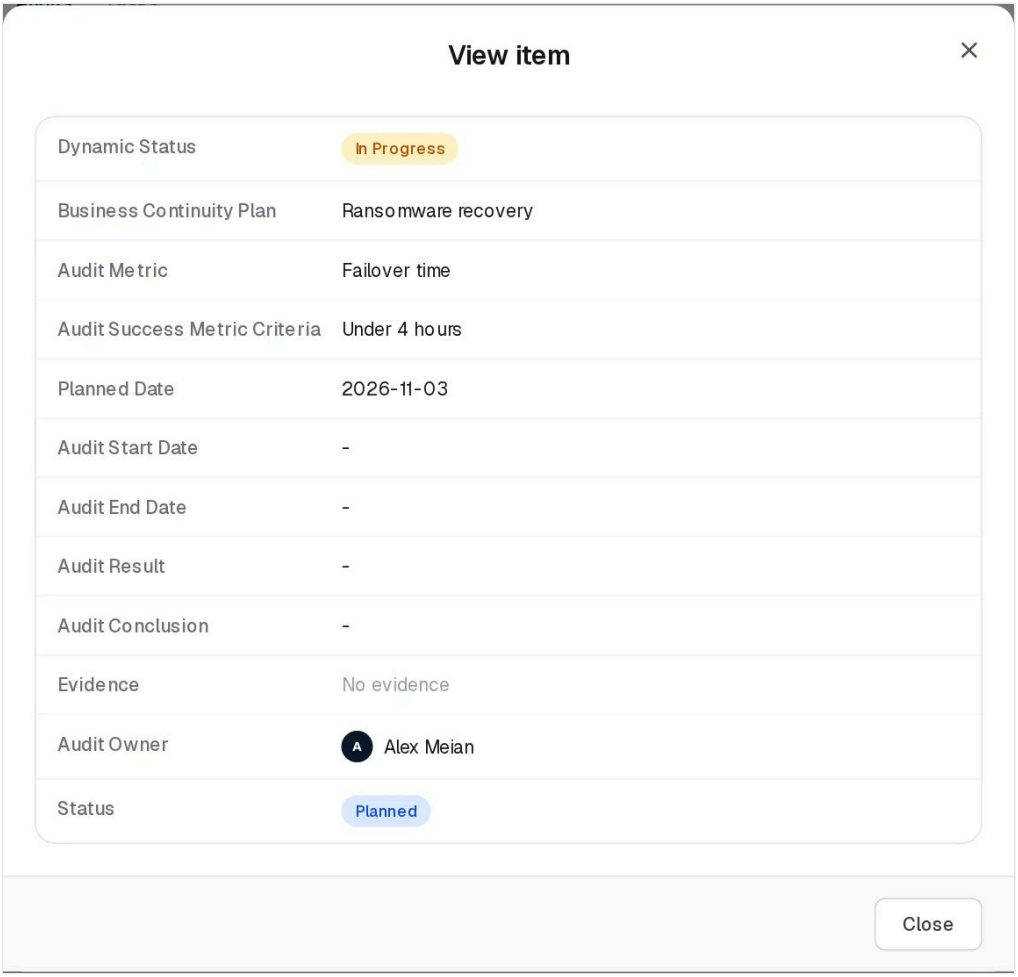
Add Item opens **Add Item (Business Continuity Plan Audits)**:



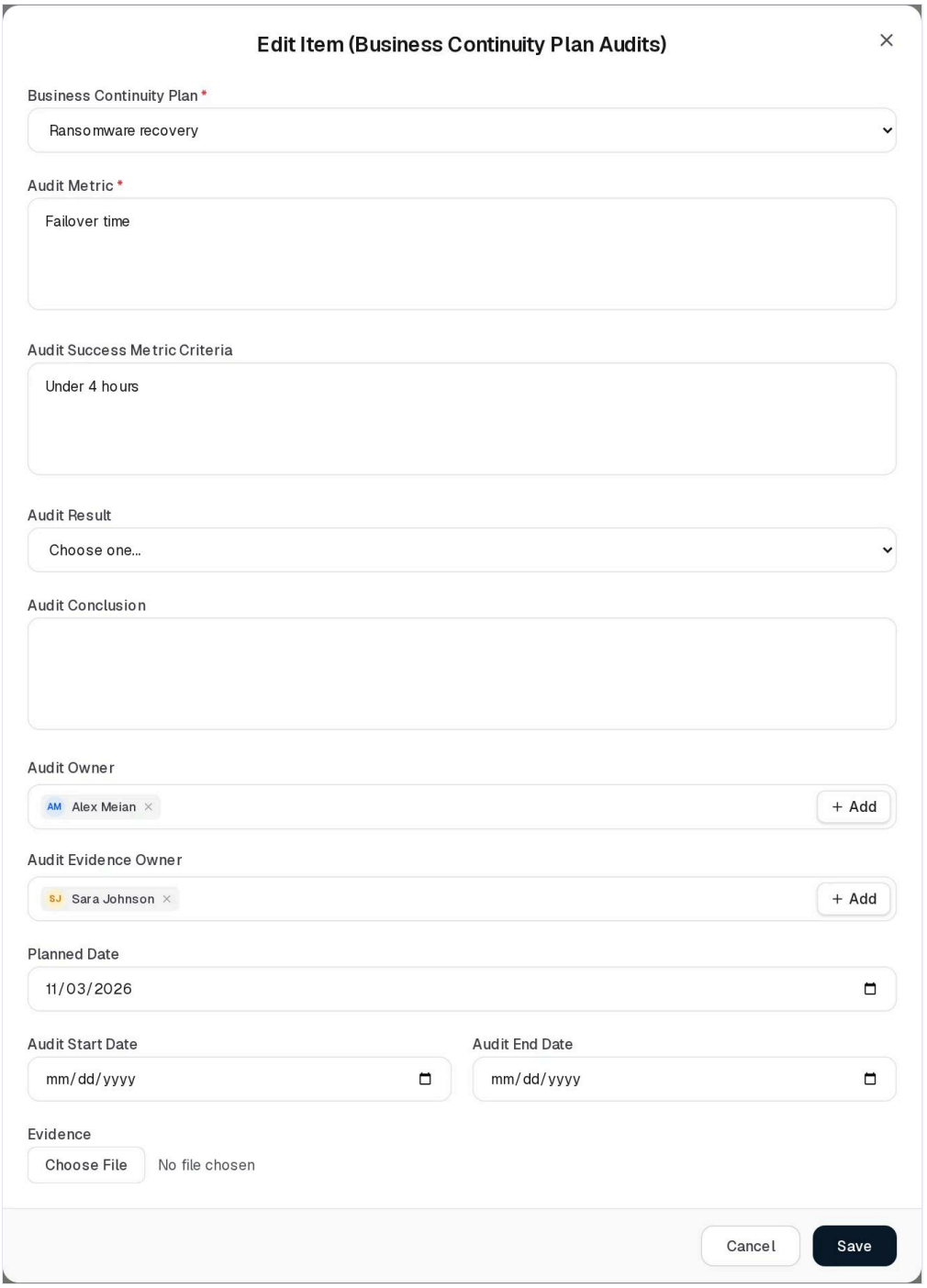
Add Continuity Plan Audit

Field	Type	Required	Rules and allowed values	Example
Business Continuity Plan	Drop-down	Yes	Pre-filled with the first plan; placeholder “Select a plan…”; “Business Continuity Plan is required.” If none exist: “Create a continuity plan first — audits are recorded against an existing plan.”	Ransomware recovery
Audit Metric	Long text	Yes	“Required.” What the audit measures.	Failover time
Audit Success Metric Criteria	Long text	No	Pre-filled from the plan (see below).	Under 4 hours

Field	Type	Required	Rules and allowed values	Example
Audit Result	Drop-down	No	**Choose one…**, **Passed**, **Failed** (fixed list; a different stored value is added to the list)	
Audit Conclusion	Long text	No		
Audit Owner	Users or groups	No		Alex Meian
Audit Evidence Owner	Users or groups	No		
Planned Date	Date	No		2026-11-03
Audit Start Date	Date	No	Setting it makes the audit In Progress.	
Audit End Date	Date	No	Setting it makes the audit Completed.	
Evidence	File upload	No	As on control audits: one file at a time, max 25 MB, “uploads on save” on a new audit. See Controls › Evidence.	



View Continuity Plan Audit

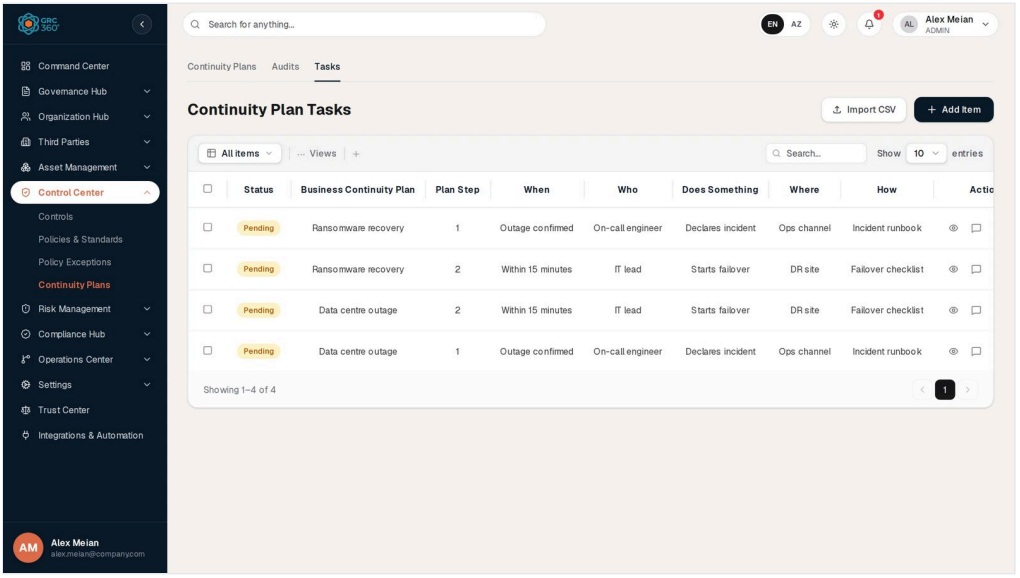


Edit Continuity Plan Audit

Metric Success Criteria behaviour. The plan's **Audit Success Metric Criteria** and the audits' **Audit Success Metric Criteria** are kept as one value:

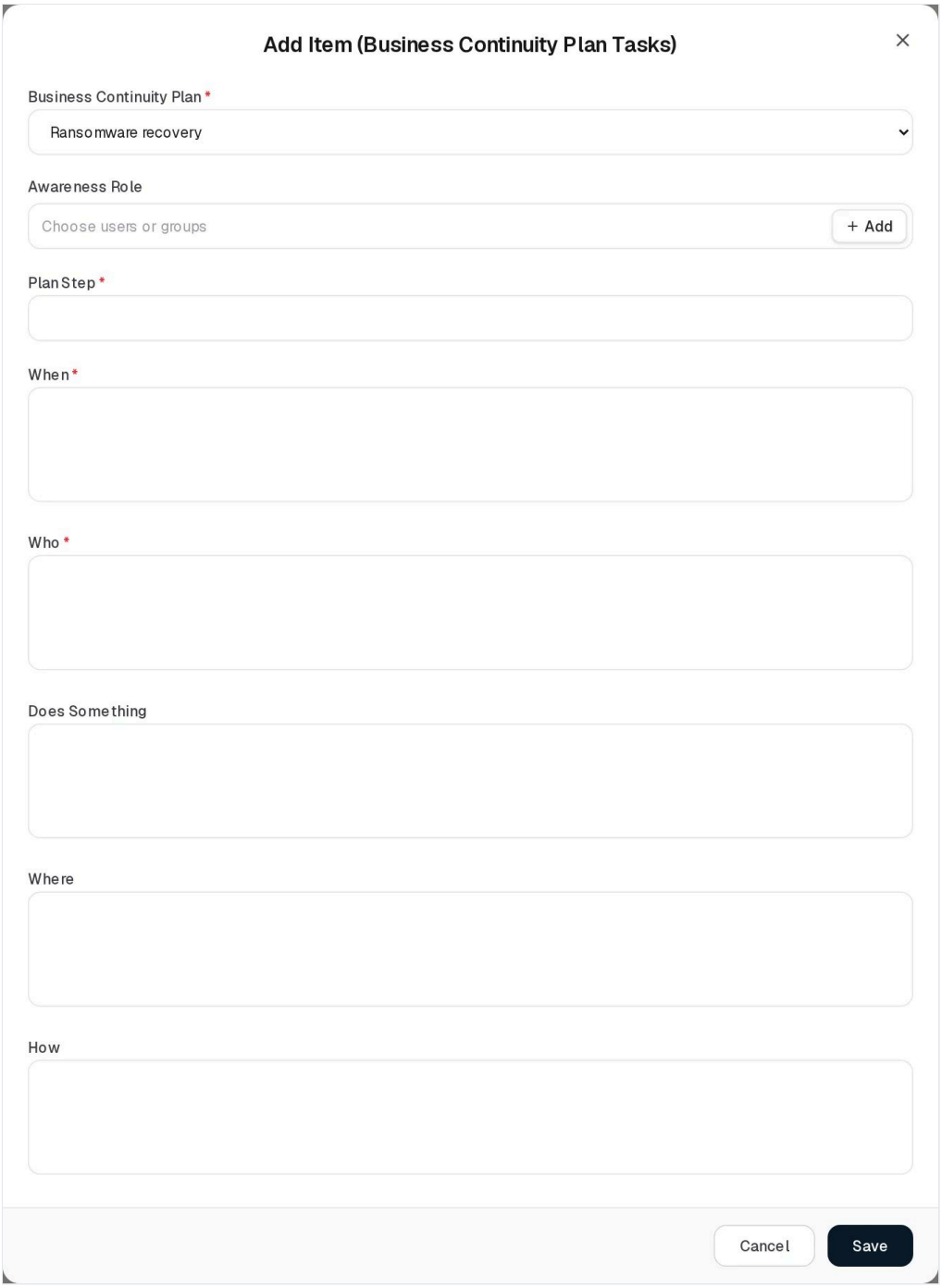
- A new audit opens with the selected plan's criteria filled in. Choosing another plan in the form replaces the text with that plan's criteria.
- An existing audit opens with its own criteria.
- When an audit is saved with criteria that are not blank and differ from the plan's, the text is written back to the plan's **Audit Success Metric Criteria**. On an edit this happens only if the audit's own criteria were changed, so re-saving an older audit for another reason does not roll the plan back. Blank criteria never overwrite the plan.
- Writing back is an edit of the plan, so it needs Manage on Continuity Plans in addition to the audit rights.
- Audits generated by the schedule leave both **Audit Metric** and **Audit Success Metric Criteria** empty, for the auditor to fill in.

Tasks



Continuity Plan Tasks

Grid **Continuity Plan Tasks**: **Status**, **Business Continuity Plan**, **Plan Step**, **When**, **Who**, **Does Something**, **Where**, **How**.

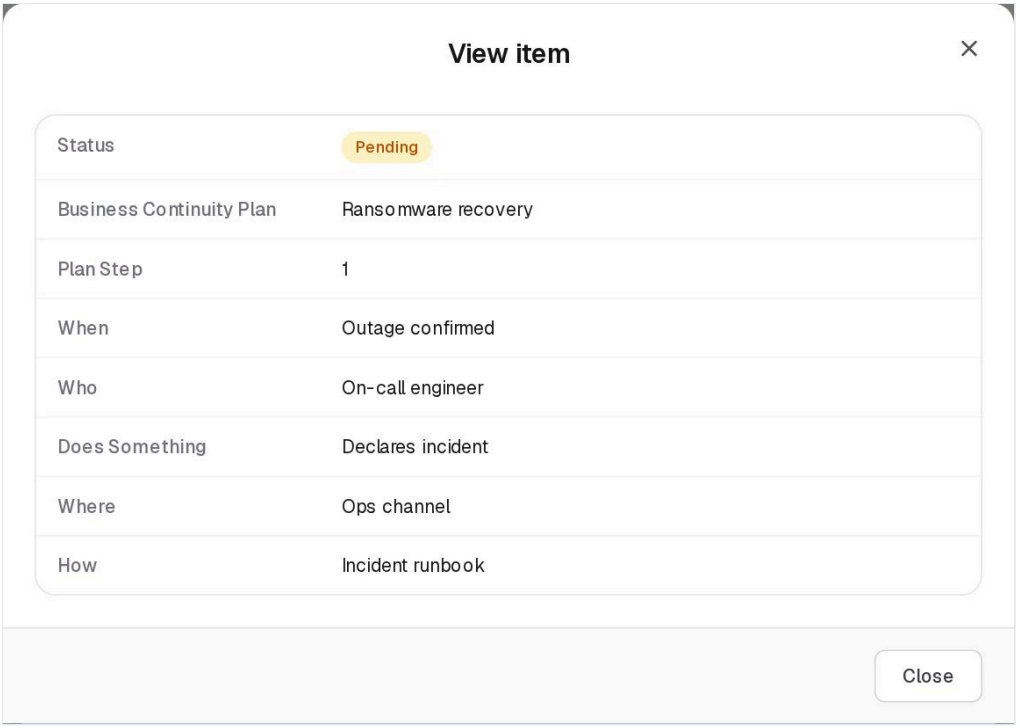


Add Continuity Plan Task

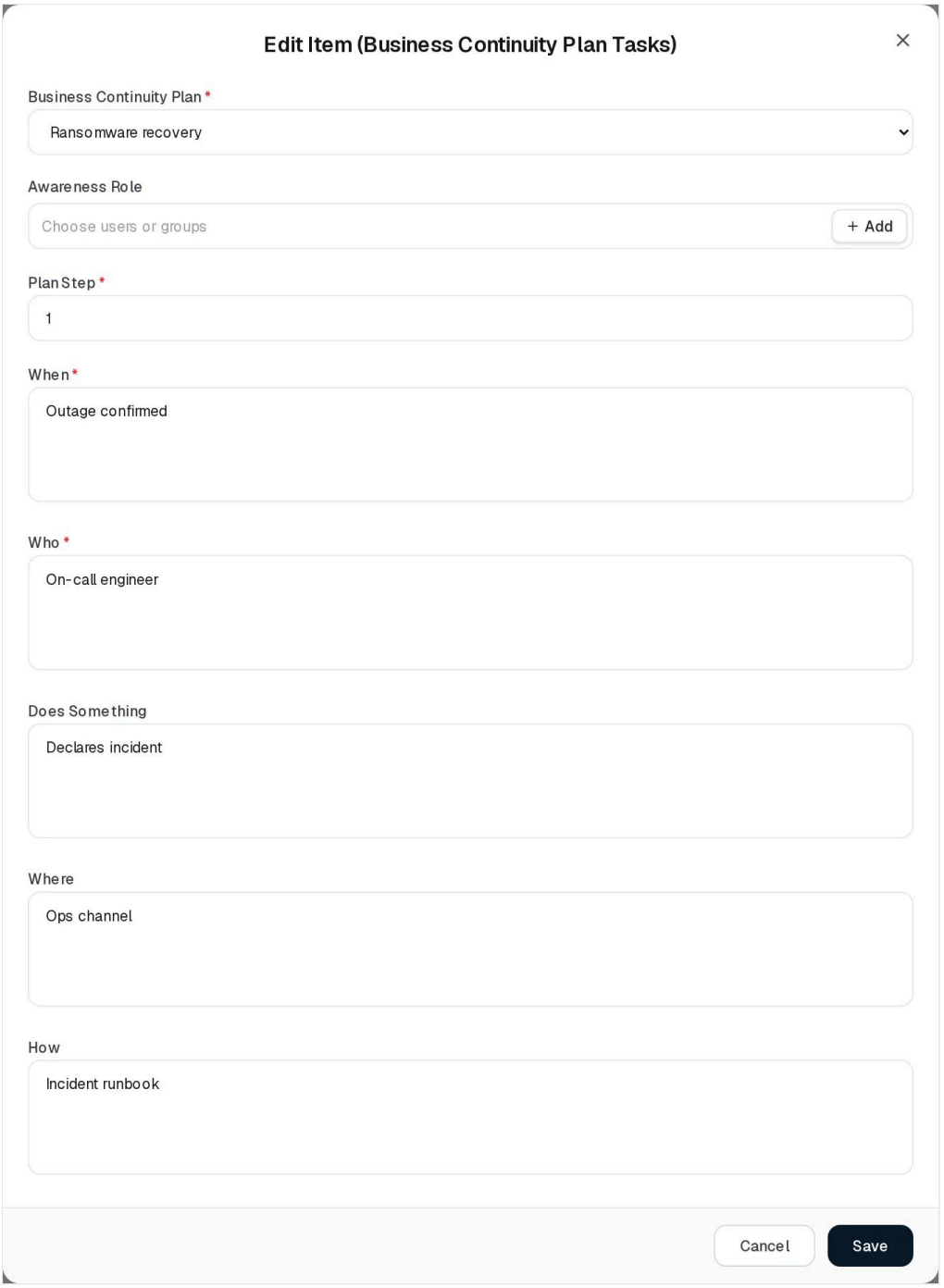
Field	Type	Required	Rules and allowed values	Example
Business Continuity Plan	Drop-down	Yes	“Business Continuity Plan is required.”	Ransomware recovery
Awareness Role	Users or groups	No	People and groups to be told about their responsibility; they receive an in-app notification (below).	
Plan Step	Text	Yes	“Required.” Read as a whole number: leading digits are kept (“3a” becomes 3) and text that does not start with a digit is saved as 0.	1

Field	Type	Required	Rules and allowed values	Example
When	Long text	Yes	“Required.”	Outage confirmed
Who	Long text	Yes	“Required.”	On-call engineer
Does Something	Long text	No	Also used as the notification text.	Declares incident
Where	Long text	No		Ops channel
How	Long text	No		Incident runbook

The Save button stays locked while the task is being saved; a failure is shown at the top of the dialog (“The task could not be saved.” if the server gives no reason). On success “Task added.” or “Task updated.” appears.

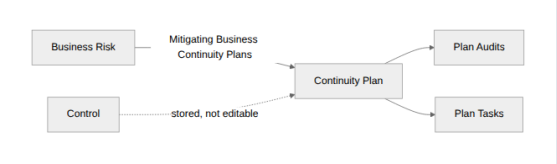


View Continuity Plan Task



Edit Continuity Plan Task

Relationships



Related record	Direction	How the link is made	Where it shows
Audits	One plan → many	Audits tab, or generated from the schedule	**Audits** count (not clickable), Audits tab
Tasks	One plan → many	Tasks tab	**Tasks** count (not clickable), Tasks tab

Related record	Direction	How the link is made	Where it shows
Business Risks	Many risks → many plans	**Mitigating Business Continuity Plans** on the business risk	Business Risks page only
Controls	Control → many plans	Stored on the control; no screen sets it	Not shown

Automations and notifications

- **Dynamic Status** of plans and audits is computed on read; an audit becomes Overdue, and its plan Audit Overdue, the day after the planned date passes.
- **Audit generation** from the schedule runs each time the plan is saved, including when an audit or task is deleted from the tabs (deletes are saves of the plan).
- **Task assignment notification.** When a task is added or edited on the Tasks tab and its **Awareness Role** names people or groups who were not named before, each of them (a group is expanded to its current members) receives an in-app notification of type `TASK_ASSIGNED`:
  - title “You are named in a continuity plan task”;
  - text “Step *n* of”*plan title*”: *Does Something*” (or “a step you are responsible for” when Does Something is empty);
  - action **Open the task**, which opens this page on the Tasks tab and shows the task in the read-only dialog **View Item (Business Continuity Plan Tasks)**. Editing a task without adding anyone sends nothing again. This is the only notification produced by the Control Center.
- No reminders are sent for upcoming or overdue plan audits.

Permissions

Action	Needed access
See the page	View on Control Center › Continuity Plans
Add or edit a plan	Manage on Continuity Plans
Delete a plan	Full Control on Continuity Plans
Open the Audits tab	View on Continuity Plans › Audits
Add or edit an audit	Manage on Audits; recording **Audit Result** / **Audit Conclusion** needs the Audit Results right (included in Manage); changing the criteria so that the plan is updated also needs Manage on Continuity Plans
Delete an audit	The button needs Full Control on Audits; the delete is saved as an edit of the plan, so Manage on Continuity Plans is also needed
Open the Tasks tab	View on Continuity Plans › Tasks
Add or edit a task	Manage on Tasks
Delete a task	The button needs Full Control on Tasks; saved as an edit of the plan (Manage on Continuity Plans)
Upload or delete audit evidence	Manage / Full Control on any Control Center page (checked at module level)
Comment and attach in the Activity Log	The group’s Comments & Attachments level

Continuity Plans is not a visibility register: everyone who can open the page sees every plan. The people fields are not subject to Can Assign / Can Reassign.

How to

Create a plan and schedule its tests

1. Click **Add Item**. Enter **Title** “Ransomware recovery” and the **Objective**.
2. Choose **Owner**, **Sponsor** and **Launch Initiator** (all three are required).
3. Fill **Launch Criteria**, costs, **Audit Methodology** and **Audit Success Metric Criteria** “RTO met”.

4. Set **Status** to **Production**. The **Audits** section appears.
5. Select **Audits required**, **Periodical**, **First audit date** and **Frequency TWICE_A_YEAR**; pick **Audit Owners**. Click **Save**. The Audits tab shows three audits, six months apart.

Record a recovery test

1. Open the **Audits** tab and click **Edit** on the **Ransomware recovery** audit planned for 2026-11-03.
2. Check **Audit Metric** (“Failover time”) and **Audit Success Metric Criteria** (“Under 4 hours”).
3. Fill **Audit Start Date** and **Audit End Date**, choose **Audit Result Passed**, write the **Audit Conclusion** and attach the test report under **Evidence**.
4. Click **Save**. The audit’s Status becomes **Completed** and its Dynamic Status **Pass**.

Add a task and notify the people responsible

1. Open the **Tasks** tab and click **Add Item**.
2. Choose the plan, pick a group in **Awareness Role**, enter **Plan Step** “3”, **When**, **Who** and **Does Something** “Restores database from backup”.
3. Click **Save**. Every member of the group receives “You are named in a continuity plan task” in the notification bell.

Change the success criteria for future tests

1. Edit any audit of the plan and change **Audit Success Metric Criteria**, or edit the plan itself.
2. After saving, the plan’s **Audit Success Metric Criteria** column shows the new text, and new audits added from the Audits tab start with it.

CSV import

Not available. **Import CSV** on the three grids shows “CSV Import (*title*): the import structure is not ready yet.” and then opens a demonstration dialog whose validation fails. The backend import endpoint `/control/continuity-plans/import-csv` is not used by any screen. See CSV import and export.

Limitations and known issues

- **Frequency shows raw codes.** The **Frequency** drop-down of the plan’s audit schedule lists WEEKLY, MONTHLY, QUARTERLY, TWICE_A_YEAR and YEARLY instead of readable labels (the control form shows “Twice a Year” and so on).
- **Plans with an older status open as “Design”.** The demo plans are stored with status “ACTIVE”, which is not one of the two form options. Their Edit form shows **Design** and hides the audit schedule, and saving keeps the old value. Because the schedule only applies to Production plans, such a save withdraws generated audits that have no result. Set **Status** to **Production** explicitly when editing these plans.
- **Task Status cannot be changed.** The task form has no Status field, so every task stays **Pending**.
- **Expired depends on a hidden field.** Dynamic Status **Expired** uses the plan’s review date, which no screen shows or edits.
- **Audit Result list is fixed.** The organisation’s continuity audit result list exists on the server but has no Settings button; the form always offers Passed and Failed.
- **Deleted generated audits come back.** Deleting a generated audit whose date is still in the schedule and has no result re-creates it on the same save.
- **Moving a task or audit to another plan is refused** by the server, although the plan drop-down is editable on Edit.
- **Mandatory people are not enforced by the server.** Owner, Sponsor and Launch Initiator are checked by the form only.

Risk Management

> **Module:** Risk Management · **Route:** `/risk-management/...` · **Permission module key:** `risk_management`

Risk Management holds the organisation's risk registers. Each register records risks of one kind, analyses them on a likelihood and an impact scale, scores them, records how they are treated, and compares the result with the organisation's risk appetite. Risk Exceptions record the formal acceptance of a risk for a limited time.

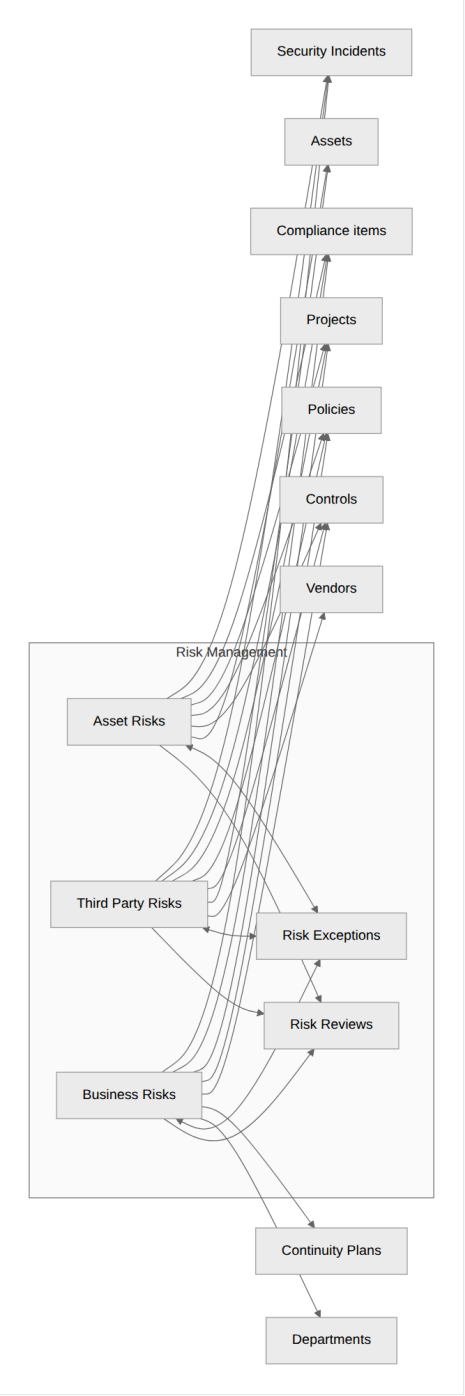
This page explains what the module contains and, in detail, how a risk is scored. The individual pages are described in their own chapters.

Pages in this module

Page (sidebar label)	Route	Permission key	Tabs	What a record is
Asset Risks	`/risk-management/asset-risks`	`risk_management.asset_risks`	**Reviews** (`asset_risks_reviews`)	A risk to one or more assets
Third Party Risks	`/risk-management/third-party-risks`	`risk_management.third_party_risks`	**Reviews** (`third_party_risks_reviews`)	A risk that comes from a vendor, supplier or partner
Business Risks	`/risk-management/operational-risks`	`risk_management.operational_risks`	**Reviews** (`operational_risks_reviews`)	A risk to a department's operations
Risk Exceptions	`/risk-management/risk-exceptions`	`risk_management.risk_exceptions`	None	A time-limited acceptance of one or more risks

Business Risks is the label the user sees. The route, the permission key and the API still use the older name *operational risks* (`operational_risks`). Both names refer to the same register.

The three risk registers share one form layout (general fields, **Analysis**, **Treatment**), one scoring model, one **Dynamic Status** rule set, one **Reviews** tab design and one **Settings** panel. These shared parts are described once on this page.

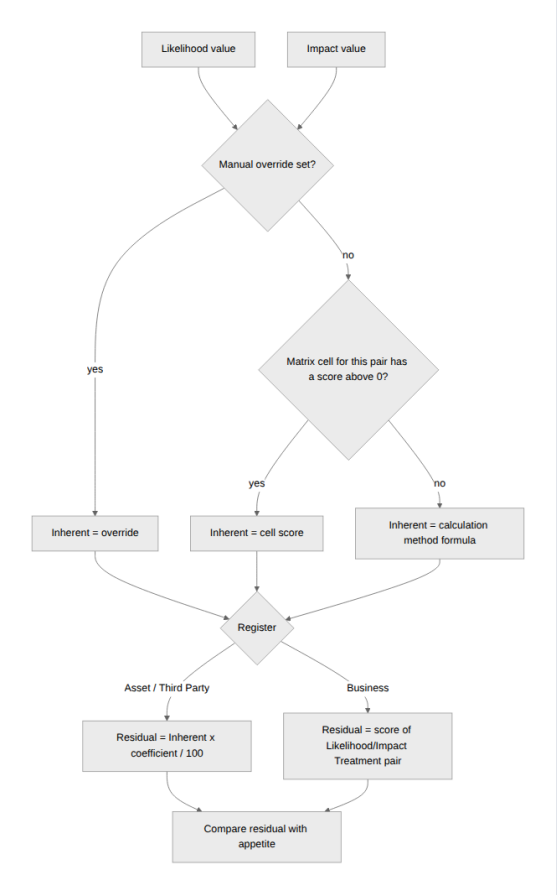


The risk scoring model

A risk gets two scores:

- **Inherent Risk Score**: the risk before treatment, from the **Likelihood (Analysis)** and **Impact (Analysis)** chosen on the form.
- **Residual Risk Score**: the risk after treatment.

Both scores are calculated by the server **when the risk is saved** and stored with it. They are not recalculated when the settings change: after you change a calculation method, a classification value or a matrix cell score, each risk keeps its old score until it is edited and saved again.



Classification types and classifications

Likelihood and impact are **classification types**. Each type has **classifications**: named levels with a numeric **Value**. Every new tenant starts with:

Classification type	Classifications (Value)
Likelihood	Rare (1), Unlikely (2), Possible (3), Likely (4), Almost certain (5)
Impact	Negligible (1), Minor (2), Moderate (3), Major (4), Critical (5)

Only the **Value** takes part in the arithmetic. The name is what you pick on the form and what the register shows, for example as the tags **Likelihood (Likely)** and **Impact (Major)** in the **Inherent Risk Classification** column.

The **Likelihood** and **Impact** pickers on the risk forms list the classifications of the two types whose internal code is `LIKELIHOOD` and `IMPACT` (the two types every tenant starts with). A type you add yourself appears in Settings but its values are not offered on the risk forms.

Calculation methods

The calculation method turns the two values into the inherent score. The **Calculation Methods** tab of Settings offers three methods:

Method	Formula used today	Example: Likely (4), Major (4)
Single Matrix - Addition	likelihood + impact	4 + 4 = **8**
Single Matrix - Multiplication	likelihood × impact	4 × 4 = **16**
Multiple Matrices - Multiplication	likelihood × impact (a risk holds one impact, so it gives the same result as Multiplication)	4 × 4 = **16**

If none of the three methods is enabled, the server multiplies. A new tenant is seeded with a fourth method row, code `THRESHOLD`, named **Threshold Matrix Method**, enabled. It is not one of the three tabs and has no formula of its own, so while it is the enabled method risks are scored by multiplication. This is the state of the demo data: every demo score is likelihood × impact.

The classification types you select under **Settings** for a method are stored but not read by the scoring; every method always uses the risk's one likelihood and one impact.

Matrix cell scores

A cell of the likelihood × impact matrix (Settings › **Risk Appetite** › **Threshold**) can carry its own **Score**. When the cell for a risk's pair has a score greater than 0, that score is used instead of the method's formula. A cell saved without a score stores 0 and does not affect scoring.

Example: you give the cell **Likely × Major** the score **18**. The next time "Unpatched internet-facing server" (Likely, Major) is saved, its inherent score becomes 18 instead of 16.

Manual score override

The API accepts a `manualScoreOverride` and an `overrideReason` on every risk. When an override is set, it becomes the inherent score whatever the likelihood and impact are. The Add and Edit forms do not have these fields, so an override can only be set through the API, and it is shown only in the **Manual Override** section of the linked-risk panel that other registers open (see Asset Risks).

Because the form does not send the override, saving the risk from its Edit form clears an override that was set through the API, and the score falls back to the formula.

Residual score

Register	How the residual score is calculated
Asset Risks, Third Party Risks	**Residual Percentage Coefficient** (0, 10, 20 … 100) is the percentage of the inherent score that remains after treatment. Residual = inherent × coefficient / 100. With no coefficient, residual = inherent.
Business Risks	When both **Likelihood (Treatment)** and **Impact (Treatment)** are chosen, the residual score is calculated from that pair exactly like the inherent score (matrix cell score first, then the method formula; the manual override does not apply). If either is empty, residual = inherent.

Worked examples:

Risk	Inherent	Treatment input	Residual
Unpatched internet-facing server (Likely 4, Major 4)	4 × 4 = 16	Coefficient 30	16 × 30 / 100 = **4.8**
Same risk	16	Coefficient 0	**0**
Same risk	16	Coefficient empty or 100	**16**
Manual payroll errors (Likely 4, Moderate 3)	4 × 3 = 12	Likelihood (Treatment) Unlikely 2, Impact (Treatment) Minor 2	2 × 2 = **4**
Same risk	12	Only Likelihood (Treatment) chosen	**12**

For Business Risks nothing stops the treatment pair from scoring higher than the inherent pair.

Risk appetite

The appetite is set in Settings › **Risk Appetite**, which has two methods. Exactly one is in use; it is recorded on the tenant's appetite setting.

Method	What you configure	What it affects
Threshold (in use by default)	A label, description and colour for each likelihood × impact cell, and a **Default Threshold** for cells without their own	The coloured chips in the **Inherent Risk Score** and **Residual Risk Score** columns

Method	What you configure	What it affects
Numerical	One number	Nothing visible on the score columns: no chips are shown while Numerical is in use

The **Above Appetite** flag always compares the residual score with the **Numerical** number, whichever method is in use. A new tenant's number is **50**. With the default 1 to 5 scales and multiplication the highest possible score is 25, so no risk can be above appetite until the number is lowered. This is why no demo risk shows **Above Appetite**.

Example: you set the numerical appetite to **15**. "Unpatched internet-facing server" (residual 16) shows **Above Appetite**; "Ransomware on file servers" (residual 15) does not, because the score must be strictly greater than the appetite.

A second value, *residual threshold* (30 for a new tenant), is stored on the appetite setting but nothing uses it.

Appetite thresholds and the score chips

A threshold is a label, a description and a colour. It counts as configured when any of the three is filled in. For each risk the server decides which threshold applies:

1. If the appetite method is **Numerical**, no threshold is shown.
2. If the risk has no likelihood or no impact, no threshold is shown.
3. If the matrix cell for the pair has a configured threshold, that one is used.
4. Otherwise, if the **Default Threshold** is configured, it is used and the chip shows a small *default* marker.
5. Otherwise no threshold is shown.

In the register the score column then shows a chip with the threshold's label and the score on the threshold's colour; the description appears as the tooltip. Without a threshold the column shows the plain number.

The residual chip follows its own rule:

Register	Residual Risk Score chip
Asset Risks, Third Party Risks	The inherent threshold when the coefficient is empty or 100. When the coefficient reduces the score, no threshold (plain number), because a percentage-reduced score belongs to no cell.
Business Risks	The threshold of the treatment likelihood × impact pair when both are chosen; otherwise the inherent threshold.

Worked example: the Default Threshold is "Low" (green) and the cell **Likely × Major** is "High" (orange, description "Needs a treatment plan within 30 days").

Risk	Inherent Risk Score column	Residual Risk Score column
Unpatched internet-facing server (Likely, Major), no coefficient	chip **High 16**	chip **High 16**
Same risk, coefficient 30	chip **High 16**	plain **4.8**
Expired TLS certificate (Likely, Minor)	chip **Low 8** with *default* marker	chip **Low 8** *default*

In the demo data no threshold is configured, so every score is a plain number.

Classification tags

The **Inherent Risk Classification** column shows the chosen analysis levels as two grey tags, for example **Likelihood (Likely) Impact (Critical)**. Business Risks has a second column, **Residual Risk Classification**, with the treatment pair. An empty pair shows `--`.

Dynamic Status of a risk

The **Dynamic Status** column of each risk register shows every problem that currently applies to the risk, one chip per problem, in this order. The server works them out each time the register is read, so date-based flags appear without anyone editing the risk.

Flag	Colour	Rule
Above Appetite	Red	The residual score (the inherent score if there is no residual) is greater than the **Numerical** appetite. No flag when no appetite number is set.
Review Expired	Amber	The risk has at least one review whose **Planned Date** is before today and which has no **Actual Date**.
No Treatment	Amber	**Risk Treatment** is empty.
Exception Expired	Amber	A risk exception listed under **Treatment: Risk Exceptions** has an **Expiration Date** before today and no **Closure Date**.
Control Last Audit Expired	Amber	A control listed under **Treatment: Controls** has an audit whose planned start is before today and that has no audit end date.

When none applies, the cell shows `--`. Example from the demo data: “DDoS on customer portal” has a Next Review Date of 12 Oct 2026; its review planned for that day has no actual date, so from 13 Oct 2026 the risk shows **Review Expired**.

The stored status

Separately, every risk stores a single dynamic status value, set when the risk is saved (and when a linked exception is approved, denied, expired or deleted). It is not shown in the register; it appears as **Dynamic Status** in the linked-risk panel opened from other registers, and it is what Compliance Analysis and the Command Center count. It is decided in this order:

Value	Rule
Closed	The risk’s lifecycle status is CLOSED
Exception Active	**Treatment: Risk Exceptions** lists at least one exception
Above Appetite	Residual score greater than the numerical appetite (50 when none is stored)
Review Due	**Next Review Date** is today or earlier
On Track	None of the above

Because this value is only refreshed on save, it can lag behind the register’s flags. Example: “DDoS on customer portal” still stores **On Track** although its review date has passed.

The lifecycle status (OPEN, UNDER_REVIEW, TREATMENT_PLANNED, TREATMENT_IN_PROGRESS, ACCEPTED, CLOSED, ARCHIVED; default OPEN) is not on the forms. It can be set only through the API and is shown only as **Status** in the linked-risk panel.

Risk Reviews

Each risk register has a **Reviews** tab. A review is a planned check of one risk: a planned date, an actual date when it was carried out, the reviewers and a description. All three tabs work the same way; see Asset Risks › Reviews for the screens and fields.

Reviews created automatically. Every time a risk is saved, the server makes sure it has a review planned for its **Next Review Date** and one for the same day a year later. Dates already in the past are skipped. Reviews that were generated this way and not yet carried out are moved when the date changes; reviews added by hand on the tab, and reviews with an **Actual Date**, are never removed. Example: “Unauthorized access” has Next Review Date 4 Nov 2026, so its Reviews tab lists reviews planned for 4 Nov 2026 and 4 Nov 2027.

Review Dynamic Status (computed when read):

Value	Colour	Rule
Completed	Green	Actual Date is set

Value	Colour	Rule
Expired	Red	Planned Date is before today and there is no Actual Date
Planned	Blue	Otherwise

An expired review makes its risk show **Review Expired**. The register's **Reviews** column shows how many reviews the risk has. Deleting a risk deletes its reviews.

Settings (the gear button)

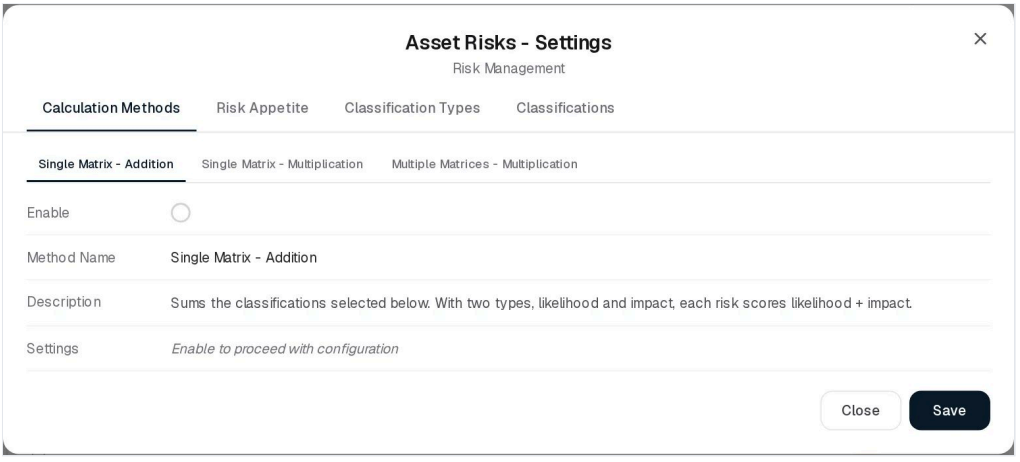
Each risk register has a round gear button (**Settings**) beside **Import CSV** and **Add Item**. It opens the dialog **- Settings** (subtitle *Risk Management*). The settings are shared by all three registers: changing them on Asset Risks changes them for Third Party Risks and Business Risks too.

The dialog has four tabs: **Calculation Methods**, **Risk Appetite**, **Classification Types**, **Classifications**. Successful changes show a green message, for example "Calculation method saved." or "Risk thresholds saved."

Calculation Methods

One sub-tab per method (**Single Matrix - Addition**, **Single Matrix - Multiplication**, **Multiple Matrices - Multiplication**). Each shows:

Row	Content
Enable	A radio button. Saving a method with **Enable** on switches every other method off, including the seeded *Threshold Matrix Method*.
Method Name	The method's name
Description	What the method does
Settings	"Enable to proceed with configuration" until **Enable** is on. Then a notice ("After re-saving a calculation the system takes any available classification from the selected types below and recalculates all risks.") and the type selection: chips for the two Single Matrix methods; a **Likelihood** dropdown and **Impact** chips for Multiple Matrices.



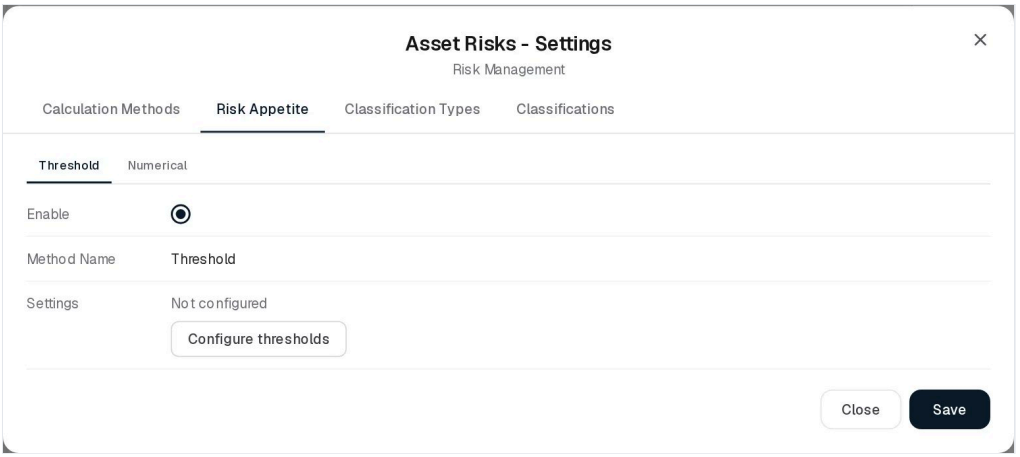
Settings: Calculation Methods

In the demo tenant all three methods show **Enable** off, because the enabled method is the seeded *Threshold Matrix Method*, which has no tab of its own.

Buttons: **Close**, **Save**. Despite the notice, saving a method does not recalculate existing risks; see Known issues.

Risk Appetite

Two sub-tabs, **Threshold** and **Numerical**.



Settings: Risk Appetite

Threshold. Enable (clicking it switches the appetite method to Threshold immediately), **Method Name** “Threshold”, and **Settings**, which shows:

- “The matrix appears once two classification types have values. Add them on the Classifications tab.” when the first two classification types do not both have values;
- “The matrix appears once a calculation method is enabled. …” when no method is enabled;
- “Not configured” and a **Configure thresholds** button when no threshold exists yet (the demo state);
- otherwise the matrix, titled **Likelihood x Impact**.

The matrix has the likelihood levels across the top, lowest first (**Likelihood (Rare)** … **Likelihood (Almost certain)**), and the impact levels down the side, worst first (**Impact (Critical)** … **Impact (Negligible)**). The axes are the first and second classification types in the list. The corner cell is the **[Default Threshold]**. Each cell shows its threshold label (or the default’s, marked *default*), its description and “Score N” (the cell’s own score, or likelihood value × impact value).

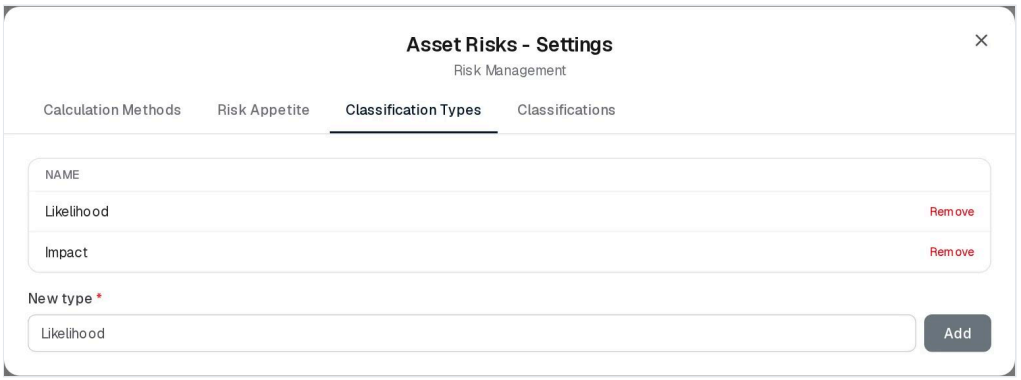
A small gear in each cell opens an editor:

Field	Notes
Threshold label	Free text, up to 50 characters
Description - what this combination means	Free text, shown as the chip’s tooltip in the registers
Score (default N)	Cells only. A number above 0 replaces the formula score for this pair (see Matrix cell scores).
Colour	Five swatches: green `#DCFCE7`, yellow `#FEF9C3`, orange `#FED7AA`, red `#FEE2E2`, indigo `#E0E7FF`
Clear	Empties the cell or the default

Save stores the whole matrix and the Default Threshold together.

Numerical. Enable, **Method Name** “Numerical”, a **Description**, and a number field under **Settings**. **Save** stores the number and switches the appetite method to Numerical. The number is the one **Above Appetite** uses in both methods.

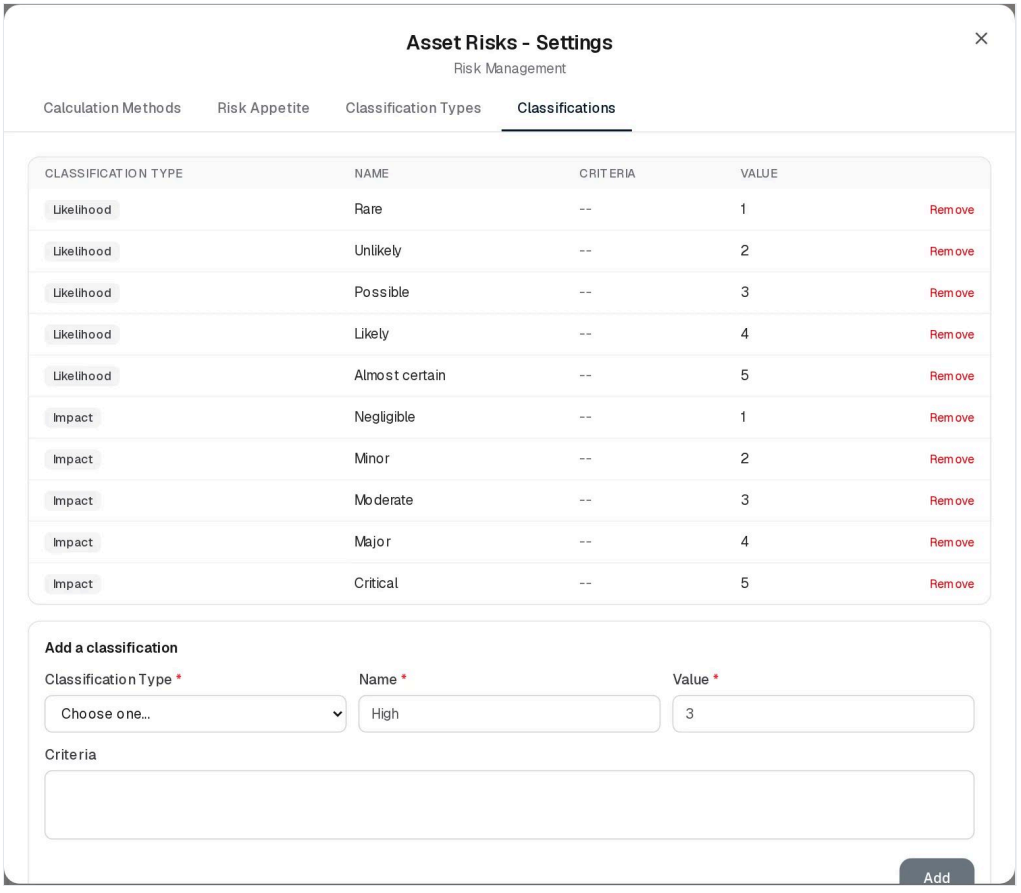
Classification Types



Settings: Classification Types

A **Name** list of the types (Likelihood and Impact in a new tenant) with a **Remove** link each, and a **New type** field (required; the grey “Likelihood” is only a placeholder) with an **Add** button that stays disabled until a name is typed. **Remove** asks for confirmation (“Delete ?”). This tab and the next have no Close or Save buttons; each **Add** and **Remove** is saved at once.

Classifications



Settings: Classifications

A table with **Classification Type** (shown as a grey tag), **Name**, **Criteria** (`--` when empty), **Value** and a **Remove** link, and an **Add a classification** form below it (“High” and “3” in the screenshot are placeholders):

Field	Required	Notes
Classification Type	Yes	Dropdown of the types
Name	Yes	For example “High”
Value	Yes	Number used in the scoring

Field	Required	Notes
Criteria	No	Text describing when the level applies

Add stays disabled until type, name and value are filled in.

Who can change the settings

Anyone who can open a risk register can open the dialog and read the settings. Saving any change needs **Full Control** (the *Manage Section Settings* right) on at least one of the three risk registers.

Automations in this module

What	When	Effect
Score calculation	On every save of a risk	Inherent and residual scores, stored dynamic status
Review schedule	On every save of a risk	Reviews for the Next Review Date and one year later
Dynamic Status flags, review and exception Dynamic Status	Every time a register is read	Computed live; no job needed
Linked compliance items	On every save of a risk that lists **Affected Compliance Items**	The linked requirements' assessment result is set to Non Compliant when a linked risk's stored status is Above Appetite, otherwise Compliant (Not Applicable items are left alone)
Risk exception expiry (`RiskExceptionScheduler`, hourly)	Implemented but **not active in this release**	See Risk Exceptions

No notification is sent for any risk, review or risk exception event.

Known issues

- Scores are not recalculated when settings change; each risk keeps its old score until it is saved again. The notice on the Calculation Methods tab says otherwise.
- The seeded *Threshold Matrix Method* is enabled in every tenant but is not one of the three method tabs, so the tabs all show **Enable** off while scoring uses multiplication.
- The matrix cells always show "Score" as likelihood × impact, even when the Addition method is in use.
- **Above Appetite** uses the numerical appetite (50 by default), which is above the maximum score of the default 5 × 5 scales.
- The stored dynamic status (used by Compliance Analysis and the Command Center) is computed only on save and gives an attached exception precedence over the appetite, so it can disagree with the register's flags.
- The manual score override exists only in the API and is cleared when the risk is saved from the form.

Related pages

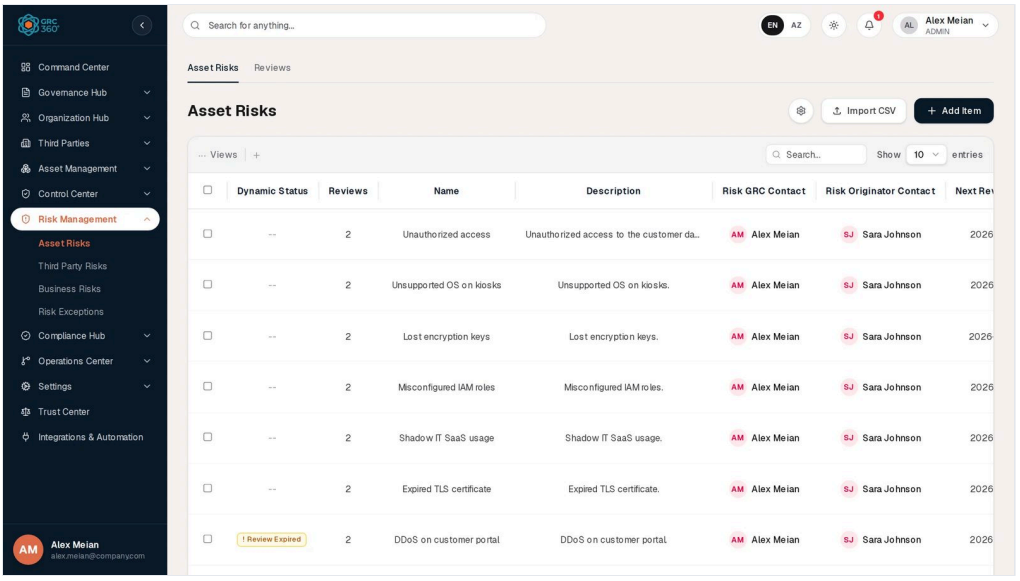
- Working with registers: toolbar, Views, search, paging, selection, Activity Log, pickers.
- Permissions and access: access levels and Assignment Management.
- Key concepts › Risk terms.

Asset Risks

> **Module:** Risk Management › Asset Risks · **Route:** `/risk-management/asset-risks` · **Permission key:** `risk_management.asset_risks`

The Asset Risks register lists the risks to the organisation's information assets. A record is one risk, for example "Unauthorized access" to the customer database: who is responsible for it, which assets it threatens, how likely and how severe it is, how it is treated, and what remains after treatment. Risk owners and the GRC team work in it; auditors read it.

How the scores, the appetite and the Dynamic Status flags are worked out is explained once in the Risk Management overview. This page describes the register itself.



Asset Risks register

At a glance

A record is	One risk to one or more assets
Typical owner	The person named as **Risk GRC Contact** (GRC team), with the **Risk Originator Contact** who raised it
Links to	Assets, Controls, Policies, Risk Exceptions, Projects, Compliance items (requirements), Security Incidents, users and groups
Linked from	Risk Exceptions, Assets, Controls, Policies & Standards, Projects, Departments, Security Incidents, Data Flows, Compliance Analysis
Tabs	**Asset Risks**, **Reviews**
Automations	Scores and stored status on save; reviews generated from the Next Review Date; Dynamic Status flags computed on read; linked compliance items re-evaluated on save

The register (list view)

The page opens on the **Asset Risks** tab. Above the grid are the round **Settings** gear (the shared risk settings, see Settings), **Import CSV** and **Add Item**. Search, **Views**, paging, row selection and the row buttons (View, Activity Log, Edit, Delete) work as described in Working with registers. The search box matches the **Name** and **Description**. The grid is paged on the server, 10 rows by default.

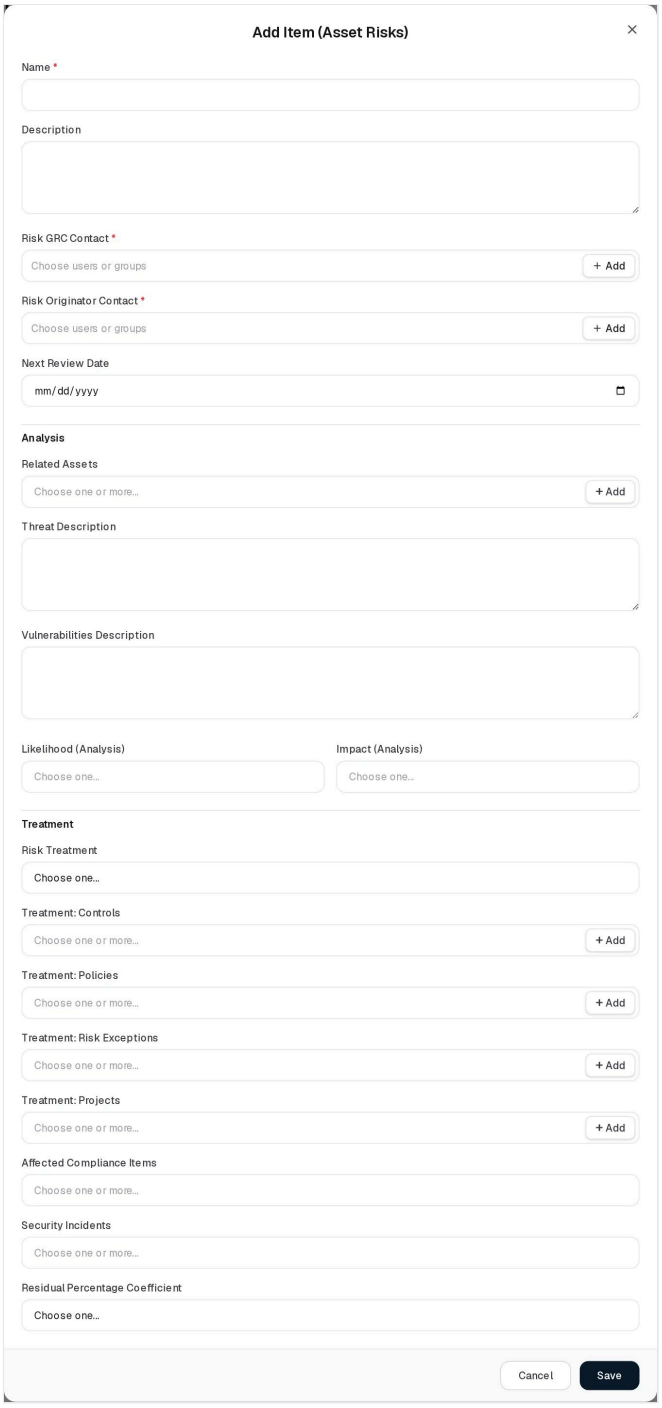
Column	What it shows	Source
Dynamic Status	One chip per problem that applies: **Above Appetite** (red), **Review Expired**, **No Treatment**, **Exception Expired**, **Control Last Audit Expired** (amber); `--` when none. Rules in Dynamic Status of a risk.	Computed by the system
Reviews	Number of reviews of this risk on the **Reviews** tab	Computed
Name	Name of the risk	Entered
Description	Description	Entered
Risk GRC Contact	Users or groups responsible, with avatar	Entered
Risk Originator Contact	Users or groups who raised the risk, with avatar	Entered
Next Review Date	Date of the next review (YYYY-MM-DD)	Entered
Related Assets	Names of the assets at risk	Linked
Inherent Risk Classification	Tags **Likelihood (…)** and **Impact (…)** from the analysis	Entered
Inherent Risk Score	Score before treatment; a coloured threshold chip when an appetite threshold applies, otherwise the number	Computed
Risk Treatment	MITIGATE, ACCEPT, TRANSFER, AVOID (older records may show MONITOR)	Entered
Treatment Risk Exceptions	Names of the risk exceptions in the treatment	Linked
Treatment Internal Controls	Names of the treating controls	Linked
Treatment Projects	Names of the treating projects	Linked
Treatment Policies	Names of the treating policies	Linked
Affected Compliance Items	Requirements this risk puts at stake	Linked
Residual Risk Score	Score after treatment; a threshold chip only when the coefficient is empty or 100	Computed

Linked names in this grid are plain text; they do not open the linked record.

Example from the demo data: “DDoS on customer portal” shows **Review Expired** because its review planned for 12 Oct 2026 has no actual date.

Creating a record

Click **Add Item**. The form **Add Item (Asset Risks)** opens in a dialog. It is one scrolling form with three parts: general fields, **Analysis** and **Treatment**.



Add Asset Risk

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Must not be blank: “Name is required”	Unauthorized access
Description	Long text	No		Unauthorized access to the customer database through compromised admin credentials.
Risk GRC Contact	Users or groups, several	Yes	“Risk GRC Contact is required”. Naming someone other than yourself needs **Can Assign**; changing who is named needs **Can Reassign**.	Alex Meian

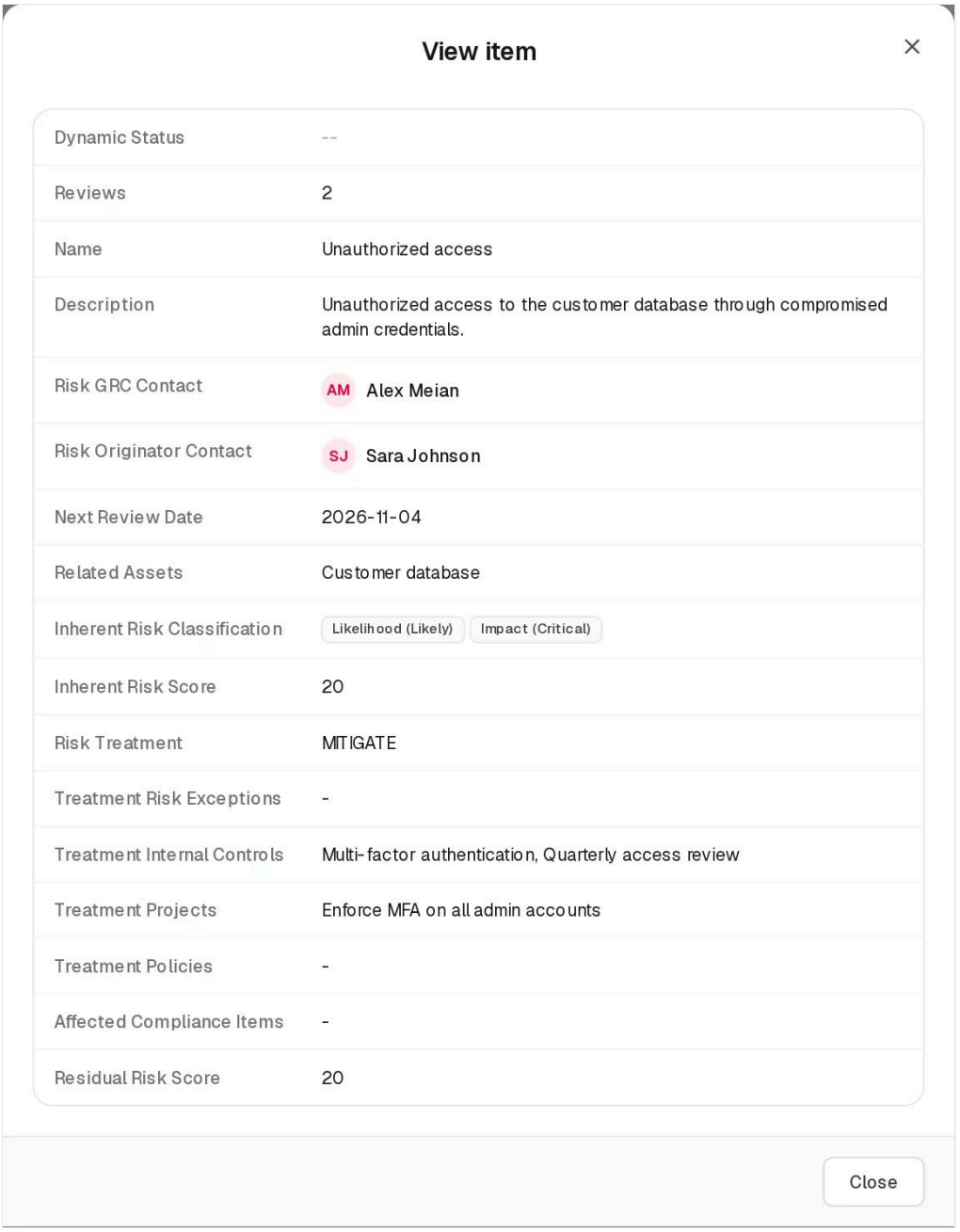
Field	Type	Required	Rules and allowed values	Example
Risk Originator Contact	Users or groups, several	Yes	“Risk Originator Contact is required”. Same assignment rule.	Sara Johnson
Next Review Date	Date	No	1900 to 2999: “Enter a valid date between 1900 and 2999”. Generates reviews, see Reviews.	2026-11-04
Analysis				
Related Assets	Assets, several	No	Picker with **+ Add** (creates an asset)	Customer database
Threat Description	Long text	No		Credential theft, password reuse
Vulnerabilities Description	Long text	No		Admin accounts without MFA
Likelihood (Analysis)	One classification	No	Values of the Likelihood type: Rare, Unlikely, Possible, Likely, Almost certain. No **+ Add**: values are managed in Settings.	Likely
Impact (Analysis)	One classification	No	Values of the Impact type: Negligible, Minor, Moderate, Major, Critical	Critical
Treatment				
Risk Treatment	Dropdown	No	Choose one…, MITIGATE, ACCEPT, TRANSFER, AVOID. Empty gives the **No Treatment** flag.	MITIGATE
Treatment: Controls	Controls, several	No	Picker with **+ Add**	Multi-factor authentication, Quarterly access review
Treatment: Policies	Policies & Standards, several	No	Picker with **+ Add**	
Treatment: Risk Exceptions	Risk exceptions, several	No	Picker with **+ Add**. Any entry makes the stored status Exception Active.	
Treatment: Projects	Projects, several	No	Picker with **+ Add**	Enforce MFA on all admin accounts
Affected Compliance Items	Compliance package requirements, several	No	Listed as “ · ”. No **+ Add**. Unknown ids are rejected.	ISO/IEC 27001:2022 · A.5.15 Access control
Security Incidents	Security incidents, several	No	No **+ Add**. Only existing incidents are kept.	Suspicious login from unknown country
Residual Percentage Coefficient	Dropdown	No	Choose one…, 0, 10, 20 … 100: the percentage of the inherent score that remains	30

The scores are not entered; they are calculated when you click **Save** (see Residual score). Example: Likely (4) × Critical (5) = 20, coefficient 30 gives a residual score of 6.

When a required field is missing, the form marks it in red and a message lists the reasons. People pickers, record pickers and **+ Add** are described in Working with registers. On success the message “Asset risk added.” appears.

Viewing and editing a record

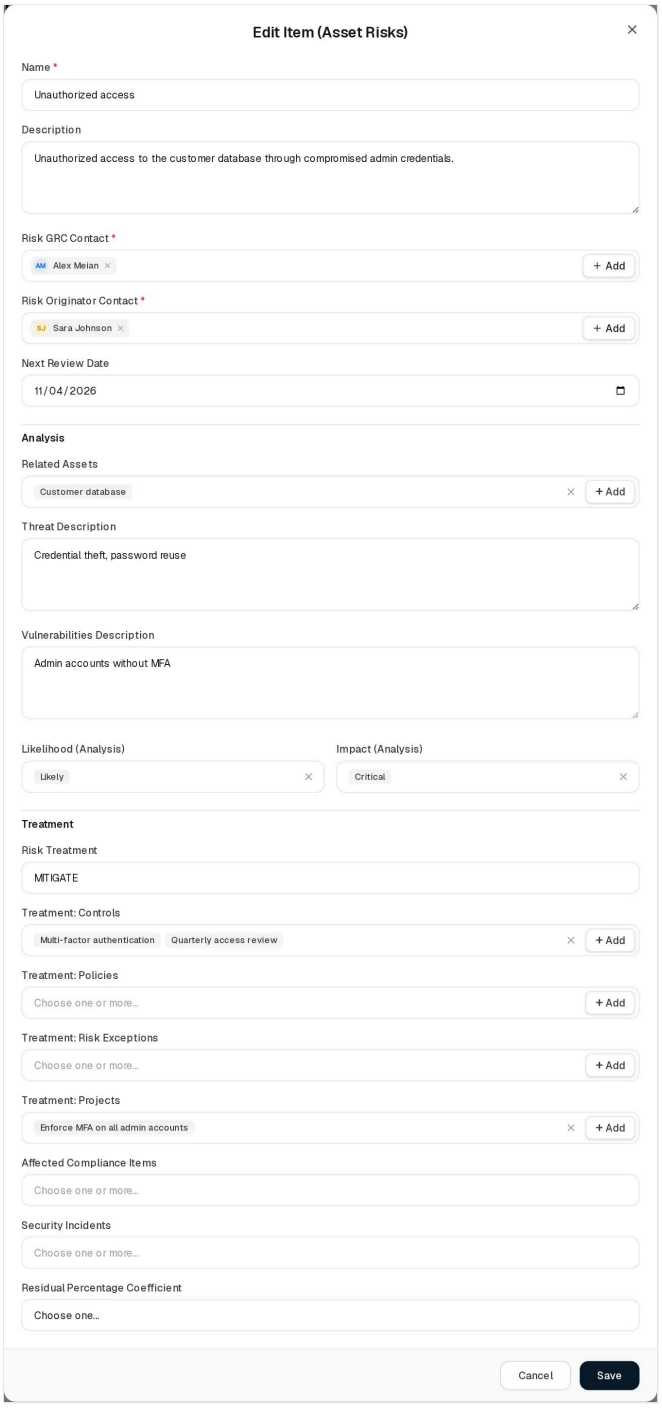
The eye button opens **View item**, a read-only list of the grid’s columns for that risk.



View Asset Risk

The view shows the same values as the grid, so the threat and vulnerability descriptions, the coefficient and the security incidents are not in it; open **Edit** to see them.

Edit opens **Edit Item (Asset Risks)**, the same form filled with the stored values. Saving recalculates both scores, re-generates the review schedule and shows “Asset risk updated.”



Edit Asset Risk

Points to know when editing:

- The scores are recalculated with the current settings, so a risk saved after a settings change can get a different score although you changed nothing on it.
- A manual score override set through the API is cleared, because the form does not carry it.
- A record whose treatment is MONITOR (an older value, for example “Shadow IT SaaS usage”) shows **Choose one…** in the **Risk Treatment** dropdown, but MONITOR is kept unless you pick another value.

Delete asks “Delete asset risk ?”. Deleting removes the risk from the register (soft delete) and permanently deletes its reviews. Several rows can be deleted at once from the selection toolbar.

Statuses

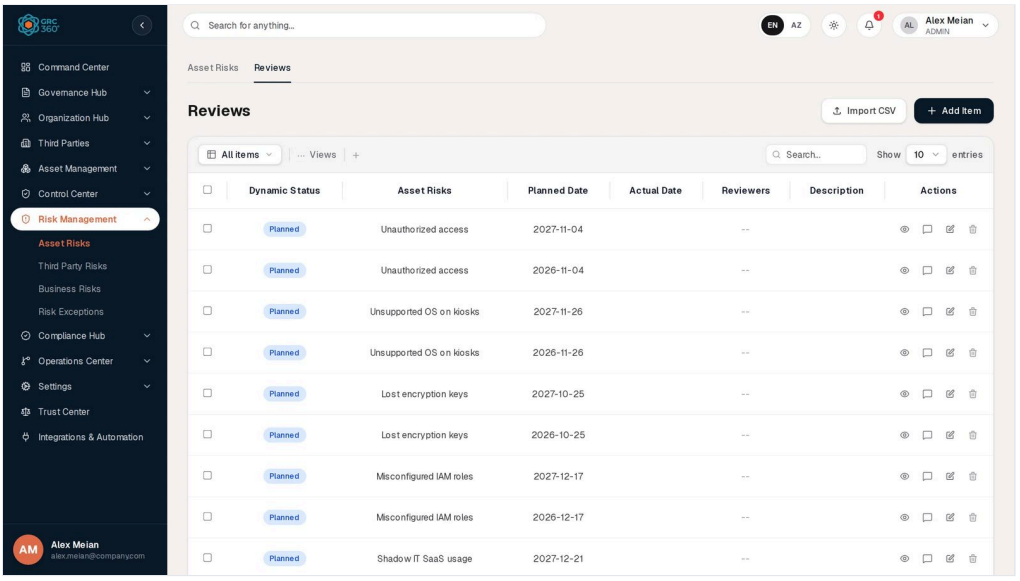
Value	Set by	Meaning
Above Appetite	System (flag)	Residual score greater than the numerical appetite. Red.
Review Expired	System (flag)	A review is past its planned date without an actual date. Amber.
No Treatment	System (flag)	**Risk Treatment** is empty. Amber.
Exception Expired	System (flag)	A treatment risk exception is past its expiration date and not closed. Amber.
Control Last Audit Expired	System (flag)	A treatment control has an unfinished audit whose planned start has passed. Amber.
On Track, Review Due, Above Appetite, Exception Active, Closed	System (stored on save)	The single stored status, shown only in the linked-risk panel; see The stored status
OPEN … ARCHIVED	API only	Lifecycle status; not on the form. Default OPEN.

The register has no user-selectable Status field.

Tabs

Reviews

The **Reviews** tab lists the reviews of all asset risks. Each review belongs to one risk. Reviews are created in two ways: automatically from the risk's **Next Review Date** (one review on that date and one a year later; past dates skipped; see Risk Reviews), and by hand with **Add Item** on this tab.



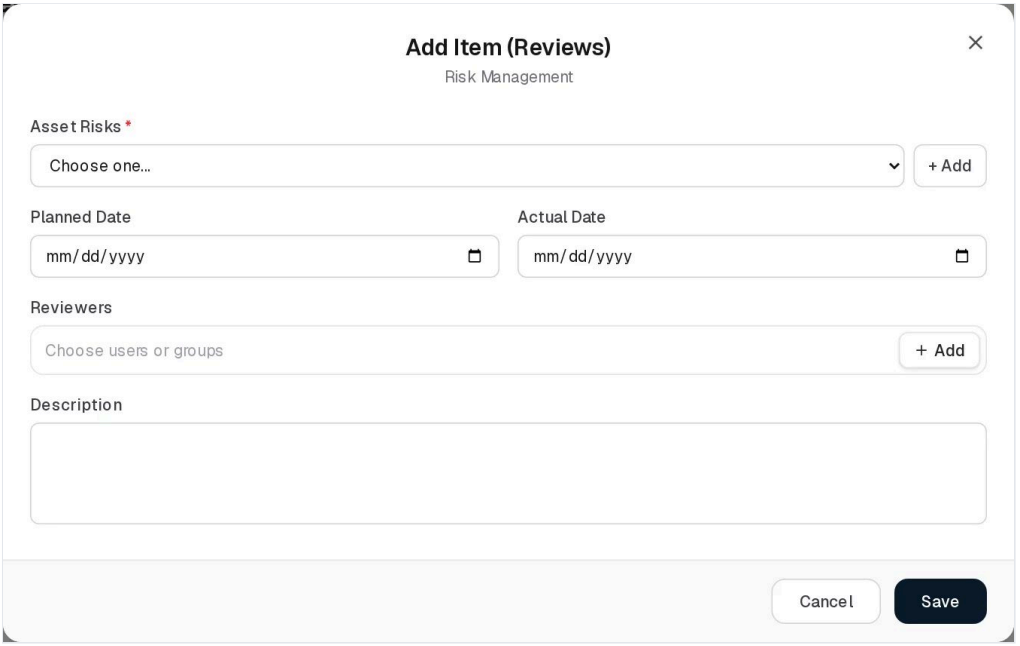
Asset Risk reviews

Column	What it shows	Source
Dynamic Status	**Completed** (green, Actual Date set), **Expired** (red, Planned Date before today and no Actual Date), **Planned** (blue)	Computed
Asset Risks	Name of the reviewed risk	Linked
Planned Date	When the review is due	Entered or generated
Actual Date	When it was carried out	Entered
Reviewers	Users or groups who review	Entered

Column	What it shows	Source
Description	Notes	Entered

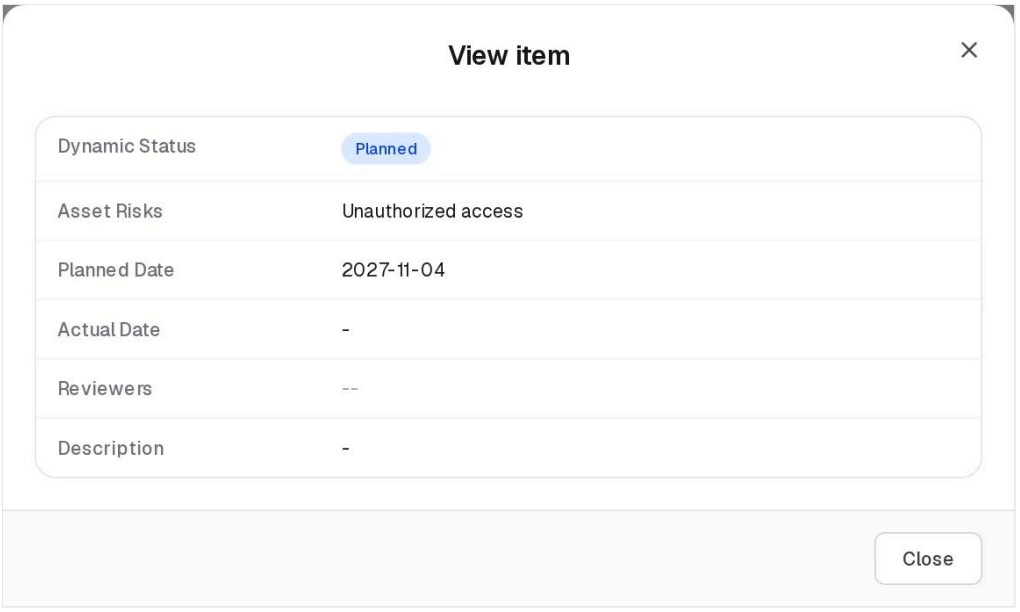
The grid has an **All items** filter in addition to the usual toolbar. When there are no reviews it says “No reviews yet. One is opened automatically when a risk is given a next review date.”

Add Item opens **Add Item (Reviews)** (subtitle *Risk Management*):



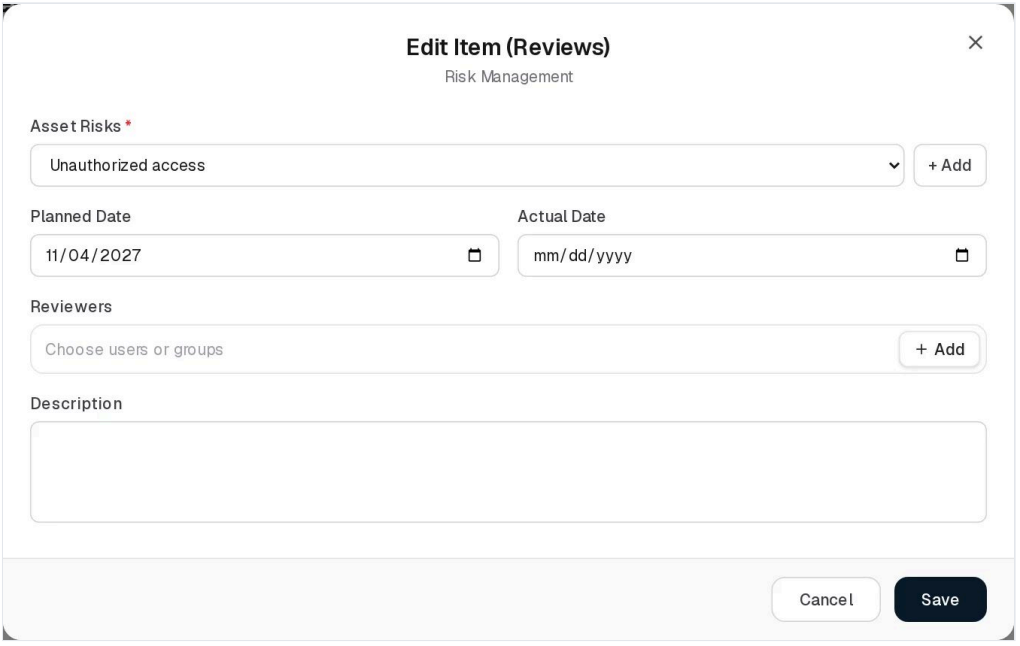
Add review

Field	Type	Required	Rules and allowed values	Example
Asset Risks	Dropdown of all asset risks	Yes	“Choose the risk this review belongs to.” appears above the grid if empty. **+ Add** creates a new asset risk with the full Asset Risks form and selects it.	Unauthorized access
Planned Date	Date	No		2026-11-04
Actual Date	Date	No	Setting it marks the review **Completed** and stops the **Review Expired** flag	
Reviewers	Users or groups, several	No		Alex Meian
Description	Long text	No		Access review signed off



View review

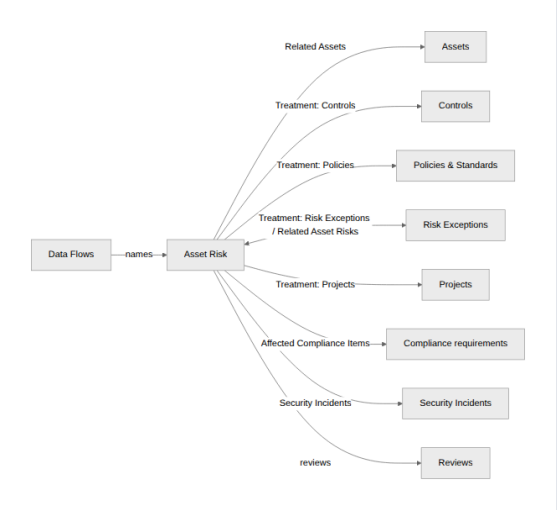
View shows the six columns. **Edit** opens **Edit Item (Reviews)** with the same fields. The risk a review belongs to cannot be changed: the dropdown can be changed on the Edit form, but the server keeps the original risk.



Edit review

Completing a review does not move the risk's **Next Review Date**; set the next date on the risk yourself. Generated reviews that are not completed are replaced when the Next Review Date changes; reviews you add by hand and completed reviews stay.

Relationships



Related record	Direction	How the link is made	Where it shows
Assets	Many to many, stored on the risk	**Related Assets** on this form	Here: **Related Assets** (text). Assets register: **Asset Risks** count (clickable). Departments: **Asset Risks** count, through the assets that name the department.
Controls	Many to many, stored on the risk	**Treatment: Controls**	Here: **Treatment Internal Controls**. Controls register: **Asset Risks** count (clickable, read-only there).
Policies & Standards	Many to many, stored on the risk	**Treatment: Policies**	Here: **Treatment Policies**. Policies & Standards: **Asset Risks Treatment** count (clickable).
Risk Exceptions	Many to many, one relation shown from both ends	**Treatment: Risk Exceptions** here, or **Related Asset Risks** on the exception	Here: **Treatment Risk Exceptions**. Risk Exceptions: **Related Asset Risks** count (clickable). See Risk Exceptions.
Projects	Many to many, stored on the risk	**Treatment: Projects**	Here: **Treatment Projects**. Projects register: **Asset Risks** count (clickable).
Compliance requirements	Many to many, stored on the risk	**Affected Compliance Items** here, or from the requirement in Compliance Analysis	Here: **Affected Compliance Items**. Compliance Analysis lists the risks on the requirement.
Security Incidents	Many to many, stored on the risk	**Security Incidents**	Security Incidents register: **Known Asset Risk** count (clickable). Not shown in this grid.
Data Flows	Many to many	Chosen on the data flow's form; also links the flow's asset to the risk	Data Flows grid
Reviews	One risk, many reviews	Generated or added on the **Reviews** tab	**Reviews** column (count, not clickable) and the **Reviews** tab

Where another register shows an asset-risk count, clicking it opens a panel with each linked risk in full: an **Overview** (Description, Status, Dynamic Status, Next Review Date, Reviews, contacts), **Analysis**, **Treatment** and **Manual Override** (Manual Score Override, Override Reason). This panel is the only place the lifecycle status, the stored dynamic status and the override are visible.

Automations and notifications

Automation	Trigger	Effect
Score calculation	Save	Inherent score, residual score, stored dynamic status
Review schedule	Save	Reviews on the Next Review Date and one year later
Dynamic Status flags	Every read	Computed live
Compliance re-evaluation	Save of a risk with Affected Compliance Items	Linked requirements set to Non Compliant or Compliant, see Automations
Linked exception decided (approve, deny, expire, delete)	API action or exception deletion	Treatment exceptions and stored status of the risk updated

No notification is sent when an asset risk is created, changed, assigned or becomes due for review.

Permissions

Action	Needed access
See the page	**View** on Risk Management › Asset Risks
Create, Edit	**Manage** on Risk Management › Asset Risks
Delete	**Full Control** on Risk Management › Asset Risks
Import CSV	**Manage** (the import itself does not work, see below)
Change the shared risk settings (gear)	**Full Control** on any of the three risk registers
Name other people as Risk GRC Contact or Risk Originator Contact	**Can Assign**; changing who else is named needs **Can Reassign**
Activity Log	The group's **Comments & Attachments** level
Reviews tab	Its own level on Risk Management › Asset Risks › Reviews (**View**, **Manage**, **Full Control** as above). The reviews you see are limited to risks you can see.

Which rows you see also depends on your group's record visibility: a group limited to its own records sees the risks that name its member as **Risk GRC Contact** or **Risk Originator Contact**, plus risks that name nobody (see Which records you see). Buttons you lack the right for are shown locked and open **Request Access**; see Permissions and access.

How to

Record a new asset risk

1. Open **Risk Management › Asset Risks** and click **Add Item**.
2. Enter **Name** "Stolen laptop data leak" and a **Description**.
3. In **Risk GRC Contact** choose Alex Meian; in **Risk Originator Contact** choose Sara Johnson.
4. Set **Next Review Date**, for example 29 Oct 2026.
5. Under **Analysis**, choose **Related Assets**, then **Likelihood (Analysis)** Possible and **Impact (Analysis)** Major.
6. Under **Treatment**, choose **Risk Treatment** MITIGATE and the treating controls.
7. Click **Save**. The grid shows **Inherent Risk Score** 12, and the **Reviews** tab has reviews for 29 Oct 2026 and 29 Oct 2027.

Reduce a residual score after treatment

1. Click **Edit** on "Unpatched internet-facing server" (Likely, Major; score 16).
2. Add the patching project under **Treatment: Projects**.
3. Set **Residual Percentage Coefficient** to 30 and click **Save**.
4. **Residual Risk Score** now shows 4.8.

Complete a review

1. Open the **Reviews** tab and find the review of “DDoS on customer portal” planned for 2026-10-12 (Dynamic Status **Expired**).
2. Click **Edit**, set **Actual Date** to today, add **Reviewers** and a **Description**, and click **Save**.
3. The review shows **Completed** and the risk’s **Review Expired** flag disappears.
4. Edit the risk and set its next **Next Review Date** if needed.

Accept a risk through an exception

1. Edit the risk and click **+ Add** beside **Treatment: Risk Exceptions** to create the exception, or choose an existing one.
2. Save. The exception appears under **Treatment Risk Exceptions**, and the risk appears in the exception’s **Related Asset Risks**.

CSV import

The **Import CSV** button first shows the message “CSV Import (Asset Risks): the import structure is not ready yet.” and then opens the generic import dialog. That dialog sends the file to a demo address that does not exist, so validation fails and nothing is imported. The server does have an asset-risk import (`/risk-management/asset-risks/import-csv` , columns `name` or `title` required, `description` optional) and an export (`/export-csv` : id, name, description, status, dynamicStatus, riskAnalysisScore, riskTreatmentScore), but neither is reachable from the page. The **Reviews** tab’s Import CSV behaves the same way and has no server import at all.

Limitations and known issues

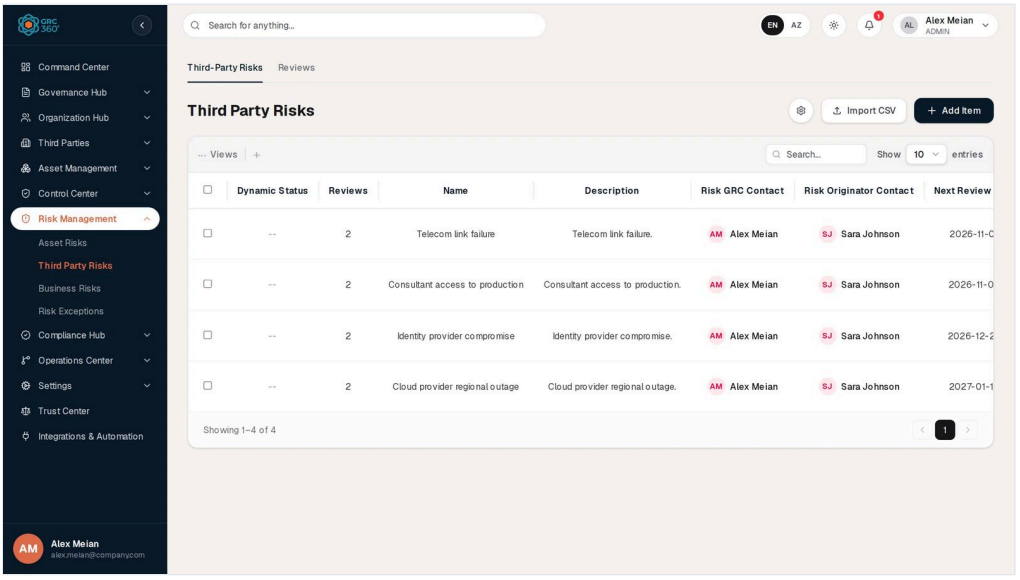
- Import CSV does not work from the page (see above); there is no Export button.
- Scores are stored on save and not recalculated when settings change.
- The manual score override is API-only and is cleared by saving the form.
- **Above Appetite** cannot appear with the default settings (appetite 50, maximum score 25).
- The **View item** dialog omits the threat and vulnerability descriptions, the coefficient and the security incidents.
- The Edit form of a review lets you pick another risk, but the change is ignored.
- The form labels the control picker **Treatment: Controls**, the grid **Treatment Internal Controls**.

Third Party Risks

> **Module:** Risk Management › Third Party Risks · **Route:** `/risk-management/third-party-risks` · **Permission key:** `risk_management.third_party_risks`

The Third Party Risks register lists the risks that come from vendors, suppliers, consultants and other outside parties. A record is one risk, for example “Consultant access to production”: which third parties it concerns, which of the organisation’s assets are shared with them, how likely and severe it is, and how it is treated. Vendor managers and the GRC team work in it; the built-in **Third Party** group gives external contacts read and edit rights on this page (not create or delete), limited to the risks that name them.

The register works like Asset Risks. Scores, appetite thresholds, Dynamic Status flags and reviews follow the shared rules in the Risk Management overview. This page describes what is specific to third party risks and repeats the field list in full.



Third Party Risks register

At a glance

A record is	One risk arising from one or more third parties
Typical owner	The **Risk GRC Contact**, usually the vendor manager or GRC analyst
Links to	Vendors (third parties), Assets, Controls, Policies, Risk Exceptions, Projects, Compliance items, Security Incidents, users and groups
Linked from	Vendors, Assets, Controls, Policies & Standards, Risk Exceptions, Security Incidents, Objectives, Data Flows, Compliance Analysis
Tabs	**Third-Party Risks**, **Reviews**
Automations	Scores and stored status on save; reviews generated from the Next Review Date; Dynamic Status flags computed on read; linked compliance items re-evaluated on save

The register (list view)

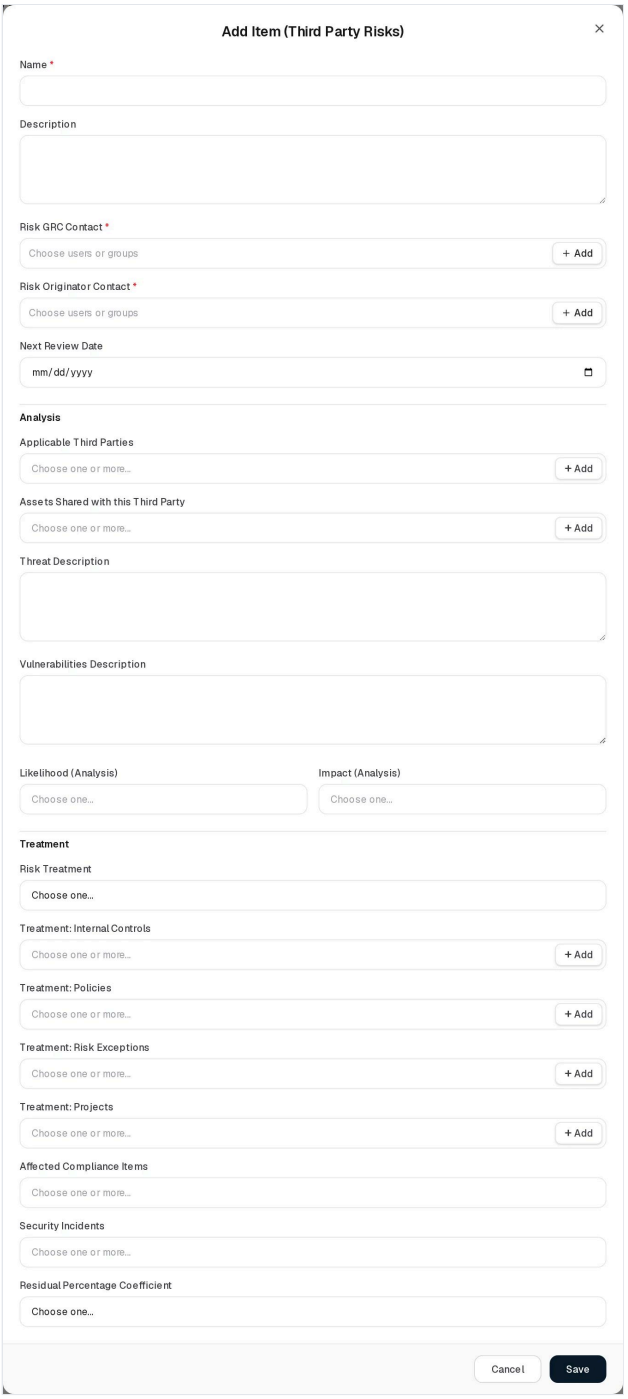
The first tab is labelled **Third-Party Risks** (with a hyphen); the grid title is **Third Party Risks**. Above the grid are the **Settings** gear (shared risk settings, see Settings), **Import CSV** and **Add Item**. Search (Name and Description), **Views**, paging and the row buttons are described in Working with registers.

Column	What it shows	Source
Dynamic Status	One chip per applicable flag: **Above Appetite**, **Review Expired**, **No Treatment**, **Exception Expired**, **Control Last Audit Expired**; `--` when none. See Dynamic Status of a risk.	Computed by the system
Reviews	Number of reviews of the risk	Computed
Name	Name of the risk	Entered
Description	Description	Entered
Risk GRC Contact	Responsible users or groups	Entered
Risk Originator Contact	Users or groups who raised the risk	Entered
Next Review Date	Date of the next review	Entered
Applicable Third Parties	Names of the vendors concerned	Linked
Assets Shared with this Third Party	Names of the assets the third party has access to	Linked
Inherent Risk Classification	**Likelihood (…)** and **Impact (…)** tags	Entered
Inherent Risk Score	Score before treatment, as a threshold chip when an appetite threshold applies	Computed
Risk Treatment	MITIGATE, ACCEPT, TRANSFER, AVOID	Entered
Treatment Risk Exceptions	Risk exceptions in the treatment	Linked
Treatment Internal Controls	Treating controls	Linked
Treatment Projects	Treating projects	Linked
Treatment Policies	Treating policies	Linked
Affected Compliance Items	Requirements put at stake	Linked
Residual Risk Score	Score after the **Residual Percentage Coefficient**; a threshold chip only when the coefficient is empty or 100	Computed

Demo data: four risks, for example “Telecom link failure” (Azercell Telecom, Possible × Moderate = 9, TRANSFER) and “Identity provider compromise” (Okta, Unlikely × Critical = 10).

Creating a record

Click **Add Item**. The dialog **Add Item (Third Party Risks)** opens.



Add Third Party Risk

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	“Name is required”	Consultant access to production
Description	Long text	No		Consultant access to production.
Risk GRC Contact	Users or groups, several	Yes	“Risk GRC Contact is required”. Naming others needs **Can Assign** / **Can Reassign**.	Alex Meian
Risk Originator Contact	Users or groups, several	Yes	“Risk Originator Contact is required”	Sara Johnson

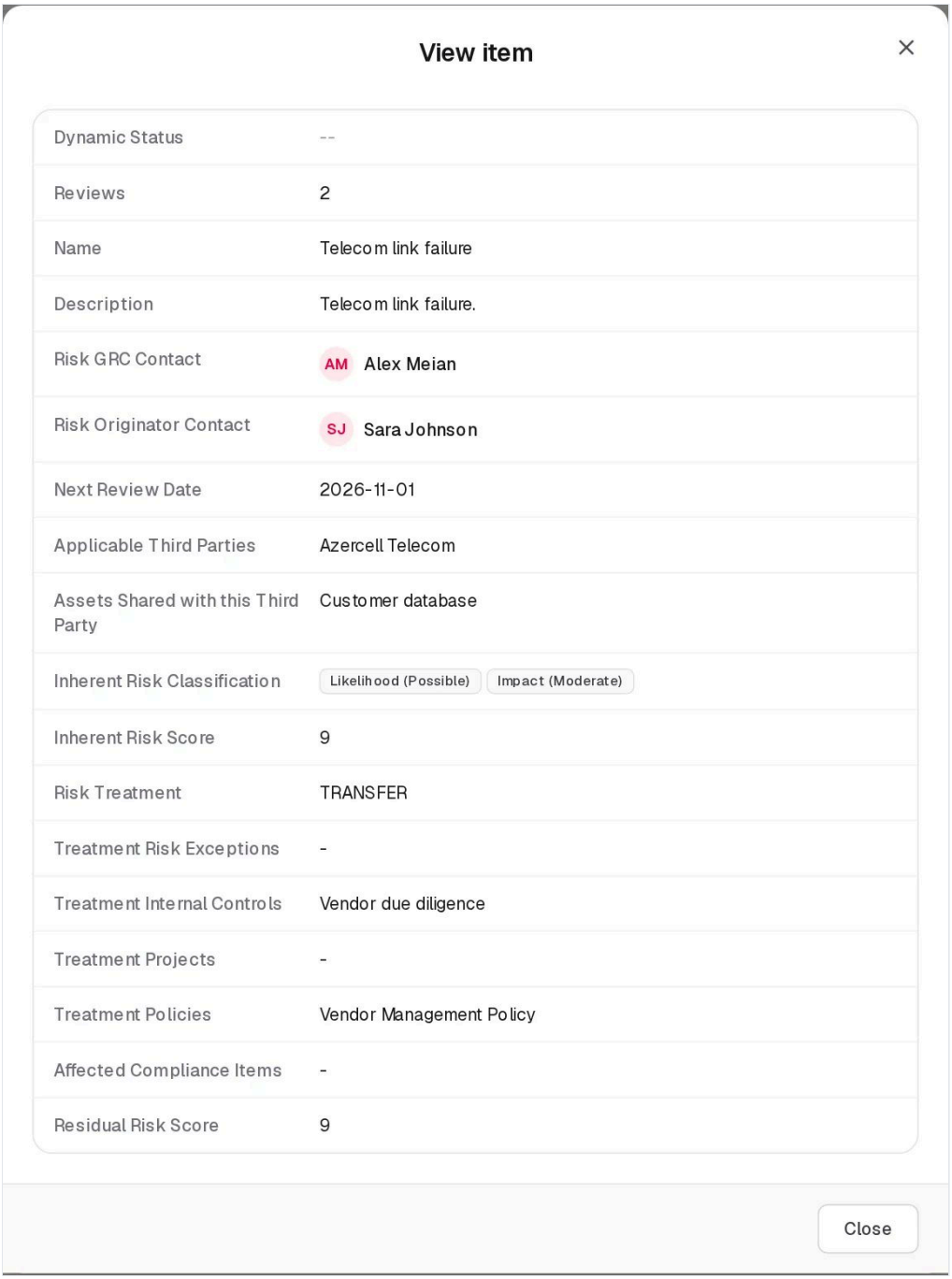
Field	Type	Required	Rules and allowed values	Example
Next Review Date	Date	No	1900 to 2999 (“Enter a valid date between 1900 and 2999”). Generates reviews.	2026-11-02
Analysis				
Applicable Third Parties	Vendors, several	No	Picker with **+ Add** (creates a vendor)	Deloitte Azerbaijan
Assets Shared with this Third Party	Assets, several	No	Picker with **+ Add**	Customer database
Threat Description	Long text	No		
Vulnerabilities Description	Long text	No		
Likelihood (Analysis)	One classification	No	Rare, Unlikely, Possible, Likely, Almost certain	Possible
Impact (Analysis)	One classification	No	Negligible, Minor, Moderate, Major, Critical	Major
Treatment				
Risk Treatment	Dropdown	No	Choose one…, MITIGATE, ACCEPT, TRANSFER, AVOID	MITIGATE
Treatment: Internal Controls	Controls, several	No	Picker with **+ Add**	Vendor due diligence
Treatment: Policies	Policies & Standards, several	No	Picker with **+ Add**	Vendor Management Policy
Treatment: Risk Exceptions	Risk exceptions, several	No	Picker with **+ Add**	
Treatment: Projects	Projects, several	No	Picker with **+ Add**	
Affected Compliance Items	Requirements, several	No	No **+ Add**	ISO/IEC 27001:2022 · A.5.15 Access control
Security Incidents	Security incidents, several	No	No **+ Add**	Suspicious login from unknown country
Residual Percentage Coefficient	Dropdown	No	Choose one…, 0, 10 … 100	50

Scores are calculated on **Save**: “Consultant access to production” is Possible (3) × Major (4) = 12; with coefficient 50 the residual score is 6. On success the message “Third party risk added.” appears.

The record also has review fields of its own (planned date, actual date, reviewers, review description) that are not on the form. They are kept unchanged when you save. The reviewers stored there count as people named on the risk for record visibility and assignment.

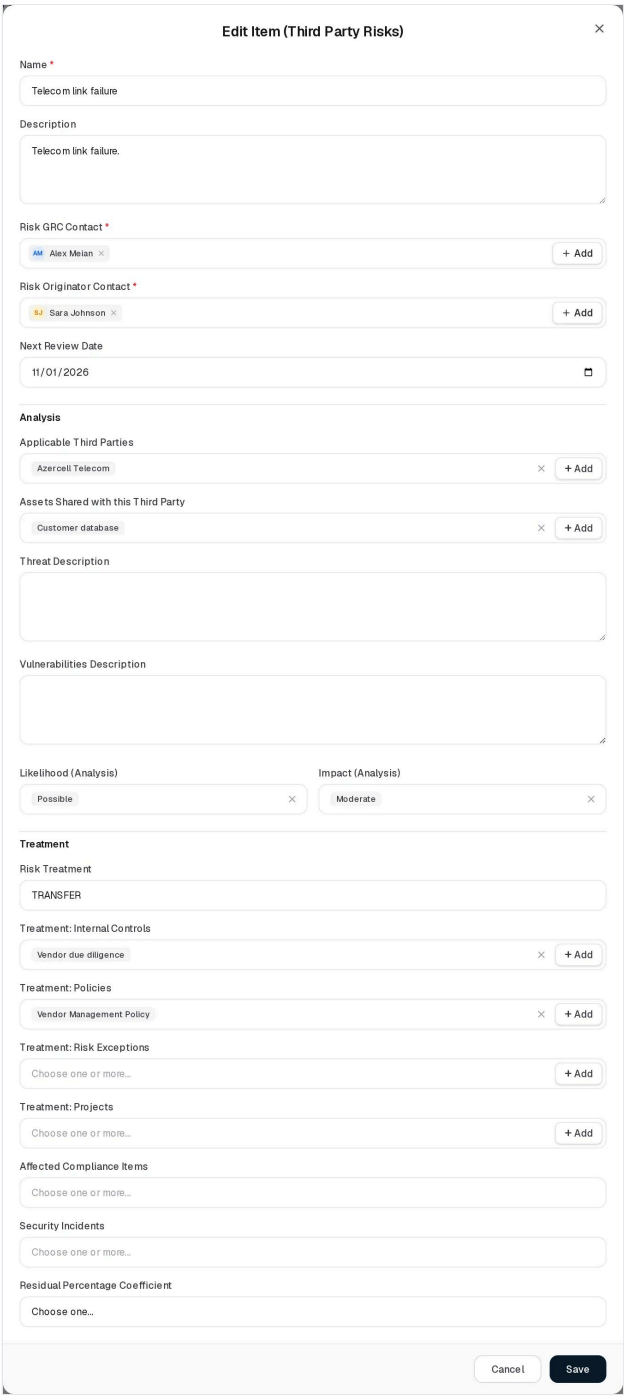
Viewing and editing a record

View opens **View item** with the grid’s columns.



View Third Party Risk

Edit opens **Edit Item (Third Party Risks)** with the same fields. Saving recalculates the scores and the review schedule and shows “Third party risk updated.” The editing notes for Asset Risks apply here too: scores use the current settings, an API-set manual override is cleared, and an old MONITOR treatment is kept unless changed.



Edit Third Party Risk

Delete asks “Delete third party risk ?”, removes the risk from the register and deletes its reviews.

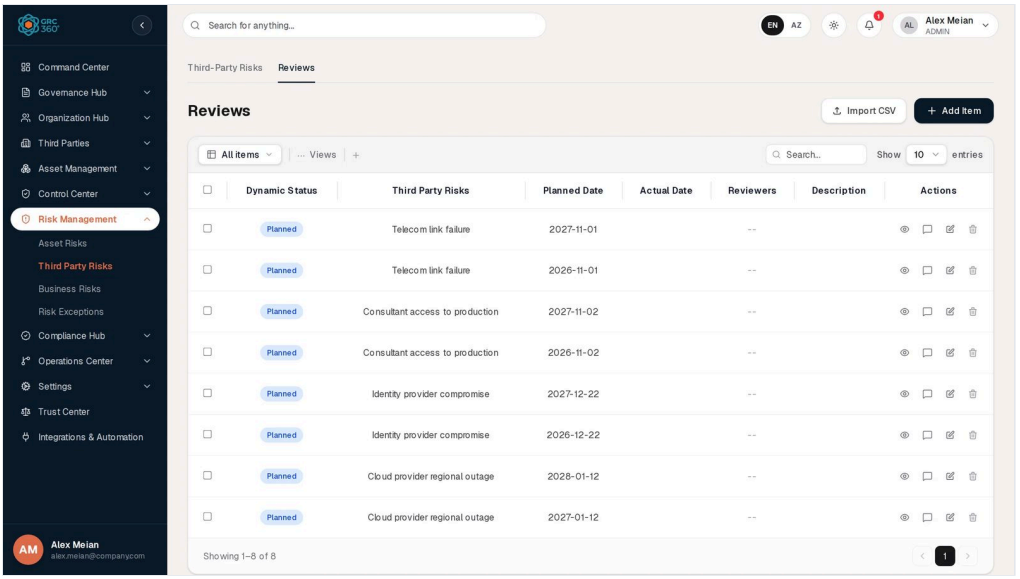
Statuses

The same values as Asset Risks: the five Dynamic Status flags computed on read, the single stored status (On Track, Review Due, Above Appetite, Exception Active, Closed) visible only in the linked-risk panel, and the API-only lifecycle status. See Asset Risks › Statuses and Dynamic Status of a risk. There is no user-selectable Status field.

Tabs

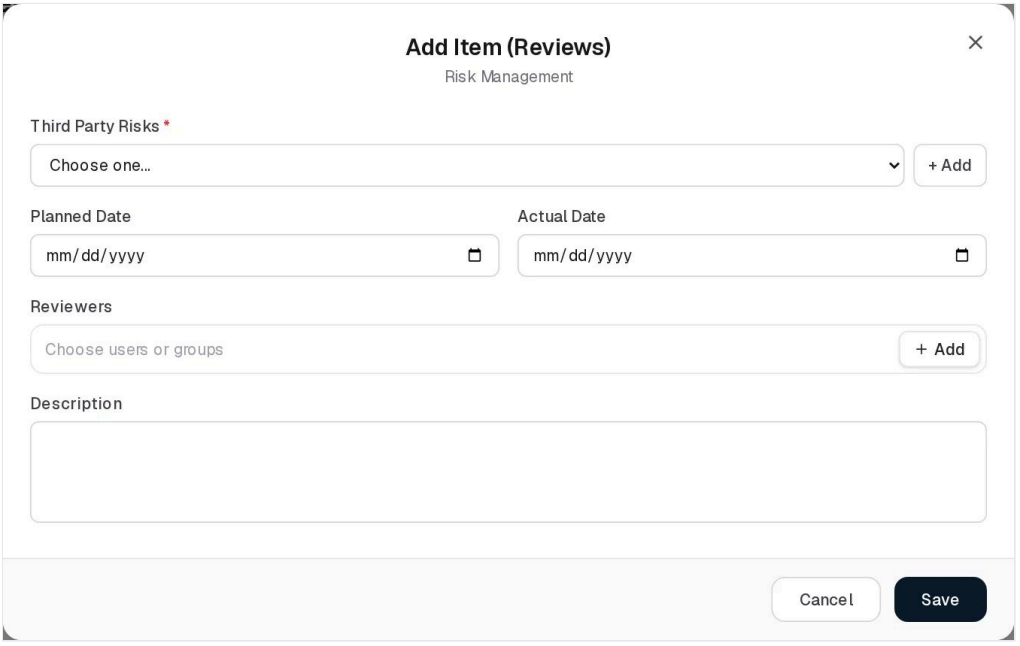
Reviews

The **Reviews** tab lists the reviews of all third party risks. It works exactly like the Asset Risks Reviews tab; only the risk column and dropdown are labelled **Third Party Risks**, and **+ Add** beside the dropdown opens the Third Party Risks form.

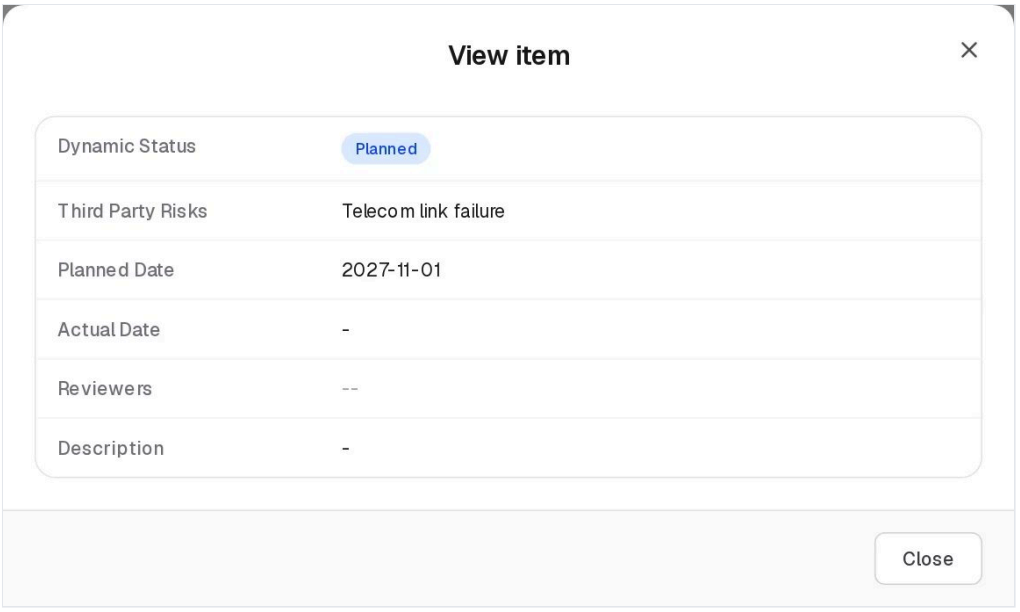


Third Party Risk reviews

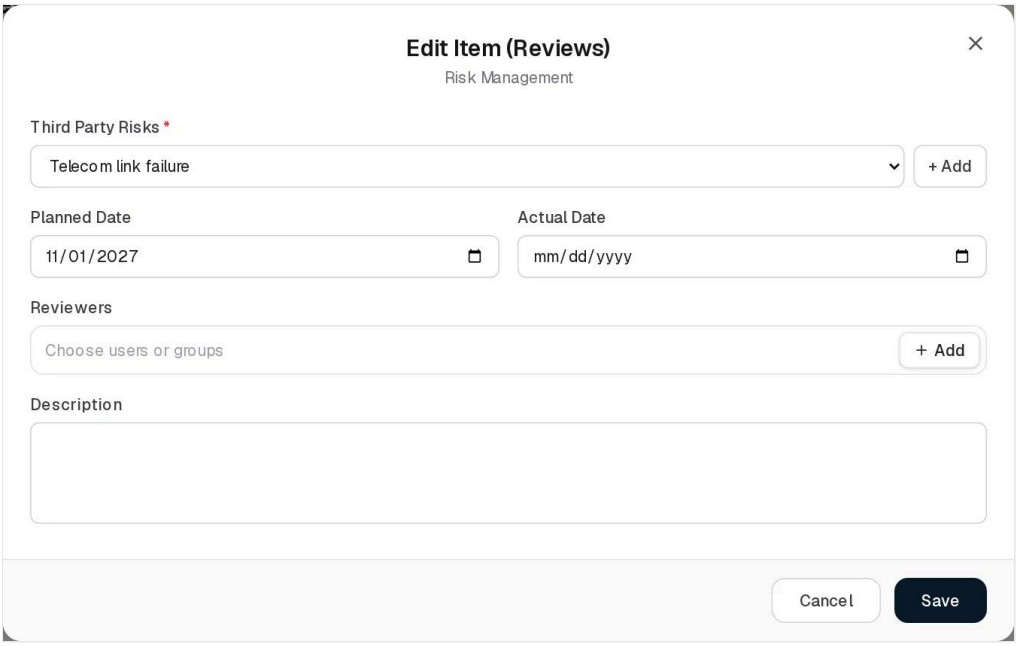
Field	Type	Required	Rules	Example
Third Party Risks	Dropdown	Yes	“Choose the risk this review belongs to.”	Telecom link failure
Planned Date	Date	No		2026-11-01
Actual Date	Date	No	Marks the review **Completed**	
Reviewers	Users or groups, several	No		
Description	Long text	No		



Add review



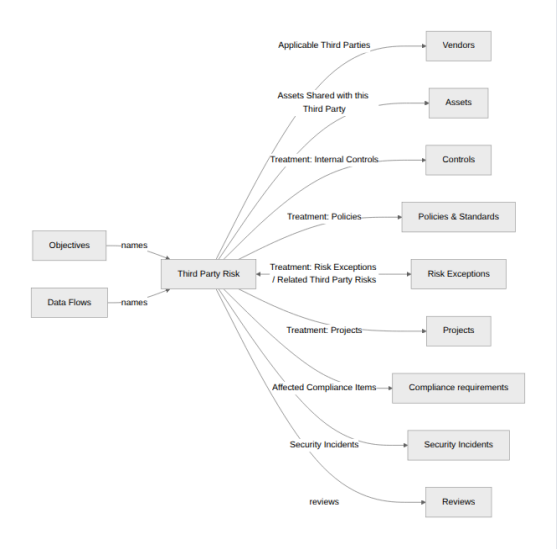
View review



Edit review

Review Dynamic Status: **Completed** (Actual Date set), **Expired** (Planned Date passed, no Actual Date), **Planned**. Example: “Cloud provider regional outage” has Next Review Date 12 Jan 2027, so it has reviews planned for 12 Jan 2027 and 12 Jan 2028.

Relationships



Related record	Direction	How the link is made	Where it shows
Vendors	Many to many, stored on the risk	**Applicable Third Parties**	Here (text). Vendors register: **Risk** count (clickable, opens the risks naming the vendor).
Assets	Many to many, stored on the risk	**Assets Shared with this Third Party**	Here (text). Assets register: **Third Party Risk** count (clickable).
Controls	Many to many, stored on the risk	**Treatment: Internal Controls**	Controls register: **Third Party Risks** count (clickable).
Policies & Standards	Many to many, stored on the risk	**Treatment: Policies**	Policies & Standards: **Third Party Risks Treatment** count (clickable).
Risk Exceptions	Many to many, one relation shown from both ends	Here, or **Related Third Party Risks** on the exception	Risk Exceptions: **Related Third Party Risks** count (clickable).
Projects	Many to many, stored on the risk	**Treatment: Projects**	Here only
Compliance requirements	Many to many, stored on the risk	**Affected Compliance Items**, or from Compliance Analysis	Compliance Analysis
Security Incidents	Many to many, stored on the risk	**Security Incidents**	Security Incidents register: **Known Third Party Risk** count (clickable)
Objectives	Many to many, stored on the objective	The objective's own form	Objectives register
Data Flows	Many to many, stored on the flow	The data flow's form	Data Flows register
Reviews	One risk, many reviews	Generated or added on the tab	**Reviews** column and tab

Clicking a count in another register opens the linked-risk panel described in Asset Risks › Relationships.

Automations and notifications

The same as Asset Risks: scores, stored status and the review schedule on every save; Dynamic Status flags on every read; linked compliance requirements re-evaluated on save. No notification is sent for third party risk events.

Permissions

Action	Needed access
See the page	**View** on Risk Management › Third Party Risks
Create, Edit	**Manage** on Risk Management › Third Party Risks

Action	Needed access
Delete	**Full Control** on Risk Management › Third Party Risks
Import CSV	**Manage** (the import does not work, see below)
Change the shared risk settings	**Full Control** on any of the three risk registers
Name other people as contacts	**Can Assign** / **Can Reassign**
Activity Log	The group's **Comments & Attachments** level
Reviews tab	Its own level on Risk Management › Third Party Risks › Reviews

Rows are limited by record visibility: a group limited to its own records sees the risks naming its member as Risk GRC Contact, Risk Originator Contact or reviewer, plus risks that name nobody. The built-in **Third Party** group starts with the read and edit rights on this page (no create, no delete) and sees only its own records.

How to

Record a risk for a new supplier

1. Open **Risk Management › Third Party Risks** and click **Add Item**.
2. Enter **Name**, **Risk GRC Contact** and **Risk Originator Contact**.
3. Under **Applicable Third Parties** choose the vendor, or click **+ Add** to create it.
4. Under **Assets Shared with this Third Party** choose the assets the supplier will access.
5. Choose **Likelihood (Analysis)** and **Impact (Analysis)**, set **Risk Treatment**, and click **Save**.
6. The vendor's **Risk** count in **Third Parties › Vendors** goes up by one.

Record that a vendor control reduces the risk

1. Edit "Telecom link failure".
2. Under **Treatment: Internal Controls** keep "Vendor due diligence" and set **Residual Percentage Coefficient** to 40.
3. Save: the residual score becomes 9 × 40 / 100 = 3.6.

Review all risks of one vendor

1. Open **Third Parties › Vendors** and click the **Risk** count of Okta.
2. The panel lists "Identity provider compromise" with its analysis and treatment.

CSV import

As on Asset Risks: **Import CSV** shows "CSV Import (Third Party Risks): the import structure is not ready yet." and then opens a demo dialog whose upload fails, so nothing is imported. The server's own `/risk-management/third-party-risks/import-csv` (name or title, description) and `/export-csv` endpoints are not reachable from the page.

Limitations and known issues

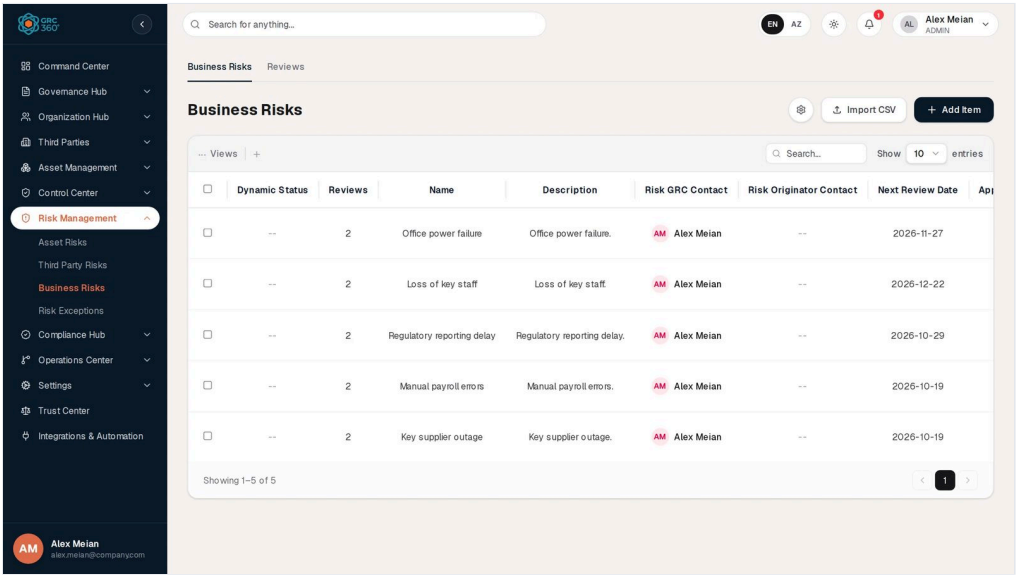
- Import CSV does not work from the page; no Export button.
- The tab is labelled **Third-Party Risks**, the grid and sidebar **Third Party Risks**.
- The record's own review fields (planned date, actual date, reviewers, review description) exist but are not on the form; they are separate from the **Reviews** tab.
- In the linked-risk panel opened from other registers, the **Treatment** section of a third party risk shows **Treatment Likelihood** and **Treatment Impact**, which this register does not have, and does not show the coefficient.
- Scores are stored on save; the manual override is API-only and cleared by saving the form.

Business Risks

> **Module:** Risk Management › Business Risks · **Route:** `/risk-management/operational-risks` · **Permission key:** `risk_management.operational_risks`

The Business Risks register lists risks to the organisation's operations: loss of key staff, a supplier outage, a reporting deadline missed. A record is one risk, tied to the departments it affects and to the business continuity plans that mitigate it. Unlike the other two risk registers, a business risk is re-analysed after treatment with a second likelihood and impact pair rather than a percentage. Department heads and the GRC team work in it.

The page is labelled **Business Risks** everywhere in the interface. The route, the permission key (`operational_risks`) and some messages still use the older name *operational risks*. Shared rules (scores, appetite thresholds, Dynamic Status flags, reviews, settings) are in the Risk Management overview.



Business Risks register

At a glance

A record is	One risk to the operations of one or more departments
Typical owner	The **Risk GRC Contact** together with the affected department
Links to	Departments, Continuity Plans, Controls, Policies, Risk Exceptions, Projects, Compliance items, Security Incidents, users and groups
Linked from	Departments, Controls, Risk Exceptions, Security Incidents, Objectives, Data Flows, Compliance Analysis
Tabs	**Business Risks**, **Reviews**
Automations	Scores and stored status on save; reviews generated from the Next Review Date; Dynamic Status flags computed on read; linked compliance items re-evaluated on save

The register (list view)

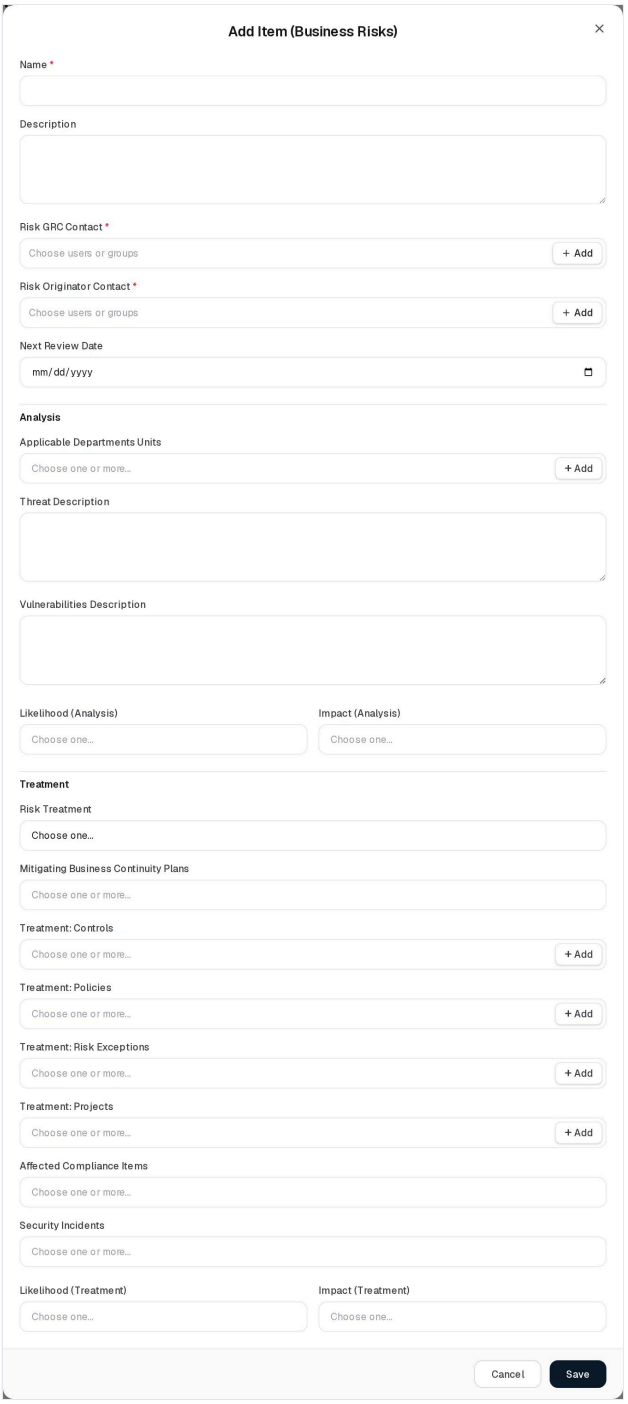
Above the grid are the **Settings** gear (see Settings), **Import CSV** and **Add Item**. Search (Name and Description), **Views**, paging and row buttons are described in Working with registers.

Column	What it shows	Source
Dynamic Status	One chip per applicable flag (**Above Appetite**, **Review Expired**, **No Treatment**, **Exception Expired**, **Control Last Audit Expired**); `--` when none. See Dynamic Status of a risk.	Computed by the system
Reviews	Number of reviews of the risk	Computed
Name	Name of the risk	Entered
Description	Description	Entered
Risk GRC Contact	Responsible users or groups	Entered
Risk Originator Contact	Users or groups who raised the risk	Entered
Next Review Date	Date of the next review	Entered
Applicable Departments Units	Names of the affected departments	Linked
Inherent Risk Classification	**Likelihood (…)** and **Impact (…)** from the analysis	Entered
Inherent Risk Score	Score before treatment; threshold chip when one applies	Computed
Risk Treatment	MITIGATE, ACCEPT, TRANSFER, AVOID	Entered
Treatment Risk Exceptions	Risk exceptions in the treatment	Linked
Treatment Internal Controls	Treating controls	Linked
Treatment Projects	Treating projects	Linked
Treatment Policies	Treating policies	Linked
Affected Compliance Items	Requirements put at stake	Linked
Mitigating Continuity Plans	Continuity plans that mitigate the risk	Linked
Residual Risk Classification	**Likelihood (…)** and **Impact (…)** from the treatment pair; `--` when not set	Entered
Residual Risk Score	Score of the treatment pair, or the inherent score when the pair is incomplete; threshold chip of that pair	Computed

Demo data: five risks, for example “Manual payroll errors” (Likely × Moderate = 12, MITIGATE) and “Office power failure” (Rare × Moderate = 3, TRANSFER). None of the demo business risks has a Risk Originator Contact.

Creating a record

Click **Add Item**. The dialog **Add Item (Business Risks)** opens.



Add Business Risk

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	“Name is required”	Manual payroll errors
Description	Long text	No		Manual payroll errors.
Risk GRC Contact	Users or groups, several	Yes	“Risk GRC Contact is required”. Naming others needs **Can Assign** / **Can Reassign**.	Alex Meian
Risk Originator Contact	Users or groups, several	Yes	“Risk Originator Contact is required”	Mike Brown
Next Review Date	Date	No	1900 to 2999 (“Enter a valid date between 1900 and 2999”). Generates reviews.	2026-10-19

Field	Type	Required	Rules and allowed values	Example
Analysis				
Applicable Departments Units	Departments, several	No	Picker with **+ Add** (creates a department)	Finance
Threat Description	Long text	No		
Vulnerabilities Description	Long text	No		
Likelihood (Analysis)	One classification	No	Rare, Unlikely, Possible, Likely, Almost certain	Likely
Impact (Analysis)	One classification	No	Negligible, Minor, Moderate, Major, Critical	Moderate
Treatment				
Risk Treatment	Dropdown	No	Choose one…, MITIGATE, ACCEPT, TRANSFER, AVOID	MITIGATE
Mitigating Business Continuity Plans	Continuity plans, several	No	No **+ Add**	Data centre outage
Treatment: Controls	Controls, several	No	Picker with **+ Add**	
Treatment: Policies	Policies & Standards, several	No	Picker with **+ Add**	
Treatment: Risk Exceptions	Risk exceptions, several	No	Picker with **+ Add**	
Treatment: Projects	Projects, several	No	Picker with **+ Add**	
Affected Compliance Items	Requirements, several	No	No **+ Add**	ISO/IEC 27001:2022 · A.5.15 Access control
Security Incidents	Security incidents, several	No	No **+ Add**	Suspicious login from unknown country
Likelihood (Treatment)	One classification	No	Same values as the analysis likelihood	Unlikely
Impact (Treatment)	One classification	No	Same values as the analysis impact	Minor

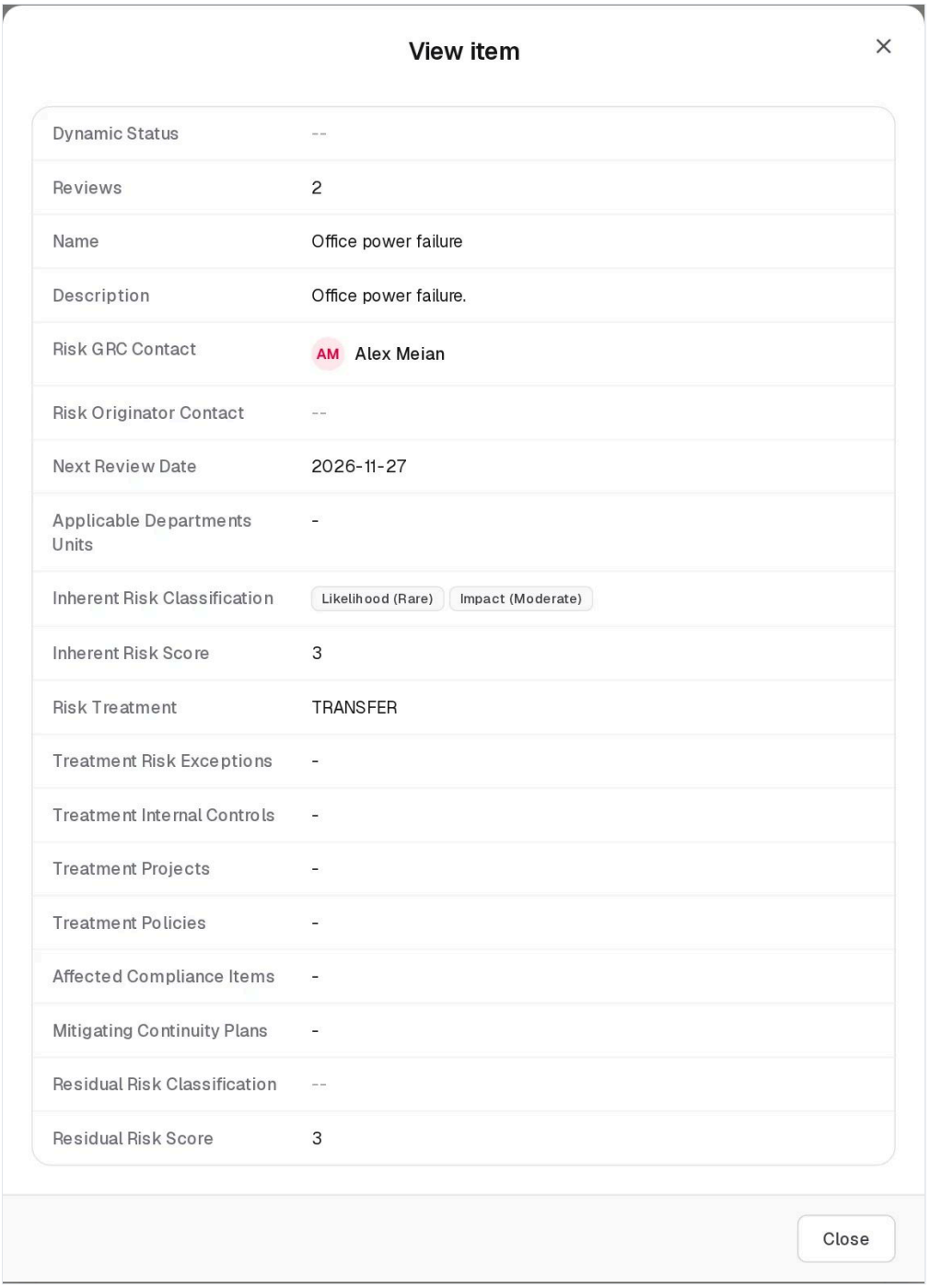
There is no **Residual Percentage Coefficient** on this register. The residual score comes from the treatment pair: with Likelihood (Treatment) Unlikely (2) and Impact (Treatment) Minor (2), “Manual payroll errors” gets a residual score of 4 against an inherent score of 12. If only one of the two treatment fields is chosen, the residual score equals the inherent score. See Residual score.

On success the message “Operational risk added.” appears.

The record also stores processes and its own review fields (planned date, actual date, reviewers, review description) that are not on the form; they are kept unchanged when you save. Reviewers stored there count as people named on the risk for visibility and assignment.

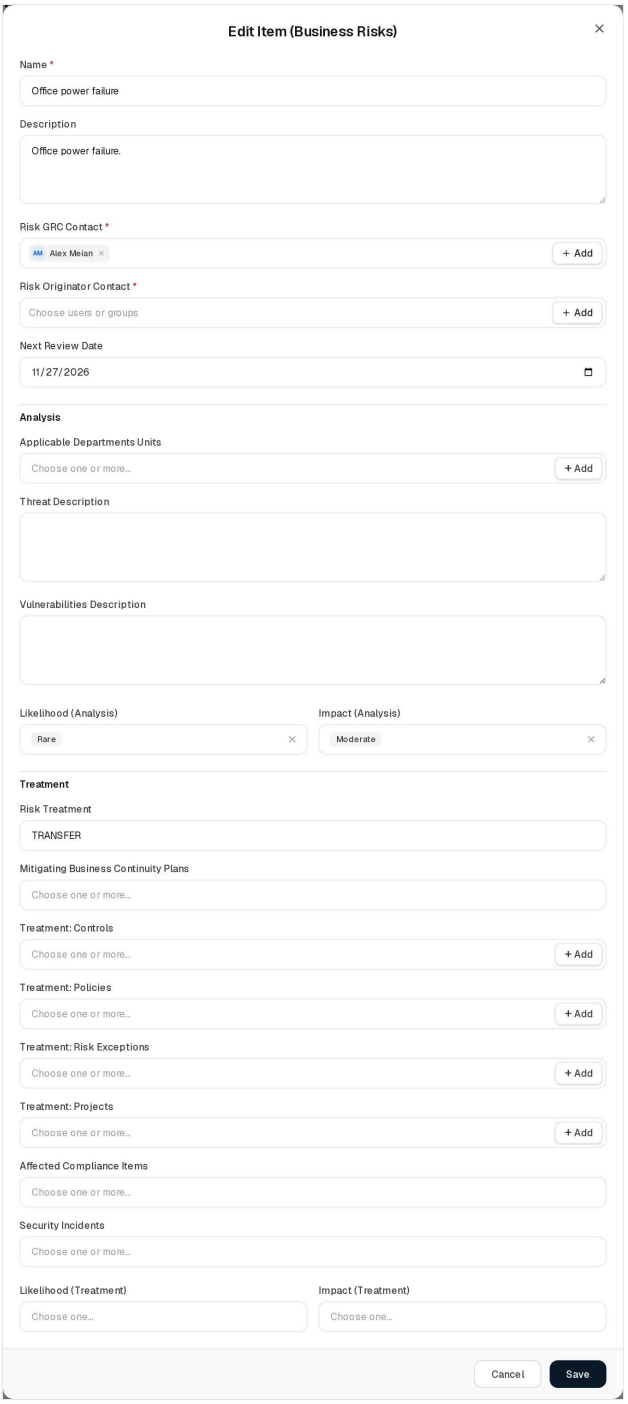
Viewing and editing a record

View opens **View item** with the grid’s columns.



View Business Risk

Edit opens **Edit Item (Business Risks)**. Saving recalculates both scores and the review schedule and shows “Operational risk updated.” Because **Risk Originator Contact** is required on the form, a demo risk without one cannot be saved until an originator is added.



Edit Business Risk

The editing notes for Asset Risks apply here too. **Delete** asks “Delete business risk ?”, removes the risk and deletes its reviews; the confirmation message is “Operational risk deleted.”

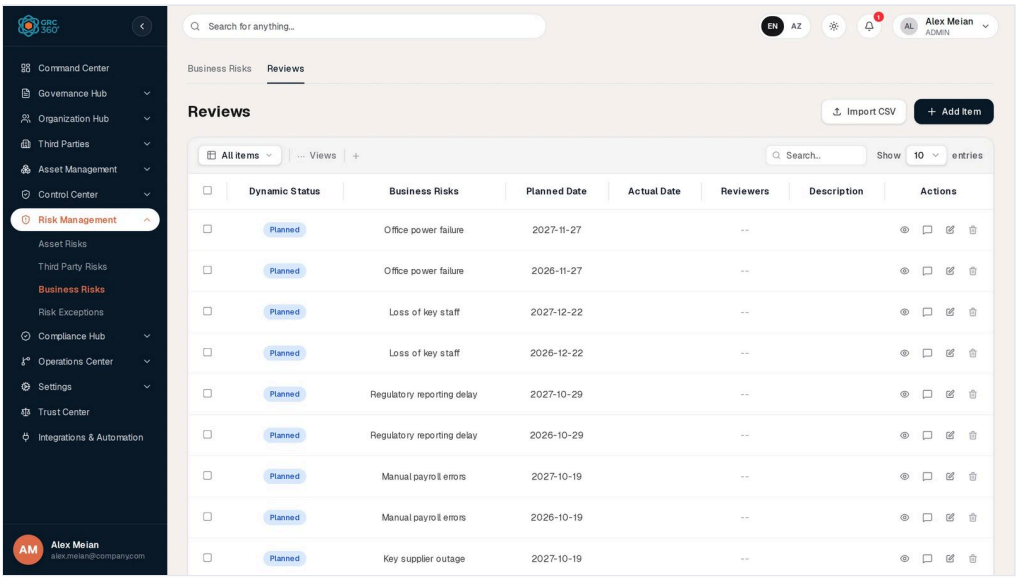
Statuses

The same values as Asset Risks: the five Dynamic Status flags computed on read, the stored status (On Track, Review Due, Above Appetite, Exception Active, Closed) visible only in the linked-risk panel, and the API-only lifecycle status. See Asset Risks › Statuses. For **Above Appetite** the residual score of the treatment pair is compared with the appetite. There is no user-selectable Status field.

Tabs

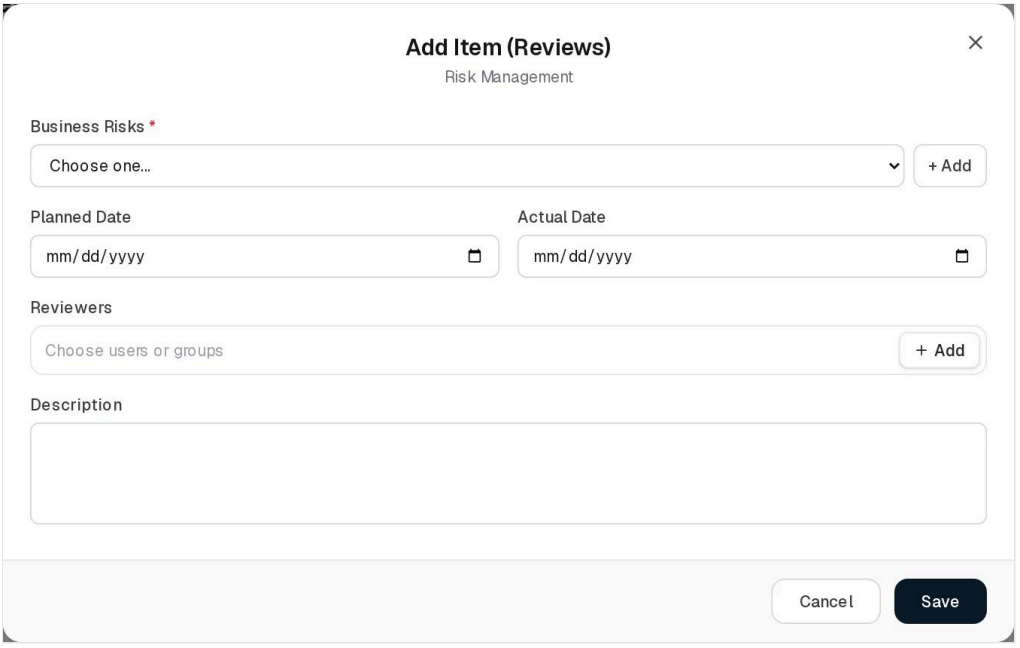
Reviews

The **Reviews** tab lists the reviews of all business risks. It works exactly like the Asset Risks Reviews tab; the risk column and dropdown are labelled **Business Risks**.

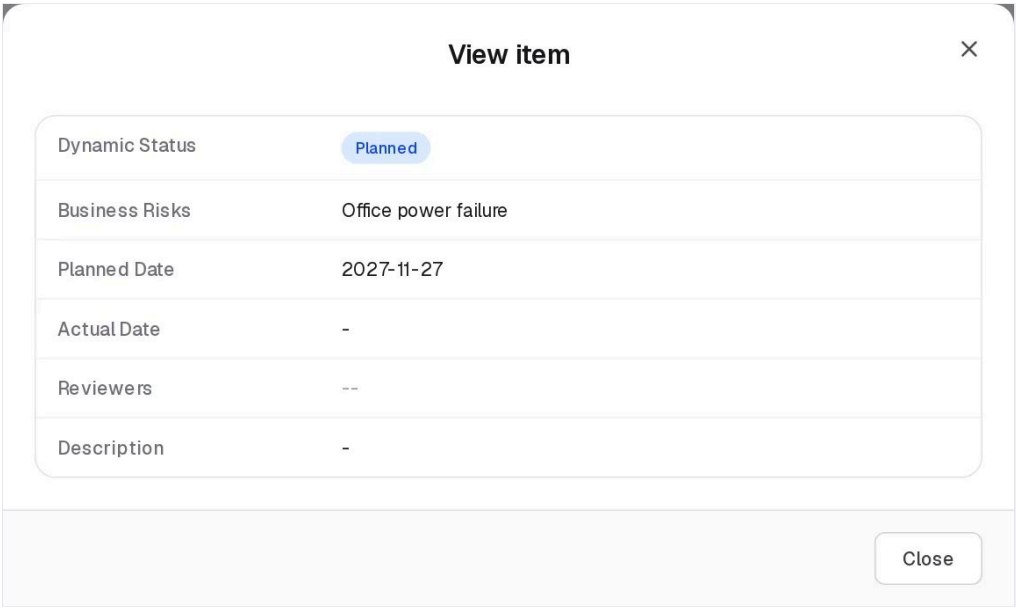


Business Risk reviews

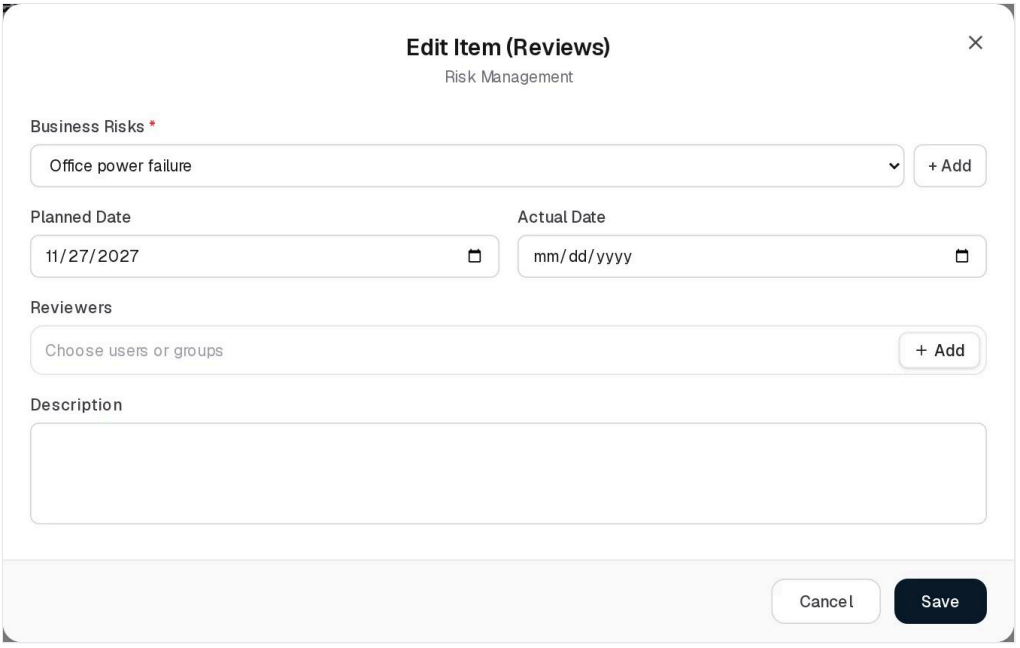
Field	Type	Required	Rules	Example
Business Risks	Dropdown	Yes	“Choose the risk this review belongs to.”; **+ Add** opens the Business Risks form	Loss of key staff
Planned Date	Date	No		2026-12-22
Actual Date	Date	No	Marks the review **Completed**	
Reviewers	Users or groups, several	No		
Description	Long text	No		



Add review



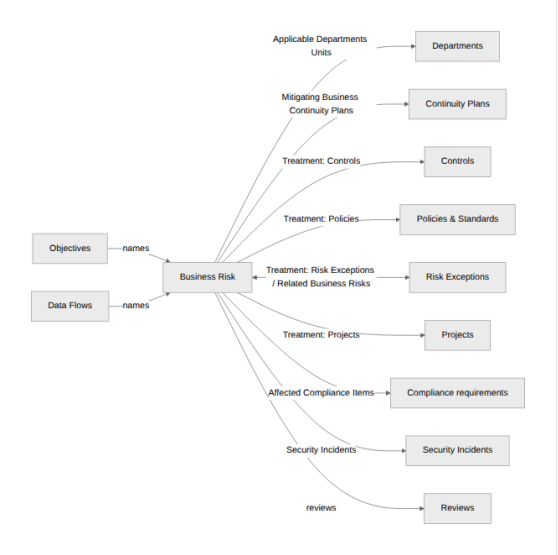
View review



Edit review

Example: “Regulatory reporting delay” has Next Review Date 29 Oct 2026, so it has reviews planned for 29 Oct 2026 and 29 Oct 2027. If the first is not completed by then, from 30 Oct 2026 it shows **Expired** and the risk shows **Review Expired**.

Relationships



Related record	Direction	How the link is made	Where it shows
Departments	Many to many, stored on the risk	**Applicable Departments Units**	Here (text). Departments register: **Business Risks** count (clickable). Members of these departments see the risk under department visibility.
Continuity Plans	Many to many, stored on the risk	**Mitigating Business Continuity Plans**	Here: **Mitigating Continuity Plans**
Controls	Many to many, stored on the risk	**Treatment: Controls**	Controls register: **Business Risks** count (clickable)
Policies & Standards	Many to many, stored on the risk	**Treatment: Policies**	Here only
Risk Exceptions	Many to many, one relation shown from both ends	Here, or **Related Business Risks** on the exception	Risk Exceptions: **Related Business Risks** count (clickable)
Projects	Many to many, stored on the risk	**Treatment: Projects**	Here only
Compliance requirements	Many to many, stored on the risk	**Affected Compliance Items**, or from Compliance Analysis	Compliance Analysis
Security Incidents	Many to many, stored on the risk	**Security Incidents**	Security Incidents register: **Known Business Risk** count (clickable)
Objectives	Many to many, stored on the objective	The objective's form	Objectives register
Data Flows	Many to many, stored on the flow	The data flow's form	Data Flows register
Reviews	One risk, many reviews	Generated or added on the tab	**Reviews** column and tab

Clicking a count in another register opens the linked-risk panel described in Asset Risks › Relationships.

Automations and notifications

The same as Asset Risks: scores, stored status and the review schedule on every save; Dynamic Status flags on every read; linked compliance requirements re-evaluated on save. No notification is sent for business risk events.

Permissions

Action	Needed access
See the page	**View** on Risk Management › Business Risks

Action	Needed access
Create, Edit	**Manage** on Risk Management › Business Risks
Delete	**Full Control** on Risk Management › Business Risks
Import CSV	**Manage** (the import does not work, see below)
Change the shared risk settings	**Full Control** on any of the three risk registers
Name other people as contacts	**Can Assign** / **Can Reassign**
Activity Log	The group's **Comments & Attachments** level
Reviews tab	Its own level on Risk Management › Business Risks › Reviews

Record visibility: a group limited to its own records sees risks naming its member as Risk GRC Contact, Risk Originator Contact or reviewer; a group limited to its department also sees risks whose **Applicable Departments Units** include the member's department.

How to

Record a business risk for a department

1. Open **Risk Management › Business Risks** and click **Add Item**.
2. Enter **Name** "Key supplier outage", **Risk GRC Contact** and **Risk Originator Contact**.
3. Under **Applicable Departments Units** choose the affected department.
4. Choose **Likelihood (Analysis)** Possible and **Impact (Analysis)** Major (score 12).
5. Choose **Risk Treatment** MITIGATE and the continuity plan under **Mitigating Business Continuity Plans**.
6. Click **Save**. The department's **Business Risks** count in **Organization Hub › Departments** increases.

Record the residual risk after treatment

1. Edit "Manual payroll errors" (inherent 12). Add a **Risk Originator Contact** if it is empty.
2. Set **Likelihood (Treatment)** Unlikely and **Impact (Treatment)** Minor.
3. Save. **Residual Risk Classification** shows **Likelihood (Unlikely) Impact (Minor)** and **Residual Risk Score** 4.

Check which business risks a control treats

1. Open **Control Center › Controls**.
2. Click the **Business Risks** count of the control to open the linked risks.

CSV import

Import CSV shows "CSV Import (Business Risks): the import structure is not ready yet." and then opens a demo dialog whose upload fails, so nothing is imported. The server's `/risk-management/operational-risks/import-csv` (name or title, description) and `/export-csv` endpoints are not reachable from the page.

Limitations and known issues

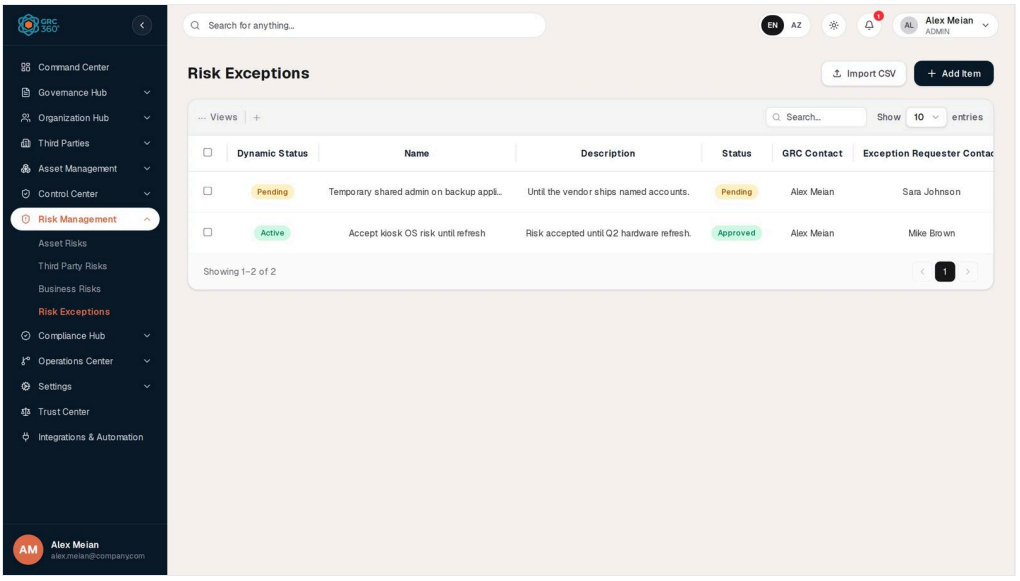
- Import CSV does not work from the page; no Export button.
- Messages say "Operational risk added / updated / deleted" while the page is called Business Risks.
- The field label is **Applicable Departments Units**.
- Processes and the record's own review fields exist on the record but not on the form.
- The demo risks have no Risk Originator Contact, so each must get one before it can be saved from the form.
- Nothing stops the treatment pair from scoring higher than the inherent pair.
- Scores are stored on save; the manual override is API-only and cleared by saving the form.

Risk Exceptions

> **Module:** Risk Management › Risk Exceptions · **Route:** `/risk-management/risk-exceptions` · **Permission key:** `risk_management.risk_exceptions`

The Risk Exceptions register records decisions to accept a risk for a limited time instead of treating it, for example “Accept kiosk OS risk until refresh”. A record is one exception: who requested it, who in the GRC team is responsible, until when it applies, and which asset, third party or business risks it covers. The GRC team maintains it; risk owners request exceptions.

An exception and a risk are linked in one relation that can be edited from either end: from the exception’s **Related … Risks** fields, or from the risk’s **Treatment: Risk Exceptions** field.



Risk Exceptions register

At a glance

A record is	One time-limited acceptance of one or more risks
Typical owner	The **GRC Contact**
Links to	Asset Risks, Third Party Risks, Business Risks, users and groups
Linked from	Asset Risks, Third Party Risks, Business Risks (**Treatment: Risk Exceptions**)
Tabs	None
Automations	Start date and closure date stamped by the server; Dynamic Status computed on read; the hourly expiry job is implemented but not active in this release

The register (list view)

The page has **Import CSV** and **Add Item** above the grid. Search (Name and Description), **Views**, paging and row buttons are described in Working with registers.

Column	What it shows	Source
Dynamic Status	**Pending**, **Active**, **Expired** or **Closed**; rules under Statuses	Computed by the system
Name	Name of the exception	Entered

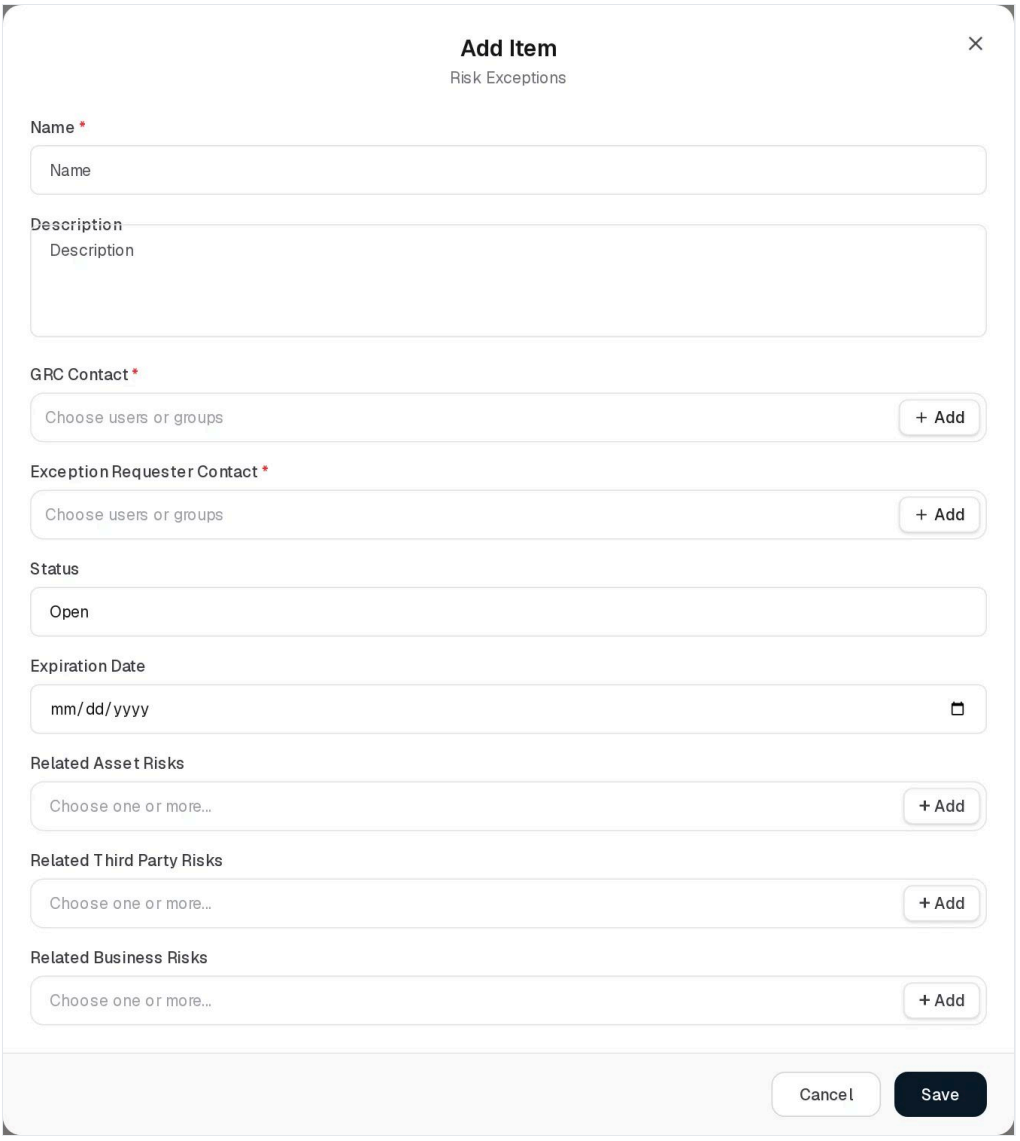
Column	What it shows	Source
Description	Description	Entered
Status	The stored status: **Open**, **Closed**, or a value set through the API (**Pending**, **Approved**, **Denied**, **Rejected**, **Revoked**, **Expired**)	Entered
GRC Contact	Responsible users or groups (names)	Entered
Exception Requester Contact	Who asked for the exception (names)	Entered
Start Date	Day the exception was created, unless set otherwise through the API	Set by the system
Expiration Date	Last day the exception is meant to apply	Entered
Closure Date	Day the exception was closed	Set by the system
Related Asset Risks	Number of linked asset risks; click to open them	Linked
Related Third Party Risks	Number of linked third party risks; click to open them	Linked
Related Business Risks	Number of linked business risks; click to open them	Linked

The three **Related** columns count the risks named on the exception plus the risks that name the exception in their **Treatment: Risk Exceptions**. A count of 0 is plain text; any other count opens a panel with each linked risk in full (overview, analysis, treatment). These columns cannot be sorted.

Demo data: “Accept kiosk OS risk until refresh” (Status **Approved**, Dynamic Status **Active**, requester Mike Brown, expires 2027-02-11, covers the asset risk “Unsupported OS on kiosks”) and “Temporary shared admin on backup appliance” (Status **Pending**, Dynamic Status **Pending**, requester Sara Johnson, expires 2026-11-28).

Creating a record

Click **Add Item**. The dialog **Add Item** (subtitle *Risk Exceptions*) opens.



Add Risk Exception

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	“Name is required”	Accept kiosk OS risk until refresh
Description	Long text	No		Risk accepted until Q2 hardware refresh.
GRC Contact	Users or groups, several	Yes	“At least one contact is required”	Alex Meian
Exception Requester Contact	Users or groups, several	Yes	“At least one requester is required”	Mike Brown
Status	Dropdown	No	**Open** (default), **Closed**	Open
Expiration Date	Date	No	1900 to 2999 (“Enter a valid date between 1900 and 2999”); must not be before the start date (“Expiration date cannot be before start date”)	2027-02-11
Related Asset Risks	Asset risks, several	No	Picker with **+ Add** (opens the Asset Risks form)	Unsupported OS on kiosks
Related Third Party Risks	Third party risks, several	No	Picker with **+ Add**	

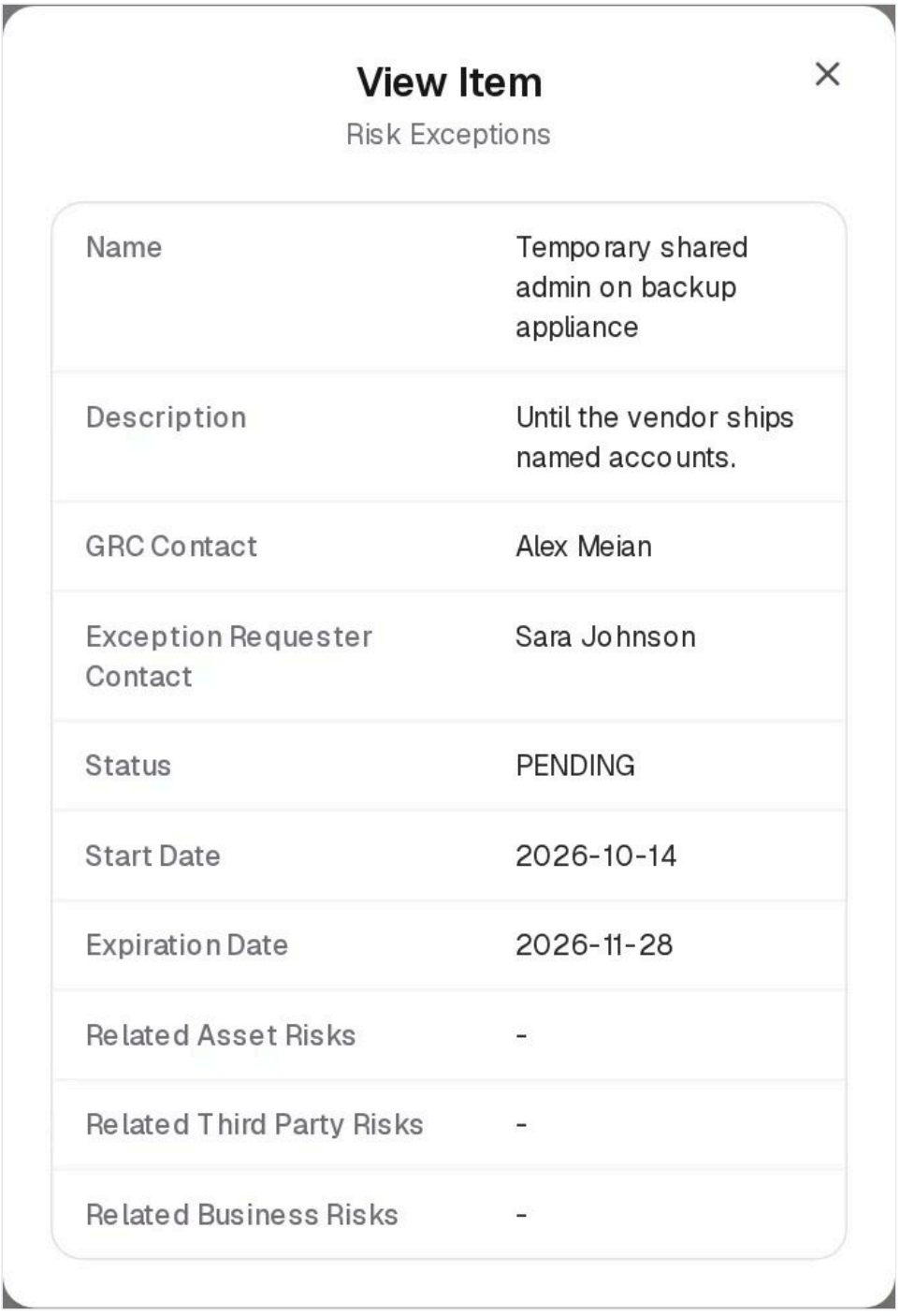
Field	Type	Required	Rules and allowed values	Example
Related Business Risks	Business risks, several	No	Picker with **+ Add**	

The form has no **Start Date** field: the server sets it to the day the exception is created and keeps it on later edits. Linking a risk you are not allowed to see is refused.

On success the message “Risk exception added.” appears.

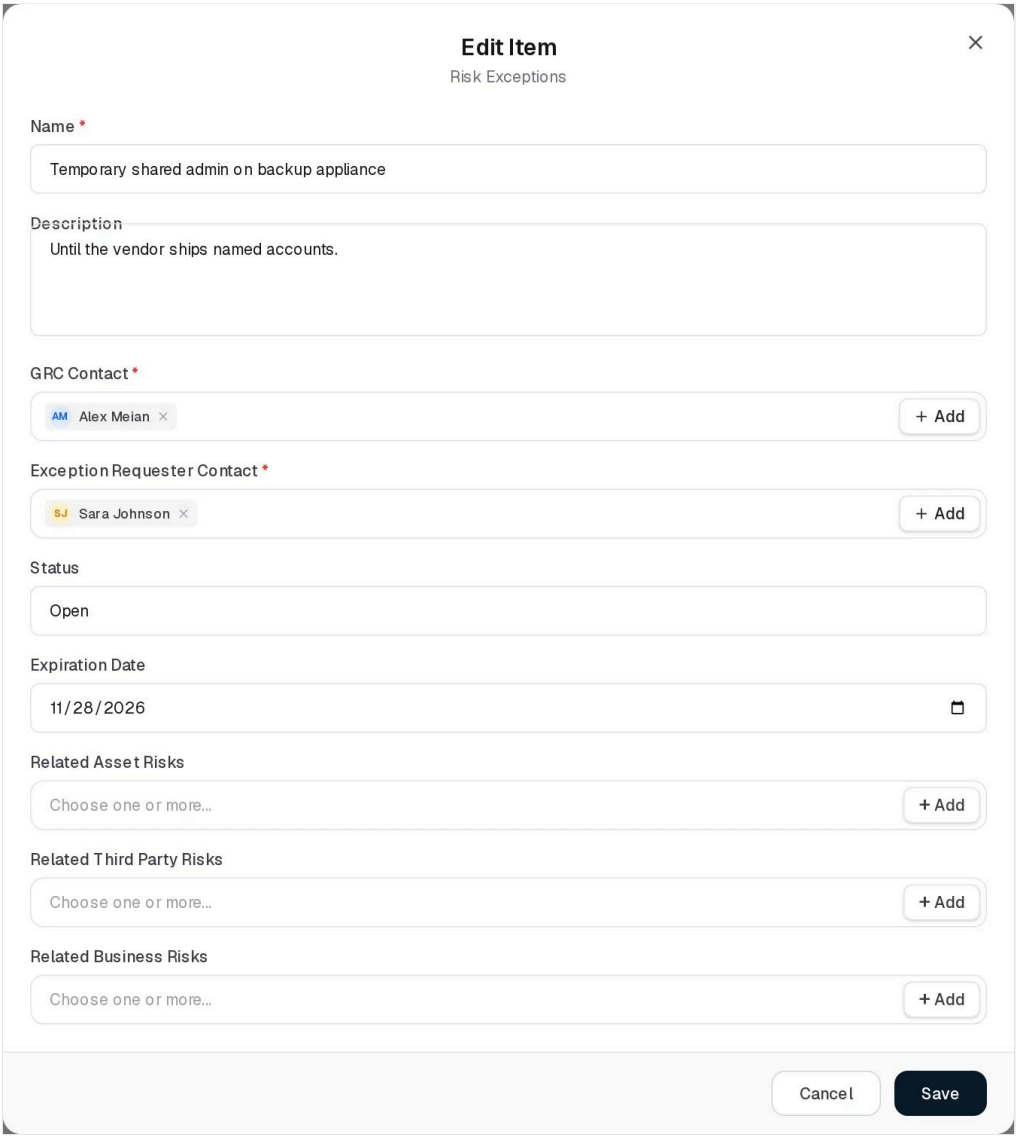
Viewing and editing a record

View opens **View Item** (subtitle *Risk Exceptions*) with Name, Description, GRC Contact, Exception Requester Contact, Status (the raw stored value, for example PENDING), Start Date, Expiration Date and the names of the related risks. It does not show the Dynamic Status or the Closure Date.



View Risk Exception

Edit opens **Edit Item** with the same fields as Add. Saving shows “Risk exception updated.”



Edit Risk Exception

Points to know when editing:

- **Status** offers only Open and Closed. An exception whose stored status is Pending or Approved shows **Open** in the dropdown, as in the screenshot, but keeps its stored status when you save without touching the field.
- Choosing **Closed** stamps today’s date as the **Closure Date**; choosing Open again clears it.
- Removing a risk from a **Related … Risks** field also removes the exception from that risk’s **Treatment: Risk Exceptions**, even when the link was made from the risk’s side.

Delete asks “Delete risk exception ?”. Deleting the exception also takes it out of the **Treatment: Risk Exceptions** of every linked risk and updates those risks’ stored status.

Statuses

Status (stored). The form offers:

Value	Set by	Meaning
Open	User (default)	The exception is being carried
Closed	User	The exception is over; the Closure Date is stamped

The server knows further values that only the API sets: **Pending** (`POST .../{id}/submit`), **Approved** and **Denied** (`.../approve` , `.../deny` , with a decision reason; administrators only), **Expired** (the expiry job), and **Rejected** and **Revoked**. The interface has no buttons for submitting, approving or denying.

Dynamic Status (computed every time the register is read, in this order):

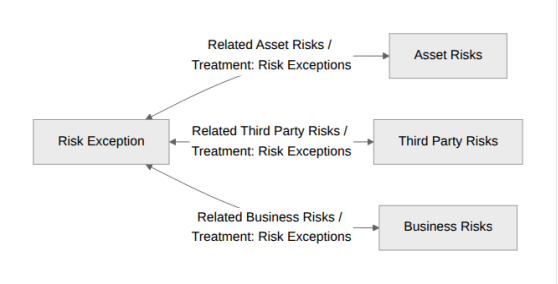
Value	Colour	Rule
Closed	Green	A Closure Date is set
Expired	Red	Status is Open, Pending or Approved and the Expiration Date is before today; or Status is Expired
Active	Green	Status is Approved and not expired
Pending	Amber	Status is Open or Pending and not expired
Closed	Green	Status is Denied, Rejected or Revoked

An Open exception therefore shows **Pending** until it expires. Example: “Temporary shared admin on backup appliance” expires on 28 Nov 2026; from 29 Nov 2026 it shows **Expired** without anyone editing it.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Asset Risks	Many to many, one relation	**Related Asset Risks** here, or **Treatment: Risk Exceptions** on the risk	Here: **Related Asset Risks** count (clickable). Asset Risks: **Treatment Risk Exceptions** (names).
Third Party Risks	Many to many, one relation	**Related Third Party Risks** here, or on the risk	Here: count (clickable). Third Party Risks: **Treatment Risk Exceptions**.
Business Risks	Many to many, one relation	**Related Business Risks** here, or on the risk	Here: count (clickable). Business Risks: **Treatment Risk Exceptions**.

What a link does to the risk:

- While the risk lists the exception under **Treatment: Risk Exceptions**, the risk’s stored status is **Exception Active**.
- When such an exception passes its Expiration Date without a Closure Date, the risk shows the **Exception Expired** flag.
- When an exception is approved through the API, its risk links move to the risks’ **Treatment: Risk Exceptions**. When it is denied, expired by the job or deleted, it is removed from the risks’ treatment but stays listed here, so this register still shows what it covered.
- Closing an exception with the form does not remove it from the risks’ treatment; remove it on the risk if it no longer applies.

Automations and notifications

Automation	Schedule	State in this release
Start Date stamp	On creation	Active
Closure Date stamp	When Status is set to Closed	Active
Dynamic Status	Every read	Active: **Expired** appears the day after the Expiration Date
Automatic expiry (`RiskExceptionScheduler`)	Hourly	**Implemented but not active in this release.** The backend does not enable scheduled jobs. If it ran, it would set every Open, Pending or Approved exception whose Expiration Date is today or earlier to Expired, remove it from the linked risks' treatment and update their status. The same action exists as `POST /risk-management/risk-exceptions/expire-due`, which the interface does not call.
`ExceptionExpirationJob`	Nightly	Not related to this register (it handles exception requests in the issue module) and also not active.

Because the expiry job does not run, the stored **Status** of an expired exception stays Open, Pending or Approved; only the Dynamic Status shows **Expired**. No notification is sent when an exception is created, nears its expiration date or expires.

Permissions

Action	Needed access
See the page	**View** on Risk Management › Risk Exceptions
Create, Edit	**Manage** on Risk Management › Risk Exceptions
Delete	**Full Control** on Risk Management › Risk Exceptions
Import CSV	**Manage** (the import does not work, see below)
Link a risk	You must be able to see that risk in its own register
Approve or deny (API only)	Administrators
Activity Log	The group's **Comments & Attachments** level

Risk exceptions have no assignment rights and no record-level visibility: everyone with access to the page sees every exception. See Permissions and access.

How to

Record an accepted risk

1. Open **Risk Management › Risk Exceptions** and click **Add Item**.
2. Enter **Name** "Accept legacy kiosk OS", a **Description**, **GRC Contact** Alex Meian and **Exception Requester Contact** Mike Brown.
3. Set **Expiration Date** to the planned end, for example 11 Feb 2027.
4. Under **Related Asset Risks** choose "Unsupported OS on kiosks".
5. Click **Save**. The **Related Asset Risks** column shows 1; click it to see the risk.

Close an exception early

1. Click **Edit** on the exception and set **Status** to **Closed**.
2. Click **Save**. **Closure Date** shows today and Dynamic Status **Closed**.
3. Open the linked risk and remove the exception from **Treatment: Risk Exceptions** if it still appears there.

Find exceptions that have run out

1. Open the register and look at the **Dynamic Status** column for **Expired**.
2. For each, either set a new **Expiration Date** (renewal) or set **Status** to **Closed**.
3. In the risk registers, risks still carrying the exception in their treatment show **Exception Expired** until you do so.

CSV import

Import CSV shows “CSV Import (Risk Exceptions): the import structure is not ready yet.” and then opens a demo dialog whose upload fails. There is no import or export for risk exceptions on the server either.

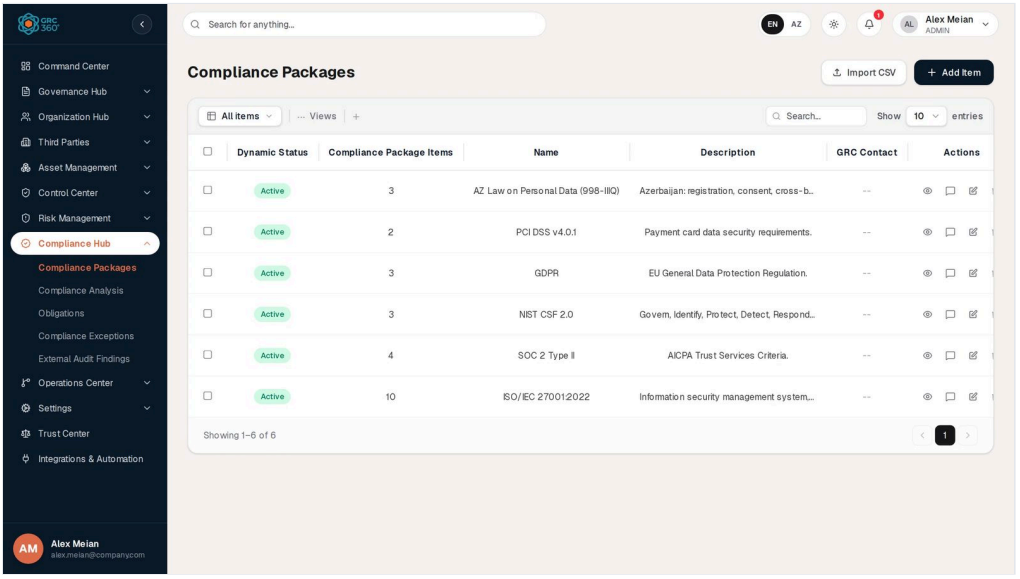
Limitations and known issues

- The automatic expiry job does not run; the stored Status of an expired exception is not changed.
- Submitting, approving and denying exist only in the API; the form offers only Open and Closed, and shows Open for a Pending or Approved exception.
- The **View Item** dialog shows the raw status (for example PENDING) and omits Dynamic Status and Closure Date.
- Closing an exception through the form leaves it in the linked risks’ treatment, so those risks stay **Exception Active**.
- An Open exception reads **Pending** in Dynamic Status.
- The **Description** label overlaps the top of its text box in the Add and Edit forms.
- Import CSV does not work.

Compliance Hub

> **Module:** Compliance Hub · **Route:** `/compliance-hub` (opens **Compliance Packages**) · **Permission module:** `compliance_hub`

The Compliance Hub holds the frameworks, laws and standards your organisation must meet, breaks each one down into individual requirements, and records how every requirement is met: which controls, policies and projects satisfy it, which risks put it at stake, which exceptions excuse it and which audit findings show it is broken. It also holds a separate register of legal obligations and a register of findings raised by external auditors.



Compliance Packages register

Pages

Page (sidebar label)	Route	Permission key	What it holds
Compliance Packages	`/compliance-hub/frameworks`	`compliance_hub.frameworks`	One record per framework, law or standard. Clicking a package opens its requirement items.
Compliance Packages › Items	same route, after clicking a package	`compliance_hub.frameworks_items`	The chapters and requirement items of one package.
Compliance Analysis	`/compliance-hub/assessments`	`compliance_hub.assessments`	One row per requirement item: the compliance strategy (Compliant, Not Applicable, Not Compliant) and everything linked to the requirement.
Obligations	`/compliance-hub/obligations`	`compliance_hub.obligations`	Legal and regulatory obligations (law, article, authority) with a recorded compliance status and a next audit date.
Compliance Exceptions	`/compliance-hub/compliance-exceptions`	`compliance_hub.compliance_exceptions`	Time-limited, accepted non-compliance with one or more requirement items.
External Audit Findings	`/compliance-hub/audit-findings`	`compliance_hub.audit_findings`	Findings raised by external auditors, the requirement items they affect, and evidence attachments.

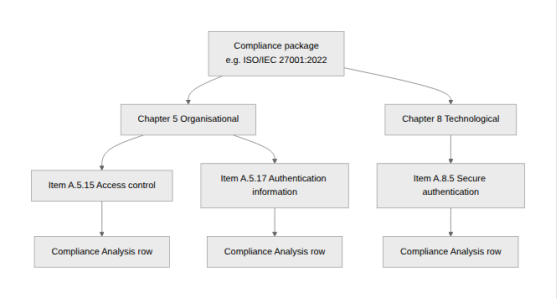
Opening `/compliance-hub` without a page redirects to **Compliance Packages**.

The compliance model

Frameworks are not pre-loaded

GRC360 does not ship framework content. A new organisation starts with an empty **Compliance Packages** register. Your team creates each package (for example *ISO/IEC 27001:2022*) and then fills it with requirement items, either one by one with **Add Item** on the package's items page or from a CSV file with **Import CSV** on that page. The demo data used in this guide contains six packages created this way: ISO/IEC 27001:2022 (10 items), SOC 2 Type II (4), NIST CSF 2.0 (3), GDPR (3), PCI DSS v4.0.1 (2) and AZ Law on Personal Data (998-IIIQ) (3).

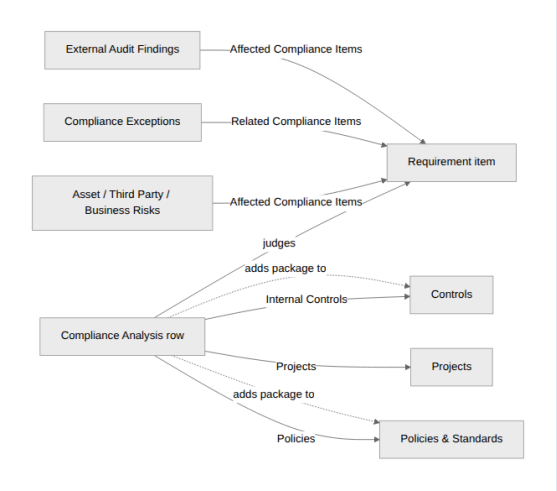
Package, chapters, requirement items



- A **compliance package** is the framework itself: name, description, GRC contact.
- A **chapter** is not a record of its own. Every requirement item carries a Chapter ID, Chapter Name and Chapter Description, and the items page builds its list of chapters from the items already in the package. Choosing an existing chapter when adding an item copies those three values onto the new item.
- A **requirement item** (shown in the UI as a *Compliance Package Item*) is one requirement: Item ID (for example `A.8.5`), Item Name, Item Description and Item Additional Information. The Item ID must be unique inside its package.

How the other records attach to a requirement item

Everything in the Hub, and several records in other modules, attaches at the level of the requirement item. The link is stored in different places depending on who owns it, but every link is visible on the item's row in **Compliance Analysis** and editable from its **Edit Action** dialog.



Attached record	Where the link is stored	Where you make it
Controls (Control Center)	On the Compliance Analysis row (**Internal Controls**)	Compliance Analysis › Edit Action › **Treatment** tab. Saving also adds the package to the control's own **Compliance Package** field.
Policies & Standards (Control Center)	On the Compliance Analysis row (**Policies**)	Edit Action › **Treatment**. Saving also adds the package to the policy's **Compliance Package** field.

Attached record	Where the link is stored	Where you make it
Projects (Operations Center)	On the Compliance Analysis row (**Projects**)	Edit Action › **Treatment**. The project's **Compliance Package** column is derived from these links.
Asset, Third Party and Business Risks	On the risk (**Affected Compliance Items**)	The risk's own form, or Edit Action › **Asset Risks** tab (writes back to the risk).
Compliance Exceptions	On the exception (**Related Compliance Items**, several allowed)	The exception's form, or Edit Action › **Treatment** › **Compliance Exception** (writes back to the exception).
External Audit Findings	On the finding (**Affected Compliance Items**, several allowed)	The finding's form, or Edit Action › **General** › **Findings** (writes back to the finding).
Obligations	An obligation-to-requirement mapping exists in the backend (`POST /compliance/obligations/{id}/map-requirements`) but no screen uses it.	Not available in the UI.

What Compliance Analysis computes

Every requirement item gets a row on the **Compliance Analysis** page automatically. When the first item is added to a package (by hand or by CSV import), the system creates a standing assessment for that package called *Compliance Analysis* and gives it one row per item; every later item gets its row the moment it is saved. A start-up job also fills in rows for packages that predate this behaviour. Each new row starts with the strategy *Under Review*, which the grid shows as `--` (not judged yet).

For each row the system computes or derives:

What	Rule
Compliance Strategy	Set by a person (Compliant, Not Applicable, Not Compliant). Overridden by the system to *Not Compliant* when a linked risk sits above the risk appetite. When a linked risk is saved, every row of the requirements it names is re-derived: *Not Compliant* if any linked risk is above appetite, otherwise *Compliant*. Rows marked *Not Applicable* are never changed by a risk.
Dynamic Status	One amber marker per lapse found behind the row's linked controls: *Control Last Audit Expired* (a control audit planned before today that is not completed), *Asset Risk Review Expired*, *Third Party Risk Review Expired*, *Business Risk Review Expired* (a risk treated by one of those controls whose next review date is in the past). `--` when nothing has lapsed.
Compliance percentage (Assessment summaries)	(Compliant + 0.5 × Partially Compliant) ÷ (all rows − Not Applicable rows) × 100, rounded to one decimal. Not Applicable rows are left out of the denominator. 0 when no row applies.

The same strategy counts feed the Trust Center's per-framework posture (compliant items out of total items, for packages that are not deleted).

Statuses at a glance

Register	Status a person sets	Dynamic Status the system shows
Compliance Packages	None in the form (the stored status is always *Active*)	*Active* while the package is switched on, *Inactive* otherwise. The form has no switch, so packages always read *Active*.
Compliance Analysis	Compliance Strategy	Expiry markers (see above)
Obligations	Compliance Status	*Current*, *Needs Review* (next audit date in the past), *Missing Date*
Compliance Exceptions	Status (Open, Closed)	*Closed*, *Expired*, *Active* (approved and not expired), *Pending* (any other open state)

Register	Status a person sets	Dynamic Status the system shows
External Audit Findings	Status (Open, Closed)	*Closed*, *Resolved*, *Overdue* (due date in the past), otherwise the status itself

Details and the exact rules are on each page and in Status and Dynamic Status rules.

Automations

- **Analysis rows**: created automatically for every new requirement item (see above). Not a scheduled job; it happens when the item is saved, and once at application start-up for older packages.
- **Strategy from risks**: re-derived whenever an Asset, Third Party or Business Risk that names requirement items is saved.
- **Exception expiry job**: an hourly job that would set past-due exceptions to *Expired* is implemented but not active in this release (scheduling is not enabled in the backend). The **Dynamic Status** of an exception still shows *Expired* as soon as its expiration date passes, because it is computed every time the register is read.
- **Notifications**: the Compliance Hub sends none. The notification type `COMPLIANCE_REMINDER` exists but nothing produces it.

Permissions

Each page, and the **Items** section of Compliance Packages, has its own access level in the group settings (No Access, View, Manage, Full Control), plus the group's Comments & Attachments level. See Permissions and access. Buttons you may not use stay visible but locked; clicking one opens **Request Access**. The built-in *Third Party* group has View and edit rights on **Compliance Analysis** only, limited to its own records.

Shared behaviour

Search, **Views** (column visibility), paging, the selection toolbar, the View dialog, comments in the Activity Log and the delete confirmation work the same way on every register; see Working with registers.

Related pages

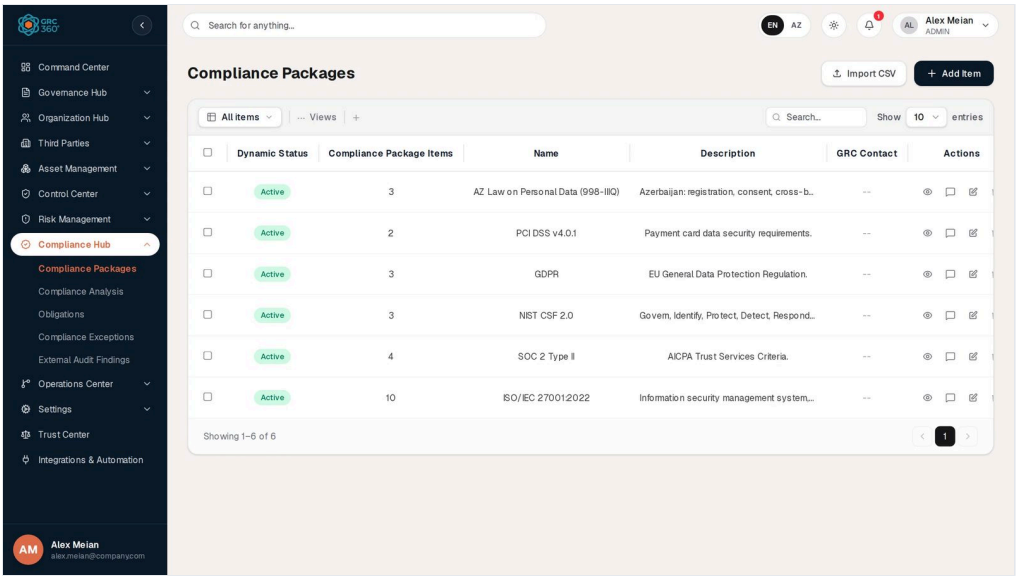
- Controls and Policies & Standards: **Compliance Package** column.
- Asset Risks, Third Party Risks, Business Risks: **Affected Compliance Items**.
- Projects: **Compliance Package** column.
- Trust Center: public per-framework compliance posture.
- Scenario: preparing for an ISO/IEC 27001 audit.

Compliance Packages

> **Module:** Compliance Hub › Compliance Packages · **Route:** `/compliance-hub/frameworks` · **Permission key:** `compliance_hub.frameworks` (items: `compliance_hub.frameworks_items`)

A compliance package is a framework, law or standard your organisation has to meet, such as ISO/IEC 27001:2022, SOC 2 Type II or the Azerbaijani Law on Personal Data. Each package holds its requirements as **compliance package items**, grouped by chapter. GRC360 ships no framework content: the compliance team creates the packages and loads their items, by hand or from a CSV file. Once items exist, each one gets a row on the Compliance Analysis page, which is where compliance is actually judged.

The page has two levels: the list of packages, and, after you click a package, the list of its items.



Compliance Packages register

At a glance

A record is	One framework, law or standard (package); one requirement of it (item)
Typical owner	Compliance manager or GRC officer (the package's **GRC Contact**)
Links to	GRC contacts (users or groups)
Linked from	Compliance Analysis rows, Compliance Exceptions, External Audit Findings, risks (Affected Compliance Items), Controls and Policies & Standards (Compliance Package), Projects (derived), Trust Center posture
Tabs	None in the dialog. The package's items open as a second page: **Compliance Package Items -** (permission section **Items**)
Automations	Every item saved or imported gets a Compliance Analysis row automatically. Dynamic Status is computed on read.

The register (list view)

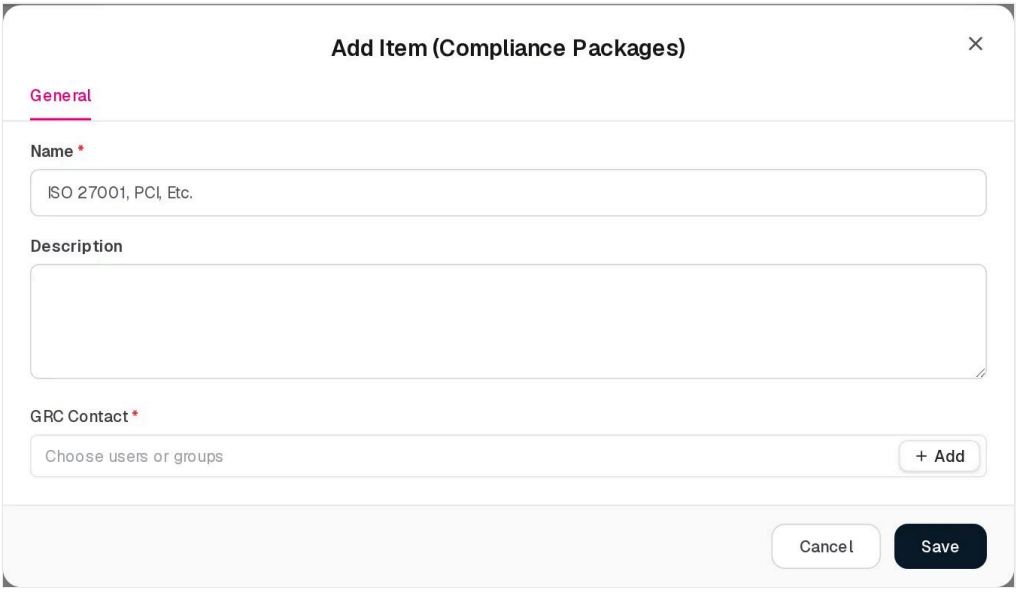
The packages grid is loaded in one request and sorted, searched and filtered in the browser. It opens with the newest package first (in the demo data ISO/IEC 27001:2022, created first, is at the bottom). The shared grid behaviour (search, Views, paging, selection, comments) is described in Working with registers. Clicking anywhere on a row (outside the checkbox and the action buttons) opens that package's items.

Column	What it shows	Source
Dynamic Status	*Active* (green) when the package is switched on, *Inactive* (grey) when it is not. See Statuses.	Computed by the system
Compliance Package Items	Number of live (not deleted) requirement items in the package, for example `10` for ISO/IEC 27001:2022	Computed
Name	Package name	Entered
Description	First part of the description; hover to read the rest	Entered
GRC Contact	The package's GRC contacts, comma-joined	Linked (users or groups)

Header buttons: **Import CSV** and **Add Item**. On this level **Import CSV** is not wired to a real import: it shows the message "CSV Import (Compliance Packages): the import structure is not ready yet." and then a demonstration dialog whose **Validate** fails. Items are imported on the package's own items page instead (see CSV import).

Creating a record

Click **Add Item**. The dialog **Add Item (Compliance Packages)** opens on a single **General** tab.



Add Compliance Package

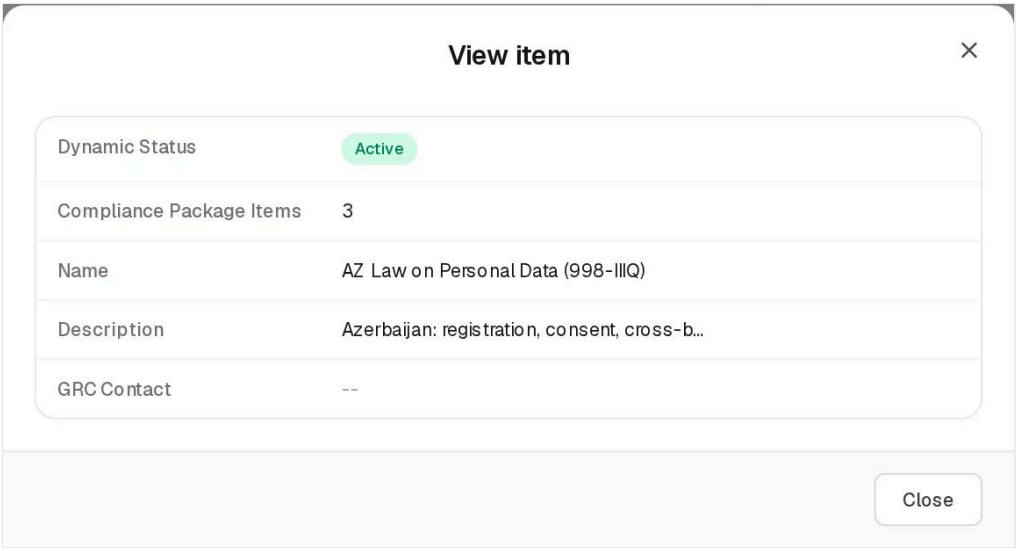
Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Must not be empty ("Name is required."). Must be unique among the organisation's packages, ignoring case; a duplicate is refused with "Compliance package with name '' already exists". Placeholder: *ISO 27001, PCI, Etc.*	ISO/IEC 27001:2022
Description	Multi-line text	No	Free text	Information security management system, Annex A controls.

Field	Type	Required	Rules and allowed values	Example
GRC Contact	User/group picker, several allowed	Yes (in the form)	At least one (“GRC Contact is required.”). Users and groups can both be chosen. The backend itself does not require it.	Alex Meian

The form has no Active switch and no status field. Every package is saved as active, with stored status *Active* and version *1.0*.

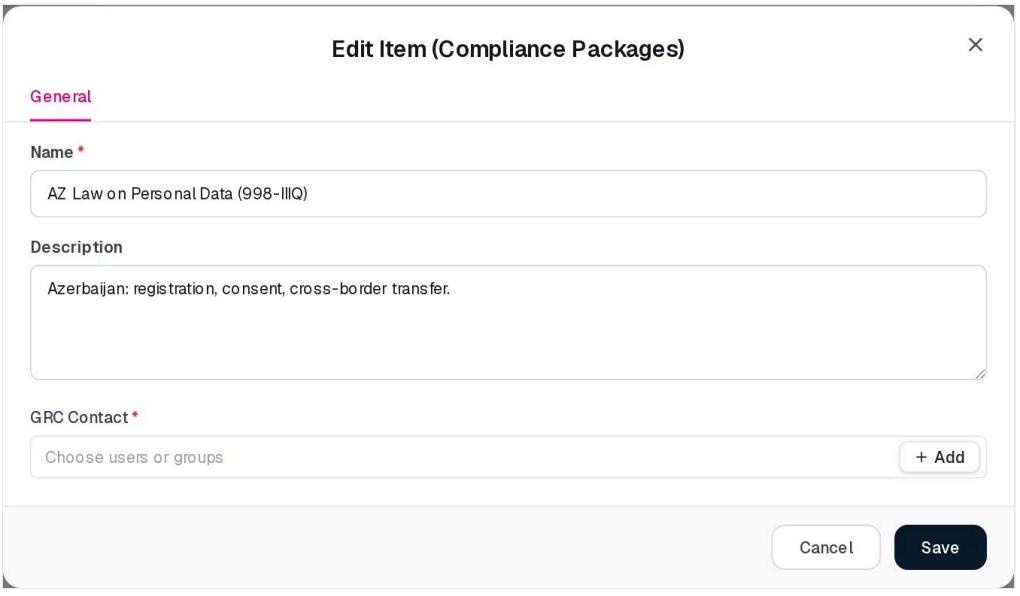
The same dialog opens from the **+ Add** button next to a package picker elsewhere (for example on the External Audit Findings form), and the new package is selected there straight away.

Viewing and editing a record



View Compliance Package

The **View** button (eye icon) opens the read-only dialog **View item** with the grid’s five columns, including the shortened description. **Edit** opens **Edit Item (Compliance Packages)** with the same three fields as Add, filled in.



Edit Compliance Package

Delete asks “Delete ?” with the note “Its requirement items will be removed from the Hub as well.” The package is soft-deleted: it disappears from this grid and from every package picker. Its items are not deleted themselves (see Limitations).

Statuses

Value	Set by	Meaning
Active	System (Dynamic Status)	The package is switched on. This is the value for every package created from the UI. Green.
Inactive	System (Dynamic Status)	The package's active flag is off. The UI has no control for this flag, so a package only reads Inactive if it was switched off through the API. Grey.

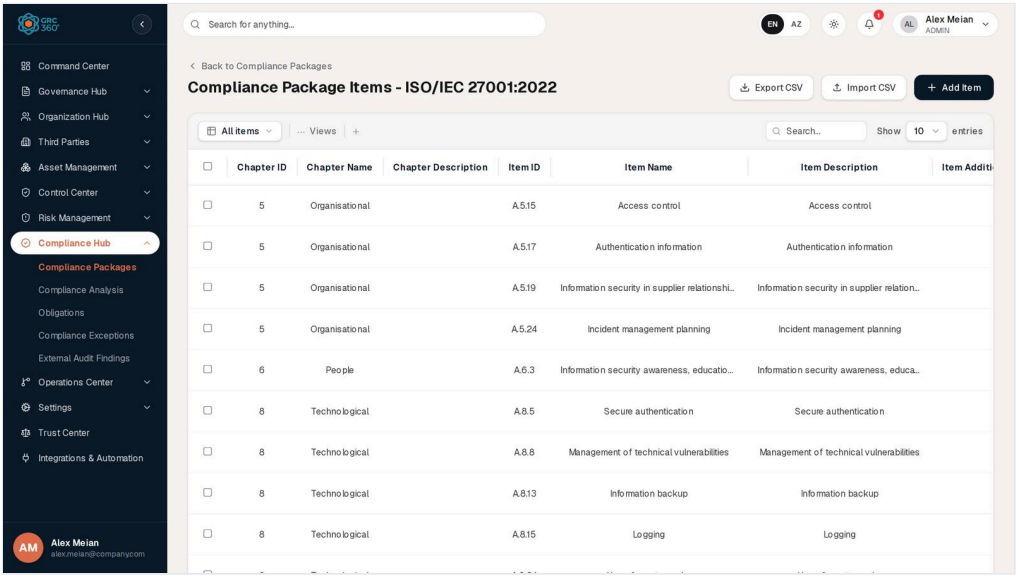
There is no user-selectable status. The packages list keeps a stored status (*Active*) that is not shown as a column; it only feeds the grid's status filter, where the choice is **All items** or **ACTIVE**.

Tabs

The Add and Edit dialogs have a single **General** tab. The package's requirement items are not a tab but a second page, opened by clicking a package; it is described in Compliance Package Items below and has its own permission section **Items**.

Compliance Package Items (the requirements of one package)

Click a package row. The page is replaced by the grid **Compliance Package Items -** , with a **Back to Compliance Packages** link above it. This grid is the permission section **Items** of Compliance Packages (`frameworks_items`).



Compliance Package Items of ISO/IEC 27001:2022

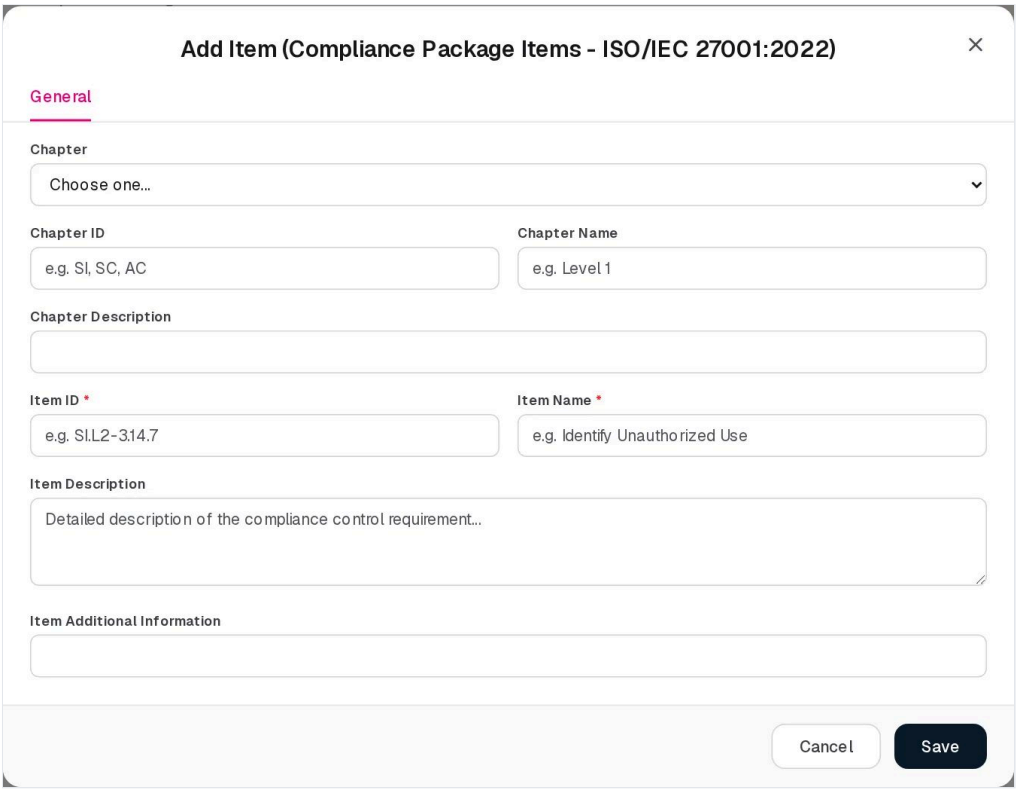
Items are listed in their stored sort order (the order in which they were loaded).

Column	What it shows	Source
Chapter ID	Chapter identifier, for example `5`	Entered
Chapter Name	For example *Organisational*	Entered
Chapter Description	Chapter text, often empty	Entered
Item ID	Requirement identifier, for example `A.5.15`	Entered
Item Name	For example *Access control*	Entered
Item Description	First part of the requirement text; hover for the rest	Entered
Item Additional Information	Extra guidance	Entered

Header buttons: **Export CSV**, **Import CSV**, **Add Item**.

Adding an item

Click **Add Item**. The dialog **Add Item (Compliance Package Items -)** opens on a **General** tab.



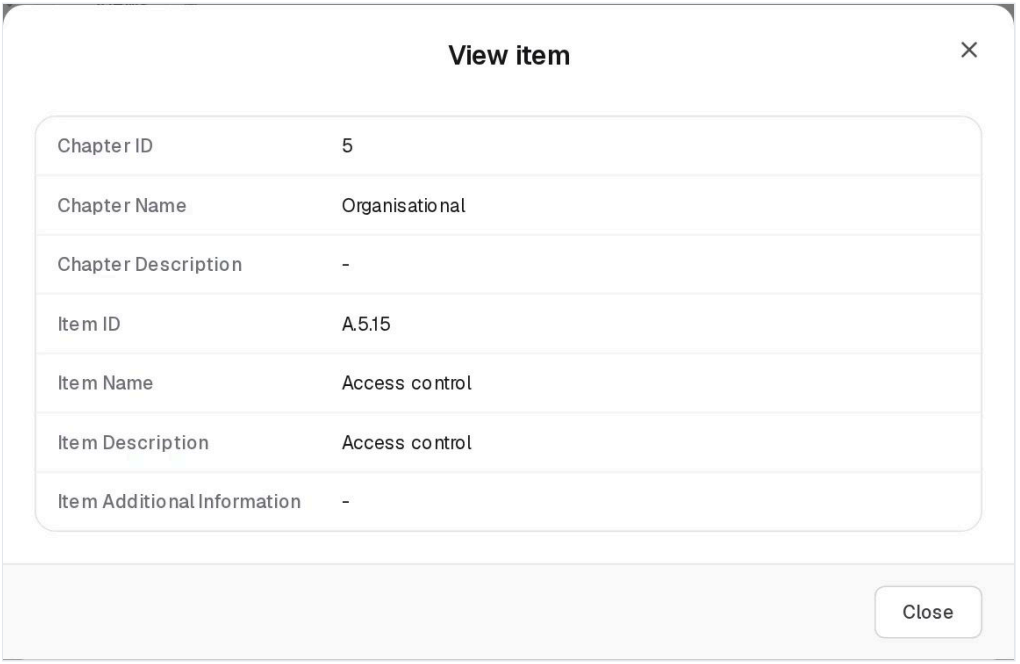
Add Compliance Package Item

Field	Type	Required	Rules and allowed values	Example
Chapter	Dropdown	See rule	**Choose one…** or one of the chapters already used in this package, shown as “ — ”. Choosing one hides the three chapter fields below and copies the chapter’s ID, name and description onto the item.	5 — Organisational
Chapter ID	Text	One of Chapter ID or Chapter Name, when no chapter is chosen	Shown only when **Chapter** is *Choose one…*. Placeholder *e.g. SI, SC, AC*. Error when both ID and name are empty: “Choose an existing chapter, or fill in the new chapter’s ID and name.”	8
Chapter Name	Text	See Chapter ID	Shown only for a new chapter. Placeholder *e.g. Level 1*	Technological
Chapter Description	Text	No	Shown only for a new chapter	

Field	Type	Required	Rules and allowed values	Example
Item ID	Text	Yes	“Item ID and Item Name are required.” Must be unique inside the package, ignoring case: “Item number ‘’ already exists in package”. Placeholder *e.g. SI.L2-3.14.7*	A.8.5
Item Name	Text	Yes	See Item ID. Placeholder *e.g. Identify Unauthorized Use*	Secure authentication
Item Description	Multi-line text	No	Placeholder *Detailed description of the compliance control requirement…*	Secure authentication
Item Additional Information	Text	No	Free text	

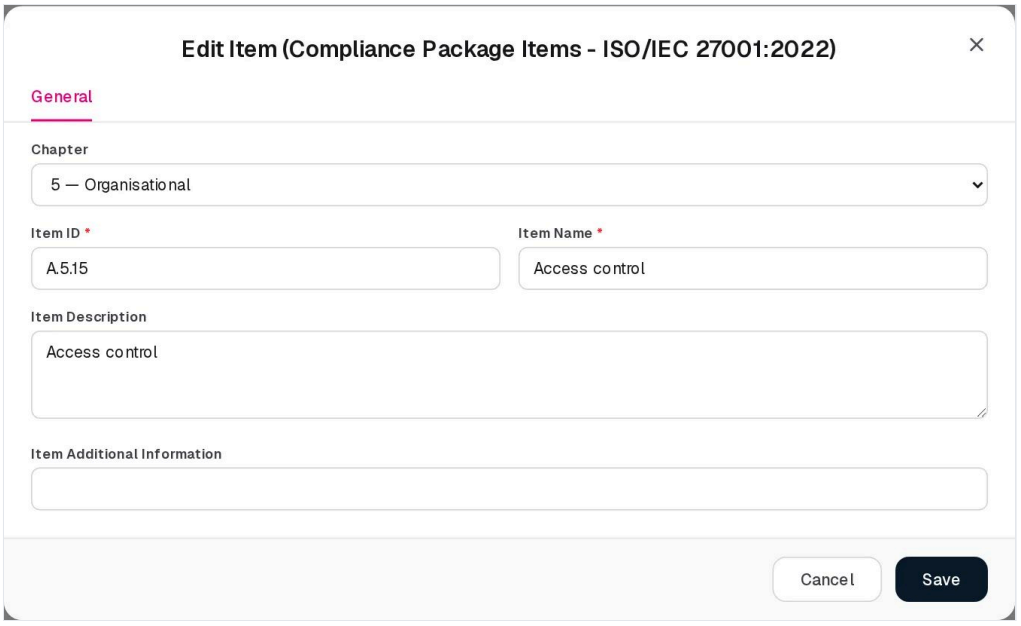
There is no field for sort order or category; new items are saved with sort order 0 and active. Saving shows “Requirement item added.” and, in the same step, creates the item’s row on **Compliance Analysis** with strategy *Under Review*.

Viewing, editing and deleting an item



View Compliance Package Item

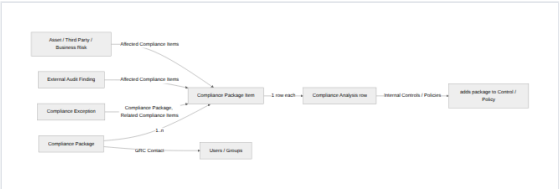
View opens **View item** with the item’s seven columns, read-only. **Edit** opens **Edit Item (Compliance Package Items -)** with the item’s own chapter already selected in **Chapter**; picking another chapter moves the item to it.



Edit Compliance Package Item

Delete asks “Delete ?” and soft-deletes the item. The package’s item count drops by one.

Relationships



Related record	Direction	How the link is made	Where it shows
Requirement items	Package → items, one to many	Add Item or Import CSV on the items page	**Compliance Package Items** column (count, not clickable); items page
GRC Contact (users, groups)	Package → people, many	Package form	**GRC Contact** column
Compliance Analysis rows	Item → row, one per item in the package’s standing analysis	Automatic when the item is saved or imported	Compliance Analysis, framework selector shows “ ()”
Controls, Policies & Standards	Package ← control/policy, many to many	On the control or policy form (**Compliance Package**), or automatically when a control or policy is linked to one of the package’s items in Compliance Analysis	**Compliance Package** column on Controls and Policies & Standards
Projects	Package ← project, derived	A project linked to one of the package’s items in Compliance Analysis	**Compliance Package** column on Projects
Compliance Exceptions	Item ← exception, many to many; package ← exception, one	Exception form (**Related Compliance Items**); the package is taken from the first item picked	Compliance Exceptions
External Audit Findings	Item ← finding, many to many	Finding form (**Affected Compliance Items**)	External Audit Findings
Risks (Asset, Third Party, Business)	Item ← risk, many to many	Risk form (**Affected Compliance Items**)	Risk registers; Compliance Analysis Edit Action › **Asset Risks**
Trust Center	Package → public posture	Automatic	Trust Center framework list (compliant items / total items)

Automations and notifications

- **Compliance Analysis rows**: when an item is added (form or CSV import, not a dry run), the system makes sure the package has its standing assessment named *Compliance Analysis* and that every live item has a row in it. Existing rows keep their strategy and links. The same check runs for every package each time the application starts.
- **Dynamic Status** is computed every time the list is read.
- No scheduled jobs and no notifications concern this page.

Permissions

Action	Needed access
See the page and open a package's items	View on Compliance Hub › Compliance Packages (the items page also needs View on the **Items** section to load its rows)
Create / Edit a package	Manage on Compliance Hub › Compliance Packages
Delete a package	Full Control on Compliance Hub › Compliance Packages
Create / Edit an item	Manage on Compliance Packages › **Items**
Delete an item	Full Control on Compliance Packages › **Items**
Import items (**Import CSV** on the items page)	Manage on Compliance Packages › **Items** (import right of the section)
Export items (**Export CSV** on the items page)	View on Compliance Packages (the export right belongs to the package page, not to the Items section)
Comments on a package / on an item	Comments & Attachments level of the group; package comments are kept under Compliance Packages, item comments under its **Items** section

Locked buttons stay visible and open **Request Access**. See Permissions and access.

How to

Create a framework and its first chapter

1. Open **Compliance Hub › Compliance Packages** and click **Add Item**.
2. Enter **Name** `NIST CSF 2.0`, a **Description**, and pick yourself under **GRC Contact**. Click **Save**.
3. Click the new row. The page shows **Compliance Package Items - NIST CSF 2.0**.
4. Click **Add Item**. Leave **Chapter** on *Choose one…*, enter **Chapter ID** `PR` and **Chapter Name** `Protect`.
5. Enter **Item ID** `PR.AA-01` and **Item Name**, then **Save**. The item now also appears on **Compliance Analysis** under NIST CSF 2.0.

Add another requirement to an existing chapter

1. Open the package (for example *ISO/IEC 27001:2022*) and click **Add Item**.
2. In **Chapter** choose `8 — Technological`. The chapter fields disappear.
3. Enter **Item ID** `A.8.16` and **Item Name** `Monitoring activities`, then **Save**.

Load a whole framework from a spreadsheet

1. Prepare a CSV file with the header `chapterId,chapterName,chapterDescription,itemNumber,itemName,itemDescription,itemAdditionalInfo,category` and one requirement per row (see CSV import).
2. Open the package and click **Import CSV**. Dismiss the notice "the import structure is not ready yet"; the import dialog opens anyway.
3. Choose the file and click **Validate**. Check **Total Rows**, **Valid** and **Errors**.
4. Click **Import rows**. The item count on the packages list and the framework selector on Compliance Analysis update.

Export a package's requirements

1. Open the package and click **Export CSV**.
2. The browser downloads `<package name>-items.csv` with the same eight columns the import accepts.

CSV import

Available on the **items page** of a package only (`POST /api/v1/compliance/packages/{id}/import` , with a dry run first).

Column (position)	Required	Notes
1 chapterId	No	
2 chapterName	No	
3 chapterDescription	No	
4 itemNumber	Yes	Must not already exist in the package (case-insensitive)
5 itemName	Yes	
6 itemDescription	No	
7 itemAdditionalInfo	No	
8 category	No	Stored, not shown anywhere in the UI

The first line is always skipped as a header. A row with fewer than five columns fails with "Row n: Invalid column count. Requires chapterId,chapterName,chapterDescription,itemNumber,itemName"; an empty Item ID or name fails with "Row n: Item number and name cannot be empty"; a duplicate fails with "Row n: Item number '' already exists in package". Quoted fields are supported. Imported items get sort order 0.

Export (`GET /api/v1/compliance/packages/{id}/export`) writes the same eight columns for the live items. On the packages list itself, **Import CSV** only opens the demonstration dialog and does not import anything.

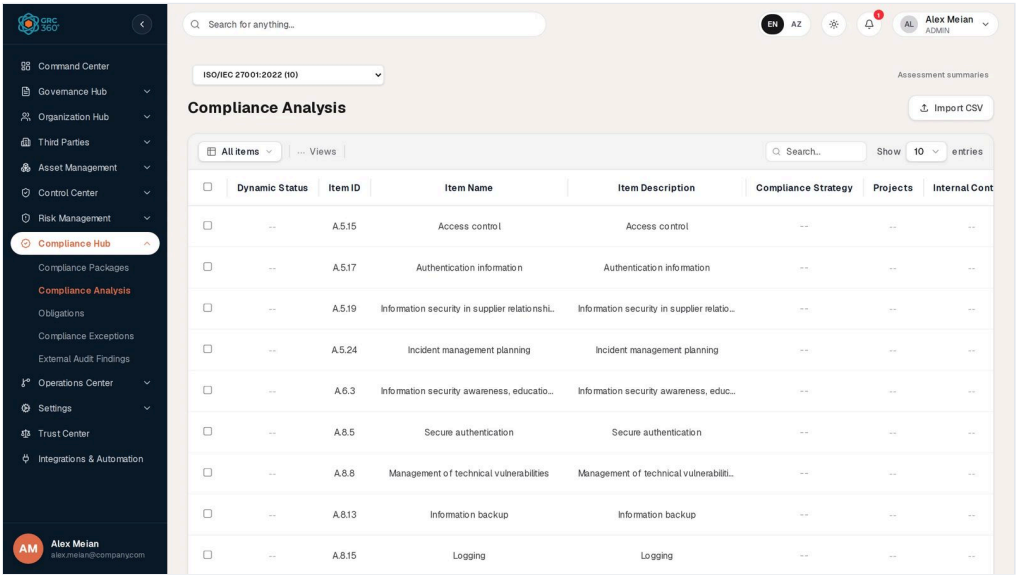
Limitations and known issues

- **Deleting a package does not delete its items.** The confirmation says the items "will be removed from the Hub as well", but only the package is flagged as deleted. Its Compliance Analysis rows are still returned when **All frameworks** is selected on Compliance Analysis, and its items remain selectable in the Compliance Exceptions item picker, which is built from those rows.
- **Deleting an item does not remove its Compliance Analysis row.** The row keeps showing the deleted item until it is removed on Compliance Analysis.
- **No Active switch.** The Dynamic Status column can only ever show *Active* for packages managed from the UI.
- **Import CSV on the packages list** is a demonstration dialog only; use the items page.
- **No sort-order field.** Items added by hand or by import get sort order 0, so their position relative to other items with the same sort order is not guaranteed.
- **GRC Contact** is required by the form but not by the backend; packages created through the API or the demo data may show an empty GRC Contact cell (all six demo packages do).

Compliance Analysis

> **Module:** Compliance Hub › Compliance Analysis · **Route:** `/compliance-hub/assessments` · **Permission key:** `compliance_hub.assessments`

Compliance Analysis is where each requirement of a framework is judged. It lists one row per requirement item of the selected compliance package, with the compliance strategy recorded for it (Compliant, Not Applicable, Not Compliant) and the controls, policies and projects that satisfy it. The **Edit Action** dialog of a row also links the requirement to audit findings, compliance exceptions and risks. Compliance managers and control owners work here when preparing for or responding to an audit.



Compliance Analysis

At a glance

A record is	One requirement item as judged in one assessment (an *assessment item*). Every package has one standing assessment named *Compliance Analysis* that holds a row for each of its items.
Typical owner	Compliance manager; the row's **Owner**
Links to	Controls, Policies & Standards, Projects (stored on the row); Asset, Third Party and Business Risks, Compliance Exceptions, External Audit Findings (stored on those records, edited from here)
Linked from	Compliance Packages (each item creates its row); Trust Center (posture); Projects (**Compliance Package** column)
Tabs	None on the page. The **Edit Action** dialog has four tabs: **Compliance Item Details**, **General**, **Treatment**, **Asset Risks**
Automations	Rows created automatically for every requirement item; strategy forced to *Not Compliant* by risks above appetite; Dynamic Status expiry markers computed on read

How the page is organised

- **Framework selector** (top left): **All frameworks** or one package, shown as " ()". The page opens on the first package in the list rather than on All frameworks. Changing the selection closes any open assessment.
- **Assessment summaries** (top right link): shows or hides a second grid with one row per assessment of the selected framework (see Assessment summaries). Hidden when the page opens; the link then reads **Hide assessment summaries**.

- **Compliance Analysis** grid: the requirement rows. Shows every row of the selected framework (or of all frameworks), or, after you click an assessment in the summaries grid, only that assessment's rows with a **Back to the whole framework** link above.

The shared grid behaviour (search, Views, paging, selection, comments) is described in Working with registers. Rows keep a fixed order (row creation time, then the item's position in its package), so editing a row does not move it.

The register (list view)

Column	What it shows	Source
Dynamic Status	One amber dot per lapse found behind the row's **Internal Controls**; hover for the names. `--` when nothing has lapsed. See Statuses.	Computed by the system
Item ID	Requirement identifier, for example `A.8.5`	From the package item
Item Name	For example *Secure authentication*	From the package item
Item Description	First part of the requirement text; hover for the rest	From the package item
Compliance Strategy	*Compliant* (green), *Not Applicable* (grey), *Not Compliant* (red), *Partially Compliant* (amber, older rows only) or `--` when not judged yet	Entered (and system override, see below)
Projects	Names of linked projects	Linked
Internal Controls	Names of linked controls	Linked
Policies	Names of linked policies and standards	Linked

Owner, findings, exceptions, notes, due date and the three risk registers are not shown as columns; they are in the **Edit Action** dialog. Name lists in the cells are not clickable.

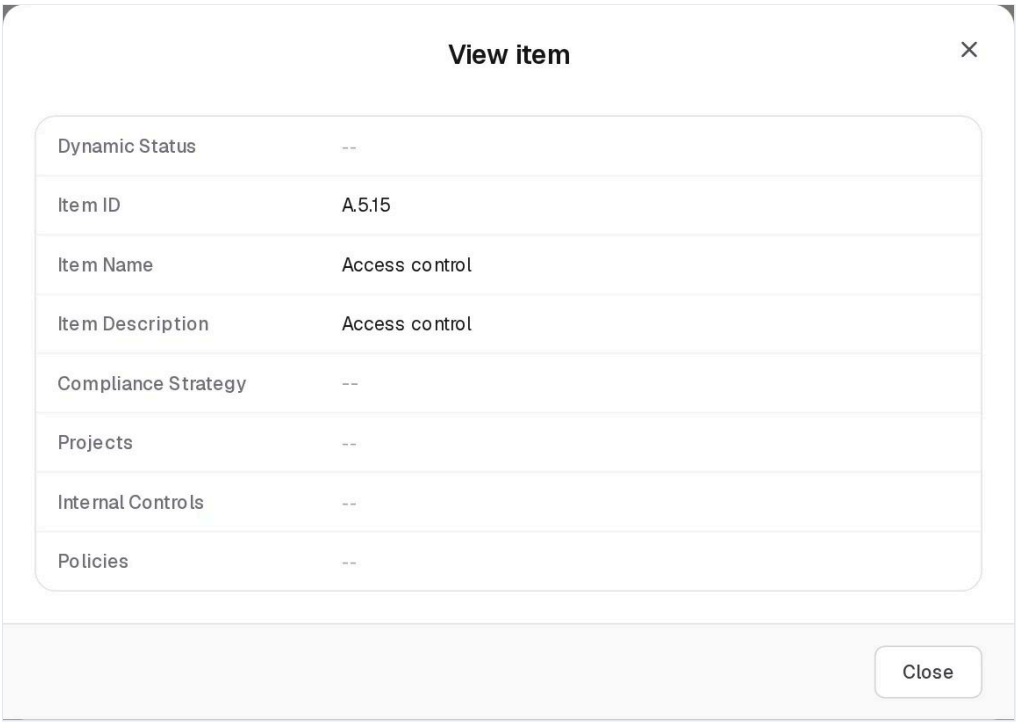
Header buttons: **Import CSV** only. There is **no Add Item** button: rows are created from the package items, never by hand. Row buttons: **View**, comments, **Edit** (opens Edit Action), **Delete** (removes the row from the analysis).

In the demo data every package has its standing *Compliance Analysis* assessment and all 25 rows are still *Under Review* (`--`), so the strategy, link and Dynamic Status cells are empty.

Creating a record

None. A row is created automatically when a requirement item is added to a package (by **Add Item** or by **Import CSV** on the package's items page). The row starts with strategy *Under Review*, shown as `--`.

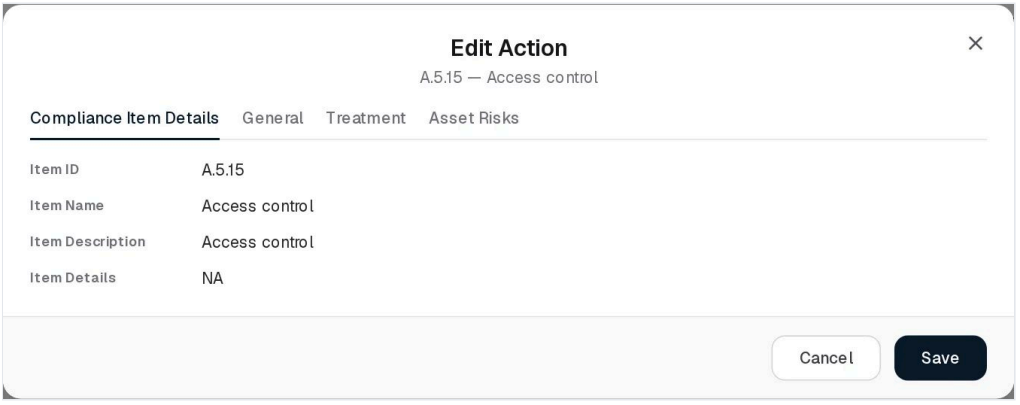
Viewing and editing a record



View Compliance Analysis row

View opens **View item** with the grid's eight columns, read-only. **Edit** opens the **Edit Action** dialog, with " — " under the title and **Cancel** / **Save** at the bottom. It opens on the **Compliance Item Details** tab.

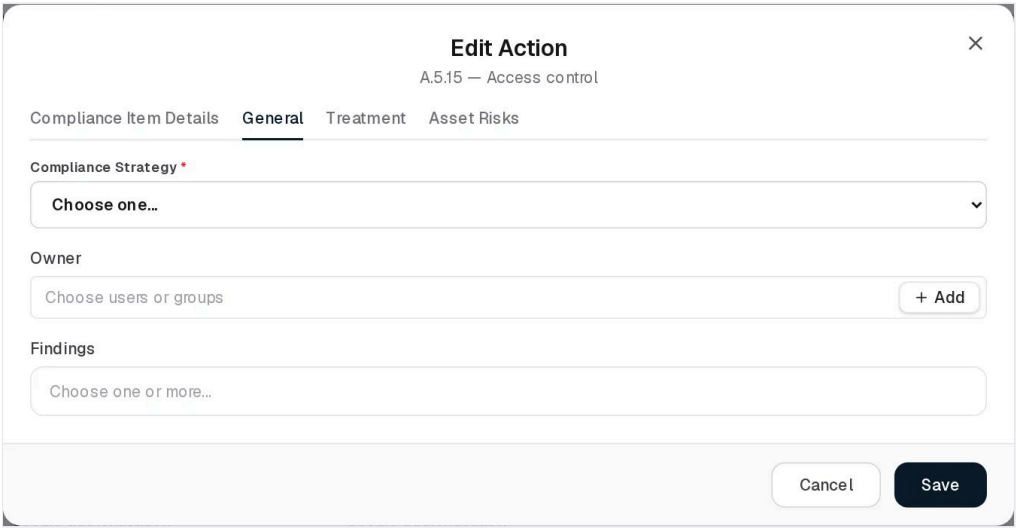
Compliance Item Details tab



Edit Action, Compliance Item Details tab

Read-only text from the package item: **Item ID**, **Item Name**, **Item Description**, **Item Details** (the item's additional information). Empty values show as `NA`. To change this text, edit the item on its package.

General tab

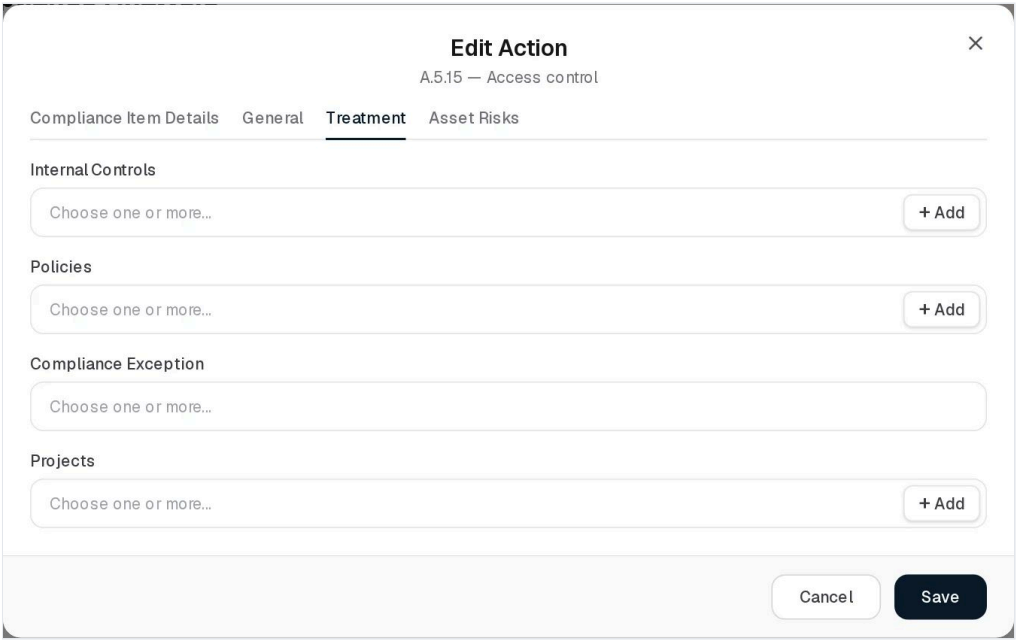


Edit Action, General tab

Field	Type	Required	Rules and allowed values	Example
Compliance Strategy	Dropdown	Yes (marked *)	**Choose one…** (stores *Under Review*, the "not judged yet" value), **Compliant**, **Not Applicable**, **Not Compliant**. A row that still holds *Partially Compliant* shows that value as an extra choice. Default for new rows: Choose one…	Compliant
Owner	User/group picker	No	Several can be picked, but only the first person is stored; the row's owner is a single user	Sara Johnson
Findings	Record picker (External Audit Findings)	No	Placeholder *Choose one or more…*; no **+ Add** button. Several allowed. Saving writes the link onto each finding's **Affected Compliance Items**, and removes it from findings you unticked.	SQL injection in customer portal

Notes and due date are stored on the row but no longer asked for; their existing values are kept unchanged when you save.

Treatment tab



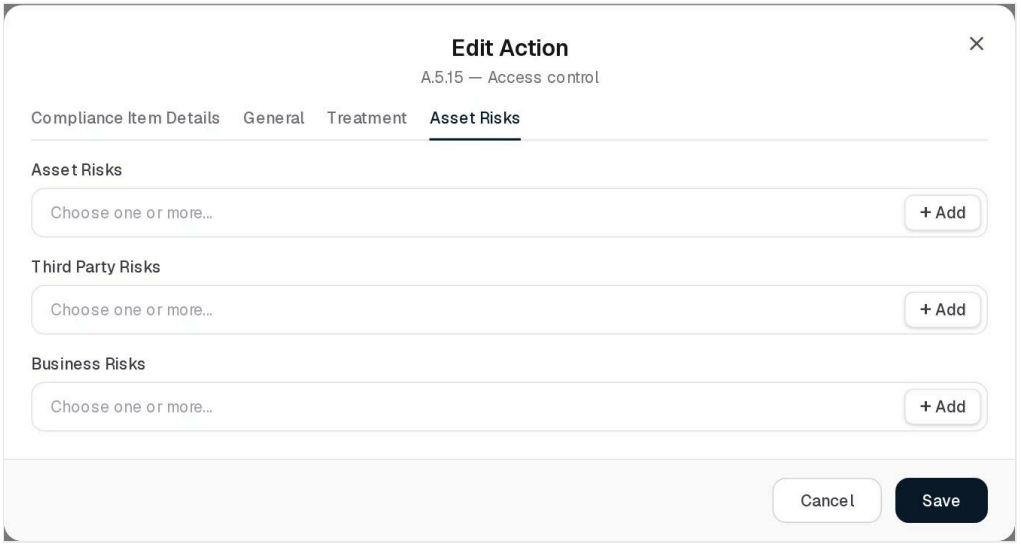
Edit Action, Treatment tab

Each picker shows *Choose one or more…*. **Internal Controls**, **Policies** and **Projects** have a **+ Add** button that creates a new control, policy or project without leaving the dialog; **Compliance Exception** has none.

Field	Type	Required	Rules	Example
Internal Controls	Record picker (Controls)	No	Several allowed. A control newly added here also gets this package added to its **Compliance Package** field.	Multi-factor authentication
Policies	Record picker (Policies & Standards)	No	Several allowed. A policy newly added here also gets this package added to its **Compliance Package** field.	Access Control Policy
Compliance Exception	Record picker (Compliance Exceptions)	No	Several allowed. Saving adds this requirement to each picked exception's **Related Compliance Items** and removes it from exceptions you unticked; the exceptions' other requirements are left alone.	A.8.8 scan coverage gap on OT network
Projects	Record picker (Projects)	No	Several allowed	

Removing a control or policy here does not remove the package from that control or policy; that is done on the control's or policy's own form.

Asset Risks tab



Edit Action, Asset Risks tab

All three pickers have a **+ Add** button for creating a new risk in that register.

Field	Type	Required	Rules	Example
Asset Risks	Record picker (Asset Risks)	No	Several allowed. Written to each risk's **Affected Compliance Items**.	Ransomware on file servers
Third Party Risks	Record picker (Third Party Risks)	No	Same, for third-party risks	Telecom link failure
Business Risks	Record picker (Business Risks)	No	Same, for business risks	

When at least one risk is linked, the tab shows "A requirement with a risk against it is recorded as Non-Compliant when saved." On save, the strategy is set to *Not Compliant* only if one of the linked risks is above the risk appetite (and the strategy is not *Not Applicable*); a risk within appetite does not change the strategy you picked.

Saving shows "Assessment item updated." and refreshes the grid and the summaries.

Delete asks "Remove from the analysis?" with "The requirement stays in its package; only the judgement recorded here goes." and a **Remove** button. The row and its strategy, owner, control, policy and project links are deleted permanently (risk, finding and exception links live on those records and stay). The row is not recreated automatically for an existing item; it comes back only when the package's analysis is lined up again (a new item added to the package, a CSV import, or an application restart).

Statuses

Compliance Strategy (set by a person, overridden by risks):

Value	Set by	Meaning
`--` (stored *Under Review*)	System default / user (**Choose one…**)	Not judged yet. Counted under *Review* in the summaries. Amber when shown as a badge elsewhere.
Compliant	User, or system	Requirement met. Green. The system sets it when a linked risk is saved and every risk linked to the requirement is within appetite.
Not Applicable	User	Requirement does not bind the organisation. Grey. Left out of the compliance percentage and never changed by risks.

Value	Set by	Meaning
Not Compliant	User, or system	Requirement not met. Red. The system sets it when a linked risk is above appetite, both when this row is saved and when the risk is saved.
Partially Compliant	Older data only	Counted as half compliant. No longer offered. Amber.

Dynamic Status (system, computed on every read from the row's **Internal Controls**):

Marker (tooltip)	Rule
Control Last Audit Expired	A linked control has an audit whose planned start is before today and which is not completed.
Asset Risk Review Expired	An asset risk that uses a linked control as treatment has a next review date before today.
Third Party Risk Review Expired	Same for a third-party risk.
Business Risk Review Expired	Same for a business risk.

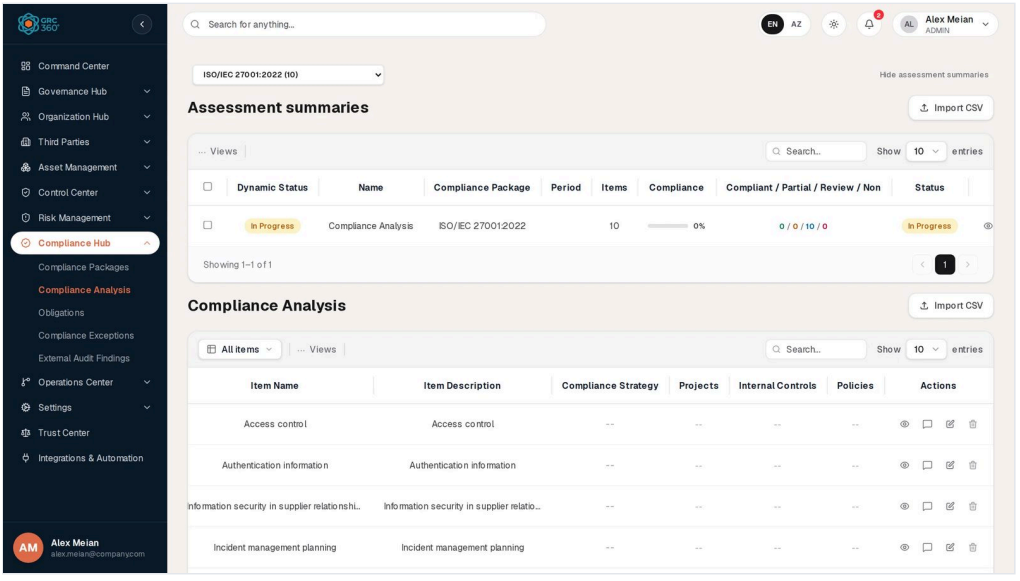
Rows without linked controls always show `--`.

Tabs

The page has no section tabs. The **Edit Action** dialog has four tabs (**Compliance Item Details**, **General**, **Treatment**, **Asset Risks**), described, each with its screenshot, under Viewing and editing a record. The **Assessment summaries** grid is described below.

Assessment summaries

Click **Assessment summaries**. A grid titled **Assessment summaries** appears above the analysis grid, listing the assessments of the selected framework (newest first). Click a row to show only that assessment's requirement rows below. The summaries grid has its own **Import CSV** button (the same strategy import) but no Add button and no status filter.



Assessment summaries above the Compliance Analysis grid

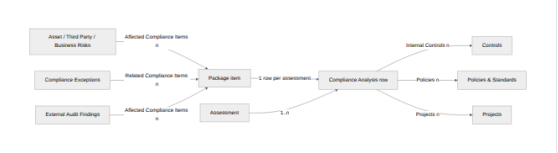
In the demo data the ISO/IEC 27001:2022 summary reads *In Progress*, 10 items, 0%, counts 0 / 0 / 10 / 0, Status *In Progress*.

Column	What it shows	Source
Dynamic Status	*Not Started* (grey) when the assessment has no rows; *Completed* (green) when the compliance percentage is 100 or more; otherwise *In Progress* (amber)	Computed in the page

Column	What it shows	Source
Name	Assessment name; the standing one is *Compliance Analysis*	Entered / system
Compliance Package	Package assessed	Linked
Period	Assessment period text	Entered
Items	Number of rows	Computed
Compliance	Bar and percentage: (Compliant + 0.5 × Partially Compliant) ÷ (rows − Not Applicable) × 100, one decimal	Computed
Compliant / Partial / Review / Non	Row counts per strategy	Computed
Status	Stored lifecycle status; always *In Progress* (the UI cannot change it)	System

Row buttons: **View**, comments, **Edit**, **Delete**. **Edit** opens **Edit Assessment** with **Compliance Package** (read-only), **Name** (required, “Name is required.”), **Assessment Period** (text, placeholder *e.g. 2026 H1*) and **Owner** (user/group picker). **Delete** asks “Delete ?” with “Its per-requirement strategies and notes will be removed from the Hub as well.” There is no Add button: new assessments cannot be started from the UI.

Relationships



Related record	Direction	How the link is made	Where it shows
Package item	Row → item, many to one	Automatic	Item ID, Item Name, Item Description columns
Assessment	Row → assessment, many to one	Automatic (standing *Compliance Analysis*)	Assessment summaries
Controls	Row → controls, many	Edit Action › Treatment	**Internal Controls** column; control’s **Compliance Package** column gains the package
Policies & Standards	Row → policies, many	Edit Action › Treatment	**Policies** column; policy’s **Compliance Package** column gains the package
Projects	Row → projects, many	Edit Action › Treatment	**Projects** column; project’s **Compliance Package** column
Risks (three registers)	Risk → requirement item, many to many	Risk form, or Edit Action › Asset Risks	Edit Action; risk’s **Affected Compliance Items**
Compliance Exceptions	Exception → requirement items, many to many	Exception form, or Edit Action › Treatment	Edit Action; exception’s **Requirement Item Number/Name** columns
External Audit Findings	Finding → requirement items, many to many	Finding form, or Edit Action › General	Edit Action; finding’s **Affected Compliance Item** column
Trust Center	Strategy counts per package	Automatic	Trust Center framework posture

Automations and notifications

- **Row creation**: whenever requirement items are added to a package, the package’s standing assessment *Compliance Analysis* is created if missing and given one *Under Review* row per item that has none. Runs on item save, on CSV import of items, and for every package at application start-up.

- **Strategy from risks**: when an Asset, Third Party or Business Risk that names requirement items is saved, every analysis row of those requirements is set to *Not Compliant* if any linked risk is above appetite, otherwise to *Compliant*. *Not Applicable* rows are skipped. Each change is written to the System Log (“ASSESSMENT_ITEM_STATUS_CHANGED”).
- **Dynamic Status** is computed on every read.
- No scheduled jobs and no notifications.

Permissions

Action	Needed access
See the page, the rows and the summaries	View on Compliance Hub › Compliance Analysis (the framework selector also reads Compliance Packages)
Edit a row (Edit Action), edit an assessment	Manage on Compliance Hub › Compliance Analysis. Links written through to risks, findings and exceptions are checked against this page only.
Remove a row, delete an assessment	Full Control on Compliance Hub › Compliance Analysis
Import CSV	Manage on Compliance Hub › Compliance Analysis
Comments	The group’s Comments & Attachments level

The built-in *Third Party* group can view and edit this page for its own records only. See Permissions and access.

How to

Record the result of an ISO/IEC 27001 control check

1. Open **Compliance Hub › Compliance Analysis** and choose **ISO/IEC 27001:2022 (10)** in the framework selector.
2. On row **A.8.5 Secure authentication** click **Edit**.
3. On **General** set **Compliance Strategy** to **Compliant** and pick the owner.
4. On **Treatment** open **Internal Controls** and pick *Multi-factor authentication*; under **Policies** pick *Access Control Policy*. Click **Save**.
5. The row shows the control and policy; the control and the policy now list ISO/IEC 27001:2022 as a compliance package.

Mark a requirement out of scope

1. Select the framework, then **Edit** the row (for example a PCI DSS requirement for a process you do not run).
2. Set **Compliance Strategy** to **Not Applicable** and **Save**. The row is left out of the compliance percentage and risks will not change it.

Link the risk that puts a requirement at stake

1. **Edit** row **A.8.8 Management of technical vulnerabilities**.
2. On **Asset Risks** pick *Unpatched internet-facing server* in **Asset Risks**. The warning about Non-Compliant appears.
3. **Save**. If that risk is above your risk appetite the strategy becomes **Not Compliant**.

Check overall progress per framework

1. Click **Assessment summaries**.
2. Read **Compliance** and the **Compliant / Partial / Review / Non** counts for the standing *Compliance Analysis* assessment.
3. Click the row to see only its requirements; use **Back to the whole framework** to return.

CSV import

Import CSV (on both grids) updates strategies of existing rows; it does not create rows. After the notice “CSV Import (…): the import structure is not ready yet.” the import dialog **Import CSV - Assessment Strategies** opens and runs against `POST /api/v1/compliance/assessments/import-csv`.

Column (position)	Required	Notes
1 assessmentItemId	Yes	The row's internal id (UUID). Not shown in the UI or in any export.
2 strategy	Yes	Stored as written; values are not checked. Use `COMPLIANT`, `NOT_APPLICABLE`, `NON_COMPLIANT` or `UNDER_REVIEW`.

The first line is skipped. Lines are split on commas without quote handling. The dry run (**Validate**) only checks that the first column is a valid UUID; whether the row exists is checked on the real import. There is no CSV export on this page.

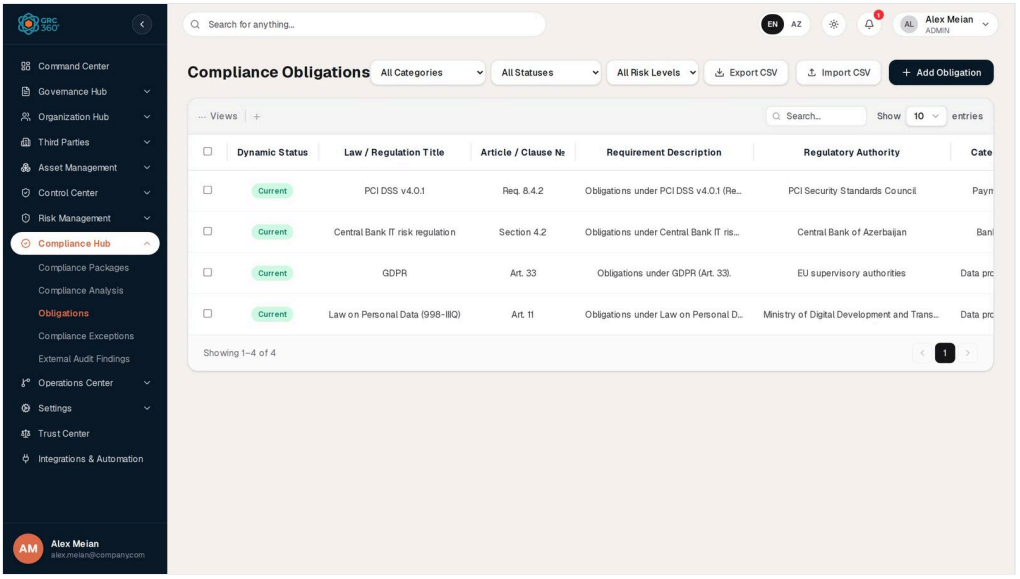
Limitations and known issues

- **No Add button for assessments.** The assessment form exists but cannot be opened in Add mode; only the standing *Compliance Analysis* assessment exists in practice. The summaries grid's empty text still says "No assessments yet. Import one via CSV.", but the import only updates strategies.
- **Deleted items, packages and assessments still show.** The rows are returned without checking whether their package item, package or assessment has been deleted. A deleted package's rows appear under **All frameworks**; a deleted item keeps its row; deleting an assessment in the summaries grid leaves its rows on the analysis grid.
- **Owner keeps only the first person** picked on a row.
- **Saving a risk can mark a requirement Compliant.** A risk saved within appetite sets every row of the requirements it names to *Compliant*, including rows still *Under Review*.
- **The CSV import is impractical**: it needs internal row ids that the UI never shows, and it accepts any strategy text.
- **Assessment Status** is always *In Progress*; the statuses *Completed* and *Paused* listed by the backend cannot be set.

Obligations

> **Module:** Compliance Hub › Obligations · **Route:** `/compliance-hub/obligations` · **Permission key:** `compliance_hub.obligations`

The Obligations register (page title **Compliance Obligations**) lists the legal and regulatory obligations the organisation is subject to: one record per law or regulation and article or clause, with the authority that enforces it, the team responsible, a recorded compliance status, a risk level and the date of the next audit. It is a stand-alone register kept by the compliance or legal team; unlike compliance packages, obligations are not broken down into requirement items and do not appear on Compliance Analysis.



Compliance Obligations register

At a glance

A record is	One obligation: a law or regulation plus one article or clause
Typical owner	Compliance or legal officer (the **Responsible Team / Contact**)
Links to	Responsible users or groups
Linked from	None in the UI
Tabs	None
Automations	Dynamic Status computed from the next audit date on every read. No reminders.

The register (list view)

The register is paged and searched on the server, newest first. The shared grid behaviour (search, Views, paging, selection, comments) is described in Working with registers. Search matches the law title, the article/clause number and the requirement description.

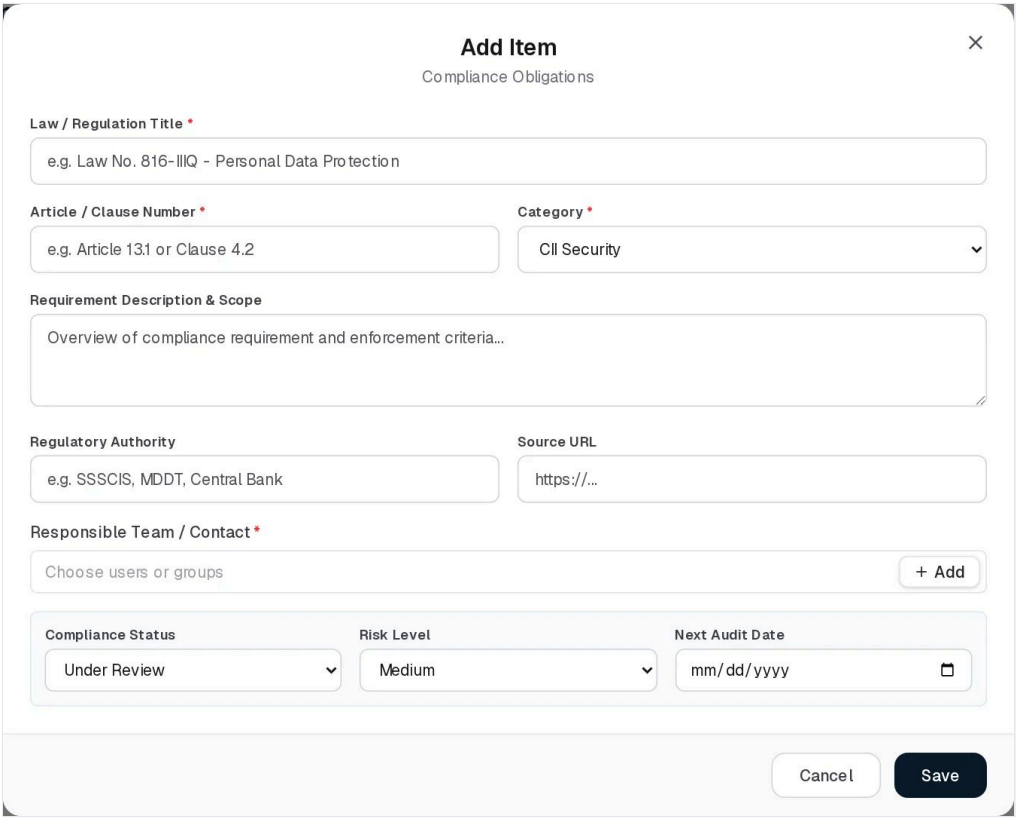
Above the grid, next to the title, three filters are applied by the server: **All Categories** (the five categories below), **All Statuses** (the four compliance statuses) and **All Risk Levels** (High, Medium, Low). Header buttons: **Export CSV**, **Import CSV**, **Add Obligation**.

Column	What it shows	Source
Dynamic Status	*Current*, *Needs Review* or *Missing Date*, from the Next Audit Date. See Statuses.	Computed by the system
Law / Regulation Title	For example *GDPR*	Entered

Column	What it shows	Source
Article / Clause №	For example *Art. 33*	Entered
Requirement Description	First part of the text; hover for the rest	Entered
Regulatory Authority	For example *EU supervisory authorities*	Entered
Category	Category label (see Limitations for how built-in categories display)	Entered
Responsible Contact	Responsible users or groups, comma-joined	Linked
Status	The compliance status a person recorded	Entered
Risk	*High* (red text), *Medium* (amber), *Low* (green)	Entered
Next Audit Date	Date (YYYY-MM-DD) or `-`	Entered

Creating a record

Click **Add Obligation**. The dialog **Add Item** (subtitle *Compliance Obligations*) opens.



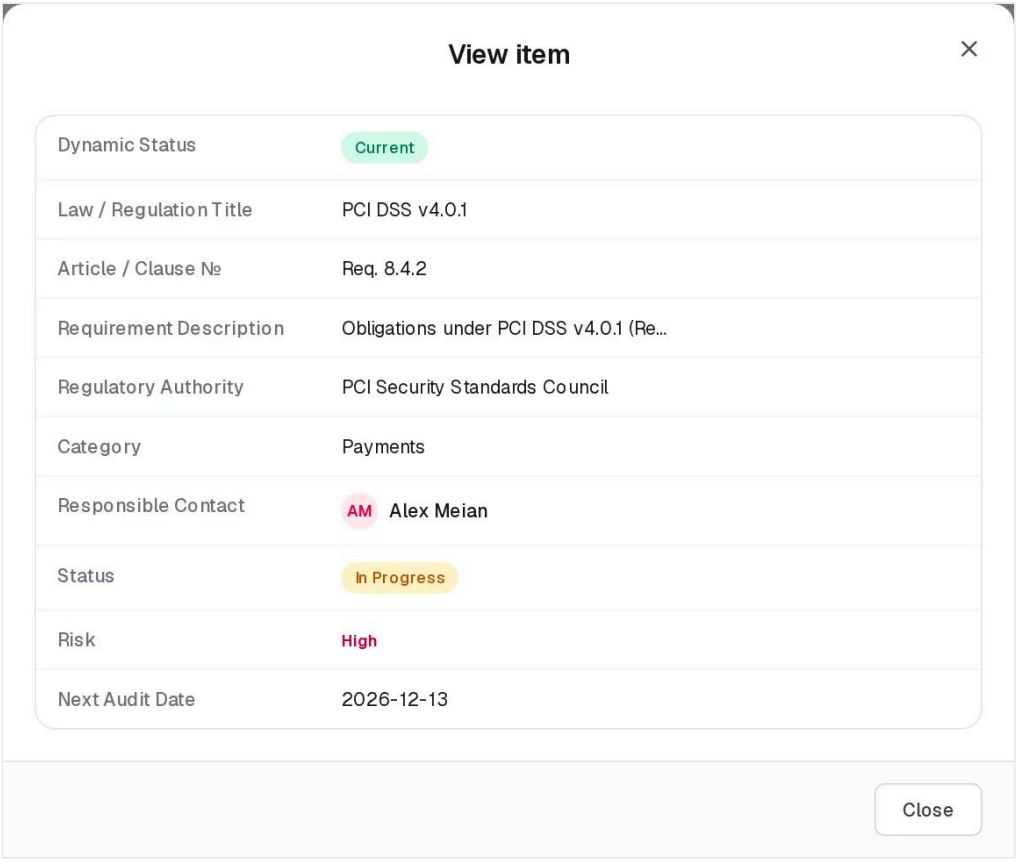
Add Obligation

Field	Type	Required	Rules and allowed values	Example
Law / Regulation Title	Text	Yes	“Law title and article/clause number are required.” Placeholder *e.g. Law No. 816-IIIQ - Personal Data Protection*	Law on Personal Data (998-IIIQ)
Article / Clause Number	Text	Yes	Same message as above. Placeholder *e.g. Article 13.1 or Clause 4.2*	Art. 11

Field	Type	Required	Rules and allowed values	Example
Category	Dropdown	Yes	**CII Security**, **Personal Data**, **Central Bank**, **Electronic Signature**, **State Standards**. Default CII Security.	Personal Data
Requirement Description & Scope	Multi-line text	No	Placeholder *Overview of compliance requirement and enforcement criteria…*	Obligations under Law on Personal Data (998-IIIQ) (Art. 11).
Regulatory Authority	Text	No	Placeholder *e.g. SSSCIS, MDDT, Central Bank*	Ministry of Digital Development and Transport
Source URL	URL	No	Must be a valid web address if filled (checked by the browser). Placeholder *https://…*	
Responsible Team / Contact	User/group picker, several allowed	Yes (in the form)	“Responsible Team / Contact is required.”	Alex Meian
Compliance Status	Dropdown	No (always has a value)	**Compliant**, **Partially Compliant**, **Under Review**, **Non Compliant**. Default Under Review.	Under Review
Risk Level	Dropdown	No (always has a value)	**High**, **Medium**, **Low**. Default Medium.	High
Next Audit Date	Date	No	Drives the Dynamic Status	2026-12-13

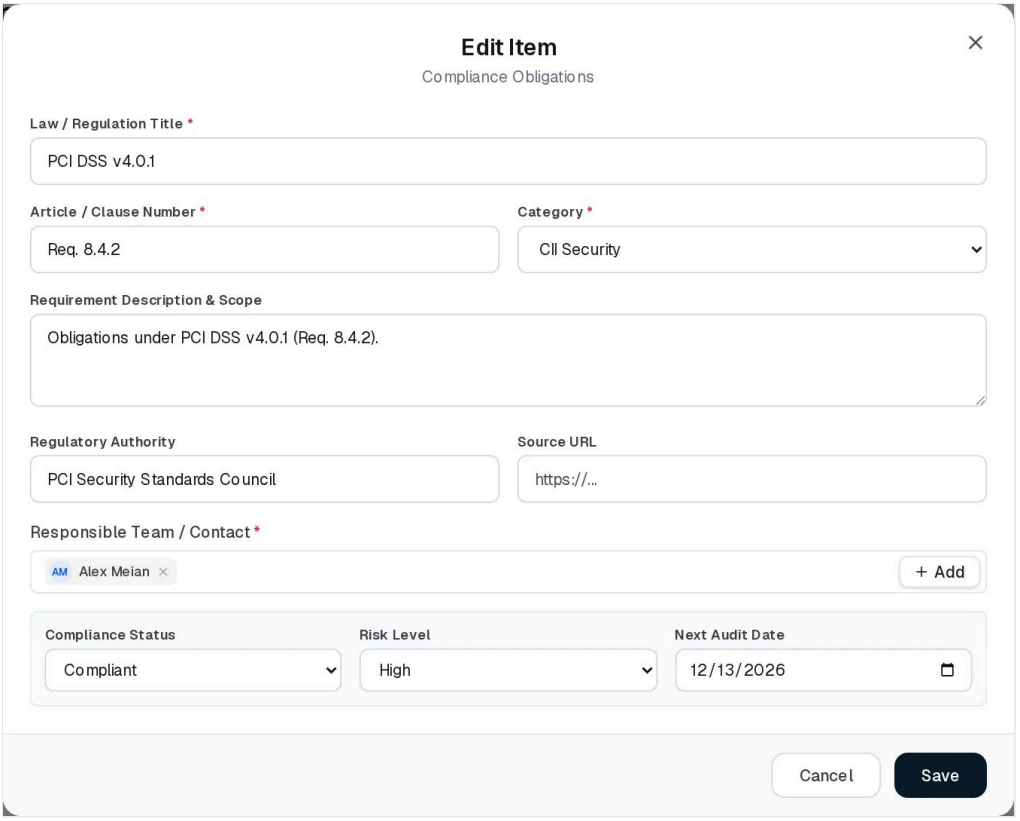
The dropdown lists come from the backend’s Compliance Hub metadata, with the same values built into the page as a fallback. Saving shows “Obligation added.”

Viewing and editing a record



View Obligation

View opens **View item** with the ten grid columns. **Edit** opens **Edit Item** (subtitle *Compliance Obligations*) with the same fields as Add. Saving shows “Obligation updated.” and records the time of the edit as the obligation’s last review time (not shown in the UI). An effective date set by the API or the demo data is kept; the form has no field for it.



Edit Obligation

The screenshot shows an effect of the demo data: *PCI DSS v4.0.1* is stored with category *Payments* and status *In Progress*, which are not in the dropdowns, so the form displays the first options (**CII Security**, **Compliant**) instead. Saving without touching those two dropdowns keeps the stored values; choosing a value replaces them.

Delete asks “Delete ?” and soft-deletes the record.

Statuses

Status (Compliance Status, set by a person):

Value	Set by	Meaning
Compliant	User	The organisation meets the obligation. Green.
Partially Compliant	User	Partly met. Amber.
Under Review	User (default)	Not yet assessed or being assessed. Amber.
Non Compliant	User	Not met. Shown in the grid as *Not Compliant*, red.

Dynamic Status (system, computed on every read; dates compared as calendar days in UTC):

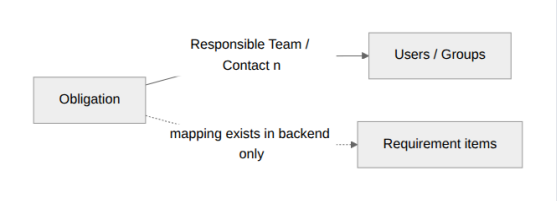
Value	Rule	Colour
Missing Date	No Next Audit Date	Amber
Needs Review	Next Audit Date is before today	Amber
Current	Next Audit Date is today or later	Green

The Dynamic Status does not depend on the Status: an obligation can be *Compliant* and *Needs Review* at the same time.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Users and groups	Obligation → people, many	**Responsible Team / Contact**	**Responsible Contact** column
Compliance requirement items	Obligation → items, many to many	Backend endpoint `POST /compliance/obligations/{id}/map-requirements` only	Nowhere in the UI

Obligations are not linked to compliance packages, risks, controls or findings.

Automations and notifications

- **Dynamic Status** is computed on read, so *Needs Review* appears the day after the Next Audit Date without any job.
- No reminder is sent before or after the Next Audit Date. No scheduled job concerns obligations.

Permissions

Action	Needed access
See the page, filter, **Export CSV**	View on Compliance Hub › Obligations
Create / Edit	Manage on Compliance Hub › Obligations
Import CSV	Manage on Compliance Hub › Obligations
Delete	Full Control on Compliance Hub › Obligations
Comments	The group's Comments & Attachments level

See Permissions and access.

How to

Register a new legal obligation

1. Open **Compliance Hub › Obligations** and click **Add Obligation**.
2. Enter **Law / Regulation Title** `GDPR`, **Article / Clause Number** `Art. 30`, choose **Category** *Personal Data*.
3. Fill **Regulatory Authority**, pick the **Responsible Team / Contact**, set **Risk Level** *High* and a **Next Audit Date**.
4. **Save**. The row shows Dynamic Status *Current*.

Record the outcome of an obligation review

1. Click **Edit** on *Central Bank IT risk regulation*.
2. Set **Compliance Status** to *Compliant* and move **Next Audit Date** to the next review.
3. **Save**.

List the high-risk obligations that need attention

1. Choose **High** in **All Risk Levels** and **Non Compliant** in **All Statuses**.
2. Sort by **Next Audit Date**, or look for *Needs Review* in **Dynamic Status**.

CSV import

Import CSV first shows “CSV Import (Compliance Obligations): the import structure is not ready yet.” and then opens the working import dialog (`POST /api/v1/compliance/obligations/import-csv` , with a dry run on **Validate**).

Column (position)	Required	Notes
1 legalActName	Yes	
2 articleOrClauseNo	Yes	
3 category	Yes	Stored in upper case; use `KII_SECURITY` , `PERSONAL_DATA` , `CENTRAL_BANK` , `E_SIGNATURE` or `STATE_STANDARDS` to match the dropdown
4 requirementDescription	No	
5 regulatoryAuthority	No	
6 status	No	Stored in upper case; default `UNDER_REVIEW`
7 riskLevel	No	Stored in upper case; default `MEDIUM`

The first line is skipped. Rows with fewer than three columns fail with “Row n: Requires legalActName,articleOrClauseNo,category”; empty required values fail with “Row n: Required fields cannot be empty”. Values are not checked against the allowed lists. Imported obligations have no responsible contact and no Next Audit Date, so they show *Missing Date*.

Export CSV downloads `obligations.csv` with the same seven columns, for every obligation (the filters and search are ignored).

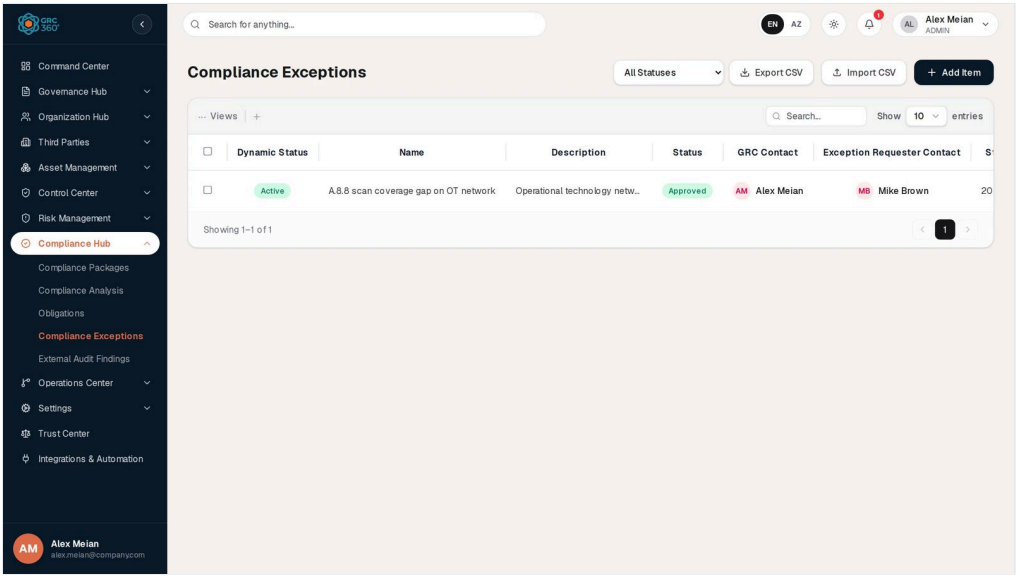
Limitations and known issues

- **Built-in categories display garbled.** For the five built-in category codes the Category column shows the backend’s Azerbaijani label, which is stored with a broken character encoding (for example *KÄ°Ä° TÉ™hlÃ¼kÉ™sizliyi* instead of *Kİİ Təhlükəsizliyi*), not the English dropdown label *CII Security*. Free-text categories, such as the demo data’s *Data protection*, display as entered.
- **Values outside the dropdowns are shown wrongly in Edit.** A stored category, status or risk level that is not in the list (from import, the API or the demo data) is displayed as the first option of the dropdown.
- **Two spellings of one status.** The dropdown and filter say *Non Compliant*; the grid badge says *Not Compliant*.
- **Export ignores the filters** and always contains every obligation.
- **No mapping to requirement items** in the UI, although the backend supports it.
- **No reminders** for the Next Audit Date; the Dynamic Status is the only signal.

Compliance Exceptions

> **Module:** Compliance Hub › Compliance Exceptions · **Route:** `/compliance-hub/compliance-exceptions` · **Permission key:** `compliance_hub.compliance_exceptions`

A compliance exception records that the organisation knowingly does not meet one or more framework requirements for a limited time, for example because a compensating measure is in place or a project will close the gap. Each exception names the people involved, the requirement items it excuses and the date it expires. Compliance managers keep this register; it is the place an auditor looks for accepted gaps.



Compliance Exceptions register

At a glance

A record is	One time-limited exception covering one or more requirement items
Typical owner	GRC Contact (compliance manager); raised by the Exception Requester Contact
Links to	Requirement items (several), their compliance package, GRC contacts, requesters
Linked from	Compliance Analysis (Edit Action › Treatment › **Compliance Exception**)
Tabs	None
Automations	Dynamic Status computed on read (shows *Expired* once the expiration date passes). An hourly expiry job exists but is not active in this release.

The register (list view)

The register is paged and searched on the server, newest first. The shared grid behaviour (search, Views, paging, selection, comments) is described in Working with registers. Search matches the name and the description.

Header controls: a status filter (**All Statuses**, **Open Exceptions**, **Closed Exceptions**), **Export CSV**, **Import CSV**, **Add Item**. The filter matches the stored status exactly, so an exception stored as *Approved* (like the demo record) appears only under **All Statuses**.

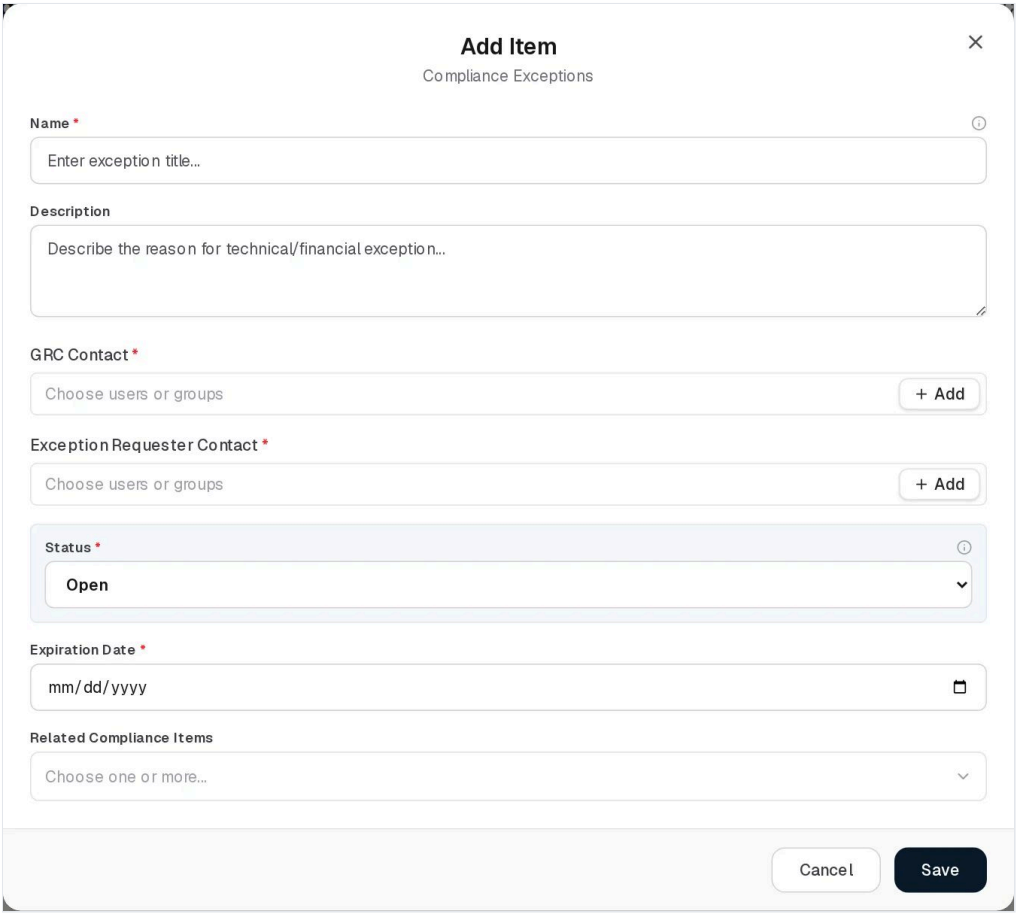
Column	What it shows	Source
Dynamic Status	*Active*, *Pending*, *Expired* or *Closed*. See Statuses.	Computed by the system

Column	What it shows	Source
Name	Exception title	Entered
Description	First part of the description; hover for the rest	Entered
Status	The stored status, for example *Approved*	Entered
GRC Contact	GRC contacts, comma-joined	Linked
Exception Requester Contact	Requesters, comma-joined	Linked
Start Date	Date the exception was raised	System (today, on creation)
Expiration Date	Date the exception ends	Entered
Closure Date	Date it was closed, `-` while open	System
Compliance Package	Package of the first requirement item picked	Derived
Requirement Item Number	Item IDs of all excused items, as chips	Linked
Requirement Item Name	Item names of all excused items, as chips	Linked

Demo record: *A.8.8 scan coverage gap on OT network*, status Approved, Dynamic Status Active, GRC Contact Alex Meian, requester Mike Brown, start 2026-09-29, expiration 2026-12-28, package ISO/IEC 27001:2022, no requirement items linked.

Creating a record

Click **Add Item**. The dialog **Add Item** (subtitle *Compliance Exceptions*) opens.

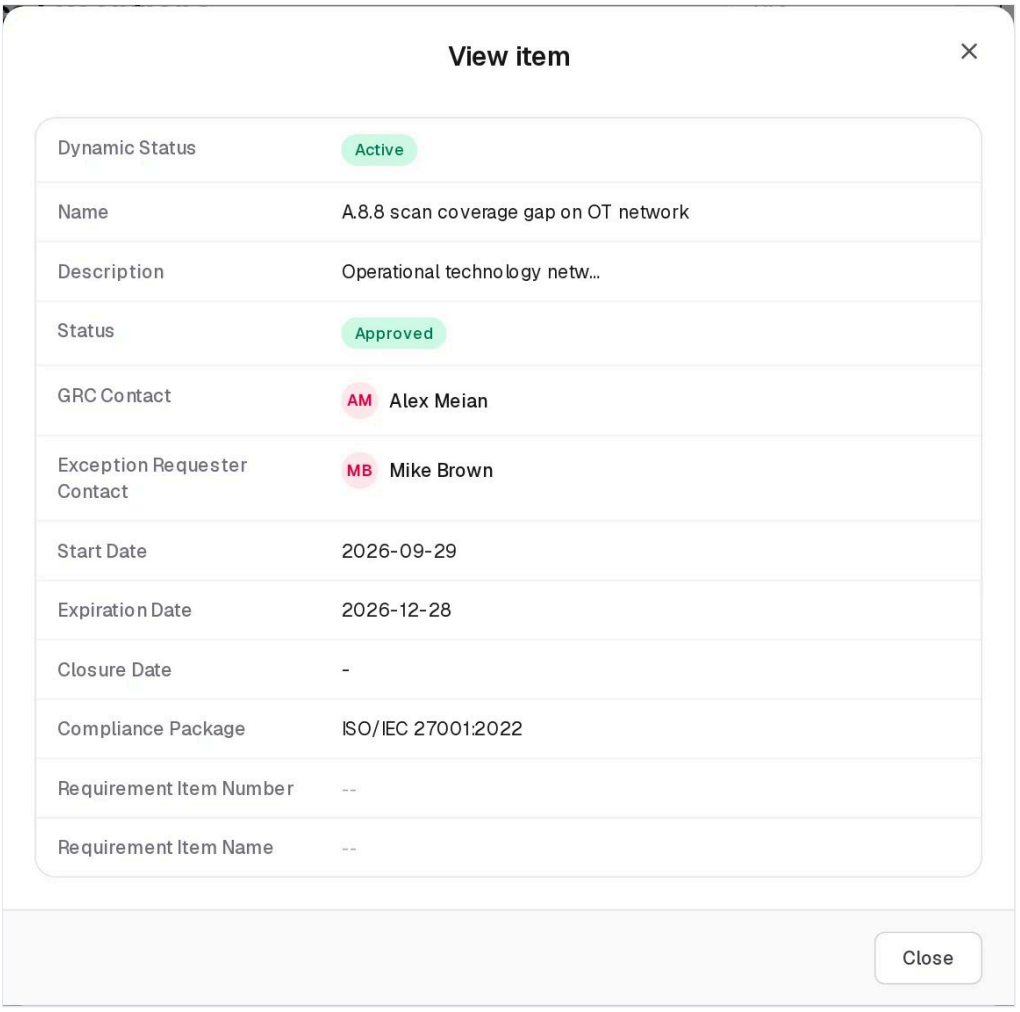


Add Compliance Exception

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	“Name is required.” Placeholder *Enter exception title…*	A.8.8 scan coverage gap on OT network
Description	Multi-line text	No	Placeholder *Describe the reason for technical/financial exception…*	Operational technology network cannot be scanned until segmentation project ends.
GRC Contact	User/group picker, several allowed	Yes	“At least one GRC contact is required.”	Alex Meian
Exception Requester Contact	User/group picker, several allowed	Yes	“At least one requester contact is required.”	Mike Brown
Status	Dropdown	Yes	**Open**, **Closed**. Default Open.	Open
Expiration Date	Date	Yes	“Expiration date is required.”	2026-12-28
Related Compliance Items	Multi-select	No	Every requirement item of every package, labelled “ ”, for example *ISO/IEC 27001:2022 A.8.8 Management of technical vulnerabilities*. Several allowed.	ISO/IEC 27001:2022 A.8.8 Management of technical vulnerabilities

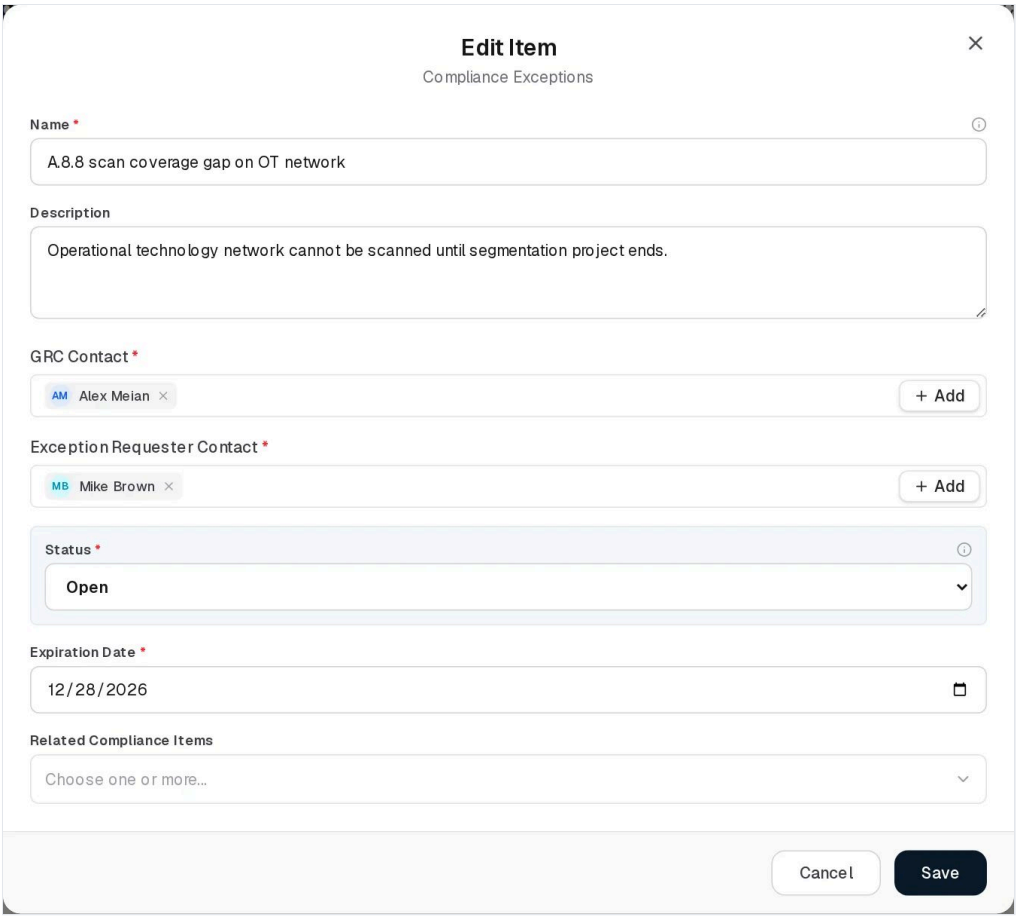
There is no Start Date field: the form sends today’s date (in your browser’s time zone) as the start date. There is no Compliance Package field either: the package is taken from the first item picked in **Related Compliance Items**. Saving shows “Compliance exception added.”

Viewing and editing a record



View Compliance Exception

View opens **View item** with the twelve grid columns. **Edit** opens **Edit Item** (subtitle *Compliance Exceptions*) with the same fields as Add.



Edit Compliance Exception

- The start date is kept as it was.
- Changing **Status** records a workflow event (“Status changed from the edit form”) and a System Log entry. Setting it to **Closed** stamps today’s date as the **Closure Date**; setting it back to **Open** clears the closure date.
- The demo record is stored as *Approved*, which the dropdown does not offer; the form therefore displays **Open**. Saving without touching **Status** keeps *Approved*; choosing a value replaces it.
- Changing **Related Compliance Items** sets the package again from the first item picked, and clears the package if you remove all items.

Saving shows “Compliance exception updated.” **Delete** asks “Delete ?” and soft-deletes the record.

Statuses

Status (set by a person):

Value	Set by	Meaning
Open	User (default)	The exception is being carried.
Closed	User	The exception is finished. Sets the Closure Date.
Approved, Under Review, Expired	Older data, API, CSV import, or the expiry job	Still read and displayed, but no longer offered in the form.

Dynamic Status (system, computed on every read):

Value	Rule (first match wins)	Colour
Closed	A Closure Date is set, or the status is Closed (also Denied, Rejected, Revoked)	Green
Expired	The status is Expired	Red

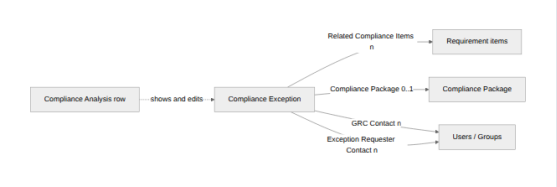
Value	Rule (first match wins)	Colour
Active	The status is Approved and the expiration date has not passed	Green
Expired	The status is Approved, Open or Under Review and the expiration date has passed	Red
Pending	Any other case, including every *Open* exception that has not expired	Amber

The expiration date is stored as midnight UTC of the chosen day, so an exception reads *Expired* from 00:00 UTC on its expiration date.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Requirement items	Exception → items, many to many	**Related Compliance Items**, or from Compliance Analysis › Edit Action › Treatment › **Compliance Exception**	**Requirement Item Number / Name** columns; Edit Action of each item's analysis row
Compliance package	Exception → package, at most one	Derived from the first requirement item	**Compliance Package** column
GRC contacts, requesters	Exception → users or groups, many	Form	**GRC Contact**, **Exception Requester Contact** columns

Linking from Compliance Analysis adds or removes only that one requirement; the exception's other requirements stay. Compliance exceptions are separate from Policy Exceptions and Risk Exceptions.

Automations and notifications

- **Dynamic Status** is computed every time the register is read, so *Expired* appears without any job.
- **Expiry job (not active in this release).** The backend contains an hourly job that would change the stored status of past-due Open, Approved and Under Review exceptions to *Expired* and log "Exception expired automatically". Scheduling is not enabled in the backend, so the job never runs and the stored **Status** stays as it was. A manual trigger exists in the API (`POST /api/v1/compliance/exceptions/expire-due` , for the caller's organisation only) but no screen calls it.
- The backend also has approval workflow actions (submit for review, approve, close) that no screen uses.
- No notifications are sent for compliance exceptions, before or after expiry.

Permissions

Action	Needed access
See the page, filter, **Export CSV**	View on Compliance Hub › Compliance Exceptions
Create / Edit (including changing Status)	Manage on Compliance Hub › Compliance Exceptions
Import CSV	Manage on Compliance Hub › Compliance Exceptions
Delete	Full Control on Compliance Hub › Compliance Exceptions

Action	Needed access
Comments	The group's Comments & Attachments level

The **Related Compliance Items** list is read from Compliance Analysis; without View on Compliance Analysis the list is empty. See Permissions and access.

How to

Record an accepted gap against an ISO requirement

1. Open **Compliance Hub › Compliance Exceptions** and click **Add Item**.
2. Enter **Name** and **Description**, pick the **GRC Contact** (Alex Meian) and the **Exception Requester Contact** (Mike Brown).
3. Set **Expiration Date** to the date the gap must be closed.
4. In **Related Compliance Items** pick *ISO/IEC 27001:2022 A.8.8 Management of technical vulnerabilities*. **Save**.
5. The row shows Dynamic Status *Pending*, package ISO/IEC 27001:2022 and Item ID A.8.8.

Close an exception when the gap is fixed

1. Click **Edit** on the exception.
2. Set **Status** to **Closed** and **Save**. The **Closure Date** shows today and the Dynamic Status becomes *Closed*.

Find exceptions that have run out

1. Sort the register by **Expiration Date**, or scan **Dynamic Status** for *Expired*. There is no filter for expired exceptions; the **Open Exceptions** filter matches the stored status only.

CSV import

Import CSV first shows "CSV Import (Compliance Exceptions): the import structure is not ready yet." and then opens the working import dialog (`POST /api/v1/compliance/exceptions/import-csv`).

Column (position)	Required	Notes
1 name	Yes	"Row n: Name cannot be empty"
2 description	No	
3 status	No	Stored in upper case; default `OPEN`. Not checked against a list.
4 expirationDate	Yes	`YYYY-MM-DD` or an ISO-8601 instant. "Row n: Expiration date is required" / "Row n: Invalid expiration date ''. Use YYYY-MM-DD or an ISO-8601 instant"
5 requirementItemNumber	No	Stored as text only; does not link the exception to the item
6 requirementItemName	No	Stored as text only

The first line is skipped; at least two columns are needed. Imported exceptions get today as start date and have no contacts, package or linked items.

Export CSV downloads `compliance-exceptions.csv` with the same six columns for every exception (the status filter and search are ignored). The item columns hold only the first linked item.

Limitations and known issues

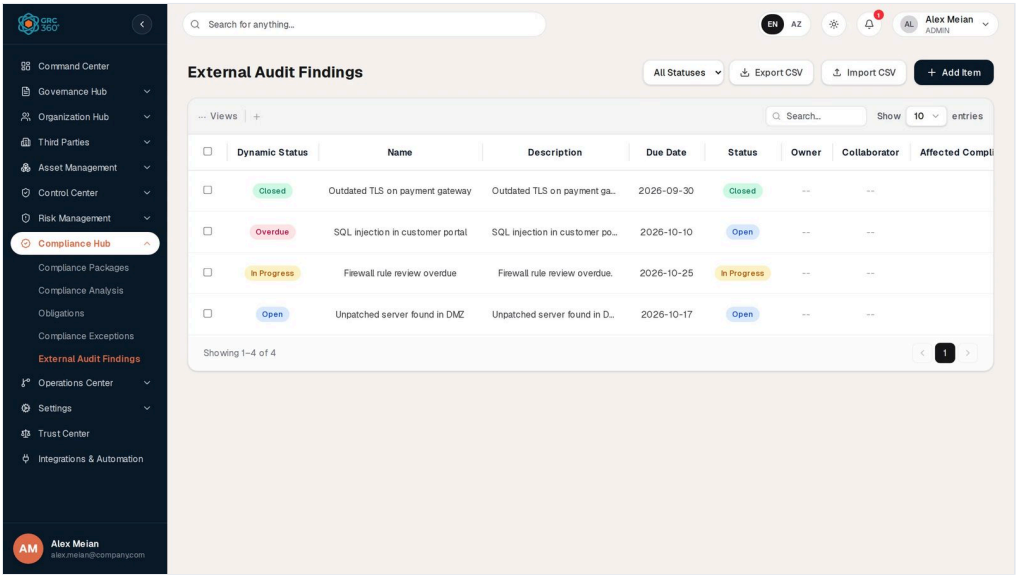
- **Open exceptions read *Pending*.** The form offers only Open and Closed, and the Dynamic Status shows *Active* only for *Approved* exceptions, so an exception created in the UI is *Pending* for its whole life.
- **Stored status never becomes Expired** because the expiry job is not active; only the Dynamic Status shows expiry.
- **Status filter misses other stored values** (Approved, Under Review, Expired) and offers no "expired" choice.

- **Edit shows Open for an Approved exception**; see Viewing and editing.
- **Package follows the first item.** Removing all items on edit clears the package; an exception covering items of two packages shows only the first one's package.
- **Deleted requirement items can still be offered** in **Related Compliance Items** (the list is built from Compliance Analysis rows, which are not cleaned up when an item or package is deleted); picking one fails with "Requirement item not found".
- **CSV import does not link items or contacts.**

External Audit Findings

> **Module:** Compliance Hub › External Audit Findings · **Route:** `/compliance-hub/audit-findings` · **Permission key:** `compliance_hub.audit_findings`

This register holds the findings raised by external auditors (certification bodies, regulators, customers' auditors): what was found, by when it must be fixed, who owns the fix, which framework requirements it breaks, and the evidence of remediation. Compliance managers record the findings after an audit and track them until they are closed. Internal control audits are recorded elsewhere, on Controls › Audits.



External Audit Findings register

At a glance

A record is	One finding from an external audit
Typical owner	The finding's **Owner**, helped by **Collaborators**
Links to	Requirement items of any package (several), owners and collaborators (users or groups), evidence attachments
Linked from	Compliance Analysis (Edit Action › General › **Findings**)
Tabs	None. Evidence files are managed in the **Evidence Attachments** dialog opened from the row.
Automations	Dynamic Status computed on read (*Overdue* once the due date has passed). No reminders.

The register (list view)

The register is paged and searched on the server, newest first. The shared grid behaviour (search, Views, paging, selection, comments) is described in Working with registers. Search matches the name and the description.

Header controls: a status filter (**All Statuses**, **Open**, **Closed**), **Export CSV**, **Import CSV**, **Add Item**. Besides **View**, comments, **Edit** and **Delete**, each row has an **Evidence attachments** button (paper clip) with a badge counting the attached files.

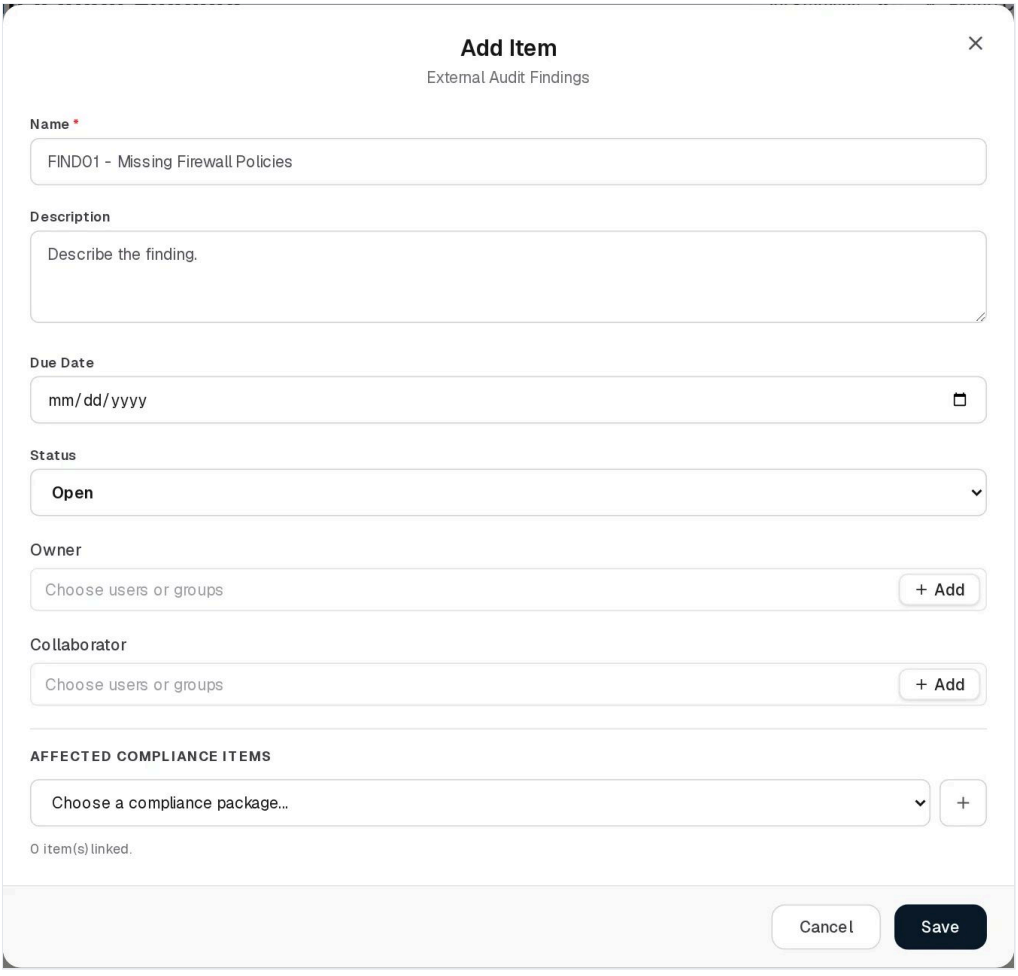
Column	What it shows	Source
Dynamic Status	*Overdue*, *Closed*, *Resolved*, or the status itself. See Statuses.	Computed by the system
Name	Finding title	Entered

Column	What it shows	Source
Description	First part of the description; hover for the rest	Entered
Due Date	Remediation deadline (YYYY-MM-DD) or `-`	Entered
Status	The stored status	Entered
Owner	Owners, comma-joined	Linked
Collaborator	Collaborators, comma-joined	Linked
Affected Compliance Item	Linked requirements as “ ()”, comma-joined; hover for the full list	Linked

Demo data: four findings, for example *SQL injection in customer portal* (status Open, due 2026-10-10, Dynamic Status *Overdue*) and *Outdated TLS on payment gateway* (Closed). They have no owners, collaborators or linked items.

Creating a record

Click **Add Item**. The dialog **Add Item** (subtitle *External Audit Findings*) opens.



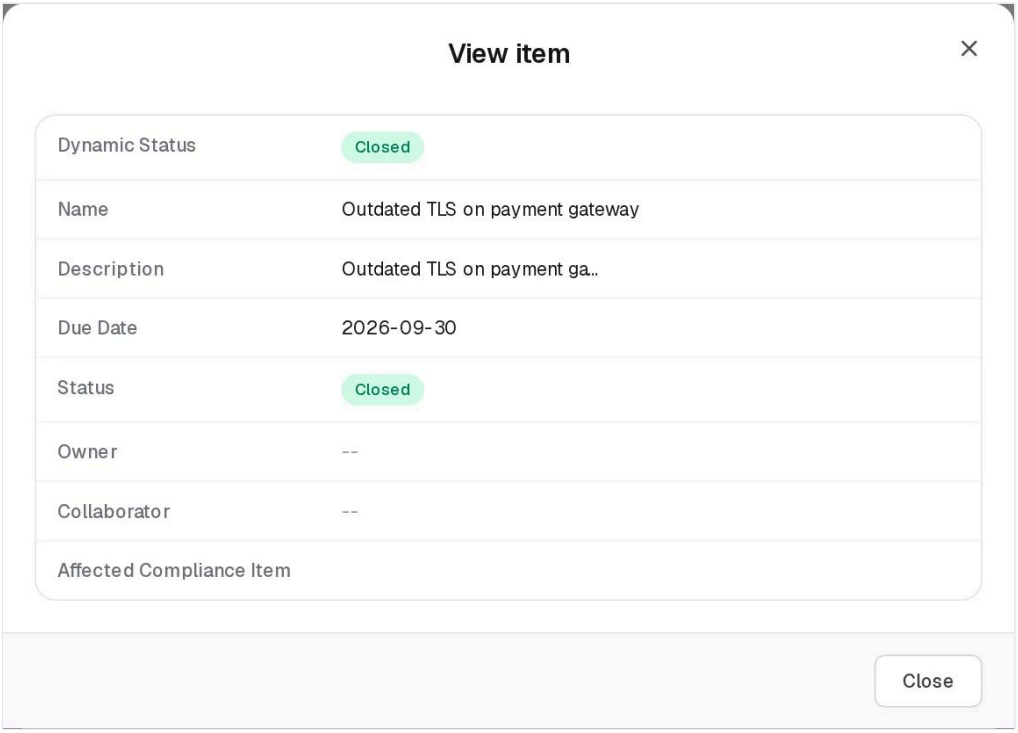
Add External Audit Finding

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	“Name is required.” Placeholder *FIND01 - Missing Firewall Policies*	SQL injection in customer portal
Description	Multi-line text	No	Placeholder *Describe the finding.*	SQL injection in customer portal.

Field	Type	Required	Rules and allowed values	Example
Due Date	Date	No	Drives the *Overdue* Dynamic Status	2026-10-10
Status	Dropdown	No (always has a value)	**Open**, **Closed**. Default Open.	Open
Owner	User/group picker	No	Several can be picked	Sara Johnson
Collaborator	User/group picker	No	Several allowed	Mike Brown
Affected Compliance Items	Package dropdown, then a checklist	No	Choose a package in **Choose a compliance package…** (the **+** button beside it creates a new package). Its items appear as a checklist with a **Search compliance items…** box; tick the affected items. Ticked items are shown as chips above the dropdown, each with a remove button, and the count reads “ item(s) linked.” You can switch package and tick items from several packages.	ISO/IEC 27001:2022 › A.8.8 Management of technical vulnerabilities

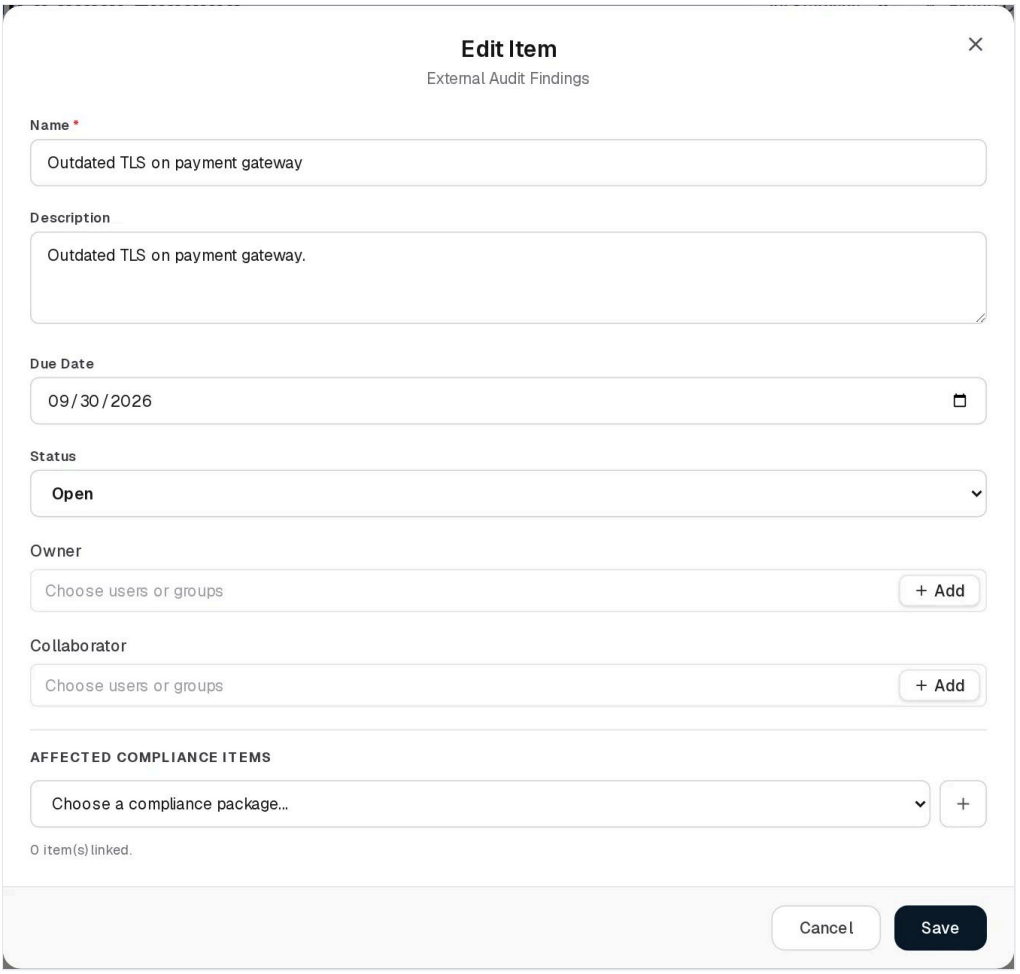
Messages in the checklist: “This package has no requirement items yet.” and “No items match”“.” Severity and source are not in the form: a new finding is saved with severity *Medium* and source *External Audit*, and an edited finding keeps its stored values. Saving shows “Audit finding added.”

Viewing and editing a record



View External Audit Finding

View opens **View item** with the eight grid columns. **Edit** opens **Edit Item** (subtitle *External Audit Findings*) with the same fields; the linked items are listed as chips and no package is preselected.



Edit External Audit Finding

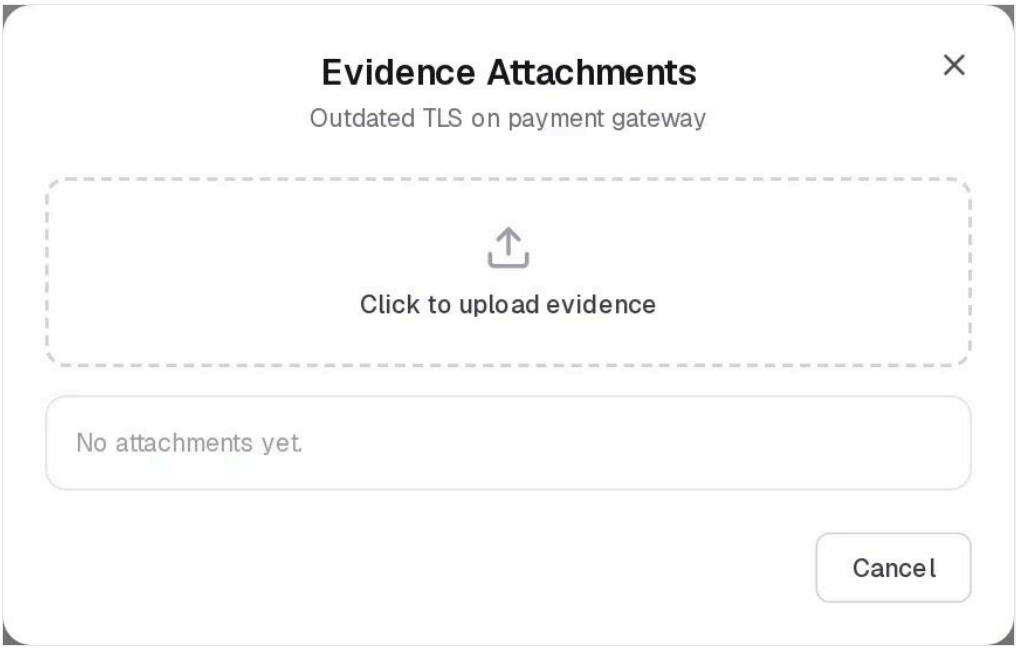
The screenshot shows *Outdated TLS on payment gateway*, stored with status *Closed* in mixed case by the demo data; the dropdown cannot match it and displays **Open**. Saving without touching **Status** keeps the stored value; choosing a value replaces it. Saving shows “Audit finding updated.” A status change is written to the System Log (“AUDIT_FINDING_STATUS_CHANGED”).

Items deleted from their package since they were linked are dropped from the finding silently on the next save.

Delete asks “Delete ?” and soft-deletes the finding.

Evidence attachments

Click the paper-clip button on a row. The dialog **Evidence Attachments** (subtitle: the finding’s name) has an upload area at the top and, below it, the list of files with name, size in KB and upload date, each with **Download** and **Delete** buttons. **Cancel** closes the dialog; uploads and deletions take effect immediately, so there is no Save.



Evidence Attachments

- **Click to upload evidence** opens a file chooser; the file is uploaded immediately. Any file type is accepted, up to 10 MB (“Attachment exceeds the 10 MB limit: ”).
- **Delete** asks “Delete ?”; the file is removed from the list (“Attachment deleted.”).
- With no files the list reads “No attachments yet.” (as for *Outdated TLS on payment gateway* in the screenshot).

Statuses

Status (set by a person):

Value	Set by	Meaning
Open	User (default)	The finding is being remediated. Blue.
Closed	User	Remediation is done. Green.
In Progress, Resolved	Older data, API or CSV import	Still read and displayed, no longer offered.

Dynamic Status (system, computed on every read; dates compared as calendar days in UTC):

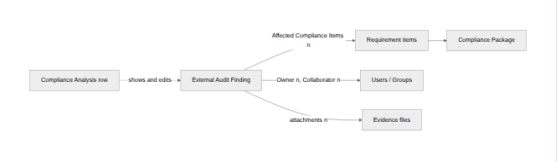
Value	Rule	Colour
Closed / Resolved	The status is Closed or Resolved (any letter case)	Green
Overdue	Any other status, and the due date is before today	Red
(the status itself)	Otherwise, for example *Open* or *In Progress*	Blue / amber

A finding due today is not yet overdue.

Tabs

None. Evidence files are handled in the Evidence attachments dialog.

Relationships



Related record	Direction	How the link is made	Where it shows
Requirement items	Finding → items, many to many	**Affected Compliance Items** checklist, or Compliance Analysis › Edit Action › General › **Findings**	**Affected Compliance Item** column (not clickable); Edit Action of each item's analysis row
Owners, collaborators	Finding → users or groups, many	Form	**Owner**, **Collaborator** columns
Evidence files	Finding → files, one to many	**Evidence Attachments** dialog	Paper-clip badge

Automations and notifications

- **Dynamic Status** is computed every time the register is read, so *Overdue* appears the day after the due date without any job.
- No reminders or notifications are sent for findings, before or after the due date. No scheduled job concerns this register.

Permissions

Action	Needed access
See the page, filter, **Export CSV**, list and download attachments	View on Compliance Hub › External Audit Findings
Create / Edit	Manage on Compliance Hub › External Audit Findings
Upload an attachment	Manage on Compliance Hub › External Audit Findings
Import CSV	Manage on Compliance Hub › External Audit Findings
Delete a finding, delete an attachment	Full Control on Compliance Hub › External Audit Findings
Comments	The group's Comments & Attachments level

The paper-clip button is not locked for users without the right; an upload or delete they may not make is refused when attempted. See Permissions and access.

How to

Record the findings of a certification audit

1. Open **Compliance Hub › External Audit Findings** and click **Add Item**.
2. Enter **Name** `Unpatched server found in DMZ`, a **Description** and the **Due Date** agreed with the auditor.
3. Pick the **Owner** and any **Collaborator**.
4. Under **Affected Compliance Items** choose *ISO/IEC 27001:2022*, type `8.8` in the search box and tick *A.8.8 Management of technical vulnerabilities*. **Save**.
5. The finding now also appears in the **Findings** field of A.8.8 on Compliance Analysis.

Attach remediation evidence and close the finding

1. Click the paper-clip button on the finding and **Click to upload evidence**; choose the patch report. Close the dialog with **Cancel**.
2. Click **Edit**, set **Status** to **Closed** and **Save**. The Dynamic Status becomes *Closed*.

Review what is overdue

1. Look for *Overdue* in **Dynamic Status** (in the demo data: *SQL injection in customer portal*), or sort by **Due Date**.
2. The **Open** status filter does not find overdue findings stored with other spellings (see below).

CSV import

Import CSV first shows “CSV Import (External Audit Findings): the import structure is not ready yet.” and then opens the working import dialog (`POST /api/v1/compliance/audit-findings/import-csv`).

Column (position)	Required	Notes
1 name	Yes	“Row n: Name cannot be empty”
2 description	No	
3 dueDate	No	`YYYY-MM-DD` or an ISO-8601 instant; “Row n: Invalid due date ‘’. Use YYYY-MM-DD or an ISO-8601 instant”
4 status	No	Stored in upper case; default `OPEN`
5 severity	No	Stored in upper case; default `MEDIUM`
6 source	No	Stored in upper case; default `EXTERNAL_AUDIT`

The first line is skipped. Values are not checked against a list. Imported findings have no owners, collaborators or linked items.

Export CSV downloads `audit-findings.csv` with the same six columns for every finding (the status filter and search are ignored).

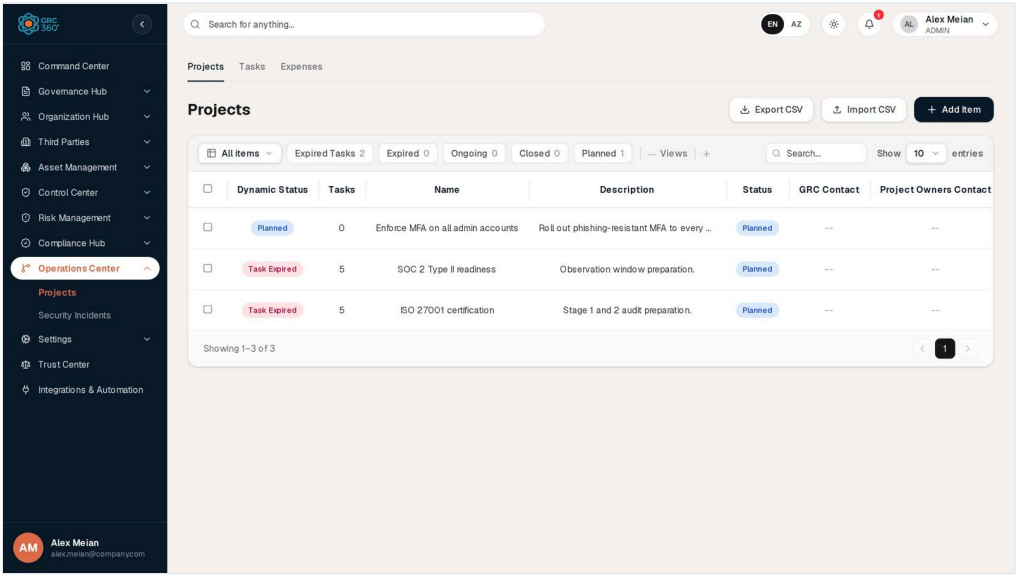
Limitations and known issues

- **Status filter is case-sensitive.** It sends `OPEN` or `CLOSED` ; findings stored in another spelling are not found. In the demo data the values are *Open*, *In Progress* and *Closed*, so **Open** and **Closed** both return no rows (the API returns 2 rows for `Open` and 0 for `OPEN`).
- **Edit shows Open for values outside the list**, including the demo data’s *Closed* and *In Progress*.
- **Severity and source** are stored and exported but cannot be seen or changed in the UI.
- **Owner** accepts several people although the page treats ownership as one person.
- **Export ignores the filter and search.**
- **No reminders** for due dates.

Operations Center

> **Module:** Operations Center · **Route:** `/operations-center` · **Permission module:** `operations_center`

The Operations Center holds the day-to-day work of the GRC programme: **Projects** that implement controls and treat risks, with their tasks and expenses, and **Security Incidents** that are taken through a fixed set of handling stages before they can be closed. Other modules point at both: controls, risks and compliance requirements name the projects that treat them, and risks name the incidents in which they materialised.



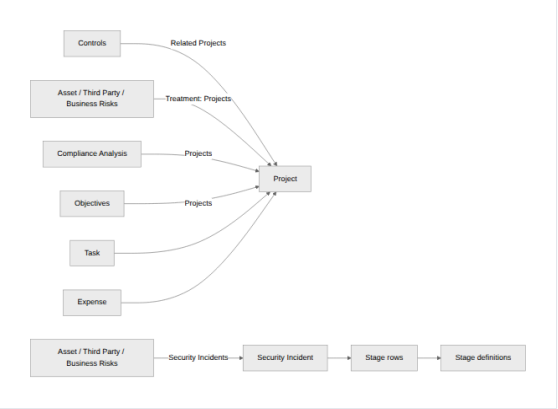
Projects register

Pages

Page (sidebar label)	Route	Permission key	What it holds
Projects	`/operations-center/projects`	`operations_center.projects`	Improvement projects: dates, contacts, status, and the controls, asset risks and compliance packages that name them.
Projects › Tasks	same route, **Tasks** tab	`operations_center.projects_tasks`	Ordered tasks of every project with owner, deadline and completion rate.
Projects › Expenses	same route, **Expenses** tab	`operations_center.projects_expenses`	Amounts spent on each project.
Security Incidents	`/operations-center/incidents`	`operations_center.incidents`	Incidents, possible incidents and events, with their stage progress and the risks that name them.
Security Incidents › Stages	same route, **Stages** tab	`operations_center.incidents_stages`	One row per stage of every incident, with its Completed or Incomplete status. Stage definitions are kept in the **Settings** dialog.

The sidebar shows the two pages under **Operations Center**; there is no overview page of its own.

How the records fit together



- A **project** chooses none of its links. The Projects grid reads them from the records that name the project: **Internal Controls**, **Asset Risks** (count) and **Compliance Package**.
- **Tasks** and **expenses** each belong to one project. A project's Dynamic Status and its automatic *Completed* status come from its tasks.
- A **security incident** also chooses no risks. Its **Known Asset / Third Party / Business Risk** counts are read from the risks whose **Security Incidents** field names it.
- **Stage definitions** are copied onto every new incident as stage rows. Closing an incident requires every stage row to be *Completed*.

Statuses at a glance

Register	Status a person sets	Dynamic Status the system shows
Projects	Planned, Ongoing, Closed (the system may set Completed)	Closed, Expired, Task Expired, Planned, Ongoing
Tasks	None (Completion Rate instead)	Completed, Expired, Ongoing, Planned
Expenses	None	Recorded, Missing Date, Missing Amount
Security Incidents	Open, Closed (new incidents are always Open)	Closed, Completed (all stages done), In Progress
Incident stages	Completed, Incomplete	Follows the status

All Dynamic Statuses are computed every time a register is read, so date-based values such as *Expired* appear without any scheduled job. The exact rules are on each page.

Automations

- **Project completion from tasks**: when every task of a project reaches 100% the project's Status becomes *Completed*; it returns to *Ongoing* when a task drops below 100%.
- **Stages on new incidents**: every new incident receives all stage definitions as *Incomplete*. A newly defined stage can be added to all open incidents (**Apply this stage to incidents that are currently open? → Yes**).
- **Closing rule**: an incident can be closed only when all its stages are *Completed*; the Closure Date is set automatically.
- **Command Center**: project tasks feed the **Task Overview**; projects feed **Overall Progress**.
- **Notifications**: none. The type *INCIDENT_ALERT* exists but nothing produces it, and no reminders are sent for task deadlines.

Permissions

Each page and each tab (Tasks, Expenses, Stages) has its own access level in the group settings (No Access, View, Manage, Full Control), plus the group's Comments & Attachments level. Export CSV needs View; Import CSV, Add and Edit need Manage; Delete needs Full Control. There are no assignment rights and no row-level filters in this module. Some checks on the incident stages do not line up between the screen and the server; see Security Incidents. General rules: Permissions and access.

CSV import and export

This module has working CSV import on Projects, Tasks, Expenses, Security Incidents and the stage definitions (Settings). As on every register, **Import CSV** first shows *CSV Import (…): the import structure is not ready yet.* and then opens the real import dialog. The Stages tab's **Import CSV** opens a demo dialog that cannot import. Export CSV exists on Projects, Tasks, Expenses, Security Incidents and the stage definitions. Formats are on each page and in CSV import and export.

Shared behaviour

All tabs use the shared grid: search, **… Views**, paging, the selection toolbar, the View dialog, the Activity Log and the delete confirmation work as described in Working with registers.

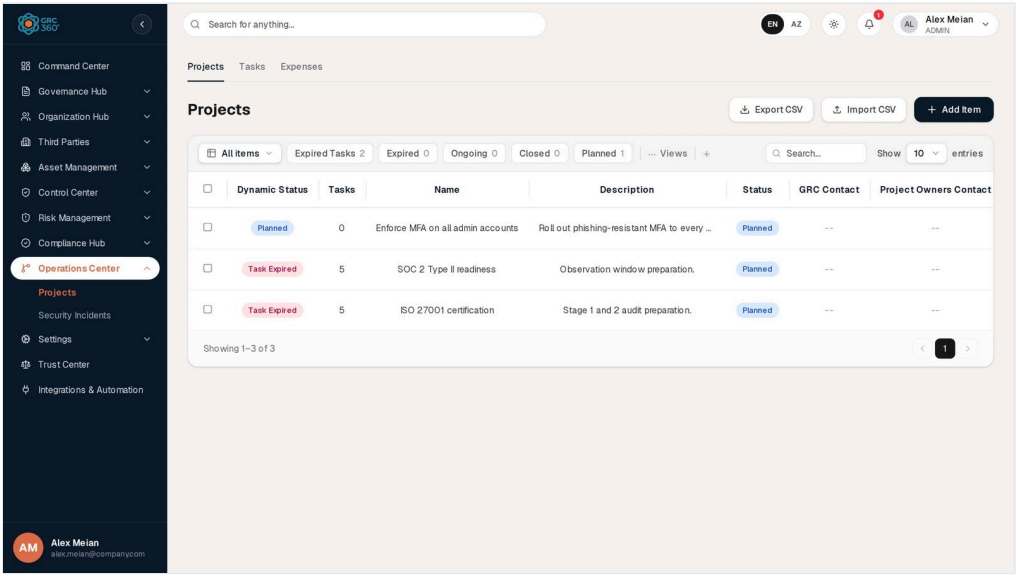
Related pages

- Controls (**Related Projects**), Asset Risks, Third Party Risks, Business Risks (**Treatment: Projects**, **Security Incidents**), Compliance Analysis (**Projects**), Objectives (**Projects**).
- Command Center: Task Overview and Overall Progress.
- Scenario: handling a security incident.

Projects

> **Module:** Operations Center › Projects · **Route:** `/operations-center/projects` · **Permission key:** `operations_center.projects` (tabs: `operations_center.projects_tasks` , `operations_center.projects_expenses`)

The Projects register tracks the improvement work of the GRC programme: rolling out a control, treating a risk, preparing for a certification. One record is one project with its dates, contacts and status. Its **Tasks** tab holds the ordered tasks of every project, each with an owner, a deadline and a completion rate, and its **Expenses** tab holds what was spent. Projects are normally run by the GRC team or project owners in IT and the business; other modules point at them as the treatment for controls, risks and compliance requirements.



Projects register

At a glance

A record is	One improvement project, with its tasks and expenses
Typical owner	Project owner (Project Owners Contact) with a GRC Contact
Links to	Users (GRC Contact, Project Owners Contact)
Linked from	Controls (**Related Projects**), Asset, Third Party and Business Risks (**Treatment: Projects**), Compliance Analysis (**Projects**), Policies (**Related Projects**), Data Flows (**Improvement Projects**), Objectives (**Projects**), Tasks and Expenses
Tabs	**Projects**, **Tasks**, **Expenses**
Automations	Dynamic Status of projects and tasks computed on every read; project status set to *Completed* when every task reaches 100%; Command Center Task Overview and Overall Progress

The register (list view)

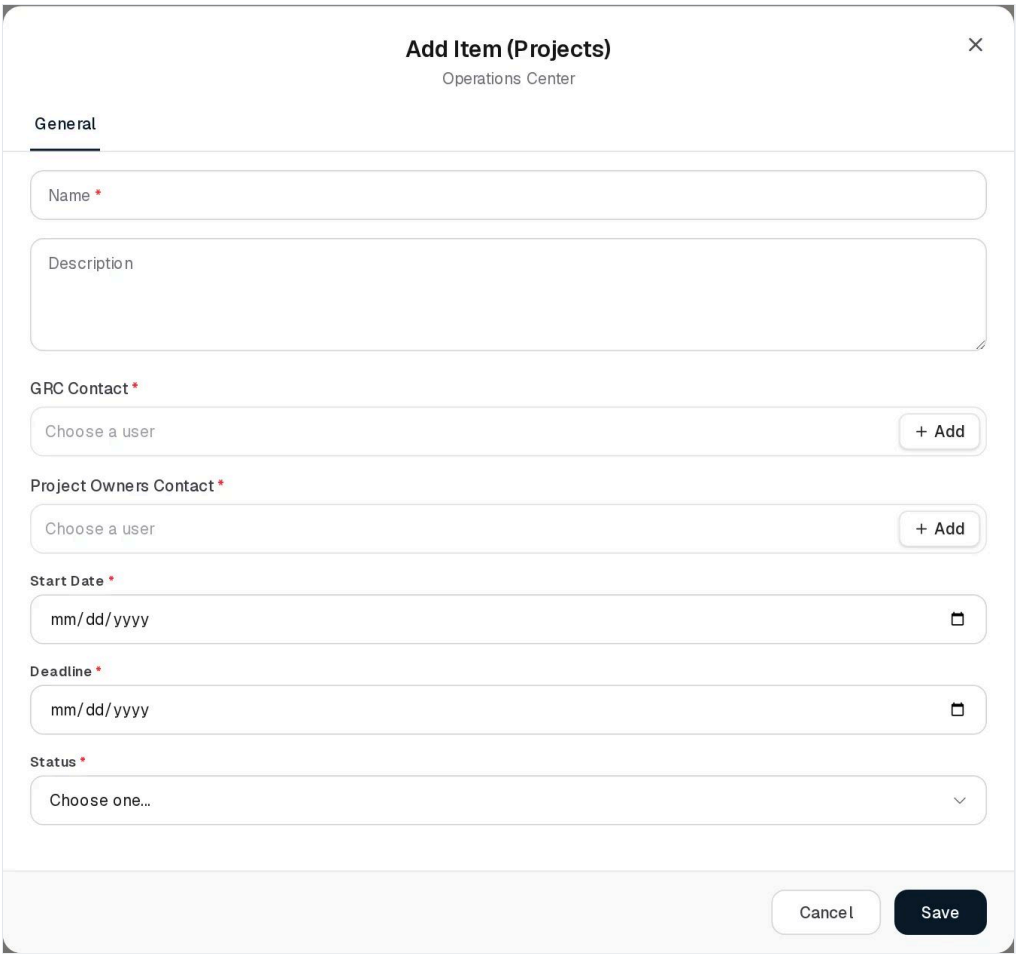
All three tabs use the shared grid described in Working with registers. Each tab loads its whole register at once, so the **All items** drop-down (filter by Status) and the view chips with their counts are available. The header has **Export CSV**, **Import CSV** and **Add Item**.

View chips on Projects (matched on the Dynamic Status): **Expired Tasks**, **Expired**, **Ongoing**, **Closed**, **Planned**. In the demo data: Expired Tasks 2, Planned 1.

Column	What it shows	Source
Dynamic Status	*Closed*, *Expired*, *Task Expired*, *Ongoing* or *Planned* (rule below)	Computed by the system
Tasks	Number of tasks of the project (deleted tasks not counted)	Computed
Name	Project name	Entered
Description	Description	Entered
Status	The status chosen on the form: *Planned*, *Ongoing*, *Closed* (older rows may show *Completed*, *Confirmed* or *Delayed*)	Entered, or set by the task automation
GRC Contact	Users named as GRC contact	Entered
Project Owners Contact	Users named as project owners	Entered
Start Date	Start date	Entered
Deadline	Project deadline	Entered
Internal Controls	Names of the controls that name this project under **Related Projects**	Linked (read from the controls)
Asset Risks	Number of asset risks naming this project under **Treatment: Projects**; click a non-zero number to open them	Linked (read from the risks)
Compliance Package	Packages of the Compliance Analysis items that name this project (each package once)	Linked (read from Compliance Analysis)

Creating a record

Click **Add Item**. The dialog **Add Item (Projects)** (subtitle *Operations Center*) has a single **General** tab.



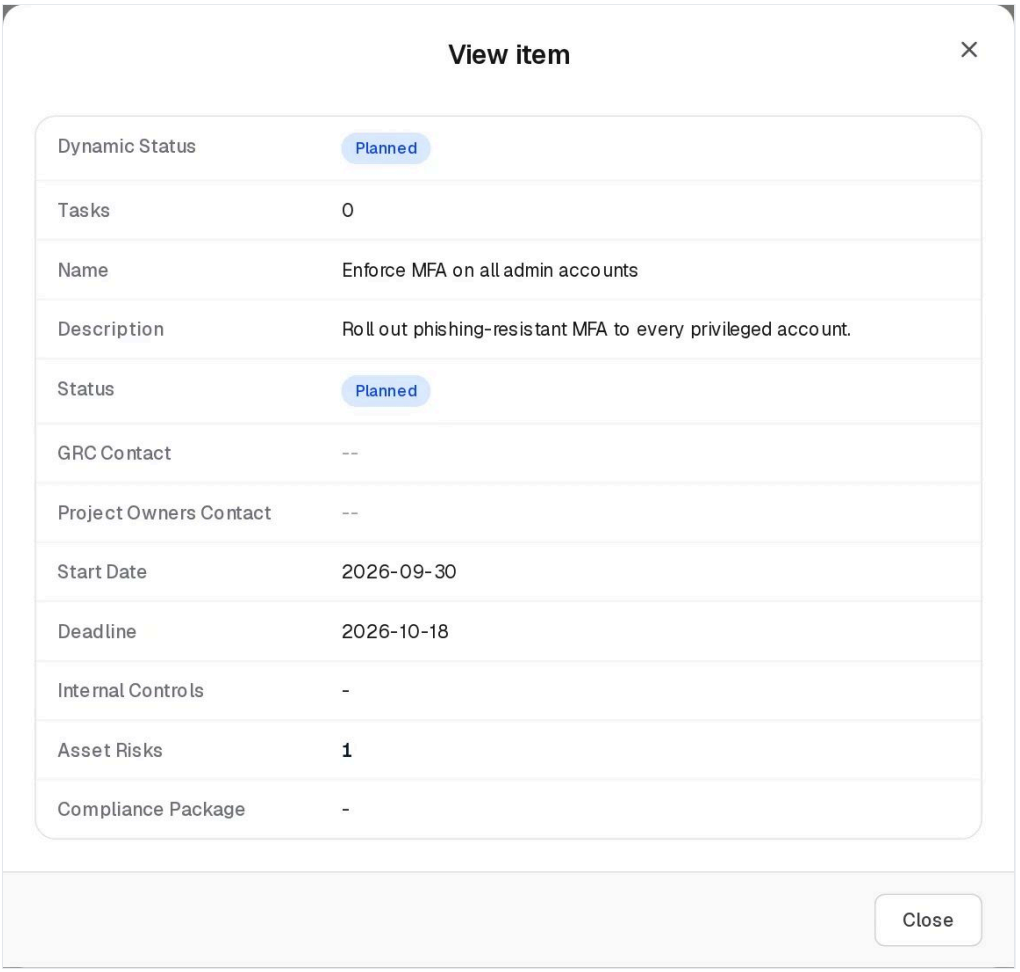
Add Project

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	*Required*. Up to 255 characters (*Project name must not exceed 255 characters*).	ISO 27001 certification
Description	Text area	No	Up to 2,000 characters.	Stage 1 and 2 audit preparation.
GRC Contact	Users only, several allowed (*Choose a user*)	Yes	*Required*. Groups cannot be chosen. **+ Add** creates a new user. Up to 255 characters of names.	Alex Meian
Project Owners Contact	Users only, several allowed	Yes	*Required*. Up to 500 characters of names.	Sara Johnson
Start Date	Date	Yes	*Required*	2026-08-06
Deadline	Date	Yes	*Required*. Not checked against Start Date.	2026-12-24
Status	Drop-down	Yes	**Closed**, **Ongoing**, **Planned**. Empty (*Choose one…*) until you pick.	Planned

Errors appear as *Required* under each field. Saving shows *Project added.* The form has no fields for controls, risks or compliance packages: those links are made on the other records (see Relationships).

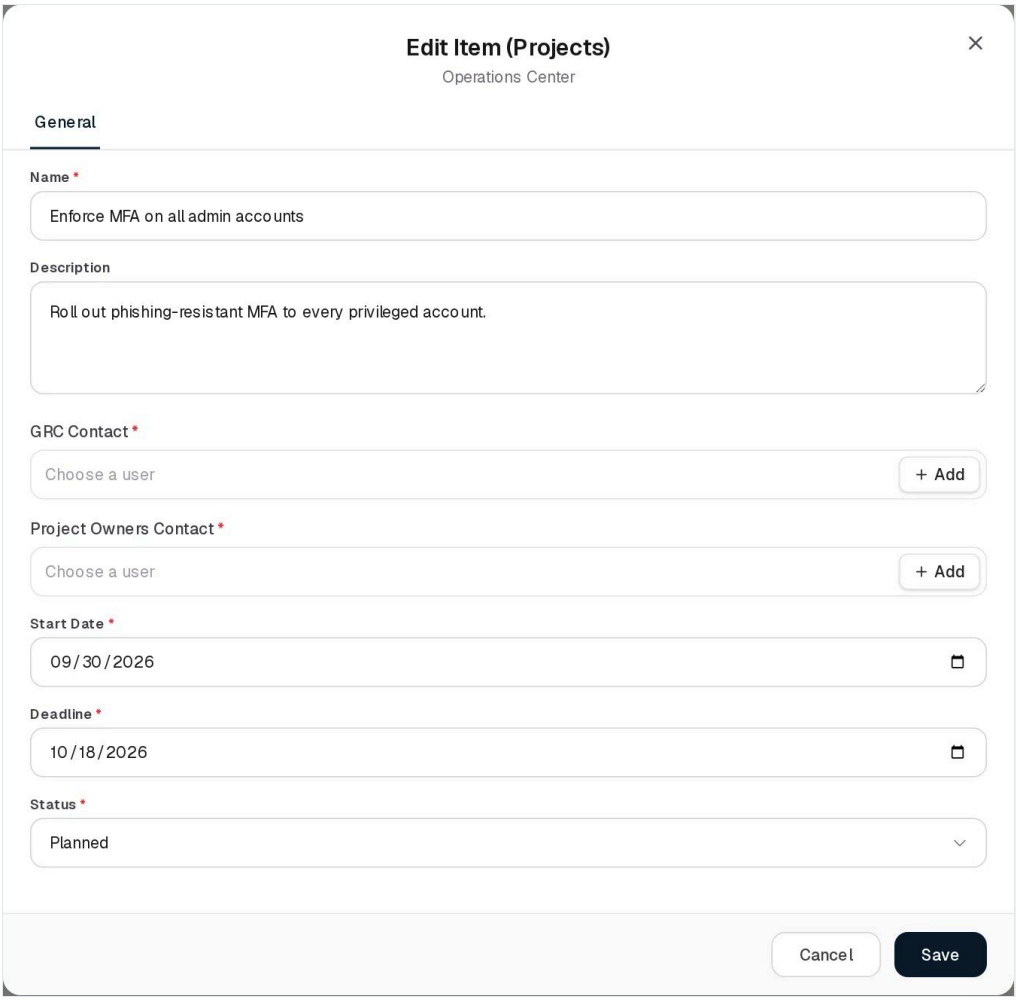
The same form opens when you click **+** next to **Project** on the Tasks and Expenses forms, or **+ Add** on a project field in another module.

Viewing and editing a record



View Project

View opens the shared **View item** dialog with every column. A non-zero **Asset Risks** count is clickable.



Edit Project

Edit Item (Projects) has the same fields. A project that holds an older status (*Completed*, *Confirmed* or *Delayed*) keeps that value in the **Status** list so it does not silently change to *Planned*. Saving shows *Project updated.*

Deleting a project asks *Delete (name)? Its tasks and expenses will be removed as well.* and removes its tasks and expenses with it.

Statuses

Status (set by a person)

Value	Meaning
Planned	Not started.
Ongoing	Work in progress.
Closed	The owner closed the project.
Completed	Set by the system when every task reaches 100% (see Automations). Also held by older rows.
Confirmed, Delayed	Held by older rows only; not offered for new choices.

Any other value sent to the server is stored as *Planned*.

Dynamic Status (computed every time the register is read; first matching rule wins)

Value	Colour	Rule
Closed	Green	Status is *Closed* or *Completed*, or the project has at least one task and every task is at 100%

Value	Colour	Rule
Expired	Red	The project deadline is before today
Task Expired	Red	The project is in time, but at least one task below 100% has a deadline before today
Planned	Blue	The project has no tasks
Ongoing	Amber	Any other case

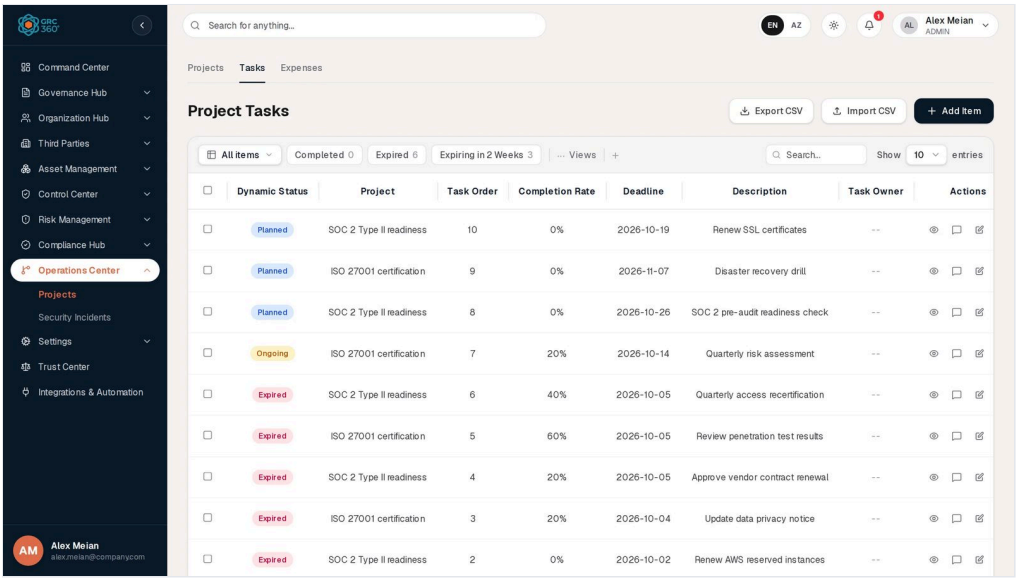
The rules are evaluated live, so a project turns *Expired* the day after its deadline without any job running. *SOC 2 Type II readiness* and *ISO 27001 certification* read *Task Expired* in the demo because tasks such as *Review Q3 internal audit report* (deadline 2026-09-29, 0%) are past due.

The backend also computes a progress percentage per project (the average completion rate of its tasks). It is not shown on this page; it feeds the Command Center.

Tabs

Tasks

The **Project Tasks** register lists the tasks of all projects. Tasks have no status of their own: the Dynamic Status follows from completion rate and deadline.

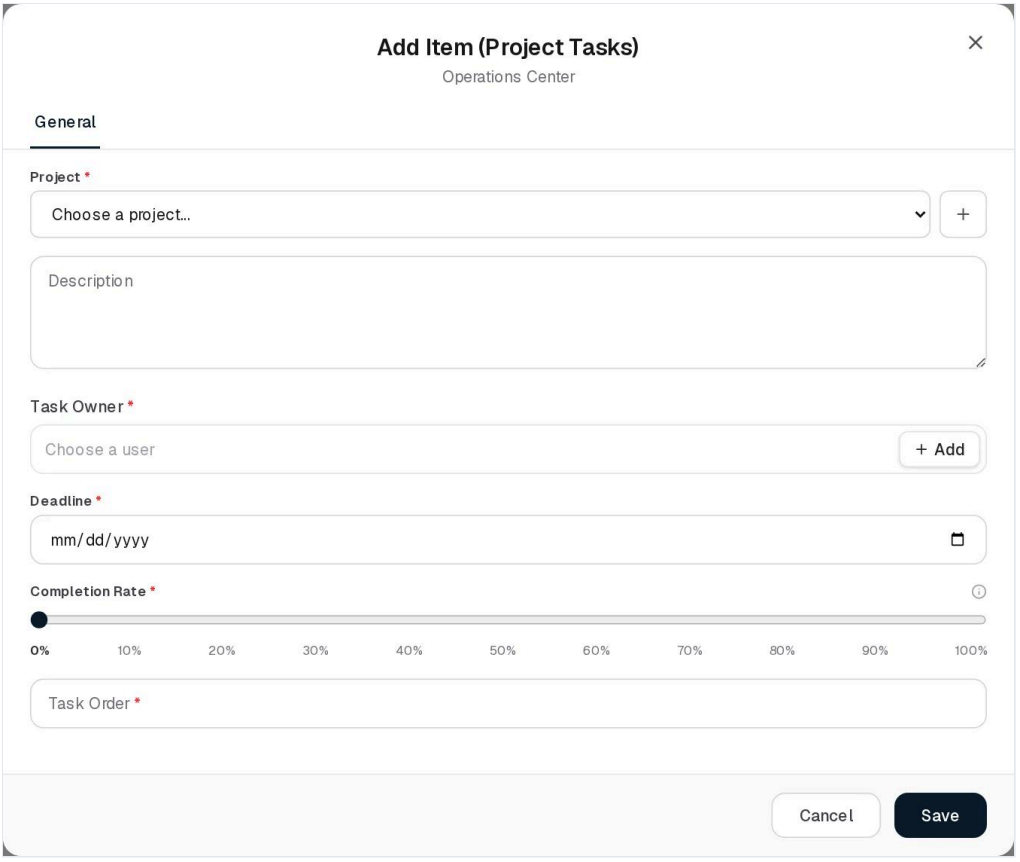


Project Tasks

View chips: **Completed** (Dynamic Status Completed), **Expired** (Dynamic Status Delayed), **Expiring in 2 Weeks** (deadline from today up to 14 days ahead and not completed). In the demo data: Completed 0, Expired 6, Expiring in 2 Weeks 3.

Column	What it shows
Dynamic Status	*Completed* (100%), *Expired* (below 100% and deadline before today), *Ongoing* (1 to 99%), *Planned* (0% and deadline today or later), in that order of precedence
Project	The project the task belongs to
Task Order	Position of the task in its project
Completion Rate	0% to 100%
Deadline	Task deadline
Description	What the task is
Task Owner	Users named as owner

Add Item (Project Tasks) / **Edit Item (Project Tasks)**:



Add Project Task

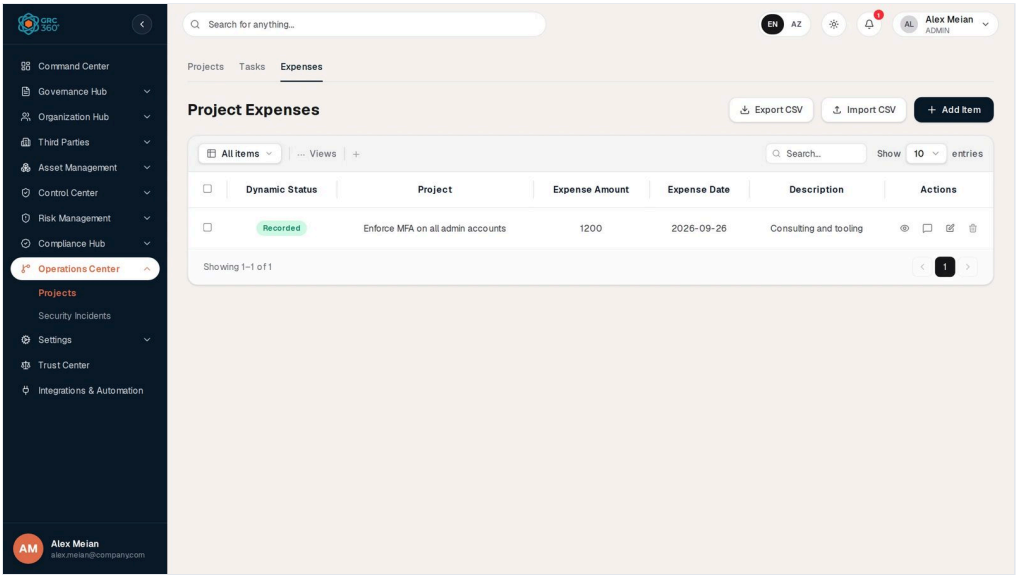
Field	Type	Required	Rules and allowed values	Example
Project	Drop-down of projects (*Choose a project…*), with **+** to create one	Yes	*Required*. Picking a project fills **Task Order** with the next free number if it is empty.	ISO 27001 certification
Description	Text area	No		Review Q3 internal audit report
Task Owner	Users only, several allowed	Yes	*Required* (server: *Task owner is required*)	Mike Brown
Deadline	Date	Yes	*Required* (server: *Deadline is required*)	2026-09-29
Completion Rate	Slider, steps of 10	Yes	0% to 100%, default 0%. The **i** icon reads *A task counts as complete at 100%.*	20%
Task Order	Number	Yes	Whole number of 1 or more (*Must be a whole number of 1 or more*). Must be unique in the project: *Task order N is already used by another task in “Project”. Pick a different order.*	1

Messages: *Task added.*, *Task updated.*, *Task deleted.*

Screenshots: View, Edit.

Expenses

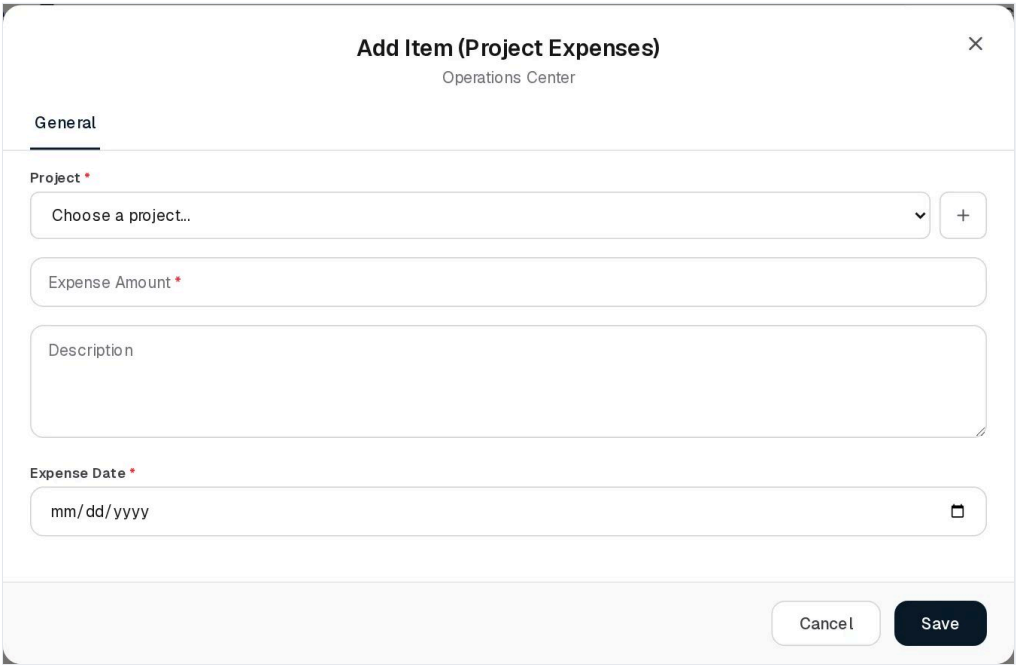
The **Project Expenses** register lists what was spent on each project. There are no view chips on this tab; the **All items** drop-down filters by the Dynamic Status.



Project Expenses

Column	What it shows
Dynamic Status	*Recorded* (amount above zero and a date), *Missing Date* (amount above zero, no date), *Missing Amount* (no amount or amount 0)
Project	The project
Expense Amount	Amount, no currency
Expense Date	Date of the expense
Description	What it was for

Add Item (Project Expenses) / **Edit Item (Project Expenses)**:



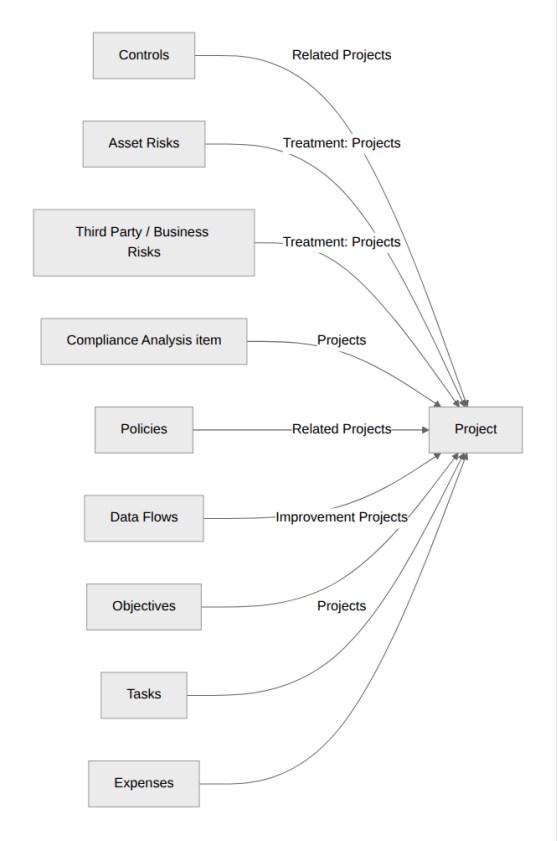
Add Project Expense

Field	Type	Required	Rules	Example
Project	Drop-down with **+**	Yes	*Required*	Enforce MFA on all admin accounts
Expense Amount	Number, step 0.01	Yes	*Required*; zero or more (*Must be zero or more*; server: *Expense amount cannot be negative*)	1200
Description	Text area	No		Consulting and tooling
Expense Date	Date	Yes	*Required* (server: *Expense date is required*)	2026-09-26

Because amount and date are required, an expense saved from this form reads *Recorded*, or *Missing Amount* when the amount is 0. Messages: *Expense added.*, *Expense updated.*, *Expense deleted.*

Screenshots: View, Edit.

Relationships



A project chooses none of these links itself. Each one is made on the other record.

Related record	Direction	How the link is made	Where it shows on Projects
Controls	Control → Project, many to many	Control form, **Related Projects**	**Internal Controls** column (names)
Asset Risks	Risk → Project, many to many	Risk form, **Treatment: Projects**	**Asset Risks** column (count, clickable)
Third Party Risks, Business Risks	Risk → Project, many to many	Risk form, **Treatment: Projects**	Not shown. Used by the Command Center scope filter.
Compliance Analysis items	Item → Project, many to many	Compliance Analysis, **Projects**	**Compliance Package** column (package names)
Policies	Policy → Project	Policy form, **Related Projects**	Not shown

Related record	Direction	How the link is made	Where it shows on Projects
Data Flows	Data flow → Project	Data flow form, **Improvement Projects**	Not shown
Objectives	Objective → Project, many to many	Objective form, **Activities › Projects**	Not shown. A finished project counts towards the objective's progress.
Tasks	Task → Project, many to one	Task form, **Project**	**Tasks** column (count, not clickable)
Expenses	Expense → Project, many to one	Expense form, **Project**	Not shown
Users	Project, task → user	GRC Contact, Project Owners Contact, Task Owner (names stored as text, first pick also as a user link)	Grid columns

When a user is deleted, their user link is removed from projects and tasks, and their name stays in the text.

Automations and notifications

- **Dynamic Status** of projects, tasks and expenses: computed on every read, no job involved.
- **Project completion from tasks** (each time a task is added, edited or deleted): when every task of a project is at 100%, the project's **Status** becomes *Completed*; when a task of a *Completed* project drops below 100%, the Status returns to *Ongoing*; when the last task of a *Completed* project is deleted, it returns to *Planned*. These changes are written to the system audit log.
- **Command Center**: tasks with a deadline appear in the **Task Overview** (Expired, Today, Future). Users who do not see all tasks see only the tasks where they are the linked owner (the first owner picked). **Overall Progress** counts projects by Dynamic Status (*Closed* as Completed, *Expired* and *Task Expired* as Delayed, *Ongoing* as On going) and averages their progress.
- **Objectives**: a project whose Status is *Completed*, or whose tasks are all at 100%, counts as finished in the progress of any objective that links it. Achieving an objective does not change its projects.
- **Notifications**: none. Projects, tasks and expenses send no notification, and no reminder is sent for task deadlines.

Permissions

Projects, **Projects › Tasks** and **Projects › Expenses** each have their own access level (No Access, View, Manage, Full Control). See Permissions and access.

Action	Needed access
See the Projects tab	View on Operations Center › Projects
Open the Tasks or Expenses tab	View on that tab (it shows a lock otherwise)
Export CSV	View on the register being exported
Create / Edit / Import CSV	Manage on the register concerned
Delete	Full Control on the register concerned. Deleting a project removes its tasks and expenses without a separate check on those tabs.
Comment / attach	The group's Comments & Attachments level
Assign	No assignment rights on these registers

The project lists in the Tasks and Expenses forms come from the Projects register, so a user without View on Projects cannot pick a project there. There is no row-level filter: everyone with View sees all projects.

How to

Plan a project with tasks

1. On **Projects**, click **Add Item**. Enter *Enforce MFA on all admin accounts*, pick the **GRC Contact** and **Project Owners Contact**, set **Start Date**, **Deadline** and **Status Planned**, and **Save**.

2. Open **Tasks**, click **Add Item**, pick the project. **Task Order** fills with 1.
3. Enter the **Description** *Inventory privileged accounts*, a **Task Owner** and a **Deadline**, and **Save**.
4. Back on **Projects**, the **Tasks** column shows 1 and the Dynamic Status changes from *Planned* to *Ongoing*.

Report progress on a task

1. On **Tasks**, click the chip **Expiring in 2 Weeks** to see what is due soon.
2. Edit *Quarterly risk assessment* and move **Completion Rate** to 60%. **Save**.
3. When the last open task of a project reaches 100%, the project's Status becomes *Completed* and its Dynamic Status *Closed*.

Find projects that are behind

1. On **Projects**, click **Expired Tasks** (project in time, a task overdue) or **Expired** (project deadline passed).

Record an expense

1. Open **Expenses**, click **Add Item**, pick *Enforce MFA on all admin accounts*.
2. Enter **Expense Amount** *1200*, **Description** *Consulting and tooling* and the **Expense Date**, then **Save**. The row reads *Recorded*.

CSV import

Import works on all three tabs. **Import CSV** first shows *CSV Import (Projects): the import structure is not ready yet.* (or *Project Tasks*, *Project Expenses*) and then opens the import dialog: choose a `.csv` file, **Validate**, then **Import *n* rows**. Headers are matched case-insensitively, with spaces read as underscores (so *Start Date* and *start_date* both work).

Tab	Columns read	Checked by Validate	Notes
Projects	`name` (required), `description`, `grc_contact`, `project_owners`, `start_date`, `deadline` (YYYY-MM-DD), `status`	Name present; no duplicate name in the file	Contacts are stored as text only (no user link). Unknown status becomes *Planned*.
Tasks	`project_id` (UUID), `task_order` (required), `description`, `task_owner`, `deadline`, `completion_rate`	Task order present; no duplicate project/order pair in the file	Project, owner, deadline and order uniqueness are only checked on the actual import; failing rows appear under *Import Errors*.
Expenses	`project_id` (UUID), `expense_amount` (or `amount`), `description`, `expense_date`	Amount not negative	Project and date are only checked on the actual import.

Export CSV downloads `projects.csv` (*Tasks, Name, Description, Status, Start Date, Deadline, GRC Contact*), `project-tasks.csv` (*Dynamic Status, Task Owner, Completion Rate, Deadline, Task Order, Description, Project Name*) and `project-expenses.csv` (*Status, Expense Amount, Description, Expense Date, Project Name*).

Limits of the import: values are split on every comma, so quoted values that contain commas are not read correctly, and the task and expense exports give the project name while the import needs the project id. An exported file therefore cannot be re-imported as it is.

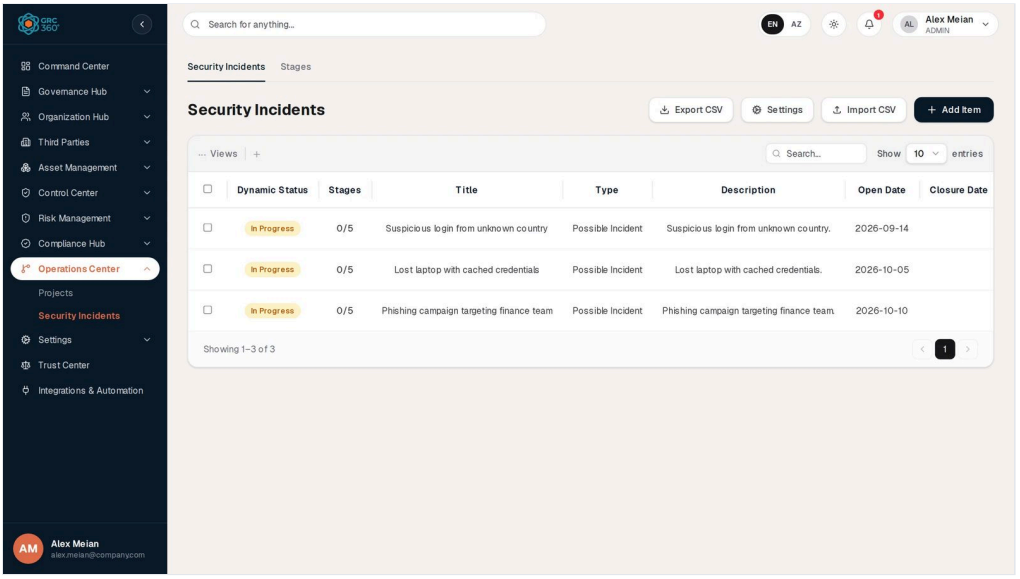
Limitations and known issues

- **The task automation writes Completed, not Closed.** A project finished through its tasks shows Status *Completed*, a value the Status list otherwise no longer offers.
- **Only asset risks are shown.** Third party and business risks that name a project under **Treatment: Projects**, and policies, data flows and objectives that link it, do not appear on the project.
- **Deadline before Start Date is accepted.**
- **No deadline reminders.** Overdue tasks are visible through Dynamic Status and the Command Center, but nobody is notified.
- **CSV import splits on commas** and cannot re-import its own export (see above).
- **Expense amounts have no currency.**

Security Incidents

> **Module:** Operations Center › Security Incidents · **Route:** `/operations-center/incidents` · **Permission key:** `operations_center.incidents` (tab **Stages**: `operations_center.incidents_stages`)

The Security Incidents register records security incidents, possible incidents and events worth keeping, and takes each one through a fixed set of handling stages before it can be closed. One record is one incident. The stages (for example *Detection*, *Containment*, *Eradication*, *Recovery*, *Lessons learned*) are defined once under **Settings**, in the style of ERAMBA, and every new incident receives all of them. The **Stages** tab lists every stage of every incident with its status. The register is kept by the security operations or incident response team, with the GRC function documenting the case.



Security Incidents register

At a glance

A record is	One security incident (or possible incident, or event) and its handling stages
Typical owner	Incident handler (Incident Contact) with a GRC Contact who documents it
Links to	Users (GRC Contact, Incident Contact), stage definitions
Linked from	Asset, Third Party and Business Risks (**Security Incidents** field on the risk)
Tabs	**Security Incidents**, **Stages** (plus the **Settings** dialog for stage definitions)
Automations	New incidents receive every defined stage; closing requires all stages completed; Dynamic Status and stage counts computed on read

The register (list view)

The **Security Incidents** tab uses the shared grid (Working with registers) with server-side paging. Because of that it has no **All items** drop-down and no view chips; search matches the incident title. The header has **Export CSV**, **Settings**, **Import CSV** and **Add Item**.

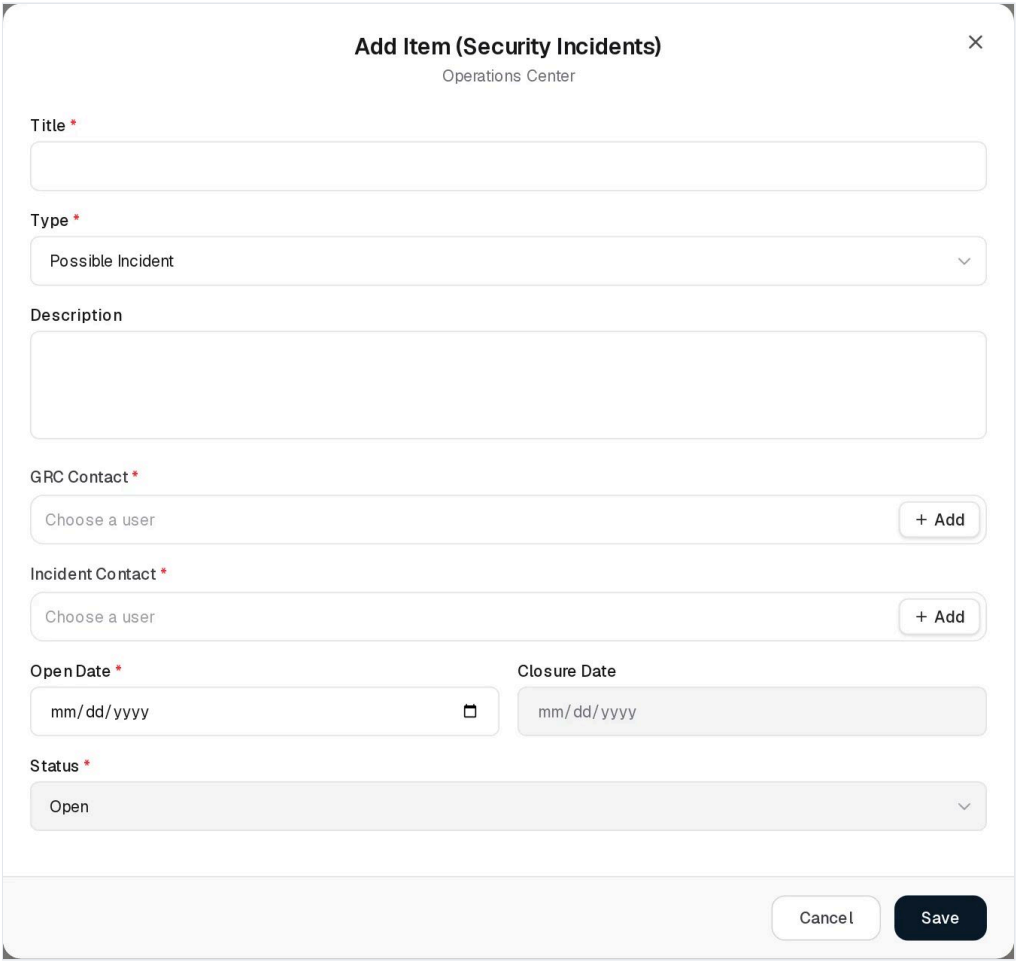
Column	What it shows	Source
Dynamic Status	*In Progress*, *Completed* or *Closed* (rule below)	Computed by the system
Stages	Stages completed out of stages assigned, for example **0/5**	Computed

Column	What it shows	Source
Title	Incident title	Entered
Type	*Incident*, *Possible Incident* or *Event*	Entered
Description	Description	Entered
Open Date	Date the incident opened	Entered
Closure Date	Date it was closed	Set by the system
Known Asset Risk	Number of asset risks that name this incident; click a non-zero number to open them	Linked (read from the risks)
Known Third Party Risk	Same, for third party risks	Linked
Known Business Risk	Same, for business risks	Linked

The GRC Contact and Incident Contact are on the form but not in the grid.

Creating a record

Click **Add Item**. The dialog is titled **Add Item (Security Incidents)** (subtitle *Operations Center*).



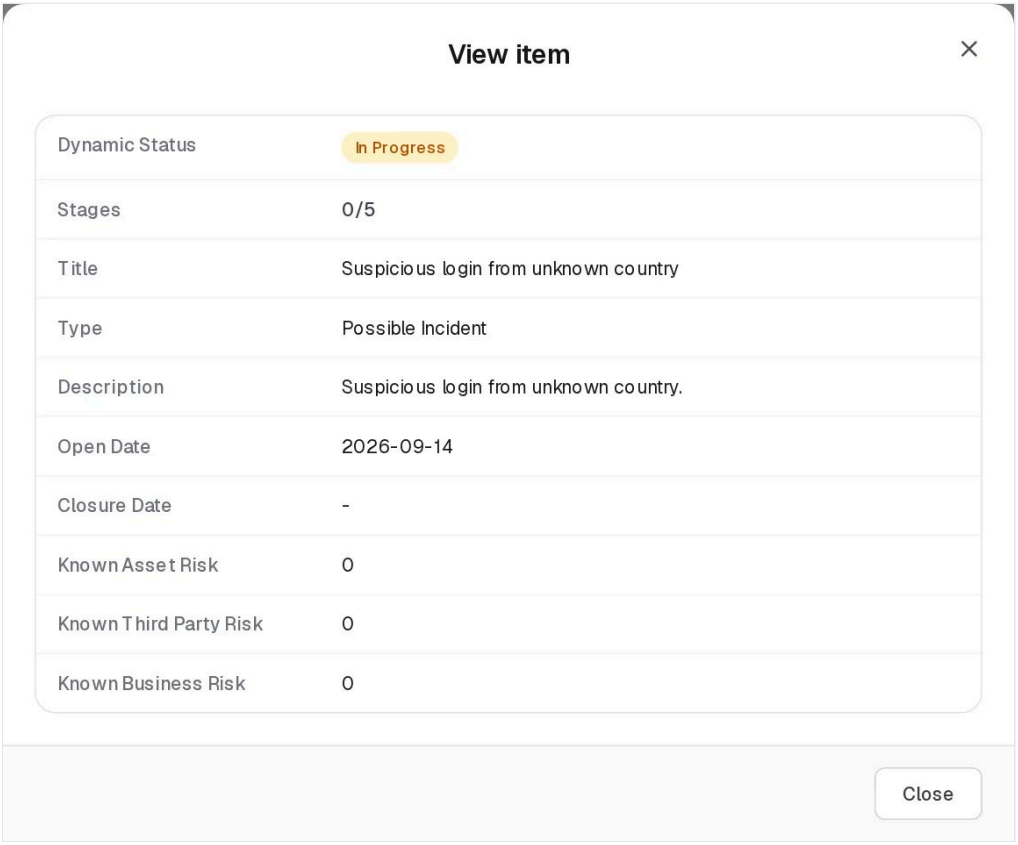
Add Security Incident

Field	Type	Required	Rules and allowed values	Example
Title	Text	Yes	*Required*. Up to 255 characters (*Title must not exceed 255 characters*).	Phishing campaign targeting finance team

Field	Type	Required	Rules and allowed values	Example
Type	Drop-down	Yes	**Incident**, **Possible Incident**, **Event**. Default **Possible Incident**.	Possible Incident
Description	Text area	No		Phishing campaign targeting finance team.
GRC Contact	Users only, several allowed (*Choose a user*)	Yes	*Required*. **+ Add** creates a new user.	Alex Meian
Incident Contact	Users only, several allowed	Yes	*Required*. The person or team handling or affected by the incident.	Mike Brown
Open Date	Date	Yes	*Required*. Cannot be later than today: the date picker stops at today, and a typed later date gives *Open Date cannot be in the future.*	2026-10-10
Closure Date	Date, greyed out	No	Never typed. Filled with today when Status is set to **Closed** on Edit, cleared when set back to **Open**.	
Status	Drop-down, greyed out on Add	Yes	**Open**, **Closed**. A new incident is always **Open**.	Open

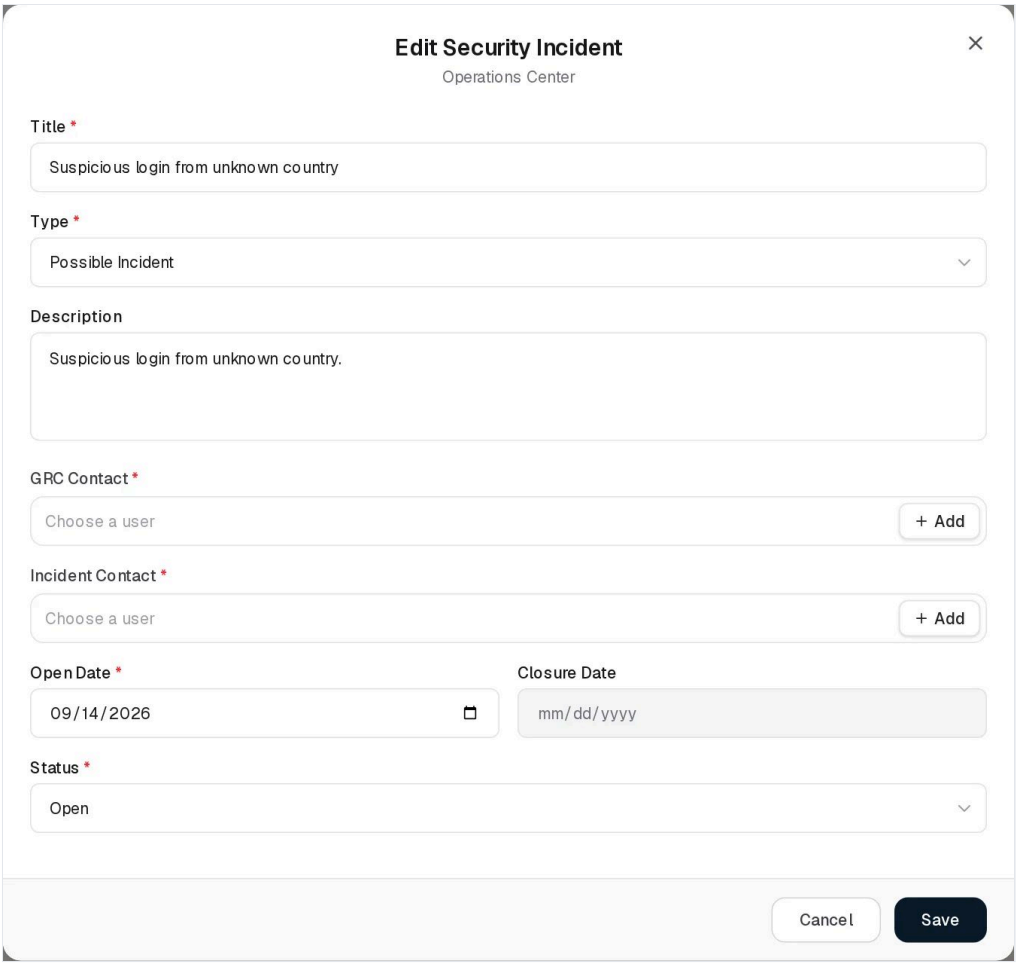
Saving shows *Incident added.* The new incident immediately receives every stage defined under **Settings**, each *Incomplete*, so its **Stages** column reads 0/n (0/5 in the demo).

Viewing and editing a record



View Security Incident

View opens the shared **View item** dialog with the grid columns. Known risk counts are clickable.



Edit Security Incident

Edit Security Incident has the same fields, with **Status** now selectable.

- Changing **Status** to **Closed** fills **Closure Date** with today. The server accepts it only if every stage of the incident is *Completed*; otherwise it refuses with *This incident still has open stages: Detection, Containment, … Complete every stage before closing it.* The message shows as a red pop-up and as a banner on the page, and the form stays open.
- Changing **Status** back to **Open** clears the Closure Date.
- Saving without changing the status re-checks nothing, so a closed incident can still be edited.

Saving shows *Incident updated.* Deleting asks *Delete incident (title)? Its stages will be removed as well.*

Statuses

Status (set by a person)

Value	Meaning
Open	The incident is being handled. Every new incident starts Open.
Closed	Handling is finished. Only possible when every stage is Completed.

Dynamic Status of an incident (computed on every read)

Value	Colour	Rule
Closed	Green	Status is *Closed*
Completed	Green	Status is *Open*, the incident has at least one stage and every stage is *Completed*: ready to close

Value	Colour	Rule
In Progress	Amber	Any other case, including an open incident with no stages

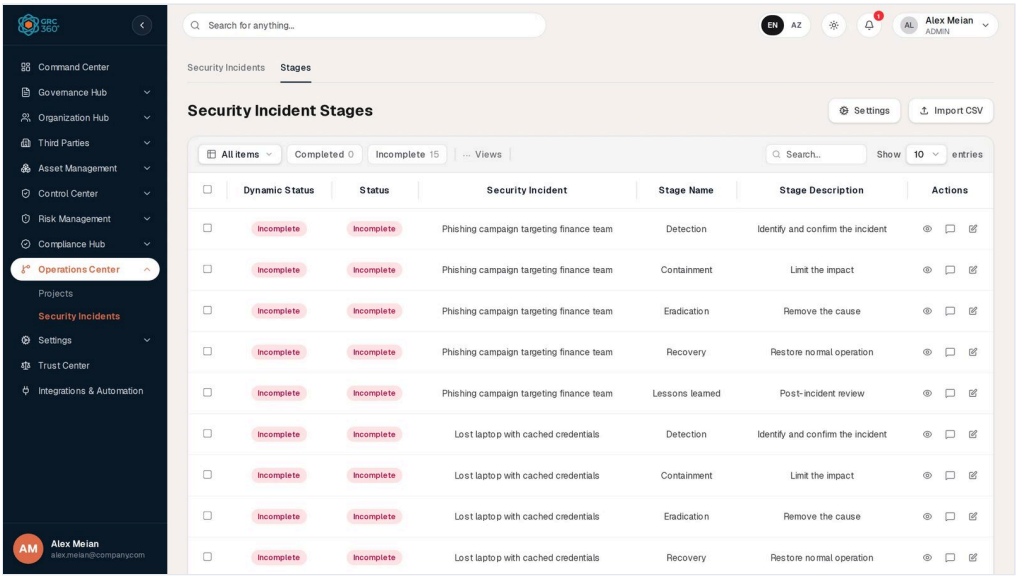
Stages column. Completed stages / stages assigned. A closed incident always reads n/n; a closed incident that never had stages reads the number of stages currently defined, for example 5/5.

Stage status (Stages tab): *Completed* or *Incomplete*, chosen by a person. The stage's Dynamic Status simply follows it: *Completed* (green) or *Incomplete* (red).

Tabs

Stages

The **Security Incident Stages** register lists one row per stage of every incident. Rows are created by the system (when an incident is added, or when a new stage is applied to open incidents); there is no **Add Item** and no **Delete** on this tab.

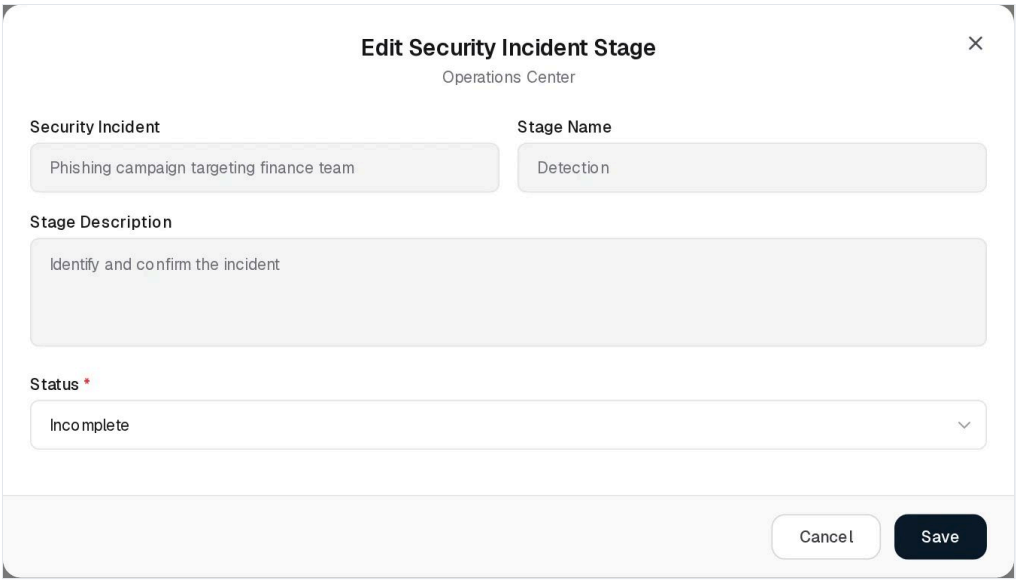


Security Incident Stages

The toolbar has **All items** and two view chips, **Completed** and **Incomplete** (Incomplete 15 in the demo: three incidents with five stages each). The header has **Settings** and **Import CSV**.

Column	What it shows
Dynamic Status	*Completed* or *Incomplete*, following Status
Status	*Completed* or *Incomplete*
Security Incident	Incident title
Stage Name	Name of the stage
Stage Description	Description of the stage

Edit (pencil, or tick a row and click **Edit**) opens **Edit Security Incident Stage**:



Edit Security Incident Stage

Field	Type	Required	Rules	Example
Security Incident	Text, read-only			Phishing campaign targeting finance team
Stage Name	Text, read-only			Detection
Stage Description	Text area, read-only			Identify and confirm the incident
Status	Drop-down	Yes	**Completed**, **Incomplete**	Completed

Saving shows *Stage updated.* and the incident's **Stages** count and Dynamic Status change at once. A stage of a closed incident cannot be set back to *Incomplete*: *A stage of a closed incident cannot be marked incomplete. Reopen the incident first.*

The View dialog shows the same five columns.

Settings: stage definitions

Settings (on either tab) opens the **Stages** dialog, a small register of stage definitions with **Name** and **Description** columns, **Export CSV**, **Import CSV** and **Add Item**. Stages are listed in the order they were created. A new tenant starts with no stages; the demo data defines *Detection*, *Containment*, *Eradication*, *Recovery* and *Lessons learned*.

Field	Type	Required	Rules	Example
Name	Text	Yes	*Required*. Up to 255 characters.	Containment
Description	Text area	Yes	*Required*	Limit the impact

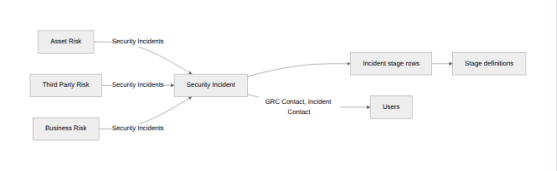
Adding a stage asks one more question after **Save**: *Apply this stage to incidents that are currently open?* with the explanation *Yes adds it to every open incident as incomplete. No keeps it for incidents added from now on.*

- **Yes**: every incident whose Status is *Open* gets the stage as *Incomplete* (never twice). Closed incidents are never changed. The message reads *Stage added to N open incidents.*
- **No**: only incidents created from now on get it. Message: *Stage added. Incidents already raised are unchanged.*
- **Cancel** returns to the form.

The question is asked only when a stage is created. **Editing** a stage changes its name and description everywhere it is used, without changing which incidents have it.

Deleting a stage asks *Delete stage (name)? Stages still in use by an incident cannot be removed.* and is refused while any incident has it: *Cannot delete stage because it is currently used by active security incidents.* A stage can therefore only be deleted before any incident has received it.

Relationships



Related record	Direction	How the link is made	Where it shows
Asset Risks	Risk → Incident, many to many	**Security Incidents** field on the asset risk form	**Known Asset Risk** column (count, clickable)
Third Party Risks	Risk → Incident, many to many	**Security Incidents** field on the third party risk form	**Known Third Party Risk** column (count, clickable)
Business Risks	Risk → Incident, many to many	**Security Incidents** field on the business risk form	**Known Business Risk** column (count, clickable)
Stage definitions	Incident → stage, many to many, through the stage rows	Automatic: all stages on creation; a new stage on open incidents when you answer **Yes**	**Stages** column (count), **Stages** tab
Users	Incident → users	**GRC Contact**, **Incident Contact** (names as text, first pick also as a user link)	Form only

The incident form has no risk field: risks are linked from the risk side. When a user is deleted, their user link on incidents is removed and the name stays in the text.

Automations and notifications

- **Stages on creation**: every stage defined at that moment is added to a new incident as *Incomplete*.
- **Apply to existing**: when a stage is added and you answer **Yes**, it is added to all open incidents.
- **Closing rule**: Open → Closed only with every stage *Completed*; Closure Date set to today (or the date sent through the API); Closed → Open clears it.
- **Dynamic Status and stage counts**: computed on every read.
- **Start-up clean-up**: at application start, stage definitions that exactly match the five stages earlier versions created automatically (*Identification*, *Containment*, *Eradication*, *Recovery*, *Lessons Learned* with their original descriptions) are removed if no incident uses them.
- **Notifications**: none. The notification type *INCIDENT_ALERT* exists but nothing produces it, and no one is notified when an incident is added, changes stage or is closed.
- All changes are recorded in the Activity Log history and in the system audit log.

Permissions

Security Incidents and **Security Incidents › Stages** each have their own access level (No Access, View, Manage, Full Control). See Permissions and access.

Action	Needed access
See the Security Incidents tab	View on Security Incidents
Add, edit, close or import incidents	Manage on Security Incidents
Delete incidents	Full Control on Security Incidents
Export incidents	View on Security Incidents
Open the Stages tab	View on Security Incidents › Stages
Change a stage's Status	Manage on Security Incidents › Stages (the Edit button) **and** Manage on Security Incidents (the server checks the incident)
Add, edit, import stage definitions in Settings	Manage on Security Incidents › Stages on the server; the buttons in the dialog are checked against Security Incidents

Action	Needed access
Delete stage definitions	Full Control on Security Incidents › Stages on the server; the button is checked against Security Incidents
Comment / attach	The group's Comments & Attachments level

The **Settings** button itself is never locked. There is no row-level filter: everyone with View sees all incidents.

How to

Record an incident

1. Open **Operations Center › Security Incidents** and click **Add Item**.
2. Enter the **Title** *Lost laptop with cached credentials*, keep **Type Possible Incident**, add a **Description**.
3. Pick the **GRC Contact** and **Incident Contact**, set **Open Date** (today or earlier) and **Save**.
4. The incident appears with **Stages** 0/5 and Dynamic Status *In Progress*.

Work through the stages and close the incident

1. Open the **Stages** tab and click **Incomplete** to see open stages.
2. Edit the row *Lost laptop with cached credentials / Detection*, set **Status** to **Completed**, **Save**. Repeat for the other four stages.
3. On **Security Incidents**, the incident now reads 5/5 and *Completed*.
4. Edit the incident, set **Status** to **Closed** (Closure Date fills with today) and **Save**. Dynamic Status becomes *Closed*.

Add a new stage to the lifecycle

1. Click **Settings**, then **Add Item**.
2. Enter **Name** *Regulator notification* and **Description** *Notify the supervisory authority within 72 hours*, then **Save**.
3. Answer **Yes** to add it to the incidents that are open now, or **No** to use it only for new incidents.

Show which risks an incident touched

1. Open the asset risk, for example *Unauthorized access*, and pick the incident in its **Security Incidents** field. Save.
2. Back on Security Incidents, **Known Asset Risk** reads 1; click it to open the risk.

CSV import

Import CSV first shows *CSV Import (register name): the import structure is not ready yet.* and then:

Where	What happens	Columns read
Security Incidents tab	Real import (**Validate**, then **Import *n* rows**)	`title` (required), `description`, `type`, `grc_contact`, `status`, `open_date`, `closure_date` (YYYY-MM-DD). Validate checks only that a title is present. Every imported incident is created *Open* with all current stages, whatever `status` says; `grc_contact` is stored as text only; a future `open_date` fails on import.
Settings dialog	Real import of stage definitions	`name` and `description`, both required. Imported stages are not applied to existing incidents.
Stages tab	Demo dialog only; it cannot validate a file. Stage rows cannot be imported.	

Export CSV: `security-incidents.csv` (*Dynamic Status, Stages, Title, Description, Open Date, Closure Date, Type, Status*) and, from Settings, `incident-stages.csv` (*Stage Name, Description*). The Stages tab has no export.

Values are split on every comma, so quoted values that contain commas are not read correctly.

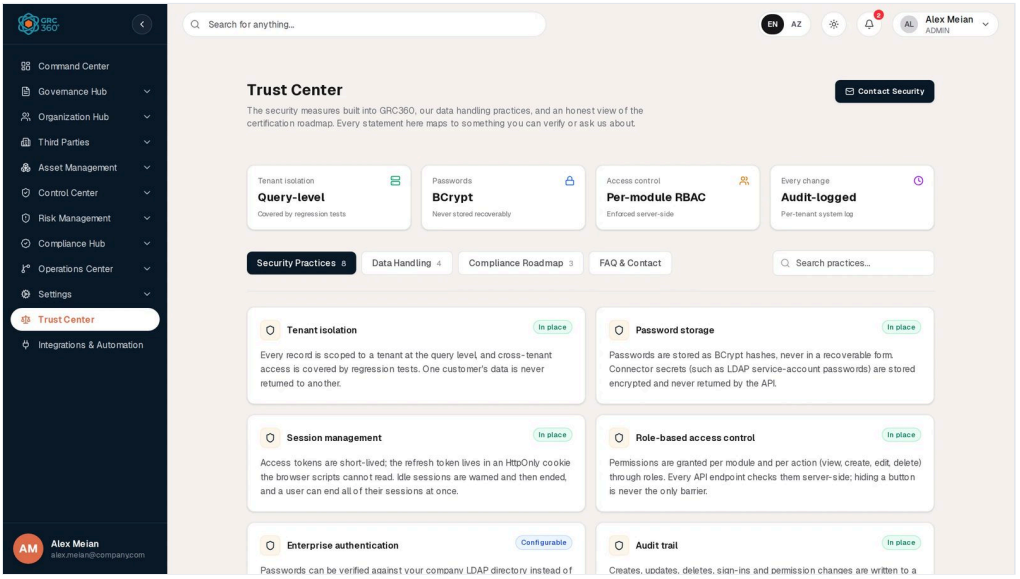
Limitations and known issues

- **Permissions do not line up.** Changing a stage's status needs edit rights on both Security Incidents and its Stages tab; the Settings dialog checks the Security Incidents rights in the browser but the Stages rights on the server; the Settings button is never locked.
- **Import CSV on the Stages tab does not work** (demo dialog), and the incident import ignores the status column.
- **No search on contacts and no contact columns**: GRC Contact and Incident Contact are only visible in the Edit form.
- **A stage in use cannot be deleted**, even when every incident using it is closed.
- **No notifications** for new, changed or closed incidents.
- **A separate, older incident store exists in the backend** (`/api/v1/incidents` , with severity and corrective actions). No screen uses it; its records never appear on this page.

Trust Center

> **Module:** Trust Center (single page, outside the permission catalogue) · **Route:** `/trust-center` · **Permission key:** None

The Trust Center is the page you open to show a customer, auditor or prospect how GRC360 itself is secured. It lists the security measures built into the product, how data is handled, the certification roadmap and a short FAQ, and offers a **Contact Security** button that opens pre-addressed e-mails. Most of the content is fixed text written into the product. One optional section, **Live compliance posture**, shows aggregate figures from your own Compliance Hub, and appears only after an administrator switches publishing on under Settings › About System.



Trust Center

At a glance

A record is	None. The page has no records.
Typical owner	Content is fixed in the product. The administrator decides whether the live posture section is shown.
Links to	Compliance Hub (live posture aggregates), Control Center › Policies & Standards (published policy count), e-mail to `contact@strativu.com`
Linked from	Sidebar (**Trust Center**, opens in a new browser tab); Support page (“Before you write”)
Tabs	**Security Practices**, **Data Handling**, **Compliance Roadmap**, **FAQ & Contact** (in-page tabs, not permission sections)
Automations	The live posture is computed when the page loads. No scheduled job.

The page (list view)

The sidebar entry opens the page in a new browser tab, so the work you had open stays where it was. The page still requires a signed-in session: opening `/trust-center` without one redirects to the sign-in page. It is not a public page for anonymous visitors in this release.

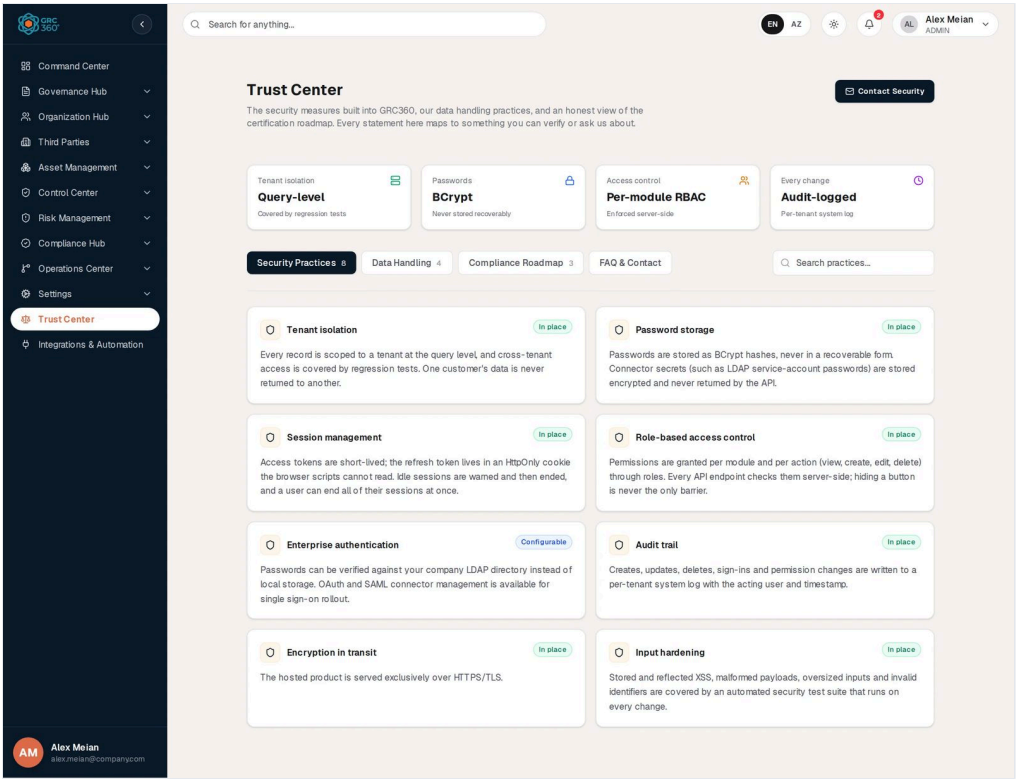
From top to bottom:

1. **Header.** “Trust Center”, a one-line introduction, and the **Contact Security** button.
2. **Four fact cards.**

Card	Value	Note
Tenant isolation	Query-level	Covered by regression tests
Passwords	BCrypt	Never stored recoverably
Access control	Per-module RBAC	Enforced server-side
Every change	Audit-logged	Per-tenant system log

3. **Live compliance posture** (only when publishing is on, see below).
4. **Tabs** with counts: **Security Practices 8**, **Data Handling 4**, **Compliance Roadmap 3**, **FAQ & Contact**. The **Security Practices** tab has a **Search practices…** box that filters the cards by title and description; with no match it shows “Nothing matches that search.”

The full page in the demo, with the **Security Practices** tab open and the live posture section absent because publishing is off:



Trust Center, full page

Security Practices tab

Eight cards, each with a badge.

Practice	Badge	What the card says
Tenant isolation	In place	Every record is scoped to a tenant at query level; cross-tenant access is covered by regression tests.
Password storage	In place	Passwords are BCrypt hashes; connector secrets (such as LDAP service-account passwords) are stored encrypted and never returned by the API.
Session management	In place	Short-lived access tokens, refresh token in an HttpOnly cookie, idle warning and timeout, sign-out of all sessions.
Role-based access control	In place	Permissions per module and action through roles, checked server-side.

Practice	Badge	What the card says
Enterprise authentication	Configurable	LDAP password verification; OAuth and SAML connector management “for single sign-on rollout”.
Audit trail	In place	Creates, updates, deletes, sign-ins and permission changes written to a per-tenant system log.
Encryption in transit	In place	The hosted product is served over HTTPS/TLS.
Input hardening	In place	XSS, malformed payloads, oversized inputs and invalid identifiers covered by an automated security test suite.

Data Handling tab

Four cards: **Deletion model** (records are soft-deleted first and recoverable by an administrator before purge), **Your data stays yours** (every register exports to CSV), **Least data** (only what the GRC process needs, no employee monitoring) and **Access on request** (infrastructure, hosting and subprocessor details on request).

Compliance Roadmap tab

An amber note states that no third-party certification is held today. Three entries follow:

Item	State
ISO/IEC 27001	Planned
SOC 2	Planned
GDPR alignment	In progress

FAQ & Contact tab

Five questions with answers (certificates held today, data location, security reviews and penetration tests, corporate directory sign-in, reporting a security issue), followed by a “Something we haven’t answered?” card with a second **Contact Security** button.

Contact Security dialog

The dialog “Contact the security team” offers four links. Each opens a new message in your own e-mail program, addressed to `contact@strativu.com`, with a fixed subject. Nothing is sent by GRC360 itself.

Link	Subject
Request security documentation	Security documentation request
Ask for the subprocessor list	Subprocessor list request
Report a security issue	Security disclosure
General security question	Security question

Live compliance posture

This section appears only when **Public Trust Center** publishing is switched on for your organisation (Settings › About System). When it is off, or the server cannot be reached, the section is simply absent; no message is shown. In the demo data it is off.

Element	Rule
Badge	**Live**
One bar per package	Every compliance package (not deleted) that has assessed requirement items, with “compliant/total compliant (N %)”. Only items judged Compliant count; Partially Compliant items do not count here (unlike the Command Center, which counts them as half).

Element	Rule
Frameworks tracked	Number of packages listed. With none, the left side reads “No frameworks are being tracked yet.”
Published policies	Number of policies in Policies & Standards with status Published.

Only these aggregates are published; no record names other than package names appear.

Creating a record

None.

Viewing and editing a record

None. The fixed content cannot be edited in the product. The only setting is the publishing switch on About System.

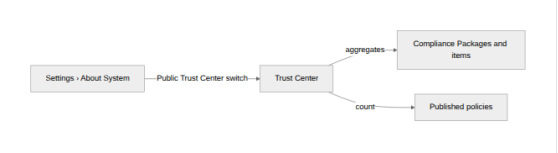
Statuses

Value	Set by	Meaning
In place	Fixed text	The practice is implemented in the product.
Configurable	Fixed text	The capability exists but depends on configuration.
Planned / In progress	Fixed text	Certification roadmap state.
Live	System	The live posture section is published for this organisation.

Tabs

The four in-page tabs are described above. They carry no separate permissions.

Relationships



Related record	Direction	How the link is made	Where it shows
Compliance package and assessed items	Read	Item counts per package and judgement	Live compliance posture bars
Policy	Read	Count of policies with status Published	Published policies
Publishing setting	Read	Switch on About System	Whether the live section appears

Automations and notifications

None. The live posture is computed when the page is opened.

Permissions

Action	Needed access
See the page	Any signed-in user. The page is outside the permission catalogue, so it is always in the sidebar and never shows Access Denied.
Turn the live posture on or off	Admin group (Settings is Admin-only), on Settings › About System.
Create / Edit / Delete	Not applicable.
Comment / Assign	Not applicable.

How to

Send a prospect the security overview

1. Click **Trust Center** in the sidebar. It opens in a new tab.
2. Walk through **Security Practices**, **Data Handling** and **Compliance Roadmap**.
3. If the prospect asks for documents, click **Contact Security** and choose **Request security documentation**; your e-mail program opens with the subject filled in.

Publish your live compliance posture

1. As an administrator, open **Settings › About System**.
2. In the **Public Trust Center** card, switch the toggle on.
3. Reload the Trust Center. The **Live compliance posture** section now shows each package with its compliant-item count and the number of published policies.

Report a security issue

1. Open **Trust Center** and click **Contact Security**.
2. Choose **Report a security issue**. A new e-mail with the subject “Security disclosure” opens in your mail program.

CSV import

None.

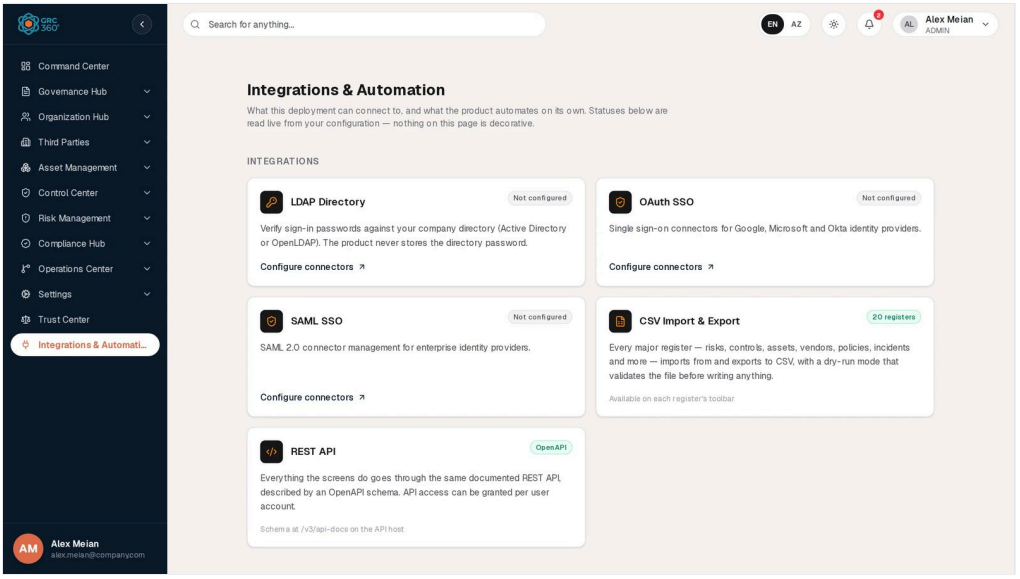
Limitations and known issues

- The page requires sign-in, although its own texts describe it as public; outside visitors without an account cannot open it.
- Several fixed statements are broader than what the product does in this release: the system log does not record sign-ins or most register changes (see System Log); OAuth and SAML connectors can be stored but are not used to sign anyone in (see Authentication); not every register exports to CSV; Clear Data and user deletion remove rows permanently rather than soft-deleting them.
- The live posture counts only Compliant items, while the Command Center counts Partially Compliant items as half, so the two pages can show different percentages for the same package.
- The page content is English only and cannot be edited by the customer.

Integrations & Automation

> **Module:** Integrations & Automation › Integrations · **Route:** `/integrations-automation` · **Permission key:** `integrations_automation.integrations`

This page states what GRC360 can connect to, what it automates on its own, and what is only planned. It reads the state of the sign-in connectors and the mail relay live from the server, and it is the place where outbound **webhooks** are managed. It holds no register records. Administrators use it to check the integration state at a glance; configuration of the sign-in connectors themselves happens in Settings › Authentication.



Integrations & Automation

At a glance

A record is	A webhook endpoint (the only thing created on this page).
Typical owner	Administrator
Links to	Settings › Authentication (connector cards), the deployment's SMTP relay, your own HTTP endpoints (webhooks)
Linked from	Sidebar
Tabs	None. The page is divided into sections: **Integrations**, **Built-in automation**, **E-mail delivery**, **Webhooks**, **Planned**.
Automations	Webhook deliveries are sent automatically for every event written to the audit trails.

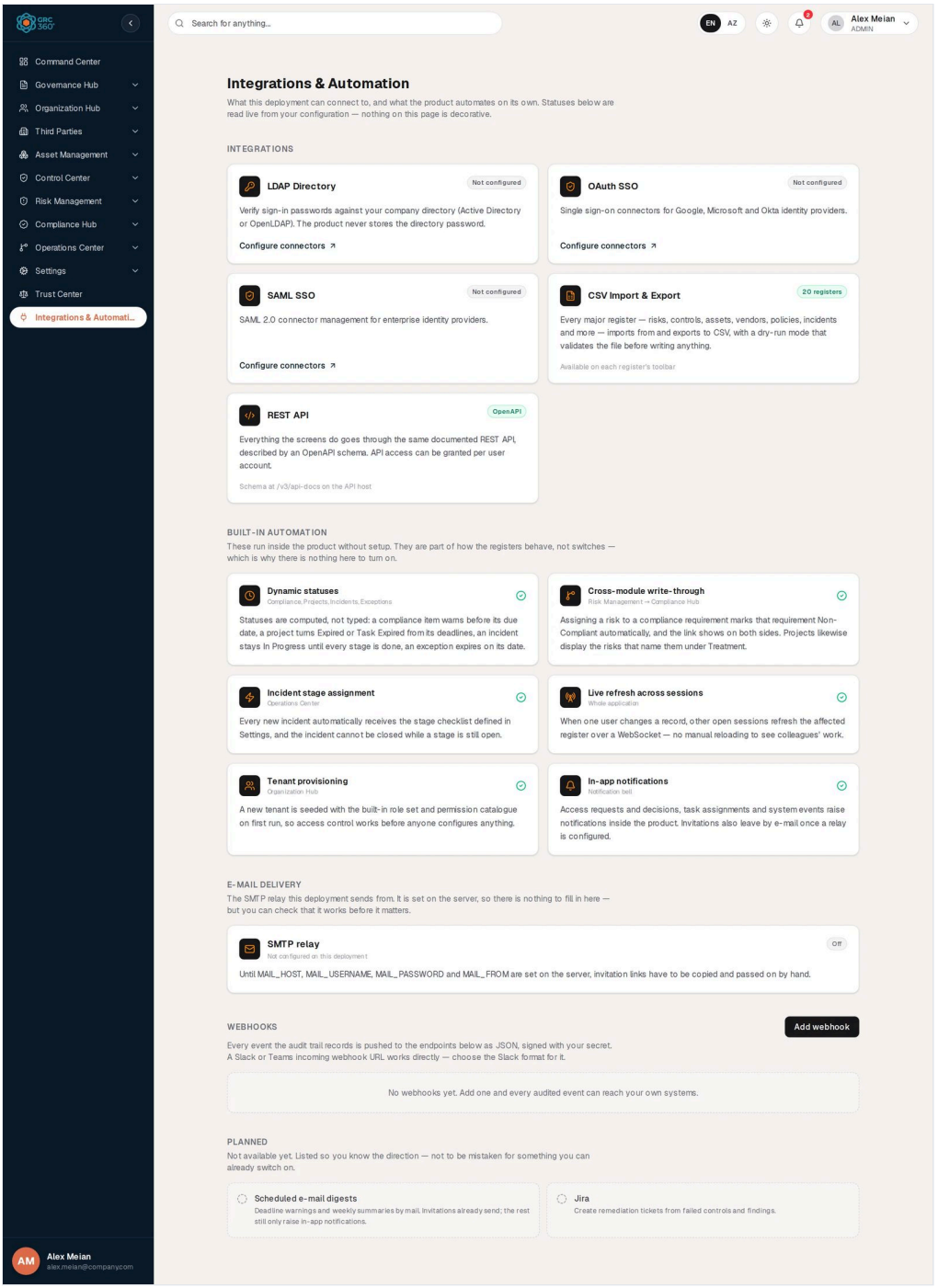
Built versus planned: summary

Item	State in this release	What actually works
LDAP Directory	Built and working	Passwords of existing GRC360 accounts can be verified against an LDAP or Active Directory server. See Authentication and SSO.
OAuth SSO	Connector management only	OAuth connectors can be stored and chosen as the main method, but no sign-in uses them. The login page has no SSO button.
SAML SSO	Connector management only	SAML connectors can be stored and chosen as the main method, but no sign-in uses them.

Item	State in this release	What actually works
CSV Import & Export	Partly built	Export works on registers that have an **Export CSV** button. Import works only on the registers that have their own import (Users, Security Incidents and Stages, Projects with Tasks and Expenses, External Audit Findings, Obligations, Compliance Analysis, Compliance Packages, Compliance Exceptions). Elsewhere the import dialog fails. See CSV import and export.
REST API	Built	Every screen uses the same REST API; the OpenAPI schema is at `/v3/api-docs` on the API host (Swagger UI at `/swagger-ui.html`). The **REST APIs** switch on a user is stored but not enforced.
In-app notifications	Built	The bell and the Notifications page. Produced for access requests and decisions, continuity plan task awareness and service agreement end dates. See E-mail, webhooks and notifications.
Dynamic statuses	Built	Computed when records are read; date-based states appear without any scheduled job.
Live refresh	Built	Open pages reload changed registers within about 10 to 12 seconds (the browser polls the server's change feed).
Tenant provisioning	Built	Built-in groups (Admin, Read Only, Third Party) and the permission catalogue are created for a tenant at start-up.
E-mail (SMTP)	Built, needs server configuration	Sends invitation e-mails and the test message. Nothing else is e-mailed.
Webhooks	Built	Signed JSON POSTs for events written to the audit trails. Managing them needs the Admin role (see Permissions).
Scheduled e-mail digests	Planned	Not available.
Jira	Planned	Not available.

The page (list view)

The page is not a grid. Its sections, from top to bottom (as an administrator sees them in the demo):



Integrations & Automation, full page

Integrations

Cards with a title, a status badge, a description and a link or note.

Card	Shown to	Badge	Link
LDAP Directory	Administrators only	Live, from the LDAP connector list	**Configure connectors** → Settings › Authentication
OAuth SSO	Administrators only	Live, from the OAuth connector list	**Configure connectors**
SAML SSO	Administrators only	Live, from the SAML connector list	**Configure connectors**
CSV Import & Export	Everyone with page access	Fixed text **20 registers**	Note “Available on each register’s toolbar”

Card	Shown to	Badge	Link
REST API	Everyone with page access	Fixed text **OpenAPI**	Note “Schema at /v3/api-docs on the API host”

Connector badge rules:

Badge	Rule
N enabled (green)	At least one connector has status Enabled (LDAP) or Active (OAuth, SAML).
N configured, none enabled (amber)	Connectors exist, none enabled.
Not configured (grey)	No connectors. This is the state in the demo data.
Checking… / **Status unavailable**	Still loading, or a list could not be read.

“Administrators only” here means users who can open Settings › Authentication. For everyone else the three connector cards and the E-mail delivery section are neither shown nor requested.

Built-in automation

Six cards, each with a green check. They describe behaviour, not switches; nothing can be turned on or off here.

Card	Where	What the card says, and what is true
Dynamic statuses	Compliance, Projects, Incidents, Exceptions	Statuses are computed from dates and progress. True: they are computed on read. Note that automatic *status changes* stored on exception records by scheduled jobs do not happen in this release (see Automations).
Cross-module write-through	Risk Management → Compliance Hub	Assigning a risk to a compliance requirement marks that requirement Non-Compliant; projects show the risks that name them under Treatment.
Incident stage assignment	Operations Center	New incidents receive the stage checklist; an incident cannot be closed while a stage is open.
Live refresh across sessions	Whole application	The card says changes arrive “over a WebSocket”. The application actually polls the server’s change feed about every 10 to 12 seconds; the effect for the user is the same.
Tenant provisioning	Organization Hub	The built-in groups and permission catalogue are seeded for a tenant.
In-app notifications	Notification bell	The card mentions “system events”; in this release no system event raises a notification. See the notification catalogue in E-mail, webhooks and notifications.

E-mail delivery

Shown to administrators only. A card **SMTP relay** with a badge:

Badge	Meaning	Line under the title
Configured	The server has an SMTP host set	“{host} — sending as {from address}”
Off	No SMTP host on the server	“Not configured on this deployment”

Under the title the card explains what the state means. When configured: “Invitations are e-mailed to the person invited. The link is still shown to the administrator, so an invite is never lost to a failed send.” When off: “Until MAIL_HOST, MAIL_USERNAME, MAIL_PASSWORD and MAIL_FROM are set on the server, invitation links have to be copied and passed on by hand.” The section heading **E-mail delivery** is followed by “The SMTP relay this deployment sends from. It is set on the server, so there is nothing to fill in here — but you can check that it works before it matters.”

The relay is configured on the server through environment variables (`MAIL_HOST` , `MAIL_PORT` , `MAIL_USERNAME` , `MAIL_PASSWORD` , `MAIL_FROM` , `MAIL_FROM_NAME` , `MAIL_STARTTLS` , `MAIL_SSL`); there is nothing to fill in on this page. When the relay is configured, an e-mail field (placeholder `your.name@company.com`) and **Send test message** appear. The result shows either “Sent to {address}. Check the inbox, and the spam folder.” or the relay’s error text. In the demo the relay is **Off**. Step-by-step setup is in E-mail, webhooks and notifications.

Webhooks

A list of outbound HTTP endpoints, an **Add webhook** button (it toggles to **Close** while the form is open) and the explanation that every audited event is pushed as JSON, signed with your secret, and that a Slack or Teams incoming webhook URL works with the Slack format. With no webhooks the list reads “No webhooks yet. Add one and every audited event can reach your own systems.” The demo has none.

Each webhook row shows its name, **Enabled** or **Disabled**, a **Slack format** badge when that format is chosen, the URL, and a line such as “All events · Never delivered” or “Events: INCIDENT_,RISK_ · Last delivery: HTTP 200 · 2 consecutive failure(s)”. Row buttons: **Send test**, **Disable**/**Enable**, **Delete**.

Planned

The heading **Planned** is followed by “Not available yet. Listed so you know the direction — not to be mistaken for something you can already switch on.” and two dashed cards with no buttons:

Item	Note on the card
Scheduled e-mail digests	Deadline warnings and weekly summaries by mail. Invitations already send; the rest still only raise in-app notifications.
Jira	Create remediation tickets from failed controls and findings.

Creating a record

Click **Add webhook**. The form opens inline above the list (not in a dialog).

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes	Max 255 characters. Placeholder “e.g. Incident alerts to Slack”.	Risk events to SIEM
URL	Text	Yes	Must start with `http://` or `https://` (server message “URL must start with http:// or https://”); max 1024 characters.	https://siem.example.com/hooks/grc
Secret (optional)	Password	No	Stored encrypted, never shown again. When set, each delivery is signed.	(a random string)
Event filter (optional)	Text	No	Comma-separated event-name prefixes, case-insensitive; blank means all events. Placeholder `INCIDENT_,RISK_` . Max 512 characters.	RISK_,COMPLIANCE_EXCEPTION_
Payload format	Dropdown	No	**Generic JSON** (default) or **Slack / Teams message**.	Generic JSON

Click **Save webhook**. If Name or URL is empty the page shows “Name and URL are required.” A new webhook is enabled immediately, and the page shows “Webhook created. Use Send test to verify the receiver.”

A webhook cannot be edited after creation except for switching it on and off. To change its URL, filter or secret, delete it and add it again.

Viewing and editing a record

There is no view dialog; everything is on the row.

- **Send test** posts a test event named `PING` with the message “Test delivery from GRC360 — your endpoint is wired up.” and waits for the answer. The page shows “Delivered: HTTP 200.” for any 2xx answer, otherwise “Delivery failed: {status or error}.”
- **Disable** / **Enable** switches deliveries off and on; the stored secret is kept.
- **Delete** asks “Delete the webhook **{name}**?” and shows “Webhook deleted.” The webhook is removed from the list (it is soft-deleted on the server).

What a delivery looks like

Part	Value
Method	POST, `Content-Type: application/json`
Header `X-GRC360-Event`	The event name, for example `COMPLIANCE_EXCEPTION_CREATED`
Header `X-GRC360-Signature`	Only when a secret is stored: `sha256=` followed by the hex HMAC-SHA256 of the raw body, keyed with the secret
Body, Generic JSON	`{"event":"…","message":"…","timestamp":"…"}`
Body, Slack / Teams	`{"text":"*EVENT* — message"}`
Timeout	5 seconds; redirects are not followed
Retries	None. A failed delivery is not retried; the failure count goes up by one, and resets to 0 on the next success.

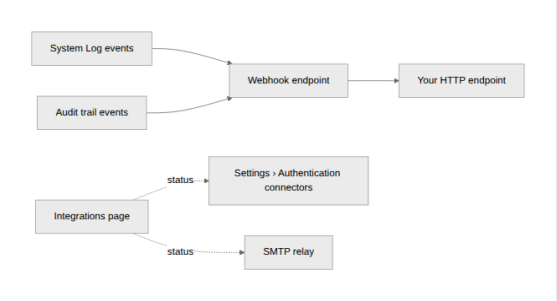
Statuses

Value	Set by	Meaning
Enabled	User	Deliveries are sent.
Disabled	User	No deliveries are sent; the webhook stays in the list.
Last delivery: HTTP nnn / error text	System	Outcome of the most recent delivery or test.
N consecutive failure(s)	System	Number of failed deliveries since the last success. The webhook is not switched off automatically.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
System Log entry	Outbound	Every action written to the System Log is offered to the webhooks whose filter matches	Delivery to your endpoint
Audit trail event	Outbound	Every event written to the internal audit trail (for example risk register and objective audit events) is offered the same way	Delivery to your endpoint
LDAP / OAuth / SAML connectors	Read	Count and status	Connector card badges
SMTP relay	Read	Server configuration	E-mail delivery card

Automations and notifications

- **Webhook fan-out.** Each event is delivered in the background to every enabled webhook whose filter matches, so a slow receiver does not slow down the save that produced the event. Events that can reach a webhook include, for example, `COMPLIANCE_PACKAGE_CREATED`, `OBLIGATION_UPDATED`, `AUDIT_FINDING_STATUS_CHANGED`, `COMPLIANCE_EXCEPTION_EXPIRED`, `AUTH_CONNECTOR_CREATED`, `AUTH_SETTINGS_UPDATED`, `SYSTEM_CACHE_CLEARED`, `RISK_CREATED`, `RISK_DELETED`, `RISK_SCORE_RECALCULATED`, `RISK_EXCEPTION_APPROVED`, `RISK_SETTINGS_UPDATED` and `OBJECTIVE_AUDIT_CREATED`. Sign-ins and most register changes outside Compliance Hub, Risk Management and objective audits produce no event.
- **No other scheduled automation runs from this page.** For the full list of scheduled jobs and which ones are active, see E-mail, webhooks and notifications.

Permissions

Action	Needed access
See the page and its sidebar entry	**View** on Integrations & Automation › Integrations
See the connector cards and E-mail delivery	Access to Settings › Authentication, which only the Admin group holds
List, add, test, enable/disable, delete webhooks	The page's catalogue right (View to list; Manage to add, test and toggle; Full Control to delete) **and**, on the server, the system role ADMIN. In practice only administrators can manage webhooks.
Send a test e-mail	Admin
Comment / Assign	Not applicable (no comment thread).

A non-administrator with access to this page sees the Webhooks section, but the server refuses the list; the page shows "Webhook list could not be loaded." and the permission dialog may open.

How to

Send risk events to your SIEM

1. Click **Add webhook**.

2. **Name**: “Risk events to SIEM”. **URL**: your collector’s HTTPS address. **Secret**: a random string your collector also knows. **Event filter**: `RISK_`. **Payload format**: **Generic JSON**.
3. Click **Save webhook**, then **Send test** on the new row. Expect “Delivered: HTTP 200.”
4. On the receiving side, verify `X-GRC360-Signature` by computing HMAC-SHA256 of the raw body with the same secret.

Post compliance exception events to a Slack channel

1. In Slack, create an incoming webhook for the channel and copy its URL.
2. In GRC360 click **Add webhook**, paste the URL, set **Event filter** to `COMPLIANCE_EXCEPTION_` and choose **Slack / Teams message**.
3. Click **Save webhook** and **Send test**; a “*PING* — Test delivery from GRC360…” message appears in the channel.

Check that invitation e-mails can be sent

1. Open the **E-mail delivery** section. If the badge reads **Off**, ask the person who runs the server to set the `MAIL_*` variables and restart.
2. When it reads **Configured**, type your own address and click **Send test message**.
3. If the result is red, the text is the relay’s own error (for example a rejected sender address).

Pause a webhook during receiver maintenance

1. On the webhook row, click **Disable**. The badge turns to **Disabled** and no events are sent.
2. Events raised while disabled are not queued; they are not delivered later.
3. Click **Enable** when the receiver is back.

CSV import

None. Webhooks cannot be imported or exported.

Limitations and known issues

- OAuth SSO and SAML SSO are listed as integrations, but no login flow uses the stored connectors and the login page has no SSO option.
- The **CSV Import & Export** card’s “20 registers” and “dry-run” claims overstate the current state; most registers’ import dialog does not work in this release.
- The **REST APIs** switch on a user (“API access can be granted per user account”) is stored but not enforced by the server.
- **Live refresh** is polling, not WebSocket as the card says.
- The **In-app notifications** card mentions system events; none raise notifications.
- Webhooks: no edit form, no retry, no delivery history beyond the last status, and in practice admin-only even though the page itself can be granted to other groups.
- The SMTP relay sends only invitation e-mails and the test message; invitations themselves have no screen in the product (see Users, groups and permissions).

Settings

Settings holds the system's own configuration: how people sign in, which sessions are open, the system's version and health, the updates register, the system log and the button that clears the organisation's data. It is not a register a team works in.

Settings is reserved to the Admin group. Only the exact built-in **Admin** group (or its older name **Administrator**), the system role ADMIN or a configured super-admin account may hold Settings. It cannot be given to any other group, granted to an individual or requested through Request Access; the Request Access dialog says "Only the Admin group can access Settings. It cannot be granted to other groups or requested." A group whose name merely contains "admin" (for example "IT Admins") does not qualify. For everyone else the **Settings** entry does not appear in the sidebar.

Pages

Page	Route	Permission key	What it is for
Authentication	`/settings/authentication`	`settings.authentication`	Main sign-in method, active sessions of every user, LDAP / OAuth / SAML connectors
About System	`/settings/about-system`	`settings.about_system`	Product version and company details; the Public Trust Center switch
System Health	`/settings/system-health`	`settings.system_health`	Running version, diagnostics options, log and diagnostics downloads, cache, live health checks
Updates	`/settings/updates`	`settings.updates`	Updates register and maintenance-mode notice
System Log	`/settings/system-log`	`settings.system_log`	Read-only audit trail of administrative and Compliance Hub actions, with CSV export
Clear Data	`/settings/clear-data`	`settings.clear_data`	Back up and then permanently delete chosen groups of this organisation's data

The route `/settings` on its own shows a placeholder card headed "Settings" with the text "Mock page (coming soon)." Use the sub-pages.

Permission actions in the catalogue

Page	Actions defined
Authentication	read, create, edit, delete, import, export
About System	read
System Health	read
Updates	read
System Log	read, export
Clear Data	read (preview), execute (run the reset and download backups)

Because the Admin group holds all of them, the split matters only for audit and for the locked-button behaviour on Clear Data. Settings pages have no comment threads.

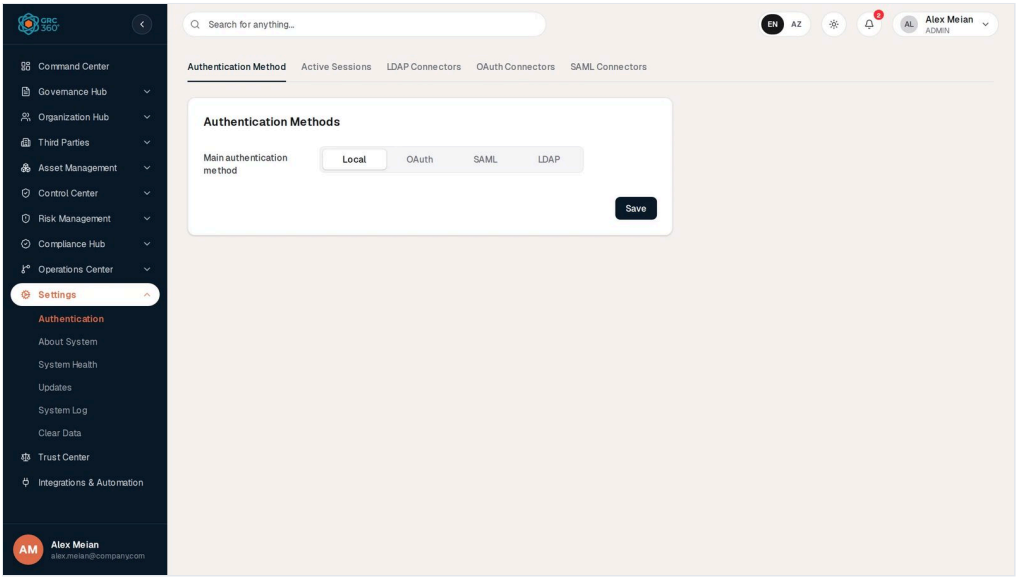
Related administration guides

- Authentication and SSO
- Sessions and security
- System maintenance

Authentication

> **Module:** Settings › Authentication · **Route:** `/settings/authentication` · **Permission key:** `settings.authentication`

The Authentication page is where an administrator chooses the organisation's main sign-in method, sees and ends every user's open sessions, and maintains the directory and single sign-on connectors. It has five tabs: **Authentication Method**, **Active Sessions**, **LDAP Connectors**, **OAuth Connectors** and **SAML Connectors**. Only the Admin group can open it.



Authentication, Authentication Method tab

At a glance

A record is	A connector (LDAP, OAuth or SAML), or one user session on the Active Sessions tab. The method setting is a single per-organisation setting.
Typical owner	Administrator
Links to	User accounts (sessions), your LDAP / identity provider servers
Linked from	Integrations & Automation (connector cards, **Configure connectors**)
Tabs	Authentication Method, Active Sessions, LDAP Connectors, OAuth Connectors, SAML Connectors. The tabs are in-page tabs with no permission keys of their own.
Automations	Session list refreshes every 30 seconds; expired session rows are purged after 30 days. No scheduled job.

What actually signs people in, in this release

Method	Effect on sign-in
Local (email and password)	Always available, whatever method is selected.
LDAP	Works. When the typed password does not match the local one, the server asks the LDAP directory. The person must already have an active GRC360 account with the same e-mail.
OAuth	No effect. Connectors are stored, but no sign-in flow uses them and the login page has no SSO button.
SAML	No effect. Connectors are stored, but there is no SAML endpoint in the server.

Step-by-step configuration of each method is in Authentication and SSO.

The register (list view)

Each tab is described in Tabs. The connector tabs use the shared grid; its toolbar, **… Views**, search and paging are described in Working with registers. Each tab loads its own data when it is opened.

Creating a record

Connectors are added from their tab with **Add Item**; see LDAP Connectors, OAuth Connectors and SAML Connectors. Sessions are created by signing in, not on this page.

Viewing and editing a record

- **LDAP connectors** have **Test connection**, **Edit** and **Delete** buttons on each row.
- **OAuth and SAML connectors** have only the shared view (eye) button. They cannot be edited, tested or deleted from the screen in this release.
- **Sessions** can be expanded with the arrow button to show details, and ended with **Sign out**.

Statuses

Value	Set by	Meaning
Disabled / Enabled (LDAP)	User	Only **Enabled** LDAP connectors are asked at sign-in and can be chosen as the main connector. New LDAP connectors default to **Disabled**.
Active / Disabled (OAuth, SAML)	User	Only **Active** connectors can be chosen as the main connector. New ones default to **Active**.
In Use	System	Intended to show the connector chosen as main. It is never set in this release and always reads “false”.
Active now / Idle for …	System	Session status: **Active now** when the session was used within the last 15 minutes (one access-token lifetime), otherwise amber “Idle for {duration}”.
End reasons	System	For ended sessions; see Active Sessions.

Tabs

Authentication Method

A card **Authentication Methods** with:

Field	Type	Required	Rules and allowed values	Example
Main authentication method	Segmented buttons	Yes	**Local** (default), **OAuth**, **SAML**, **LDAP**	Local
User authentication connector	Dropdown	Yes, when the method is not Local (marked *)	Lists the connectors of the chosen type. A connector that is not Enabled/Active is shown with ” (disabled)“. While empty the field is outlined red with”The field is required”.	Corporate AD

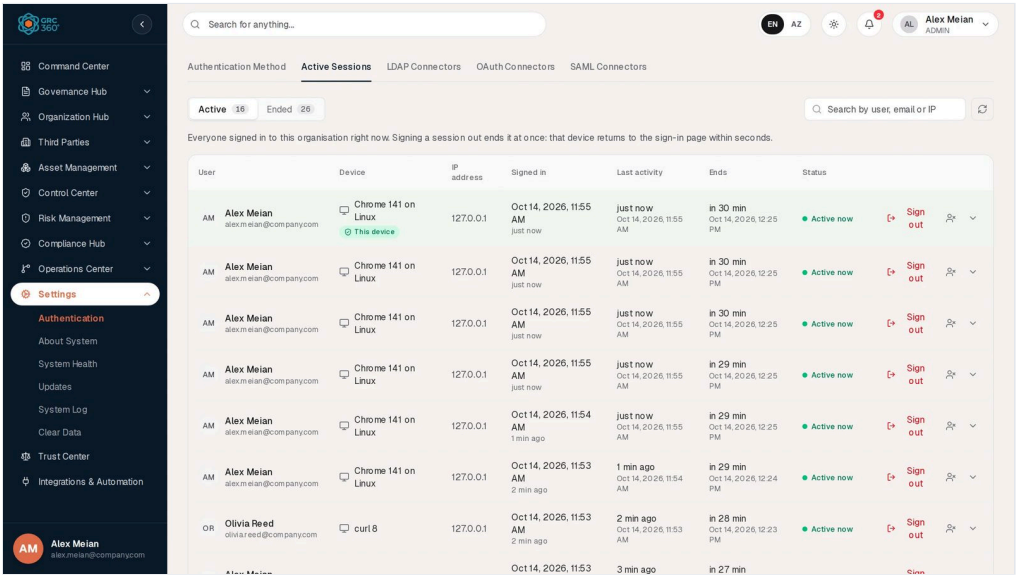
Click **Save**. Success shows “Authentication settings saved successfully.” The server refuses:

Situation	Server message
OAuth, SAML or LDAP without a connector	“OAuth connector ID is required when method is OAUTH” (and the SAML / LDAP equivalents)
Connector of the wrong organisation or deleted	“OAuth connector not found: {id}” (and equivalents)
Chosen connector not Enabled (LDAP) or Active (OAuth, SAML)	“Selected LDAP connector is disabled and cannot be activated” (and equivalents)

Saving writes **AUTH_SETTINGS_UPDATED** to the System Log. In the demo data the method is **Local**.

Effect of the choice: selecting **LDAP** with a connector makes that connector the first one asked at sign-in; other Enabled LDAP connectors whose **Mail Domain** matches the user’s e-mail domain are still asked after it. Local passwords keep working in every mode, so a local administrator can always sign in when the directory is down. Choosing **OAuth** or **SAML** changes nothing at sign-in.

Active Sessions



Active Sessions

Every session in the organisation, for all users. A person’s own devices are on their Account page.

Controls at the top: a switch **Active** / **Ended**, each with its count; a search box “Search by user, email or IP” (matches the owner’s e-mail, name or IP address, case-insensitive); and a refresh button. The explanatory line reads “Everyone signed in to this organisation right now. Signing a session out ends it at once: that device returns to the sign-in page within seconds.” on Active, and “Sessions that ended in the last 30 days — signed out, timed out, or replaced — and why.” on Ended.

Column	What it shows	Source
User	Initials, full name and e-mail	Account
Device	Browser and operating system read from the browser’s user agent (for example “Chrome 141 on Linux”; “curl 8” for an API client), with a **This device** badge on your own current session and **Remembered** for sessions opened with “Keep me signed in”	Computed
IP address	Address the session last came from	Recorded
Signed in	Date and time of sign-in, and “… ago”	Recorded
Last activity	Time since the last token refresh, and the exact time	Recorded

Column	What it shows	Source
Ends (Active) / Ended (Ended)	When the session will end at the latest (the earlier of the idle limit and the absolute limit), or when it ended. Hovering **Ends** says which limit applies.	Computed
Status (Active) / Reason (Ended)	**Active now** or **Idle for …**; for ended sessions the reason	Computed

Row buttons (Active list only): **Sign out** ends this one session; the person icon ends all of that user's sessions; the arrow shows details (**Browser**, **Operating system**, **IP address**, **Session type** "Remembered (Keep me signed in)" or "Standard — ends when the browser closes", **Ends after inactivity**, **Ends at the latest**, **User agent**, **Session ID**).

Confirmation dialogs:

Action	Dialog text	Success
Sign out on another user's session	"Sign out **{name}** on **{device}**? It stops working right away." Button **Sign out**.	"Session signed out."
Sign out on your own current session	"This is the session you are using. You will be signed out now."	You are signed out.
Person icon	"Sign out **{name}** from every device? They will have to sign in again." Button **Sign out all**.	"User signed out of every device."

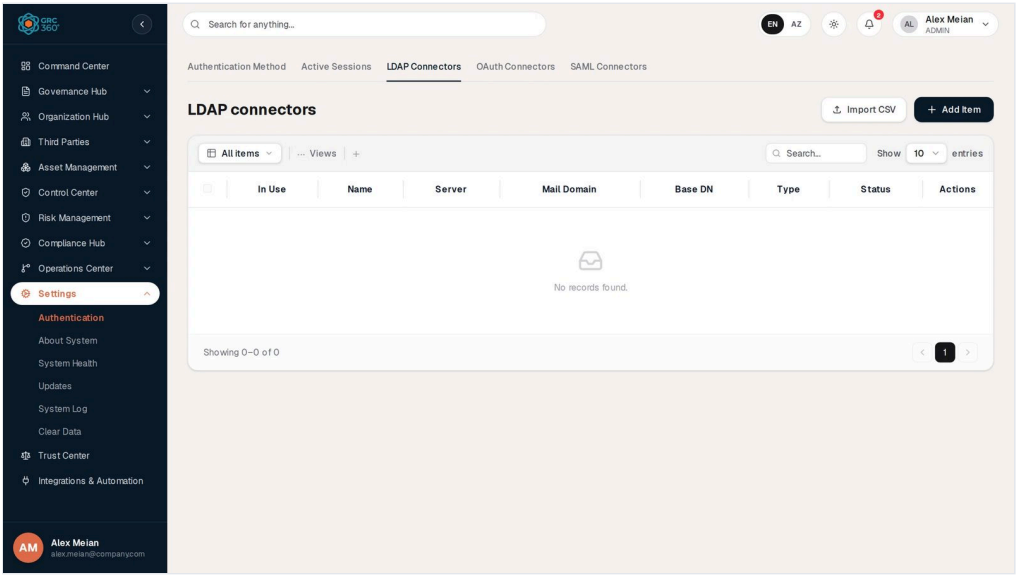
The signed-out device gets an error on its next request and is sent to the sign-in page within about 10 seconds. Paging shows 20 sessions per page ("Showing 1–6 of 6"). The list refreshes itself every 30 seconds while visible.

End reasons shown on the Ended list:

Reason text	Code	Cause
Signed out	LOGOUT	The user signed out.
Signed out everywhere	LOGOUT_ALL	The user chose Sign out everywhere.
Signed out remotely	ADMIN_REVOKED	Ended from this tab or from the Account page of the owner.
Ended for security: its sign-in token was reused	REUSE_DETECTED	An old refresh token was presented again; the whole session chain is ended.
Timed out after inactivity	IDLE_TIMEOUT	No activity within the idle limit.
Reached the maximum session length	ABSOLUTE_TIMEOUT	Absolute limit reached.
Replaced by a newer sign-in	SESSION_LIMIT	The user opened more than 10 sessions; the oldest was ended.
Account deactivated	ACCOUNT_INACTIVE	The user's account is no longer Active.

Session limits are described in Sessions and security.

LDAP Connectors



LDAP Connectors

Column	What it shows	Source
In Use	Always “false” in this release	System
Name	Connector name	Entered
Server	**LDAP Server Hostname**	Entered
Mail Domain	E-mail domain served by this directory	Entered
Base DN	**LDAP Server Base DN**	Entered
Type	Always “LDAP” (see known issues)	System
Status	Disabled / Enabled badge	Entered

Row buttons: **Test connection**, **Edit**, **Delete**. The demo has no LDAP connectors (“No records found.”).

Add Item opens the dialog “Add Item (LDAP Connectors)” (on edit “Edit LDAP Connector”) with two tabs, **General** and **Connector Settings**. No field is marked with an asterisk; the server requires Name and LDAP Server Hostname.

General tab:

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes (server: “Connector name is required”)		Corporate AD
Description	Text	No		Head-office Active Directory
Status	Dropdown	No	**Disabled** (default), **Enabled**	Disabled
LDAP Server Hostname	Text	Yes (server: “LDAP server hostname is required”)	A host name, or a full `ldap://host:port` / `ldaps://host:port` URL. Without a scheme, `ldaps://` is used when Port is 636, otherwise `ldap://`.	dc01.company.local

Field	Type	Required	Rules and allowed values	Example
Mail Domain	Text	No	Domain part of users' e-mails; an `@` is ignored. Used to pick this connector for matching e-mails.	company.com
Port	Text	No	Number; default 389. Non-numeric input is sent as 389.	636
LDAP Username	Text (yellow)	No	DN of the service account used to search the directory. Blank means anonymous search.	CN=svc-grc,OU=Service,DC=company,DC=local
LDAP Password	Password (yellow)	No	Stored encrypted, never shown again. On edit the placeholder reads "Leave blank to keep the stored password".	
LDAP Server Base DN	Text	No	Root of the directory tree.	DC=company,DC=local

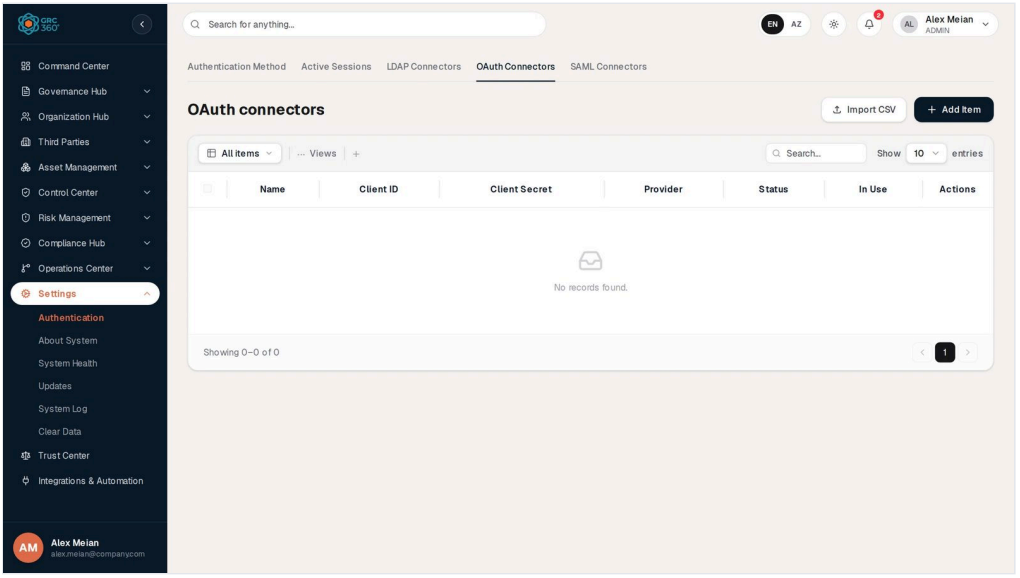
Connector Settings tab (introduced by "These decide how a person typing their email at the login screen is found in your directory."):

Field	Type	Required	Rules and allowed values	Example
User Search Filter	Text	No	`{0}` is replaced by the e-mail typed at login. Default `(mail={0})`. Active Directory often needs `(userPrincipalName={0})`. A blank value keeps the default.	(userPrincipalName={0})
User Search Base	Text	No	Where the search starts; blank means the Base DN.	OU=Staff,DC=company,DC=local
Type	Dropdown	No	**Authenticator** (default), **Group**. Not stored by the server.	Authenticator

Save shows "LDAP connector created. Use Test connection before enabling it." or "LDAP connector updated." **Test connection** connects with the service account, then counts entries matching the filter. Success: "Connected to {url}. {n} user(s) matched under {search base or"the server root"}." Failure messages name the cause, for example "Could not reach the server. Check the hostname, the port, and that the network allows it.", "The server rejected the LDAP username or password.", "The server accepted the login but the base DN does not exist on it." or "No server hostname is set on this connector." Each create, update, delete and test is written to the System Log (**AUTH_CONNECTOR_CREATED**, **_UPDATED**, _DELETED**, _TESTED**).

Delete asks "Delete the LDAP connector **{name}**?" and confirms with "Connector deleted." The connector is soft-deleted.

OAuth Connectors



OAuth Connectors

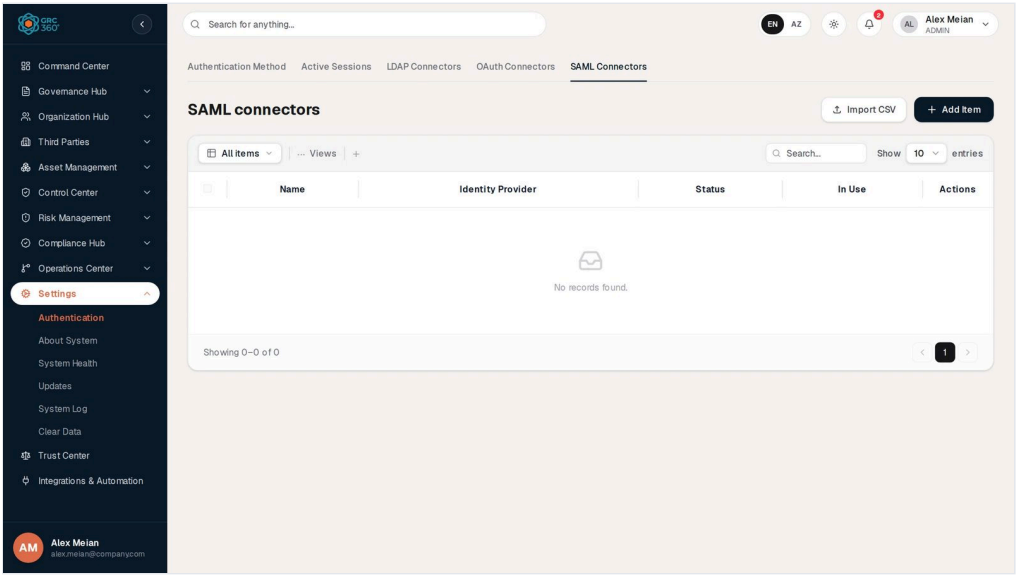
Columns: **Name**, **Client ID**, **Client Secret** (always empty; the server returns only a masked value under another name), **Provider** (stored in capitals, for example GOOGLE), **Status**, **In Use** (always “false”). The demo has none.

Add Item opens “Add Item (OAuth Connectors)” with a single **General** tab. A blue box **Redirect URLs** lists `{this site}/login` and `{this site}/portal/policy/login` to register at the provider.

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes (server: “Connector name is required”)		Google Workspace
Client ID	Text	Yes (server: “Client ID is required”)		1234.apps.googleusercontent.com
Client Secret	Text (not masked while typing)	No	Stored encrypted.	
Provider	Dropdown	Yes (server: “Provider is required”)	“Choose one…”, **Google**, **Microsoft**, **Okta**	Google
Status	Dropdown	No	**Active** (default), **Disabled**	Active

Save shows “OAuth connector created successfully.” The connector cannot be edited or deleted afterwards from the screen, and it is not used to sign anyone in.

SAML Connectors



SAML Connectors

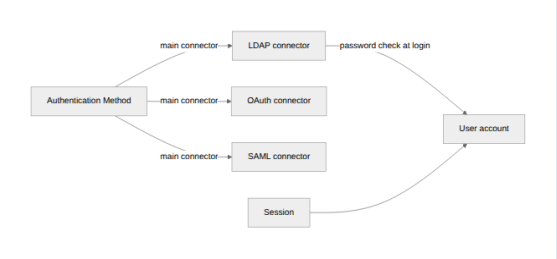
Columns: **Name**, **Identity Provider** (always empty in this release), **Status**, **In Use** (always “false”). The demo has none.

Add Item opens “Add Item (SAML Connectors)” with a single **General** tab. Two blue boxes list the values to give the identity provider: **Single sign on URL** `{this site}/saml/saml-connectors/single-sign-on`, **Audience URI (SP Entity ID)** `{this site}/saml/saml-connectors/get-metadata`, **Default RelayState** `{this site}/login`, **Assertion Consumer Service (ACS)** `{this site}/login?acs=1`, **Logout URL** `{this site}/saml/saml-connectors/single-logout`, and **Redirect URLs** as for OAuth. None of these addresses is served by the product in this release.

Field	Type	Required	Rules and allowed values	Example
Name	Text	Yes (server: “Connector name is required”)		Okta SAML
Identity Provider	Text	Yes (server: “Identity provider metadata URL is required”)	IdP metadata URL	https://company.okta.com/app/xyz/sso/saml/metadata
IDP x509 Certificate	Text area	No	Not saved (see known issues)	
Remote sign in URL	Text	No		https://company.okta.com/app/xyz/sso/saml
Email field	Text	No	Attribute holding the e-mail; server default “email” when omitted	email
Sign SAML request	Switch	No	Off by default. Not saved.	Off
SP x509 Certificate	Text area	No	Not saved	
SP Private Key	Text area	No	Stored encrypted	
Authentication Context	Dropdown	No	**Password Protected Transport** (only option)	Password Protected Transport
Status	Dropdown	No	**Active** (default), **Disabled**	Active

Save shows “SAML connector created successfully.” The connector cannot be edited or deleted afterwards from the screen.

Relationships



Related record	Direction	How the link is made	Where it shows
Connector	Authentication Method → connector	**User authentication connector**	Method tab
User account	LDAP connector → account	Same e-mail at sign-in	Not shown
User account	Session → account	Sign-in	Active Sessions, User column

Automations and notifications

- The Active Sessions list refreshes every 30 seconds while visible.
- Ended session rows are kept 30 days and then purged. The purge runs at most once an hour, triggered by token refreshes, not by a scheduled job.
- No notifications are raised by this page. Connector and method changes are written to the System Log and are therefore also sent to matching webhooks.

Permissions

Action	Needed access
See the page	Admin group (Settings is Admin-only)
Save the method, add / edit / delete / test connectors	Admin group
Sign out sessions	Admin group
Comment / Assign	Not applicable

How to

Let staff sign in with their Active Directory password

1. Make sure each person already has a GRC360 account with their company e-mail (Organization Hub › Users).
2. On **LDAP Connectors**, click **Add Item**. Fill **Name**, **LDAP Server Hostname**, **Mail Domain**, **Port**, **LDAP Username**, **LDAP Password** and **LDAP Server Base DN**. On **Connector Settings**, set **User Search Filter** to `(userPrincipalName={0})`. Save.
3. Click **Test connection** and read the result. Fix the hostname, credentials or base DN until it reports users matched.
4. Click **Edit**, set **Status** to **Enabled**, save.
5. On **Authentication Method**, choose **LDAP**, select the connector, click **Save**.

Sign a lost laptop out

1. Open **Active Sessions** and search for the user, for example “sara”.
2. Find the session by device and IP address and click **Sign out**, or click the person icon to end all of Sara Johnson’s sessions.
3. Confirm. The device returns to the sign-in page within seconds.

Find out why a session ended

1. On **Active Sessions**, switch to **Ended**.
2. Search for the user and read the **Reason** column, for example “Timed out after inactivity”.

CSV import

The connector grids show **Import CSV**, but it opens the shared demo import dialog, which fails in this release. The server has CSV import and export for connectors (`/settings/authentication/{ldap|oauth|saml}-connectors/import-csv` and `/export-csv`) that the screen does not use. There is no **Export CSV** button.

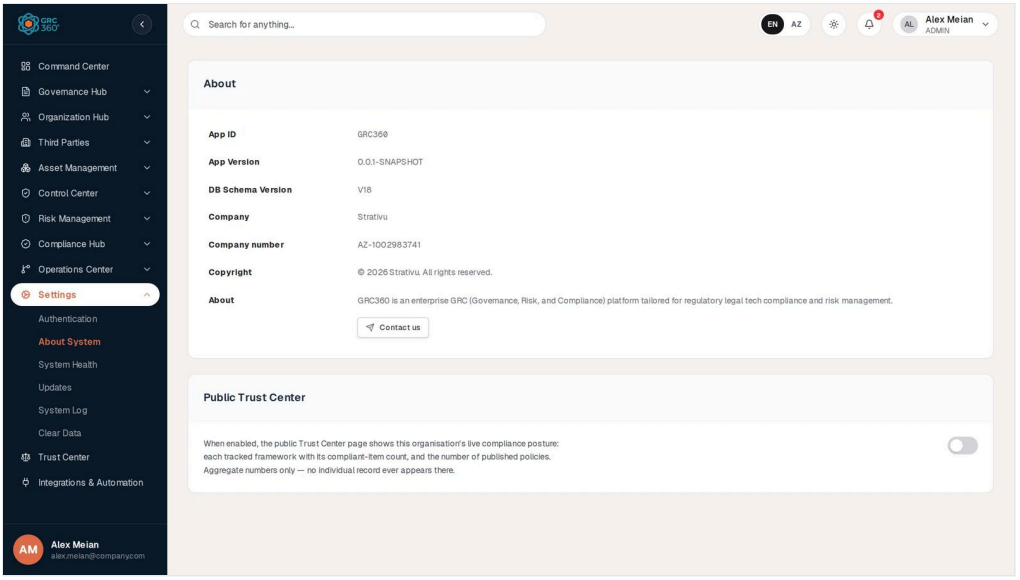
Limitations and known issues

- OAuth and SAML connectors are stored only; neither is used to sign anyone in, and selecting them as main method has no effect.
- **In Use** is never set, so it always reads “false”, and a connector chosen as the main connector can still be deleted.
- LDAP **Type** (**Authenticator** / **Group**) is not saved; the column always shows “LDAP”.
- OAuth **Client Secret** column and SAML **Identity Provider** column are always empty.
- The SAML dialog sends the certificate fields and the **Sign SAML request** switch under names the server does not read, so they are not saved. The authentication context and the status are saved as the screen’s display text (“Password Protected Transport”, “Active”).
- OAuth and SAML connectors cannot be edited, tested or deleted from the screen.
- LDAP sign-in requires an existing, active local account with the same e-mail; it does not create accounts.
- **Import CSV** on the connector tabs does not work.

About System

> **Module:** Settings › About System · **Route:** `/settings/about-system` · **Permission key:** `settings.about_system`

About System shows which build of GRC360 is running and who supplies it, and holds the one switch that changes what outsiders can see: whether the organisation’s live compliance posture appears on the Trust Center. Administrators use it when reporting a problem to support or when deciding to publish the posture.



About System

At a glance

A record is	None. One read-only information card and one organisation-wide switch.
Typical owner	Administrator
Links to	Trust Center (live posture section), the supplier’s web site (**Contact us**)
Linked from	Sidebar (Settings › About System)
Tabs	None
Automations	None

The register (list view)

The page has two cards.

About

Row	What it shows in this release	Source
App ID	GRC360	Fixed in the server
App Version	The version from the server build; “0.0.1-SNAPSHOT” on a development build without a version	Server build
DB Schema Version	V18	Fixed in the server
Company	Strativu	Fixed in the server
Company number	AZ-1002983741	Fixed in the server

Row	What it shows in this release	Source
Copyright	© 2026 Strativu. All rights reserved.	Fixed in the server
About	“GRC360 is an enterprise GRC (Governance, Risk, and Compliance) platform tailored for regulatory legal tech compliance and risk management.”	Fixed in the server

Below the About text, **Contact us** opens `https://strativu.com` in a new tab.

When the information cannot be loaded, an amber box shows “Permission Denied: You do not have permission to view system info.” or the error text, and the rows fall back to “-” (App Version falls back to “1.0”, Copyright to “© 2026 Strativu GRC Ltd”).

Public Trust Center

A text explains: “When enabled, the public Trust Center page shows this organisation’s live compliance posture: each tracked framework with its compliant-item count, and the number of published policies. Aggregate numbers only — no individual record ever appears there.” A toggle on the right switches publishing on (green) or off (grey). It saves immediately; there is no Save button. If loading fails the card shows “The publishing state could not be loaded.”; if saving fails, “The change could not be saved.” Publishing is off by default and off in the demo.

Creating a record

None.

Viewing and editing a record

Only the **Public Trust Center** toggle can be changed. All About rows are read-only.

Statuses

Value	Set by	Meaning
Toggle on	User	The Trust Center shows the Live compliance posture section.
Toggle off	User (default)	The section is hidden.

Tabs

None.

Relationships

Related record	Direction	How the link is made	Where it shows
Trust Center	About System → Trust Center	Publishing switch	Live compliance posture section

Automations and notifications

None. The switch is not written to the System Log.

Permissions

Action	Needed access
See the page	Admin group
Change the publishing switch	Admin group
Comment / Assign	Not applicable

How to

Report the running version to support

1. Open **Settings › About System**.
2. Copy **App Version** and **DB Schema Version** into your support request (see also **Download Diagnostics** on System Health).

Publish the live compliance posture

1. Open **Settings › About System**.
2. Switch the **Public Trust Center** toggle on.
3. Open **Trust Center**; the **Live compliance posture** section now appears for signed-in users.

CSV import

None.

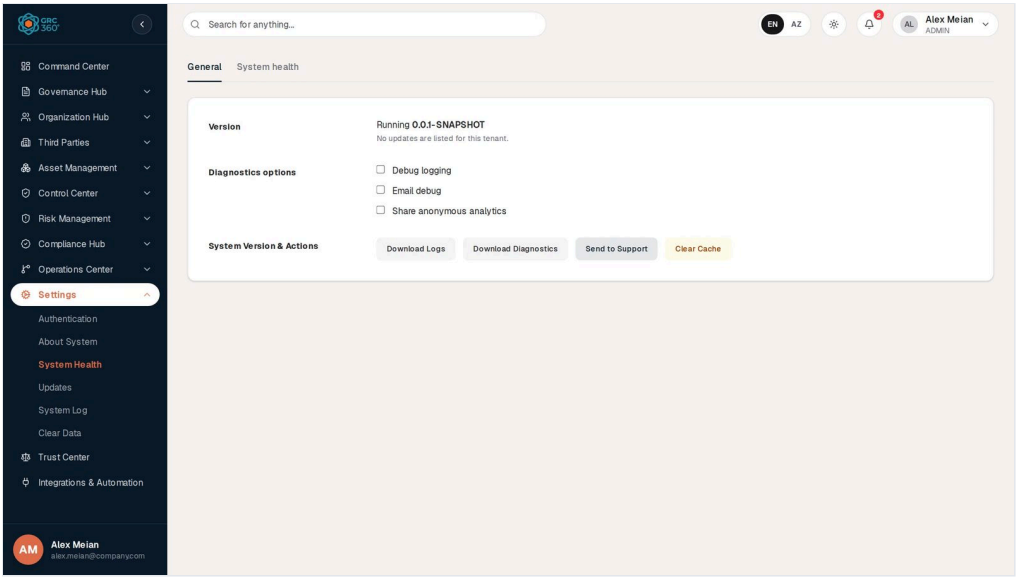
Limitations and known issues

- All About values except the version are fixed in the server and cannot be changed per customer.
- The card calls the Trust Center “public”, but the Trust Center requires sign-in in this release.
- Changing the publishing switch leaves no System Log entry.

System Health

> **Module:** Settings › System Health · **Route:** `/settings/system-health` · **Permission key:** `settings.system_health`

System Health tells an administrator whether the server and its dependencies are working, and provides the files support usually asks for. The **General** tab shows the running version, three diagnostics switches and four action buttons; the **System health** tab runs live checks of the database, memory, disk, cache and mail relay.



System Health, General tab

At a glance

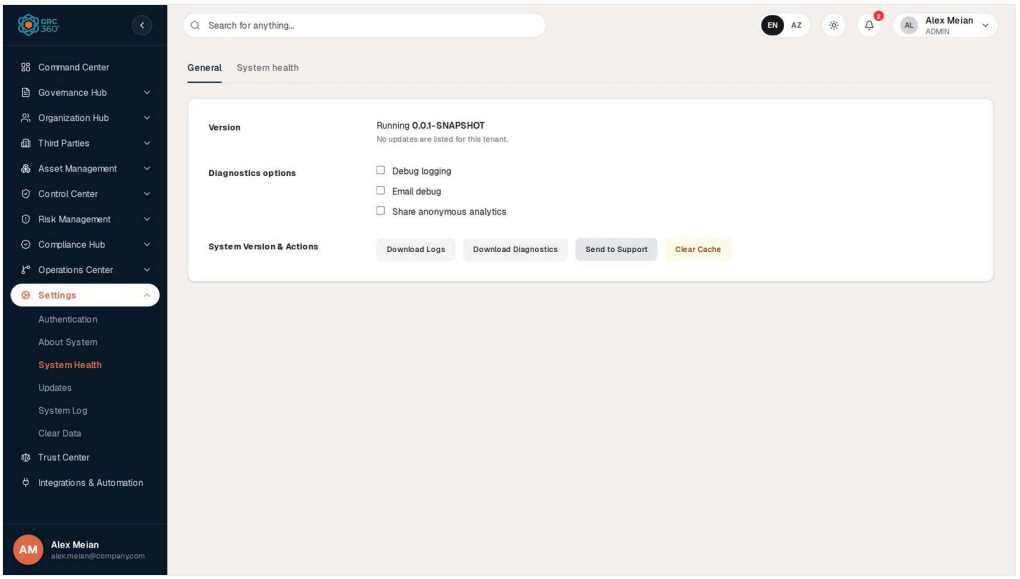
A record is	None. One settings row per organisation (the diagnostics switches) and a list of live checks.
Typical owner	Administrator
Links to	Updates register (version message), System Log (download), SMTP configuration (mail check)
Linked from	Sidebar
Tabs	**General**, **System health** (in-page tabs)
Automations	Checks run when the tab is opened. No scheduled job.

The register (list view)

General tab

Row	What it shows
Version	“Running **{version}**” and a message: “Version {x} is available.” when the Updates register lists a higher version with status Available, otherwise “No updates are listed for this tenant.”
Diagnostics options	Three check boxes: **Debug logging**, **Email debug**, **Share anonymous analytics**. Each saves immediately and shows the toast “Saved.” (or “Could not save the setting.”).
System Version & Actions	Four buttons, described below.

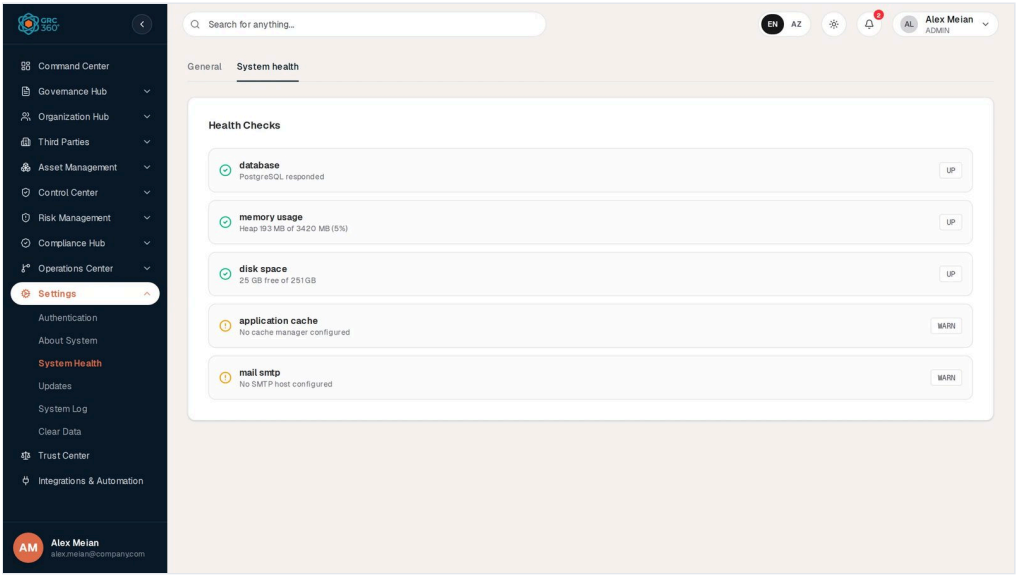
The General tab fits on one screen; the full-page capture shows the same content:



System Health, General tab, full page

Button	What it does	Result
Download Logs	Downloads this organisation's System Log as a file named `system_logs.log`. The content is the same comma-separated list as the System Log export (id, action, portal, username, message, createdAt).	File download; writes SYSTEM_LOGS_DOWNLOADED to the System Log.
Download Diagnostics	Downloads `diagnostics.txt` with the generation time, organisation id, app version, Java version, operating system, uptime, active server profiles and the results of all health checks.	File download; writes SYSTEM_DIAGNOSTICS_DOWNLOADED.
Send to Support	Without a mail relay and a configured support address, shows "No support mail channel is configured on this deployment. Download the diagnostics package and send it to support yourself." With both configured, shows "Diagnostics queued for delivery to {address}."	Toast; writes SYSTEM_DIAGNOSTICS_SEND_UNAVAILABLE or SYSTEM_DIAGNOSTICS_SENT_TO_SUPPORT.
Clear Cache	Empties every application cache. In this release no cache is configured, so it has nothing to clear.	Toast "Application cache cleared successfully"; writes SYSTEM_CACHE_CLEARED.

System health tab



System Health, health checks

The heading **Health Checks** is followed by one row per check, with an icon (green check for UP, amber warning for WARN, red cross for DOWN), the check name, details, the response time in ms when measured, and the status.

Check	UP	WARN	DOWN	Demo result
database	The database answered within 2 seconds (“PostgreSQL responded”)		No answer within 2 seconds, or connection failed (with the error)	UP
memory usage	Heap use below 75 %	75 % to 89 %	90 % or more	UP, “Heap 373 MB of 3420 MB (10%)”
disk space	5 GB or more free on the server’s working disk	1 to 4 GB free	Less than 1 GB free	UP, “26 GB free of 251 GB”
application cache	A cache manager is active (lists cache names)	“No cache manager configured”		WARN
mail smtp	“SMTP host {host}”	“No SMTP host configured”		WARN

While running the tab shows “Running health checks…”; with no results, “No health check reports available.”

Creating a record

None.

Viewing and editing a record

Only the three **Diagnostics options** check boxes can be changed.

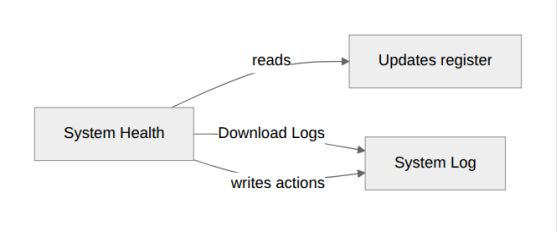
Statuses

Value	Set by	Meaning
UP / WARN / DOWN	System	Result of each live check, rules above.

Tabs

See **General** and **System health** above.

Relationships



Related record	Direction	How the link is made	Where it shows
Update	Read	Highest version with status Available	Version message
System Log	Read and write	Download Logs exports it; every button writes an entry	Download; System Log page

Automations and notifications

None. Checks run on demand. The button actions are written to the System Log and are therefore also sent to matching webhooks.

Permissions

Action	Needed access
See both tabs	Admin group
Change switches, download, send, clear cache	Admin group
Comment / Assign	Not applicable

How to

Prepare a support request

1. Open **Settings › System Health**, tab **System health**, and note any WARN or DOWN rows.
2. On **General**, click **Download Diagnostics** and **Download Logs**.
3. Attach both files to an e-mail to support (or use **Support** in the user menu, which opens a pre-filled e-mail).

Check that the mail relay is configured

1. Open the **System health** tab.
2. If **mail smtp** shows WARN “No SMTP host configured”, invitation e-mails cannot be sent; see E-mail, webhooks and notifications.

CSV import

None.

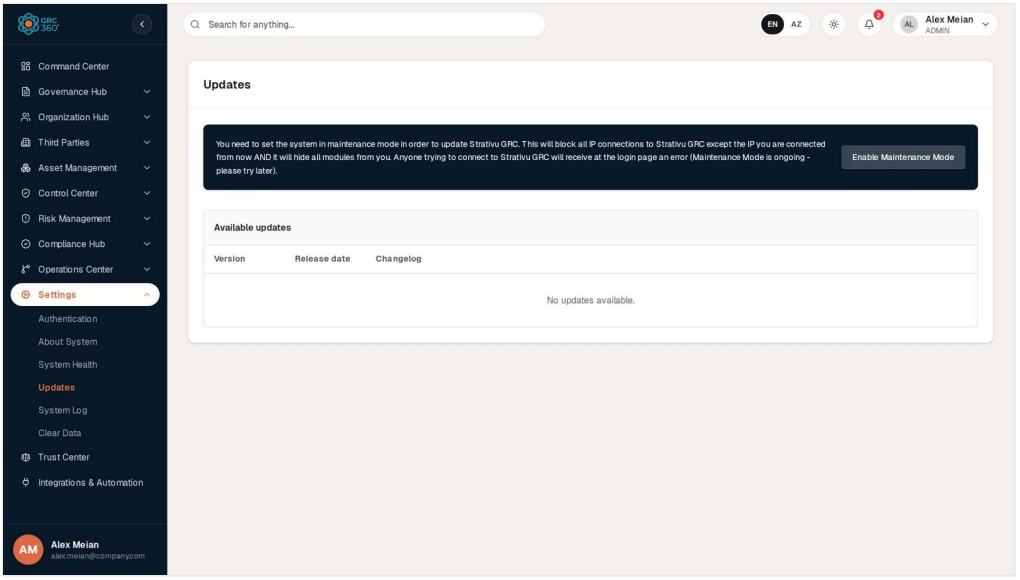
Limitations and known issues

- **Debug logging**, **Email debug** and **Share anonymous analytics** are stored but nothing in the server reads them; switching them has no other effect.
- **Download Logs** names its file `.log`, but the content is comma-separated values.
- **Clear Cache** has nothing to clear in this release (caching is off).
- **Send to Support** needs a `support.contact-email` server setting that is not part of the standard configuration, and even when it is set the server only records the request; it does not send an e-mail.

Updates

> **Module:** Settings › Updates · **Route:** `/settings/updates` · **Permission key:** `settings.updates`

The Updates page lists the product versions recorded for this organisation and carries a notice about maintenance mode. In this release it is informational: updates are installed by whoever runs the server, not from this page, and the maintenance-mode button has no effect.



Updates

At a glance

A record is	One update entry (version, release date, description). Entries are not created from the screen.
Typical owner	Administrator, together with the person who operates the server
Links to	System Health (the “update available” message reads this register)
Linked from	Sidebar
Tabs	None
Automations	None

The register (list view)

The card **Updates** has two parts.

1. **Maintenance notice.** A dark banner reads: “You need to set the system in maintenance mode in order to update Strativu GRC. This will block all IP connections to Strativu GRC except the IP you are connected from now AND it will hide all modules from you. Anyone trying to connect to Strativu GRC will receive at the login page an error (Maintenance Mode is ongoing - please try later).” with the button **Enable Maintenance Mode**.
2. **Available updates.** A table:

Column	What it shows	Source
Version	Version number	Updates register
Release date	Release date	Updates register
Changelog	The description, and a link that is meant to point to the release notes	Updates register

With no entries the table reads “No updates available.” This is the state in the demo and in a normal installation: the server no longer invents update entries, and nothing in the product adds them. If loading fails, a red box shows the error.

Creating a record

None. There is no form; update entries can only exist in the database.

Viewing and editing a record

None.

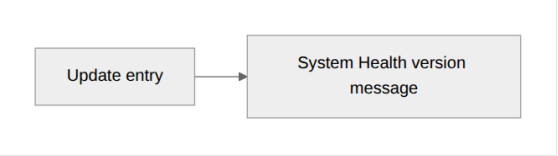
Statuses

Value	Set by	Meaning
Available (stored on an entry)	Server data	An entry with status Available and a version different from the running one makes System Health say “Version {x} is available.”

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
System Health	Update → System Health	Highest Available version	Version row on System Health › General

Automations and notifications

None.

Permissions

Action	Needed access
See the page	Admin group
Enable Maintenance Mode	Admin group (the button does nothing, see below)
Comment / Assign	Not applicable

How to

Check whether a newer version is recorded

1. Open **Settings › Updates** and read **Available updates**.
2. Or open **Settings › System Health › General** and read the line under **Version**.

Plan an upgrade

1. Agree a time with the person who operates the server; the upgrade is a deployment task (see the technical reference).
2. Tell users in advance. The **Enable Maintenance Mode** button does not block sign-ins in this release, so announce the window by other means.
3. After the upgrade, confirm the new **App Version** on **Settings › About System**.

CSV import

None.

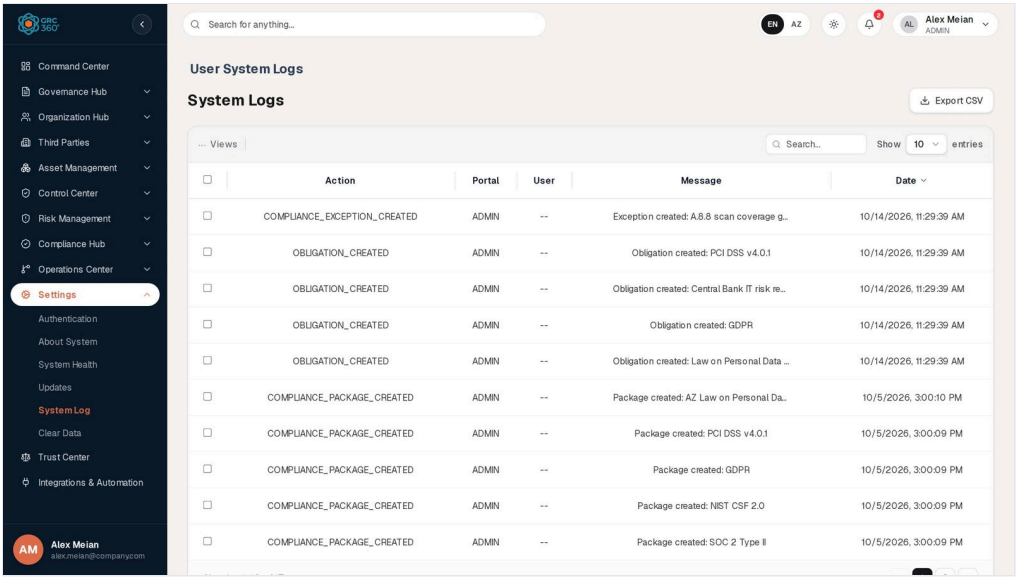
Limitations and known issues

- **Enable Maintenance Mode** has no action attached; clicking it does nothing. The server has a maintenance-mode setting, but nothing enforces it and the public maintenance status always reports “System is operational”.
- The **Changelog** link reads a field the server does not send, so it is empty even when an entry has release notes.
- The table can only ever show entries put into the database by hand.

System Log

> **Module:** Settings › System Log · **Route:** `/settings/system-log` · **Permission key:** `settings.system_log`

The System Log is the organisation's read-only, append-only trail of administrative and Compliance Hub actions: who changed the authentication settings, which compliance package was created, which exception expired. Administrators and auditors read it to answer "what happened and when", and export it as CSV for evidence. No entry can be edited or deleted from the product.



System Log

At a glance

A record is	One logged action (action code, portal, user, message, date).
Typical owner	Administrator; auditors receive exports
Links to	None (entries carry text only)
Linked from	System Health (**Download Logs** exports the same entries); webhooks receive every new entry
Tabs	None
Automations	Entries are written by the server as actions happen; each new entry is also sent to matching webhooks.

The register (list view)

The page heading is "User System Logs", the grid title "System Logs", with **Export CSV** on the right. The grid is server-paged and sorted newest first; its shared behaviour (search, **… Views**, paging) is described in Working with registers. It has no Add, Edit, Delete or Import buttons and no row actions. With no entries it reads "No logs found."

Column	What it shows	Source
Action	Action code, for example COMPLIANCE_PACKAGE_CREATED	System
Portal	Always "ADMIN" in this release	System
User	The acting user's name. In this release it shows "–" for actions done in the application (the server stores the user id, not the name).	System

Column	What it shows	Source
Message	Description, for example “Package created: GDPR”	System
Date	Date and time in your browser’s locale; “–” when missing	System

The search box filters on the server. In the demo data the log holds 17 entries, for example an OBLIGATION_CREATED entry with the message “Obligation created: PCI DSS v4.0.1”.

What is logged

Area	Action codes
Authentication settings	AUTH_SETTINGS_UPDATED, AUTH_CONNECTOR_CREATED, AUTH_CONNECTOR_UPDATED, AUTH_CONNECTOR_DELETED, AUTH_CONNECTOR_TESTED
System Health	SYSTEM_HEALTH_CONFIG_UPDATED, SYSTEM_LOGS_DOWNLOADED, SYSTEM_DIAGNOSTICS_DOWNLOADED, SYSTEM_DIAGNOSTICS_SEND_UNAVAILABLE, SYSTEM_DIAGNOSTICS_SENT_TO_SUPPORT, SYSTEM_CACHE_CLEARED
Compliance Packages	COMPLIANCE_PACKAGE_CREATED, _UPDATED, _DELETED, _IMPORTED, _EXPORTED
Compliance Analysis	ASSESSMENT_CREATED, ASSESSMENT_IMPORTED, ASSESSMENT_ITEM_STATUS_CHANGED
Obligations	OBLIGATION_CREATED, OBLIGATION_UPDATED, OBLIGATION_DELETED
External Audit Findings	AUDIT_FINDING_CREATED, AUDIT_FINDING_UPDATED, AUDIT_FINDING_STATUS_CHANGED, AUDIT_FINDING_ATTACHMENT_UPLOADED
Compliance Exceptions	COMPLIANCE_EXCEPTION_CREATED, COMPLIANCE_EXCEPTION_STATUS_EDITED, COMPLIANCE_EXCEPTION_{workflow action}, COMPLIANCE_EXCEPTION_EXPIRED

Not logged here: sign-ins and sign-outs, permission and group changes, user changes, and changes in registers outside Compliance Hub (assets, risks, controls, policies, vendors, projects, incidents and others). Some of those (risk register and objective audit events) go to a separate internal audit trail that has no screen but does feed webhooks. Changes to individual records are also visible in each record’s Activity Log.

Creating a record

None. Entries are written only by the server.

Viewing and editing a record

The grid has no row actions and no view dialog; the long **Message** is truncated in the grid, so use **Export CSV** to read it in full. Entries cannot be edited or deleted; the server has no endpoint for either.

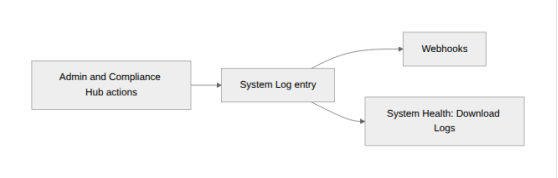
Statuses

None.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Webhook	System Log → webhook	Every new entry is offered to webhooks whose filter matches the action code	Your endpoint
System Health	Read	**Download Logs** exports the entries	File download

Automations and notifications

Each entry is sent to matching webhooks in the background. A data reset that includes **Audit trail and notifications** empties the log; the reset itself is then recorded in the internal audit trail, not in the System Log.

Permissions

Action	Needed access
See the page	Admin group (catalogue right `settings_system_log_read`)
Export CSV	Admin group (`settings_system_log_export`)
Create / Edit / Delete	Not possible for anyone
Comment / Assign	Not applicable

How to

Export the log for an auditor

1. Open **Settings › System Log**.
2. Click **Export CSV**. The file `system-logs.csv` contains every entry of the organisation (not only the current page) with the columns id, action, portal, username, message, createdAt.

Find who changed the sign-in method

1. Type “AUTH_SETTINGS” in the search box.
2. Read the **Message** (“Authentication settings updated to LDAP”) and **Date** columns. The **User** column does not identify the person in this release; compare the time with the Active Sessions list on Authentication if needed.

Review compliance exception expiries

1. Search for “COMPLIANCE_EXCEPTION”.
2. Entries with action COMPLIANCE_EXCEPTION_EXPIRED were expired automatically; status changes made by people appear as COMPLIANCE_EXCEPTION_STATUS_EDITED or with the workflow action in the code.

CSV import

None. Import is hidden on this grid. Export is described above.

Limitations and known issues

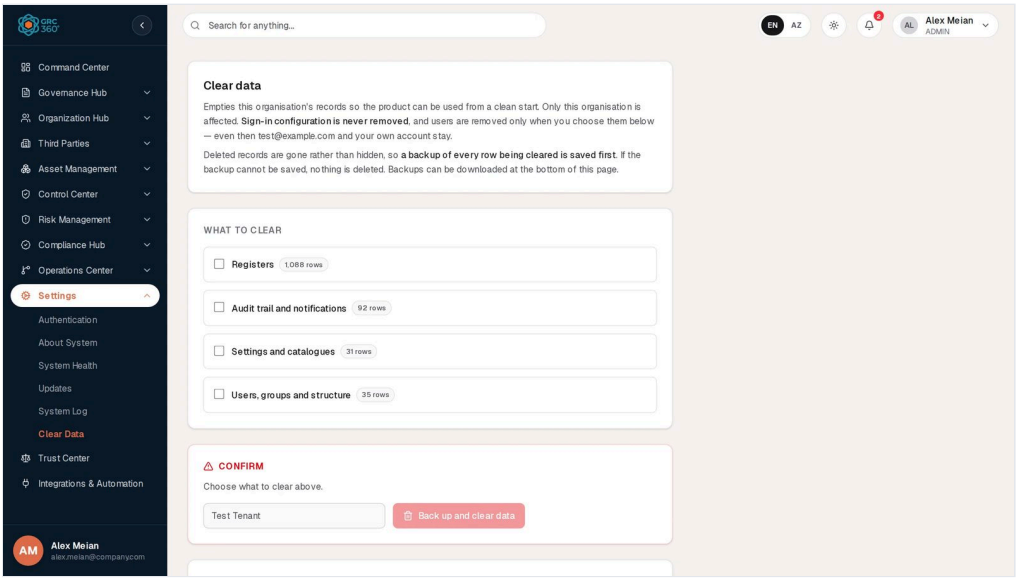
- The **User** column shows “–” for entries made by signed-in users; the export’s username column is empty for the same reason.
- **Portal** is always “ADMIN”.
- Coverage is limited to authentication settings, System Health actions and Compliance Hub; sign-ins, permission changes and most register changes are not in this log, although the Trust Center describes them as logged.
- Automatic expiry of compliance exceptions (COMPLIANCE_EXCEPTION_EXPIRED) depends on a scheduled job that is not active in this release; such entries appear only when the expiry is triggered by other means.

Clear Data

> **Module:** Settings › Clear Data · **Route:** `/settings/clear-data` · **Permission key:** `settings.clear_data`

Clear Data permanently deletes chosen groups of this organisation's data so the product can be used from a clean start, for example after a trial or a demo. Before anything is deleted the server saves a backup of every row it is about to remove, and if that backup cannot be saved nothing is deleted. Only the Admin group can open the page, and the deletion has to be confirmed by typing the organisation's name.

Deleted rows are gone, not hidden. There is no undo and no restore function in the product. The backup file is the only copy.



Clear Data

At a glance

A record is	A backup taken by a reset (listed under **Backups**).
Typical owner	Administrator
Links to	Every register of the organisation (as deletion targets)
Linked from	Sidebar
Tabs	None
Automations	After a reset every open browser tab of the organisation reloads its data.

Who may do it

Action	Needed access
Open the page and see the row counts and backups	Admin group (catalogue right **read** on Settings › Clear Data). No other group can hold Settings.
Run **Back up and clear data** and **Download** a backup	Admin group (catalogue right **execute**, labelled "Execute Reset"). Without it the buttons are greyed with a lock and open Request Access, which for Settings explains that it cannot be requested.

Only the caller's own organisation is affected. The organisation comes from the signed-in session, never from the request, so no request can reach another organisation's data.

The page (list view)

The page has four cards.

1. **Clear data.** Explains that only this organisation is affected, that “Sign-in configuration is never removed”, that users are removed only when chosen and that `test@example.com` and your own account stay, and that “a backup of every row being cleared is saved first”.
2. **What to clear.** Four check boxes, each with the current row count from the server (“…” while loading):

Check box	Group code	Demo count
Registers	REGISTERS	1,081 rows
Audit trail and notifications	LOGS	90 rows
Settings and catalogues	SETTINGS	22 rows
Users, groups and structure	PEOPLE	23 rows

The counts include the link rows between records (for example a risk’s link to an asset), not only the records themselves. If **Settings and catalogues** is ticked without **Registers**, an amber note warns: “Scales, stages and catalogues are still referenced by the records that use them, so most of them will not clear while the registers are kept. Add Registers to clear both.”

3. **Confirm.** With nothing ticked it reads “Choose what to clear above.” Otherwise: “This will back up and then delete **N rows**. To confirm, type the organisation name: **{name}**”. Type the name into the field (placeholder: the name; in the demo “Test Tenant”; case does not matter) and click **Back up and clear data**. The button stays disabled until at least one group is ticked and the typed name matches. While running it reads “Backing up and clearing…”.
4. **Backups.** “One file per clear, holding every row it deleted as gzipped JSON, table by table.” A table lists **Taken**, **By**, **Cleared** (groups), **Rows**, **Size** and a **Download** button. With none: “No backups yet. One is saved each time data is cleared.”

After a successful run a **Cleared** card shows “N rows removed.”, “A backup was saved before clearing. It is the newest entry under Backups below.”, a list of tables with the number of rows deleted from each, and, if any, “Still referenced elsewhere and left as they were: {tables}.” If the run fails, a red box shows the server’s message; the server’s own wording starts “Nothing was cleared:”.

What is deleted

Group	What goes
Registers	Every other table of the organisation that is not in one of the three groups below and not in the never-deleted list: assets, data flows, risks of all three registers and their reviews, risk exceptions, controls with audits, issues and maintenances, policies and reviews, policy exceptions, continuity plans with audits and tasks, compliance packages, items, analyses, obligations, compliance exceptions and audit findings, vendors and service agreements, objectives, coverage and issues, projects with tasks and expenses, security incidents, comments and attachments records, activity history, and every link row between them.
Audit trail and notifications	The internal audit trail, the System Log, all notifications and notification history.
Settings and catalogues	Risk settings (module settings, appetite, analysis matrices, calculation methods, classification types and values), control catalogue options, obligation categories, objective audit result options, security incident stages, notification templates and preferences, policy templates, the Trust Center publishing switch and all **webhooks**.
Users, groups and structure	All users and their sign-in accounts, sessions, pending invitations and individual permission grants, departments, user groups and **custom** groups, **except** the kept accounts below.

Kept accounts. When **Users, groups and structure** is cleared, these accounts stay with their sessions: the account of the administrator who runs the reset, and every e-mail listed in the server setting `APP_DATA_RESET_KEEP_EMAILS` (default `test@example.com`). The built-in groups **Admin**, **Read Only** and **Third Party** always stay. Where a kept row points at a deleted one (for example a kept user’s department), that reference is emptied rather than the kept row being deleted.

Never deleted, whatever is ticked: the organisation itself and its domains and profile; the permission catalogue and system roles; all sign-in configuration (authentication method, LDAP, OAuth and SAML connectors, SSO configuration); system information and the updates register; and earlier reset backups.

Files. Uploaded attachment files in file storage are not part of the backup and are not removed by the reset; only their database records are.

The backup

- Taken on the same database connection immediately before the first deletion. If it cannot be written or stored, the whole operation is rolled back and nothing is deleted.
- Contains every row the plan will delete, including link rows, as gzipped JSON: format `grc360-tenant-backup/1`, organisation id, time, who ran it, groups, and per table its columns and rows.
- Stored in the server's file storage. The download is named `grc360-backup-yyyyMMdd-HHmmss.json.gz`.
- Listed under **Backups**, newest first. Backups are never deleted by a later reset and are not cleaned up automatically.
- There is no restore button. Restoring data from a backup is a manual database task for the server operator.

Creating a record

A backup is created only by running a reset.

Viewing and editing a record

Backups can only be downloaded.

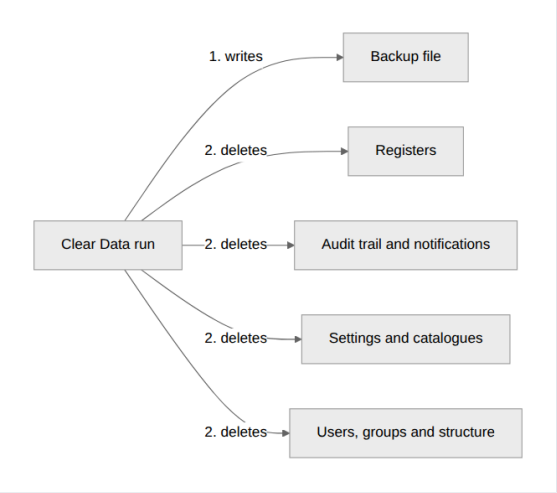
Statuses

None.

Tabs

None.

Relationships



Related record	Direction	How the link is made	Where it shows
Every organisation table	Clear Data → table	Group membership	What to clear counts; Cleared table list
Backup	Clear Data → backup	One per run	Backups list

Automations and notifications

- After a reset, every open tab of the organisation is told to reload all data.
- The reset is recorded in the internal audit trail after the deletion (so it survives a clear of **Audit trail and notifications**) and is therefore also sent to matching webhooks, unless webhooks were themselves cleared. It is not shown in the System Log page.
- No notification is sent.

Permissions

See Who may do it.

How to

Clear the demo data before going live

1. Download any data you want to keep using the **Export CSV** buttons of the registers.
2. Open **Settings › Clear Data**. Tick **Registers** and **Audit trail and notifications**. Leave **Users, groups and structure** unticked to keep your colleagues' accounts.
3. Read the total in **Confirm**, type the organisation name exactly as shown (in the demo "Test Tenant") and click **Back up and clear data**.
4. Check the **Cleared** card and download the new backup from **Backups** for safekeeping.

Reset everything except your own sign-in

1. Tick all four boxes. Note that every other user will be removed and signed out, and that custom groups and departments go.
2. Type the organisation name and click **Back up and clear data**.
3. You remain signed in. Sign-in configuration (for example an LDAP connector) is still there.

Retrieve a backup

1. Scroll to **Backups**.
2. Click **Download** on the row with the right **Taken** time and **Cleared** groups.

CSV import

None.

Limitations and known issues

- No restore function; the backup can only be downloaded.
- Clearing **Settings and catalogues** without **Registers** leaves most of those tables in place because records still reference them; they are reported as "Still referenced elsewhere".
- Uploaded files in storage are not deleted or backed up.
- The page text names `test@example.com` as the kept account; if the server operator changed `APP_DATA_RESET_KEEP_EMAILS`, the text does not follow.

Part 3 — How the modules work together

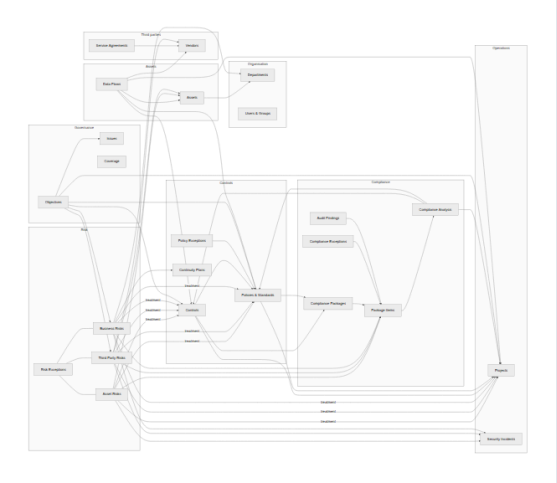
Relationship map

GRC360's registers are linked: a risk names the assets it threatens and the controls that treat it, a control names the policies behind it and the compliance packages it satisfies, and so on. This page lists every link a user can make, where it is made, and where it shows up on the other side.

Reading the tables

- **Set on**: the form and field where you create the link. A link is always stored on one side.
- **Shown on the other side**: where the link appears on the record you linked to. Counts marked *clickable* open the linked records' details (see clickable counts).
- **Not shown**: the link exists and is used by the system, but the other record's page does not display it.

The overall picture



Organisation and assets

From	To	Set on	Cardinality	Shown on the other side
User	Department	Users › **Department**	many users → one department	Departments: department contact
User	Group	Users › **Groups**	many ↔ many	Groups: member count and members panel
Asset	Department	Assets › **Related Departments**	many ↔ many	Departments › **Asset Risks** counts risks of the department's assets
Asset	Reviews	Assets › Reviews tab	one asset → many reviews	Assets › **Reviews** count; row click opens them
Data Flow	Asset	Data Flows › asset field	many flows → one asset	Assets › **Data Asset Flows** count
Data Flow	Vendors / third parties	Data Flows › third parties	many ↔ many	Not shown on the vendor
Data Flow	Departments	Data Flows › departments	many ↔ many	Not shown
Data Flow	Asset, Third Party and Business Risks	Data Flows › risk fields	many ↔ many	Adds the risk to the asset's links

From	To	Set on	Cardinality	Shown on the other side
Data Flow	Controls (compensating), Policies, Projects (improvement)	Data Flows › **Compensating Controls**, **Policies**, **Improvement Projects**	many ↔ many	Not shown on the control, policy or project

Third parties

From	To	Set on	Cardinality	Shown on the other side
Service Agreement	Vendor	Service Agreements › **Vendor** (required)	many → one	Vendors: agreements of the vendor
Third Party Risk	Vendor	Third Party Risks › **Applicable Third Parties**	many ↔ many	Vendors › **Risk** count (clickable)
Third Party Risk	Asset	Third Party Risks › **Assets Shared with this Third Party**	many ↔ many	Assets › **Third Party Risk** count

Risks

The three risk registers link to the same kinds of records. The link is always stored on the risk.

From	To	Set on (risk form field)	Cardinality	Shown on the other side
Asset Risk	Asset	**Related Assets**	many ↔ many	Assets › **Asset Risks** count (clickable); Departments › **Asset Risks**
Business Risk	Department	**Applicable Business Units**	many ↔ many	Departments › **Business Risks** count
Business Risk	Continuity Plan	**Mitigating Business Continuity Plans**	many ↔ many	Shown only on the risk
Any risk	Control	**Treatment: Controls**	many ↔ many	Controls › **Asset Risks**, **Third Party Risks**, **Business Risks** counts (clickable, read-only)
Any risk	Policy	**Treatment: Policies**	many ↔ many	Policies & Standards › **Asset Risks Treatment**, **Third Party Risks Treatment** (business risks are not shown)
Any risk	Project	**Treatment: Projects**	many ↔ many	Projects › **Asset Risks** count (third-party and business risks are not shown)
Any risk	Risk Exception	**Treatment: Risk Exceptions**	many ↔ many	Risk Exceptions › risk counts. Also set from the exception's **Related … Risks** fields: either side works
Any risk	Compliance package item	**Affected Compliance Items**	many ↔ many	Compliance Analysis › **Asset Risks** tab of the item. Also editable from there

From	To	Set on (risk form field)	Cardinality	Shown on the other side
Any risk	Security Incident	**Security Incidents**	many ↔ many	Security Incidents › **Known Asset / Third Party / Business Risk** counts (clickable). The incident form has no risk field
Risk Review	Risk	Reviews tab › risk field	many reviews → one risk	Risk grid › **Reviews** count. Deleting a risk deletes its reviews

Side effect on compliance. Saving a risk updates the Compliance Analysis rows of the items it affects:

- If any linked risk is above appetite, the rows become **Not Compliant**.
- Otherwise they become **Compliant**.
- Rows marked **Not Applicable** are left alone.

See Compliance Analysis.

Controls and policies

From	To	Set on	Cardinality	Shown on the other side
Control	Policy	Controls › **Related Policies**	many ↔ many	Policies & Standards › **Internal Controls**
Control	Project	Controls › **Related Projects**	many ↔ many	Projects › **Internal Controls**
Control	Compliance Package	Set from Compliance Analysis when the control is added to an item	many ↔ many	Controls › **Compliance Package** column
Control	Audits, Issues, Maintenances	the control's tabs	one → many	Controls › **Audits**, **Issues**, **Maintenances** counts. Deleting the control deletes them
Policy	Project	Policies › **Related Projects**	many ↔ many	Not shown on the project
Policy	Compliance Package	Policies, or set from Compliance Analysis	many ↔ many	Policies › package column
Policy	Reviews	Policies & Standards › Reviews tab	one → many	Policies › **Reviews** count
Policy Exception	Policy	Policy Exceptions › **Related Policies**	many ↔ many	Shown on the exception
Continuity Plan	Audits, Tasks	the plan's tabs	one → many	Counts on the plan

Compliance

From	To	Set on	Cardinality	Shown on the other side
Package item	Package	Package Items › Add	many items → one package	Packages › **Compliance Package Items** count; row click opens them
Analysis row	Package item	Created automatically for every item	one per item	Compliance Analysis
Analysis row	Controls, Policies, Projects	Compliance Analysis › **Edit Action** › Treatment	many ↔ many	Adds the package to the control or policy; Projects › **Compliance Package**
Compliance Exception	Package items	Compliance Exceptions › requirement items	many ↔ many	Compliance Analysis › Treatment of the item

From	To	Set on	Cardinality	Shown on the other side
External Audit Finding	Package items	External Audit Findings › affected items	many ↔ many	Compliance Analysis › Treatment of the item
Package	Trust Center	automatic		Trust Center posture uses the analysis results per package

Governance

From	To	Set on	Cardinality	Shown on the other side
Objective	Issues	Objectives › **Program Issues**	many ↔ many	Not shown on the issue
Objective	Controls, Policies, Projects	Objectives › **Activities**	many ↔ many	Not shown on the other record
Objective	Third Party Risks, Business Risks	Objectives › **Activities**	many ↔ many	Objectives grid counts (clickable)
Objective	Audits	Objectives › Audit tab	one → many	Objectives › **Audits** count. Deleting the objective deletes them

Operations

From	To	Set on	Cardinality	Shown on the other side
Project	Tasks, Expenses	Projects › Tasks and Expenses tabs	one → many	Projects › **Tasks** count; view chips such as **Expired Tasks**
Security Incident	Stages	Security Incidents › Stages tab	many ↔ many, with a status per stage	Incident stage progress

Links that only exist on one side

These links are stored and used by GRC360, but the linked record's page does not display them:

- Third-party and business risks that a project treats: the project shows only asset risks.
- Business risks treated by a policy: the policy shows only asset and third-party risks.
- Projects linked from policies, data flows and objectives.
- Controls, policies and projects linked from objectives.
- Data flows' links to vendors, compensating controls and policies.

Use the record that holds the link (the risk, policy, data flow or objective) to see and change it.

Deleting linked records

- Deleting a parent deletes its children:
  - a control's audits, issues and maintenances;
  - an objective's audits;
  - a risk's reviews;
  - a project's tasks and expenses;
  - a continuity plan's audits and tasks.
- Deleting a control also removes it from projects, incidents and objectives.
- Deleting a user keeps the person's name on the records they were named on.
- When a record cannot be deleted because others depend on it, the delete dialog says so.

Related pages

- What is GRC360
- The module pages under Module reference: each has a *Relationships* section with its own diagram.

Scenario: a risk assessment cycle

Goal. Identify a risk to an asset, score it, decide the treatment, link the controls and projects that carry it out, and keep it under review.

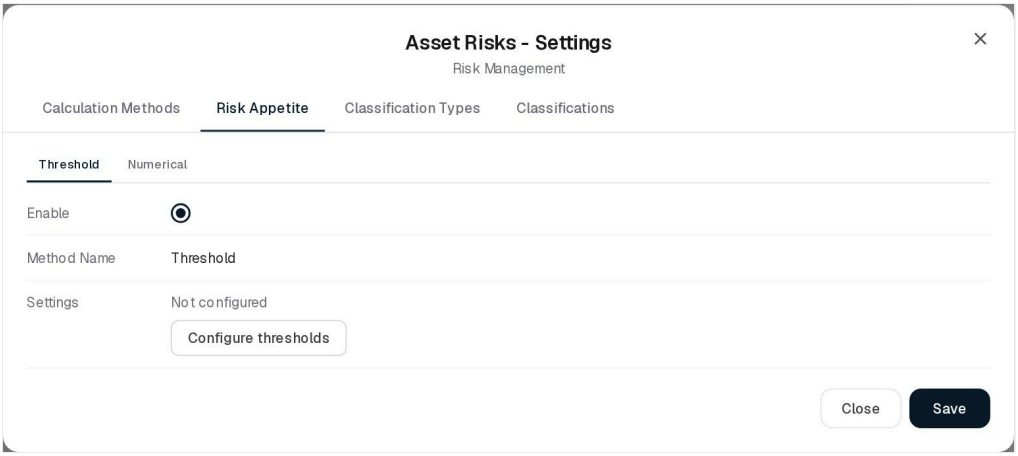
Example. The customer database could be reached through stolen administrator passwords.

Who. A risk owner with **Manage** access to Asset Risks, plus **View** on Assets, Controls and Projects. To create a missing control or project on the spot, you also need **Manage** on that register.

1. Check the scoring settings

Before the first risk, open **Risk Management › Asset Risks** and click the gear button. Check:

- **Classification Types** and **Classifications**: the likelihood and impact scales, by default 1–5 each.
- **Risk Appetite**: the score above which a risk is flagged *Above Appetite*.



Risk appetite settings

Check the appetite value. The default appetite value is higher than the largest score of the default 5 × 5 matrix (25). Lower it to a value inside your scale, or the flag will never appear.

Details: Risk Management › scoring model.

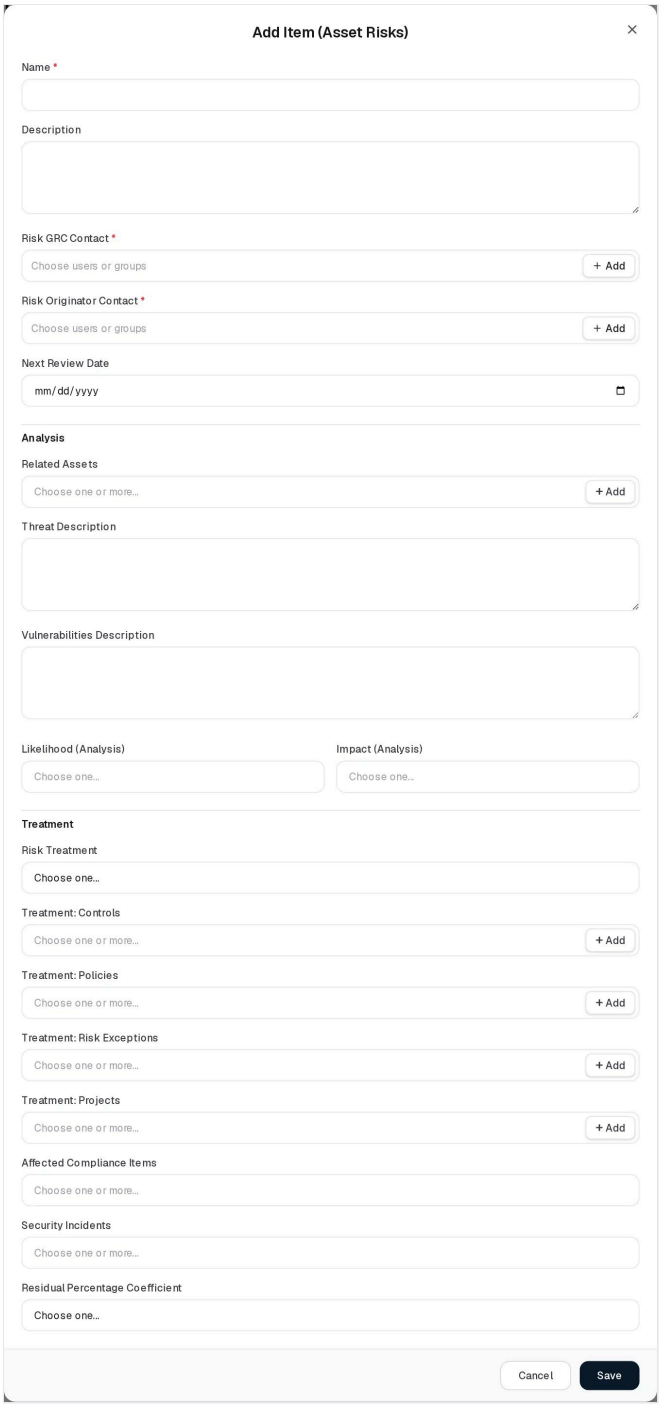
2. Find the asset

Open **Asset Management › Assets**. The risk will point to the asset, so it must exist; here *Customer database*.

If it is missing, add it there, or create it from the risk form with **+ Add** in the **Related Assets** field.

3. Add the risk and analyse it

In **Risk Management › Asset Risks** click **Add Item**.



Add an asset risk

Field	Example
Name *	Unauthorized access
Description	Unauthorized access to the customer database through compromised admin credentials.
Risk GRC Contact *	Alex Meian
Risk Originator Contact *	Sara Johnson
Next Review Date	in 30 days
Related Assets	Customer database
Threat Description	Credential theft, password reuse
Vulnerabilities Description	Admin accounts without MFA

Field	Example
Likelihood (Analysis)	Likely
Impact (Analysis)	Critical

The score. On **Save**, GRC360 calculates the inherent score: Likely (4) × Critical (5) = **20**.

4. Decide the treatment

In the **Treatment** part of the form choose **Risk Treatment**:

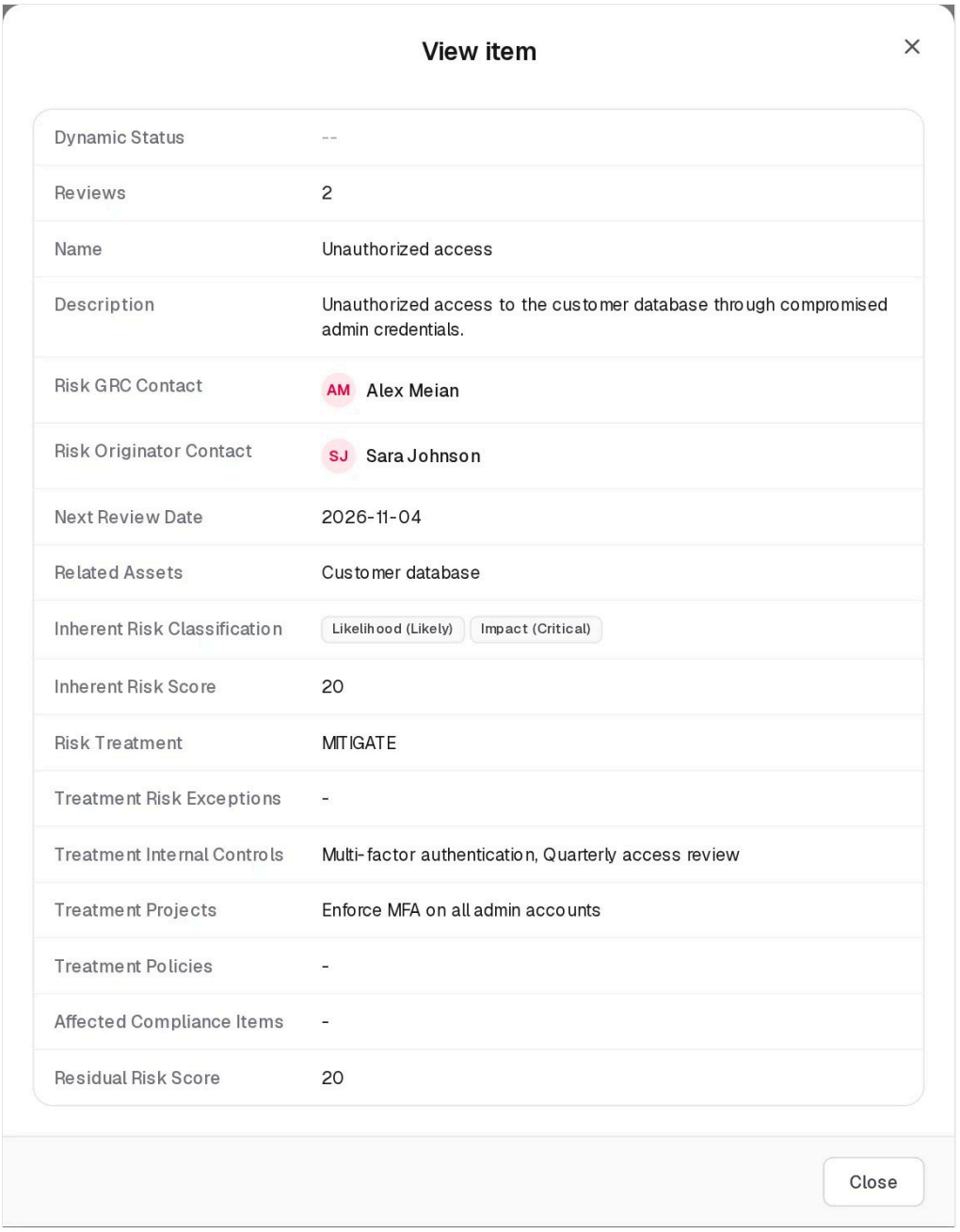
Treatment	Use when
Mitigate	You will reduce the risk with controls, policies or projects.
Accept	The risk is within appetite, or it costs more to treat than to bear. Record a risk exception (step 8).
Transfer	Someone else carries it, for example an insurer or a supplier.
Avoid	You stop the activity that causes it.

5. Link what carries the treatment out

- **Treatment: Controls**: *Multi-factor authentication*, *Quarterly access review*.
- **Treatment: Policies**: *Access Control Policy*.
- **Treatment: Projects**: a project for the work still to do. Use **+ Add** to create *Enforce MFA on all admin accounts* without leaving the form.
- **Residual Percentage Coefficient**: how much of the risk remains after the treatment. The residual score is calculated from it on save.

After saving:

- the control shows the risk in its **Asset Risks** count;
- the project shows it in its **Asset Risks** count;
- the policy shows it in **Asset Risks Treatment**.



The risk with its treatment

6. Link the requirements the risk affects

In **Affected Compliance Items**, pick the framework requirements this risk puts at stake, for example *A.8.5 Secure authentication*.

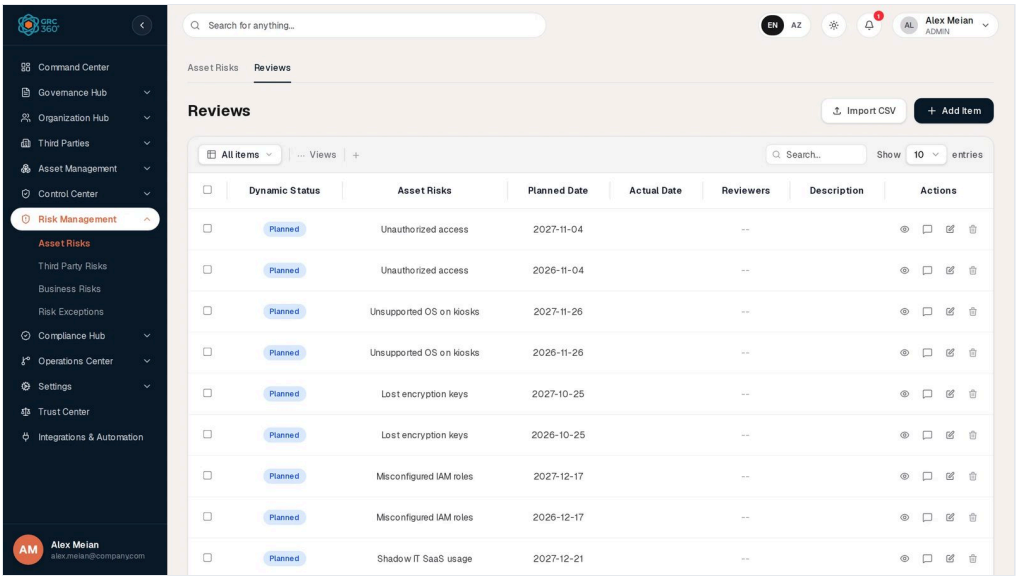
Effect on Compliance Analysis. When you save, the analysis rows for those requirements are updated:

- **Not Compliant** while any linked risk is above appetite;
- **Compliant** otherwise;
- rows marked *Not Applicable* are not changed.

See Compliance Analysis.

7. Keep it under review

- **Next Review Date** sets when the risk is due for review.
- Once that date passes, the risk's Dynamic Status shows **Review Expired**. No job needs to run for this.
- Record each review on the **Reviews** tab, with planned and actual dates, reviewers and a description.



Risk reviews

8. If you accept the risk

Open **Risk Management › Risk Exceptions** and click **Add Item**. Fill in:

- the reason;
- the requester and the contact;
- start and expiry dates;
- the related risks.

The exception appears in the risk's treatment.

After the expiry date, the exception's Dynamic Status shows **Expired**. Its stored status is not changed automatically in this release. See Risk Exceptions.

9. Follow up

Where	What to watch
Command Center	The **Asset Risks** heat map: the risk sits in the *Critical* × *Likely* cell
Projects	Progress of the treatment project's tasks; the **Expired Tasks** view
Controls	Audits of the treating controls
The risk's **Activity Log**	Who changed the score, treatment or owners, and when

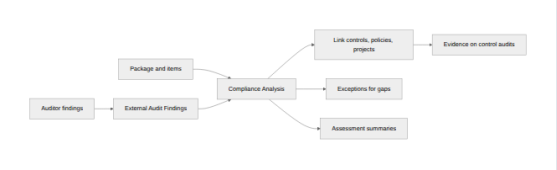
Things to know

- **Recalculation.** Scores are recalculated when the risk is saved. Changing the scales or the method later does not update existing risks until each is saved again.
- **Approving exceptions.** Risk exceptions can be submitted, approved and denied only through the API in this release. The form's status field offers **Open** and **Closed**.
- **The rest.** See the full list of limitations under Asset Risks.

Scenario: preparing for an ISO/IEC 27001 audit

Goal. Know, requirement by requirement, how the organisation meets ISO/IEC 27001, what evidence supports it, and what is still open, before the certification auditor arrives.

Who. The compliance manager, with **Manage** on Compliance Hub and **View** on Controls, Policies and the risk registers.

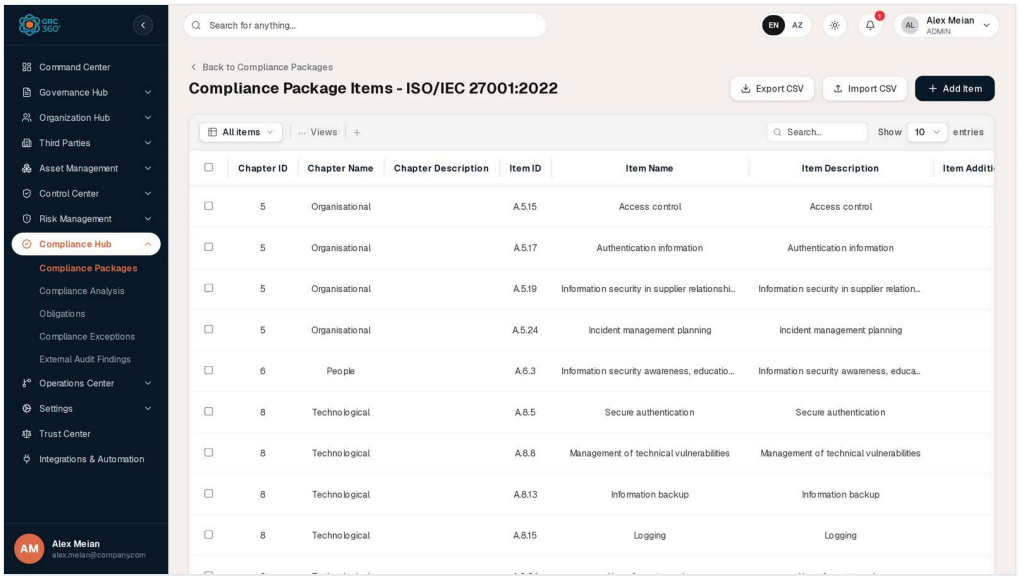


1. Create the package and its requirements

GRC360 does not ship the text of ISO/IEC 27001; you enter the requirements you are assessed against.

1. Open **Compliance Hub › Compliance Packages** and click **Add Item**. Name the package *ISO/IEC 27001:2022*.
2. Click the package row to open **Compliance Package Items**.
3. Add each Annex A control as an item, with:
   - **Chapter ID** and **Chapter Name**, for example *8 Technological*;
   - **Item ID**, for example *A.8.5*;
   - **Item Name**, for example *Secure authentication*.

   Alternatively, use **Import CSV** on the items page.



Compliance package items

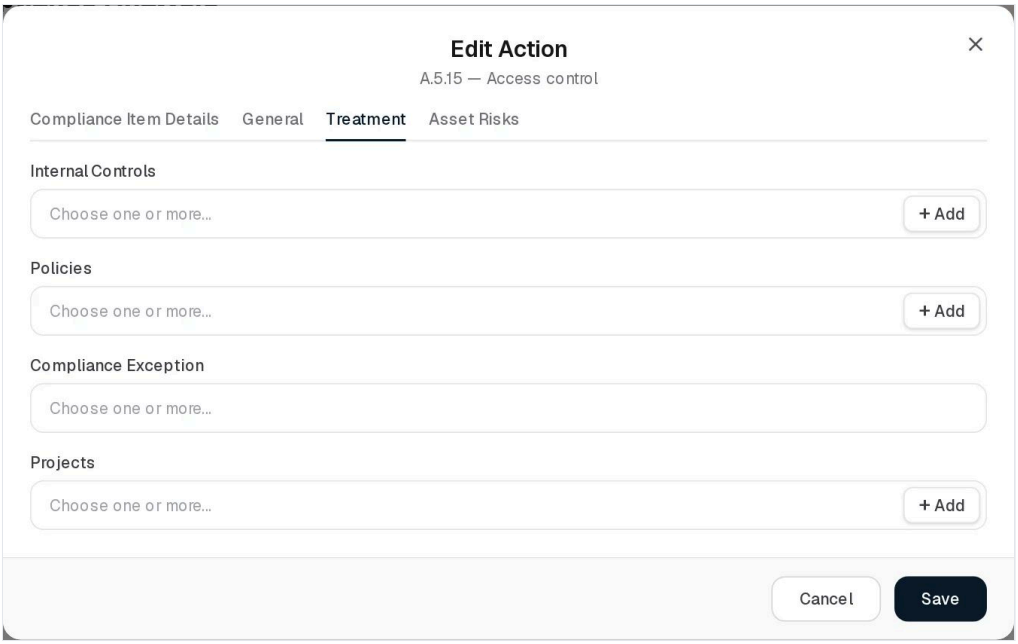
Analysis rows. Every item automatically gets a row in Compliance Analysis.

Details: Compliance Packages.

2. Assess each requirement

Open **Compliance Hub › Compliance Analysis** and choose the framework. For each row click **Edit** (*Edit Action*):

- **General**:
  - set **Compliance Strategy**: Compliant, Not Compliant or Not Applicable;
  - pick the **Owner**;
  - link any **Findings**.
- **Treatment**: link the **Internal Controls**, **Policies** and **Projects** that meet the requirement, and any **Compliance Exception**.
- **Asset Risks**: link the risks that put this requirement at stake.



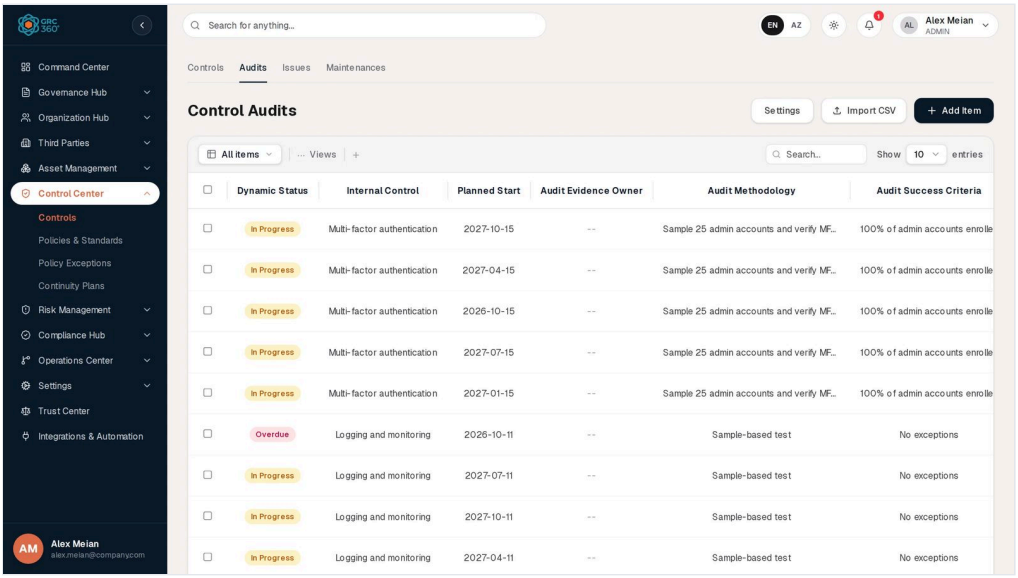
Edit Action, Treatment tab

Links back to the package. A control or policy you link here gets *ISO/IEC 27001:2022* added to its **Compliance Package** field. That is how the Controls register shows which framework each control serves.

3. Make sure each control has evidence

For each linked control, open **Control Center › Controls** and check its **Audits** tab:

- Each audit holds its methodology, success criteria, dates, result and evidence file.
- The audit schedule comes from the control's audit settings: specific dates, or periodic from a first date.



Control audits

Expiry warnings. In Compliance Analysis, a row whose control's last audit has expired, or whose linked risk's review has expired, shows an amber warning in **Dynamic Status**.

Recording results. Audits cannot be set to Completed from the form in this release. See Controls for how results are recorded today.

4. Handle the gaps

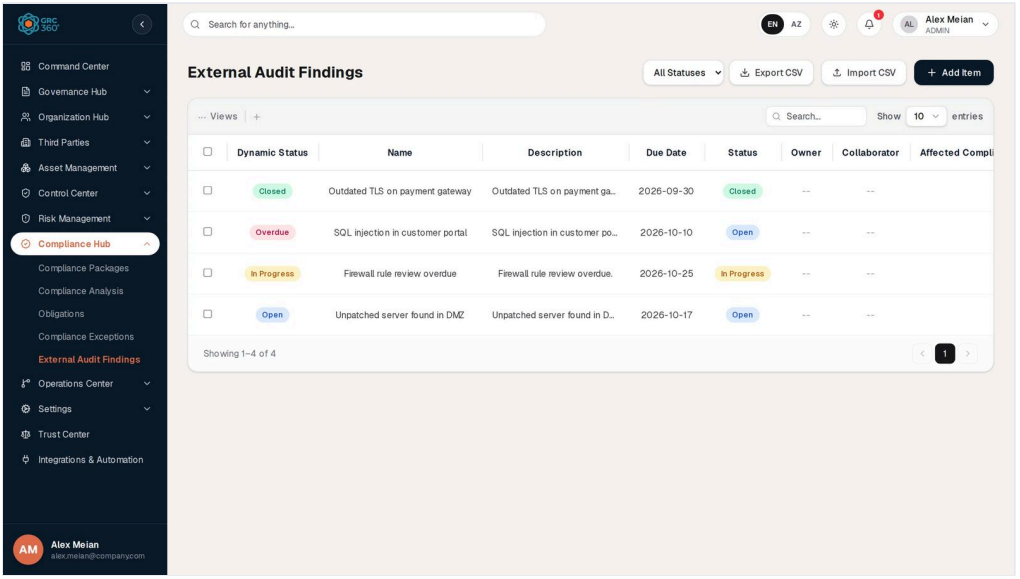
Gap	What to record
The requirement is met only partly and a fix is planned	A **Project** linked on the Treatment tab, with tasks and a deadline
The requirement cannot be met for now and the risk is accepted	A **Compliance Exception** with requester, GRC contact and expiry date (Compliance Exceptions)
A policy is missing or out of date	A policy in Policies & Standards, with its review date
The requirement does not apply	**Compliance Strategy: Not Applicable**, which leaves it out of the percentage

5. Record what the auditor finds

For each finding the auditor raises, open **Compliance Hub › External Audit Findings** and click **Add Item**. Fill in:

- the name and description;
- the due date and status;
- the owners;
- the affected requirement items.

Attach the auditor's report with the **Evidence attachments** button on the row.



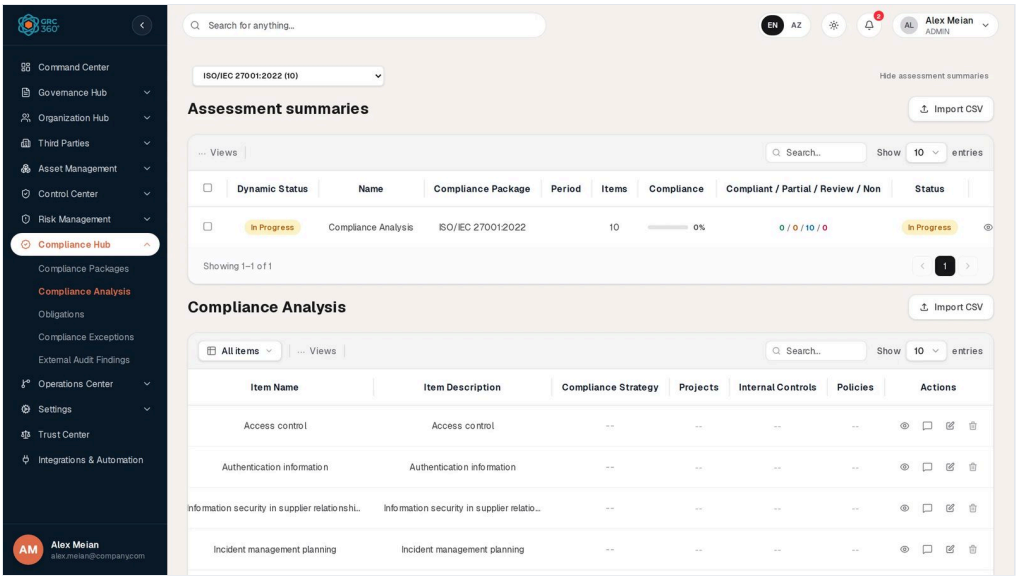
External audit findings

Overdue findings. A finding past its due date and not closed shows **Overdue** in Dynamic Status.

6. Check readiness

In Compliance Analysis click **Assessment summaries**. It shows, per assessment:

- the compliance percentage;
- the counts of Compliant, Partial, Review and Non-compliant rows.



Assessment summaries

Sharing with customers. The Trust Center shows your posture to customers and partners.

7. For the auditor

Auditors usually ask how a control was tested, by whom and when. Point them to:

- **Compliance Analysis**, filtered to the framework: one row per requirement with its controls, policies and status;
- each control's **Audits** tab and **Activity Log**: who did what, and when;
- System Log (administrators): every action in the tenant;
- **Export CSV** on the registers that offer it, for the auditor's own sampling.

A read-only **Auditors** group (first-time setup) lets the auditor look for themselves.

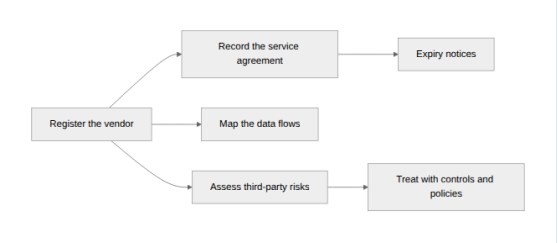
Scenario: onboarding a new vendor

Goal. Before a new supplier receives your data or runs one of your services:

- register the supplier;
- record the contract;
- assess the risk it brings;
- link it to the assets and data it touches.

Example. An identity provider, *Okta*.

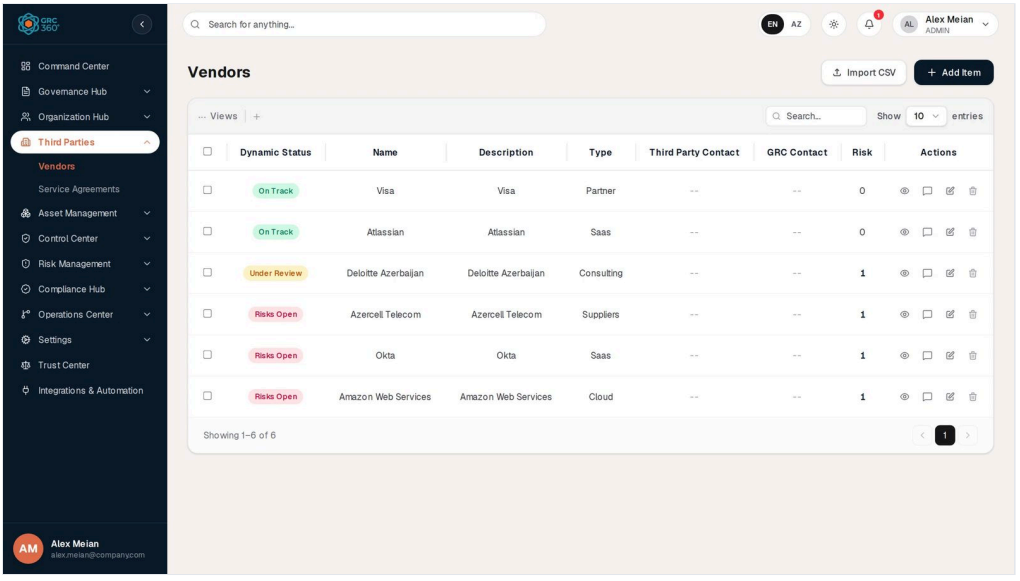
Who. The vendor manager, with **Manage** on Third Parties. Risk owners need **Manage** on Third Party Risks.



1. Register the vendor

Open **Third Parties › Vendors** and click **Add Item**:

Field	Example
Name *	Okta
Description	Workforce identity and single sign-on
GRC Contact *	Alex Meian, who is responsible for the vendor in your GRC programme
Third Party Contact *	Sara Johnson, who manages the relationship day to day
Type *	Suppliers



Vendors

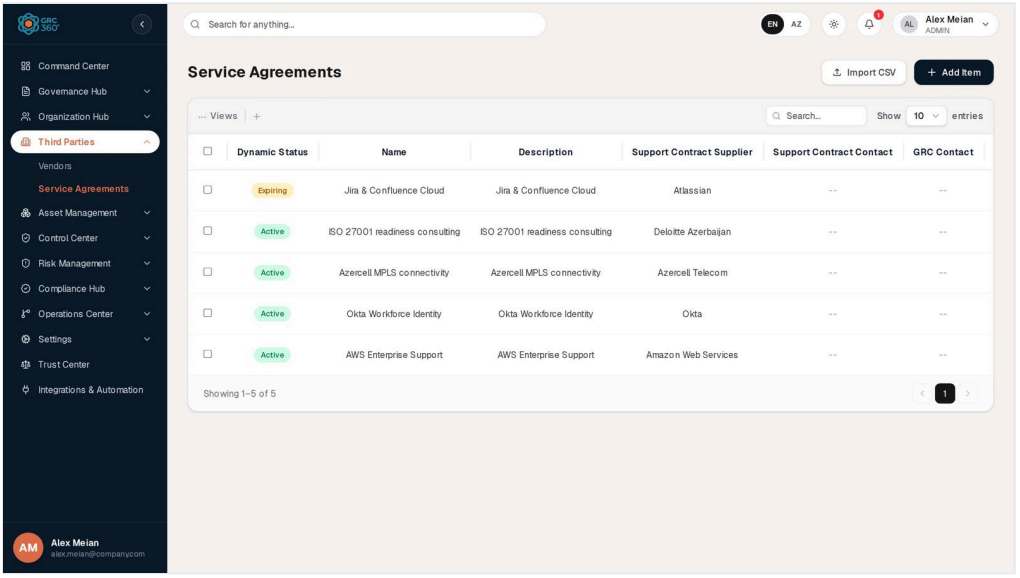
The vendor's Dynamic Status. Shown in the vendor list, it tells you at a glance where the vendor stands:

- **Risks Open** as soon as any third-party risk names the vendor;
- **On Track** when none does;
- **Under Review** or **Inactive** from its stored status.

2. Record the service agreement

Open **Third Parties › Service Agreements** and click **Add Item**:

Field	Example
Name *	Okta Workforce Identity
GRC Contact * / **Support Contract Contact** *	Alex Meian / Sara Johnson
Support Contract Supplier *	Okta. If the vendor does not exist yet, **+ Add** creates it without leaving the form.
Service Value *	The yearly contract value
Start Date * / **End Date** *	The contract term



Service agreements

Expiry notices. Before the agreement ends, its GRC and support-contract contacts are notified three times:

- 7 days before the end date;
- 3 days before;
- on the end date itself.

Dynamic Status. The agreement shows **Expiring** for its last 30 days and **Expired** afterwards.

3. Map the data the vendor receives

If the vendor processes your data, record it in **Asset Management › Data Flows**:

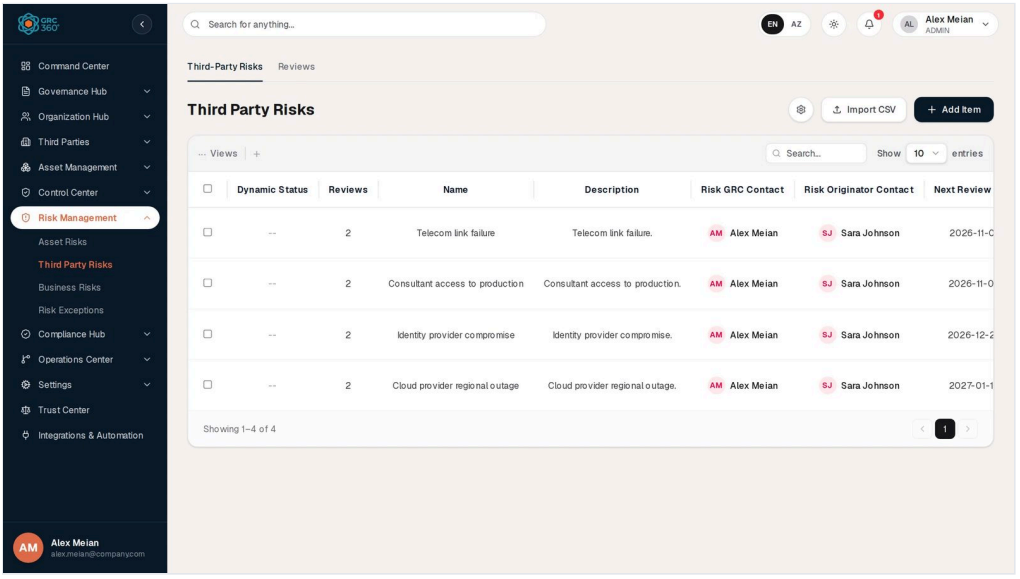
- the asset the data comes from, for example *HR system (BambooHR)*;
- the vendor as third party;
- source and destination;
- classification and encryption;
- the GDPR questions.

See Data Flows.

4. Assess the third-party risks

Open **Risk Management › Third Party Risks** and click **Add Item**. One vendor can bring several risks:

Field	Example
Name *	Identity provider compromise
Applicable Third Parties	Okta
Assets Shared with this Third Party	Customer database
Likelihood / Impact	Unlikely / Critical
Risk Treatment	Mitigate
Treatment: Controls	Vendor due diligence
Treatment: Policies	Vendor Management Policy
Next Review Date	in 90 days



Third party risks

The vendor's **Risk** count now shows the risk. The count is clickable.

5. Keep the vendor under review

- **Review the risks.** Record each review on the risk's **Reviews** tab. Once **Next Review Date** passes, the risk shows *Review Expired*.
- **Renew or end the agreement** before its end date. The expiry notices remind the contacts.
- **Record problems.** Use the vendor's **Activity Log** for due-diligence evidence and correspondence, for example questionnaires and certificates.

Things to know

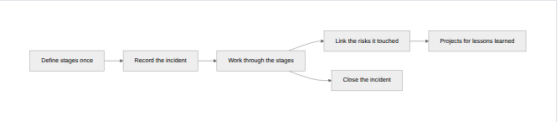
- **Type and status.** The vendor form offers three types: **Customers**, **Regulators** and **Suppliers**. It has no status field.
- **Agreement status.** Service agreements are stored as **Active** from creation. Their stored status does not change by itself in this release, but their Dynamic Status does.
- **The rest.** See Vendors and Service Agreements.

Scenario: handling a security incident

Goal. Record a security incident as soon as it is known, move it through your response stages, link it to the risks it touched, and follow up the improvements it calls for.

Example. A phishing campaign targets the finance team.

Who. The incident handler, with **Manage** on Operations Center › Security Incidents and its Stages tab. Risk owners update the risk registers.



1. Define your response stages (once)

1. Open **Operations Center › Security Incidents** and switch to the **Stages** tab.
2. Open the Settings for stages and add the stages your incident response follows, each with a **Name** and **Description**.

A typical lifecycle:

Stage	Purpose
Detection	Identify and confirm the incident
Containment	Limit the impact
Eradication	Remove the cause
Recovery	Restore normal operation
Lessons learned	Post-incident review

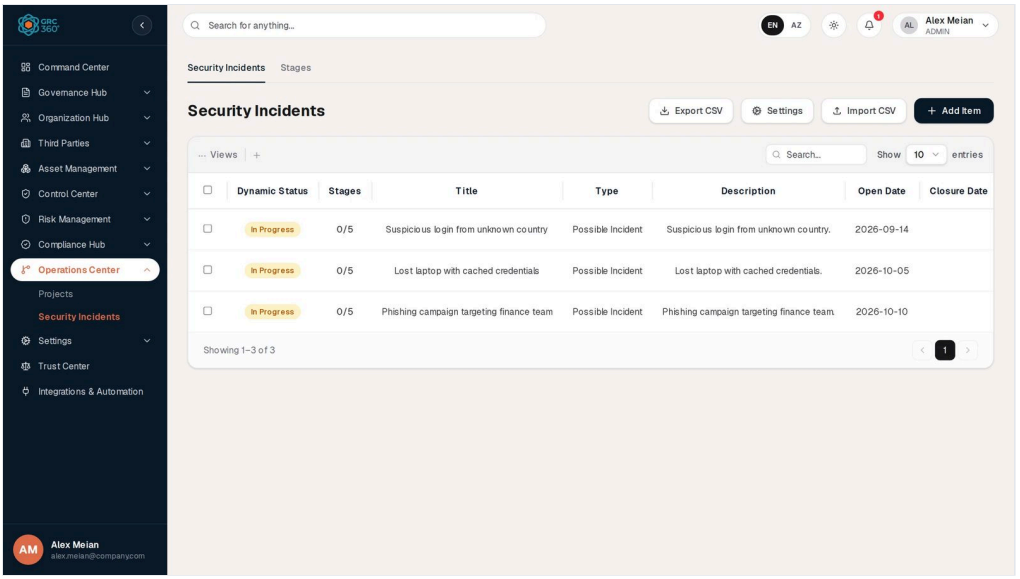
Every incident then gets these stages to work through.

Details: Security Incidents › Stages.

2. Record the incident

On the **Security Incidents** tab click **Add Item**:

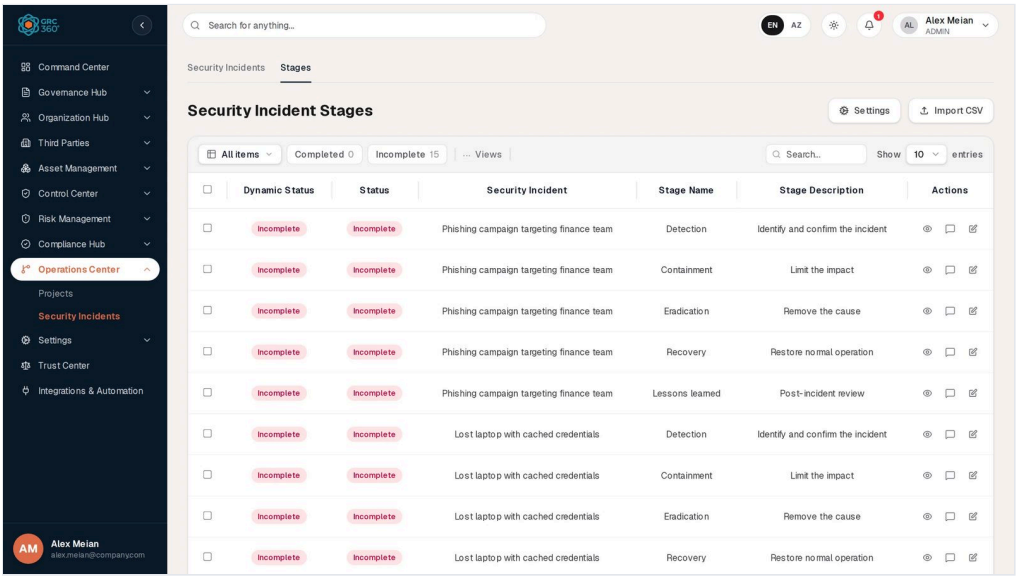
Field	Example
Title *	Phishing campaign targeting finance team
Description	What happened and what is known so far
GRC Contact *	Alex Meian
Incident Contact *	Sara Johnson
Open Date *	The day it was discovered (it cannot be in the future)



Security incidents

3. Work through the stages

On the **Stages** tab, each incident's stages are listed with their status. Update the status of each stage as the response progresses, for example Detection to complete and Containment to in progress.



Incident stages

Follow-up for the whole team.

- On the **Stages** tab, the **Incomplete** and **Completed** chips show how many stages are still open across all incidents.
- The **Activity Log** on the incident is the place for the running record: notes, decisions and attached evidence such as e-mail headers and screenshots.

4. Link the risks the incident touched

The incident form has no risk field; the link is made from the risk:

1. Open the affected risk. Here that is the asset risk *Phishing credential theft*, but third-party and business risks work the same way.
2. In **Security Incidents** on the risk form, pick the incident.
3. Consider whether the incident changes the risk's **Likelihood (Analysis)**.

The incident then shows the risk in its **Known Asset Risk** (or **Known Third Party Risk** / **Known Business Risk**) count. The count is clickable, and gives a quick view of how often each risk materialises.

5. Turn lessons learned into projects

For each improvement the review calls for:

1. Create a project in **Operations Center › Projects**, with tasks, owners and deadlines.
2. Link it from the risk's **Treatment: Projects**.
3. If the incident revealed a control weakness, record an **Issue** on that control in **Control Center › Controls › Issues**.

6. Close the incident

Edit the incident and set **Status** to **Closed**. The **Closure Date** is filled in with today's date automatically.

Things to know

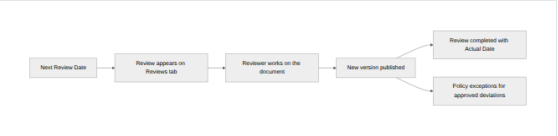
- **No notifications.** Incidents do not send notifications in this release. Agree on how the team is alerted, for example by e-mail or chat, and use the incident record as the system of record.
- **Bulk import.** Import CSV works on Security Incidents and on the stage definitions (in the incidents' Settings) for bringing in a backlog. Stage rows of an incident cannot be imported. See CSV import and export.
- **Limitations.** See Security Incidents.

Scenario: the annual policy review

Goal. Review each policy when it falls due, publish the new version, and handle approved deviations.

Example. The *Access Control Policy*.

Who. The policy owner (named in **GRC Contact**) and the reviewer (named in **Policy Reviewer Contact**), with **Manage** on Control Center › Policies & Standards and its Reviews tab.

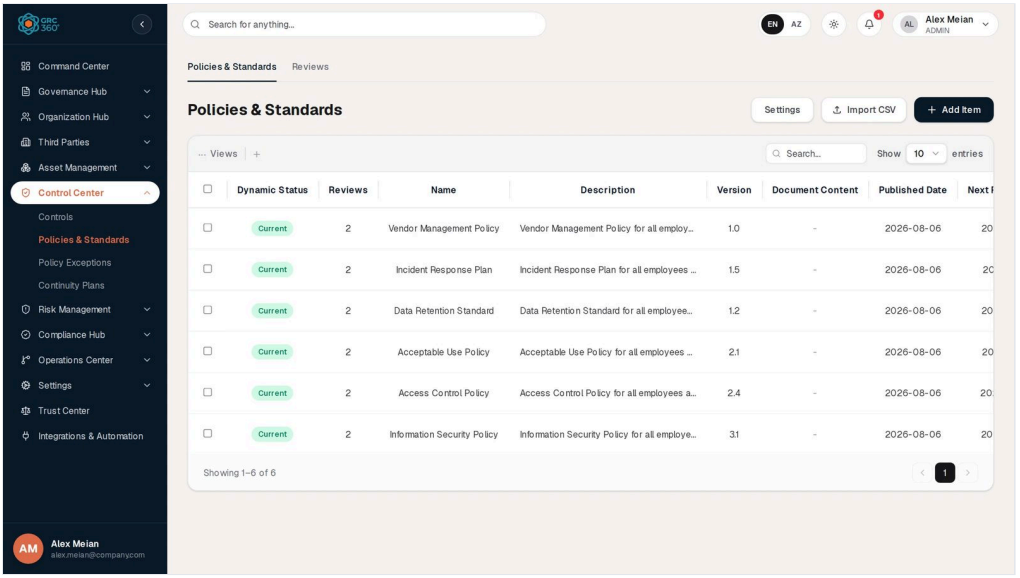


1. Know what is due

Next Review Date. Each policy has one. GRC360 creates the planned review rows on the **Reviews** tab from it.

Overdue policies. Once the date has passed, the policy's Dynamic Status shows **Needs Review** until the Next Review Date is moved forward.

Finding due policies. Open **Control Center › Policies & Standards** and sort by **Next Review Date**.



Policies & Standards

2. Review the document

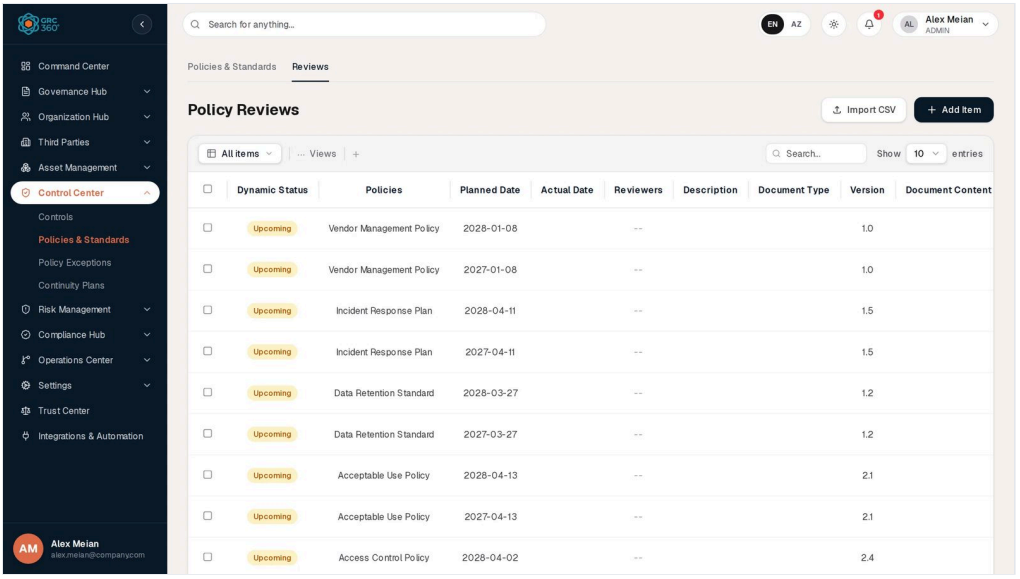
1. Open the policy with **Edit**.
2. Make the changes to the document. The **Document Content** field holds one of:
   - text written in GRC360;
   - a URL link;
   - an attached file.
3. Raise the **Version**, for example from 2.4 to 2.5.
4. Set **Published Date** and keep the status **Published**, or set it to **Draft** while it is being approved.
5. Move **Next Review Date** forward, usually by a year. This clears *Needs Review* and plans the next review.

Use the policy's **Activity Log** for review comments and the approver's decision. Its history shows exactly which fields changed.

3. Record the review

On the **Reviews** tab open the planned review, or click **Add Item**, and fill in:

Field	Example
Planned Date	The due date
Actual Date	The day the review was completed. Filling it completes the review.
Reviewers	Sara Johnson
Version	2.5
Description	What changed and why



Policy reviews

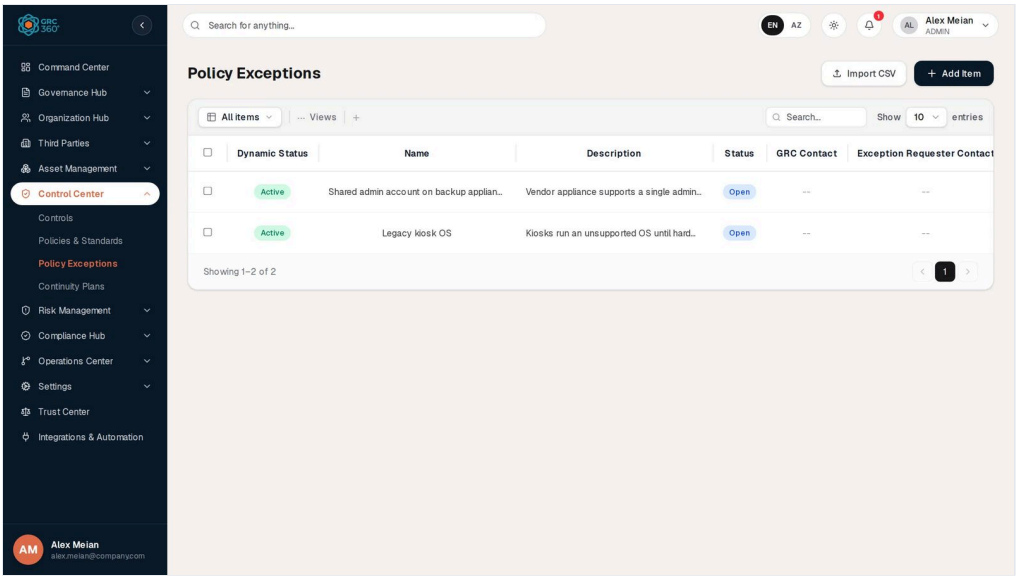
4. Check the controls behind the policy

A policy is carried out by controls. The policy's **Internal Controls** column lists the controls that name it in **Related Policies**. If the new version changes what is required, check those controls and their audit criteria.

5. Approve deviations

When a team cannot follow the policy for a while, record a **Policy Exception** in **Control Center › Policy Exceptions**:

- name and description;
- requester and contact;
- the expiration date (GRC360 sets the start date itself);
- the related policy.



Policy exceptions

From the day after its expiration date, the exception's Dynamic Status shows **Expired**.

Details: Policy Exceptions.

Things to know

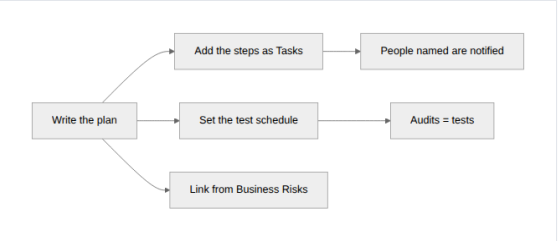
- **Attachments on reviews.** Files attached to a review are not kept in this release. Attach supporting files to the policy's **Activity Log** instead.
- **Exception status.** The policy exception form offers only **Open** and **Closed**, and its Dynamic Status reads *Pending* for open exceptions.
- **The rest.** See Policies & Standards.

Scenario: business continuity planning and testing

Goal. Write a recovery plan with clear steps, tell the people involved what they must do, test the plan on a schedule, and link it to the business risks it mitigates.

Example. The plan *Ransomware recovery*.

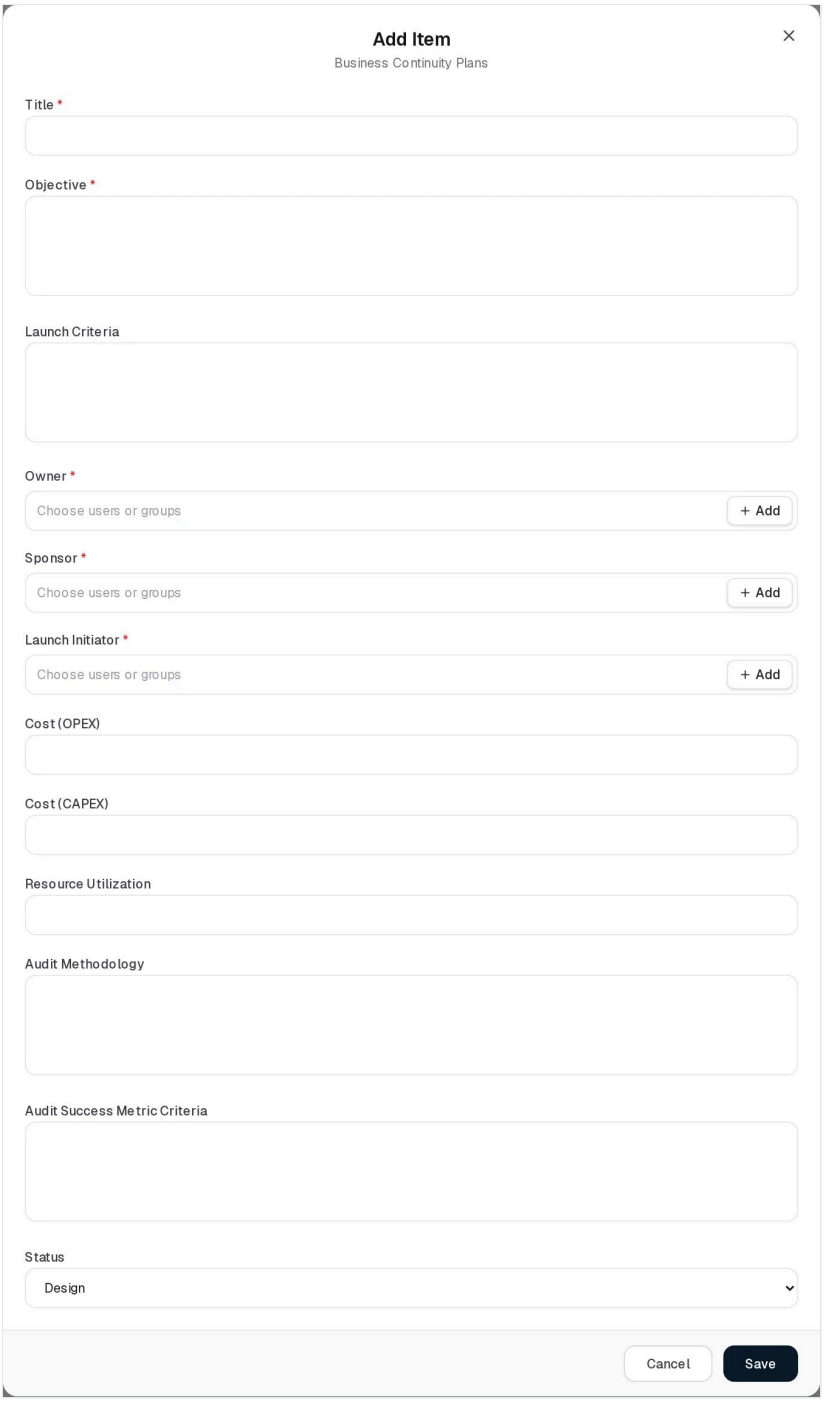
Who. The continuity manager, with **Manage** on Control Center › Continuity Plans and its Audits and Tasks tabs.



1. Write the plan

Open **Control Center › Continuity Plans** and click **Add Item**:

Field	Example
Title *	Ransomware recovery
Objective *	Recover core systems from immutable backups within 24 hours.
Launch Criteria	Core systems encrypted or unavailable
Owner * / **Sponsor** * / **Launch Initiator** *	Alex Meian / Sara Johnson / Alex Meian
Cost (OPEX) / **Cost (CAPEX)**	12000 / 40000
Status	**Design** while it is written, **Production** once it is in force



Add a continuity plan

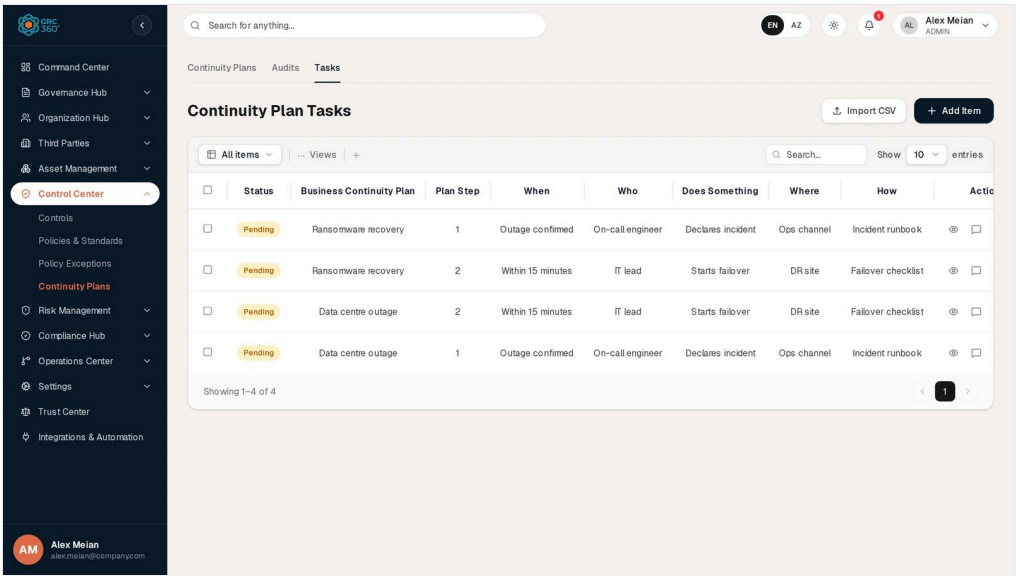
2. Add the steps

On the **Tasks** tab add one task per step:

Field	Meaning
Plan Step	The order, for example 1, 2, 3
When	The trigger, for example *Outage confirmed*
Who	The role that acts
Does Something	The action
Where	The location or channel
How	The runbook to use

Field	Meaning
Awareness Role	The people and groups who must know about this step

Notifications. Everyone newly named in **Awareness Role** receives a notification, *"You are named in a continuity plan task"*, with a link to the task. Groups are expanded to their members.



Continuity plan tasks

3. Schedule the tests

In the plan's audit settings:

1. Switch audits on.
2. Choose **Specific** dates or **Periodical** with a first date and a frequency, for example *Twice a Year*.
3. Fill in the **Audit Methodology** and **Audit Success Metric Criteria**, for example *Tabletop exercise and failover test* and *RTO met*.

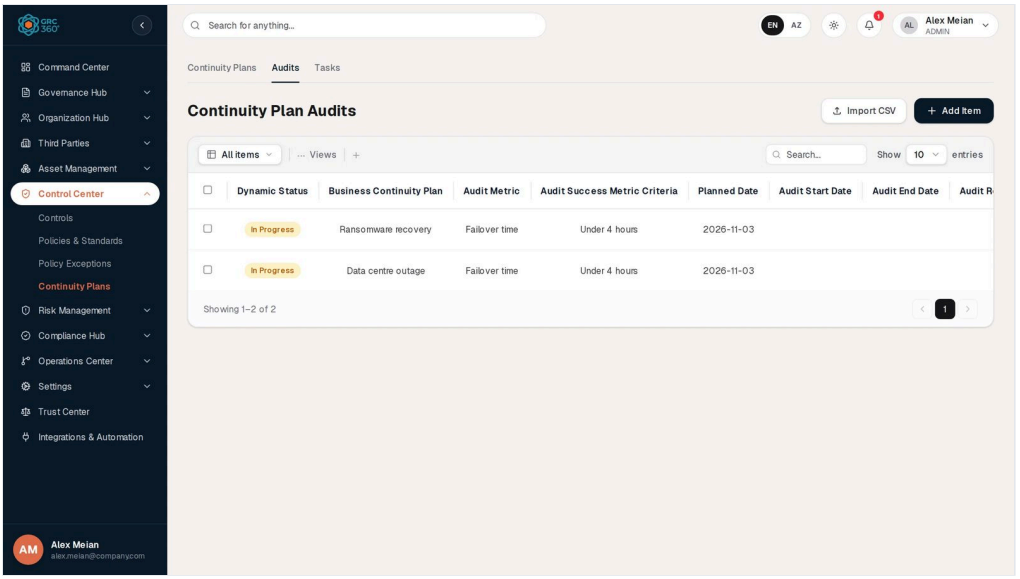
Planned audits. When the plan is saved in **Production**, GRC360 creates the planned audits on the **Audits** tab.

4. Record each test

On the **Audits** tab open the planned audit and fill in:

- **Audit Start Date**: makes the audit *In Progress*;
- **Audit End Date**: makes it *Completed*;
- result and conclusion;
- audit owner;
- the evidence file.

If the success criteria change, edit them on the audit. The plan's criteria are updated too, so future tests use the new criteria.



Continuity plan audits

5. Link the plan to the risks it mitigates

In **Risk Management › Business Risks**, open each business risk the plan addresses and pick the plan in **Mitigating Business Continuity Plans**, for example *Key supplier outage* or *Office power failure*.

Things to know

- **Required people.** Owner, Sponsor and Launch Initiator are required when saving from the form.
- **Deleted audits come back.** Deleting a generated audit from the tab re-creates it the next time the plan is saved, because the schedule still contains its date. Change the schedule instead.
- **The rest.** See Continuity Plans.

Part 4 — Administration

Administration guide

This part of the guide is for the people who set up and run GRC360 for an organisation: who gets an account, what each group may do, how people sign in, which e-mails, webhooks and notifications the system sends, how sessions are controlled, and how to keep the system healthy. It describes the October 2026 release exactly as built; where a screen offers something the server does not yet do, the page says so.

Most administration happens in two places:

- **Organization Hub** (Users, Departments, Groups): who exists and what they may do. Groups can be delegated to non-administrators who hold the right to manage access.
- **Settings** (Authentication, About System, System Health, Updates, System Log, Clear Data): the system's own configuration. Settings is reserved to the built-in **Admin** group and cannot be delegated. See Settings.

Some configuration lives on the server rather than in the product (the mail relay, session lifetimes, the super-admin list, the accounts kept by a data reset). Those settings are named in these pages so that an administrator knows what to ask the server operator for.

Pages

#	Page	Covers
1	Users, groups and permissions	Creating and importing users, invitations, built-in and custom groups, the access matrix, additional permissions, the access request queue
2	Authentication and SSO	Local sign-in, LDAP / Active Directory, OAuth and SAML connectors, step by step
3	E-mail, webhooks and notifications	SMTP relay and test, webhooks, every notification type and when it fires, every scheduled job and whether it runs
4	Sessions and security	Session lifetime, idle timeout, token refresh, active sessions, signing users out, login throttling
5	System maintenance	System Health, Updates, System Log, Clear Data, backups

First tasks for a new organisation

1. Sign in with the administrator account you were given and open **Settings › About System** to note the version.
2. Create departments, then users (page 1).
3. Decide which built-in group each person needs, or create custom groups with the access matrix (page 1).
4. If staff should use their directory password, configure an LDAP connector (page 2).
5. Ask the server operator to configure the mail relay and test it (page 3).
6. Remove demo or trial data with **Settings › Clear Data** before going live (page 5).

Users, groups and permissions

This page explains how to give people access to GRC360 and control what they can do: creating and importing users, the built-in and custom groups, the access matrix, individual additional permissions and the access-request queue. Field-by-field reference for the screens is in Organization Hub › Users and Organization Hub › Groups; how permissions look to an ordinary user is in Permissions and access.

How access is built

Concept	Meaning
User	A person in Organization Hub › Users. Creating a user also creates their sign-in account with the same e-mail and password.
Group	A set of permissions (labelled “Groups” in the sidebar; the route and permission keys still say `roles`). A user’s rights are the union of all their groups plus any active additional permissions. There is no “deny”.
Unit	Each page and each tab of a page is a separate unit with its own access level (for example Risk Management › Asset Risks, and its Reviews tab).
Access level	Per unit: **No Access**, **View**, **Manage** or **Full Control** (see below).
Additional permission	One permission granted to one user on top of their groups, optionally for a limited time.
Access request	A request a user sends from a locked button; an administrator approves or rejects it.

Changes to groups, memberships and grants reach users who are already signed in within about 10 seconds, without signing in again.

Built-in groups

Every organisation has three built-in groups. They cannot be deleted.

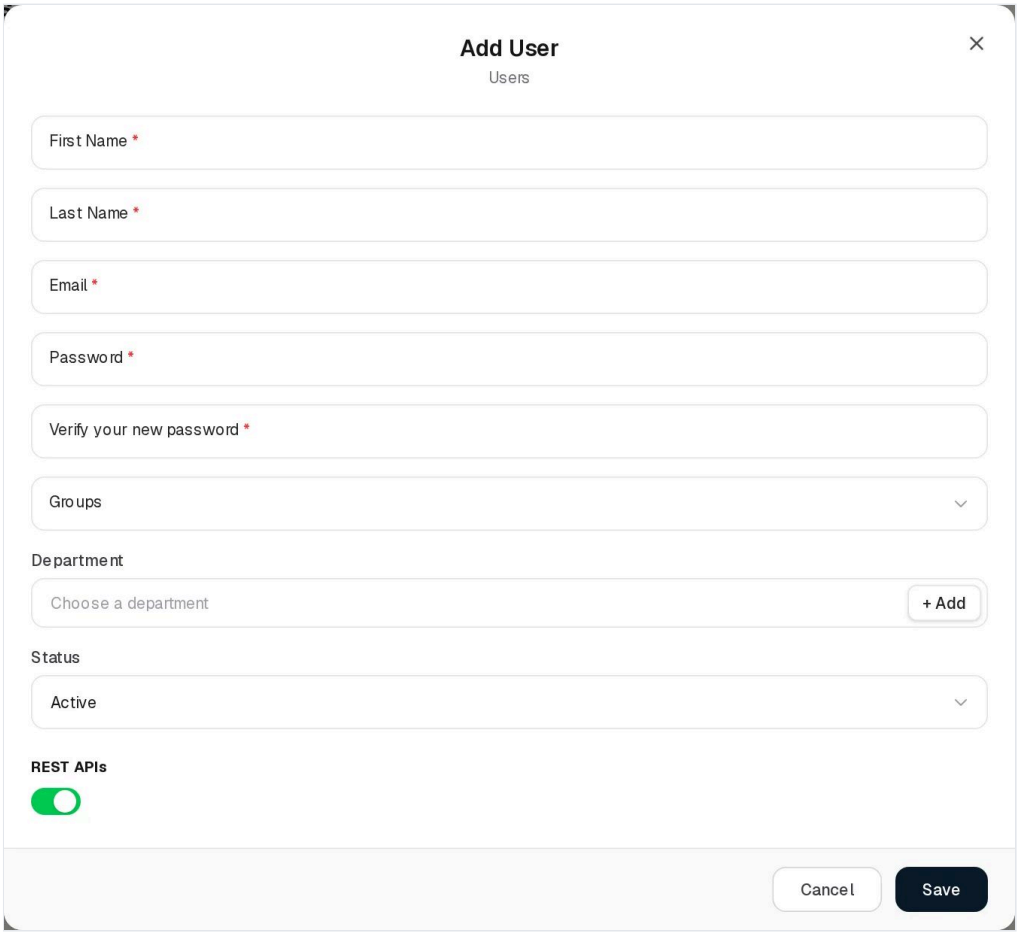
Group	Starts with	Data visibility	Notes
Admin	Every permission, including Settings	All Records	Locked: its permissions cannot be edited. Only an administrator can add someone to it or remove someone from it. At least one Admin must remain: removing the last one fails with “Cannot remove the Admin role. At least 1 Admin must remain in the system.”, deleting the last one with “Cannot delete the last Admin. At least 1 Admin must remain in the system.”
Read Only	Read (View) on every page and tab except Settings	All Records	Suitable for auditors and observers.
Third Party	Only Third Parties › Vendors, Third Parties › Service Agreements, Risk Management › Third Party Risks and Compliance Hub › Compliance Analysis	Assigned Records Only (own records)	For external contacts. No dashboard, no Organization Hub, no Settings.

Only the exact **Admin** group (or its earlier name **Administrator**), the system role ADMIN given to accounts by the server, and super-admin accounts listed in the server setting `SUPER_ADMIN_EMAILS` count as administrators. A custom group whose name contains “admin” does not.

Provisioning users

Adding one user

1. Open **Organization Hub › Users** and click **Add Item**. The **Add User** dialog opens.



Add User dialog

2. Fill **First Name**, **Last Name** and **Email** (all required; the e-mail must look like an address and must not already exist: “User with this email already exists”).
3. Enter **Password** and **Verify your new password**. The password must be at least 8 characters (“Password must be at least 8 characters”) and both must match (“Passwords do not match”).
4. Choose one entry in **Groups**. The field takes a single group, although a user can belong to several (see known issues).
5. Optionally choose a **Department** (use **+ Add** to create one on the spot), keep **Status Active**, and leave **REST APIs** as it is (the switch is stored but not enforced).
6. Click **Save**. Give the person the address of the site, their e-mail and the password through a secure channel. There is no “send credentials” e-mail.

The same dialog opens from the **+ Add** button of every person picker in the product, so a contact can be created while filling in another record.

Changing or deactivating a user

- **Edit** opens **Edit User**. **New password (optional)** sets a new password; leave it blank to keep the current one.
- Setting **Status** to **Inactive** stops the person signing in. Their open sessions end at the next token refresh (within 15 minutes) with the reason “Account deactivated”; to end them at once, use **Settings › Authentication › Active Sessions** and sign the user out.
- **Delete** removes the user and their sign-in account permanently. Records that name the person keep the name as text. The last Admin cannot be deleted.

Rules the server enforces on every change of group membership:

Rule	Message when broken
Only an administrator can add someone to, or remove someone from, the Admin group	409 ADMIN_GROUP_REQUIRES_ADMIN
Nobody except an administrator can change their own groups	409 SELF_MEMBERSHIP
Only groups of your own organisation can be assigned	(other groups are ignored)

Importing users from CSV

The Users grid has a working **Import CSV**. (The toast “CSV Import (Users): the import structure is not ready yet.” may appear first; the import then runs.) The file needs a header row; column names are matched case-insensitively:

Column	Required	Meaning
`firstname`	Yes	First name
`lastname`	Yes	Last name
`email`	Yes	E-mail, must be new
`password`	No	When empty, a random 12-character password is generated and not shown to anyone
`department`	No	Department name; ignored when no department has that name
`role`	No	Name of one group; ignored when no group has that name

Values are split on commas without quote handling, so a value must not contain a comma. Imported users are Active. On success the page shows “Users imported.”; rows with errors are skipped. Users imported without a password must be given one with **Edit** before they can sign in (or sign in through LDAP).

Invitations

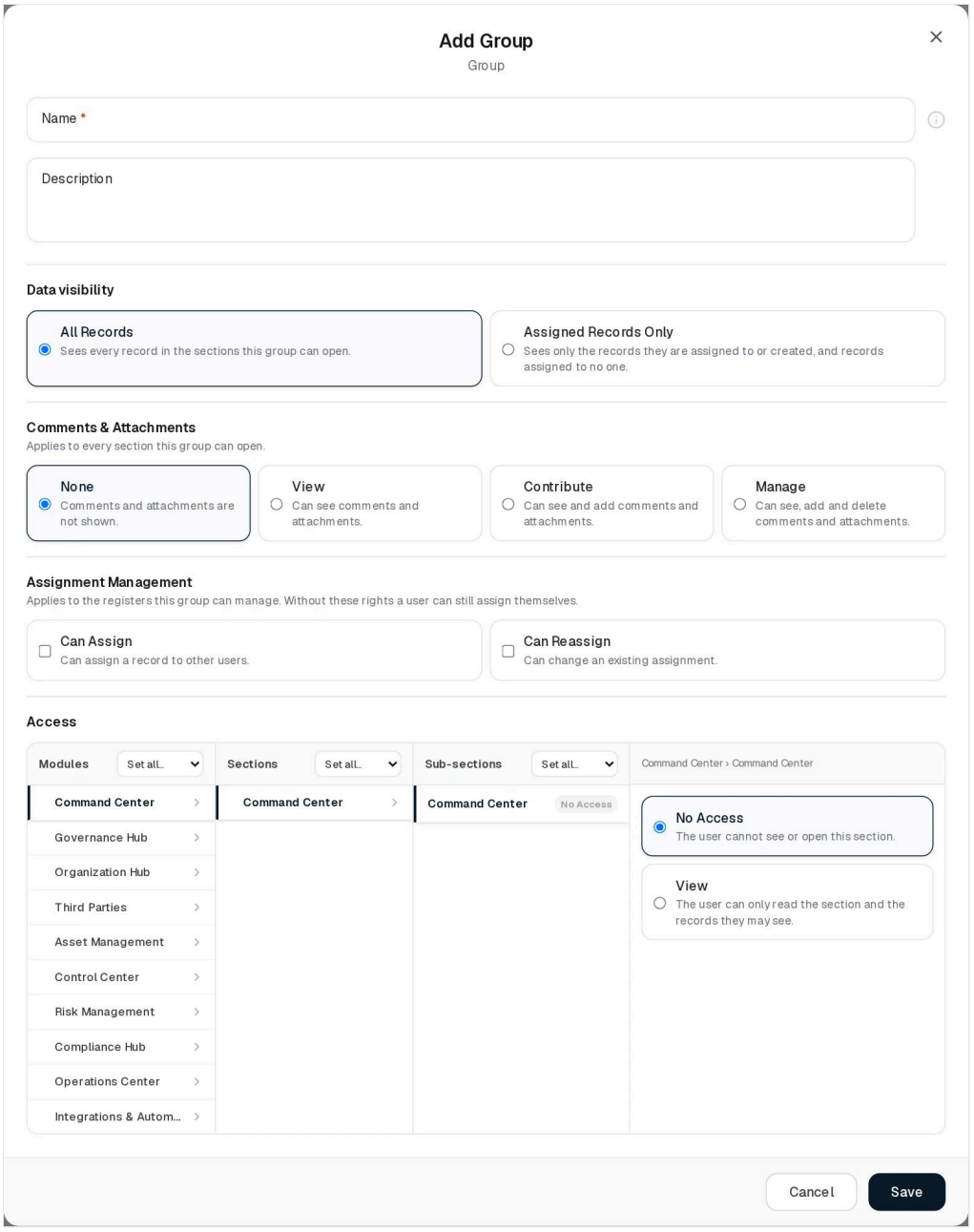
The server can create an invitation (it records the e-mail, a token valid for 7 days, and sends an e-mail “You have been invited to GRC360” with an **Accept invitation** button when the mail relay is configured). In this release:

- no screen creates invitations; it is available only to administrators through the API (`POST /api/v1/users/invite`);
- the link in the e-mail points to `/invite/{token}` , a page that does not exist in the product, so the invitee cannot complete it.

Create users with **Add Item** instead.

Groups and the access matrix

Open **Organization Hub › Groups** and click **Add Item** (or edit a group). The full field reference is on the Groups page; this section explains how administrators use it.



Add Group dialog

Part of the dialog	What to decide
Name, **Description**	How the group is recognised.
Data visibility	**All Records** (sees every record of the pages it can open) or **Assigned Records Only** (sees only records they are assigned to or created, and records assigned to no one).
Comments & Attachments	One choice for every page the group can open: **None**, **View**, **Contribute** (see and add) or **Manage** (see, add and delete).
Assignment Management	**Can Assign** (name other users on a record) and **Can Reassign** (change an existing assignment). Without them a user can still assign themselves. These apply to the registers whose assignees decide visibility: Assets, Asset Risks, Third Party Risks, Business Risks, Controls, Policies & Standards, Vendors, Service Agreements and Objectives.
Access	Four columns: **Modules**, **Sections**, **Sub-sections** and the level panel for the selected unit. Each column has a **Set all..** dropdown to apply one level to everything listed in it.

Access levels per unit:

Level	Grants
No Access	Nothing; the page is hidden from the sidebar and shows Access Denied if opened by URL.
View	Read the page and use **Export CSV** (“Section Index”, “View Reports”).
Manage	View plus create, edit, import, and record audit and maintenance results.
Full Control	Manage plus delete, the page’s settings (for example risk calculation settings) and, on Groups, managing access.

A level is offered only where it adds something: the Command Center offers only **No Access** and **View**. Setting a tab above No Access raises its page to at least View; setting a page to No Access takes its tabs with it. Existing groups whose permissions match no level show **Custom**, and differing comment or assignment rights across pages show **Mixed**; they are not changed unless you change them.

Settings never appears in the matrix: it belongs to the Admin group only.

Rules for changing a group’s permissions:

Rule	Message when broken
Changing permissions or data visibility needs **Full Control** on Organization Hub › Groups (the “Manage Access Control” right). Edit alone changes only name, description and status.	403 (Request Access dialog)
A non-administrator cannot change the permissions of a group they belong to	409 SELF_GROUP_ACCESS
A non-administrator cannot grant a permission they do not hold themselves	409 PERMISSION_NOT_HELD
Settings permissions cannot be put on any group except Admin	409 ADMIN_ONLY_PERMISSION

Additional permissions for one user

On **Organization Hub › Users**, users who hold **Full Control** on Groups see a key icon **Additional Permissions** on each row. The dialog explains: “Grants add a single permission on top of the user’s roles — the role itself does not change. Prefer a time-boxed grant; if the same access is requested repeatedly, fix the role instead.”

1. Choose the permission from **Select a permission…** (grouped by module; Settings is not offered).
2. Choose the duration: **7 days**, **30 days (recommended)**, **90 days** or **Permanent**.
3. Optionally enter a **Reason (shown in the audit trail)** (max 1000 characters).
4. Click **Grant**.

The dialog lists **Active** grants (“Until {date}” or “Permanent”, “by {name}”, the reason) with a **Revoke** button, and a **History** of revoked and expired ones. With none it reads “This user has no additional permissions.” Expiry takes effect automatically at the end date; no scheduled job is needed. You cannot grant a permission to yourself.

Access requests

When a user clicks a locked button, the **Permission Required** dialog lets them send a request with a justification (required, up to 2000 characters).

1. Every administrator receives an **ACCESS_REQUEST** notification “Access request from {name}” with the link **Review request**.
2. The link opens **Organization Hub › Groups** with the **Access Requests** queue. The **Access Requests** button on Groups shows a red count of pending requests and is visible only to users with Full Control on Groups.
3. Each request shows the requester, e-mail, Module › Page › Tab, the action, the justification and its age. Choose one of:
    - **Grant to this user only**, for **7 days**, **30 days (recommended)**, **90 days** or **Permanent** (creates an additional permission), or
    - **Add to one of their groups** (warns “N users hold this group — all of them will receive this permission”; not offered when the requester holds only built-in groups).
4. Optionally write a decision note, then click **Approve** or **Reject**.

5. The requester receives **ACCESS_APPROVED** (“Your request for … was approved”) or **ACCESS_REJECTED** (with your note). An approval unlocks the button in their open session within about 10 seconds.

Requests for Settings cannot be created or approved. The Access Denied panel shown for a whole page has no request button; users who lack a page entirely must ask an administrator directly.

Delegating user administration

A non-administrator can be given **Manage** or **Full Control** on Organization Hub › Users and Groups (for example an HR group). Such a user can create users and put them in any group except Admin, but cannot change their own groups, cannot change the permissions of a group they belong to, and cannot hand out permissions they do not hold.

Known issues

- **Groups** in the Add/Edit User dialog accepts one group. Editing and saving a user who belongs to several groups is likely to keep only the first one; manage multiple memberships carefully.
- Invitations cannot be created or accepted from the product.
- The **REST APIs** switch on a user is stored but not enforced.
- A user put in the Admin group through Organization Hub does not receive the server’s system role ADMIN. From the code, such a user sees only their own tasks on the Command Center, and several Settings screens that check that system role (Authentication, About System, System Health, Updates, System Log, webhooks, mail test) are likely to refuse them; Clear Data is not affected. The demo administrator Alex Meian has the system role.
- In the browser, a group whose name contains “ADMIN” makes every non-Settings button look unlocked, while the server still refuses actions the group lacks.
- Users imported from CSV without a password receive an unknown random password.

Authentication and SSO

This page explains how people sign in to GRC360 and how to configure each sign-in method. The screens are described field by field in Settings › Authentication; this page gives the procedures and the behaviour behind them. Only the Admin group can do any of this.

What works in this release

Method	State	Summary
Local (e-mail and password)	Working, always on	Every account has a local password. It works whatever main method is selected.
LDAP / Active Directory	Working	When the local password does not match, the server checks the password against the directory. The person must already have an active GRC360 account.
OAuth (Google, Microsoft, Okta)	Configuration only	Connectors can be stored and selected; nothing signs in through them and the login page has no SSO button.
SAML 2.0	Configuration only	Connectors can be stored and selected; the server has no SAML endpoint.
Multi-factor authentication	Not available	The server has MFA endpoints, but there is no screen to enrol and the sign-in does not ask for a second factor.

Local sign-in

The sign-in page asks for **Email** and **Password**, with a **Keep me signed in** option (see Sessions and security). There is no “Forgot password” link and no self-registration.

What happens when someone signs in:

1. The server looks for an **Active** account with that e-mail in the organisation. An inactive or unknown account is refused with the same message as a wrong password, so the screen does not reveal which accounts exist.
2. The password is compared with the stored BCrypt hash.
3. If it does not match, the LDAP directory is asked (next section). If that also fails, the attempt counts as a failure.
4. After 5 failed attempts for the same e-mail within 15 minutes, the account is blocked from signing in for 15 minutes (the server answers “too many attempts”). Separately, at most 10 sign-in attempts per minute are accepted from one IP address. Both limits are server settings (`RATE_LIMIT_LOGIN_*`).

To reset a person’s password, edit the user in **Organization Hub › Users** and fill **New password (optional)**.

LDAP and Active Directory

LDAP lets staff use their directory password. GRC360 never stores that password; it binds to the directory with it at each sign-in.

How the directory is chosen at sign-in

Only connectors with status **Enabled** are used. They are asked in this order, stopping at the first that accepts the password:

1. The connector selected under **Authentication Method** when the main method is **LDAP**.
2. Every other Enabled connector whose **Mail Domain** equals the domain of the e-mail typed (an `@` in the field is ignored).

For each connector, the server searches **User Search Base** (or **LDAP Server Base DN** when blank) with **User Search Filter**, `{0}` replaced by the e-mail. Exactly one entry must match; zero or several matches refuse the sign-in. It then binds as that entry with the typed password. A directory that is down never blocks local passwords.

Step by step

1. **Prepare in the directory:** a read-only service account that can search the user tree, its distinguished name and password, the server host name, the port (389 for LDAP, 636 for LDAPS) and the base DN. Confirm which attribute holds the e-mail people type (Active Directory: often `userPrincipalName` or `mail`; OpenLDAP: `mail` or `uid`).
2. **Make sure every person has a GRC360 account** with exactly the same e-mail and status Active (Organization Hub › Users). Their local password can be any long random value.
3. Open **Settings › Authentication › LDAP Connectors** and click **Add Item**.
4. On the **General** tab fill:

Field	What to enter
Name	A name for the directory, for example “Corporate AD” (required)
Description	Optional
Status	Leave **Disabled** until the test passes
LDAP Server Hostname	Host name, for example `dc01.company.local`, or a full URL `ldaps://dc01.company.local:636` (required)
Mail Domain	The e-mail domain of the people in this directory, for example `company.com`
Port	389, or 636 for LDAPS (636 without a scheme in the host name selects `ldaps://`)
LDAP Username	The service account DN, for example `CN=svc-grc,OU=Service,DC=company,DC=local`; leave blank for anonymous search
LDAP Password	The service account password (stored encrypted; leave blank on edit to keep it)
LDAP Server Base DN	For example `DC=company,DC=local`

5. On the **Connector Settings** tab fill:

Field	What to enter
User Search Filter	`(mail={0})` (default) or `(userPrincipalName={0})`
User Search Base	Optional narrower start point, for example `OU=Staff,DC=company,DC=local`
Type	Leave **Authenticator** (the value is not stored)

6. Click **Save**, then **Test connection** on the row. Read the message:

Message	What to fix
“Connected to … N user(s) matched under …”	Nothing; N should be roughly your staff count.
“Could not reach the server. Check the hostname, the port, and that the network allows it.”	Host, port, firewall between the GRC360 server and the directory.
“The server rejected the LDAP username or password.”	Service account DN or password.
“The server accepted the login but the base DN does not exist on it.”	Base DN.
“No server hostname is set on this connector.”	Host name.

7. Click **Edit**, set **Status** to **Enabled**, save.
8. Optionally open **Authentication Method**, choose **LDAP**, select the connector in **User authentication connector** and click **Save** (“Authentication settings saved successfully.”). This makes it the first directory asked; it is not required when **Mail Domain** is set.
9. Ask a colleague to sign in with their directory password.

Each save, test and delete is recorded in the System Log.

Several directories

Create one connector per directory with its own **Mail Domain** and enable each. People are routed by the domain of their e-mail.

OAuth connectors

In this release OAuth connectors are stored for a future single sign-on rollout; they do not sign anyone in. To prepare one:

1. At the provider (Google, Microsoft or Okta), register an application and add the two redirect URLs shown in the dialog: `{your site}/login` and `{your site}/portal/policy/login`.
2. In **Settings › Authentication › OAuth Connectors** click **Add Item** and fill:

Field	What to enter
Name	For example “Google Workspace” (required)
Client ID	From the provider (required)
Client Secret	From the provider; stored encrypted
Provider	**Google**, **Microsoft** or **Okta** (required)
Status	**Active** or **Disabled**

3. Click **Save** (“OAuth connector created successfully.”).

The connector cannot be edited, tested or deleted from the screen afterwards. Selecting **OAuth** as main method is accepted (the connector must be Active) but changes nothing at sign-in.

SAML connectors

SAML connectors are likewise stored only. To prepare one:

1. In **Settings › Authentication › SAML Connectors** click **Add Item**. The dialog lists the service-provider values: **Single sign on URL**, **Audience URI (SP Entity ID)**, **Default RelayState**, **Assertion Consumer Service (ACS)**, **Logout URL** and **Redirect URLs**. These addresses are not served by GRC360 in this release, so an identity provider configured with them will not complete a sign-in.
2. Fill:

Field	What to enter
Name	For example “Okta SAML” (required)
Identity Provider	The IdP metadata URL (required)
IDP x509 Certificate	The IdP signing certificate (currently not saved)
Remote sign in URL	The IdP sign-in URL
Email field	The attribute carrying the e-mail, for example `email`
Sign SAML request	On or off (currently not saved)
SP x509 Certificate	Your service-provider certificate (currently not saved)
SP Private Key	Your service-provider key; stored encrypted
Authentication Context	**Password Protected Transport**
Status	**Active** or **Disabled**

3. Click **Save** (“SAML connector created successfully.”).

Super-admin (break-glass) accounts

The server setting `SUPER_ADMIN_EMAILS` (comma-separated e-mails) names accounts that are treated as administrators regardless of their groups, so that access can be recovered if the Admin group is emptied or misconfigured. It can only be set on the server, not in the product. Every super-admin sign-in and every bypassed permission check is written to the server's security log.

Known issues

- OAuth and SAML connectors do not provide sign-in; the login page has no SSO option.
- SAML certificate fields and **Sign SAML request** are not saved; OAuth and SAML connectors cannot be edited or deleted on screen.
- **In Use** never shows "true", so a connector selected as main can still be deleted.
- LDAP does not create accounts; each person needs an existing account with the same e-mail.
- There is no MFA in the sign-in flow.

E-mail, webhooks and notifications

This page covers everything GRC360 sends on its own: e-mail through an SMTP relay, webhook calls to your systems, and in-app notifications. It also lists every scheduled job in the code and states which of them actually run in this release.

SMTP relay

What is e-mailed

E-mail	When
“You have been invited to GRC360”	When an administrator creates an invitation through the API (there is no screen for it; see invitations). Sent in the background; a failure never cancels the invitation.
“GRC360 test message”	When an administrator clicks **Send test message** on the Integrations page.

Nothing else is e-mailed. Notifications, deadlines and reminders appear only in the application. Scheduled e-mail digests are listed as planned on the Integrations & Automation page.

Setting it up

The relay is configured on the server, not in the product. Ask the server operator to set these environment variables and restart the backend:

Variable	Default	Meaning
`MAIL_HOST`	(empty)	SMTP server host. Empty means no mail is sent; the server only logs the subject and recipient.
`MAIL_PORT`	587	SMTP port
`MAIL_USERNAME`	(empty)	SMTP login
`MAIL_PASSWORD`	(empty)	SMTP password
`MAIL_STARTTLS`	true	Use STARTTLS (typical on 587)
`MAIL_SSL`	false	Use implicit TLS (typical on 465)
`MAIL_FROM`	(empty)	Sender address; must be a verified sender at the provider. Required: without it the relay counts as not configured.
`MAIL_FROM_NAME`	GRC360	Sender display name

Connection, read and write timeouts are 5 seconds each, so a dead relay delays a send by at most a few seconds and never breaks the action that triggered it. Any SMTP provider works (for example Brevo, Resend, Mailgun, Gmail).

Testing it

1. Open **Integrations & Automation** and find **E-mail delivery**. The **SMTP relay** card reads **Configured** with “{host} — sending as {from}” when both host and sender are set, or **Off** with “Not configured on this deployment”.
2. When configured, type your address and click **Send test message**.
3. A green result “Sent to {address}. Check the inbox, and the spam folder.” means the relay accepted the message. A red result shows the relay’s own error, for example an authentication failure or a rejected sender.

Settings › System Health › System health also shows a **mail smtp** check; note that it looks only at the host, so it can read UP while the Integrations card still reads Off because `MAIL_FROM` is missing.

Webhooks

Webhooks send an HTTP POST to a URL you own for every event the audit trails record. They are managed on the Integrations & Automation page, which describes the form, payloads, the `X-GRC360-Signature` HMAC header and the test button. Summary for administrators:

- Only administrators can list or change webhooks in practice (the server requires the system role ADMIN).
- Event names are the System Log action codes and the internal audit-trail event types (for example `COMPLIANCE_PACKAGE_CREATED`, `AUTH_SETTINGS_UPDATED`, `RISK_CREATED`, `RISK_EXCEPTION_APPROVED`, `OBJECTIVE_AUDIT_CREATED`). The **Event filter** matches name prefixes.
- Delivery is one attempt with a 5-second timeout; failures are counted, not retried, and the webhook is never switched off automatically.
- **Settings › Clear Data** with **Settings and catalogues** deletes all webhooks.

In-app notifications

Notifications appear in the bell at the top of every page (red badge with the unread count, “9+” above 9) and on the Notifications page reached with **See all**. Each person sees only their own. How users work with them is described in Your profile, account, notifications and support.

Notification catalogue

Type	When it fires	Recipient	Title / link
ACCESS_REQUEST	A user sends an access request from a locked button	Every administrator	“Access request from {name}”; **Review request** opens Organization Hub › Groups with the Access Requests queue
ACCESS_APPROVED	An administrator approves a request	The requester	“Access request approved”; no link. The requester’s open session unlocks the granted button within about 10 seconds.
ACCESS_REJECTED	An administrator rejects a request	The requester	“Access request rejected”, with the decision note; no link
TASK_ASSIGNED	Someone is newly named in the **Awareness Role** of a Continuity Plan task (on creation, or added on edit). A group named there expands to its members.	The named users	“You are named in a continuity plan task”; **Open the task** opens Control Center › Continuity Plans, Tasks tab, on that task
SERVICE_AGREEMENT_EXPIRING_WEEK	A service agreement with status Active or Expiring ends in 4 to 7 days	The agreement’s GRC contacts and support-contract contacts (groups expand to members)	“Service agreement expires in a week”; the message gives the actual days left; **Open the agreement** opens it
SERVICE_AGREEMENT_EXPIRING_SOON	Same, ending in 1 to 3 days	Same	“Service agreement expires in 3 days”
SERVICE_AGREEMENT_EXPIRES_TODAY	Same, ending today	Same	“Service agreement expires today”
OBJECTIVE_AUDIT_DUE	Would fire when an objective’s audit date is today or past	Objective owner	Produced only by a scheduled job that does not run in this release; never received.
OBJECTIVE_TARGET_OVERDUE	Would fire when an objective’s target date has passed and it is not Achieved	Objective owner	Same: never received in this release.

Type	When it fires	Recipient	Title / link
RISK_ALERT, INCIDENT_ALERT, COMPLIANCE_REMINDER, INFO, WARNING, ERROR	Never produced automatically. They exist for notifications created directly through the API (`POST /api/v1/notifications`).	As specified in the request	

Service-agreement warnings: each recipient receives each milestone at most once per agreement. The narrowest milestone that fits applies, so an agreement saved 5 days before its end gets the “in a week” warning. The check runs when the agreement is created or saved, once a day for every organisation, and the first time each day anyone in the organisation opens their notifications.

Being made owner or assignee on any other register (risks, controls, assets, projects and so on) sends no notification in this release, and comments do not notify anyone.

Scheduled jobs

The backend does not enable Spring’s scheduler, so every job declared with a fixed schedule in the code is dormant. Only the jobs in the first table run.

Running

Job	Schedule	What it does
Daily notification sweep	Every day at 08:00 server time (server settings `NOTIFICATIONS_SWEEP_CRON` , `NOTIFICATIONS_SWEEP_ENABLED`)	Runs the time-based notification checks for every organisation. The only check today is the service-agreement end-date warning.
Notification sweep on first bell read	At most once per organisation per day, when anyone opens their notifications	The same checks, so warnings appear even if the server was down at 08:00.
Session purge	At most once an hour, triggered by a token refresh	Deletes session records that ended more than 30 days ago.

Computed values do not need a job: Dynamic Status values (for example a project turning Expired, an exception showing as expired by date) are calculated each time a record is read, so they are always current on screen.

Implemented but not active in this release

Job	Declared schedule	What it would do
Objective alerts	Daily 09:00	Create OBJECTIVE_AUDIT_DUE and OBJECTIVE_TARGET_OVERDUE notifications
Risk exception expiry	Hourly	Set the stored status of risk exceptions past their expiry to expired
Compliance exception expiry	Hourly	Set the stored status of compliance exceptions past their expiration to EXPIRED and log COMPLIANCE_EXCEPTION_EXPIRED
Exception request expiry	Daily 00:00	Expire approved exception requests past their “valid until” date
Service agreement status	Daily 01:00	Move Active/Expiring agreements to Expiring (within 30 days) or Expired (past end date). Without it, the stored status of an agreement does not change by itself.
Dashboard cache cleanup	Hourly	Clear all caches (also requires a Redis cache, which is not configured)
Data archiving	Daily 00:00	Placeholder that only counts and logs; archives nothing

What this means in practice: stored statuses of exceptions and service agreements must be changed by people, and objective owners are not alerted. Check the Dynamic Status columns and the views of each register instead.

Known issues

- Only invitations and the test message are e-mailed; invitations have no screen.
- Six notification types are never produced automatically but are offered in the Notifications page’s **Type** filter.
- TASK_ASSIGNED covers only continuity plan tasks.
- OBJECTIVE_* notifications are never sent because their job does not run.
- Webhooks are effectively admin-only and have no retry.

Sessions and security

This page explains how long people stay signed in, what ends a session, and how administrators see and end sessions. The user's side (the idle warning, "Keep me signed in", the Account page) is described in Signing in and sessions.

How a session works

Signing in creates a **session**. The browser receives:

- an **access token**, valid for 15 minutes and kept only in the page's memory, which accompanies every request; and
- a **refresh cookie** (`grc_refresh` , HttpOnly, sent only to the sign-in endpoints), with which the browser obtains a new access token when the old one expires or the page is reloaded.

Each refresh replaces the refresh token with a new one. If an old refresh token is ever presented again (a sign that it was copied), the server ends the whole session at once with the reason "Ended for security: its sign-in token was reused". A replaced token is still accepted for 10 seconds, so two tabs refreshing at the same moment do not trip this.

Lifetimes

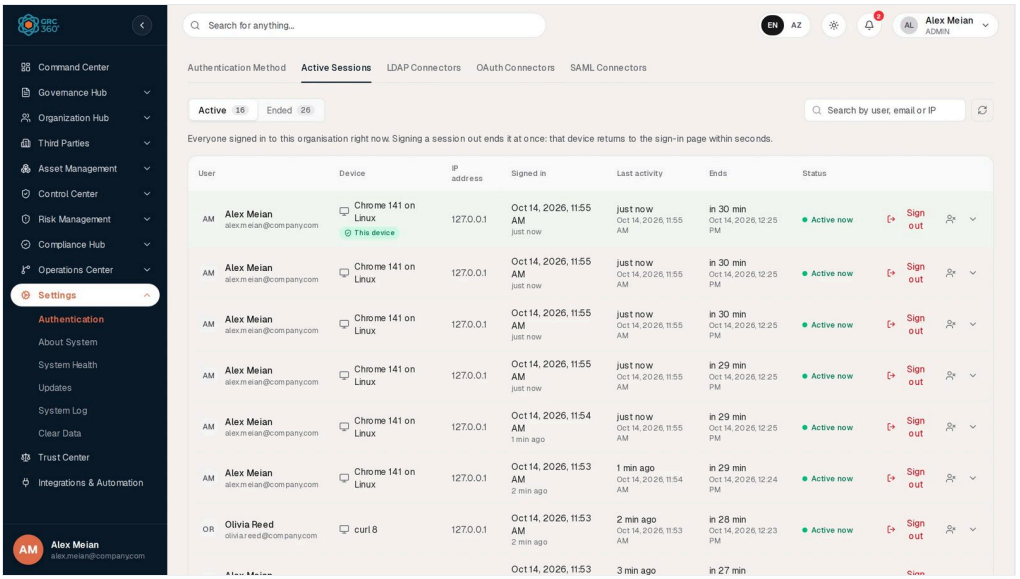
Setting	Standard session	With "Keep me signed in"	Server variable
Idle timeout (no activity)	30 minutes	12 hours	`SESSION_IDLE_TIMEOUT_SECONDS` , `SESSION_REMEMBER_ME_IDLE_TIMEOUT_SECONDS`
Absolute maximum	8 hours from sign-in	7 days from sign-in	`SESSION_ABSOLUTE_TIMEOUT_SECONDS` , `SESSION_REMEMBER_ME_ABSOLUTE_TIMEOUT_SECONDS`
Access token	15 minutes	15 minutes	`JWT_EXPIRATION_SECONDS`
Sessions per user	10; an 11th sign-in ends the oldest ("Replaced by a newer sign-in")	same	`SESSION_MAX_PER_USER`
Ended sessions kept for review	30 days	same	`SESSION_RETENTION_DAYS`
"Keep me signed in" offered	yes		`SESSION_REMEMBER_ME_ENABLED`

These values are server configuration; they cannot be changed in the product. The choice of standard or remembered is fixed at sign-in.

What counts as activity. In the browser, clicks, key presses, mouse-wheel scrolling and touches count; moving the mouse does not. Activity in any open tab counts for all tabs. Sixty seconds before the idle limit the user sees **Still there?** with **Stay signed in** and **Sign out now**. If nobody answers, the session is ended on the server and all tabs show **Your session has ended**.

Seeing every session

Open **Settings › Authentication › Active Sessions**. The tab is described in detail in Authentication.



Active Sessions

- **Active** lists sessions that are not revoked, are within both limits, and belong to an active account. **Active now** means the session refreshed within the last 15 minutes; otherwise it shows **Idle for …**.
- **Ended** lists sessions that ended in the last 30 days with the reason.
- Search by user name, e-mail or IP address. The list refreshes every 30 seconds.

Each person sees their own devices, and can sign them out, on their **Account** page under **Signed in on** (**Sign out** per device, **Sign out other devices**, **Sign out everywhere**).

Signing people out

Goal	Where	Result
End one session of one user	Active Sessions, **Sign out** on the row	That device gets an error on its next request and returns to the sign-in page within about 10 seconds. Reason “Signed out remotely”.
End all sessions of one user	Active Sessions, the person icon on any of their rows	Every device of that user is signed out (“User signed out of every device.”).
Stop a person signing in again	Organization Hub › Users, **Status** Inactive (and sign them out as above)	Sign-in is refused; any remaining session ends at its next refresh with “Account deactivated”.
Sign yourself out everywhere	Account page, **Sign out everywhere**	All your sessions end (“Signed out everywhere”).

There is no single button that signs out every user of the organisation. To force everyone out, sign out each user from Active Sessions.

An ended session is refused on the device’s very next request (the server answers that the session was revoked), and the browser’s background check brings such a device to the sign-in page within about 10 seconds even when nobody is clicking.

Other protections

Protection	Behaviour
Sign-in throttling	5 failed attempts for one e-mail within 15 minutes block that e-mail for 15 minutes; at most 10 attempts per minute per IP address (`RATE_LIMIT_LOGIN_*`).
Password storage	BCrypt hashes; connector secrets (LDAP service password, OAuth client secret, SAML private key) and webhook secrets are stored encrypted and never returned.

Protection	Behaviour
Organisation isolation	Every request is bound to one organisation; records of other organisations are never returned.
Permission checks	Every API request is checked on the server against the user's groups and grants; hidden or locked buttons are not the only barrier.
Cookie	The refresh cookie is HttpOnly, SameSite=Lax and Secure by default (`SESSION_COOKIE_SECURE`).

Known issues

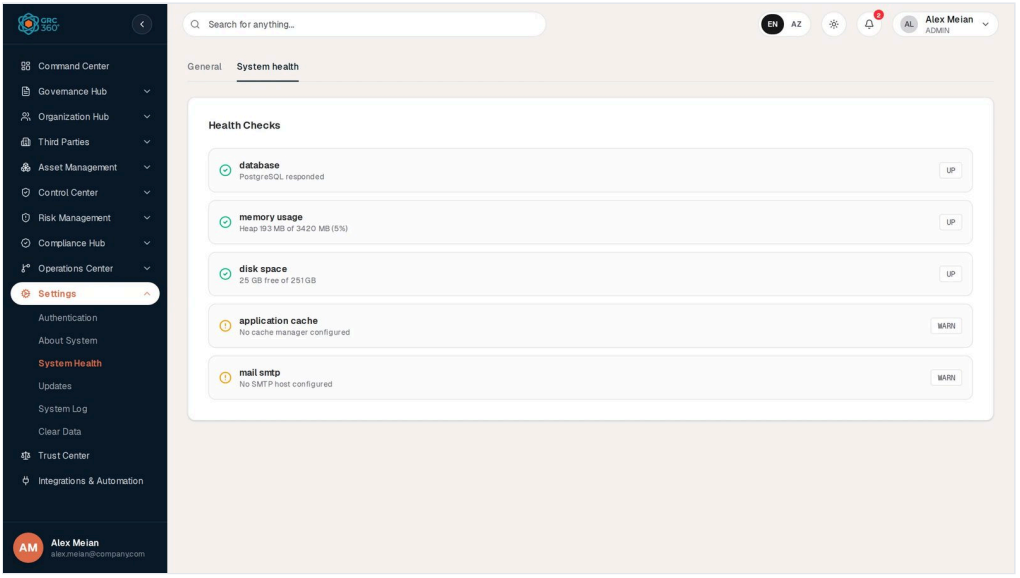
- After an idle timeout, **Go to sign in** returns the user to the Command Center rather than the page they were on, although the dialog says otherwise.
- There is no organisation-wide "sign out everyone" action.
- Session lifetimes cannot be set per organisation or per group; they are server-wide.
- There is no multi-factor authentication in the sign-in flow.

System maintenance

This page collects the routine tasks of keeping GRC360 healthy: checking the system, recording versions, reading and exporting the system log, clearing data and taking care of backups. The screens are described in detail under Settings. All of them are reserved to the Admin group.

Checking system health

Open **Settings › System Health**.



System Health checks

Check	Act when
database	DOWN: the database did not answer within 2 seconds. Nothing works until it is back; contact the server operator.
memory usage	WARN at 75 % heap, DOWN at 90 %. Ask the operator to restart or give the server more memory.
disk space	WARN below 5 GB free, DOWN below 1 GB. Ask the operator to free space.
application cache	WARN “No cache manager configured” is the normal state of this release.
mail smtp	WARN “No SMTP host configured” means invitation e-mails cannot be sent; see SMTP relay.

On the **General** tab:

- **Version** shows the running build and whether the Updates register lists a newer one.
- **Download Diagnostics** gives `diagnostics.txt` (version, Java, operating system, uptime, server profiles, health checks); **Download Logs** gives the System Log as comma-separated text. Attach both to support requests.
- **Send to Support** does not send anything on a standard installation; it tells you to download the diagnostics and send them yourself.
- **Clear Cache** has nothing to clear in this release.
- The three **Diagnostics options** switches are stored but have no effect.

For monitoring tools, the backend also exposes the standard health endpoints under `/actuator/health` (liveness and readiness probes); see the technical reference.

Versions and updates

- **Settings › About System** shows **App Version** and **DB Schema Version**. Record them before and after every upgrade.
- **Settings › Updates** lists update entries recorded in the database; normally it reads “No updates available.”
- Upgrades are carried out by the server operator by deploying a new build. The **Enable Maintenance Mode** button on the Updates page does nothing in this release, so announce maintenance windows to users by other means.

Using the System Log

Settings › System Log is the append-only trail of authentication-setting changes, System Health actions and Compliance Hub changes (packages, analyses, obligations, audit findings, compliance exceptions). See System Log for the full list of action codes.

- Search by action code or message text, for example “AUTH_” for all sign-in configuration changes.
- **Export CSV** downloads every entry (id, action, portal, username, message, createdAt) for auditors.
- Entries cannot be edited or deleted. They are removed only by a data reset that includes **Audit trail and notifications**.
- The **User** column is empty (“–”) in this release. Sign-ins, permission changes and most register changes are not in this log; use each record’s Activity Log and the Active Sessions list for those.

To send the same events to an external log collector or SIEM as they happen, add a webhook.

Clearing data

Settings › Clear Data permanently deletes chosen parts of the organisation’s data. Read Clear Data before using it. In short:

Group	Deletes
Registers	All register records and the links between them
Audit trail and notifications	The internal audit trail, the System Log and all notifications
Settings and catalogues	Risk scales and matrices, catalogue options, incident stages, templates, the Trust Center switch and webhooks
Users, groups and structure	All users and accounts except yours and the kept accounts (`APP_DATA_RESET_KEEP_EMAILS` , default `test@example.com`), custom groups, departments, grants and invitations

Never deleted: the organisation, the permission catalogue and system roles, all sign-in configuration, system information, the updates register and earlier backups. Built-in groups stay.

Procedure:

1. Export anything you want to keep from the registers’ **Export CSV** buttons.
2. Tick the groups. Tick **Registers** together with **Settings and catalogues**, otherwise most settings stay because records still use them.
3. Type the organisation’s name as shown and click **Back up and clear data**.
4. Download the new backup from **Backups** and store it safely.

Only administrators can run it: opening the page needs the Clear Data read right and running it the **Execute Reset** right, and Settings belongs to the Admin group alone.

Backups

GRC360 keeps two kinds of copies, and neither replaces the server operator’s own backups.

Copy	Made by	Contains	Restore
Reset backup	Every **Clear Data** run, automatically, before deleting	Every row the run deleted, as gzipped JSON (`grc360-backup-yyyyMMdd-HHmmss.json.gz`), downloadable from **Settings › Clear Data › Backups**	No restore function; restoring means loading the JSON into the database by hand

Copy	Made by	Contains	Restore
Database and file storage backups	The server operator	Everything	Operator’s procedure

There is no scheduled backup inside the product, and reset backups are never deleted automatically. Uploaded attachment files are kept in the server’s file storage and are not part of reset backups. Agree database and file-storage backup schedules with the server operator; see the technical reference on operations.

Routine checklist

How often	Task
Weekly	Open System Health › System health; act on WARN or DOWN rows.
Weekly	Review **Organization Hub › Groups › Access Requests** and pending requests.
Monthly	Review **Active Sessions** for remembered sessions on shared machines; review additional permissions marked **Permanent**.
Monthly	Export the System Log for your records.
Monthly	Because expiry jobs do not run in this release, review exceptions and service agreements whose dates have passed and update their stored status by hand.
Before and after upgrades	Note App Version; download diagnostics.

Part 5 — Technical reference

Technical reference

This part of the guide is for developers, DevOps engineers and people installing GRC360 on their own infrastructure. It describes the system as it is built in the October 2026 release: frontend repository `GRC_Frontend_Code` (branch `main`, Next.js 16.2.6, React 19.2.4) and backend repository `GRC_Backend_Code` (branch `develop`, Spring Boot 3.5.16, compiled for Java 17, run on a Java 21 image).

Every statement here was taken from the source code, the configuration files, or a running instance (backend started with `--spring.profiles.active=dev --grc.seed.dummy-data=true`, frontend with `next dev`). Where the existing project documentation, a README or a configuration file disagrees with the code, the code is described and the difference is called out.

Pages

Page	What it covers
Architecture	Components, request flow through the Next.js proxy, multi-tenancy, backend module map, cross-cutting packages
Installation and deployment	Docker images and Compose file, every environment variable, Spring profiles, first start, seeding, on-premise and air-gapped notes, upgrades, schema management
REST API	Conventions (authentication, tenant header, paging, sorting, errors, rate limits), OpenAPI location, catalogue of all 619 operations by module
Data model	The 120 JPA entities grouped by module, their tables, relationships and link tables, with diagrams
Security	Authentication, sessions, the proxy's CSRF and header rules, authorisation layers, tenant isolation, rate limiting, audit trails, file storage, secrets
Operations	Logging, health and metrics, Prometheus and Grafana, caching, recurring jobs, backups, troubleshooting
Development	Repository layout, running locally, tests, lint and type checks, coding rules, branching, CI/CD

The system in one paragraph

The browser loads a Next.js application and never talks to the backend directly: every API call goes to the same-origin route `/api/v1/[...path]`, which forwards it to the Spring Boot backend named by `BACKEND_API_URL`. The backend is a modular monolith (24 packages under `modules/`, 100 controllers, 619 REST operations) on PostgreSQL 16. Files go to MinIO or any S3-compatible store (or a local directory for development). Every business row carries a `tenant_id`; the tenant of a request comes from the access token, or from the `X-Tenant-Id` header before sign-in. Access tokens are short-lived JWTs kept in browser memory; the session lives in an HttpOnly refresh cookie and in the `user_sessions` table. Redis, Prometheus and Grafana appear in the Compose file, but Redis is not used by any shipped profile and the repository contains no Prometheus or Grafana configuration.

Facts worth knowing before you install

These are the points most likely to surprise an installer. Each is explained on the page linked.

Fact	Where
The Compose file has no frontend service, and the `nginx/`, `prometheus/` and `grafana/` directories it mounts are not in the repository	Installation

Fact	Where
A fresh database has no tenant and no user unless the backend is started once with the `dev` profile	Installation
Flyway is disabled (`spring.flyway.enabled=false`); the schema is created and extended by Hibernate `ddl-auto=update` plus `SchemaRepairRunner`	Installation
`/actuator/health` reports `DOWN` (HTTP 503) when no LDAP server is reachable on `localhost:389` or no SMTP host is set, which makes the Docker health check fail	Operations
No `@Scheduled` job runs (scheduling is not enabled); the only recurring tasks are the daily notification sweep and the session purge	Operations
There is no automatic database backup; Data Reset writes its own backup file before deleting	Operations
The frontend has no `.env.example` ; `BACKEND_API_URL` must include the `/api/v1` path	Installation

Related documentation in the repositories

The repositories contain older documents, mostly in Azerbaijani. They are useful background, but several are out of date:

Document	State
`GRC_Backend_Code/doc/api/*.md` (access-control, sessions, sync, file-storage, notifications, data-reset, error-codes)	Mostly current. `error-codes.md` shows a `correlationId` field that the error body does not contain.
`doc/diagrams/architecture.md` , `doc/diagrams/sequence-auth.md` (both repositories)	Outdated: they show Redis storing refresh tokens and caching, and an nginx-to-backend path. Replaced by Architecture.
`doc/diagrams/erd.md` (both repositories)	Outdated: entity names and relations do not match the code. Replaced by Data model.
`doc/api/openapi.yaml` (both repositories)	Stubs with 6 and 11 paths. The live specification at `/v3/api-docs` has 416 paths.
`doc/server/*.md`	Describe a different stack (React/Vite frontend, OpenLDAP container, nightly `pg_dump`) that is not in the repositories.

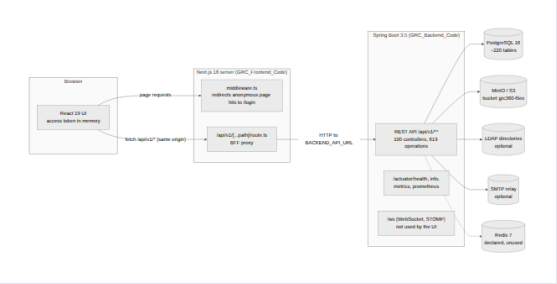
Architecture

GRC360 is two deployable applications and a set of backing services:

- **Frontend**: a Next.js 16 application (`GRC_Frontend_Code`) that serves the user interface and acts as a backend-for-frontend (BFF) proxy for every API call.
- **Backend**: a Spring Boot 3.5 modular monolith (`GRC_Backend_Code`) that owns all data, business rules and authorisation.
- **PostgreSQL 16**: the only system of record.
- **Object storage**: MinIO or any S3-compatible service for uploaded files; a local directory for development.
- **Optional**: an SMTP relay for outgoing mail, LDAP directories for password checks.

Redis, Prometheus and Grafana are declared in the backend's `docker-compose.yml` , but Redis is not used by any shipped Spring profile (see Caching) and the Prometheus and Grafana configuration files the Compose file mounts are not in the repository (see Installation).

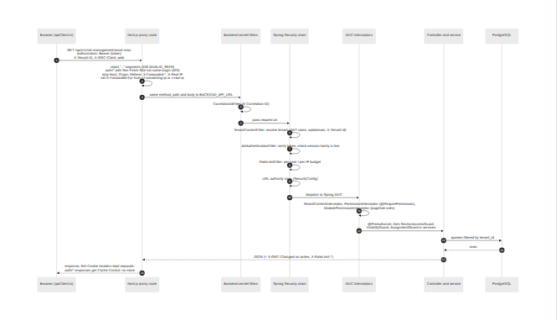
System overview



Component	Technology	Port (default)	Source
Frontend	Next.js 16.2.6, React 19.2.4, TypeScript 5, Tailwind CSS 4	3000 (`next start`), `next dev` uses 3000 unless `-p` is given	`package.json` , `Dockerfile`
BFF proxy	Next.js route handler	same as frontend, path `/api/v1/*`	`src/app/api/v1/[...path]/route.ts`
Backend	Spring Boot 3.5.16, Spring Security, Spring Data JPA (Hibernate), springdoc-openapi 2.8.6, jjwt 0.12.6	8080 (`PORT`)	`pom.xml` , `application.properties`
Database	PostgreSQL 16 (Compose image `postgres:16-alpine`)	5432	`docker-compose.yml`
Object storage	MinIO (Compose image `minio/minio:latest`), any S3 API	9000 API, 9001 console	`infrastructure/storage/MinioFileStorage.java`
Metrics	Micrometer Prometheus registry, `/actuator/prometheus`	8080	`pom.xml` , `application.properties`

Request flow

The browser only ever calls its own origin. The access token is attached by the frontend's `apiClient` , the proxy forwards the request, and the backend decides everything else.



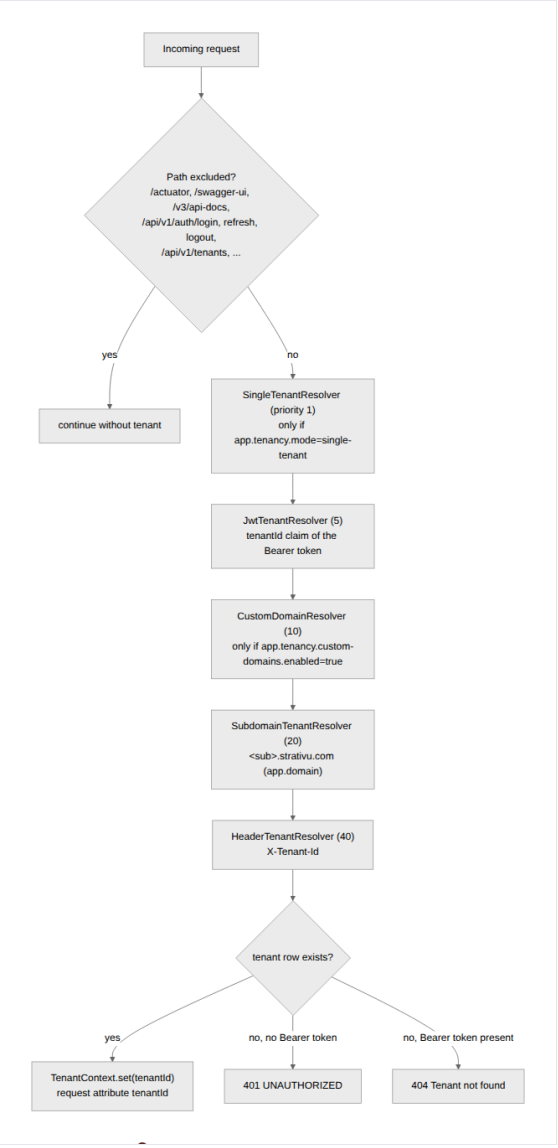
Details of each step:

Step	What happens	Source
Page navigation	`middleware.ts` lets `/login`, `/_next/*`, `/api/*` and files through. Any other path without the `grc_refresh_present` cookie is redirected to `/login?next=<path>`. The cookie is a hint only; it grants nothing.	`src/middleware.ts`
API call	`apiClient` sends `Authorization: Bearer <token>`, `X-Tenant-ID` (taken from the token's `tenantId` claim, or from `localStorage.tenant_id` / `NEXT_PUBLIC_TENANT_ID` for `/auth/login` and `/auth/refresh`), and `X-GRC-Client: web`.	`src/shared/api/apiClient.ts`
Proxy	Forwards to `${BACKEND_API_URL}/${path}?${query}` with a 15 s timeout (60 s for `multipart/form-data`), returns 504 `Backend timeout` on abort and 500 `Internal Proxy Error` on other failures. Request bodies are streamed.	`route.ts`
Correlation	`CorrelationIdFilter` (highest precedence) reuses an incoming `X-Correlation-ID` or creates a UUID, puts it in the MDC as `correlationId` and returns it as a response header.	`observability/correlation/CorrelationIdFilter.java`
Tenant	`TenantContextFilter` resolves the tenant and stores it in `TenantContext` and in the request attribute `tenantId`. See Multi-tenancy.	`infrastructure/tenancy/TenantContextFilter.java`
Authentication	`JwtAuthenticationFilter` validates the HMAC-signed token, rejects an inactive account (`ACCOUNT_INACTIVE`) and a token whose session family was revoked (`SESSION_REVOKED`).	`modules/auth/security/JwtAuthenticationFilter.java`
Rate limiting	`RateLimitFilter` (only when `security.rate-limit.enabled=true`). See Security.	`security/ratelimit/RateLimitFilter.java`
Coarse authorisation	`SecurityConfig` URL rules per module prefix and verb.	`config/SecurityConfig.java`
Fine authorisation	Interceptors and service guards check the page and tab permission, row visibility and assignment rights. See Security.	`modules/organization/security/*`, `modules/visibility/security/*`

Step	What happens	Source
Change feed	After commit, every entity change is recorded by table name; the write response carries `X-GRC-Changed`, and other tabs learn of it through `GET /api/v1/sync/changes`, which the UI polls about every 10 seconds.	`common/sync/*`, `src/shared/ui/SyncPoller.tsx`

Multi-tenancy

GRC360 is multi-tenant with a shared database and shared schema. Isolation is by row: every tenant-owned entity extends `common/TenantScopedEntity`, which adds a non-null `tenant_id` column and fills it from the current tenant on insert (`@PrePersist`, throws `TenantContextException` if no tenant is set). Repositories and services filter by `tenant_id` in their queries.



Aspect	Behaviour
Resolver order	Lowest priority number first; the first resolver that supports the request and returns a tenant that exists in `tenants` wins (`TenantResolutionService`).
Signed-in requests	The JWT resolver runs before the header resolver, so the token's `tenantId` claim is authoritative. A different `X-Tenant-Id` header is not used.

Aspect	Behaviour
Sign-in	`POST /api/v1/auth/login` is excluded from the filter and reads the `X-Tenant-Id` header itself (required). A missing header produces HTTP 500, a blank or malformed one HTTP 400.
Refresh and logout	Excluded from the filter; the tenant is read from the stored `user_sessions` row, never from the header.
Subdomains	Only hosts ending in `.strativu.com` (property `app.domain`) with 3 to 50 characters `[a-z0-9-]` are considered; `www`, `app`, `api`, `admin`, `demo`, `test` and others are reserved. Behind the BFF the backend sees the proxy's own `Host`, because the proxy strips the browser's `Host` header, so in practice the tenant comes from the token or the header.
Single-tenant mode	Setting `app.tenancy.mode=single-tenant` and `app.single-tenant.id=<uuid>` activates a resolver that returns that tenant for every request. Neither property is set in any shipped profile.
Context holders	Two thread-local holders exist: `shared/context/TenantContext` (set by the filter, used by entities and most services) and `common/TenantContext` (set by `TenantContextInterceptor` from the request attribute or header). Both are cleared at the end of the request.
Database row-level security	Migration `V13__tenant_rls_policies.sql` defines PostgreSQL RLS policies for four compliance tables, and `TenantAwareRepository` can issue `SET LOCAL app.current_tenant_id`. Neither is active: Flyway is disabled and `TenantAwareRepository` is not configured as the repository base class. The running database has no RLS policies (`pg_policies` is empty). Isolation therefore relies on application queries.
Tenant administration	`TenantController` (`/api/v1/tenants`, 9 operations, ADMIN role) can create, list, re-plan, re-brand, suspend and activate tenants. The web client does not call it.

Backend module map

The backend source root is `src/main/java/com/strativu/grc360` (1,222 Java files). Business code lives in 24 packages under `modules/`. Each module follows the same internal layout: `api` (controllers), `dto`, `entity`, `repository`, `service` (`service/impl`), and where needed `event`, `listener`, `scheduler`, `seed`, `security`, `visibility`, `migration`.

Package	Java files	UI area	What it contains
`modules/commandcenter`	15	Command Center	Dashboard aggregate (`/command-center/dashboard`), dormant cache and archiving schedulers
`modules/governance`	62	Governance Hub	Objectives and their audits, audit evidence and result options, governance issues, coverage
`modules/organization`	90	Organization Hub	Users (organization profile), departments, groups (`OrganizationRole`), permission catalogue and seeding, access requests, individual grants, principal lookup, the permission interceptors and `SectionAccessGuard`

Package	Java files	UI area	What it contains
`modules/auth`	64	Sign-in, Account	Login, refresh, logout, sessions, JWT issue and validation, sign-in accounts (`UserAccount`), auth-side roles and permissions, invitations
`modules/thirdparty`	31	Third Parties	Vendors, service agreements, agreement expiry notifier, vendor-role deletion guard
`modules/asset`	53	Asset Management	Assets, asset reviews, data movements (Data Flows), vendor documents and questionnaires
`modules/control`	131	Control Center	Internal controls with audits, issues and maintenances; policies and standards with reviews; policy exceptions; continuity plans with audits, tasks and playbooks; catalogue options; control evidence files
`modules/risk`	136	Risk Management	Asset, third-party and business (operational) risk registers, risk reviews, risk exceptions, classification scales, analysis matrices, calculation methods, appetite thresholds, dynamic status computation, reference data for pickers
`modules/compliance`	126	Compliance Hub, Trust Center	Compliance packages and requirement items, compliance analysis, obligations, compliance exceptions, external audit findings, metadata, older framework and gap-assessment models, Trust Center documents
`modules/operations`	73	Operations Center	Projects with tasks and expenses, security incidents with stages, account reviews, saved views, reference data
`modules/settings`	89	Settings, Integrations	Authentication method, LDAP/OAuth/SAML connectors, SSO providers, MFA endpoints, mail, webhooks, system health, system log, updates and maintenance flag, about, data reset, Trust Center posture
`modules/notification`	29	Notification bell	Notifications, mail sending, notification listeners, `NotificationSweepScheduler`
`modules/comments`	10	Activity Log panel	Record comments and attachments
`modules/activity`	12	Activity Log panel	`record_activity` change history written from Hibernate events
`modules/visibility`	23	(cross-module)	Row-level visibility: `record_participants` , `VisibilityGuard` , `AssignmentGuard` , backfill runners

Package	Java files	UI area	What it contains
`modules/search`	4	Global search	`/search` across registers
`modules/sync`	1	(cross-module)	`GET /sync/changes`
`modules/realtime`	4	none	STOMP controller and an event publisher that only logs
`modules/audit`	8	none	`audit_logs` table and `/audit-logs` (written for older risk and incident events)
`modules/incident`	20	none	Older incident model (`/incidents`), superseded by Operations Center incidents
`modules/issue`	22	none	Older issue and exception-request models (`/issues`, `/exceptions`)
`modules/policy`	31	none	Older policy model, policy templates, policy acknowledgments
`modules/evidence`	14	none	Older evidence and evidence-request models
`modules/task`	11	none	Older task model (`/tasks`)

“none” in the UI column means the web client does not call the module’s endpoints. The API catalogue in REST API marks every controller the same way.

Module boundaries are partly enforced by ArchUnit tests (`architecture/OrganizationArchitectureTest`, `modules/organization/architecture/OrganizationModuleBoundaryTest`, `architecture/RemovedRegisterSurfacesTest`).

Cross-cutting packages

Package	Purpose	State in this release
`shared/relation`	`RelationCatalog` turns ids stored in relation fields into `{id, name}` pairs (`RelationLink`) for 12 kinds: department, vendor, asset, the three risk types, internal control, policy/standard, project, continuity plan, compliance package, risk exception. The implementation (`infrastructure/relation/RelationCatalogImpl`) sits below the modules so modules do not depend on each other.	Active
`common/sync`	`ChangeTrackingEntityListener` on every `BaseEntity` and `ChangeTracker` record which tables changed per tenant after commit. `ChangedResourcesHeader` adds `X-GRC-Changed` to the write response. `GET /api/v1/sync/changes?since=<seq>` returns `{epoch, seq, changed[]}`. State is in memory of one JVM.	Active

Package	Purpose	State in this release
`events`	A custom `EventPublisher` and in-memory `EventStore`.	Not used by any module. Modules publish Spring application events (`ApplicationEventPublisher`) handled by `@EventListener` / `@TransactionalEventListener` classes (notifications, audit log, deletion guards, cache invalidation).
`websocket`, `config/WebSocketConfig`, `modules/realtime`	Two registrations on `/ws`: a raw WebSocket handler and a STOMP endpoint (with SockJS) with broker prefixes `/topic`, `/queue`. Allowed origins `*`.	Not used by the web client. `RealtimeEventPublisher` only writes log lines. Live refresh in the UI comes from the sync poll, not from WebSocket.
`cache`	Tenant-aware cache key generator, TTL properties (`cache.ttl.*`), cache metrics, invalidation listener.	Inactive: `CacheConfig` (the only `@EnableCaching`) loads only when `spring.cache.type=redis`; all profiles set `none` or `simple`. See Caching.
`observability`	`CorrelationIdFilter`, `TenantAwareLoggingFilter`, `PiiMaskingUtil`.	Correlation id is set but not printed by the log pattern; `PiiMaskingUtil` is not called anywhere. See Logging.
`chaos`	Fault injection (database drop, API timeout, memory stress, network latency, random exception, rate limiting) with `/api/chaos/*` endpoints.	Loaded only with the `dev` profile; disabled until `POST /api/chaos/enable`.
`security/ratelimit`	Fixed-window in-memory rate limiter and login-failure blocking.	Active by default.
`security` (other)	`SuperAdminService` (break-glass accounts from `SUPER_ADMIN_EMAILS`), `AccessPolicyService`, `SecurityIntelligenceService`, `infrastructure/security/DeviceManagementService` (device fingerprinting, `security.device-fingerprinting.enabled=false` by default).	
`infrastructure/storage`	`FileStorage` port with `MinioFileStorage` and `LocalDiskFileStorage`, `StorageHealthIndicator`, `StorageMigrationRunner`.	Active
`infrastructure/tenancy`, `domain/tenant`, `application/tenant`	Tenant resolution and the tenant aggregate.	Active
`migration`	`SchemaRepairRunner` (all profiles), `DatabaseConstraintFixer` (dev), `BlueGreenDeploymentStrategy`, `ZeroDowntimeMigrationStrategy` (classes not used at runtime).	See Installation.
`seed`, `config/DevDataInitializer`	Demo data for the `dev` profile.	See Installation.
`api/versioning`	`@ApiVersion` annotation and `ApiVersionRequestMappingHandlerMapping`.	The handler mapping is not registered as a bean; all live paths are hard-coded under `/api/v1`.
`timescale`	`TimescaleDBConfiguration`, `TimescaleDBRepository` for time-series hypertables.	No method of the configuration runs at startup, and `postgres/init.sql` does not install the TimescaleDB extension.

Package	Purpose	State in this release
`common/logging`	`@AuditLog` annotation (68 annotated methods) and `AuditLogAspect`, which writes to the `AUDIT_LOG` / `AUDIT_WARN` / `AUDIT_ERROR` loggers.	Active (log files only)

Frontend structure

Path	Contents
`src/app/(public)/login`	Sign-in page
`src/app/(app)/<module>/[section]`	One route per module and section (Command Center, Governance, Organization, Third Parties, Asset Management, Control Center, Risk Management, Compliance Hub, Operations Center, Trust Center, Integrations & Automation, Settings, Notifications, Account, Profile, Support)
`src/app/api/v1/[...path]`	BFF proxy (`route.ts` , `clientIp.ts`)
`src/middleware.ts`	Anonymous redirect for page routes
`src/domain/<module>`	Pages and forms per business module
`src/shared/api`	`apiClient.ts` (token handling, refresh, error mapping), `sessionChannel.ts` (cross-tab), `listCache.ts`
`src/shared/auth`	`AuthContext` , `PageAccessGuard` , `useActionGuard` , `useSectionGuard` , idle timer
`src/shared/config/navigation.ts`	Sidebar, page and section permission keys (mirror of the backend `PermissionCatalog`)
`src/shared/ui`	`DataTable` , modals, pickers, `SyncPoller` , `SessionExpiryModal` , Activity Log
`src/shared/i18n`	English and Azerbaijani strings

The frontend holds no business data of its own. Lists are cached per browser tab (`listCache`) and invalidated by the `grc:data-changed` event that write responses and the sync poll raise.

Installation and deployment

This page describes what the two repositories ship for building and running GRC360, every configuration setting, and what happens when the backend starts. It states the files as they are; where they are incomplete or inconsistent, that is said explicitly so you can plan around it.

What you deploy

Unit	Built from	Runtime	Listens on
Backend	`GRC_Backend_Code/Dockerfile`	`eclipse-temurin:21-jre-alpine`, runs as non-root user `grc360`, `java -cp /app:/app/lib/* com.strativu.grc360.Grc360Application`	`${PORT:-8080}`
Frontend	`GRC_Frontend_Code/Dockerfile`	`node:20-alpine`, runs as non-root user `nextjs` (uid 1001), `npm start` (`next start`)	`PORT=3000`
PostgreSQL 16	image		5432
MinIO (or any S3-compatible store)	image		9000 (API), 9001 (console)
Reverse proxy with TLS	your choice		80/443

Optional: an SMTP relay (`MAIL_*`), LDAP directories (configured in the UI), Prometheus and Grafana.

Backend image

`Dockerfile` is a two-stage build:

1. `eclipse-temurin:21-jdk-alpine`: `./mvnw dependency:go-offline -B`, then `./mvnw clean package -DskipTests -B`, then unpacks the jar.
2. `eclipse-temurin:21-jre-alpine`: installs `curl`, copies the unpacked classes and libraries to `/app`, switches to user `grc360`, declares `HEALTHCHECK curl -f http://localhost:${PORT:-8080}/actuator/health` (interval 30 s, start period 60 s).

The project is compiled for Java 17 (`<java.version>17</java.version>` in `pom.xml`) and runs on the Java 21 runtime image. Tests are not run during the image build.

Working directory inside the container is `/app`. Log files are written to `/app/logs/...` and, with `STORAGE_TYPE=local`, files to `/app/uploads`. Neither path is a volume in the Compose file, so they are lost when the container is recreated.

Frontend image

`Dockerfile` has three stages on `node:20-alpine`: `npm ci`, `npm run build` (with `NEXT_TELEMETRY_DISABLED=1`), and a runner that copies `public`, `.next`, `node_modules` and `package.json` and starts `npm start` on port 3000. `next.config.ts` is empty (no `output: "standalone"`), so the full `node_modules` is copied into the image.

`NEXT_PUBLIC_*` variables are inlined into the browser bundle at build time, so they must be present when `npm run build` runs. `BACKEND_API_URL` is read by the proxy route on the server at run time and must be present in the running container. The Dockerfile sets neither.

Docker Compose

`GRC_Backend_Code/docker-compose.yml` defines seven services on one bridge network `grc360-network`:

Service	Image	Host ports	Volumes	Health check	Depends on
`nginx`	`nginx:alpine`	80, 443	`./nginx/nginx.conf` (ro), `./nginx/ssl` (ro)	`wget http://localhost:80/health`	`app`
`app`	built from `Dockerfile`	8080	none	`curl -f http://localhost:8080/actuator/health` (start period 60 s)	`db`, `redis`, `minio` (all `service_healthy`)
`db`	`postgres:16-alpine`	5432	`postgres_data`, `./postgres/init.sql` as init script	`pg_isready -U postgres -d grc360-db`	
`redis`	`redis:7-alpine`	6379	`redis_data`	`redis-cli ping`	
`minio`	`minio/minio:latest`	9000, 9001	`minio_data`	`curl -f http://localhost:9000/minio/health/live`	
`prometheus`	`prom/prometheus:latest`	9090	`./prometheus/prometheus.yml` (ro), `prometheus_data`	`/-/healthy`	`app`
`grafana`	`grafana/grafana:latest`	3000	`grafana_data`, `./grafana/provisioning` (ro)	`/api/health`	`prometheus`

The `app` service has resource limits of 1 CPU and 1 GB memory (reservation 0.5 CPU, 512 MB) and these environment values:

```
SPRING_PROFILES_ACTIVE=docker
DB_HOST=db  DB_PORT=5432  DB_NAME=grc360-db
SPRING_DATASOURCE_USERNAME=postgres  SPRING_DATASOURCE_PASSWORD=123456
SPRING_JPA_HIBERNATE_DDL_AUTO=update
JWT_SECRET=your-256-bit-secret-key-here-change-in-production
JWT_EXPIRATION=86400
REDIS_HOST=redis
STORAGE_TYPE=minio  MINIO_ENDPOINT=http://minio:9000
MINIO_ACCESS_KEY=admin  MINIO_SECRET_KEY=password123  MINIO_BUCKET_NAME=grc360-files
MAIL_HOST, MAIL_PORT (587), MAIL_STARTTLS (true), MAIL_SSL (false),
MAIL_USERNAME, MAIL_PASSWORD, MAIL_FROM, MAIL_FROM_NAME (GRC360)   passed through from the host
```

`postgres/init.sql` creates the extensions `uuid-ossp` and `pg_trgm`, sets the time zone to UTC and defines a helper function `jsonb_merge`.

Gaps in the Compose file

Read these before using the file as is:

Gap	Effect
There is no frontend service.	The UI must be built and run separately (frontend `Dockerfile`), and something must route browser traffic to it.
`nginx/nginx.conf`, `nginx/ssl/`, `prometheus/prometheus.yml` and `grafana/provisioning/` do not exist in the repository.	Docker creates empty directories for missing bind-mount sources. nginx and Prometheus then cannot read their configuration file and will not start correctly. You must supply these files.
Grafana publishes port 3000.	It collides with the frontend's default port 3000 on the same host.
`JWT_EXPIRATION=86400`	The `docker` profile maps `JWT_EXPIRATION` to `security.jwt.expiration-seconds`, so access tokens live 24 hours instead of the 15-minute default used elsewhere.

Gap	Effect
`JWT_SECRET` is a committed default value, and the database password is `123456`.	The `docker` profile is not treated as hardened by `SecurityValidationConfig`, so the application starts with them and only prints warnings.
`SESSION_COOKIE_SECURE` is not set.	The `docker` profile defaults it to `false`. Set it to `true` whenever users reach the system over HTTPS.
`MINIO_BUCKET_NAME`	Ignored by the `docker` profile, which hard-codes `minio.bucket-name=grc360-files`.
Redis is required healthy before `app` starts.	The application does not use Redis in any profile (see Caching).
The app health check targets `/actuator/health`.	That endpoint reports `DOWN` (HTTP 503) when the LDAP health indicator cannot reach `localhost:389` or the mail indicator has no host, so the container is marked unhealthy even when the application works. See Health checks.
Prometheus has no credentials for the backend.	`/actuator/prometheus` requires the ADMIN role through a Bearer token. A plain scrape receives 401.
`minio/minio:latest`, `prom/prometheus:latest`, `grafana/grafana:latest`	Unpinned tags; the result changes over time.

Backend configuration

Configuration is read from `src/main/resources/application.properties` and then from `application-<profile>.properties` for each active profile, which override individual keys. Any property can also be set through an environment variable using Spring Boot's relaxed binding (for example `SPRING_JPA_HIBERNATE_DDL_AUTO` for `spring.jpa.hibernate.ddl-auto`). The `.env.example` file in the backend repository lists the common variables; the application does not load a `.env` file itself.

Backend environment variables

"Base" is `application.properties` (no profile, or the `dev` profile, which has no file of its own). A dash means the profile does not override the base value.

Server, database, schema

Variable	Property	Base default	`docker`	`prod`
`PORT`	`server.port`	`8080`	`8080`	`8080`
`DB_HOST`	part of `spring.datasource.url`	`localhost`	`db`	required, no default
`DB_PORT`	part of `spring.datasource.url`	`5432`	`5432`	required
`DB_NAME`	part of `spring.datasource.url`	`grc360-db`	`grc360-db`	required
`SPRING_DATASOURCE_USERNAME`	`spring.datasource.username`	`postgres`	`postgres`	required
`SPRING_DATASOURCE_PASSWORD`	`spring.datasource.password`	`123456`	`123456`	required; `prod` refuses to start with an empty value or `123456`
`SPRING_JPA_HIBERNATE_DDL_AUTO`	`spring.jpa.hibernate.ddl-auto`	`update` (fixed)	`update`	`update` (fixed)

Connection pool: `maximum-pool-size` 20 and `minimum-idle` 5 (base, `docker`); 10 and 2 with `leak-detection-threshold=60000` (`prod`). `spring.jpa.show-sql=true` in the base file (and therefore with the `dev` profile); `false` in `docker` and `prod`.

Public address, CORS, administrators

Variable	Property	Default	Notes
`APP_PUBLIC_BASE_URL`	`app.public-base-url`	`http://localhost:3000` (`prod`: `https://grc360.strativu.com`)	Used in invitation links and the SSO callback URLs shown under Settings › Authentication. Must be the URL users reach the frontend at.
`CORS_ALLOWED_ORIGINS`	`cors.allowed-origins`	empty	Comma-separated origin patterns. Empty means the profile defaults in `SecurityConfig`: `prod` / `production` allow `https://grc360.strativu.com`, `https://*.strativu.com`, `https://strativu.com`; `staging` allows `https://staging.strativu.com` and localhost; anything else allows `http://localhost:*`, `https://*.localhost:*`, `http://127.0.0.1:*`, `https://*.127.0.0.1:*`. Browsers that go through the BFF proxy do not need CORS.
`SUPER_ADMIN_EMAILS`	`security.super-admin-emails`	empty	Comma-separated e-mails of break-glass accounts that bypass the role catalogue. Configuration only; cannot be granted through the UI.
`APP_DATA_RESET_KEEP_EMAILS`	`app.data-reset.keep-emails`	`test@example.com`	Accounts kept by a Settings › Data Reset of the People group, in addition to the person running it.

Tokens and sessions

Variable	Property	Base default	`docker`	`prod`
`JWT_SECRET`	`security.jwt.secret`	`dev-only-insecure-jwt-secret-change-me-0123456789`	`your-256-bit-secret-key-here-change-in-production`	required; at least 32 characters and not one of the committed defaults
`JWT_EXPIRATION_SECONDS`	`security.jwt.expiration-seconds`	`900`	not read	`900`
`JWT_EXPIRATION`	`security.jwt.expiration-seconds`	not read	`900` (Compose sets `86400`)	not read
`SESSION_COOKIE_SECURE`	`security.session.cookie-secure`	`true`	`false`	always `true`
`SESSION_IDLE_TIMEOUT_SECONDS`	`security.session.idle-timeout-seconds`	`1800`	`1800`	`1800`
`SESSION_ABSOLUTE_TIMEOUT_SECONDS`	`security.session.absolute-timeout-seconds`	`28800`	`28800`	`28800`
`SESSION_ROTATION_GRACE_SECONDS`	`security.session.rotation-grace-seconds`	`10`	-	-
`SESSION_RETENTION_DAYS`	`security.session.retention-days`	`30`	-	`30`

Variable	Property	Base default	`docker`	`prod`
`SESSION_MAX_PER_USER`	`security.session.max-per-user`	`10`	-	`10`
`SESSION_REMEMBER_ME_ENABLED`	`security.session.remember-me.enabled`	`true`	-	-
`SESSION_REMEMBER_ME_IDLE_TIMEOUT_SECONDS`	`security.session.remember-me.idle-timeout-seconds`	`43200` (12 h)	-	-
`SESSION_REMEMBER_ME_ABSOLUTE_TIMEOUT_SECONDS`	`security.session.remember-me.absolute-timeout-seconds`	`604800` (7 days)	-	-

Fixed session properties: `security.session.cookie-name=grc_refresh`, `cookie-path=/api/v1/auth` (the path the browser sees through the proxy), `cookie-same-site=Lax`.

Rate limiting (in-memory, per JVM, one-minute windows)

Variable	Property	Default
`RATE_LIMIT_ENABLED`	`security.rate-limit.enabled`	`true` (switches the request filter only; the login failure block always applies)
`RATE_LIMIT_LOGIN_IP_PER_MINUTE`	`security.rate-limit.login.ip-per-minute`	`10`
`RATE_LIMIT_LOGIN_MAX_FAILURES`	`security.rate-limit.login.max-failures`	`5`
`RATE_LIMIT_LOGIN_FAILURE_WINDOW_SECONDS`	`security.rate-limit.login.failure-window-seconds`	`900`
`RATE_LIMIT_LOGIN_BLOCK_SECONDS`	`security.rate-limit.login.block-seconds`	`900`
`RATE_LIMIT_REFRESH_IP_PER_MINUTE`	`security.rate-limit.refresh.ip-per-minute`	`60`
`RATE_LIMIT_API_USER_PER_MINUTE`	`security.rate-limit.api.user-per-minute`	`300`
`RATE_LIMIT_API_IP_PER_MINUTE`	`security.rate-limit.api.ip-per-minute`	`60`

File storage

Variable	Property	Base default	`docker`	`prod`
`STORAGE_TYPE`	`storage.type`	`minio` (`local` for machines without MinIO)	-	-
`STORAGE_LOCAL_ROOT`	`storage.local.root`	`uploads`	-	-
`STORAGE_LEGACY_UPLOAD_ROOT`	`storage.legacy-upload-root`	`uploads`	-	-
`STORAGE_MIGRATE_LEGACY`	`storage.migrate-legacy`	`true`	-	-
`MINIO_ENDPOINT`	`minio.endpoint`	`http://localhost:9000`	`http://minio:9000`	`http://localhost:9000`
`MINIO_ACCESS_KEY`	`minio.access-key`	`admin`	`minioadmin`	`admin`
`MINIO_SECRET_KEY`	`minio.secret-key`	`password123`	`minioadmin`	`password123`

Variable	Property	Base default	`docker`	`prod`
`MINIO_BUCKET_NAME`	`minio.bucket-name`	`grc360-files`	fixed `grc360-files`	`grc360-files`
`MINIO_REGION`	`minio.region`	`us-east-1`	fixed `us-east-1`	`us-east-1`
`MINIO_SECURE`	`minio.secure`	`false`	fixed `false`	`false`

Upload limits: `spring.servlet.multipart.max-file-size=25MB`, `max-request-size=30MB` (base, all profiles). The bucket is created at startup if it does not exist.

Mail (SMTP)

Variable	Property	Default
`MAIL_HOST`	`spring.mail.host`	empty: the application sends no mail and logs what it would have sent; invitations still work and show the link to the administrator
`MAIL_PORT`	`spring.mail.port`	`587`
`MAIL_USERNAME`, `MAIL_PASSWORD`	`spring.mail.username`, `spring.mail.password`	empty
`MAIL_STARTTLS`	`mail.smtp.starttls.enable`	`true`
`MAIL_SSL`	`mail.smtp.ssl.enable`	`false` (set `true` and `MAIL_STARTTLS=false` for port 465)
`MAIL_FROM`	`app.mail.from`	empty (no mail is sent while empty)
`MAIL_FROM_NAME`	`app.mail.from-name`	`GRC360`

SMTP connect, read and write timeouts are fixed at 5000 ms. The property `support.contact-email` (not in any file) is read by Settings › System Health › Send to support; see Operations.

Notifications

Variable	Property	Default
`NOTIFICATIONS_SWEEP_ENABLED`	`notifications.sweep.enabled`	`true`
`NOTIFICATIONS_SWEEP_CRON`	`notifications.sweep.cron`	`0 0 8 * * *` (08:00 every day, JVM time zone)

Other properties without an environment variable in the files

Property	Value in files	Notes
`jasypt.encryptor.password`	`grc360-encryption-key-change-in-production` (base)	Key that encrypts LDAP bind passwords, SSO and webhook secrets and MFA secrets in the database. Override with `JASYPT_ENCRYPTOR_PASSWORD`. Changing it later makes existing encrypted values unreadable. Algorithm `PBEWITHHMACSHA512ANDAES_256`.
`spring.security.oauth2.client.registration.google.*`	placeholders; `prod` reads `GOOGLE_CLIENT_ID`, `GOOGLE_CLIENT_SECRET`, `GOOGLE_REDIRECT_URI`	No OAuth login flow is wired into the security chain; see Security.
`spring.data.web.pageable.max-page-size`	`500`	Maximum page size for list endpoints.
`spring.cache.type`	`none` (base, `docker`), `simple` (`prod`)	Caching is inactive in both cases.
`spring.flyway.enabled`	`false` in every profile	See Database schema management.

Property	Value in files	Notes
`server.forward-headers-strategy`	`native`	
`management.endpoints.web.exposure.include`	`health,info,metrics,prometheus`	
`management.endpoint.health.show-details`	`always` (base, `docker`), `when-authorized` (`prod`)	
`springdoc.api-docs.enabled`, `springdoc.swagger-ui.enabled`	`false` in `prod` only	
`app.tenancy.mode`, `app.single-tenant.id`	not set	`single-tenant` mode; see Architecture.
`app.tenancy.custom-domains.enabled`	not set	Enables the custom-domain resolver.
`app.domain`	not set (`strativu.com` in code)	Parent domain for subdomain tenants.
`security.device-fingerprinting.enabled`	not set (`false` in code)	
`grc.seed.dummy-data`	not set	`true` enables `DummyDataSeeder` with the `dev` profile.
`REDIS_HOST`, `REDIS_PORT`	in `.env.example`; `REDIS_HOST` read by `docker` only	Redis auto-configuration is excluded in the base file, so these have no effect.

Spring profiles

Profile	Activated by	What it changes
none	default	Base file only. CORS uses the “dev” origin list (the code treats a missing profile as `dev`).
`dev`	`--spring.profiles.active=dev`	No properties file. Activates `DevDataInitializer`, `DummyDataSeeder` (with `grc.seed.dummy-data=true`), `DatabaseConstraintFixer` and the chaos module. The demo instance runs with this profile.
`docker`	`SPRING_PROFILES_ACTIVE=docker` (Compose)	Container host names, `show-sql=false`, `JWT_EXPIRATION` instead of `JWT_EXPIRATION_SECONDS`, `cookie-secure=false` by default, MinIO defaults `minioadmin`. Not treated as hardened.
`prod`	`SPRING_PROFILES_ACTIVE=prod`	Requires `DB_HOST`, `DB_PORT`, `DB_NAME`, credentials and `JWT_SECRET`; refuses to start with weak values (`SecurityValidationConfig`). Secure cookie forced on. Health details only for authorised callers. Swagger UI and `/v3/api-docs` disabled. `spring.cache.type=simple`.
`staging`	name only	No properties file. Recognised as hardened by `SecurityValidationConfig` and has its own CORS list.
`test`	`@ActiveProfiles("test")` in tests	`src/test/resources/application-test.properties`: in-memory H2 in PostgreSQL mode, `ddl-auto=create-drop`, rate limiting and the notification sweep disabled, Redis, OAuth and WebSocket auto-configuration excluded.

Frontend environment variables

The frontend repository has no `.env.example`, although its `README.md` tells you to copy one. The README's defaults are also wrong (it shows `BACKEND_API_URL=http://localhost:8080` and `NEXT_PUBLIC_TENANT_ID=strativu-default`). The code reads exactly three variables:

Variable	Read where	When	Required	Value
`BACKEND_API_URL`	`src/app/api/v1/[...path]/route.ts` (server)	run time	yes	Backend base URL **including** `/api/v1`, for example `http://localhost:8080/api/v1` or `http://app:8080/api/v1`. The proxy appends the path after `/api/v1/`. Without it every API call returns HTTP 500 `{"error":"BACKEND_API_URL is not configured"}`. There is no default.
`NEXT_PUBLIC_API_BASE_URL`	`src/shared/api/apiClient.ts` (browser)	build time	no	Defaults to `/api/v1`. Must stay a relative path: an absolute URL makes the browser call the backend cross-site, the refresh cookie is not sent, and `apiClient` logs an error and disables session refresh.
`NEXT_PUBLIC_TENANT_ID`	`apiClient.ts` (browser)	build time	see note	Tenant UUID sent as `X-Tenant-ID` on sign-in when the browser has no `tenant_id` in `localStorage`. A browser that has never signed in needs it, because `POST /auth/login` requires the header. After sign-in the tenant comes from the token.

`next.config.ts` contains no settings. Port: `next dev` and `next start` use 3000 unless `-p` or `PORT` says otherwise (the demo instance runs `next dev -p 3200`).

Reverse proxy and TLS

Neither repository contains a working reverse-proxy configuration (the Compose file references a missing `nginx/nginx.conf`; `scripts/ssl-setup.sh` generates a self-signed certificate for `localhost` or requests a Let's Encrypt certificate). The code imposes these requirements on whatever proxy you place in front:

Requirement	Reason
Route browser traffic for the site, including `/api/v1/*`, to the Next.js server. Do not route `/api/v1/*` straight to the backend.	The refresh cookie is scoped to the frontend origin's `/api/v1/auth`, and the CSRF check for auth endpoints lives in the proxy route.
Allow request bodies of at least 30 MB (nginx `client_max_body_size`, default 1 MB).	Backend limit is 25 MB per file, 30 MB per request.

Requirement	Reason
Set `X-Real-IP` (nginx) or keep `CF-Connecting-IP` (Cloudflare).	The proxy route derives the client address from `cf-connecting-ip`, then `x-real-ip`, then the first `x-forwarded-for` entry, and forwards it as `X-Forwarded-For`. The backend uses it for rate limits, sessions and audit.
Allow at least 60 seconds for uploads and 15 seconds for other calls.	Proxy route timeouts.
Terminate TLS and set `SESSION_COOKIE_SECURE=true` (forced in `prod`).	The refresh cookie must be `Secure` on HTTPS.
Keep the backend port (8080) off the public network.	The backend trusts the first `X-Forwarded-For` value for per-IP rate limits and logged IPs, and the actuator, Swagger UI and `/ws` endpoints are on the same port.

First start and seeding

What runs at startup

Every start runs the following `ApplicationRunner`s, in this order. None of them fails the start; failures are logged.

Order	Runner	What it does
0	`migration/SchemaRepairRunner`	Adds columns that `ddl-auto=update` cannot add (NOT NULL with defaults), drops obsolete columns and constraints, rebuilds enum CHECK constraints, one-time backfills recorded by marker rows. 703 lines of idempotent SQL.
0	`migration/DatabaseConstraintFixer` (`dev` only)	Repairs `organization_roles` left in a hybrid state by older migrations.
1	`organization/seed/PermissionCatalogSyncRunner`	For every tenant that has users: upserts the permission catalogue, removes obsolete permission rows, refreshes the built-in groups (`Admin`, `Read Only`, `Third Party`).
1	`visibility/migration/PrincipalIdBackfillRunner`	Converts people stored only by name in older rows into principal ids.
1	`operations/migration/ProjectControlLinkMigration`	Moves project-to-control links onto `internal_control_projects`.
1	`infrastructure/storage/StorageMigrationRunner`	Copies files from the old `uploads/` directory and the old `audit_finding_attachments.content` column into object storage (when `STORAGE_MIGRATE_LEGACY=true`). Sources are not deleted.
2	`visibility/migration/ParticipantBackfillRunner`	Fills `record_participants` from existing records, once per tenant.
2	`compliance/seed/ComplianceAnalysisBackfillRunner`	Creates Compliance Analysis rows for packages imported before the analysis existed.
3	`risk/seed/SeededMatrixCellCleanupRunner`, `operations/seed/DefaultIncidentStageCleanupRunner`	Remove obsolete seeded matrix cells and default incident stages.
last	`config/DevDataInitializer` (`dev` only)	See below.
last	`seed/DummyDataSeeder` (`dev` and `grc.seed.dummy-data=true`)	See below.

Demo and bootstrap data (`dev` profile)

`DevDataInitializer` is the only code that creates a tenant and sign-in accounts. It runs with the `dev` profile only:

- **Every start**: creates, if missing, the tenant `550e8400-e29b-41d4-a716-446655440000` ("Test Tenant", status ACTIVE, plan BASIC) via JDBC; seeds the auth-side permission codes; runs `DefaultRoleSeedService.seedDefaultRolesAndPermissions` for that tenant; makes sure the auth roles `ADMIN` (all permissions), `EDITOR`, `AUDITOR` and `TEST_DELETE_ROLE` exist.
- **Only when the tenant did not exist before this start** (fresh database): departments IT, HR, Finance, Risk & Compliance, Security, Marketing, Operations, Legal; organizations "Strativu Tech" and "Strativu Legal"; organization groups; and four sign-in accounts, all with password `password123`:

E-mail	Name	Status	Auth role
`test@example.com`	System Admin	ACTIVE	ADMIN
`alex.meian@company.com`	Alex Meian	ACTIVE	ADMIN
`sara.j@company.com`	Sara Johnson	ACTIVE	EDITOR
`mike.b@company.com`	Mike Brown	INACTIVE	AUDITOR

Demo content is created only once: records deleted through the UI are not recreated at the next start.

`DummyDataSeeder` (property `grc.seed.dummy-data=true`, `dev` profile) writes departments, users, governance, command-center, risk, compliance, objective and third-party sample rows under tenant `00000000-0000-0000-0000-000000000001`. It does not create a `tenants` row for that id, so the rows cannot be reached through the API (tenant resolution requires an existing tenant). On the demo database this tenant id holds 2 users and no tenant row.

The screenshot data used in this guide was created through the API by `doc/guide/tools/seed_demo.py` (frontend repository), which signs in and posts records; it is idempotent by record name.

`GRC_Backend_Code/db/seed-data.sql` is outdated: it inserts into columns and tables (for example `users.role`, `documents`) that the current entities do not have. Do not use it.

Bootstrapping a new installation

With the `docker` or `prod` profile alone, the database starts empty: no tenant, no account, and `POST /api/v1/tenants` requires an existing ADMIN. The code offers these ways to get the first administrator:

1. Start the backend once with the `dev` profile added (for example `SPRING_PROFILES_ACTIVE=docker,dev`). This creates the tenant and accounts listed above. Then sign in, create your real administrator, change or deactivate the four demo accounts, and restart without `dev`. While `dev` is active the chaos endpoints are also loaded (disabled until enabled through `/api/chaos/enable`).
2. Insert a `tenants` row, a `user_accounts` row with a BCrypt hash and the role links yourself with SQL. The next start's `PermissionCatalogSyncRunner` only syncs tenants that have rows in `users`, so an organization profile is needed as well. This path is not scripted in the repositories.

Set `NEXT_PUBLIC_TENANT_ID` to the tenant UUID when building the frontend, so a browser that has never signed in can do so.

On-premise and air-gapped installation

What the code needs from the network at run time:

Dependency	Needed for	Air-gapped notes
PostgreSQL	everything	local
MinIO / S3	uploads and downloads, Data Reset backups	local MinIO or `STORAGE_TYPE=local` (a directory; not recommended for production by the code comments)
SMTP relay	invitation and notification e-mail	optional; empty `MAIL_HOST` disables sending
LDAP	password check fallback	optional, configured per tenant in the UI

Dependency	Needed for	Air-gapped notes
Internet	nothing at run time	No update check calls out: Settings › Updates lists rows of the `system_updates` table. The Google OAuth endpoints in the properties are not used by any login flow.

What needs the internet at build time:

- Backend: `./mvnw dependency:go-offline` downloads Maven dependencies and the Maven wrapper distribution.
- Frontend: `npm ci` downloads packages, and `src/app/layout.tsx` uses `next/font/google` (Geist, Geist Mono), which fetches font files from Google during `next build`.

For an air-gapped site, build both images on a connected machine, export them with `docker save`, and load them on the target with `docker load`, together with the `postgres:16-alpine` and MinIO images.

For a single organisation, the backend can be pinned to one tenant with `app.tenancy.mode=single-tenant` and `app.single-tenant.id=<uuid>` (not used by any shipped profile). The tenant row must exist.

Upgrade procedure

The repositories contain no upgrade script; the CI workflows call scripts that live on the servers (`/home/grc-strativu-user/deployment/staging-backend.sh`, `.../frontend.sh`). What an upgrade does, as defined by the code:

1. **Back up first.** Take a PostgreSQL dump and a copy of the object storage bucket (see Backups). Schema changes are applied automatically at startup and are not reversible by the application.
2. **Deploy the new backend image** and start it. Hibernate `ddl-auto=update` adds new tables and columns. `SchemaRepairRunner` adds NOT NULL columns with defaults, drops columns and constraints that were removed from entities, and runs one-time backfills. The other startup runners sync the permission catalogue for every tenant and backfill visibility and analysis data.
3. **Check the log** for `Permission catalogue sync completed for N tenant(s)`, `Legacy file migration: ...` and any `ERROR` lines from the runners.
4. **Deploy the new frontend** built with the same `NEXT_PUBLIC_*` values. The backend's sync feed carries a per-JVM `epoch`; open browser tabs notice the restart and reload their data.
5. Sessions survive a backend restart (they are stored in `user_sessions`); in-memory state does not: rate-limit counters, login-failure blocks, the change-feed sequence and the "notification sweep already ran today" marker start fresh.

Downgrades are not supported by the code: columns dropped by `SchemaRepairRunner` are gone.

Database schema management

Item	State
Flyway	`spring.flyway.enabled=false` in `application.properties`, `application-docker.properties`, `application-prod.properties` and `application-test.properties`. The dependencies `flyway-core` and `flyway-database-postgresql` are on the classpath but do not run. The demo database has no `flyway_schema_history` table.
Migration scripts	`src/main/resources/db/migration` holds 24 files `V1` to `V22`. Versions `V2` and `V3` each appear twice (`V2__add_username_unique_constraint.sql` and `V2__mvp_policy_features.sql`; `V3__add_department_contact_fk.sql` and `V3__mvp_evidence_features.sql`), which Flyway would reject. The scripts are historical and do not describe the current schema.
Schema creation	`spring.jpa.hibernate.ddl-auto=update` in every non-test profile (the `docker` profile allows `SPRING_JPA_HIBERNATE_DDL_AUTO` to change it). Hibernate creates missing tables, columns and indexes but never drops or alters existing ones.

Item	State
Repairs	`SchemaRepairRunner` (all profiles) covers what `update` cannot do.
Reported schema version	Settings › About System shows `dbSchemaVersion: V18`; the value is a constant in `SystemInfoAndHealthServiceImpl`, not read from the database.
Size	The demo database has 220 tables in schema `public` (120 entity tables plus join and link tables).

REST API

The backend exposes a JSON REST API under `/api/v1`. The web client is its main consumer, but every endpoint can be called directly by an integration that holds a valid access token. This page describes the conventions shared by all endpoints and lists every operation, generated from the live OpenAPI document of the running backend (`GET /v3/api-docs`, 416 paths, 619 operations) and matched to the backend source.

Where to find the specification

What	Where	Availability
OpenAPI 3 JSON	`GET http://<backend>:8080/v3/api-docs`	All profiles except `prod` (`springdoc.api-docs.enabled=false`). Anonymous.
Swagger UI	`http://<backend>:8080/swagger-ui.html` (redirects to `/swagger-ui/index.html`)	All profiles except `prod`. Anonymous.
Root banner	`GET http://<backend>:8080/` returns `{"version":"1.0.0","message":"GRC360 API is running","swagger":"/swagger-ui/index.html","api_docs":"/v3/api-docs"}`	All profiles
Static files	`doc/api/openapi.yaml` in both repositories, `doc/api/postman-collection.json` (frontend)	Outdated stubs (6 and 11 paths). Use the live document.

The OpenAPI document declares one security scheme, `bearer-jwt` (HTTP bearer, JWT format), applied globally. Its `servers` entry is the URL the document was fetched from.

Two ways to call the API

Caller	Base URL	Authentication
Browser (the GRC360 UI)	`https://<frontend>/api/v1/...` (same origin, through the Next.js proxy)	Bearer access token in memory plus the HttpOnly refresh cookie `grc_refresh` (path `/api/v1/auth`)
Integration, script, test	`http://<backend>:8080/api/v1/...` directly, or through the proxy	Bearer access token; refresh only works with the cookie

Calls through the proxy are subject to the proxy's rules: path segments `.`, `..` or containing `/` or `\` return `400 {"error":"INVALID_PATH"}`; a call to `auth/*` whose `Sec-Fetch-Site` header is present and not `same-origin` returns `403 {"error":"CROSS_SITE_AUTH_BLOCKED"}`; the backend must answer within 15 s (60 s for multipart uploads) or the proxy answers `504 {"error":"Backend timeout"}`.

Authentication endpoints

Method and path	Auth	Purpose
`POST /api/v1/auth/login`	none; header `X-Tenant-Id` required	Body `{"email": "...", "password": "...", "rememberMe": false}`. `identifier` and `login` are accepted as aliases of `email`. Returns `{accessToken, expiresIn, userId, email, fullName, tenantId, roles[], permissions[], modules[]}` and sets two cookies: `grc_refresh` (HttpOnly, path `/api/v1/auth`) and `grc_refresh_present` (HttpOnly, path `/`). Without `rememberMe` both are session cookies; with it they get a `Max-Age`.
`POST /api/v1/auth/refresh`	refresh cookie; header `X-GRC-Client` required (any non-blank value; the UI sends `web`)	Rotates the refresh token and returns `{accessToken, expiresIn}`. The `X-Tenant-Id` header is ignored; the tenant comes from the session row.
`POST /api/v1/auth/logout`	refresh cookie; `X-GRC-Client`	Revokes the current session and clears both cookies.
`POST /api/v1/auth/logout-all`	access token or refresh cookie; `X-GRC-Client`	Revokes every session of the user.
`GET /api/v1/auth/me`	Bearer; header `X-Tenant-Id` required	Echoes the token claims: `userId`, `tenantId`, `roles`, `permissions`.
`GET /api/v1/auth/me/permissions`	Bearer	Recomputes roles, permission codes and modules from the database (including individual grants) and returns `orgUserId`.
`GET /api/v1/auth/sessions`, `GET /auth/sessions/ended`, `POST /auth/sessions/revoke-others`, `DELETE /auth/sessions/{id}`	Bearer	The caller's own sessions.

A missing `X-GRC-Client` header on refresh, logout or logout-all is rejected as access denied (403). The access token is a JWT signed with HMAC-SHA (`Keys.hmacShaKeyFor` over `JWT_SECRET`; the demo secret yields HS384). Claims: `sub` (user account id), `tenantId`, `roles`, `permissions` (module-level authorities only, such as `risk_management_read`, plus older codes such as `POLICY_STANDARD_WRITE`), `sid` (session family), `iat`, `exp`. Lifetime: `security.jwt.expiration-seconds` (900 s by default).

Example with curl (directly against the backend):

```
TENANT=550e8400-e29b-41d4-a716-446655440000
TOKEN=$(curl -s -H "X-Tenant-Id: $TENANT" -H "Content-Type: application/json" \
  -d '{"email":"alex.meian@company.com","password":"password123"}' \
  http://localhost:8080/api/v1/auth/login | jq -r .accessToken)

curl -s -H "Authorization: Bearer $TOKEN" \
  "http://localhost:8080/api/v1/risk-management/asset-risks?page=0&size=20&sort=createdAt,desc"
```

Headers

Header	Direction	Meaning
`Authorization: Bearer <jwt>`	request	Access token. Required for everything except the anonymous paths listed in Security.

Header	Direction	Meaning
`X-Tenant-Id`	request	Tenant UUID. Required on `POST /auth/login` and `GET /auth/me`. For other calls the tenant is taken from the token; without a token the header is used to resolve the tenant. Matched case-insensitively (the UI sends `X-Tenant-ID`).
`X-GRC-Client`	request	Required on `/auth/refresh`, `/auth/logout`, `/auth/logout-all`. Not in the CORS allowed-header list, so a cross-origin browser cannot send it.
`X-Correlation-ID`	both	Echoed if sent, otherwise generated (UUID). Present on every response.
`X-RateLimit-Limit`, `X-RateLimit-Remaining`, `X-RateLimit-Reset`	response	On every counted `/api/**` response while rate limiting is enabled. `Reset` is an epoch second.
`Retry-After`	response	Seconds to wait, on 429 responses.
`X-GRC-Changed`	response	On successful POST/PUT/PATCH/DELETE: comma-separated resource keys (table names) the request changed.
`Set-Cookie`	response	`grc_refresh` and `grc_refresh_present` from login, refresh and logout.
`Cache-Control: no-store`	response	Added by the proxy to every `auth/*` response.

Paging, sorting and filtering

List endpoints come in two styles.

Style A, Spring `Pageable` (30 GET operations). Parameters `page` (zero-based), `size`, `sort=<property>,<asc|desc>` (repeatable). The default size is Spring's 20 unless the endpoint sets another; 15 endpoints declare `@PageableDefault(size = 20)`, 13 of them with `sort = "createdAt", direction = DESC`. `size` is capped at 500 (`spring.data.web.pageable.max-page-size`). Sorting by an unknown property returns `400 INVALID_SORT_PROPERTY`.

Style B, explicit parameters (a few controllers, for example `/tasks` and `/risk-management/operational-risks`). Parameters `page`, `size` (defaults 10 or 20 depending on the endpoint), `sortBy`, `sortDir` (`asc` / `desc`). Size is clamped to 500 by `PaginationLimits.clamp`.

Both styles return the standard Spring `Page` JSON:

```
{
  "content": [ ... ],
  "totalElements": 15, "totalPages": 8, "number": 0, "size": 2,
  "numberOfElements": 2, "first": true, "last": false, "empty": false,
  "pageable": { ... }, "sort": { ... }
}
```

Some endpoints return a plain JSON array (for example `GET /notifications` without `page`, `GET /auth/sessions`, picker reference data). Free-text filtering uses the `search` parameter on 51 GET operations; other filters are endpoint-specific (`status`, `type`, `riskType`, `packageId`, `from`, `to`, …). Global search is `GET /api/v1/search?q=<text>&maxResults=20`.

Writes and files

- Request and response bodies are JSON (`Content-Type: application/json`), except uploads.
- Uploads are `multipart/form-data`. Limits: 25 MB per file, 30 MB per request (`413 FILE_TOO_LARGE`). A truncated body returns `400 INVALID_UPLOAD`. Object storage outages return `503 STORAGE_UNAVAILABLE`.
- Downloads stream the file with `Content-Disposition: attachment; filename*=UTF-8''<name>`.

- Many registers have `POST .../import-csv` and `GET .../export-csv` endpoints (risk registers, Operations Center, Compliance Hub, connectors, controls, policies, continuity plans, policy exceptions, users). Compliance packages use `POST /compliance/packages/{id}/import` and `GET /compliance/packages/{id}/export`. Which of these the UI actually uses is described per register in the module pages.
- Dates are ISO-8601 strings; ids are UUIDs.

Errors

Most errors use the standard body `ApiErrorResponse` (`presentation/common/ApiErrorResponse.java`; null fields are omitted):

```
{
  "error": "RESOURCE_NOT_FOUND",
  "message": "Human-readable text",
  "status": 404,
  "timestamp": "2026-10-14T11:41:17.883Z",
  "path": "/api/v1/...",
  "details": ["optional", "itemised reasons"]
}
```

There is no `correlationId` field in the body (the backend's `doc/api/error-codes.md` shows one); use the `X-Correlation-ID` response header instead. Some layers produce their own shapes:

Source	Status	Body
Spring Security entry point and access-denied handler (`SecurityErrorHandlers`)	401, 403	`{"code":"UNAUTHORIZED","message":"Authentication is required","timestamp":...}` or `{"code":"FORBIDDEN","message":"Access is forbidden",...}` (note `code`, not `error`)
`JwtAuthenticationFilter`	401	`{"error":"TOKEN_EXPIRED" or "INVALID_TOKEN" or "ACCOUNT_INACTIVE" or "SESSION_REVOKED","message":...,"status":401,"timestamp":...,"path":...}`
Refresh failures (`RefreshTokenException`)	401	standard body with `error` = `INVALID_REFRESH_TOKEN`, `IDLE_TIMEOUT`, `ABSOLUTE_TIMEOUT`, `REUSE_DETECTED` or `ACCOUNT_INACTIVE`
`TenantContextFilter`	401, 404, 500	`{"error":"UNAUTHORIZED" or "Tenant not found" or "Tenant resolution error","message":...,"timestamp":...,"requestId":...}`
Permission catalogue checks (`PermissionInterceptor`, `ModulePermissionInterceptor`, `PermissionDeniedAdvice`)	403	`{"error":"Insufficient permissions","required":{"module":"...","submodule":"...","action":"..."}}`
`RateLimitFilter`	429	`{"error":"TOO_MANY_REQUESTS","message":"Too many requests. Try again in N seconds.","status":429,"timestamp":...,"path":...}` plus `Retry-After`
Next.js proxy	400, 403, 500, 504	`{"error":"INVALID_PATH" / "CROSS_SITE_AUTH_BLOCKED" / "BACKEND_API_URL is not configured" / "Internal Proxy Error" / "Backend timeout"}`

Error codes produced by `RestGlobalExceptionHandler` and the filters:

HTTP	`error`	When
400	`VALIDATION_ERROR`	Bean validation failed (`@Valid`); `details` lists fields
400	`CONSTRAINT_VIOLATION`	Parameter constraint violated
400	`INVALID_PARAMETER`	Parameter of the wrong type (for example a malformed UUID in the path)
400	`INVALID_SORT_PROPERTY`	Unknown sort property
400	`MALFORMED_REQUEST`	Unreadable JSON body
400	`BAD_REQUEST`	`IllegalArgumentException` (for example a blank or malformed `X-Tenant-Id` on login)
400	`TENANT_VALIDATION_ERROR` , `DOMAIN_ERROR` , `POLICY_VALIDATION_ERROR`	Tenant, domain or policy rule violations
400	`INVALID_UPLOAD`	Multipart body cannot be read
401	`UNAUTHORIZED`	Authentication missing or failed (a wrong password or unknown e-mail returns the message “Email or password is incorrect.”)
401	`TOKEN_EXPIRED` , `INVALID_TOKEN` , `ACCOUNT_INACTIVE` , `SESSION_REVOKED`	Token problems (see above)
403	`FORBIDDEN`	Access denied, including row-level visibility (`This record is not one of yours...`)
403	`Insufficient permissions`	Permission catalogue denial with `required` triple
404	`RESOURCE_NOT_FOUND`	Record not found in this tenant, or file metadata without a stored object
404	`ENDPOINT_NOT_FOUND`	No such path
404	`TENANT_NOT_FOUND` , `TENANT_RESOLUTION_ERROR`	Tenant missing
405	`METHOD_NOT_ALLOWED`	Verb not supported on the path
409	`CONFLICT`	`IllegalStateException` from a business rule (for example a duplicate)
409	`DATA_INTEGRITY_VIOLATION`	Database constraint violated
409	`IMMUTABLE_ROLE` , `ROLE_IN_USE` , `VENDOR_IN_USE` , `TENANT_LIMIT_EXCEEDED`	Specific blocked operations
409	`ADMIN_ONLY_PERMISSION` , `SELF_GROUP_ACCESS` , `SELF_MEMBERSHIP` , `ADMIN_GROUP_REQUIRES_ADMIN` , `PERMISSION_NOT_HELD`	Access-escalation guards (see Security)
413	`FILE_TOO_LARGE`	File over 25 MB or request over 30 MB
429	`TOO_MANY_REQUESTS`	Rate limit window exhausted
429	`TOO_MANY_ATTEMPTS`	Account blocked after repeated failed logins

HTTP	`error`	When
500	`INTERNAL_SERVER_ERROR`	Unhandled exception (message `An unexpected error occurred`); also a missing `X-Tenant-Id` header on `/auth/login` or `/auth/me`
500	`INFRASTRUCTURE_ERROR`	Infrastructure exception
503	`STORAGE_UNAVAILABLE`	Object storage not reachable

The web client maps these into messages: a 403 with `required` opens the Request Access dialog, `SESSION_REVOKED` ends the session, a message containing “tenant not found” clears the stored tenant id, and 429 shows the `Retry-After` delay.

Rate limiting

Enabled by default (`RATE_LIMIT_ENABLED=true`), in memory, per JVM, fixed one-minute windows. It applies to paths under `/api/` except CORS preflights:

Budget	Key	Default per minute
`POST /api/v1/auth/login`	client IP	10
`POST /api/v1/auth/refresh`	client IP	60
Any other `/api/**` call with a valid token	user account id	300
Any other `/api/**` call without a token	client IP	60

Separately, five failed logins for the same tenant and e-mail within 15 minutes block that account for 15 minutes (`429 TOO_MANY_ATTEMPTS`, with `Retry-After`), even with the right password; a successful login resets the counter. Failures are counted for e-mails that do not exist as well. The client IP is the first `X-Forwarded-For` value, then `X-Real-IP`, then the socket address. Values are configurable; see Installation.

Endpoint catalogue

Generated from `GET /v3/api-docs` on the running backend (dev profile). “Purpose” is the operation summary from the code (`@Operation(summary)`), or, where the code has none (109 operations), the Java method name spelled out. Each group header names the controller class and whether the web client calls it (a search of the frontend `src` for the controller’s base path, test files excluded).

The `chaos` group exists only when the `dev` profile is active. Everything else exists in every profile.

Operations per module

Module	Paths	Operations
Command Center	1	1
Governance Hub	13	28
Organization Hub	26	37
Third Parties	5	11
Asset Management	17	28
Control Center	32	68
Risk Management	62	89
Compliance Hub and older compliance models	52	75
Operations Center	53	86
Settings	50	69
Authentication and sessions	24	31

Module	Paths	Operations
Notifications	7	8
Comments and Activity Log	6	7
Global search	1	1
Sync feed	1	1
Audit log	1	1
Tenant management	8	9
Evidence (older model)	7	8
Incidents (older model)	2	4
Issues and exception requests (older model)	6	10
Policy templates and acknowledgments (older model)	8	10
Tasks (older model)	20	23
Chaos testing (dev profile only)	13	13
Root	1	1
Total	**416**	**619**

Of the 619 operations, 174 belong to controllers the web client does not call (older models, alternative endpoints, MFA, SSO provider, tenant management, chaos).

Command Center

Source package: `modules/commandcenter`. 1 path, 1 operation.

Command Center - Overview (1 operation; `DashboardController`; used by the web client)

Path	Methods	Purpose
`/api/v1/command-center/dashboard`	GET	Get dashboard overview for the tenant

Governance Hub

Source package: `modules/governance`. 13 paths, 28 operations.

Governance - Objectives (5 operations; `ObjectiveController`; used by the web client)

Path	Methods	Purpose
`/api/v1/governance/objectives`	GET, POST	GET: List objectives for the tenant, one page at a time; POST: Create a new objective
`/api/v1/governance/objectives/{id}`	GET, PUT, DELETE	GET: Get objective by ID; PUT: Update an existing objective; DELETE: Delete an objective

Governance - Objective Audits (5 operations; `ObjectiveAuditController`; used by the web client)

Path	Methods	Purpose
`/api/v1/governance/objective-audits`	GET, POST	GET: List objective audits for the tenant, optionally filtered by objective; POST: Create a new objective audit
`/api/v1/governance/objective-audits/{id}`	GET, PUT, DELETE	GET: Get an objective audit by ID; PUT: Update an objective audit; DELETE: Delete an objective audit

Governance - Objective Audit Results (4 operations; `ObjectiveAuditResultOptionController`; used by the web client)

Path	Methods	Purpose
`/api/v1/governance/objective-audits/result-options`	GET, POST	GET: List audit result options; seeds the defaults on the tenant's first call; POST: Create a new audit result option
`/api/v1/governance/objective-audits/result-options/{id}`	PUT, DELETE	PUT: Rename, reclassify or reorder an audit result option; DELETE: Delete an audit result option (409 while audits still use it)

Governance - Issues (5 operations; `IssueController`; used by the web client)

Path	Methods	Purpose
`/api/v1/governance/issues`	GET, POST	GET: List issues for the tenant, one page at a time; POST: Create a new issue
`/api/v1/governance/issues/{id}`	GET, PUT, DELETE	GET: Get issue by ID; PUT: Update an existing issue; DELETE: Delete an issue

Governance - Coverage (5 operations; `CoverageController`; used by the web client)

Path	Methods	Purpose
`/api/v1/governance/coverages`	GET, POST	GET: List all coverages for the tenant with optional filtering; POST: Create a new coverage
`/api/v1/governance/coverages/{id}`	GET, PUT, DELETE	GET: Get coverage by ID; PUT: Update an existing coverage; DELETE: Delete a coverage

Governance - Objective Audit Evidence (4 operations; `ObjectiveAuditEvidenceController`; used by the web client)

Path	Methods	Purpose
`/api/v1/governance/objective-audits/evidence`	GET, POST	GET: List goal audit evidence, for one audit or for the whole tenant; POST: Attach an evidence file to a goal audit
`/api/v1/governance/objective-audits/evidence/{id}`	DELETE	Remove a goal audit evidence file
`/api/v1/governance/objective-audits/evidence/{id}/download`	GET	Download a goal audit evidence file

Organization Hub

Source package: `modules/organization`. 26 paths, 37 operations.

Organization - Users (7 operations; `UserController`; used by the web client)

Path	Methods	Purpose
`/api/v1/organization/users`	GET, POST	GET: List users for the tenant, one page at a time; POST: Create a new user
`/api/v1/organization/users/import-csv`	POST	Import users from CSV file
`/api/v1/organization/users/{id}`	GET, PUT, DELETE	GET: Get user by ID; PUT: Update an existing user; DELETE: Deactivate a user (soft delete)
`/api/v1/organization/users/{id}/activate`	PATCH	Activate a deactivated user

Organization - Roles (14 operations; `RoleController`; used by the web client)

Path	Methods	Purpose
`/api/v1/organization/roles`	GET, POST	GET: List all roles for the tenant; POST: Create a new role
`/api/v1/organization/roles/bulk-delete`	POST	Delete several roles at once; returns a per-role outcome (default and in-use roles are refused individually)
`/api/v1/organization/roles/permissions`	GET, POST	GET: List all permissions for the tenant; POST: Create a new permission
`/api/v1/organization/roles/permissions/by-module/{module}`	GET	Get permissions by module
`/api/v1/organization/roles/permissions/catalog`	GET	Get permission catalog grouped by module and submodule
`/api/v1/organization/roles/permissions/seed`	POST	Force seed default roles and permissions
`/api/v1/organization/roles/permissions/{id}`	GET	Get permission by ID
`/api/v1/organization/roles/{id}`	GET, PUT, DELETE	GET: Get role by ID; PUT: Update an existing role (default roles are immutable); DELETE: Delete a role (default roles cannot be deleted)
`/api/v1/organization/roles/{id}/clone`	POST	Clone a role with all its permissions
`/api/v1/organization/roles/{id}/permissions`	PUT	Update role permissions

Organization - Departments (6 operations; `DepartmentController`; used by the web client)

Path	Methods	Purpose
`/api/v1/organization/departments`	GET, POST	GET: Get all departments for the tenant; POST: Create a new department
`/api/v1/organization/departments/{id}`	GET, PUT, DELETE	GET: Get department by ID; PUT: Update department; DELETE: Deactivate a department, or delete it outright with hard=true
`/api/v1/organization/departments/{id}/activate`	PATCH	Activate a deactivated department

Organization - Permission Grants (3 operations; `PermissionGrantController`; used by the web client)

Path	Methods	Purpose
`/api/v1/organization/users/{userId}/grants`	GET, POST	GET: List a user’s permission grants, including expired and revoked ones; POST: Grant a single permission to a user (optionally time-boxed)
`/api/v1/organization/users/{userId}/grants/{grantId}/revoke`	POST	Revoke a grant (soft: the audit record is kept)

Organization - Access Requests (6 operations; `AccessRequestController`; used by the web client)

Path	Methods	Purpose
`/api/v1/organization/access-requests`	POST	File an access request for a denied permission
`/api/v1/organization/access-requests/my`	GET	The caller’s own access requests

Path	Methods	Purpose
`/api/v1/organization/access-requests/pending`	GET	Undecided access requests (admin queue)
`/api/v1/organization/access-requests/pending/count`	GET	Number of undecided access requests: feeds the queue badge
`/api/v1/organization/access-requests/{id}/approve`	POST	Approve as a personal grant (USER_GRANT) or a role update (ADD_TO_ROLE)
`/api/v1/organization/access-requests/{id}/reject`	POST	Reject an access request, optionally with a note

Organization - Principals (1 operation; `PrincipalLookupController`; used by the web client)

Path	Methods	Purpose
`/api/v1/organization/principals`	GET	List selectable users and groups for the tenant

Third Parties

Source package: `modules/thirdparty`. 5 paths, 11 operations.

Third Party - Vendors (5 operations; `VendorController`; used by the web client)

Path	Methods	Purpose
`/api/v1/thirdparty/vendors`	GET, POST	GET: List vendors for the tenant, one page at a time; POST: Create a new vendor
`/api/v1/thirdparty/vendors/{id}`	GET, PUT, DELETE	GET: Get vendor by ID; PUT: Update an existing vendor; DELETE: Delete a vendor

Third Party - Service Agreements (6 operations; `ServiceAgreementController`; used by the web client)

Path	Methods	Purpose
`/api/v1/thirdparty/service-agreements`	GET, POST	GET: List service agreements for the tenant, one page at a time; POST: Create a new service agreement
`/api/v1/thirdparty/service-agreements/vendor/{vendorId}`	GET	Get service agreements by vendor ID
`/api/v1/thirdparty/service-agreements/{id}`	GET, PUT, DELETE	GET: Get service agreement by ID; PUT: Update an existing service agreement; DELETE: Delete a service agreement

Asset Management

Source package: `modules/asset`. 17 paths, 28 operations.

vendor-document-controller (7 operations; `VendorDocumentController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/vendors/documents/expiring`	GET	Get expiring documents
`/api/v1/vendors/{vendorId}/documents`	GET, POST	GET: Get vendor documents; POST: Upload document
`/api/v1/vendors/{vendorId}/documents/{documentId}`	GET, DELETE	GET: Get document by id; DELETE: Delete document
`/api/v1/vendors/{vendorId}/documents/{documentId}/approve`	PUT	Approve document

Path	Methods	Purpose
`/api/v1/vendors/{vendorId}/documents/{documentId}/reject`	PUT	Reject document

asset-controller (5 operations; `AssetController` ; used by the web client)

Path	Methods	Purpose
`/api/v1/assets`	GET, POST	GET: List; POST: Create
`/api/v1/assets/{id}`	GET, PUT, DELETE	GET: Get by id; PUT: Update; DELETE: Delete

Asset Management - Data Movement (6 operations; `DataMovementController` ; used by the web client)

Path	Methods	Purpose
`/api/v1/asset/data-movements`	GET, POST	GET: List data movements for the tenant, one page at a time; POST: Create a new data movement record
`/api/v1/asset/data-movements/asset/{assetId}`	GET	Get data movements by asset ID
`/api/v1/asset/data-movements/{id}`	GET, PUT, DELETE	GET: Get data movement by ID; PUT: Update an existing data movement; DELETE: Delete a data movement

Asset Management - Reviews (5 operations; `AssetReviewController` ; used by the web client)

Path	Methods	Purpose
`/api/v1/asset-management/reviews`	GET, POST	GET: List asset reviews, optionally filtered by asset; POST: Create an asset review
`/api/v1/asset-management/reviews/{id}`	GET, PUT, DELETE	GET: Get an asset review by ID; PUT: Update an asset review; DELETE: Delete an asset review

vendor-questionnaire-controller (5 operations; `VendorQuestionnaireController` ; not called by the web client)

Path	Methods	Purpose
`/api/v1/vendor-questionnaires`	POST	Create questionnaire
`/api/v1/vendor-questionnaires/status/{status}`	GET	Get questionnaires by status
`/api/v1/vendor-questionnaires/vendor/{vendorId}`	GET	Get questionnaires by vendor
`/api/v1/vendor-questionnaires/{id}/complete`	POST	Complete questionnaire
`/api/v1/vendor-questionnaires/{id}/send`	POST	Send questionnaire

Control Center

Source package: `modules/control` . 32 paths, 68 operations.

Control Center - Policies & Standards (6 operations; `PolicyStandardController` ; used by the web client)

Path	Methods	Purpose
`/api/v1/control/policies-standards`	GET, POST	GET: List policy standards, one page at a time; POST: Create a new policy standard

Path	Methods	Purpose
`/api/v1/control/policies-standards/import-csv`	POST	Import policy standards from a CSV file
`/api/v1/control/policies-standards/{id}`	GET, PUT, DELETE	GET: Get policy standard by ID; PUT: Update an existing policy standard; DELETE: Delete a policy standard

Control Center - Policy Reviews (5 operations; `PolicyReviewController`; used by the web client)

Path	Methods	Purpose
`/api/v1/control/policies-standards/reviews`	GET, POST	GET: List all policy reviews; POST: Create a new policy review
`/api/v1/control/policies-standards/reviews/{id}`	GET, PUT, DELETE	GET: Get policy review by ID; PUT: Update an existing policy review; DELETE: Delete a policy review

Control Center - Playbooks (6 operations; `PlaybookController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/control/playbooks`	GET, POST	GET: List all playbooks for the tenant; POST: Create a new playbook
`/api/v1/control/playbooks/continuity-plan/{continuityPlanId}`	GET	Get playbooks by continuity plan ID
`/api/v1/control/playbooks/{id}`	GET, PUT, DELETE	GET: Get playbook by ID; PUT: Update an existing playbook; DELETE: Delete a playbook

Control Center - Internal Controls (21 operations; `InternalControlController`; used by the web client)

Path	Methods	Purpose
`/api/v1/control/internal-controls`	GET, POST	GET: List internal controls, one page at a time; POST: Create a new internal control
`/api/v1/control/internal-controls/import-csv`	POST	Import internal controls from a CSV file
`/api/v1/control/internal-controls/{controlId}/audits`	GET, POST	GET: List all audits for internal control; POST: Create a new audit for internal control
`/api/v1/control/internal-controls/{controlId}/audits/{auditId}`	GET, PUT, DELETE	GET: Get audit by ID; PUT: Update an existing audit; DELETE: Delete an audit
`/api/v1/control/internal-controls/{controlId}/issues`	GET, POST	GET: List all issues for internal control; POST: Create a new issue for internal control
`/api/v1/control/internal-controls/{controlId}/issues/{issueId}`	GET, PUT, DELETE	GET: Get issue by ID; PUT: Update an existing issue; DELETE: Delete an issue
`/api/v1/control/internal-controls/{controlId}/maintenances`	GET, POST	GET: List all maintenances for internal control; POST: Create a new maintenance for internal control
`/api/v1/control/internal-controls/{controlId}/maintenances/{maintenanceId}`	GET, PUT, DELETE	GET: Get maintenance by ID; PUT: Update an existing maintenance; DELETE: Delete a maintenance
`/api/v1/control/internal-controls/{id}`	GET, PUT, DELETE	GET: Get internal control by ID; PUT: Update an existing internal control; DELETE: Delete an internal control

Control Center - Exceptions (6 operations; `ControlExceptionController`; used by the web client)

Path	Methods	Purpose
`/api/v1/control/exceptions`	GET, POST	GET: List all control exceptions; POST: Create a new control exception
`/api/v1/control/exceptions/import-csv`	POST	Import control exceptions from a CSV file
`/api/v1/control/exceptions/{id}`	GET, PUT, DELETE	GET: Get control exception by ID; PUT: Update an existing control exception; DELETE: Delete a control exception

Control Center - Continuity Plan Tasks (5 operations; `ContinuityPlanTaskController`; used by the web client)

Path	Methods	Purpose
`/api/v1/control/continuity-plans/{planId}/tasks`	GET, POST	GET: List all tasks for a continuity plan; POST: Create a new continuity plan task
`/api/v1/control/continuity-plans/{planId}/tasks/{id}`	GET, PUT, DELETE	GET: Get task by ID; PUT: Update an existing task; DELETE: Delete a task

Control Center - Continuity Plan Audits (5 operations; `ContinuityPlanAuditController`; used by the web client)

Path	Methods	Purpose
`/api/v1/control/continuity-plans/{planId}/audits`	GET, POST	GET: List all audits for a continuity plan; POST: Create a new continuity plan audit
`/api/v1/control/continuity-plans/{planId}/audits/{id}`	GET, PUT, DELETE	GET: Get audit by ID; PUT: Update an existing audit; DELETE: Delete an audit

Control Center - Business Continuity (6 operations; `ContinuityPlanController`; used by the web client)

Path	Methods	Purpose
`/api/v1/control/continuity-plans`	GET, POST	GET: List all continuity plans for the tenant; POST: Create a new continuity plan
`/api/v1/control/continuity-plans/import-csv`	POST	Import continuity plans from a CSV file
`/api/v1/control/continuity-plans/{id}`	GET, PUT, DELETE	GET: Get continuity plan by ID; PUT: Update an existing continuity plan; DELETE: Delete a continuity plan

Control Center - Catalogues (4 operations; `ControlCatalogOptionController`; used by the web client)

Path	Methods	Purpose
`/api/v1/control/catalog-options`	GET, POST	GET: List a catalogue; POST: Add an entry to a catalogue
`/api/v1/control/catalog-options/{id}`	PUT, DELETE	PUT: Rename a catalogue entry; DELETE: Remove a catalogue entry

Control Center - Evidence (4 operations; `ControlEvidenceController`; used by the web client)

Path	Methods	Purpose
`/api/v1/control/evidence`	GET, POST	GET: List evidence of one kind, for a single owner or for the whole tenant; POST: Attach an evidence file
`/api/v1/control/evidence/{id}`	DELETE	Remove an evidence file

Path	Methods	Purpose
`/api/v1/control/evidence/{id}/download`	GET	Download an evidence file

Risk Management

Source package: `modules/risk`. 62 paths, 89 operations.

Risk Management - Risk Exceptions (6 operations; `RiskExceptionController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/risk/risk-exceptions`	GET, POST	GET: List all risk exceptions for the tenant; POST: Create a new risk exception
`/api/v1/risk/risk-exceptions/risk/{riskId}`	GET	Get risk exceptions by risk ID
`/api/v1/risk/risk-exceptions/{id}`	GET, PUT, DELETE	GET: Get risk exception by ID; PUT: Update an existing risk exception; DELETE: Delete a risk exception

Third Party Risk Management (8 operations; `ThirdPartyRiskController`; used by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/third-party-risks`	GET, POST	GET: List Third Party Risks; POST: Create Third Party Risk
`/api/v1/risk-management/third-party-risks/by-vendor/{vendorId}`	GET	Get Third Party Risks by Vendor ID
`/api/v1/risk-management/third-party-risks/export-csv`	GET	Export Third Party Risks to CSV
`/api/v1/risk-management/third-party-risks/import-csv`	POST	Import Third Party Risks from CSV
`/api/v1/risk-management/third-party-risks/{id}`	GET, PUT, DELETE	GET: Get Third Party Risk by ID; PUT: Update Third Party Risk; DELETE: Delete Third Party Risk

Risk Management Reviews (4 operations; `RiskReviewController`; used by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/risk-reviews`	GET, POST	GET: List reviews of one risk type, for a single risk or the whole tenant; POST: Add a review
`/api/v1/risk-management/risk-reviews/{id}`	PUT, DELETE	PUT: Update a review; DELETE: Delete a review

Risk Exceptions Management (9 operations; `RiskExceptionManagementController`; used by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/risk-exceptions`	GET, POST	GET: List Risk Exceptions; POST: Create Risk Exception
`/api/v1/risk-management/risk-exceptions/expire-due`	POST	Trigger automatic expiration of due risk exceptions (Admin/System)
`/api/v1/risk-management/risk-exceptions/{id}`	GET, PUT, DELETE	GET: Get Risk Exception by ID; PUT: Update Risk Exception; DELETE: Delete Risk Exception

Path	Methods	Purpose
`/api/v1/risk-management/risk-exceptions/{id}/approve`	POST	Approve Risk Exception
`/api/v1/risk-management/risk-exceptions/{id}/deny`	POST	Deny Risk Exception
`/api/v1/risk-management/risk-exceptions/{id}/submit`	POST	Submit Risk Exception for approval

Operational / Business Risk Management (8 operations; `OperationalRiskManagementController`; used by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/operational-risks`	GET, POST	GET: List Operational/Business Risks; POST: Create Operational/Business Risk
`/api/v1/risk-management/operational-risks/by-department/{departmentId}`	GET	Get Operational/Business Risks by Department ID
`/api/v1/risk-management/operational-risks/export-csv`	GET	Export Operational/Business Risks to CSV
`/api/v1/risk-management/operational-risks/import-csv`	POST	Import Operational/Business Risks from CSV
`/api/v1/risk-management/operational-risks/{id}`	GET, PUT, DELETE	GET: Get Operational/Business Risk by ID; PUT: Update Operational/Business Risk; DELETE: Delete Operational/Business Risk

risk-module-settings-controller (2 operations; `RiskModuleSettingsController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/module-settings/{riskType}`	GET, PUT	GET: Get; PUT: Update

Risk Management Settings (17 operations; `RiskSettingsController`; used by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/analysis-matrix`	GET, PUT	GET: Get analysis matrix; PUT: Update analysis matrix
`/api/v1/risk-management/appetite`	GET, PUT	GET: Get risk appetite settings; PUT: Update risk appetite settings
`/api/v1/risk-management/calculation-methods`	GET, POST	GET: Get calculation methods; POST: Create calculation method
`/api/v1/risk-management/calculation-methods/{id}`	PUT, DELETE	PUT: Update calculation method; DELETE: Delete calculation method
`/api/v1/risk-management/classification-types`	GET, POST	GET: Get classification types; POST: Create classification type
`/api/v1/risk-management/classification-types/{id}`	PUT, DELETE	PUT: Update classification type; DELETE: Delete classification type
`/api/v1/risk-management/classifications`	GET, POST	GET: Get classification values; POST: Create classification value

Path	Methods	Purpose
`/api/v1/risk-management/classifications/{id}`	PUT, DELETE	PUT: Update classification value; DELETE: Delete classification value
`/api/v1/risk-management/settings`	GET	Get overall risk management settings

Asset Risk Management (7 operations; `AssetRiskController`; used by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/asset-risks`	GET, POST	GET: List Asset Risks; POST: Create Asset Risk
`/api/v1/risk-management/asset-risks/export-csv`	GET	Export Asset Risks to CSV
`/api/v1/risk-management/asset-risks/import-csv`	POST	Import Asset Risks from CSV
`/api/v1/risk-management/asset-risks/{id}`	GET, PUT, DELETE	GET: Get Asset Risk by ID; PUT: Update Asset Risk; DELETE: Delete Asset Risk

risk-control-mapping-controller (5 operations; `RiskControlMappingController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/risk-control-mappings`	POST	Create mapping
`/api/v1/risk-control-mappings/control/{controlId}`	GET	Get mappings by control
`/api/v1/risk-control-mappings/risk/{riskId}`	GET	Get mappings by risk
`/api/v1/risk-control-mappings/{id}`	DELETE	Delete mapping
`/api/v1/risk-control-mappings/{id}/effectiveness`	PUT	Update control effectiveness

Risk Saved Views (3 operations; `RiskSavedViewController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/saved-views`	GET, POST	GET: List Saved Views; POST: Create Saved View
`/api/v1/risk-management/saved-views/{id}`	DELETE	Delete Saved View

Risk Reference Data & Metadata (18 operations; `RiskReferenceDataController`; used by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/metadata`	GET	Get Risk Management Metadata
`/api/v1/risk-management/reference-data`	GET	Get Combined Reference Data
`/api/v1/risk-management/reference-data/assets`	GET	Get Assets reference data
`/api/v1/risk-management/reference-data/business-units`	GET	Get Business Units reference data
`/api/v1/risk-management/reference-data/compliance-items`	GET	Compliance requirement items a risk can affect
`/api/v1/risk-management/reference-data/continuity-plans`	GET	Get Continuity Plans reference data

Path	Methods	Purpose
`/api/v1/risk-management/reference-data/controls`	GET	Get Controls reference data
`/api/v1/risk-management/reference-data/impacts`	GET	Get Impact values reference data
`/api/v1/risk-management/reference-data/likelihoods`	GET	Get Likelihood values reference data
`/api/v1/risk-management/reference-data/policies`	GET	Get Policies reference data
`/api/v1/risk-management/reference-data/processes`	GET	Get Processes reference data
`/api/v1/risk-management/reference-data/projects`	GET	Get Operations Projects reference data
`/api/v1/risk-management/reference-data/risk-exceptions`	GET	Get Risk Exceptions reference data
`/api/v1/risk-management/reference-data/risks`	GET	Every risk across the three registers, for pickers outside Risk Management
`/api/v1/risk-management/reference-data/security-incidents`	GET	Security incidents a risk can name (QA Modul 8)
`/api/v1/risk-management/reference-data/treatments`	GET	Get Treatment options reference data
`/api/v1/risk-management/reference-data/users-groups`	GET	Get Users & Groups reference data
`/api/v1/risk-management/reference-data/vendors`	GET	Get Vendors reference data

Risk Command Center Aggregates (2 operations; `RiskCommandCenterController` ; not called by the web client)

Path	Methods	Purpose
`/api/v1/risk-management/command-center`	GET	Fallback forward for frontend dashboard typo
`/api/v1/risk-management/command-center/summary`	GET	Get Command Center Risk Summary and Aggregates

Compliance Hub and older compliance models

Source package: `modules/compliance` . 52 paths, 75 operations.

trust-center-controller (6 operations; `TrustCenterController` ; not called by the web client)

Path	Methods	Purpose
`/api/v1/trust-center/documents`	POST	Upload document
`/api/v1/trust-center/documents/public`	GET	Get public documents
`/api/v1/trust-center/documents/status/{status}`	GET	Get documents by status
`/api/v1/trust-center/documents/type/{type}`	GET	Get documents by type
`/api/v1/trust-center/documents/{id}/access`	PUT	Update document access

Path	Methods	Purpose
`/api/v1/trust-center/documents/{id}/revoke`	POST	Revoke document

gap-assessment-controller (4 operations; `GapAssessmentController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/gap-assessments`	GET, POST	GET: Get assessments; POST: Create assessment
`/api/v1/gap-assessments/framework/{frameworkId}`	GET	Get assessment by framework
`/api/v1/gap-assessments/{id}`	PUT	Update assessment

compliance-framework-controller (4 operations; `ComplianceFrameworkController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/frameworks`	GET, POST	GET: Get active frameworks; POST: Create framework
`/api/v1/frameworks/{code}`	GET	Get framework by code
`/api/v1/frameworks/{id}`	PUT	Update framework

Compliance Hub - Frameworks & Packages (11 operations; `CompliancePackageController`; used by the web client)

Path	Methods	Purpose
`/api/v1/compliance/packages`	GET, POST	GET: List all compliance packages; POST: Create a new compliance package
`/api/v1/compliance/packages/{id}`	GET, PUT, DELETE	GET: Get compliance package by ID; PUT: Update compliance package; DELETE: Delete compliance package (Soft Delete)
`/api/v1/compliance/packages/{id}/export`	GET	Export requirement items to CSV
`/api/v1/compliance/packages/{id}/import`	POST	Import requirement items via CSV
`/api/v1/compliance/packages/{id}/items`	GET, POST	GET: Get requirement items for a package; POST: Add requirement item to package
`/api/v1/compliance/packages/{id}/items/{itemId}`	PUT, DELETE	PUT: Update requirement item; DELETE: Delete requirement item (Soft Delete)

Compliance Hub - Obligations (11 operations; `ObligationController`; used by the web client)

Path	Methods	Purpose
`/api/v1/compliance/obligations`	GET, POST	GET: List all obligations with filters; POST: Create a new obligation
`/api/v1/compliance/obligations/categories`	GET, POST	GET: Get obligation categories; POST: Create obligation category
`/api/v1/compliance/obligations/export-csv`	GET	Export obligations to CSV
`/api/v1/compliance/obligations/import-csv`	POST	Import obligations from CSV
`/api/v1/compliance/obligations/summary`	GET	Get obligation dashboard KPI summary

Path	Methods	Purpose
`/api/v1/compliance/obligations/{id}`	GET, PUT, DELETE	GET: Get obligation by ID; PUT: Update an existing obligation; DELETE: Delete an obligation (Soft Delete)
`/api/v1/compliance/obligations/{id}/map-requirements`	POST	Map obligation to compliance requirement items

Compliance Hub - Exceptions (12 operations; `ComplianceExceptionHubController`; used by the web client)

Path	Methods	Purpose
`/api/v1/compliance/exceptions`	GET, POST	GET: List compliance exceptions; POST: Create compliance exception
`/api/v1/compliance/exceptions/expire-due`	POST	Trigger auto-expire for this tenant's due exceptions
`/api/v1/compliance/exceptions/export-csv`	GET	Export exceptions to CSV
`/api/v1/compliance/exceptions/import-csv`	POST	Import exceptions from CSV
`/api/v1/compliance/exceptions/reference`	GET	Exceptions as reference data for pickers
`/api/v1/compliance/exceptions/{id}`	GET, PUT, DELETE	GET: Get compliance exception by ID; PUT: Update compliance exception; DELETE: Delete compliance exception (Soft Delete)
`/api/v1/compliance/exceptions/{id}/approve`	POST	Approve compliance exception
`/api/v1/compliance/exceptions/{id}/close`	POST	Close compliance exception
`/api/v1/compliance/exceptions/{id}/submit-review`	POST	Submit exception for review

Compliance Hub - External Audit Findings (12 operations; `ExternalAuditFindingController`; used by the web client)

Path	Methods	Purpose
`/api/v1/compliance/audit-findings`	GET, POST	GET: List audit findings; POST: Create external audit finding
`/api/v1/compliance/audit-findings/export-csv`	GET	Export findings to CSV
`/api/v1/compliance/audit-findings/import-csv`	POST	Import findings from CSV
`/api/v1/compliance/audit-findings/reference`	GET	Findings as reference data for pickers
`/api/v1/compliance/audit-findings/{id}`	GET, PUT, DELETE	GET: Get audit finding by ID; PUT: Update audit finding; DELETE: Delete audit finding (Soft Delete)
`/api/v1/compliance/audit-findings/{id}/attachments`	GET, POST	GET: Get finding attachments list; POST: Upload evidence attachment for finding
`/api/v1/compliance/audit-findings/{id}/attachments/{attachmentId}`	DELETE	Delete attachment (Soft Delete)

Path	Methods	Purpose
`/api/v1/compliance/audit-findings/{id}/attachments/{attachmentId}/download`	GET	Download attachment file

Compliance Hub - Assessments (11 operations; `ComplianceAssessmentController`; used by the web client)

Path	Methods	Purpose
`/api/v1/compliance/analysis`	GET	Get compliance analysis for a package, or for every package when none is given
`/api/v1/compliance/assessment-items/{itemId}`	PUT, DELETE	PUT: Update assessment item strategy and evidence/control links; DELETE: Remove a requirement row from the analysis
`/api/v1/compliance/assessments`	GET, POST	GET: List compliance assessments; POST: Create compliance assessment
`/api/v1/compliance/assessments/import-csv`	POST	Import assessment items strategy via CSV
`/api/v1/compliance/assessments/{id}`	GET, PUT, DELETE	GET: Get compliance assessment by ID; PUT: Update compliance assessment; DELETE: Delete compliance assessment (Soft Delete)
`/api/v1/compliance/assessments/{id}/items`	GET	Get assessment items
`/api/v1/compliance/assessments/{id}/summary`	GET	Get assessment summary metrics

Compliance Hub - Saved Views (3 operations; `ComplianceSavedViewController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/compliance/saved-views`	GET, POST	GET: Get saved views for module; POST: Create custom saved view
`/api/v1/compliance/saved-views/{id}`	DELETE	Delete saved view

Compliance Hub - Metadata (1 operation; `ComplianceMetadataController`; used by the web client)

Path	Methods	Purpose
`/api/v1/compliance/metadata`	GET	Get compliance hub metadata

Operations Center

Source package: `modules/operations`. 53 paths, 86 operations.

Operations Center - Security Incidents (18 operations; `SecurityIncidentController`; used by the web client)

Path	Methods	Purpose
`/api/v1/operations/incidents`	GET, POST	GET: List security incidents, one page at a time; POST: Create a new security incident
`/api/v1/operations/incidents/export-csv`	GET	Export security incidents to CSV
`/api/v1/operations/incidents/import-csv`	POST	Import security incidents from CSV
`/api/v1/operations/incidents/{id}`	GET, PUT, DELETE	GET: Get security incident by ID; PUT: Update security incident; DELETE: Delete security incident (soft delete)

Path	Methods	Purpose
`/api/v1/operations/incidents/{id}/stages`	GET	List stage mappings for a security incident
`/api/v1/operations/incidents/{id}/stages/{stageId}`	PUT	Set a stage of a security incident to COMPLETED or INCOMPLETE
`/api/v1/operations/security-incidents`	GET, POST	GET: List security incidents, one page at a time; POST: Create a new security incident
`/api/v1/operations/security-incidents/export-csv`	GET	Export security incidents to CSV
`/api/v1/operations/security-incidents/import-csv`	POST	Import security incidents from CSV
`/api/v1/operations/security-incidents/{id}`	GET, PUT, DELETE	GET: Get security incident by ID; PUT: Update security incident; DELETE: Delete security incident (soft delete)
`/api/v1/operations/security-incidents/{id}/stages`	GET	List stage mappings for a security incident
`/api/v1/operations/security-incidents/{id}/stages/{stageId}`	PUT	Set a stage of a security incident to COMPLETED or INCOMPLETE

Operations Center - Security Incident Stages (16 operations; `SecurityIncidentStageController`; used by the web client)

Path	Methods	Purpose
`/api/v1/operations/incident-stages`	GET, POST	GET: List all stages; POST: Create a new stage
`/api/v1/operations/incident-stages/export-csv`	GET	Export stages to CSV
`/api/v1/operations/incident-stages/import-csv`	POST	Import stages from CSV
`/api/v1/operations/incident-stages/mappings`	GET	List all stage mappings across all incidents (Stages tab)
`/api/v1/operations/incident-stages/{id}`	GET, PUT, DELETE	GET: Get stage by ID; PUT: Update stage; DELETE: Delete stage (soft delete)
`/api/v1/operations/security-incident-stages`	GET, POST	GET: List all stages; POST: Create a new stage
`/api/v1/operations/security-incident-stages/export-csv`	GET	Export stages to CSV
`/api/v1/operations/security-incident-stages/import-csv`	POST	Import stages from CSV
`/api/v1/operations/security-incident-stages/mappings`	GET	List all stage mappings across all incidents (Stages tab)
`/api/v1/operations/security-incident-stages/{id}`	GET, PUT, DELETE	GET: Get stage by ID; PUT: Update stage; DELETE: Delete stage (soft delete)

Operations Center - Saved Views (6 operations; `OperationSavedViewController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/operations/saved-views`	GET, POST	GET: List saved views by module type; POST: Create a new saved view
`/api/v1/operations/saved-views/{id}`	GET, PUT, DELETE	GET: Get saved view by ID; PUT: Update saved view; DELETE: Delete saved view (soft delete)

Path	Methods	Purpose
`/api/v1/operations/saved-views/{id}/set-default`	POST	Set view as default for module

Operations Center - Projects (7 operations; `OperationsProjectController`; used by the web client)

Path	Methods	Purpose
`/api/v1/operations/projects`	GET, POST	GET: List projects, one page at a time; POST: Create a new project
`/api/v1/operations/projects/export-csv`	GET	Export projects to CSV
`/api/v1/operations/projects/import-csv`	POST	Import projects from CSV
`/api/v1/operations/projects/{id}`	GET, PUT, DELETE	GET: Get project by ID; PUT: Update project; DELETE: Delete project (soft delete)

Operations Center - Project Tasks (16 operations; `ProjectTaskController`; used by the web client)

Path	Methods	Purpose
`/api/v1/operations/project-tasks`	GET, POST	GET: List project tasks, one page at a time; POST: Create a new project task
`/api/v1/operations/project-tasks/by-project/{projectId}`	GET	List tasks by project
`/api/v1/operations/project-tasks/export-csv`	GET	Export tasks to CSV
`/api/v1/operations/project-tasks/import-csv`	POST	Import tasks from CSV
`/api/v1/operations/project-tasks/{id}`	GET, PUT, DELETE	GET: Get task by ID; PUT: Update task; DELETE: Delete task (soft delete)
`/api/v1/operations/tasks`	GET, POST	GET: List project tasks, one page at a time; POST: Create a new project task
`/api/v1/operations/tasks/by-project/{projectId}`	GET	List tasks by project
`/api/v1/operations/tasks/export-csv`	GET	Export tasks to CSV
`/api/v1/operations/tasks/import-csv`	POST	Import tasks from CSV
`/api/v1/operations/tasks/{id}`	GET, PUT, DELETE	GET: Get task by ID; PUT: Update task; DELETE: Delete task (soft delete)

Operations Center - Project Expenses (16 operations; `ProjectExpenseController`; used by the web client)

Path	Methods	Purpose
`/api/v1/operations/expenses`	GET, POST	GET: List project expenses, one page at a time; POST: Create a new project expense
`/api/v1/operations/expenses/by-project/{projectId}`	GET	List expenses by project
`/api/v1/operations/expenses/export-csv`	GET	Export expenses to CSV
`/api/v1/operations/expenses/import-csv`	POST	Import expenses from CSV

Path	Methods	Purpose
`/api/v1/operations/expenses/{id}`	GET, PUT, DELETE	GET: Get expense by ID; PUT: Update expense; DELETE: Delete expense (soft delete)
`/api/v1/operations/project-expenses`	GET, POST	GET: List project expenses, one page at a time; POST: Create a new project expense
`/api/v1/operations/project-expenses/by-project/{projectId}`	GET	List expenses by project
`/api/v1/operations/project-expenses/export-csv`	GET	Export expenses to CSV
`/api/v1/operations/project-expenses/import-csv`	POST	Import expenses from CSV
`/api/v1/operations/project-expenses/{id}`	GET, PUT, DELETE	GET: Get expense by ID; PUT: Update expense; DELETE: Delete expense (soft delete)

Operations Center - Account Reviews (5 operations; `AccountReviewController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/operations/account-reviews`	GET, POST	GET: List all account reviews for the tenant; POST: Create a new account review
`/api/v1/operations/account-reviews/{id}`	GET, PUT, DELETE	GET: Get account review by ID; PUT: Update an existing account review; DELETE: Delete an account review

Operations Center - Reference Data (2 operations; `OperationsReferenceDataController`; used by the web client)

Path	Methods	Purpose
`/api/v1/operations/reference-data/projects`	GET	Operations projects reference data
`/api/v1/operations/reference-data/users-groups`	GET	Users available as GRC contacts, project owners and task owners

Settings

Source package: `modules/settings`. 50 paths, 69 operations.

Trust Center (3 operations; `TrustCenterPostureController`; used by the web client)

Path	Methods	Purpose
`/api/v1/public/trust-center`	GET	Public compliance posture, aggregates only, opt-in per tenant
`/api/v1/settings/trust-center`	GET, PUT	GET: Read the trust center publishing state; PUT: Turn public posture publishing on or off

Settings - System Health (7 operations; `SystemHealthController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/system-health/cache/clear`	POST	Clear application cache
`/api/v1/settings/system-health/checks`	GET	Get system component health checks
`/api/v1/settings/system-health/diagnostics/download`	GET	Download system diagnostics package

Path	Methods	Purpose
`/api/v1/settings/system-health/general`	GET, PUT	GET: Get general health configuration; PUT: Update general health configuration
`/api/v1/settings/system-health/logs/download`	GET	Download masked system logs archive
`/api/v1/settings/system-health/send-to-support`	POST	Send system logs and diagnostics to support

SSO Provider (6 operations; `SsoProviderController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/settings/sso/providers`	GET, POST	GET: List all SSO providers; POST: Create new SSO provider
`/api/v1/settings/sso/providers/{id}`	GET, PUT, DELETE	GET: Get SSO provider by ID; PUT: Update SSO provider; DELETE: Delete SSO provider
`/api/v1/settings/sso/providers/{id}/test`	POST	Test SSO provider configuration

Settings - Webhooks (5 operations; `WebhookController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/integrations/webhooks`	GET, POST	GET: List webhook endpoints; POST: Create a webhook endpoint
`/api/v1/settings/integrations/webhooks/{id}`	PUT, DELETE	PUT: Update a webhook endpoint; DELETE: Delete a webhook endpoint
`/api/v1/settings/integrations/webhooks/{id}/test`	POST	Send a test delivery to a webhook endpoint

Settings - Authentication Method (3 operations; `AuthSettingsController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/authentication`	GET, PUT	GET: Get current main authentication settings; PUT: Update main authentication settings
`/api/v1/settings/authentication/metadata`	GET	Get authentication method metadata and options

Settings - SAML Connectors (9 operations; `SettingsSamlConnectorsController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/authentication/saml-connectors`	GET, POST	GET: List SAML connectors; POST: Create SAML connector
`/api/v1/settings/authentication/saml-connectors/export-csv`	GET	Export SAML connectors to CSV
`/api/v1/settings/authentication/saml-connectors/import-csv`	POST	Import SAML connectors from CSV
`/api/v1/settings/authentication/saml-connectors/{id}`	GET, PUT, DELETE	GET: Get SAML connector by ID; PUT: Update SAML connector; DELETE: Delete SAML connector (Soft Delete)
`/api/v1/settings/authentication/saml-connectors/{id}/metadata`	GET	Get SAML SP metadata for connector
`/api/v1/settings/authentication/saml-connectors/{id}/test`	POST	Test SAML connector connection

Settings - OAuth Connectors (8 operations; `SettingsOauthConnectorsController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/authentication/oauth-connectors`	GET, POST	GET: List OAuth connectors; POST: Create OAuth connector
`/api/v1/settings/authentication/oauth-connectors/export-csv`	GET	Export OAuth connectors to CSV
`/api/v1/settings/authentication/oauth-connectors/import-csv`	POST	Import OAuth connectors from CSV
`/api/v1/settings/authentication/oauth-connectors/{id}`	GET, PUT, DELETE	GET: Get OAuth connector by ID; PUT: Update OAuth connector; DELETE: Delete OAuth connector (Soft Delete)
`/api/v1/settings/authentication/oauth-connectors/{id}/test`	POST	Test OAuth connector connection

Settings - LDAP Connectors (8 operations; `SettingsLdapConnectorsController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/authentication/ldap-connectors`	GET, POST	GET: List LDAP connectors; POST: Create LDAP connector
`/api/v1/settings/authentication/ldap-connectors/export-csv`	GET	Export LDAP connectors to CSV
`/api/v1/settings/authentication/ldap-connectors/import-csv`	POST	Import LDAP connectors from CSV
`/api/v1/settings/authentication/ldap-connectors/{id}`	GET, PUT, DELETE	GET: Get LDAP connector by ID; PUT: Update LDAP connector; DELETE: Delete LDAP connector (Soft Delete)
`/api/v1/settings/authentication/ldap-connectors/{id}/test`	POST	Test LDAP connector connection

Settings - Updates & Maintenance (3 operations; `SystemUpdatesController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/updates`	GET	Get available system updates
`/api/v1/settings/updates/maintenance-mode`	GET, POST	GET: Get tenant maintenance mode status; POST: Enable or disable maintenance mode

MFA (6 operations; `MfaController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/settings/mfa/backup-codes`	GET	Get backup codes
`/api/v1/settings/mfa/disable`	POST	Disable MFA
`/api/v1/settings/mfa/enable`	POST	Enable MFA after verifying code
`/api/v1/settings/mfa/regenerate-codes`	POST	Regenerate backup codes
`/api/v1/settings/mfa/setup`	POST	Setup MFA - generate secret and backup codes
`/api/v1/settings/mfa/verify`	POST	Verify TOTP code

Settings - Mail (2 operations; `MailSettingsController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/mail`	GET	Outbound mail status
`/api/v1/settings/mail/test`	POST	Send a test message to check the relay

Settings - Data reset (4 operations; `DataResetController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/data-reset`	GET, POST	GET: Row counts per group, and the confirmation phrase; POST: Clear the chosen groups for this organisation
`/api/v1/settings/data-reset/backups`	GET	Backups taken before each data reset, newest first
`/api/v1/settings/data-reset/backups/{id}/download`	GET	Download one backup as gzipped JSON

Settings - System Logs (3 operations; `SystemLogHubController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/system-logs`	GET	List system audit logs (Immutable Append-Only)
`/api/v1/settings/system-logs/export`	GET	Export system audit logs to CSV
`/api/v1/settings/system-logs/{id}`	GET	Get system audit log by ID

Settings - About System (1 operation; `AboutSystemController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/about`	GET	Get system about details (Read-only)

Public System API (1 operation; `PublicSystemController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/public/system/maintenance-status`	GET	Public maintenance status endpoint for login page checks

Authentication and sessions

Source package: `modules/auth`. 24 paths, 31 operations.

Users (7 operations; `UserAccountController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/users`	GET, POST	GET: Get all users for the tenant; POST: Create a new user
`/api/v1/users/invite`	POST	Invite a new user
`/api/v1/users/{id}`	GET, PUT, DELETE	GET: Get user by ID; PUT: Update user; DELETE: Delete user
`/api/v1/users/{id}/status`	PUT	Update user status

Authentication - Roles (7 operations; `RoleController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/auth/roles`	GET, POST	GET: Find all; POST: Create
`/api/v1/auth/roles/{id}`	GET, PUT, DELETE	GET: Find by id; PUT: Update; DELETE: Delete

Path	Methods	Purpose
`/api/v1/auth/roles/{id}/permissions`	GET, PUT	GET: Get permissions; PUT: Assign permissions

Settings - Sessions (3 operations; `TenantSessionController`; used by the web client)

Path	Methods	Purpose
`/api/v1/settings/authentication/sessions`	GET	List the tenant's active or ended sessions
`/api/v1/settings/authentication/sessions/users/{userAccountId}/revoke`	POST	Sign a user out of every session
`/api/v1/settings/authentication/sessions/{id}`	DELETE	Sign out one session of any user in the tenant

auth-session-controller (7 operations; `AuthSessionController`; used by the web client)

Path	Methods	Purpose
`/api/v1/auth/logout`	POST	Logout
`/api/v1/auth/logout-all`	POST	Logout all
`/api/v1/auth/refresh`	POST	Refresh
`/api/v1/auth/sessions`	GET	Sessions
`/api/v1/auth/sessions/ended`	GET	Ended sessions
`/api/v1/auth/sessions/revoke-others`	POST	Revoke other sessions
`/api/v1/auth/sessions/{id}`	DELETE	Revoke session

auth-controller (3 operations; `AuthController`; used by the web client)

Path	Methods	Purpose
`/api/v1/auth/login`	POST	Login
`/api/v1/auth/me`	GET	Me
`/api/v1/auth/me/permissions`	GET	My permissions

Permission Management (2 operations; `PermissionController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/permissions`	GET	Find all
`/api/v1/permissions/modules`	GET	Find grouped by module

o-auth-controller (2 operations; `OAuthController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/oauth/success`	GET	Oauth success
`/api/v1/oauth/user-info`	GET	Get user info

Notifications

Source package: `modules/notification`. 7 paths, 8 operations.

notification-controller (8 operations; `NotificationController`; used by the web client)

Path	Methods	Purpose
`/api/v1/notifications`	GET, POST	GET: List; POST: Create
`/api/v1/notifications/bulk-delete`	POST	Bulk delete
`/api/v1/notifications/read-all`	PATCH	Mark all read
`/api/v1/notifications/unread-count`	GET	Unread count
`/api/v1/notifications/{id}`	DELETE	Delete
`/api/v1/notifications/{id}/read`	PATCH	Mark read
`/api/v1/notifications/{id}/unread`	PATCH	Mark unread

Comments and Activity Log

Source package: `modules/comments + modules/activity`. 6 paths, 7 operations.

Comments (7 operations; `RecordActivityController, RecordCommentController`; used by the web client)

Path	Methods	Purpose
`/api/v1/comments`	GET, POST	GET: The comments of one record, oldest first; POST: Add a comment to a record
`/api/v1/comments/activity`	GET	The change history of one record, oldest first
`/api/v1/comments/counts`	GET	Live comment counts for the given records of one page
`/api/v1/comments/{id}`	DELETE	Remove a comment, its files and its replies (soft delete)
`/api/v1/comments/{id}/attachments/{attachmentId}`	DELETE	Remove one file from a comment (soft delete)
`/api/v1/comments/{id}/attachments/{attachmentId}/download`	GET	Download a file posted with a comment

Global search

Source package: `modules/search`. 1 path, 1 operation.

Global Search (1 operation; `GlobalSearchController`; used by the web client)

Path	Methods	Purpose
`/api/v1/search`	GET	Search across all modules

Sync feed

Source package: `modules/sync`. 1 path, 1 operation.

Sync (1 operation; `SyncController`; used by the web client)

Path	Methods	Purpose
`/api/v1/sync/changes`	GET	Resources changed in this tenant since the given cursor

Audit log

Source package: `modules/audit`. 1 path, 1 operation.

audit-log-controller (1 operation; `AuditLogController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/audit-logs`	GET	List

Tenant management

Source package: `presentation`. 8 paths, 9 operations.

Tenant Management (9 operations; `TenantController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/tenants`	GET, POST	GET: Get all active tenants; POST: Create a new tenant
`/api/v1/tenants/{id}`	GET	Get tenant by ID
`/api/v1/tenants/{id}/activate`	POST	Activate tenant
`/api/v1/tenants/{id}/branding`	PUT	Update tenant branding
`/api/v1/tenants/{id}/can-upgrade`	GET	Check if tenant can be upgraded
`/api/v1/tenants/{id}/health`	GET	Get tenant health score
`/api/v1/tenants/{id}/plan`	PUT	Upgrade tenant plan
`/api/v1/tenants/{id}/suspend`	POST	Suspend tenant

Evidence (older model)

Source package: `modules/evidence`. 7 paths, 8 operations.

evidence-controller (3 operations; `EvidenceController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/evidence`	GET, POST	GET: List; POST: Create
`/api/v1/evidence/{id}`	GET	Get by id

evidence-request-controller (5 operations; `EvidenceRequestController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/evidence-requests`	POST	Create request
`/api/v1/evidence-requests/control/{controlId}`	GET	Get requests by control
`/api/v1/evidence-requests/pending`	GET	Get pending requests
`/api/v1/evidence-requests/{id}/approve`	POST	Approve request
`/api/v1/evidence-requests/{id}/submit`	POST	Submit evidence

Incidents (older model)

Source package: `modules/incident`. 2 paths, 4 operations.

incident-controller (4 operations; `IncidentController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/incidents`	GET, POST	GET: List; POST: Create

Path	Methods	Purpose
`/api/v1/incidents/{id}`	GET, PUT	GET: Get by id; PUT: Update

Issues and exception requests (older model)

Source package: `modules/issue`. 6 paths, 10 operations.

Issues (5 operations; `IssueController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/issues`	GET, POST	GET: List all issues for the tenant; POST: Create a new issue
`/api/v1/issues/{id}`	GET, PUT, DELETE	GET: Get issue by ID; PUT: Update an existing issue; DELETE: Delete an issue

exception-request-controller (5 operations; `ExceptionRequestController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/exceptions`	GET, POST	GET: List; POST: Create
`/api/v1/exceptions/{id}`	GET	Get by id
`/api/v1/exceptions/{id}/approve`	PUT	Approve
`/api/v1/exceptions/{id}/reject`	PUT	Reject

Policy templates and acknowledgments (older model)

Source package: `modules/policy`. 8 paths, 10 operations.

policy-template-controller (6 operations; `PolicyTemplateController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/policy-templates`	GET, POST	GET: Get all templates; POST: Create template
`/api/v1/policy-templates/category/{category}`	GET	Get templates by category
`/api/v1/policy-templates/default`	GET	Get default templates
`/api/v1/policy-templates/{id}`	PUT, DELETE	PUT: Update template; DELETE: Delete template

policy-acknowledgment-controller (4 operations; `PolicyAcknowledgmentController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/policy-acknowledgments`	POST	Acknowledge policy
`/api/v1/policy-acknowledgments/check`	GET	Has user acknowledged
`/api/v1/policy-acknowledgments/policy/{policyId}`	GET	Get acknowledgments by policy
`/api/v1/policy-acknowledgments/user/{userId}`	GET	Get acknowledgments by user

Tasks (older model)

Source package: `modules/task`. 20 paths, 23 operations.

Task Management (23 operations; `TaskController`; not called by the web client)

Path	Methods	Purpose
`/api/v1/tasks`	GET, POST	GET: Get all tasks; POST: Create task
`/api/v1/tasks/assignee/{assigneeId}`	GET	Get tasks by assignee
`/api/v1/tasks/compliance/{complianceId}`	GET	Get tasks by compliance
`/api/v1/tasks/count-by-status`	GET	Get task count by status
`/api/v1/tasks/due-soon`	GET	Get tasks due soon
`/api/v1/tasks/my-tasks`	GET	Get my tasks
`/api/v1/tasks/overdue`	GET	Get overdue tasks
`/api/v1/tasks/priority/{priority}`	GET	Get tasks by priority
`/api/v1/tasks/risk/{riskId}`	GET	Get tasks by risk
`/api/v1/tasks/search`	POST	Search tasks
`/api/v1/tasks/statistics`	GET	Get task statistics
`/api/v1/tasks/status/{status}`	GET	Get tasks by status
`/api/v1/tasks/type/{type}`	GET	Get tasks by type
`/api/v1/tasks/{parentTaskId}/subtasks`	GET	Get subtasks
`/api/v1/tasks/{taskId}`	GET, PUT, DELETE	GET: Get task by ID; PUT: Update task; DELETE: Delete task
`/api/v1/tasks/{taskId}/assign`	PUT	Assign task
`/api/v1/tasks/{taskId}/complete`	PUT	Complete task
`/api/v1/tasks/{taskId}/progress/{progressPercent}`	PUT	Update task progress
`/api/v1/tasks/{taskId}/start`	PUT	Start task
`/api/v1/tasks/{taskId}/status/{status}`	PUT	Update task status

Chaos testing (dev profile only)

Source package: `chaos`. 13 paths, 13 operations.

chaos-controller (13 operations; `ChaosController`; not called by the web client)

Path	Methods	Purpose
`/api/chaos/config/memory-stress`	POST	Set memory stress
`/api/chaos/config/network-latency`	POST	Set network latency
`/api/chaos/config/rate-limit`	POST	Set rate limit
`/api/chaos/config/timeout`	POST	Set timeout delay
`/api/chaos/disable`	POST	Disable chaos
`/api/chaos/enable`	POST	Enable chaos
`/api/chaos/exclude/class`	POST	Exclude class
`/api/chaos/exclude/method`	POST	Exclude method
`/api/chaos/reset`	POST	Reset

Path	Methods	Purpose
`/api/chaos/scenarios/active`	GET	Get active scenarios
`/api/chaos/scenarios/{scenario}/activate`	POST	Activate scenario
`/api/chaos/scenarios/{scenario}/deactivate`	POST	Deactivate scenario
`/api/chaos/status`	GET	Get status

Root

Source package: `api`. 1 path, 1 operation.

home-controller (1 operation; `HomeController` ; not called by the web client)

Path	Methods	Purpose
`/`	GET	Home

Data model

This page is generated from the JPA entity classes in `GRC_Backend_Code/src/main/java/com/strativu/grc360` and checked against the running PostgreSQL database. It replaces `doc/diagrams/erd.md` in both repositories, which is outdated. The backend copy draws mostly the older models (`risks` with `risk_control_mappings` and `risk_treatment_plans`, `compliance_requirements` with `compliance_checks`, `incidents` with `corrective_actions`), shows foreign keys from every table to `tenants` that do not exist (no table has a foreign key to `tenants`), and omits the registers the UI uses (asset, third-party and business risks, internal controls, policies and standards, compliance packages, Operations Center). The frontend copy uses conceptual names (`CONTROLS`, `MAINTENANCES`, `FINDINGS`, `DATA_ASSETS`) that are not tables.

Counts and conventions

Item	Value
Entity classes (`@Entity`)	120 in `src/main/java` (a plain text search for `@Entity` also matches the two `@EntityListeners` annotations on `Policy` and `Task`, which gives 122)
Tables in the demo database (`public` schema)	220: entity tables plus join tables and id-list link tables
Base class `TenantScopedEntity`	105 entities. Adds `tenant_id uuid not null`, filled from the current tenant on insert. Extends `BaseEntity`.
Base class `BaseEntity` only	2 entities (`sys_permissions`, `compliance_exception_workflow_events`). Adds `id uuid` (generated, `GenerationType.UUID`), `created_at`, `updated_at` (set on insert and update) and the change-tracking listener that feeds the sync feed.
No base class	13 entities with their own id columns (`tenants`, `tenant_domains`, `policies` (class `Policy`; the same table is also mapped by `PolicyDocument`, which extends `TenantScopedEntity`), `policy_history`, `policy_templates`, `tasks`, `notification_history`, `notification_preferences`, `notification_templates`, `compliance_package_contacts`, `compliance_exception_contacts`, `compliance_obligation_responsible_principals`, `external_audit_finding_principals`). `Policy` and `Task` implement `TenantOwned` and declare the change-tracking listener themselves.
Mapped relations	57 `@ManyToOne`, 19 `@ManyToMany`, 19 `@OneToMany` (all `mappedBy` inverses), 1 `@OneToOne`
Id-list link tables	81 `@ElementCollection` fields. Each is a two-column table (`<owner>_id`, value) with a foreign key to the owner only. The value is a UUID of another record or a principal, without a database foreign key; the service layer resolves and validates it.
Soft delete	32 entities carry soft-delete columns (`deleted` and/or `deleted_at`): the risk register and risk settings tables, the Compliance Hub registers, the Operations Center registers, connectors, webhooks, comments and their attachments, business processes, objective audit result options.
Optimistic locking	`@Version` on 13 entities
Schema management	Hibernate `ddl-auto=update` plus `SchemaRepairRunner`; Flyway disabled. See Installation.

How to read the diagrams

- One diagram per module, using **table names**. Tables from other modules appear where a relation points to them.
- `}o--||` is a required many-to-one (`@JoinColumn(nullable = false)`), `}o--o|` an optional one.
- `}o--o{` with a solid line is a JPA many-to-many; the label is the join table.

- `}o..o{` with a dotted line is an id-list link table (`@ElementCollection`) whose target table is confirmed in the service code (`RelationCatalog` kinds, name resolvers). Id lists that hold people (users or groups) are not drawn; they are listed in the table under each diagram.
- Tables shown as a box with only `id` have no mapped relation.

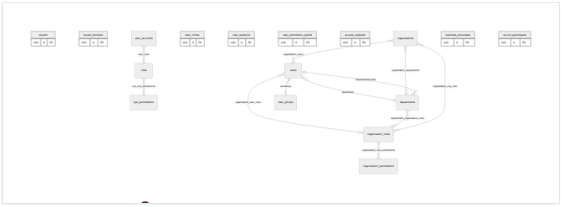
Things that are not in the diagrams

- **Polymorphic references.** Several tables point at "any record" with a type column and a UUID, without a foreign key: `record_comments` and `record_activity` (`module`, `submodule`, `record_id`), `record_participants` (`record_type`, `record_id`, `principal_kind`, `principal_id`, `relation`), `risk_reviews` (`risk_type`, `risk_id`).
- **Single UUID columns.** Many entities keep a reference as a plain UUID column (for example `owner_user_id`, `contact_user_id`, `vendor_role_id`) next to a display name column. Only JPA-mapped relations are drawn.
- **Two user tables.** `user_accounts` (module `auth`) is the sign-in identity: e-mail, BCrypt password hash, status, auth-side roles. `users` (module `organization`) is the organization profile shown in Organization › Users: name, department, groups. They are matched by e-mail within a tenant (`AuthServiceImpl` looks up the profile with `findByEmailAndTenantId`). Older modules (Operations Center projects, tasks and incidents) reference `user_accounts`; Governance references `users`.
- **Two permission models.** `roles` / `sys_permissions` / `sys_role_permissions` / `user_roles` are the older auth-side roles (ADMIN, EDITOR, AUDITOR) that still appear in the JWT. `organization_roles` / `organization_permissions` / `organization_role_permissions` / `organization_user_roles` are the permission catalogue behind Organization › Groups. See Security.
- **Older models.** Some tables belong to models that the web client no longer calls (generic `risks`, `policies`, `incidents`, `issues`, `tasks`, `evidences`, `compliance_frameworks` and their satellites). Two current relations still point at the generic `risks` table: `governance_objectives` to `risks` (join table `governance_objective_risks`) and `governance_issues.risk_id`, and `risk_exceptions.risk_id`.

Tenancy, identity and access

Entity class	Table	Package	Base class	What it holds
`TenantEntity`	`tenants`	`infrastructure/persistence/entity`	(none; own id)	Tenant registry (not tenant-scoped)
`TenantDomainEntity`	`tenant_domains`	`infrastructure/persistence/entity`	(none; own id)	Custom domains per tenant (resolver disabled unless `app.tenancy.custom-domains.enabled=true`)
`UserAccount`	`user_accounts`	`modules/auth`	TenantScopedEntity	Sign-in identity: email, BCrypt password hash, status, auth-side roles
`Role`	`roles`	`modules/auth`	TenantScopedEntity	Auth-side roles (ADMIN, EDITOR, AUDITOR, …) that feed the JWT
`Permission`	`sys_permissions`	`modules/auth`	BaseEntity	Auth-side permission codes (not tenant-scoped)
`UserInvite`	`user_invites`	`modules/auth`	TenantScopedEntity	Invitation links (Organization › Users invite)
`UserSession`	`user_sessions`	`modules/auth`	TenantScopedEntity	One row per refresh-token rotation; a login is a family (`family_id`)
`User`	`users`	`modules/organization`	TenantScopedEntity	Organization profile of a person (Organization › Users)
`Department`	`departments`	`modules/organization`	TenantScopedEntity	Organization › Departments

Entity class	Table	Package	Base class	What it holds
`OrganizationRole`	`organization_roles`	`modules/organization`	TenantScopedEntity	Organization › Groups (permission catalogue roles)
`Permission`	`organization_permissions`	`modules/organization`	TenantScopedEntity	Permission catalogue rows per tenant (`module_submodule_action`)
`UserGroup`	`user_groups`	`modules/organization`	TenantScopedEntity	User groups
`UserPermissionGrant`	`user_permission_grants`	`modules/organization`	TenantScopedEntity	Individual grants (from approved access requests)
`AccessRequest`	`access_requests`	`modules/organization`	TenantScopedEntity	Request Access workflow
`Organization`	`organizations`	`modules/organization`	TenantScopedEntity	Legal entities
`BusinessProcess`	`business_processes`	`modules/organization`	TenantScopedEntity	Business processes (picker on Business Risks)
`RecordParticipant`	`record_participants`	`modules/visibility`	TenantScopedEntity	Who a record names (row-level visibility)



Governance Hub

Entity class	Table	Package	Base class	What it holds
`Objective`	`governance_objectives`	`modules/governance`	TenantScopedEntity	Governance › Objectives
`ObjectiveAudit`	`governance_objective_audits`	`modules/governance`	TenantScopedEntity	Objectives › Audits tab
`ObjectiveAuditResultOption`	`governance_objective_audit_result_options`	`modules/governance`	TenantScopedEntity	Audit result options
`Issue`	`governance_issues`	`modules/governance`	TenantScopedEntity	Governance › Issues (`@Entity(name="GovernanceIssue")`)
`Coverage`	`governance_coverages`	`modules/governance`	TenantScopedEntity	Governance › Coverage

Id-list link tables (`@ElementCollection` , no foreign key to the target):

Owner table	Field	Link table	Holds
`governance_objectives`	`contactIds`	`governance_objective_contacts`	principal ids (users or groups)
`governance_objectives`	`goalOwnerContactIds`	`governance_objective_goal_owners`	principal ids (users or groups)
`governance_objectives`	`auditOwnerIds`	`governance_objective_audit_owners`	principal ids (users or groups)
`governance_objectives`	`auditEvidenceOwnerIds`	`governance_objective_audit_evidence_owners`	principal ids (users or groups)

Third Parties

Entity class	Table	Package	Base class	What it holds
`Vendor`	`third_party_vendors`	`modules/thirdparty`	TenantScopedEntity	Third Parties › Vendors
`ServiceAgreement`	`service_agreements`	`modules/thirdparty`	TenantScopedEntity	Third Parties › Service Agreements
`VendorDocument`	`vendor_documents`	`modules/asset`	TenantScopedEntity	Vendor documents (API only, not called by the web client)
`VendorQuestionnaire`	`vendor_questionnaires`	`modules/asset`	TenantScopedEntity	Vendor questionnaires (API only)

Id-list link tables (`@ElementCollection` , no foreign key to the target):

Owner table	Field	Link table	Holds
`third_party_vendors`	`contactIds`	`third_party_vendor_contacts`	principal ids (users or groups)
`third_party_vendors`	`grcContactIds`	`third_party_vendor_grc_contacts`	principal ids (users or groups)
`service_agreements`	`grcContactIds`	`service_agreement_grc_contacts`	principal ids (users or groups)
`service_agreements`	`supportContractContactIds`	`service_agreement_support_contacts`	principal ids (users or groups)

Asset Management

Entity class	Table	Package	Base class	What it holds
`Asset`	`assets`	`modules/asset`	TenantScopedEntity	Asset Management › Assets
`AssetReview`	`asset_reviews`	`modules/asset`	TenantScopedEntity	Assets › Reviews tab
`DataMovement`	`data_movements`	`modules/asset`	TenantScopedEntity	Asset Management › Data Flows

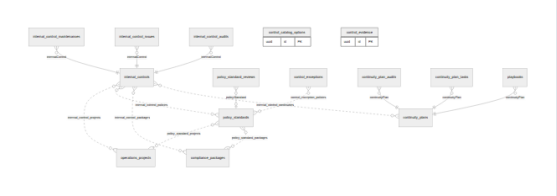
Id-list link tables (`@ElementCollection` , no foreign key to the target):

Owner table	Field	Link table	Holds
`assets`	`contactIds`	`asset_contacts`	principal ids (users or groups)
`assets`	`reviewerContactIds`	`asset_reviewer_contacts`	principal ids (users or groups)
`assets`	`relatedDepartmentIds`	`asset_related_departments`	ids of `departments` rows
`assets`	`dataOwnerIds`	`asset_data_owners`	principal ids (users or groups)
`assets`	`dpoRoleIds`	`asset_dpo_roles`	principal ids (users or groups)
`assets`	`controllerRoleIds`	`asset_controller_roles`	principal ids (users or groups)
`assets`	`controllerRepresentativeIds`	`asset_controller_representatives`	principal ids (users or groups)
`data_movements`	`departmentIds`	`data_movement_departments`	ids of `departments` rows
`data_movements`	`thirdPartyIds`	`data_movement_third_parties`	ids of `third_party_vendors` rows
`data_movements`	`assetRiskIds`	`data_movement_asset_risks`	ids of `asset_risks` rows
`data_movements`	`thirdPartyRiskIds`	`data_movement_tp_risks`	ids of `third_party_risks` rows
`data_movements`	`businessRiskIds`	`data_movement_business_risks`	ids of `operational_risks` rows
`data_movements`	`compensatingControlIds`	`data_movement_controls`	ids of `internal_controls` rows
`data_movements`	`improvementProjectIds`	`data_movement_projects`	ids of `operations_projects` rows
`data_movements`	`policyIds`	`data_movement_policies`	ids of `policy_standards` rows

Control Center

Entity class	Table	Package	Base class	What it holds
`InternalControl`	`internal_controls`	`modules/control`	TenantScopedEntity	Control Center › Controls
`InternalControlAudit`	`internal_control_audits`	`modules/control`	TenantScopedEntity	Controls › Audits tab
`InternalControlIssue`	`internal_control_issues`	`modules/control`	TenantScopedEntity	Controls › Issues tab
`InternalControlMaintenance`	`internal_control_maintenances`	`modules/control`	TenantScopedEntity	Controls › Maintenances tab
`PolicyStandard`	`policy_standards`	`modules/control`	TenantScopedEntity	Control Center › Policies & Standards
`PolicyReview`	`policy_standard_reviews`	`modules/control`	TenantScopedEntity	Policies & Standards › Reviews tab
`ControlException`	`control_exceptions`	`modules/control`	TenantScopedEntity	Control Center › Policy Exceptions

Entity class	Table	Package	Base class	What it holds
`ContinuityPlan`	`continuity_plans`	`modules/control`	TenantScopedEntity	Control Center › Continuity Plans
`ContinuityPlanAudit`	`continuity_plan_audits`	`modules/control`	TenantScopedEntity	Continuity Plans › Audits tab
`ContinuityPlanTask`	`continuity_plan_tasks`	`modules/control`	TenantScopedEntity	Continuity Plans › Tasks tab
`Playbook`	`playbooks`	`modules/control`	TenantScopedEntity	Playbooks (API only)
`ControlCatalogOption`	`control_catalog_options`	`modules/control`	TenantScopedEntity	Configurable dropdown options for controls
`ControlEvidence`	`control_evidence`	`modules/control`	TenantScopedEntity	Evidence files of control audits/maintenances, policy reviews (metadata; bytes in object storage)



Id-list link tables (`@ElementCollection` , no foreign key to the target):

Owner table	Field	Link table	Holds
`internal_controls`	`controlOperatorContactIds`	`internal_control_operator_contacts`	principal ids (users or groups)
`internal_controls`	`grcContactIds`	`internal_control_grc_contacts`	principal ids (users or groups)
`internal_controls`	`auditOwnerIds`	`internal_control_audit_owners`	principal ids (users or groups)
`internal_controls`	`auditEvidenceOwnerIds`	`internal_control_audit_evidence_owners`	principal ids (users or groups)
`internal_controls`	`maintenanceOwnerIds`	`internal_control_maintenance_owners`	principal ids (users or groups)
`internal_controls`	`businessContinuityIds`	`internal_control_continuities`	ids of `continuity_plans` rows
`internal_controls`	`compliancePackageIds`	`internal_control_packages`	ids of `compliance_packages` rows
`internal_controls`	`securityPolicyIds`	`internal_control_policies`	ids of `policy_standards` rows
`internal_controls`	`relatedProjectIds`	`internal_control_projects`	ids of `operations_projects` rows
`policy_standards`	`compliancePackageIds`	`policy_standard_packages`	ids of `compliance_packages` rows
`policy_standards`	`relatedProjectIds`	`policy_standard_projects`	ids of `operations_projects` rows
`policy_standards`	`grcContactIds`	`policy_standard_grc_contacts`	principal ids (users or groups)
`policy_standards`	`reviewerContactIds`	`policy_standard_reviewer_contacts`	principal ids (users or groups)

Owner table	Field	Link table	Holds
`control_exceptions`	`relatedPolicyIds`	`control_exception_policies`	ids of `policy_standards` rows

Risk Management

Entity class	Table	Package	Base class	What it holds
`AssetRisk`	`asset_risks`	`modules/risk`	TenantScopedEntity	Risk Management › Asset Risks
`ThirdPartyRisk`	`third_party_risks`	`modules/risk`	TenantScopedEntity	Risk Management › Third Party Risks
`OperationalRisk`	`operational_risks`	`modules/risk`	TenantScopedEntity	Risk Management › Business Risks
`RiskReview`	`risk_reviews`	`modules/risk`	TenantScopedEntity	Reviews tab of the three risk registers
`RiskException`	`risk_exceptions`	`modules/risk`	TenantScopedEntity	Risk Management › Risk Exceptions
`RiskClassificationType`	`risk_classification_types`	`modules/risk`	TenantScopedEntity	Risk settings: classification scales
`RiskClassificationValue`	`risk_classification_values`	`modules/risk`	TenantScopedEntity	Values of a classification scale
`RiskAnalysisMatrix`	`risk_analysis_matrices`	`modules/risk`	TenantScopedEntity	Risk settings: likelihood x impact matrix cells
`RiskCalculationMethod`	`risk_calculation_methods`	`modules/risk`	TenantScopedEntity	Risk settings: calculation method per register
`RiskAppetiteSetting`	`risk_appetite_settings`	`modules/risk`	TenantScopedEntity	Risk settings: appetite / threshold
`RiskModuleSettings`	`risk_module_settings`	`modules/risk`	TenantScopedEntity	Per-register module settings
`RiskSavedView`	`risk_saved_views`	`modules/risk`	TenantScopedEntity	Saved views (API only)
`Risk`	`risks`	`modules/risk`	TenantScopedEntity	Older generic risk table (`/api/v1/risks`); still the target of Objective and Governance Issue links
`RiskControlMapping`	`risk_control_mappings`	`modules/risk`	TenantScopedEntity	Older risk-control mapping (API only)
`RiskTreatmentPlan`	`risk_treatment_plans`	`modules/risk`	TenantScopedEntity	Older treatment plans (no web client use)

Id-list link tables (`@ElementCollection` , no foreign key to the target):

Owner table	Field	Link table	Holds
`asset_risks`	`riskGrcContactIds`	`asset_risk_grc_contacts`	principal ids (users or groups)
`asset_risks`	`riskOriginatorContactIds`	`asset_risk_originator_contacts`	principal ids (users or groups)

Owner table	Field	Link table	Holds
asset_risks	relatedAssetIds	asset_risk_assets	ids of assets rows
asset_risks	treatmentControlIds	asset_risk_controls	ids of internal_controls rows
asset_risks	treatmentPolicyIds	asset_risk_policies	ids of policy_standards rows
asset_risks	treatmentRiskExceptionIds	asset_risk_exceptions	ids of risk_exceptions rows
asset_risks	treatmentProjectIds	asset_risk_projects	ids of operations_projects rows
asset_risks	affectedComplianceItemIds	asset_risk_compliance_items	ids of compliance_requirement_items rows
asset_risks	securityIncidentIds	security_incident_asset_risks	ids of security_incidents rows
third_party_risks	riskGrcContactIds	tp_risk_grc_contacts	principal ids (users or groups)
third_party_risks	riskOriginatorContactIds	tp_risk_originator_contacts	principal ids (users or groups)
third_party_risks	reviewerIds	tp_risk_reviewers	principal ids (users or groups)
third_party_risks	applicableThirdPartyIds	tp_risk_third_parties	ids of third_party_vendors rows
third_party_risks	assetsSharedWithThisThirdPartyIds	tp_risk_shared_assets	ids of assets rows
third_party_risks	treatmentControlIds	tp_risk_controls	ids of internal_controls rows
third_party_risks	treatmentPolicyIds	tp_risk_policies	ids of policy_standards rows
third_party_risks	treatmentRiskExceptionIds	tp_risk_exceptions	ids of risk_exceptions rows
third_party_risks	treatmentProjectIds	tp_risk_projects	ids of operations_projects rows
third_party_risks	affectedComplianceItemIds	tp_risk_compliance_items	ids of compliance_requirement_items rows
third_party_risks	securityIncidentIds	security_incident_third_party_risks	ids of security_incidents rows
operational_risks	riskGrcContactIds	op_risk_grc_contacts	principal ids (users or groups)
operational_risks	riskOriginatorContactIds	op_risk_originator_contacts	principal ids (users or groups)
operational_risks	reviewerIds	op_risk_reviewers	principal ids (users or groups)
operational_risks	applicableBusinessUnitIds	op_risk_business_units	ids of departments rows
operational_risks	processIds	op_risk_processes	ids of business_processes rows
operational_risks	mitigatingBusinessContinuityPlanIds	op_risk_bcp_plans	ids of continuity_plans rows
operational_risks	treatmentControlIds	op_risk_controls	ids of internal_controls rows
operational_risks	treatmentPolicyIds	op_risk_policies	ids of policy_standards rows
operational_risks	treatmentRiskExceptionIds	op_risk_exceptions	ids of risk_exceptions rows

Owner table	Field	Link table	Holds
`operational_risks`	`treatmentProjectIds`	`op_risk_projects`	ids of `operations_projects` rows
`operational_risks`	`affectedComplianceItemIds`	`op_risk_compliance_items`	ids of `compliance_requirement_items` rows
`operational_risks`	`securityIncidentIds`	`security_incident_operational_risks`	ids of `security_incidents` rows
`risk_exceptions`	`contactIds`	`risk_exception_contacts`	principal ids (users or groups)
`risk_exceptions`	`exceptionRequesterContactIds`	`risk_exception_requesters`	principal ids (users or groups)
`risk_exceptions`	`relatedAssetRiskIds`	`risk_exception_asset_risks`	ids of `asset_risks` rows
`risk_exceptions`	`relatedThirdPartyRiskIds`	`risk_exception_third_party_risks`	ids of `third_party_risks` rows
`risk_exceptions`	`relatedOperationalRiskIds`	`risk_exception_operational_risks`	ids of `operational_risks` rows

Compliance Hub

Entity class	Table	Package	Base class	What it holds
`CompliancePackage`	`compliance_packages`	`modules/compliance`	TenantScopedEntity	Compliance Hub › Compliance Packages
`CompliancePackageContact`	`compliance_package_contacts`	`modules/compliance`	(none; own id)	Package contacts
`ComplianceRequirementItem`	`compliance_requirement_items`	`modules/compliance`	TenantScopedEntity	Package items (requirements)
`CompliancePackageImportJob`	`compliance_package_import_jobs`	`modules/compliance`	TenantScopedEntity	Package import jobs
`ComplianceAssessment`	`compliance_assessments`	`modules/compliance`	TenantScopedEntity	Compliance Hub › Compliance Analysis
`ComplianceAssessmentItem`	`compliance_assessment_items`	`modules/compliance`	TenantScopedEntity	Analysis rows per requirement item
`ComplianceObligationEntity`	`compliance_obligations`	`modules/compliance`	TenantScopedEntity	Compliance Hub › Obligations
`ComplianceObligationPrincipal`	`compliance_obligation_responsible_principals`	`modules/compliance`	(none; own id)	Obligation responsible users/groups
`ComplianceObligationCategory`	`compliance_obligation_categories`	`modules/compliance`	TenantScopedEntity	Obligation categories
`ComplianceExceptionEntity`	`compliance_exceptions`	`modules/compliance`	TenantScopedEntity	Compliance Hub › Compliance Exceptions
`ComplianceExceptionContact`	`compliance_exception_contacts`	`modules/compliance`	(none; own id)	Exception contacts
`ComplianceExceptionWorkflowEvent`	`compliance_exception_workflow_events`	`modules/compliance`	BaseEntity	Exception workflow history
`ExternalAuditFinding`	`external_audit_findings`	`modules/compliance`	TenantScopedEntity	Compliance Hub › External Audit Findings

Entity class	Table	Package	Base class	What it holds
`ExternalAuditFindingPrincipal`	`external_audit_finding_principals`	`modules/compliance`	(none; own id)	Finding owners/contacts
`AuditFindingAttachment`	`audit_finding_attachments`	`modules/compliance`	TenantScopedEntity	Finding attachments (metadata; bytes in object storage)
`ComplianceSavedView`	`compliance_saved_views`	`modules/compliance`	TenantScopedEntity	Saved views (API only)
`ComplianceFramework`	`compliance_frameworks`	`modules/compliance`	TenantScopedEntity	Older framework model (`/api/v1/frameworks` , API only)
`Control`	`compliance_controls`	`modules/compliance`	TenantScopedEntity	Older framework controls
`ComplianceRequirement`	`compliance_requirements`	`modules/compliance`	TenantScopedEntity	Older requirements
`ComplianceCheck`	`compliance_checks`	`modules/compliance`	TenantScopedEntity	Older checks
`ComplianceEvidence`	`compliance_evidence`	`modules/compliance`	TenantScopedEntity	Older evidence
`GapAssessment`	`gap_assessments`	`modules/compliance`	TenantScopedEntity	Older gap assessments (API only)
`Obligation`	`obligations`	`modules/compliance`	TenantScopedEntity	Older obligations
`TrustCenterDocument`	`trust_center_documents`	`modules/compliance`	TenantScopedEntity	Trust Center documents (`/api/v1/trust-center`)

Id-list link tables (`@ElementCollection` , no foreign key to the target):

Owner table	Field	Link table	Holds
`compliance_assessment_items`	`evidenceIds`	`assessment_item_evidence`	ids
`compliance_assessment_items`	`controlIds`	`assessment_item_control`	ids of `internal_controls` rows
`compliance_assessment_items`	`findingIds`	`assessment_item_finding`	ids
`compliance_assessment_items`	`projectIds`	`assessment_item_project`	ids of `operations_projects` rows
`compliance_assessment_items`	`policyIds`	`assessment_item_policy`	ids of `policy_standards` rows
`compliance_controls`	`mappings`	`control_mappings`	ControlMapping values

Operations Center

Entity class	Table	Package	Base class	What it holds
`OperationsProject`	`operations_projects`	`modules/operations`	TenantScopedEntity	Operations Center › Projects
`ProjectTask`	`project_tasks`	`modules/operations`	TenantScopedEntity	Projects › Tasks tab
`ProjectExpense`	`project_expenses`	`modules/operations`	TenantScopedEntity	Projects › Expenses tab

Entity class	Table	Package	Base class	What it holds
`SecurityIncident`	`security_incidents`	`modules/operations`	TenantScopedEntity	Operations Center › Security Incidents
`SecurityIncidentStage`	`security_incident_stages`	`modules/operations`	TenantScopedEntity	Incident stage definitions
`SecurityIncidentStageMapping`	`security_incident_stage_mappings`	`modules/operations`	TenantScopedEntity	Incidents › Stages tab (stage per incident)
`AccountReview`	`account_reviews`	`modules/operations`	TenantScopedEntity	Account reviews (API only)
`OperationSavedView`	`operation_saved_views`	`modules/operations`	TenantScopedEntity	Saved views (API only)

Settings

Entity class	Table	Package	Base class	What it holds
`AuthSettings`	`auth_settings`	`modules/settings`	TenantScopedEntity	Settings › Authentication method
`LdapConnector`	`ldap_connectors`	`modules/settings`	TenantScopedEntity	LDAP connectors
`OauthConnector`	`oauth_connectors`	`modules/settings`	TenantScopedEntity	OAuth connectors (configuration only)
`SamlConnector`	`saml_connectors`	`modules/settings`	TenantScopedEntity	SAML connectors (configuration only)
`SsoProviderConfig`	`sso_provider_configs`	`modules/settings`	TenantScopedEntity	SSO provider configs (API only)
`SystemInfo`	`system_info`	`modules/settings`	TenantScopedEntity	About System, maintenance-mode flag
`SystemLog`	`system_log`	`modules/settings`	TenantScopedEntity	Settings › System Log
`SystemUpdate`	`system_updates`	`modules/settings`	TenantScopedEntity	Settings › Updates register
`TenantDataBackup`	`tenant_data_backups`	`modules/settings`	TenantScopedEntity	Backups written by Data Reset
`TrustCenterSettings`	`trust_center_settings`	`modules/settings`	TenantScopedEntity	Trust Center publish setting
`WebhookEndpoint`	`webhook_endpoints`	`modules/settings`	TenantScopedEntity	Webhooks

Notifications, comments, activity and audit

Entity class	Table	Package	Base class	What it holds
`Notification`	`notifications`	`modules/notification`	TenantScopedEntity	Notification bell and page
`NotificationHistory`	`notification_history`	`modules/notification`	(none; own id)	Notification history

Entity class	Table	Package	Base class	What it holds
`NotificationPreference`	`notification_preferences`	`modules/notification`	(none; own id)	Notification preferences
`NotificationTemplate`	`notification_templates`	`modules/notification`	(none; own id)	Notification templates
`RecordComment`	`record_comments`	`modules/comments`	TenantScopedEntity	Comments on any record
`RecordCommentAttachment`	`record_comment_attachments`	`modules/comments`	TenantScopedEntity	Comment attachments (metadata; bytes in object storage)
`RecordActivity`	`record_activity`	`modules/activity`	TenantScopedEntity	Activity Log (field-level change history)
`AuditLog`	`audit_logs`	`modules/audit`	TenantScopedEntity	Older audit trail (`/api/v1/audit-logs`)

Older models not used by the web client

Entity class	Table	Package	Base class	What it holds
`PolicyDocument`	`policies`	`modules/policy`	TenantScopedEntity	Older policy model, mapped by two classes
`Policy`	`policies`	`modules/policy`	(none; own id)	Older policy model, mapped by two classes
`PolicyHistory`	`policy_history`	`modules/policy`	(none; own id)	Older policy history
`PolicyTemplate`	`policy_templates`	`modules/policy`	(none; own id)	Policy templates (API only)
`PolicyAcknowledgment`	`policy_acknowledgments`	`modules/policy`	TenantScopedEntity	Policy acknowledgments (API only)
`Incident`	`incidents`	`modules/incident`	TenantScopedEntity	Older incident model (`/api/v1/incidents` , API only)
`CorrectiveAction`	`corrective_actions`	`modules/incident`	TenantScopedEntity	Older corrective actions
`Issue`	`issues`	`modules/issue`	TenantScopedEntity	Older issue model (`/api/v1/issues` , API only)
`ExceptionRequest`	`exception_requests`	`modules/issue`	TenantScopedEntity	Older exception requests (`/api/v1/exceptions`)
`Evidence`	`evidences`	`modules/evidence`	TenantScopedEntity	Older evidence (`/api/v1/evidence`)
`EvidenceRequest`	`evidence_requests`	`modules/evidence`	TenantScopedEntity	Older evidence requests
`Task`	`tasks`	`modules/task`	(none; own id)	Older task model (`/api/v1/tasks` , API only)

Id-list link tables (`@ElementCollection` , no foreign key to the target):

Owner table	Field	Link table	Holds
`policy_templates`	`applicableFrameworks`	`policy_template_frameworks`	String values

Security

This page describes the security mechanisms as implemented. It is written for reviewers and installers; the user-side view of permissions is in Permissions and access. Known gaps are listed at the end of each section and summarised in Known security gaps.

Authentication

Sign-in

`POST /api/v1/auth/login` (`AuthController`, `AuthServiceImpl.login`):

1. The tenant comes from the `X-Tenant-Id` header (required).
2. If the account (tenant + e-mail) is currently blocked after failed attempts, the request is answered `429 TOO_MANY_ATTEMPTS` before any database lookup.
3. The account is looked up by tenant, e-mail and status `ACTIVE`. An unknown or inactive account counts as a failure and returns `401` "Email or password is incorrect."
4. The password is checked against the BCrypt hash in `user_accounts.password_hash`. If it does not match, the tenant's LDAP connectors are asked (see LDAP). If neither accepts, the failure is counted and `401` is returned.
5. On success the failure counter is reset, the user's roles and permission codes are computed, a session row is written and the response returns the access token and sets the refresh cookies.

E-mail is the only login identifier. There is no self-service password reset, registration or e-mail verification endpoint: `TenantContextFilter` exempts `/api/v1/auth/register`, `/forgot-password`, `/reset-password` and `/verify`, but no controller handles those paths.

Tokens and cookies

Item	Implementation
Access token	JWT signed with an HMAC key derived from `JWT_SECRET` (`Keys.hmacShaKeyFor`; the algorithm follows the key length, HS384 with the demo secret). Claims `sub`, `tenantId`, `roles`, `permissions`, `sid`, `iat`, `exp`. Lifetime `security.jwt.expiration-seconds`, 900 s by default (24 h in the Compose file; see Installation).
Where the access token lives	Only in a JavaScript module variable in the browser (`apiClient.ts`). It is never written to `localStorage` or `sessionStorage`; legacy keys `auth_token` and `token` are deleted. A page reload obtains a new token from the refresh cookie.
Refresh token	32 random bytes from `SecureRandom`, Base64url, sent only as the cookie `grc_refresh`: `HttpOnly`, `Secure` per `security.session.cookie-secure`, `SameSite=Lax`, `Path=/api/v1/auth`. Stored in `user_sessions` as a SHA-256 hash; compared in constant time.
Presence cookie	`grc_refresh_present=1`, `HttpOnly`, same flags, `Path=/`. Lets `middleware.ts` redirect anonymous page requests to `/login`. Carries no authority.
Cookie lifetime	Without "Keep me signed in": session cookies. With it: `Max-Age` equal to the remaining absolute session time.
Rotation	Every `POST /auth/refresh` creates a new session row in the same family and marks the previous one `ROTATED`. A replay of an already rotated token within `SESSION_ROTATION_GRACE_SECONDS` (10 s) gets the same answer (for parallel tabs); later it is treated as reuse (`REUSE_DETECTED`) and the family is revoked.

Item	Implementation
Session limits	Idle 30 min and absolute 8 h; with “Keep me signed in” idle 12 h and absolute 7 days. At most 10 sessions per user. Ended sessions are kept 30 days.
Revocation	Each request’s `sid` claim is checked against `user_sessions` (`existsByFamilyIdAndRevokedAtIsNull`) by `JwtAuthenticationFilter` , so signing out a device (Account page, Settings › Authentication › Active Sessions, “Sign out everywhere”) stops its access token at once with `401 SESSION_REVOKED` . The account’s status is also checked on every request (`401 ACCOUNT_INACTIVE`).
Background polling	The 10-second `/sync/changes` poll does not trigger a token refresh on 401, so an unattended tab does not keep the idle window alive.

Session details and endpoints: backend `doc/api/sessions.md` . The browser-side idle timer and multi-tab coordination are described in Signing in and sessions.

The BFF proxy

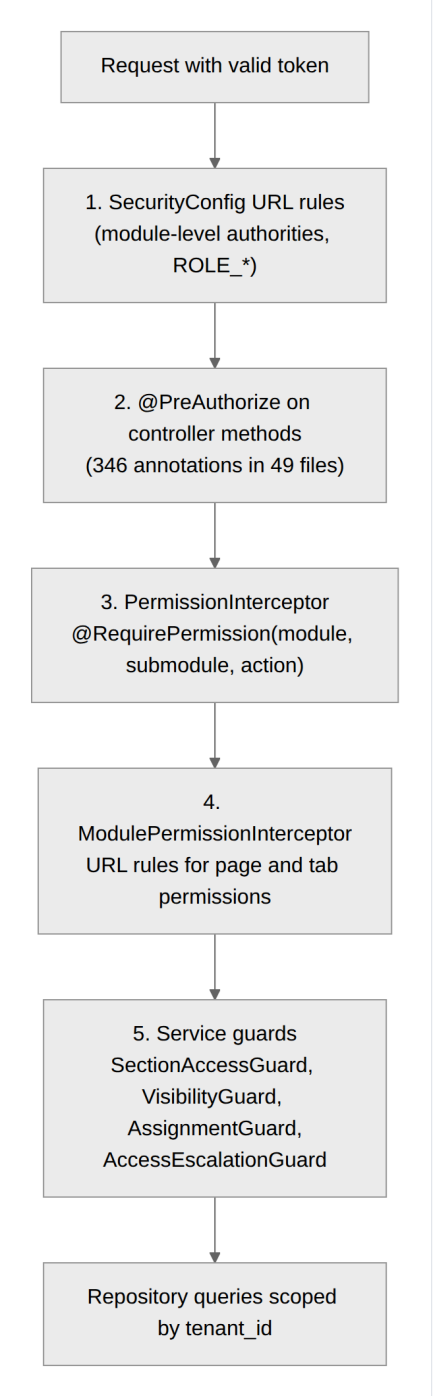
All browser API traffic goes through `src/app/api/v1/[...path]/route.ts` :

Control	Behaviour
CSRF on auth endpoints	Requests to `auth/*` whose `Sec-Fetch-Site` header is present and not `same-origin` are refused with `403 CROSS_SITE_AUTH_BLOCKED` . Requests without the header (non-browser clients) pass. The backend never sees `Origin` or `Referer` , so this check can only happen here.
Second CSRF factor	The backend requires the custom header `X-GRC-Client` on `/auth/refresh` , `/auth/logout` and `/auth/logout-all` . A cross-site form post cannot set it, and it is not in the backend’s CORS allowed headers. All other endpoints require a Bearer token, which a cross-site request cannot attach. Spring Security’s own CSRF protection is disabled (stateless API).
Header scrubbing	Removes `host` , `origin` , `referer` , `connection` , `content-length` , `accept-encoding` , `expect` , `x-forwarded-for` , `x-forwarded-host` , `x-forwarded-proto` , `x-forwarded-port` , `x-real-ip` and `forwarded` from the browser’s request, then sets one `x-forwarded-for` from `cf-connecting-ip` , else `x-real-ip` , else the first `x-forwarded-for` value.
Path traversal	Segments `.` , `..` , or containing `/` or `\` return `400 INVALID_PATH` , so the proxy cannot reach `/actuator` or other paths outside `/api/v1` .
Caching	`Cache-Control: no-store` on every `auth/*` response.
Cookies	Multiple `Set-Cookie` headers are copied individually so the refresh cookie is not folded.
Fail closed	No `BACKEND_API_URL` : every call returns 500 instead of falling back to a default host.

`middleware.ts` does not run on `/api/*` (matcher excludes it), which also avoids Next.js’s 10 MB body buffering on uploads.

Authorisation

Authorisation is layered. A request must pass every layer that applies to it.



Permission model

Concept	Implementation
Group	`OrganizationRole` (`organization_roles`), shown as Organization › Groups. Permissions are granted only to groups; users are members of groups. Effective permissions are the union of the user's groups plus active individual grants (`user_permission_grants`). There is no deny.
Permission code	`<module>_<submodule>_<action>` , lower case, `-` replaced by `_` . Pages and tabs are separate units, for example `control_center_controls_read` and `control_center_controls_audits_audit_results` . Catalogue: `modules/organization/seed/PermissionCatalog.java` , mirrored by the frontend's `src/shared/config/navigation.ts` ; tests check they match.

Concept	Implementation
Actions	`read`, `create`, `edit`, `delete`, `import`, `export`, `manage-settings`, `audit-results`, `maintenance-results`, `view-comments`, `create-comments`, `delete-comments`, `manage-access`, `execute`, `assign`, `reassign`
Access levels (UI)	The Groups dialog offers one level per page or tab: No Access, View (`read`, `export`), Manage (View + `create`, `edit`, `import`, `audit-results`, `maintenance-results`), Full Control (Manage + `delete`, `manage-settings`, `manage-access`); per group, Comments & Attachments (None, View, Contribute, Manage) and Assignment Management (Can Assign, Can Reassign). The mapping lives in the frontend (`roleAccessModel.ts`); the backend stores action codes.
Implied read	Granting any action on a unit also grants its `read`, and for a tab also the parent page's `read`.
Built-in groups	`Admin` (all permissions, locked), `Read Only` (every `read` outside admin-only modules), `Third Party` (only its own vendor records; visibility `OWN`). All three cannot be deleted. Synced at every start by `PermissionCatalogSyncRunner`.
Admin-only module	`settings`. Its permissions are held only by the `Admin` group (or the legacy name `Administrator`), the auth-side `ADMIN` role and super admins. They cannot be given to another group, an individual grant or an access request (`409 ADMIN_ONLY_PERMISSION`).
Super admins	E-mails in `SUPER_ADMIN_EMAILS`. They bypass the permission interceptors; every bypass is logged as `SUPER ADMIN BYPASS: user=... performed <METHOD> <path>` (WARN). Not grantable through the UI or API.
Auth-side roles	The older roles `ADMIN`, `EDITOR`, `AUDITOR` (`roles`, `sys_permissions`) still exist. `ROLE_ADMIN` passes all permission checks. These roles are managed only through `/api/v1/auth/roles` (ADMIN only, not used by the UI).

Enforcement points

Layer	What it checks	Response on denial
`SecurityConfig`	Per path prefix and verb, an authority such as `risk_management_read` / `_create` / `_edit` / `_delete` or a legacy `ROLE_*` (for example `/api/v1/risks/**`, `/assets/**`, `/compliance/**`, `/control/**`, `/policies/**`, `/incidents/**`). ADMIN only: `/roles/**`, `/auth/roles/**`, `/permissions/**`, `/users/**`, `/tenants/**`, `/trust-center/**` (except the public listing), `/actuator/**` (except health and info). ADMIN or AUDITOR: `/audit/**`, `/audit-logs/**`. Everything else: authenticated.	`403 {"code":"FORBIDDEN"}`
`@PreAuthorize`	Module-level authority expressions on controller methods.	`403 FORBIDDEN`
`PermissionInterceptor`	Exact `(module, submodule, action)` from `@RequirePermission` (37 annotations in 6 controllers: Organization users, groups, departments, grants, access requests, and tenant sessions), evaluated against the database.	`403 {"error":"Insufficient permissions","required":{...}}`

Layer	What it checks	Response on denial
`ModulePermissionInterceptor`	For endpoints without `@RequirePermission`: URL rules map to a page or tab; verb maps to action (GET/HEAD `read`, POST `create` except search-like paths, PUT/PATCH `edit`, DELETE `delete`, `/import` and `/export` suffixes). Unknown paths pass. Skipped for anonymous calls, `ROLE_ADMIN`, super admins and accounts without any organization group. `/api/v1/settings/mfa` is always allowed (self-service).	same as above
`SectionAccessGuard`	Rights the URL cannot express: risk reviews per register, audit and maintenance result fields (`audit-results` / `maintenance-results` versus `edit`), comment rights, continuity audit criteria written back to the plan.	same as above
`VisibilityGuard`	Row-level visibility for nine registers (`ASSET`, `ASSET_RISK`, `THIRD_PARTY_RISK`, `OPERATIONAL_RISK`, `INTERNAL_CONTROL`, `POLICY_STANDARD`, `VENDOR`, `SERVICE_AGREEMENT`, `OBJECTIVE`): a group in mode `ALL` sees everything; in `OWN` (UI “Assigned Records Only”) a user sees records that name them or their group, records they created, and records that name nobody. Tabs and attachments are judged by their parent record. Lists filter in SQL so totals stay correct.	`403 FORBIDDEN`; for an external party (vendor role) on vendors, agreements, vendor documents and questionnaires `404`
`AssignmentGuard`	Naming someone other than yourself in an assignee field of those nine registers requires `assign` (field was empty) or `reassign` (field had others).	`403` with `required.action` `assign` or `reassign`
`AccessEscalationGuard`	Only `manage-access` may change a group’s permissions or visibility; non-administrators cannot change groups they belong to, their own memberships, the Admin group’s membership, or grant permissions they do not hold.	`403` or `409 SELF_GROUP_ACCESS`, `SELF_MEMBERSHIP`, `ADMIN_GROUP_REQUIRES_ADMIN`, `PERMISSION_NOT_HELD`

The JWT carries only module-level authorities (`<module>_<action>`), not page codes, to keep the header small. Page and tab precision is decided in the interceptors and guards from the database, so a change to a group takes effect on the next request. The UI learns of permission changes through the `access_control` key in the sync feed and reloads `GET /auth/me/permissions` within about 10 seconds.

Full detail (catalogue per module, inheritance rules, tests): backend `doc/api/access-control.md`.

Frontend guards

The frontend repeats the checks for display only: `PageAccessGuard` (page-level “Access Denied”), `useActionGuard` and `useSectionGuard` (buttons and tabs locked, not hidden, with Request Access), sidebar items hidden without `read`. The frontend’s `isAdmin` is true for any group whose name contains “ADMIN”, which is broader than the backend’s exact-name rule; the backend decides.

Password hashing

Item	Implementation
Algorithm	BCrypt (`new BCryptPasswordEncoder()`, Spring default strength 10)
Where	`user_accounts.password_hash`

Item	Implementation
Minimum length	8 characters for users created or updated through Organization › Users (`UserCreateRequest` , `UserUpdateRequest`); 6 characters on the older `/api/v1/users` endpoints. No other complexity rule.
Refresh tokens	SHA-256 hash (high-entropy random input)
Seeded demo accounts	Password `password123` (dev profile only); see Installation.

LDAP, OAuth, SAML and MFA

Mechanism	State
LDAP	Working. Connectors are configured per tenant under Settings › Authentication (`ldap_connectors` ; bind password encrypted). At login, if the local password does not match, `DirectoryAuthenticatorImpl` asks the connector chosen in the authentication settings first, then every enabled connector whose mail domain matches the e-mail. The account must already exist in `user_accounts` with status `ACTIVE` ; LDAP does not create accounts. A directory that is down does not block local logins. A local password always works as break-glass.
OAuth connectors, SAML connectors, SSO providers	Configuration only. Records can be created, edited, imported and exported (`oauth_connectors` , `saml_connectors` , `sso_provider_configs` ; secrets and SP private keys encrypted), and the UI shows callback URLs built from `APP_PUBLIC_BASE_URL` . The security chain has no `oauth2Login()` or SAML login, and `pom.xml` has no SAML library, so users cannot sign in through them. `/api/v1/oauth/success` returns a mock token (`mock-jwt-token-for-e2e-testing`) when called without an OAuth principal.
Google OAuth properties	`spring.security.oauth2.client.registration.google.*` are present but unused by any login flow.
MFA	Endpoints exist under `/api/v1/settings/mfa` (`setup` , `enable` , `verify` , `disable` , `backup-codes` , `regenerate-codes`), but the web client does not call them and sign-in never asks for a second factor. The implementation is incomplete: `enable` verifies the submitted code against itself as the secret, and `verify` returns whether MFA is enabled without checking the code.

Tenant isolation

Control	State
Tenant of a request	From the token's `tenantId` claim when a Bearer token is present (highest-priority resolver), otherwise from subdomain or `X-Tenant-Id` . The tenant must exist. See Architecture.
Row ownership	`tenant_id NOT NULL` on 105 entities, set on insert from the tenant context; an insert without context fails.
Query filtering	Application code: repository methods take `tenantId` (`findByIdAndTenantId` , `findAllByTenantId...`). There is no Hibernate filter or PostgreSQL row-level security in effect (`pg_policies` is empty on the demo database; the RLS migration is not applied because Flyway is disabled).
Cross-tenant ids	Lookups include the tenant, so another tenant's record id answers 404.
Session tenant	Refresh and logout read the tenant from the stored session row; the header is ignored, so a session cannot be moved to another tenant.
Files	Storage keys include the tenant id and are always read from a tenant-filtered database row.

Control	State
Tenant administration	`/api/v1/tenants/**` requires the auth-side `ADMIN` role and is exempt from tenant resolution. `ADMIN` is a per-tenant role and there is no separate platform-operator role, so an administrator of any tenant can list all active tenants (`GET /api/v1/tenants`) and create, re-plan, suspend or activate tenants. The web client does not call these endpoints.

Rate limiting

`security/ratelimit` : an in-memory fixed-window limiter (`FixedWindowRateLimiter`) and an account-level login block (`LoginAttemptService`). Budgets and headers are listed in REST API.

- The filter sits after JWT authentication and before authorisation, so a flood cannot probe 403s.
- State is per JVM: with several backend instances each keeps its own counters, and a restart clears them.
- The client IP is the first value of `X-Forwarded-For` . Through the BFF that value is set by the proxy from trusted hops; a client that reaches port 8080 directly can set it freely and pick its own per-IP bucket.
- The login failure block (5 failures in 15 minutes, 15-minute block) is always active, even with `RATE_LIMIT_ENABLED=false` .

Audit and logging of security events

Trail	Content	Where
Record Activity Log	One `record_activity` row per insert, update and delete of every entity marked `ActivityTracked` , with field diffs. Fields matching `password` , `secret` , `token` , `hash` , `credential` are never recorded; values are cut at 500 characters. Written in the same transaction as the change.	Database; shown in each record's Activity Log panel
System Log	`system_log` rows written by `SystemLogHubService.logAction` from Settings services (authentication settings and connectors, maintenance mode, cache clear, diagnostics, health configuration) and Compliance Hub services (packages, analysis, obligations, compliance exceptions, audit findings). Other registers do not write here. Each entry is also dispatched to the tenant's webhooks. Read-only in the UI, exportable to CSV.	Database; Settings › System Log
`@AuditLog`	68 annotated methods in 20 classes (including `LOGIN`). `AuditLogAspect` writes operation, user, IP, tenant, duration and outcome.	Log files only (`AUDIT_LOG` , `AUDIT_WARN` , `AUDIT_ERROR` loggers)
`SECURITY_AUDIT` logger	Session issue, rotation, revocation, reuse detection, revoked-token use.	Log output
`audit_logs`	Rows appended by `AuditEventListener` for `RiskCreated/Updated` and `IncidentCreated/Updated` events. Only the older incident service (`/api/v1/incidents`) publishes such events, so the registers the UI uses do not write here. Read through `/api/v1/audit-logs` (ADMIN or AUDITOR).	Database
Super admin bypass	WARN line per bypassed request; `SUPER ADMIN LOGIN` on sign-in.	Log output

File storage security

Aspect	Implementation
Access path	All uploads and downloads go through the backend; no pre-signed URLs are issued. The object store does not need to be reachable from browsers.
Keys	`<area>/<tenantId>/<ownerId>/<uuid>` (`StorageKeys.newKey`). The original file name is stored only in the database. `StorageKeys.requireSafe` rejects `..` , `\` , absolute paths and empty segments. Keys are never taken from user input.
Authorisation	Download and delete require the parent record's page permission. For the nine visibility registers the parent's row visibility also applies: evidence files are judged by their owning audit, maintenance, review or policy, comment files by the commented record.
Integrity	SHA-256 checksum computed while streaming the upload and stored with the metadata.
Limits	25 MB per file, 30 MB per request.
Content checks	No content-type allow-list and no malware scanning in the code.
Encryption at rest	Not set by the application (no server-side encryption option on `putObject`); depends on the storage service. `MINIO_SECURE=false` by default, so traffic to MinIO is plain HTTP unless changed.
Download headers	`Content-Disposition: attachment` with RFC 5987 file name.

Secrets handling

Secret	Where it comes from	Notes
`JWT_SECRET`	environment	`prod` / `production` / `staging` profiles refuse to start if it is missing, shorter than 32 characters, or one of the three committed defaults. Other profiles only warn.
Database password	`SPRING_DATASOURCE_PASSWORD`	Hardened profiles refuse an empty value or `123456` . The error message mentions `DB_PASSWORD` , but the property is read from `SPRING_DATASOURCE_PASSWORD` .
Jasypt key	`jasypt.encryptor.password` in `application.properties` (`grc360-encryption-key-change-in-production`); override with `JASYPT_ENCRYPTOR_PASSWORD`	Encrypts LDAP bind passwords, OAuth client secrets, SAML SP private keys, SSO client ids and secrets, webhook signing secrets, MFA secrets and backup codes. Not validated at startup.
MinIO keys	`MINIO_ACCESS_KEY` , `MINIO_SECRET_KEY`	Defaults `admin` / `password123` (`minioadmin` in `docker`).
SMTP password	`MAIL_PASSWORD`	
Webhook signatures	per endpoint	Deliveries carry `X-GRC360-Event` and, when a secret is set, `X-GRC360-Signature: sha256=<HMAC-SHA256 of the body>` .
Frontend	none	The frontend holds no secrets; `NEXT_PUBLIC_*` values are public by design.

The backend `.gitignore` excludes `.env` ; `.env.example` contains only placeholders and development defaults.

HTTP security headers

Spring Security's defaults apply to backend responses: `X-Content-Type-Options: nosniff`, `X-XSS-Protection: 0`, `Cache-Control: no-cache, no-store, max-age=0, must-revalidate`, `X-Frame-Options: SAMEORIGIN` (configured), and `Strict-Transport-Security` with `max-age=31536000` on HTTPS requests. The Next.js frontend sets no Content-Security-Policy or other security headers of its own (`next.config.ts` is empty).

Anonymous endpoints

Permitted without a token in `SecurityConfig`: `/`, `/actuator/health`, `/actuator/health/**`, `/actuator/info`, `/api/v1/trust-center/documents/public`, `/api/v1/auth/login`, `/api/v1/auth/refresh`, `/api/v1/auth/logout`, `/api/v1/auth/logout-all`, `/swagger-ui.html`, `/swagger-ui/**`, `/v3/api-docs`, `/v3/api-docs/**`, `/login/**`, `/oauth2/**`, `/api/v1/public/**`, `/error`, `/error/**`, and every `OPTIONS` request. Paths under `/api/v1` other than the auth paths still need a resolvable tenant (`X-Tenant-Id`), otherwise `TenantContextFilter` answers 401.

Known security gaps

Gap	Detail
No enforced MFA	See above.
No SSO sign-in	OAuth and SAML records are configuration only.
No password reset flow	Passwords are set by administrators.
No database-level tenant isolation	Isolation depends on every query including `tenant_id`.
Default secrets in non-hardened profiles	The `docker` profile and the Compose file start with the committed JWT secret, database password `123456`, MinIO `admin` / `password123` and Grafana `admin` / `password123`.
Chaos endpoints under `dev`	With the `dev` profile, `/api/chaos/*` (enable, activate scenarios such as database connection drops or memory stress) is open to any authenticated user. The demo instance runs with `dev`.
WebSocket endpoint	`/ws` is registered twice with allowed origins `*`; unused by the UI.
`X-Forwarded-For` trust	Direct access to port 8080 lets a caller choose the IP used for rate limits and logs.
Health details	`show-details=always` outside `prod` exposes database and disk details on the anonymous `/actuator/health`.
Webhooks	Dispatched for each System Log entry (Settings actions and Compliance Hub actions such as `COMPLIANCE_PACKAGE_CREATED`, `OBLIGATION_UPDATED`, `AUDIT_FINDING_CREATED`) and for events of the older incident API. Changes to assets, risks, controls, policies, vendors, objectives and Operations Center records produce no webhook event.
Tenant registry	Any tenant's `ADMIN` can read and change the tenant registry through `/api/v1/tenants`.

Operations

This page covers running GRC360 day to day: logs, health and metrics, caching, the work the backend does on its own, backups, and how to diagnose common failures.

Logging

Backend

Configuration: `src/main/resources/logback-spring.xml` (selected by `logging.config=classpath:logback-spring.xml` in every profile except `test`, which uses `logback-spring-test.xml`).

Appender	Target	Level filter	Pattern
`CONSOLE`	standard output	all (root `INFO`)	`yyyy-MM-dd HH:mm:ss.SSS | %X{user} | %X{ip} | %X{operation} | LEVEL | message`
`ERROR_FILE`	`logs/<day>/error/<start-time>.log`	ERROR only	`... | User: %X{user} (ID: %X{userId}) | IP: %X{ip} | Tenant: %X{tenant} | Op: %X{operation} | LEVEL | message`
`WARN_FILE`	`logs/<day>/warning/<start-time>.log`	WARN only	same
`INFO_FILE`	`logs/<day>/info/<start-time>.log`	INFO only	same

Behaviour to be aware of:

- Paths are relative to the working directory (`/app` in the Docker image). `<day>` and `<start-time>` are computed once when the application starts (`<timestamp>` elements), so a process that runs for a week keeps writing to the folder of its start day. Each start creates new files.
- The appenders are plain `FileAppender`s: no rotation, no size limit, no retention. Clean up the `logs/` directory yourself.
- Logger levels: `com.strativu.grc360` INFO; Spring Security, Spring Web, Hibernate SQL WARN. The base properties file (and therefore the `dev` profile and a run without a profile) also sets `spring.jpa.show-sql=true`, which prints every SQL statement to standard output; `docker` and `prod` set it to `false`.
- Named loggers: `AUDIT_LOG` (to console and the info file), `AUDIT_WARN`, `AUDIT_ERROR` (from `@AuditLog`); `SECURITY_AUDIT` (session issue, rotation, revocation, reuse detection, revoked-token use) goes through the root appenders.
- The MDC fields in the pattern (`user`, `userId`, `ip`, `tenant`, `operation`) are filled only while an `@AuditLog` method runs (`AuditLogAspect` via `LoggingContext`). Other log lines show them empty.

Correlation ids

`CorrelationIdFilter` accepts an incoming `X-Correlation-ID` header or generates a UUID, stores it in the MDC under `correlationId` and returns it in the `X-Correlation-ID` response header. The log pattern does not print `%X{correlationId}`, so the id cannot currently be found in the log files; add it to the patterns in `logback-spring.xml` if you need to trace a request. `TenantAwareLoggingFilter` puts a `tenantId` MDC key that is not in the pattern either (the pattern uses `tenant`). The tenant filter's own error responses carry a separate `requestId`.

Frontend

The Next.js server writes to standard output. The proxy logs `Proxy error:` with the exception for failed backend calls. There is no log configuration in the frontend repository.

Health checks

Spring Boot Actuator exposes `health`, `info`, `metrics` and `prometheus` (`management.endpoints.web.exposure.include`).

Endpoint	Access	Notes
`/actuator/health`	anonymous	Aggregate status. Details shown to everyone outside `prod` (`show-details=always`), only to authorised callers in `prod` (`when-authorized`).
`/actuator/health/liveness`, `/actuator/health/readiness`	anonymous	Probe groups (`management.endpoint.health.probes.enabled=true`).
`/actuator/info`	anonymous	Returns `{}` (no build info configured).
`/actuator/metrics`, `/actuator/prometheus`	`ROLE_ADMIN` (Bearer token)	Anonymous calls get 401.

Health indicators reported by the running demo instance:

Component	Source	Status in the demo	Notes
`db`	Spring Boot	UP	PostgreSQL `isValid()`
`diskSpace`	Spring Boot	UP	threshold 10 MB
`storage`	`StorageHealthIndicator`	UP (`backend: local`)	DOWN when MinIO cannot be reached
`ldap`	Spring Boot, auto-configured because `spring-ldap-core` is on the classpath	**DOWN** (`CommunicationException: localhost:389`)	Not related to the LDAP connectors configured in the UI; it checks Spring's default `spring.ldap.urls` (`ldap://localhost:389`).
`mail`	Spring Boot	**DOWN** (`failed to connect, no password specified?`, location `:587`)	Present because `spring.mail.host` is defined (even when empty).
`ping`, `ssl`, `livenessState`, `readinessState`	Spring Boot	UP	

Because `ldap` and `mail` are DOWN, `/actuator/health` returns **HTTP 503 with `"status":"DOWN"`** on an installation without an LDAP server on `localhost:389` and without SMTP, although the application works. `/actuator/health/liveness` and `/actuator/health/readiness` return 200 `UP`. The Docker `HEALTHCHECK` in the backend `Dockerfile` and the Compose health check both call `/actuator/health`, so they report the container unhealthy in that situation. Options: point the health checks at `/actuator/health/readiness`, or switch the two indicators off with the standard Spring Boot properties `management.health.ldap.enabled=false` and `management.health.mail.enabled=false` (environment `MANAGEMENT_HEALTH_LDAP_ENABLED=false`, `MANAGEMENT_HEALTH_MAIL_ENABLED=false`), or configure real LDAP and SMTP endpoints.

Settings › System Health (`/api/v1/settings/system-health/checks`) runs its own checks: `database`, `memory_usage`, `disk_space` (DOWN under 1 GB free, WARN under 5 GB), `application_cache` (WARN "No cache manager configured" in every shipped profile), `mail_smtp` (WARN when no host). The page also offers a diagnostics text file (version, Java, OS, uptime, profiles, these checks) and a CSV of the tenant's System Log.

Metrics, Prometheus and Grafana

- `micrometer-registry-prometheus` is on the classpath and `management.prometheus.metrics.export.enabled=true` with a 1-minute step. The standard JVM, HTTP server (`http.server.requests`), HikariCP and Tomcat metrics are available at `/actuator/prometheus`.
- Custom meters exist only for the cache layer (`cache.hits`, `cache.misses`, `cache.evictions`, `cache.invalidations`, `cache.operation.latency`), which is inactive.
- `/actuator/prometheus` requires an ADMIN Bearer token. Access tokens expire after 15 minutes by default, so a static Prometheus scrape configuration cannot authenticate. To scrape, either expose the endpoint on a separate management port reachable only from Prometheus (standard Spring Boot `management.server.port`) and adjust the security rule, or front it with a proxy that injects credentials. The code provides neither.

- The Compose file starts Prometheus (retention 200 h, lifecycle API enabled) and Grafana (admin `admin` / `password123`, sign-up disabled), but `prometheus/prometheus.yml` and `grafana/provisioning/` are not in the repository. No dashboards or alert rules are shipped.

Caching

Layer	State
Spring Cache (`@Cacheable` / `@CacheEvict` on notifications and assets)	Inactive. The only `@EnableCaching` is on `config/CacheConfig`, which loads only when `spring.cache.type=redis` (or the property is absent). The base and `docker` files set `none`, `prod` sets `simple`; neither activates caching, so the annotations have no effect.
Redis	Not used. `RedisAutoConfiguration` is excluded in the base file (inherited by every profile) and `RedisConfig` has the same condition as `CacheConfig`. The Compose `redis` service is started but nothing connects to it. `management.health.redis.enabled=false`.
Settings › System Health › Clear cache	Calls `POST /settings/system-health/cache/clear`; with no cache manager it only writes `SYSTEM_CACHE_CLEARED` to the System Log.
Frontend list cache	Per browser tab (`src/shared/api/listCache.ts`), invalidated by write responses (`X-GRC-Changed`) and the sync poll.
Hibernate	No second-level cache configured; `default_batch_fetch_size=50`.

Recurring work and scheduled jobs

Scheduling is not enabled: the application class has only `@SpringBootApplication` and no class carries `@EnableScheduling`. Every method annotated `@Scheduled` is therefore declared but never runs. The code documents this choice in `NotificationSweepScheduler` and `SessionCleanupService` (“switching it on would simultaneously wake seven dormant jobs that nobody has vetted”).

What actually runs

Task	Trigger	What it does	Configuration
Daily notification sweep (`modules/notification/service/NotificationSweepScheduler`)	Hand-registered `CronTrigger` on a private single-thread scheduler, started as a `SmartLifecycle` bean	For every tenant that has organization users, runs each `NotificationSweep` once per day. The only sweep is `ServiceAgreementExpiryNotifier`: for service agreements in status ACTIVE or EXPIRING it creates `SERVICE_AGREEMENT_EXPIRING_WEEK` (7 days before the end date), `SERVICE_AGREEMENT_EXPIRING_SOON` (3 days) and `SERVICE_AGREEMENT_EXPIRES_TODAY` (end date) for the GRC contacts and support-contract contacts (groups expanded), each milestone at most once per recipient.	`notifications.sweep.cron` (default `0 0 8 * * *`, 08:00 in the JVM’s time zone; the Docker image does not set a time zone, so the container default applies), `notifications.sweep.enabled` (default `true`; `false` in tests)

Task	Trigger	What it does	Configuration
Sweep on bell read	`GET /api/v1/notifications` (both the list and the paged form)	Runs the same sweeps for the caller's tenant if they have not run today. The "already ran" date is kept in memory (`NotificationSweepRunner`), so a restart or a second instance runs them once more; the sweep deduplicates against the database.	none
Service agreement save	Saving an agreement	Runs the expiry check for that agreement immediately.	none
Session purge (`modules/auth/service/impl/SessionCleanupService`)	Called from the token refresh path at most once per hour (`SWEEP_INTERVAL`)	Deletes `user_sessions` rows whose absolute expiry (`expires_at`) is more than `security.session.retention-days` (30) days in the past, in its own transaction; failures are logged and ignored. The purge only happens when someone refreshes a token.	`SESSION_RETENTION_DAYS`
Asynchronous work	`@Async("asyncExecutor")` (`async/AsyncConfiguration`) and `@Async`	Sends SMTP mail (`SmtpEmailSender`) and webhook deliveries (`WebhookServiceImpl.dispatch` , 5 s timeout, no redirects) off the request thread.	none
Startup runners	each start	Schema repair, permission catalogue sync, backfills; see Installation.	none

Date-based **dynamic statuses** (for example an expired agreement or an overdue review shown as such in a grid) are computed when records are read, so they appear without any job.

Declared but inactive in this release

Job	Declared schedule	What it would do
`governance/scheduler/ObjectiveAlertScheduler.sendObjectiveAlerts`	`cron = "0 0 9 * * *"` (daily 09:00)	Create `OBJECTIVE_AUDIT_DUE` when an objective's audit date is today or past, and `OBJECTIVE_TARGET_OVERDUE` when the target date is past and the objective is not ACHIEVED. With no owner it would address a random UUID.
`risk/scheduler/RiskExceptionScheduler.autoExpireDueExceptions`	`cron = "0 0 * * * *"` (hourly)	Mark risk exceptions past their expiration date as expired.
`compliance/service/impl/ComplianceExceptionHubServiceImpl` (scheduled method)	`cron = "0 0 * * * *"` (hourly)	Set compliance exceptions past their expiration date to EXPIRED and record an `AUTO_EXPIRE` workflow event.
`commandcenter/scheduler/DashboardCacheScheduler.clearExpiredCacheEntries`	`fixedRate = 3600000` (hourly)	Clear all caches.
`commandcenter/service/DataArchivingService.archiveOldData`	`cron = "0 0 0 * * ?"` (midnight)	"Archive" data older than two years; the implementation only counts and logs.
`issue/service/job/ExceptionExpirationJob.expireOldExceptions`	`cron = "0 0 0 * * ?"` (midnight)	Set APPROVED exception requests (older `/exceptions` model) past `validUntil` to EXPIRED.

Job	Declared schedule	What it would do
`thirdparty/scheduler/ServiceAgreementScheduler.updateServiceAgreementStatuses`	`cron = "0 0 1 * * ?"` (01:00)	Move ACTIVE/EXPIRING agreements past their end date to EXPIRED, and those within 30 days to EXPIRING.

Consequences: stored statuses of service agreements, risk exceptions and compliance exceptions do not change by themselves, and objective alerts are never sent. Adding `@EnableScheduling` would start all seven at once, including the archiving job.

Backups

What exists	What it covers	Limits
`scripts/backup.sh` (backend repository)	`pg_dump` of `grc360-db` on `localhost:5432` as `postgres`, gzip, into `/backup`, deletes dumps older than 7 days	The password in the script is `password123`, which does not match the Compose database password `123456`; edit before use. Not scheduled by anything in the repositories. Does not cover object storage.
Settings › Data Reset backups	Before a Data Reset deletes anything, all affected rows (including join tables) are written as gzipped JSON (`grc360-tenant-backup/1`) to object storage under `data-reset-backups/<tenant>/...` and listed in `tenant_data_backups`; downloadable from the same page. If the backup cannot be written, nothing is deleted.	Only for the tenant and groups being reset. There is no restore function in the application.
`staging-clear-data.yml` workflow	Takes a `pg_dump` on the staging host before clearing staging data	Staging only.
`doc/server/server-envanteri.md`	Mentions a daily 03:00 `pg_dump` to encrypted S3	Describes another environment; nothing in the repositories implements it.

There is no automatic backup of the database or the object storage bucket. A complete backup consists of:

1. A PostgreSQL dump of the application database (all tenants share it).
2. A copy of the object storage bucket (`grc360-files` by default), or of the `storage.local.root` directory when `STORAGE_TYPE=local`. File metadata in the database and objects in storage must be restored together.
3. The environment configuration, especially `JWT_SECRET` and the Jasypt key: without the same Jasypt key, encrypted connector passwords, webhook secrets and MFA data in the database cannot be decrypted.

Log files and the in-memory state (rate limits, change feed) need no backup.

Multi-instance operation

The backend keeps this state in the memory of one JVM: rate-limit counters and login blocks, the change feed (`ChangeTracker`, which drives live refresh in other tabs), the notification sweep's "ran today" marker, the refresh-rotation grace cache, and WebSocket sessions. Running more than one backend instance behind a load balancer works for requests, but limits apply per instance and a change made through one instance is not announced to browsers polling another until their next full reload. The code contains no shared store for this state.

Troubleshooting

Symptom	Cause	Fix
Every API call from the UI returns HTTP 500 `{"error":"BACKEND_API_URL is not configured"}`	`BACKEND_API_URL` not set in the frontend server's environment	Set it at run time, including `/api/v1`, and restart the Next.js server.

Symptom	Cause	Fix
Sign-in fails with 401 “Authentication required.” and other calls return 404 `ENDPOINT_NOT_FOUND` for paths such as `/risk-management/...`	`BACKEND_API_URL` lacks `/api/v1` (for example `http://localhost:8080`, the value the frontend README suggests), so the proxy calls `/auth/login` instead of `/api/v1/auth/login`	Use `http://<host>:8080/api/v1`.
UI calls fail with 504 `Backend timeout`	Backend slower than 15 s (60 s for uploads) or unreachable from the Next.js server	Check backend health and network from the frontend host.
UI calls fail with 500 `Internal Proxy Error`	Connection refused or DNS failure towards `BACKEND_API_URL`	Check the URL and that the backend is listening.
Sign-in returns 500 `INTERNAL_SERVER_ERROR`	No `X-Tenant-Id` header on `POST /auth/login`: a browser with no stored tenant and a frontend built without `NEXT_PUBLIC_TENANT_ID`	Rebuild the frontend with `NEXT_PUBLIC_TENANT_ID=<tenant uuid>`, or send the header from the API client.
Sign-in returns 400 `BAD_REQUEST` (“This request did not say which organization it belongs to.”)	`X-Tenant-Id` blank or not a UUID	Send a valid tenant UUID.
Sign-in returns 401 “Email or password is incorrect.” for a known user	Wrong tenant id (the account is looked up by tenant + e-mail), account INACTIVE, or wrong password	Check `user_accounts` for the tenant and status.
Sign-in returns 429 `TOO_MANY_ATTEMPTS`	5 failures for that account in 15 minutes	Wait for `Retry-After` (up to 15 minutes) or restart the backend (counters are in memory).
Requests without a token return 401 `{"error":"UNAUTHORIZED","message":"Authentication required.","requestId":...}`	Tenant could not be resolved and the call is anonymous	Sign in, or send `X-Tenant-Id` for the anonymous public endpoints.
Requests return 404 `Tenant not found`	The token or header names a tenant that has no `tenants` row (for example data from `DummyDataSeeder`, tenant `00000000-...-0001`)	Use an existing tenant. The UI clears its stored tenant id when it sees this message.
Users are logged out at every page reload	Refresh cookie not sent: `NEXT_PUBLIC_API_BASE_URL` set to an absolute URL, `SESSION_COOKIE_SECURE=true` on plain HTTP (non-localhost), or the API reached on a different host than the UI	Keep the API base relative (`/api/v1`), serve over HTTPS or set `SESSION_COOKIE_SECURE=false` only for HTTP test setups.
Refresh returns 403	`X-GRC-Client` header missing (custom clients) or `Sec-Fetch-Site` not `same-origin` (proxy `CROSS_SITE_AUTH_BLOCKED`)	Send `X-GRC-Client`; call from the same origin.
Uploads and downloads return 503 `STORAGE_UNAVAILABLE`	MinIO/S3 not reachable or wrong credentials; the application starts anyway and logs an ERROR at startup; `/actuator/health` shows `storage: DOWN`	Check `MINIO_ENDPOINT`, `MINIO_ACCESS_KEY`, `MINIO_SECRET_KEY`, network; or use `STORAGE_TYPE=local` for a test machine.
Download returns 404 “Stored file is missing … please re-upload”	Metadata exists but the object does not (not migrated or deleted in storage)	Restore the object from the bucket backup.
Upload returns 413 `FILE_TOO_LARGE`	File over 25 MB or request over 30 MB	Smaller file. If the 413 comes from nginx (HTML body), raise `client_max_body_size` to at least 30m.
Upload returns 400 `INVALID_UPLOAD`	Body cut off on the way (proxy body limit, timeout)	Check reverse-proxy limits and timeouts.
`/actuator/health` returns 503 and the container is “unhealthy” while the app works	`ldap` and `mail` health indicators DOWN	See Health checks.

Symptom	Cause	Fix
Backend refuses to start: “Hardened profile requires JWT_SECRET …” / “… a secure database password via DB_PASSWORD”	`prod` or `staging` profile with a missing, short or default secret, or database password empty / `123456`	Set `JWT_SECRET` (32+ characters, not a committed default) and `SPRING_DATASOURCE_PASSWORD`.
A list endpoint returns 500 after an upgrade with “column … does not exist”	A new NOT NULL column that `ddl-auto=update` could not add to a populated table	Check the startup log of `SchemaRepairRunner`; the column must be added there with a default.
A sort returns 400 `INVALID_SORT_PROPERTY`	`sort` names a property the entity does not have	Use an entity property name.
403 `{"error":"Insufficient permissions","required":{...}}`	The user’s groups lack the page, tab or action named in `required`	Grant it in Organization › Groups, or approve the user’s access request.
403 `FORBIDDEN` “This record is not one of yours…”	Row-level visibility (`Assigned Records Only`)	Name the user or their group on the record, or change the group’s data visibility.
401 `SESSION_REVOKED`	The session was signed out elsewhere or refresh-token reuse was detected	Sign in again.
Settings pages return 403 for a group named “IT Admins”	Settings is admin-only and only the exact `Admin` group counts	Add the user to `Admin`.
Objective alerts, automatic exception expiry or agreement status changes never happen	Scheduled jobs are inactive	See Declared but inactive.
Live refresh between tabs stops working on some users	Several backend instances; the change feed is per instance	See Multi-instance operation.

Known operational limitations

- Settings › System Health › Send to support: without `spring.mail.host` and `support.contact-email` it says to download the diagnostics instead; with both set it answers “Diagnostics queued for delivery” and writes a System Log entry, but no code sends anything.
- Settings › Updates lists rows of the `system_updates` table; nothing fills that table, and the application does not check for or install updates.
- Settings › Updates › Maintenance mode stores a flag and a message per tenant and logs the change; no filter blocks requests while it is on, and the login page does not query `/api/v1/public/system/maintenance-status`.
- Settings › About System reports `dbSchemaVersion: V18` as a fixed value.

Development

This page is for developers working on either repository: where things are, how to run both parts locally, how to test, and the rules and pipelines the projects use.

Repositories

Repository	Default branch for this release	Stack
`Strativuco/GRC_Frontend_Code`	`main`	Next.js 16.2.6 (App Router), React 19.2.4, TypeScript 5 (`strict: true`), Tailwind CSS 4, Vitest 3, Testing Library, MSW
`Strativuco/GRC_Backend_Code`	`develop` (also `main`)	Spring Boot 3.5.16, Java 17 language level (runs on 21), Maven wrapper, Spring Data JPA, Spring Security, springdoc, jjwt, MinIO client, Lombok, JUnit 5, ArchUnit, H2 for tests

Backend layout

```
GRC_Backend_Code/
  pom.xml, mvnw, mvnw.cmd, .mvn/        Maven build
  Dockerfile, .dockerignore             backend image
  docker-compose.yml                    full stack (see Installation)
  .env.example                          backend environment variables
  postgres/init.sql                     PostgreSQL init script for Compose
  docker/local-ldap/                    throwaway OpenLDAP (ldap://localhost:13389) and a Java test directory
for LDAP work
  scripts/                              backup.sh, ssl-setup.sh, one-off SQL fix
  db/                                   seed-data.sql (outdated), staging-clear-business-data.sql
  doc/                                  api/*.md, adr/, diagrams/, plan/, server/ (mostly Azerbaijani)
  src/main/java/com/strativu/grc360/
    Grc360Application.java
    modules/<module>/{api,dto,entity,repository,service,...}   24 business modules
    shared/, common/                     base entities, tenant context, relation catalogue, sync, logging
    infrastructure/                      tenancy resolvers, storage, persistence (tenants), relation impls
    config/                              security, OpenAPI, WebSocket, MVC, cache, dev data
    security/                            rate limiting, super admin, access policy
    presentation/                        global exception handler, tenant controller
    migration/, seed/, events/, cache/, observability/, chaos/, websocket/, async/, timescale/, api/
  src/main/resources/
    application.properties, application-docker.properties, application-prod.properties
    logback-spring.xml
    db/migration/                        Flyway scripts (Flyway disabled)
  src/test/java/...                      550 test source files
  src/test/resources/                    application-test.properties, logback-spring-test.xml
  .github/workflows/                     staging deploy and maintenance workflows
```

Frontend layout

```
GRC_Frontend_Code/
  package.json, package-lock.json       npm scripts and dependencies
  next.config.ts                         empty
  tsconfig.json                          strict, "@/*" -> "./src/*"
  eslint.config.mjs                      eslint-config-next core-web-vitals + typescript
  .prettierrc                            semi, double quotes, 2 spaces, prettier-plugin-tailwindcss
  .editorconfig, .markdownlint.json
  vitest.config.mts, vitest.setup.ts     jsdom, base URL http://localhost:3000
  Dockerfile                             frontend image
  .gitmodules -> .rules                  shared rules submodule (Az-Intellect/.rules)
  AGENTS.md, AI-README.md, CONTRIBUTING.md, RAPORT.md, CHANGELOG.md
  doc/                                   guide/ (this documentation), plan/, adr/, api/, diagrams/, issues/,
server/
  src/
    app/(public)/login                   sign-in page
    app/(app)/<module>/[section]         module routes
    app/api/v1/[...path]/route.ts        BFF proxy
    middleware.ts                        anonymous redirect
    domain/<module>/                     pages, forms, module logic
    shared/{api,auth,config,hooks,i18n,layouts,notifications,theme,types,ui,utils}
    test/                                MSW handlers and test harness
  tests/                                 cross-cutting tests (unit, integration, contract, chaos, e2e-style, QA
stages)
  .github/workflows/ci-cd.yml            production deploy on push to main
```

Running locally

Prerequisites

- JDK 17 or newer (the image uses 21), Node.js 20 or newer with npm.
- PostgreSQL 16 (local or `docker compose up -d db` from the backend repository).
- Optional: MinIO (`docker compose up -d minio`, API `:9000`, console `:9001`, `admin` / `password123`). Without it, use `STORAGE_TYPE=local`.

Backend

The demo instance used for this guide was started like this (from the backend repository, after `./mvnw -DskipTests package`):

```
export DB_NAME=grc360 SPRING_DATASOURCE_PASSWORD=postgres
export STORAGE_TYPE=local STORAGE_LOCAL_ROOT=/tmp/grc-uploads
java -jar target/grc360-0.0.1-SNAPSHOT.jar --spring.profiles.active=dev --grc.seed.dummy-data=true
```

Equivalent during development: `./mvnw spring-boot:run -Dspring-boot.run.profiles=dev` (Windows: `.\mvnw.cmd spring-boot:run`). With the `dev` profile, a fresh database receives the tenant `550e8400-e29b-41d4-a716-446655440000` and the demo accounts (`alex.meian@company.com` / `password123` and others; see Installation). The API is on `http://localhost:8080/api/v1`, Swagger UI on `http://localhost:8080/swagger-ui.html`.

Notes:

- Without a profile the base `application.properties` applies (same as `dev` minus the seeding and chaos beans).
- `spring.jpa.show-sql=true` in the base file prints every SQL statement.
- The schema is created by Hibernate on first start (`ddl-auto=update`); there is no migration step to run.
- `/actuator/health` will report DOWN without a local LDAP server and SMTP host; this does not affect the application (see Operations).
- For LDAP work: `docker compose -f docker/local-ldap/docker-compose.yml up -d` starts an OpenLDAP with test people on `ldap://localhost:13389`.
- `clear-ports.bat` (Windows) frees ports 8080, 5432, 6379, 9000, 9001.

Frontend

```
npm install
BACKEND_API_URL=http://localhost:8080/api/v1 \
NEXT_PUBLIC_TENANT_ID=550e8400-e29b-41d4-a716-446655440000 \
npm run dev            # http://localhost:3000 ; the demo uses: npx next dev -p 3200
```

There is no `.env.example`; put the variables in `.env.local` or the shell. `BACKEND_API_URL` must end in `/api/v1`. `NEXT_PUBLIC_TENANT_ID` is only needed so a fresh browser can sign in (see Installation). Production build: `npm run build` then `npm start`.

Demo data for screenshots

`doc/guide/tools/seed_demo.py` fills a tenant with linked, fictional records through the API (idempotent by name). `doc/guide/tools/screens.cjs` captures the screenshots, `convert.py` converts them to WebP under `doc/guide/images`, and `check_links.py` verifies every relative link and image in `doc/guide`.

Tests

Backend

Item	Value
Command	`./mvnw test` (the README uses `./mvnw clean test -Dspring.profiles.active=test`)
Test sources	550 files under `src/test/java` (544 named `*Test`), mirroring the main packages (`modules/*`, `shared`, `infrastructure`, `presentation`, `config`, `cache`, `chaos`, `database`, `architecture`)
Spring context tests	23 classes use `@SpringBootTest`; 60 classes use `@ActiveProfiles("test")`. The rest are plain unit tests with mocks.
Test profile	`application-test.properties`: H2 in-memory database in PostgreSQL mode, `ddl-auto=create-drop`, Flyway and Liquibase off, cache off, Redis/OAuth2/WebSocket auto-configuration excluded, rate limiting off (login failure threshold 100000), notification sweep off, `minio.enabled=false`. Tests that need storage use `InMemoryFileStorage`.
Time zone	Surefire runs with `-Duser.timezone=UTC`.
External services	None required. `testcontainers` and `postgresql` test dependencies are declared but no test starts a container.
Architecture tests	ArchUnit: `architecture/OrganizationArchitectureTest`, `architecture/RemovedRegisterSurfacesTest`, `modules/organization/architecture/OrganizationModuleBoundaryTest`. Coverage tests keep the permission catalogue, visibility wiring and the frontend mirror in step (`PermissionCatalogTest`, `CatalogueCoverageTest`, `RegisterVisibilityWiringTest`, `RecordTypeCoverageTest`, `PageRecordParentsCoverageTest`).

Frontend

Item	Value
Command	`npm test` (`vitest run`); watch mode `npm run test:watch`

Item	Value
Test files	87: co-located `*.test.ts(x)` under `src/` and 13 under `tests/` (`unit/` , `integration/` including `bff-proxy.test.ts` and `auth-session.test.ts` , `contract/openapi-contract.test.ts` , `chaos/resilience.test.ts` , `e2e/workflow-navigation.test.tsx` , QA stage suites)
Environment	jsdom with document URL `http://localhost:3000` (required because `apiClient` uses relative URLs); MSW for API mocks (`src/test/msw`); explicit imports from `vitest` (no globals)
Browser end-to-end tests	None in the repository; `tests/e2e` runs in jsdom.

Lint, type check and formatting

Repository	Command	Tool
Frontend	`npm run lint`	ESLint 9 flat config: `eslint-config-next/core-web-vitals` and `eslint-config-next/typescript`
Frontend	`npm run typecheck`	`tsc --noEmit` with `strict: true` (also type-checks `vitest.config.mts`)
Frontend	(no script) `npx prettier --check .`	Prettier 3 with `prettier-plugin-tailwindcss` , settings in `.prettierrc`
Frontend docs	(no script)	`.markdownlint.json` , `.markdownlintignore`
Backend	`./mvnw compile`	No Checkstyle, SpotBugs or formatter plugin is configured in `pom.xml` .

Coding rules

Source	Content
`.rules` submodule (`https://github.com/Az-Intellect/.rules.git` , declared in the frontend's `.gitmodules`)	Shared organisation rules. `AI-README.md` (both repositories) makes `.rules/00-INDEX.md` mandatory reading and points to `.rules/prompt/` , `.rules/paths.yaml` and the policy files in `.rules/*.md` ; `07-kod-prinsipleri.md` cites `Architecture-Policy.md` . The submodule is not initialised in this checkout (empty directory); run `git submodule update --init` to fetch it. The backend repository has no `.gitmodules` .
`doc/plan/07-kod-prinsipleri.md` (both repositories; Azerbaijani)	SOLID, DRY, KISS, YAGNI, separation of concerns, fail fast (for example a missing `BACKEND_API_URL` must fail loudly), zero-trust frontend (every permission is checked by the backend). Architecture: modular monolith with a BFF proxy, `useServerTable` and `apiClient.ts` as single sources of truth. TypeScript strict, no `any` ; every data component handles five states (loading, content, empty, error, disabled); controlled form components; functions up to about 50 lines, files up to 300-400 lines, nesting up to 3-4 levels; Next.js 16 async `params` / `searchParams` ; `'use client'` only where interactivity needs it.
`AGENTS.md` (frontend)	Warns that Next.js 16 has breaking changes against older knowledge and asks to read `node_modules/next/dist/docs/` before writing code.

Source	Content
`CONTRIBUTING.md` (frontend; Azerbaijani)	Branch prefixes `feature/`, `fix/`, `refactor/`, `docs/`, `chore/`; Conventional Commits (`feat(risk): ...`); no AI tool signatures in commit messages; before a PR, `npm run typecheck` and `npm run lint` must pass; a PR that adds an endpoint, page or architecture change updates `doc/` and `CHANGELOG.md`; no secrets in git; at least one approving review.
`CONTRIBUTING.md` (backend; Azerbaijani)	Describes a fork-based flow from personal forks into the upstream repository and the `Strativuco/GRC_Backend_Code` develop/main pair.
Permission catalogue	Any new page or tab must be added to both `PermissionCatalog.java` (backend) and `navigation.ts` (frontend); tests on both sides fail otherwise.
Sync resource keys	The frontend's `src/shared/config/syncResources.ts` must use the backend table names; renaming a table silently stops live refresh for it (backend `doc/api/sync.md`). New entities should always declare `@Table(name = ...)`.
Schema changes	With Flyway disabled, a new NOT NULL column on an existing table needs a matching `ALTER TABLE ... ADD COLUMN IF NOT EXISTS ... DEFAULT ...` in `SchemaRepairRunner`, and a removed column needs a drop there; `ddl-auto=update` does neither.

Branching and release flow

Repository	Branch	What happens on push
Frontend	`main`	Production deploy (`ci-cd.yml`)
Backend	`develop`	Staging deploy (`staging.yml`)
Backend	`main`	Nothing automated in the repository

The frontend CONTRIBUTING file describes `main` as protected, with all changes through pull requests. Release notes are kept in `CHANGELOG.md` in each repository; `RAPORT.md` is a running status report.

CI/CD

Workflow	Repository	Trigger	Steps
`ci-cd.yml` "Frontend Deploy"	frontend	push to `main`	SSH into the production host (`appleboy/ssh-action@v1.2.2`, secrets `SERVER_HOST`, `SERVER_USER`, `SERVER_SSH_KEY`) and run `/home/grc-strativu-user/deployment/frontend.sh`
`staging.yml` "Deploy Staging"	backend	push to `develop`	SSH into the staging host (secrets `STAGING_HOST`, `STAGING_USER`, `STAGING_SSH_KEY`) and run `/home/grc-strativu-user/deployment/staging-backend.sh`; concurrent runs cancelled

Workflow	Repository	Trigger	Steps
`staging-clear-data.yml`	backend	manual (`workflow_dispatch`)	`mode=dry` reports, `mode=wipe` (confirm text `DELETE STAGING DATA`) takes a `pg_dump` on the host and runs `db/staging-clear-business-data.sql` in one transaction; optionally clears the upload directory
`staging-ldap.yml`	backend	manual	Starts or stops the test LDAP directory from `docker/local-ldap` on the staging host

No workflow runs tests, lint or type checks, and no workflow builds Docker images. The deploy scripts called on the hosts are not in the repositories. Checks therefore depend on developers running `npm run typecheck` , `npm run lint` , `npm test` and `./mvnw test` before merging.

Appendices

Glossary

Terms a user meets in GRC360 and in this guide, in alphabetical order. Each entry links to the page that explains it in full. UI labels are given as they appear in the English interface; where the permission or API key differs, it is given in brackets.

ERAMBA. GRC360 follows the register model of ERAMBA, an open GRC tool: a risk is treated by controls, policies, projects or exceptions, a control satisfies requirements of compliance packages, and every register keeps its own reviews and audits. Several labels come from ERAMBA, for example *Expired* for an overdue task, *Program Issues*, *Data Asset Flows*, and the action names *Section Index*, *View Reports* and *Manage Import Tool*. Entries taken from ERAMBA are marked (ERAMBA). See What is GRC360.

A · B · C · D · E · F · G · H · I · K · L · M · N · O · P · R · S · T · U · V · W

A

Above Appetite. Risk Dynamic Status flag (red): the residual score is greater than the numerical risk appetite. With the default 5 × 5 scales and an appetite of 50 it cannot appear. See Risk Management.

Access Denied. The panel shown instead of a page when the user has no View access to it. It has no Request Access button. See Permissions and access.

Access level. What a group may do on one page or tab: **No Access**, **View**, **Manage** or **Full Control**. Each level stands for a set of permission codes. See Permission keys.

Access request. A user's request for one permission they lack, sent from a locked button with a justification. An administrator approves it as a personal grant (7, 30, 90 days or permanent) or by adding the permission to one of the user's groups, or rejects it. See Groups.

Access token. The 15-minute sign-in token kept in the browser's memory and sent with every request. See Security.

Achieved automation. What happens when an objective is saved as **Achieved**: linked issues are discarded and resolved, linked controls set to Production, linked third party risks closed and linked business risks mitigated. See Objectives.

Activity Log. The per-record panel holding comments, attachments and the change history (who changed which field from what to what). See Working with registers.

Additional permission (individual grant). One permission given to one user on top of their groups, optionally time-limited. Managed from **Additional Permissions** on Users. See Users.

Admin. The built-in group with every permission, including Settings. It cannot be edited, deleted or renamed and is rewritten from the catalogue at every server start. See Permission keys.

Applicable Third Parties. The field of a third party risk naming the vendors it concerns. A vendor named here reads **Risks Open**. See Third Party Risks.

Appetite threshold. A label, description and colour assigned to a likelihood × impact cell of the risk matrix, shown as a chip on the risk scores. See Risk Management.

Apply to existing. The choice, when a new incident stage is defined, to add it to every incident that is currently open. See Security Incidents.

Assessment, assessment item. An assessment groups one row (assessment item) per requirement of a compliance package; each row holds the Compliance Strategy and the treatment links. Each package has one standing assessment named *Compliance Analysis*. See Compliance Analysis.

Asset. Anything of value to the organisation (application, hardware, infrastructure, data) recorded in the Assets register, with owners, a reviewer and a review schedule. See Assets.

Asset review. A planned review of one asset, on the **Reviews** tab of Assets, usually generated from the asset's Next Review Date. See Assets.

Assigned Records Only. The data visibility choice under which a group's members see only records that name them or their groups, records they created, and records that name nobody, on the nine visibility registers. See Groups.

Assignment Management. The group-wide rights **Can Assign** and **Can Reassign**. See Permissions and access.

Audit (control audit). One check of a control, on the **Audits** tab of Controls, with planned dates, methodology, result and conclusion. See Controls.

Audit Methodology. How a control or objective is audited. On objectives it becomes the Audit Metric of generated audits. See Objectives.

Audit Metric, Audit Success Metric Criteria. What a continuity plan audit measures and the threshold for a pass; the criteria are shared with the plan. See Continuity Plans.

Audit Overdue. Continuity plan Dynamic Status (red) when one of its audits is Overdue. See Statuses.

Audit plan, maintenance plan. The schedule on a control, continuity plan or objective from which individual audits or maintenances are generated on save. See Controls.

Audit Result option. A value of the tenant's list of audit results (default *Failed*, *Passed*, *In review*), edited with **Settings**. On objectives each option has an outcome Pass, Fail or In Progress. See Objectives.

Audit Results (action). The right to record an audit's result and conclusion, separate from editing its schedule. Included in Manage. See Permission keys.

Auto-generated row. An audit, maintenance or review created by a schedule. If its date leaves the schedule while it is still blank, it is withdrawn on the next save. See Controls.

Awareness Role. The users and groups named on a continuity plan task to be made aware of it. Newly named people receive a TASK_ASSIGNED notification. See Continuity Plans.

B

BFF proxy. The web client's server route `/api/v1/...` that forwards every browser request to the backend. See Security.

Built-in group. Admin, **Read Only** and **Third Party**: undeletable, not renamable, marked **Default**. See Permission keys.

Business Risk (`operational_risks`). A risk tied to business units and processes, scored with an inherent and a treatment likelihood × impact pair. See Business Risks.

C

Calculation method. The formula that turns likelihood and impact values into a risk score: Single Matrix - Addition, Single Matrix - Multiplication, Multiple Matrices - Multiplication (plus the seeded Threshold Matrix Method). See Risk Management.

Can Assign, Can Reassign. Rights to name other people in an empty people field (Can Assign) or to change other people already named (Can Reassign), on the nine assignable registers. Without them the picker offers only the user. See Permissions and access.

Chapter. A grouping of requirement items inside a compliance package. Chapter ID, name and description are carried on each item; a chapter is not a separate record. See Compliance Packages.

Classification, classification type. A classification type is a scale used to analyse risks (Likelihood, Impact); a classification is one named level of it with a numeric value (for example *Likely* = 4). See Risk Management.

Clear Data. The Settings page that backs up and then permanently deletes chosen groups of an organisation's data. Admin only. See Clear Data.

Comments & Attachments level. The group-wide choice None, View, Contribute or Manage that decides what members can do in the Activity Log. See Groups.

Command Center. The landing dashboard: task columns, risk heat maps, compliance status per package and overall project progress. See Command Center.

Completion Rate. A project task's progress in 10% steps; 100% means complete. See Projects.

Compliance Analysis (`assessments`). The screen where each requirement of a package is judged and linked to the controls, policies and projects that cover it. Also the name of each package's standing assessment. See Compliance Analysis.

Compliance exception. Approved, time-limited non-compliance with one or more requirement items. See Compliance Exceptions.

Compliance package (`frameworks`). A framework, law or standard (for example ISO/IEC 27001:2022) created or imported by the organisation; GRC360 ships none. See Compliance Packages.

Compliance package item (requirement item). One requirement of a package, identified by an Item ID unique within the package. See Compliance Packages.

Compliance percentage. (Compliant + 0.5 × Partially Compliant) / (rows − Not Applicable) × 100, per package. The Trust Center counts Compliant only. See Compliance Analysis.

Compliance Strategy. The verdict on a requirement: Compliant, Not Applicable or Not Compliant; Under Review (shown `--`) means not judged; Partially Compliant exists on older data. See Statuses.

Connector. Stored configuration of an external identity source (LDAP, OAuth or SAML). Only LDAP is used at sign-in in this release. See Authentication.

Contact. A person or group named on a record, such as Risk GRC Contact or Control Operator Contact. Contact fields accept users and groups. See Key concepts.

Continuity plan (`continuity_recovery`). A business continuity or recovery plan with Owner, Sponsor and Launch Initiator, audits (tests) and tasks. See Continuity Plans.

Control (internal control). A safeguard the organisation operates, which treats risks or implements a policy. It has audits, issues and maintenances. See Controls.

Control Last Audit Expired. Warning shown on risks and on Compliance Analysis rows when a linked control has an audit whose planned start has passed and which is not finished. See Statuses.

Control Operator Contact. The person or group who runs a control day to day. See Controls.

Coverage. A scope element of the GRC programme: a region, business unit, process or IT system. See Coverage.

Coverage type. Region, Business Unit, Process or IT System. Stored by the backend, not shown in the UI. See Coverage.

Custom (level chip). Shown in the Groups dialog when a unit's stored permissions match no access level, for example the Third Party group's read and edit without create. See Groups.

D

Data asset. An asset whose Type is *Data Asset*. Data assets appear on the Data Flows page with their GDPR analysis. See Data Flows.

Data flow (data movement) (`data_movement`). One stage in the life of a data asset's data (Collected, Stored, Modified, Transit, Deleted), with its GDPR answers. The tab is called **Data Asset Flows** (ERAMBA). See Data Flows.

Data visibility. The group-wide choice of which records of the nine visibility registers members see: All Records, Assigned Records Only, or (on older groups) Their department. See Groups.

Default Threshold. The appetite threshold used for matrix cells that have none of their own. See Risk Management.

Demo dialog (CSV). The import dialog opened on registers without a working import. Its validation always fails. See CSV import and export.

Department. An organisational unit. Users, assets, data flows and business risks can be linked to departments. See Departments.

Department Contact. The people named for a department. See Departments.

Dynamic Status. A status the system computes every time a record is read, from its dates and linked records; it changes by itself as time passes. Opposite of Status. See Statuses.

E

Event filter. Comma-separated prefixes of event names that a webhook receives. See Integrations & Automation.

Evidence. A file attached to an audit, maintenance, continuity audit, policy, policy review or objective audit, kept in object storage. See Controls.

Evidence attachment (finding). A file of up to 10 MB attached to an external audit finding. See External Audit Findings.

Exception Active. Stored risk status when the risk's treatment lists a risk exception. See Statuses.

Exception Expired. Risk Dynamic Status flag: a risk exception in the treatment has passed its expiration date and is not closed. See Risk Management.

Expired (ERAMBA). Dynamic Status for a date that has passed: an asset or policy review date, a service agreement end date, an exception's expiration date, a project deadline, or (for tasks) a task deadline. See Statuses.

Expiry warnings. The amber markers in the Dynamic Status column of Compliance Analysis: Control Last Audit Expired and Asset / Third Party / Business Risk Review Expired. See Compliance Analysis.

External audit finding (`audit_findings`). An issue raised by an external auditor, linked to the requirement items it affects, with owners, due date and evidence. See External Audit Findings.

External contact. A member of a group set as a vendor's Vendor Role; confined to that vendor's records. See Vendors.

F

Full Control. The highest access level: Manage plus delete, Manage Section Settings and Manage Access Control where the unit has them. See Permission keys.

G

Generated review. An asset, policy or risk review created automatically from the record's Next Review Date (that date and the same day a year later). See Assets.

Global search. The search box in the top bar, which finds records across registers and opens the register list. See Navigation and layout.

Goal Owner Contact. The business owner of an objective. See Objectives.

GRC Contact. The person or group responsible for a record on the governance, risk and compliance side. See Key concepts.

Group (`roles`). A set of permissions that users are members of, with a comments level, assignment rights and data visibility. Called "role" in permission codes. See Groups.

H

Heat map (risk matrix). The Command Center's 5 × 5 grid of impact by likelihood counting risks by their analysis levels. See Command Center.

I

Import CSV. The button on registers that loads records from a file. It works on eleven registers only. See CSV import and export.

Incident, Possible Incident, Event. The three types of security incident. See Security Incidents.

Inherent Risk Score. The score before treatment, from likelihood × impact (or the matrix cell score, or a manual override). See Risk Management.

Issue (control). A problem found on a control, on the **Issues** tab of Controls, with an end date. See Controls.

Issue (governance). A governance issue with a source, contacts and a visible lifecycle status, linkable to objectives as Program Issues. See Issues.

Issue Contact. The business-side person responsible for resolving a governance issue. See Issues.

Issue Source. Where a governance issue came from: Internal or External. See Issues.

K

Kept accounts. Sign-in accounts that survive a “Users, groups and structure” reset in Clear Data. See Clear Data.

L

Launch Initiator. The person or group who may launch a continuity plan or declare it needed. See Continuity Plans.

Lifecycle status (risk). Open, Under Review, Treatment Planned, Treatment In Progress, Accepted, Closed, Archived. API only; shown in the linked-risk panel. See Risk Management.

Likelihood, Impact. The two default classification types used to analyse a risk, each with five levels. See Key concepts.

Linked-records panel. The panel opened by clicking a count in a grid (for example the Asset Risks count of an asset), listing the linked records. See Working with registers.

Live compliance posture. The Trust Center section with compliant-item counts per package and the number of published policies, shown when an administrator enables it in About System. See Trust Center.

M

Main authentication method. The organisation setting choosing Local, OAuth, SAML or LDAP and a connector. See Authentication.

Maintenance. A planned upkeep task of a control, on the **Maintenances** tab, with task result and conclusion. See Controls.

Manage. The access level giving View plus create, edit, import and recording audit and maintenance results. See Permission keys.

Manage Access Control (`manage-access`). The right, on Groups, to change groups’ access, give individual grants and decide access requests. Part of Full Control. See Permission keys.

Manage Import Tool (ERAMBA). The label of the `import` action. See Permission keys.

Manage Section Settings (`manage-settings`). The right to change the risk calculation settings. Part of Full Control on a risk register. See Permission keys.

Manual score override. A value that replaces a risk’s calculated inherent score. Only settable through the API, and cleared when the risk is saved from the form. See Risk Management.

Module. A top-level sidebar entry grouping registers, for example Risk Management. See Key concepts.

N

Needs Review. Dynamic Status of a policy whose Next Review Date has passed, or of an obligation whose Next Audit Date has passed. See Statuses.

No Treatment. Risk Dynamic Status flag: the risk’s Risk Treatment is empty. See Risk Management.

Not applicable (waiver). A switch on a data asset or data flow recording that a GDPR role or answer does not apply. See Data Flows.

Notification. A message in the bell menu and on the Notifications page. In this release only access requests and decisions, continuity task awareness and service agreement expiry produce notifications. See Notifications and scheduled jobs.

Notification sweep. The daily (08:00 server time) and first-read-of-the-day check that raises time-based notifications, today only for service agreement expiry. See Notifications and scheduled jobs.

Numerical appetite. The single number a risk’s residual score is compared with for Above Appetite (50 in a new organisation). See Risk Management.

O

Objective (goal). A goal of the GRC programme with status, contacts, an audit schedule and linked issues, projects, controls, risks and policies. See Objectives.

Objective audit. One audit of an objective, on the **Audit** tab, generated by the schedule or added by hand. See Objectives.

Obligation. A legal or regulatory duty (law and article or clause) with authority, responsible team, compliance status, risk level and next audit date. See Obligations.

Occurrence type. How the dates of an audit or maintenance plan are laid out: Specific (chosen dates, each repeated a year later) or Periodical (a first date and a frequency, for one year). See Controls.

Overall Progress. The Command Center panel with average project progress and counts of Completed, Delayed and On going projects. See Command Center.

P

Page (submodule), section, permission unit. A page of a module, or a tab of a page with permissions of its own; each is a separate unit that gets an access level. See Permission keys.

Permission catalogue. The fixed list of permission units and their actions, defined on the server and mirrored by the sidebar. See Permission keys.

Permission code. One permission, written `<module>_<page>_<action>`, for example `risk_management_asset_risks_read`. See Permission keys.

Policy, standard. A governing document with version, document type, publication and review dates, stored in Policies & Standards. See Policies & Standards.

Policy exception (`exceptions`). Approved, time-limited permission to deviate from one or more policies. See Policy Exceptions.

Policy review. A planned review of one policy on the **Reviews** tab of Policies & Standards. See Policies & Standards.

Program Issues (ERAMBA). The governance issues linked to an objective. See Objectives.

Project, project task, project expense. A project groups the tasks (with order, owner, deadline and completion rate) and expenses of an improvement effort; risks can name projects as treatment. See Projects.

R

Read Only. Built-in group with read access to every page and tab except Settings. See Permission keys.

Record, register. A register is a list of records of one kind, shown as one page (for example Asset Risks); a record is one row. See Key concepts.

Refresh cookie. The HttpOnly cookie used to obtain new access tokens without signing in again. See Security.

Remembered session. A session opened with **Keep me signed in**. See Signing in.

Request Access. The dialog opened by a locked button or tab, in which the user explains why they need the right; administrators are notified. See Permissions and access.

Residual Percentage Coefficient. The percentage (0 to 100 in steps of 10) of an asset or third party risk's inherent score that remains after treatment. See Risk Management.

Residual Risk Score. The score after treatment: inherent score × coefficient / 100 (asset and third party risks), or the score of the treatment likelihood × impact pair (business risks). See Risk Management.

Review Due. Stored risk status when the Next Review Date is today or earlier. See Statuses.

Review Expired. Risk Dynamic Status flag: a review of the risk is past its planned date without an actual date. See Risk Management.

Risk. An uncertain event that could harm the organisation, kept in one of three registers: Asset Risks, Third Party Risks or Business Risks. See Risk Management.

Risk appetite. The level of risk the organisation accepts, set in the risk settings as thresholds per matrix cell and a numerical limit. See Risk Management.

Risk exception. A time-limited acceptance of one or more risks, linked to them through their treatment. See Risk Exceptions.

Risk review. A planned check of one risk with planned and actual dates, on the **Reviews** tab of each risk register; generated from the Next Review Date. See Risk Management.

Risk Treatment. What is done about a risk (Mitigate, Accept, Transfer, Avoid), with the controls, policies, projects and exceptions that carry it out. See Key concepts.

Risks Open. Vendor Dynamic Status (red) when a third party risk names the vendor. See Vendors.

S

Section Index, View Reports, Create New Item, Edit Accessible Items, Delete Accessible Items (ERAMBA). The labels of the actions read, export, create, edit and delete in the Groups and Request Access dialogs. See Permission keys.

Service agreement. A contract with one vendor, with validity window, value and contacts; it raises expiry notifications. See Service Agreements.

Session. One sign-in on one device. It ends by sign-out, idle timeout, revocation, the session limit or deactivation of the user. See Sessions and security.

Settings. The admin-only module (Authentication, About System, System Health, Updates, System Log, Clear Data). It cannot be given to any other group. See Settings.

Stage (data flow). The step of a data flow: Collected, Stored, Modified, Transit or Deleted. See Data Flows.

Stage (incident stage), stage row. A handling step every incident goes through (for example Detection, Containment), defined in Settings; a stage row is one stage of one incident with status Completed or Incomplete. See Security Incidents.

Status. The value a person chooses in the Add or Edit form and that is stored with the record. Opposite of Dynamic Status. See Statuses.

Stored risk status. The single dynamic status each risk stores when saved (On Track, Review Due, Above Appetite, Exception Active, Closed), used by Compliance Analysis and the Command Center. See Risk Management.

Super admin. A break-glass account listed in the server setting SUPER_ADMIN_EMAILS that bypasses the permission catalogue. See Security.

Support Contract Supplier. The vendor a service agreement is with. See Service Agreements.

Sync feed (live refresh). The background check, every 10 to 12 seconds, that refreshes open pages when another user or tab changes data. See Integrations & Automation.

System Log. The tenant's log of administrative and Compliance Hub actions, under Settings. See System Log.

T

Task Expired. Project Dynamic Status (red) when the project is within its deadline but at least one unfinished task is past its own deadline. See Projects.

Tenant. One customer organisation. Every record belongs to exactly one tenant; tenants never see each other's data. See Key concepts.

Third Party (group). Built-in group for external contacts: read and edit on Vendors, Service Agreements, Third Party Risks and Compliance Analysis, limited to their own records. See Permission keys.

Third Party Risk. A risk arising from a vendor or from assets shared with one. See Third Party Risks.

Trust Center. A page describing the organisation's security posture, optionally with the live compliance posture. Open to every signed-in user. See Trust Center.

U

Upcoming. Dynamic Status (amber) of an asset, review or service agreement whose date has not yet arrived. See Statuses.

V

Vendor. A third party (supplier, customer, regulator) in the Vendors register. See Vendors.

Vendor Role. A group that confines its members to one vendor's records. No longer editable in this release. See Vendors.

View. The access level giving read and export. See Permission keys.

Visibility registers. The nine registers narrowed by data visibility and covered by Can Assign / Can Reassign: Assets, Asset Risks, Third Party Risks, Business Risks, Controls, Policies & Standards, Vendors, Service Agreements, Objectives. See Groups.

W

Webhook. An HTTP address that receives a signed JSON message for each System Log event, configured on Integrations & Automation. See Integrations & Automation.

Permission keys

This appendix lists every permission unit in GRC360: each page and each tab that carries its own permissions, with the keys the system uses for it, its address, and the actions that exist there. It also shows how the four access levels of the Groups dialog translate into those actions, and what the built-in groups hold.

For how permissions look from a user's side (locked buttons, Request Access, Access Denied), see Permissions and access. For how an administrator sets them, see Groups and Users, groups and permissions.

How permissions are structured

Module, page, section

Permissions are arranged in three levels that follow the sidebar:

Level	What it is	Example key
Module	One top-level sidebar entry	`risk_management`
Page (submodule)	One page of the module	`asset_risks`
Section (tab)	A tab of a page that has permissions of its own. Its key is the page key followed by the tab name.	`asset_risks_reviews`

A page and each of its sections are separate **permission units**: a group can, for example, have Manage on **Controls** and only View on **Controls › Audits**.

Permission codes

Every permission is one code built from the three parts:

`<module>_<page or section>_<action>`, lower case, with hyphens replaced by underscores.

Unit	Action	Code
Risk Management › Asset Risks	read	`risk_management_asset_risks_read`
Control Center › Controls › Audits	audit-results	`control_center_controls_audits_audit_results`
Organization Hub › Groups	manage-access	`organization_roles_manage_access`
Settings › Clear Data	execute	`settings_clear_data_execute`

The same codes appear in individual grants (Additional Permissions on a user) and in access requests. The catalogue is defined once on the server (`PermissionCatalog.java`) and mirrored by the sidebar configuration of the web client (`navigation.ts`); both build codes the same way.

Several keys keep an older name although the page label changed. The key, not the label, is what the codes are built from:

Label in the sidebar	Key	Route
Groups	`roles`	`/organization/roles`
Data Flows	`data_movement`	`/asset-management/data-movement`
Policy Exceptions	`exceptions`	`/control-center/exceptions`
Continuity Plans	`continuity_recovery`	`/control-center/continuity-recovery`
Business Risks	`operational_risks`	`/risk-management/operational-risks`
Compliance Packages	`frameworks`	`/compliance-hub/frameworks`
Compliance Analysis	`assessments`	`/compliance-hub/assessments`

Label in the sidebar	Key	Route
External Audit Findings	`audit_findings`	`/compliance-hub/audit-findings`

Actions

Not every unit has every action. A unit only has the actions that some screen or endpoint actually uses.

Action	Label in the Groups and Request Access dialogs	What it allows
`read`	Section Index	Open the page or tab and list its records
`create`	Create New Item	Add records
`edit`	Edit Accessible Items	Change records the user can see
`delete`	Delete Accessible Items	Delete records the user can see
`import`	Manage Import Tool	Use **Import CSV**
`export`	View Reports	Use **Export CSV**
`audit-results`	Audit Results	Record an audit's result and conclusion (separately from editing its schedule)
`maintenance-results`	Maintenance Results	Record a maintenance's result and conclusion
`manage-settings`	Manage Section Settings	Change the risk calculation settings (the gear on the risk registers)
`manage-access`	Manage Access Control	Change groups' access, give individual grants, decide access requests
`assign`	Can Assign	Name other people in a people field that named nobody else
`reassign`	Can Reassign	Change or remove other people already named in a people field
`view-comments`	View List of Comments and Attachments	Read the Activity Log thread
`create-comments`	Create Comments and Attachments	Add comments and attachments
`delete-comments`	Delete Comments and Attachments	Delete other people's comments and attachments
`execute`	Execute Reset	Run Settings › Clear Data

Implied read. Any action on a unit brings that unit's `read`, and any action on a section also brings its page's `read`. The Groups dialog, the server and the seeding of built-in groups all apply this rule.

Unit types

The catalogue builds each unit from one of a few patterns. The tables below name the pattern for each unit.

Pattern	Actions
Register	read, create, edit, delete, import, export, view-comments, create-comments, delete-comments (plus any extras listed)
Form	read, create, edit, delete, view-comments, create-comments, delete-comments
Section (tab)	read, create, edit, delete, view-comments, create-comments, delete-comments (plus any extras listed)
Register section (tab that is itself a register)	As **Register**
Plain	Only the actions listed, no comments

Access levels and the actions they grant

In the Groups dialog each unit gets one access level. The level is a shorthand: what is stored is the set of action codes.

Level	Grants on the unit	Codes
No Access	Nothing. The page disappears from the sidebar; opening its address shows **Access Denied**. A tab shows a lock.	none
View	Read and export	`read` , `export`
Manage	View, plus create, edit, import and recording results	View + `create` , `edit` , `import` , `audit-results` , `maintenance-results`
Full Control	Manage, plus delete and the unit's administrative rights	Manage + `delete` , `manage-settings` , `manage-access` , and any action the dialog does not otherwise map (for example `execute`)

Rules applied by the dialog and the server:

- A level grants only the codes the unit has. A level that would grant nothing more than the level below is not offered. The dashboard therefore offers **No Access** and **View** only.
- Setting a tab above No Access raises its page to at least View. Setting a page to No Access sets all its tabs to No Access.
- A unit whose stored codes match no level (for example read and edit without create) shows **Custom**.

Three choices apply to the whole group rather than per unit:

Group-wide choice	Values	Codes on every unit the group can open (View or higher) that has comments
Comments & Attachments	None / View / Contribute / Manage	none / `view-comments` / + `create-comments` / + `delete-comments`
Assignment Management	**Can Assign**, **Can Reassign** (two checkboxes)	`assign` , `reassign` , only on the nine assignable registers where the group has Manage or Full Control
Data visibility	All Records / Assigned Records Only (Their department only on groups that already use it)	Not a code; stored on the group

The nine assignable registers, which are also the nine registers narrowed by data visibility, are: Assets, Asset Risks, Third Party Risks, Business Risks, Controls, Policies & Standards, Vendors, Service Agreements and Objectives.

A user's rights are the union of all their groups plus their active individual grants. There is no deny.

Units per module

In the tables, **Levels** lists the levels the Groups dialog offers for the unit. "Comments" means the three comment actions.

Command Center

Module key `command_center` . See Command Center.

Page / tab	Route	Key	Pattern	Actions	Levels
Command Center (dashboard)	`/command-center`	`dashboard`	Plain	read	No Access, View

Seeing every task in the task columns is decided by the system role ADMIN in the sign-in token, not by this permission.

Governance Hub

Module key `governance` . See Governance Hub.

Page / tab	Route	Key	Pattern	Actions	Levels
Coverage	`/governance/coverage`	`coverage`	Form	read, create, edit, delete, comments	All four
Issues	`/governance/issues`	`issues`	Form	read, create, edit, delete, comments	All four
Objectives	`/governance/objectives`	`objectives`	Register	Register actions, comments, assign, reassign	All four
Objectives › Audits (tab labelled **Audit** on the page)	same page	`objectives_audits`	Section	read, create, edit, delete, comments, audit-results	All four

Coverage and Issues have no import or export right and no CSV buttons. Objectives has import and export rights, but the Objectives tab shows no CSV buttons.

Organization Hub

Module key `organization`. See Organization Hub.

Page / tab	Route	Key	Pattern	Actions	Levels
Users	`/organization/users`	`users`	Register	Register actions, comments	All four
Departments	`/organization/departments`	`departments`	Register	Register actions, comments	All four
Groups	`/organization/roles`	`roles`	Register	Register actions, comments, manage-access	All four

`organization_roles_manage_access` (Full Control on Groups) also gates the **Additional Permissions** button on Users and the **Access Requests** queue.

Third Parties

Module key `third_parties`. See Third Parties.

Page / tab	Route	Key	Pattern	Actions	Levels
Vendors	`/third-parties/vendors`	`vendors`	Register	Register actions, comments, assign, reassign	All four
Service Agreements	`/third-parties/service-agreements`	`service_agreements`	Register	Register actions, comments, assign, reassign	All four

Asset Management

Module key `asset_management`. See Asset Management.

Page / tab	Route	Key	Pattern	Actions	Levels
Assets	`/asset-management/assets`	`assets`	Register	Register actions, comments, assign, reassign	All four
Assets › Reviews	same page	`assets_reviews`	Section	read, create, edit, delete, comments	All four

Page / tab	Route	Key	Pattern	Actions	Levels
Data Flows	`/asset-management/data-movement`	`data_movement`	Register	Register actions, comments	All four

The **Data Assets** tab of Data Flows has no key of its own: its buttons are judged on `data_movement`, while the server checks `assets` for its writes (see Known issues).

Control Center

Module key `control_center`. See Control Center.

Page / tab	Route	Key	Pattern	Actions	Levels
Controls	`/control-center/controls`	`controls`	Register	Register actions, comments, assign, reassign	All four
Controls › Audits	same page	`controls_audits`	Section	read, create, edit, delete, comments, audit-results	All four
Controls › Issues	same page	`controls_issues`	Section	read, create, edit, delete, comments	All four
Controls › Maintenances	same page	`controls_maintenances`	Section	read, create, edit, delete, comments, maintenance-results	All four
Policies & Standards	`/control-center/policies-standards`	`policies_standards`	Register	Register actions, comments, assign, reassign	All four
Policies & Standards › Reviews	same page	`policies_standards_reviews`	Section	read, create, edit, delete, comments	All four
Policy Exceptions	`/control-center/exceptions`	`exceptions`	Register	Register actions, comments	All four
Continuity Plans	`/control-center/continuity-recovery`	`continuity_recovery`	Register	Register actions, comments	All four
Continuity Plans › Audits	same page	`continuity_recovery_audits`	Section	read, create, edit, delete, comments, audit-results	All four
Continuity Plans › Tasks	same page	`continuity_recovery_tasks`	Section	read, create, edit, delete, comments	All four

Server-side particulars:

- Saving an audit or maintenance is judged by the service: a change of result or conclusion needs `audit-results` / `maintenance-results`, a change of other fields needs `edit`.
- Issue writes, and deletes of audits, maintenances, continuity audits and tasks, are saved as an update of the parent record, so the server checks `edit` on the parent page (Controls or Continuity Plans) in addition to the tab's right shown by the button.
- Evidence uploads and the Settings value lists (`/control/evidence`, `/control/catalog-options`) are checked at module level: the action on any Control Center page satisfies them.

Risk Management

Module key `risk_management`. See Risk Management.

Page / tab	Route	Key	Pattern	Actions	Levels
Asset Risks	`/risk-management/asset-risks`	`asset_risks`	Register	Register actions, comments, manage-settings, assign, reassign	All four
Asset Risks › Reviews	same page	`asset_risks_reviews`	Section	read, create, edit, delete, comments	All four
Third Party Risks	`/risk-management/third-party-risks`	`third_party_risks`	Register	Register actions, comments, manage-settings, assign, reassign	All four
Third Party Risks › Reviews	same page	`third_party_risks_reviews`	Section	read, create, edit, delete, comments	All four
Business Risks	`/risk-management/operational-risks`	`operational_risks`	Register	Register actions, comments, manage-settings, assign, reassign	All four
Business Risks › Reviews	same page	`operational_risks_reviews`	Section	read, create, edit, delete, comments	All four
Risk Exceptions	`/risk-management/risk-exceptions`	`risk_exceptions`	Register	Register actions, comments	All four

The risk settings (calculation methods, appetite, classification types, classifications) are shared by the three registers. Reading them needs `read` on any risk page; saving them needs `manage-settings` (Full Control) on any of the three risk registers. Approving or denying a risk exception exists only in the API and requires the authority `risk.exception.approve` or the system role ADMIN.

Compliance Hub

Module key `compliance_hub`. See Compliance Hub.

Page / tab	Route	Key	Pattern	Actions	Levels
Compliance Packages	`/compliance-hub/frameworks`	`frameworks`	Register	Register actions, comments	All four
Compliance Packages › Items (drill-in page of one package)	same page	`frameworks_items`	Section	read, create, edit, delete, comments, import	All four
Compliance Analysis	`/compliance-hub/assessments`	`assessments`	Register	Register actions, comments	All four
Obligations	`/compliance-hub/obligations`	`obligations`	Register	Register actions, comments	All four
Compliance Exceptions	`/compliance-hub/compliance-exceptions`	`compliance_exceptions`	Register	Register actions, comments	All four
External Audit Findings	`/compliance-hub/audit-findings`	`audit_findings`	Register	Register actions, comments	All four

Importing items into a package needs `import` on `frameworks_items`; exporting them needs `export` on `frameworks` (the Items section has no export right). The **Edit Action** of Compliance Analysis also writes links on risks, findings and exceptions, but is checked only against `assessments` edit.

Operations Center

Module key `operations_center`. See Operations Center.

Page / tab	Route	Key	Pattern	Actions	Levels
Projects	`/operations-center/projects`	`projects`	Register	Register actions, comments	All four
Projects › Tasks	same page	`projects_tasks`	Register section	Register actions, comments	All four
Projects › Expenses	same page	`projects_expenses`	Register section	Register actions, comments	All four
Security Incidents	`/operations-center/incidents`	`incidents`	Register	Register actions, comments	All four
Security Incidents › Stages	same page	`incidents_stages`	Register section	Register actions, comments	All four

Changing a stage row's status is checked by the server against `incidents` edit, while the button uses `incidents_stages` edit. The stage definitions in the Settings dialog are checked by the server against `incidents_stages` and by the buttons against `incidents`.

Settings (Admin only)

Module key `settings`. See Settings.

Page / tab	Route	Key	Pattern	Actions	Levels
Authentication	`/settings/authentication`	`authentication`	Plain	read, create, edit, delete, import, export	Not offered
About System	`/settings/about-system`	`about_system`	Plain	read	Not offered
System Health	`/settings/system-health`	`system_health`	Plain	read	Not offered
Updates	`/settings/updates`	`updates`	Plain	read	Not offered
System Log	`/settings/system-log`	`system_log`	Plain	read, export	Not offered
Clear Data	`/settings/clear-data`	`clear_data`	Plain	read (preview), execute (run the reset)	Not offered

The Admin-only rule. Settings is an admin-only module. Only the group named exactly **Admin** (or its former name **Administrator**), the system role ADMIN and the super-admin account may hold it. A group whose name merely contains "admin" (for example "IT Admins") may not. The Groups dialog does not show Settings for other groups; the server refuses Settings codes in any other group, individual grant or access request, and removes them from every other group at each server start. The Request Access dialog says *"Only the Admin group can access Settings. It cannot be granted to other groups or requested."*

Integrations & Automation

Module key `integrations_automation`. See Integrations & Automation.

Page / tab	Route	Key	Pattern	Actions	Levels
Integrations	`/integrations-automation`	`integrations`	Plain	read, create, edit, delete	All four

The webhook endpoints behind this page additionally require the system role ADMIN or a Settings authority, so in practice only administrators can manage webhooks.

Pages outside the catalogue

These pages have no permission key. Every signed-in user can open them, and they are never hidden or locked: **Trust Center** (`/trust-center`), **Profile** (`/profile`), **Account** (`/account`), **Support** (`/support`) and **Notifications** (`/notifications`).

Built-in groups

Every organisation has three built-in groups. They cannot be deleted or renamed and carry the **Default** badge.

Group	Description	Data visibility	Starting permissions	Can be edited
Admin	*Full access to every module and setting*	All Records	Every code in the catalogue (377 codes in this release), including Settings, Manage Access Control, all comment rights, Can Assign and Can Reassign. Rewritten from the catalogue at every server start.	No
Read Only	*Read-only visibility across every module*	All Records	`read` on every page and tab except Settings (42 codes). No export, no comments, no assignment. Shown as **View**.	Yes
Third Party	*External contact: only their own vendor records and assessments*	Assigned Records Only	`read` and `edit` on Third Parties › Vendors, Third Parties › Service Agreements, Risk Management › Third Party Risks and Compliance Hub › Compliance Analysis (8 codes). Shown as **Custom**. No tabs, no comments.	Yes

- The starting permissions of Read Only and Third Party are written once, when the group is created (or when an existing group of that name is adopted). Later changes made by the organisation survive restarts.
- In organisations that existed before the assignment rights were introduced, every group that could create or edit a register received **Can Assign** on it, and every group that could edit it **Can Reassign**, once. In the demo data the Third Party group therefore holds 14 codes (the 8 above plus assign and reassign on Vendors, Service Agreements and Third Party Risks).
- Groups that were built in in earlier releases (Analyst, Approver, Respondent, Domain manager, Department Manager) are kept as ordinary groups with their members and permissions, and can be edited and deleted.

Related pages

- Permissions and access
- Groups
- Users, groups and permissions
- Known issues

Status and Dynamic Status rules

This appendix lists, for every register and tab, the status values a person can choose and the values the system computes, with the exact rule and colour of each. The module pages explain the same values in context; follow the link under each heading.

Status and Dynamic Status

	Status	Dynamic Status
Who sets it	A person, in the Add or Edit form (on a few registers the system sets it on save)	The system
Stored	Yes	No. Worked out from the record's dates and linked records every time the record is read
Changes when	Someone saves the record	Time passes, or a linked record changes
Sent by the form	Yes	Never

Because Dynamic Status is calculated on read, date-based values such as *Expired*, *Overdue*, *Review Expired* or *Needs Review* appear on the day they become true, without any background job. The scheduled jobs that would change stored statuses (for example the expiry of exceptions) are not active in this release; see Notifications and scheduled jobs.

A column heading always says which of the two it shows. Where a register has both, they are separate columns. Risk registers can show several Dynamic Status flags on one row.

Exception: the stored risk status. Each risk also stores one dynamic status value, calculated when the risk is saved. It is not the register's Dynamic Status column; it is shown only in the linked-risk panel and is used by Compliance Analysis and the Command Center. See Risk registers.

Colours

Every status is shown as a coloured pill. The colour depends only on the value, so the same value has the same colour everywhere.

Colour	Meaning	Values
Green	Done, healthy, compliant	Active, Enabled, Current, Production, Completed, Resolved, Closed, Approved, Compliant, Pass, Passed, Achieved, Mitigated, Published, Recorded, On Track, Low, and others of the same kind
Amber	In progress or needs attention	In Progress, Ongoing, Design, Pending, Under Review, Needs Review, Review Expired, No Treatment, Exception Expired, Control Last Audit Expired, Partially Compliant, Delayed, Upcoming, Expiring, Missing Date, Medium
Red	Failed, overdue or above a limit	Incomplete (incident stage), Expired, Task Expired, Overdue, Fail, Failed, Rejected, Not Compliant, Above Appetite, Audit Overdue, Risks Open, High, Critical
Blue	Open or planned	Open, New, Planned, Scheduled, Assigned, Exception Active
Grey	Inactive, not applicable, or not recognised	Not Applicable, Draft, Inactive, Disabled, Archived, Retired, Discarded, Terminated, Cancelled, Revoked, Denied, Not Started, Missing Amount, and any value the system does not know
`--`	No value	

The value is normalised before it is coloured, so `IN_PROGRESS`, `In Progress` and `in-progress` are the same. `NON_COMPLIANT` is always displayed as **Not Compliant**.

How to read the tables

Each register has one table with the same columns:

- **Value**: as displayed.
- **Kind**: **Status** (chosen or stored) or **Dynamic** (computed on read).
- **Set by**: *User* (offered in the form), *System* (computed or written automatically), *API / import* (stored only by other means; not offered in the form).
- **Rule or meaning**: for Dynamic values the condition; where several rules exist they are checked from top to bottom and the first match wins.
- **Colour**.

“Today” is the server’s date. Where a page says dates are compared in UTC, that is noted.

Governance Hub

Coverage

Coverage. No Dynamic Status column.

Value	Kind	Set by	Rule or meaning	Colour
Draft	Status	User (default)	The scope element is being prepared. The only value that the form actually stores.	Grey
Active, Archived, Superseded	Status	User (offered)	Offered in the drop-down, but the server does not know these values and stores *Draft* instead.	(never stored)
Current, Discarded	Status	API / import	Accepted by the server, not offered in the form. Shown if present.	Green, grey

The server also keeps an internal dynamic status (Active, Pending, Archived). It is not computed, is reset to Active on each save, and is not shown.

Issues

Issues. No Dynamic Status column. An issue holds two statuses; only the first is visible.

Value	Kind	Set by	Rule or meaning	Colour
Draft	Status	User (default)	Recorded, not yet confirmed	Grey
Current	Status	User	Confirmed and being worked on	Green
Discarded	Status	User; System when a linked objective becomes Achieved	No longer relevant	Grey
Open	Workflow state (hidden)	System	Workflow state of every new issue	Not shown
Resolved	Workflow state (hidden)	System	Set with today’s date when a linked objective becomes Achieved	Not shown
In Progress, Closed, Blocked, Deferred	Workflow state (hidden)	API	Other workflow states	Not shown

The hidden workflow state counts for objective progress: an issue is finished when it is Resolved or Closed.

Objectives

Objectives. The goal has no Dynamic Status column.

Value	Kind	Set by	Rule or meaning	Colour
Draft	Status	User (default)	New goal	Grey
Current	Status	User	Being pursued (stored as ACTIVE)	Green
Discarded	Status	User	Dropped (stored as ABANDONED)	Grey
Achieved	Status	User	Met. Saving a goal as Achieved runs the achieved automation (linked issues discarded and resolved, controls to Production, third party risks closed, business risks mitigated).	Green

Objectives › Audits

Value	Kind	Set by	Rule or meaning	Colour
In Progress	Dynamic	System	No Audit Result; or the result option's outcome is In Progress	Amber
Pass	Dynamic	System	The Audit Result names an option whose outcome is Pass (default option *Passed*)	Green
Fail	Dynamic	System	The Audit Result names an option whose outcome is Fail (default option *Failed*)	Red

If the result matches no current option (renamed or deleted), a result containing "fail" reads Fail, one containing "pass" reads Pass, anything else In Progress. Options created on screen always get the outcome In Progress (see Known issues).

Organization Hub

Users

Users. No Dynamic Status.

Value	Kind	Set by	Rule or meaning	Colour
Active	Status	User (default)	Can sign in	Green
Inactive	Status	User	Cannot sign in; the record and references stay	Grey
Inactive (for stored Passive, Suspended, Pending)	Status	API	Displayed as Inactive; saving the user writes Inactive	Grey

Departments

Departments. No Dynamic Status.

Value	Kind	Set by	Rule or meaning	Colour
Active	Status	System (every department)	In use. A department stored as Passive through the API also displays Active.	Green

Groups: access requests

Groups. Groups themselves have no status.

Value	Kind	Set by	Rule or meaning	Colour
Pending	Status	System	Request filed, waiting in the Access Requests queue	Amber
Approved	Status	Administrator	Granted as a personal grant or by adding the permission to a group	Green
Rejected	Status	Administrator	Refused, optionally with a note	Red

Third Parties

Vendors

Vendors. The form has no Status field; the stored status is Active unless loaded otherwise.

Value	Kind	Set by	Rule or meaning	Colour
Inactive	Dynamic	System	1. Stored status is Inactive or Terminated	Grey
Under Review	Dynamic	System	2. Stored status is Under Review	Amber
Risks Open	Dynamic	System	3. At least one non-deleted third party risk names the vendor under Applicable Third Parties, whatever that risk's status	Red
On Track	Dynamic	System	4. Otherwise	Green

Service Agreements

Service Agreements. The form has no Status field; the stored status is Active from creation.

Value	Kind	Set by	Rule or meaning	Colour
Draft	Dynamic	System	1. Stored status is Draft (API only)	Grey
Terminated	Dynamic	System	2. Stored status is Terminated (API only)	Grey
Expired	Dynamic	System	3. End Date is before today	Red
Upcoming	Dynamic	System	4. Start Date is after today	Amber
Expiring	Dynamic	System	5. End Date is today or within the next 30 days	Amber
Active	Dynamic	System	6. Otherwise	Green

Asset Management

Assets

Assets.

Value	Kind	Set by	Rule or meaning	Colour
Active	Status	System	Every asset; there is no field to change it	Green
Missing Date	Dynamic	System	No Next Review Date	Amber
Expired	Dynamic	System	Next Review Date is before today	Red
Upcoming	Dynamic	System	Next Review Date is today or later	Amber

The asset's Dynamic Status does not look at whether reviews were carried out.

Assets › Reviews

Value	Kind	Set by	Rule or meaning	Colour
Planned (default), In Progress, Completed, Expired	Status	User	The reviewer's own statement; does not affect Dynamic Status	Blue, amber, green, red
Completed	Dynamic	System	1. Actual Date is set	Green
Missing Date	Dynamic	System	2. No Actual Date and no Planned Date	Amber
Expired	Dynamic	System	3. No Actual Date and Planned Date before today	Red
Upcoming	Dynamic	System	4. No Actual Date and Planned Date today or later	Amber

Data Flows (Data Assets and Data Asset Flows)

Data Flows. The **Data Assets** tab shows assets, so it uses the asset rules above.

Value	Kind	Set by	Rule or meaning	Colour
Missing Date / Expired / Upcoming	Dynamic (data asset)	System	As for Assets	Amber / red / amber
Active	Status (flow)	System	Every flow; no field to change it	Green

Control Center

Controls

Controls.

Value	Kind	Set by	Rule or meaning	Colour
Design	Status	User (default)	Being designed	Amber
Production	Status	User	Live	Green

Value	Kind	Set by	Rule or meaning	Colour
Not Compliant	Dynamic	System	1. Any audit has Dynamic Status Fail, or any issue has Dynamic Status Overdue	Red
Partially Compliant	Dynamic	System	2. Status is Design, or any issue is Open, or any audit is Overdue, or any maintenance is Overdue	Amber
Compliant	Dynamic	System	3. Otherwise	Green

Controls › Audits

Value	Kind	Set by	Rule or meaning	Colour
Planned (default), In Progress, Completed	Status	System / API	Not on the form: a new audit is Planned and an edit keeps the stored value	Blue, amber, green
Fail	Dynamic	System	Status is Completed and Audit Result is exactly “fail” (any capitalisation)	Red
Pass	Dynamic	System	Status is Completed and any other result (including “Failed”)	Green
Overdue	Dynamic	System	Not Completed, and Planned Start or Audit End Date is before today	Red
In Progress	Dynamic	System	Not Completed, otherwise	Amber

Controls › Issues

Value	Kind	Set by	Rule or meaning	Colour
Open (default), Closed	Status	User		Blue, green
Closed	Dynamic	System	1. Status is Closed	Green
Overdue	Dynamic	System	2. End Date is before today	Red
Open	Dynamic	System	3. Otherwise	Blue

Controls › Maintenances

Value	Kind	Set by	Rule or meaning	Colour
Pending (default), In Progress, Completed	Status	System / API	Not on the form	Amber, amber, green
Completed	Dynamic	System	1. Status is Completed	Green
Overdue	Dynamic	System	2. Planned Start or Maintenance End Date is before today	Red
Active	Dynamic	System	3. Otherwise	Green

Policies & Standards

Policies & Standards.

Value	Kind	Set by	Rule or meaning	Colour
Draft	Status	User (default)	Being written	Grey
Published	Status	User	The version in force	Green
Needs Review	Dynamic	System	Next Review Date is before today	Amber
Current	Dynamic	System	Otherwise, including when no Next Review Date is set	Green

The server also defines Expired for policies, but never produces it.

Policies & Standards › Reviews

Value	Kind	Set by	Rule or meaning	Colour
Planned, Completed	Status	System on save	Completed if Actual Date is set, otherwise Planned (In Progress and Expired only on older rows)	Blue, green
Completed	Dynamic	System	1. Actual Date is set	Green
Missing Date	Dynamic	System	2. No Actual Date and no Planned Date	Amber
Expired	Dynamic	System	3. No Actual Date and Planned Date before today	Red
Upcoming	Dynamic	System	4. No Actual Date and Planned Date today or later	Amber

Policy Exceptions

Policy Exceptions. “Expired” means the Expiration Date is before today.

Value	Kind	Set by	Rule or meaning	Colour
Open (default)	Status	User	In force or awaiting closure. Any stored value other than Closed is displayed and saved as Open.	Blue
Closed	Status	User	Ended; sets the Closure Date	Green
Closed	Dynamic	System	1. A Closure Date is set	Green
Expired	Dynamic	System	2. Status Open and expired	Red
Pending	Dynamic	System	3. Status Open and not expired (every exception created on screen while in force)	Amber
Active	Dynamic	System	4. Status Approved (API or older data only) and not expired	Green

Continuity Plans

Continuity Plans.

Value	Kind	Set by	Rule or meaning	Colour
Design	Status	User (default)	Being written; the audit schedule does not apply	Amber

Value	Kind	Set by	Rule or meaning	Colour
Production	Status	User	Live; the audit schedule applies	Green
Inactive	Dynamic	System	1. Status is Design (or Draft, Archived, Inactive on older or imported records)	Grey
Expired	Dynamic	System	2. The plan's review date (not on the form) is before today	Red
Audit Overdue	Dynamic	System	3. Any of the plan's audits is Overdue	Red
Active	Dynamic	System	4. Otherwise	Green

Continuity Plans › Audits

Value	Kind	Set by	Rule or meaning	Colour
Planned, In Progress, Completed	Status	System on save	Completed if Audit End Date is set, In Progress if only Audit Start Date is set, otherwise Planned	Blue, amber, green
Fail	Dynamic	System	Completed, and Audit Result contains "fail"	Red
Pass	Dynamic	System	Completed, and Audit Result contains "pass"	Green
In Progress	Dynamic	System	Completed with any other result; or not completed and not overdue	Amber
Overdue	Dynamic	System	Not completed, and Planned Date or Audit End Date is before today	Red

Continuity Plans › Tasks

Value	Kind	Set by	Rule or meaning	Colour
Pending (default), In Progress, Completed	Status	System / API	Not on the form, so tasks created on screen stay Pending. No Dynamic Status.	Amber, amber, green

Risk Management

Risk registers (Asset Risks, Third Party Risks, Business Risks)

Risk Management, Asset Risks, Third Party Risks, Business Risks. The forms have no Status field. The Dynamic Status column shows every flag that applies, in this order; with none it shows `--`.

Value	Kind	Set by	Rule or meaning	Colour
Above Appetite	Dynamic flag	System	Residual score (inherent score if there is no residual) is greater than the Numerical appetite. No flag when no appetite number is set. Business Risks use the residual score of the treatment pair.	Red

Value	Kind	Set by	Rule or meaning	Colour
Review Expired	Dynamic flag	System	A review of the risk has a Planned Date before today and no Actual Date	Amber
No Treatment	Dynamic flag	System	Risk Treatment is empty	Amber
Exception Expired	Dynamic flag	System	A risk exception under Treatment: Risk Exceptions has an Expiration Date before today and no Closure Date	Amber
Control Last Audit Expired	Dynamic flag	System	A control under Treatment: Controls has an audit whose Planned Start is before today and which has no Audit End Date	Amber

Stored risk status (set on save; shown only in the linked-risk panel; used by Compliance Analysis and the Command Center):

Value	Kind	Set by	Rule or meaning	Colour
Closed	Stored dynamic	System on save	1. Lifecycle status is Closed	Green
Exception Active	Stored dynamic	System on save	2. Treatment: Risk Exceptions lists at least one exception	Blue
Above Appetite	Stored dynamic	System on save	3. Residual score greater than the Numerical appetite (50 when none is stored)	Red
Review Due	Stored dynamic	System on save	4. Next Review Date is today or earlier	Amber
On Track	Stored dynamic	System on save	5. Otherwise	Green
Open (default), Under Review, Treatment Planned, Treatment In Progress, Accepted, Closed, Archived	Lifecycle status	API	Not on the forms; shown as Status in the linked-risk panel	Blue, amber, grey (unknown), grey, green, green, grey

Risk registers › Reviews

Value	Kind	Set by	Rule or meaning	Colour
Completed	Dynamic	System	1. Actual Date is set	Green
Expired	Dynamic	System	2. Planned Date before today and no Actual Date	Red
Planned	Dynamic	System	3. Otherwise	Blue

Risk Exceptions

Risk Exceptions.

Value	Kind	Set by	Rule or meaning	Colour
Open (default)	Status	User	Being carried	Blue
Closed	Status	User	Over; the Closure Date is stamped	Green

Value	Kind	Set by	Rule or meaning	Colour
Pending, Approved, Denied, Rejected, Revoked, Expired	Status	API	Submit, approve, deny and expiry exist only in the API (the expiry job is not active). The form displays these as Open.	Amber, green, grey, red, grey, red
Closed	Dynamic	System	1. A Closure Date is set	Green
Expired	Dynamic	System	2. Status Open, Pending or Approved and Expiration Date before today; or Status Expired	Red
Active	Dynamic	System	3. Status Approved and not expired	Green
Pending	Dynamic	System	4. Status Open or Pending and not expired	Amber
Closed	Dynamic	System	5. Status Denied, Rejected or Revoked	Green

Compliance Hub

Compliance Packages

Compliance Packages. There is no user-selectable status; the Items drill-in has no status column.

Value	Kind	Set by	Rule or meaning	Colour
Active	Dynamic	System	The package's active flag is on (always for packages created on screen)	Green
Inactive	Dynamic	System	The active flag is off (only through the API)	Grey

Compliance Analysis

Compliance Analysis. The row's **Compliance Strategy** plays the role of a status.

Value	Kind	Set by	Rule or meaning	Colour
`--` (stored Under Review)	Strategy	System default; User (**Choose one…**)	Not judged yet; counted as Review in the summaries	Amber where shown as a badge
Compliant	Strategy	User; System	Requirement met. Set by the system when a linked risk is saved and no linked risk's stored status is Above Appetite.	Green
Not Applicable	Strategy	User	Excluded from the percentage; never changed by risks	Grey
Not Compliant	Strategy	User; System	Requirement not met. Set by the system when a linked risk's stored status is Above Appetite.	Red
Partially Compliant	Strategy	Older data	Counts as half compliant; no longer offered	Amber

Value	Kind	Set by	Rule or meaning	Colour
Control Last Audit Expired	Dynamic marker	System	A linked control has an audit whose Planned Start is before today and whose status is not Completed	Amber ring
Asset / Third Party / Business Risk Review Expired	Dynamic marker	System	A risk of that register that uses a linked control as treatment has a Next Review Date before today	Amber ring

Rows without linked controls show `--` as Dynamic Status. Compliance percentage = (Compliant + 0.5 × Partially Compliant) / (rows − Not Applicable) × 100.

Assessment summaries (second grid on the page):

Value	Kind	Set by	Rule or meaning	Colour
In Progress	Status	System	Every assessment; cannot be changed on screen	Amber
Not Started	Dynamic (computed in the browser)	System	The assessment has no rows	Grey
Completed	Dynamic	System	Compliance percentage is 100 or more	Green
In Progress	Dynamic	System	Otherwise	Amber

Obligations

Obligations. Dates are compared as calendar days in UTC. Status and Dynamic Status are independent.

Value	Kind	Set by	Rule or meaning	Colour
Under Review (default)	Status	User	Not yet assessed	Amber
Compliant	Status	User	Met	Green
Partially Compliant	Status	User	Partly met	Amber
Non Compliant (badge: Not Compliant)	Status	User	Not met	Red
Missing Date	Dynamic	System	No Next Audit Date	Amber
Needs Review	Dynamic	System	Next Audit Date before today	Amber
Current	Dynamic	System	Next Audit Date today or later	Green

Compliance Exceptions

Compliance Exceptions. The expiration date is stored as midnight UTC of the chosen day.

Value	Kind	Set by	Rule or meaning	Colour
Open (default)	Status	User	Being carried	Blue
Closed	Status	User	Finished; sets the Closure Date	Green
Approved, Under Review, Expired	Status	API / import	Not offered in the form; the form displays them as Open but keeps the stored value unless the field is changed	Green, amber, red

Value	Kind	Set by	Rule or meaning	Colour
Closed	Dynamic	System	1. A Closure Date is set, or Status is Closed, Denied, Rejected or Revoked	Green
Expired	Dynamic	System	2. Status is Expired	Red
Active	Dynamic	System	3. Status Approved and the expiration date has not passed	Green
Expired	Dynamic	System	4. Status Approved, Open or Under Review and the expiration date has passed	Red
Pending	Dynamic	System	5. Otherwise, including every Open exception that has not expired	Amber

External Audit Findings

External Audit Findings. Dates are compared as calendar days in UTC.

Value	Kind	Set by	Rule or meaning	Colour
Open (default)	Status	User	Being remediated	Blue
Closed	Status	User	Remediation done	Green
In Progress, Resolved	Status	API / import / older data	Displayed, not offered	Amber, green
Closed / Resolved	Dynamic	System	1. Status is Closed or Resolved (any letter case)	Green
Overdue	Dynamic	System	2. Due date before today	Red
(the Status itself)	Dynamic	System	3. Otherwise	As the Status

Operations Center

Projects

Projects.

Value	Kind	Set by	Rule or meaning	Colour
Planned	Status	User	Not started. Any unknown value sent to the server is stored as Planned.	Blue
Ongoing	Status	User	In progress	Amber
Closed	Status	User	Closed by the owner	Green
Completed	Status	System	Written when every task reaches 100%; also on older rows	Green
Confirmed, Delayed	Status	Older data	Not offered	Grey (unknown), amber
Closed	Dynamic	System	1. Status Closed or Completed, or at least one task and every task at 100%	Green
Expired	Dynamic	System	2. Project deadline before today	Red

Value	Kind	Set by	Rule or meaning	Colour
Task Expired	Dynamic	System	3. At least one task below 100% with a deadline before today	Red
Planned	Dynamic	System	4. The project has no tasks	Blue
Ongoing	Dynamic	System	5. Otherwise	Amber

Projects › Tasks

Tasks have no Status of their own.

Value	Kind	Set by	Rule or meaning	Colour
Completed	Dynamic	System	1. Completion Rate is 100%	Green
Expired (server value DELAYED)	Dynamic	System	2. Deadline before today	Red
Ongoing	Dynamic	System	3. Completion Rate 1 to 99%	Amber
Planned	Dynamic	System	4. Otherwise	Blue

Projects › Expenses

Value	Kind	Set by	Rule or meaning	Colour
Recorded	Dynamic	System	Amount above zero and a date	Green
Missing Date	Dynamic	System	Amount above zero, no date	Amber
Missing Amount	Dynamic	System	No amount, or amount 0	Grey

Security Incidents

Security Incidents.

Value	Kind	Set by	Rule or meaning	Colour
Open	Status	System on create; User	Being handled. Every new or imported incident starts Open.	Blue
Closed	Status	User	Handling finished; allowed only when every stage is Completed	Green
Closed	Dynamic	System	1. Status is Closed	Green
Completed	Dynamic	System	2. Status Open, at least one stage, and every stage Completed (ready to close)	Green
In Progress	Dynamic	System	3. Otherwise, including an open incident with no stages	Amber

Security Incidents › Stages

Value	Kind	Set by	Rule or meaning	Colour
Completed, Incomplete	Status	User	Status of one stage of one incident	Green, red
Completed, Incomplete	Dynamic	System	Follows the Status	Green, red

Other pages

Page	Value	Kind	Set by	Rule or meaning	Colour
Command Center	Critical / High / Medium / Normal	Task urgency	System	From the task deadline	Red / red / amber / grey
Command Center	Completed / In Progress / Not Started	Compliance Status	System	From the package percentage	Green / amber / grey
Command Center	Completed / Delayed / On going	Overall Progress tiles (coloured figures, not pills)	System	Project Dynamic Status Closed; Expired or Task Expired; Ongoing	Green / red / blue
Authentication	Enabled / Disabled (LDAP, default Disabled); Active / Disabled (OAuth, SAML, default Active)	Status	User	Only Enabled or Active connectors can be the main connector	Green / grey
Authentication	In Use	Status	System	Never set in this release; always “false”	Grey
Authentication (sessions)	Active now / Idle for …	Dynamic	System	Active now if used within the last 15 minutes	Green / amber
System Health	UP / WARN / DOWN	Dynamic	System	Result of each live check	Green / amber / red
Integrations & Automation (webhooks)	Enabled / Disabled	Status	User	Whether deliveries are sent	Green / grey
Trust Center	In place / Configurable / Planned / In progress / Live	Fixed text	None	Fixed statements on the page; Live when the posture section is published	As displayed

Related pages

- Key concepts › Status and Dynamic Status
- Notifications and scheduled jobs
- Known issues

Notifications and scheduled jobs

This appendix lists every notification type GRC360 knows, which ones are actually sent in this release, and every background job with its real state.

Notifications that are sent

Type	Sent when	Recipients	Link opens
`ACCESS_REQUEST`	A user sends a Request Access	Every administrator	Organization Hub › Groups, with the Access Requests queue open
`ACCESS_APPROVED`	An administrator approves the request	The requester	No link: the notification is only marked read
`ACCESS_REJECTED`	An administrator rejects the request; the message includes the administrator's note	The requester	No link
`TASK_ASSIGNED`	Someone is newly named in a **Continuity Plan task**'s **Awareness Role**. Groups are expanded to their members. Title: *"You are named in a continuity plan task"*	The people newly named	The task on Control Center › Continuity Plans › Tasks
`SERVICE_AGREEMENT_EXPIRING_WEEK`	A service agreement ends in 7 days (*"Service agreement expires in a week"*)	The agreement's GRC contacts and support-contract contacts, with groups expanded	The agreement on Third Parties › Service Agreements
`SERVICE_AGREEMENT_EXPIRING_SOON`	A service agreement ends in 3 days	As above	As above
`SERVICE_AGREEMENT_EXPIRES_TODAY`	A service agreement ends today	As above	As above

Service agreement notices: conditions.

- They apply only to agreements whose status is **Active** or **Expiring**.
- Each recipient gets each of the three notices at most once per agreement.
- The check runs every day and right after an agreement is saved. See daily sweep.

Being named as an owner or contact. Naming someone as an owner or contact on any other register sends no notification in this release.

Notification types that are not sent

These types exist and appear in the **Type** filter on the Notifications page, but nothing in GRC360 creates them automatically in this release:

Type	Intended for
`OBJECTIVE_AUDIT_DUE`	An objective's audit date has arrived. Implemented in a job that is not active (see below).
`OBJECTIVE_TARGET_OVERDUE`	An objective has passed its target date and is not achieved. Same job.
`RISK_ALERT`, `INCIDENT_ALERT`, `COMPLIANCE_REMINDER`	General alerts. Can only be created through the API.
`INFO`, `WARNING`, `ERROR`	General messages. Can only be created through the API.

Where notifications appear

- **Notification bell.** The ten most recent notifications, with the unread count. See Navigation and layout.
- **Notifications page.** All notifications, with filters by type, read state and date. See Your profile.

- **E-mail.** E-mail delivery is configured under E-mail, webhooks and notifications. In this release, invitations are sent by e-mail; the notifications above appear in the application only. Scheduled e-mail digests are listed as planned on the Integrations & Automation page.

Jobs that run

Job	When	What it does
Daily notification sweep	Every day at 08:00 server time. The schedule is set by `notifications.sweep.cron`; the sweep can be switched off with `notifications.sweep.enabled`.	Runs the service agreement expiry check for every tenant
Sweep on first read	The first time anyone in a tenant opens their notifications on a given day	Runs the same sweep for that tenant, at most once per day, so notices are not delayed when the server was restarted
Session clean-up	At most once an hour, triggered by token refreshes	Removes ended session records

Jobs that are implemented but not active

The backend contains these scheduled jobs, but scheduling is not switched on in this release, so **none of them runs**. They are listed so that nobody relies on them.

Job	Declared schedule	What it would do
Objective alerts	Daily 09:00	Send `OBJECTIVE_AUDIT_DUE` and `OBJECTIVE_TARGET_OVERDUE`
Risk exception expiry	Hourly	Set risk exceptions past their expiration date to Expired
Compliance exception expiry	Hourly	Set compliance exceptions past their expiration date to Expired
Exception request expiry	Daily 00:00	Set approved exception requests past their validity to Expired
Service agreement status	Daily 01:00	Move agreements to Expiring (within 30 days of the end) and Expired (after the end)
Dashboard cache	Hourly	Clear the Command Center cache
Data archiving	Daily 00:00	Count records older than two years (it only logs)

What this means for users

- **Date-based states still show. Dynamic Status** is calculated whenever a record is read, so values such as *Expired*, *Overdue*, *Review Expired* or *Needs Review* appear on time without any job. Only the stored **Status** of exceptions and service agreements does not change by itself.
- **Change the stored status by hand.** Where you want the stored status to change, for example an exception that has ended, edit the record.
- **Objective dates.** Watch them on the Objectives page or in the Command Center. No reminder is sent.

CSV import and export

This appendix gives the real state of **Import CSV** and **Export CSV** on every register and tab in this release, describes how the import dialog behaves, and lists the file format each working import expects, with a minimal example.

Summary

- **Import CSV** appears on almost every register (the shared grid adds it). Eleven imports actually work: Users, Projects, Project Tasks, Project Expenses, Security Incidents, incident stage definitions (Settings dialog), Compliance Package Items, Compliance Analysis strategies, Obligations, Compliance Exceptions and External Audit Findings. Everywhere else the button opens a demonstration dialog that cannot validate a file.
- **Every** Import CSV click, including the working ones, first shows the information message *“CSV Import (): the import structure is not ready yet.”* This message is shown before the real import too and can be ignored there.
- **Export CSV** exists only on Projects, Project Tasks, Project Expenses, Security Incidents, the incident stage definitions, Compliance Package Items, Obligations, Compliance Exceptions, External Audit Findings and the System Log. Exports always contain every record of the register; the grid’s filters and search are not applied.
- Without the **import** right the button is locked and opens Request Access; the same applies to **Export CSV** and the **export** right. See Permission keys.

State per register

Module	Register or tab	Import CSV	Export CSV	Notes
Command Center	Dashboard	Not present	Not present	
Governance Hub	Coverage	Not present	Not present	No CSV right in the catalogue, no backend endpoint
Governance Hub	Issues	Not present	Not present	No CSV right, no endpoint
Governance Hub	Objectives	Not present	Not present	Import and export rights exist in the catalogue but nothing uses them
Governance Hub	Objectives › Audit	Demo dialog (fails)	Not present	
Organization Hub	Users	**Works** (no preview, see below)	Not present	
Organization Hub	Departments	Demo dialog (fails)	Not present	No backend import
Organization Hub	Groups	Demo dialog (fails)	Not present	No backend import
Third Parties	Vendors	Demo dialog (fails)	Not present	No backend import
Third Parties	Service Agreements	Demo dialog (fails)	Not present	No backend import
Asset Management	Assets, Assets › Reviews	Demo dialog (fails)	Not present	No backend import
Asset Management	Data Flows: Data Assets, Data Asset Flows	Demo dialog (fails)	Not present	No backend import
Control Center	Controls, Audits, Issues, Maintenances	Demo dialog (fails)	Not present	Backend has `/control/internal-controls/import-csv`, unused
Control Center	Policies & Standards, Reviews	Demo dialog (fails)	Not present	Backend has `/control/policies-standards/import-csv`, unused
Control Center	Policy Exceptions	Demo dialog (fails)	Not present	Backend has `/control/exceptions/import-csv`, unused

Module	Register or tab	Import CSV	Export CSV	Notes
Control Center	Continuity Plans, Audits, Tasks	Demo dialog (fails)	Not present	Backend has `/control/continuity-plans/import-csv`, unused
Risk Management	Asset Risks, Third Party Risks, Business Risks	Demo dialog (fails)	Not present	Backend has `/risk-management/{asset-risks, third-party-risks, operational-risks}/import-csv` (columns `name` or `title`, `description`) and `/export-csv` (id, name, description, status, dynamicStatus, riskAnalysisScore, riskTreatmentScore), unused
Risk Management	Reviews tabs of the three registers	Demo dialog (fails)	Not present	No backend import
Risk Management	Risk Exceptions	Demo dialog (fails)	Not present	No backend import
Compliance Hub	Compliance Packages (package list)	Demo dialog (fails)	Not present	
Compliance Hub	Compliance Package Items (one package)	**Works**	**Works**	
Compliance Hub	Compliance Analysis (both grids)	**Works** (updates strategies only)	Not present	
Compliance Hub	Obligations	**Works**	**Works**	
Compliance Hub	Compliance Exceptions	**Works**	**Works**	
Compliance Hub	External Audit Findings	**Works**	**Works**	
Operations Center	Projects, Tasks, Expenses	**Works**	**Works**	
Operations Center	Security Incidents	**Works**	**Works**	
Operations Center	Security Incidents › Stages tab	Demo dialog (fails)	Not present	Stage rows cannot be imported
Operations Center	Security Incidents › Settings (stage definitions)	**Works**	**Works**	
Settings	Authentication: LDAP, OAuth, SAML connectors	Demo dialog (fails)	Not present	Backend has `/settings/authentication/{ldap,oauth,saml}-connectors/import-csv` and `/export-csv`, unused
Settings	System Log	Hidden	**Works**	Columns id, action, portal, username, message, createdAt
Other	Notifications, Trust Center, Integrations & Automation	Not present	Not present	

The import dialog

Working imports (all except Users)

1. Click **Import CSV**. The message *“CSV Import (…): the import structure is not ready yet.”* appears, then the dialog **Import CSV -** opens.
2. Click the upload area (*“Click or drag CSV file to upload”*) or drop a file on it. Only files ending in `.csv` are accepted (*“Please select a CSV file”*). A file chosen by clicking must be under 10 MB (*“File size must be less than 10MB”*); a dropped file is not size-checked by the dialog.
3. Click **Validate**. The file is sent to the server as a **dry run**: rows are checked but nothing is saved.
4. The preview shows three counts, **Total Rows**, **Valid** and **Errors**, and under **Validation Errors:** one line per failed row (for example *“Row 3: Name cannot be empty”*).
5. Click **Import *n* rows** (disabled when no row is valid) or **Back** to choose another file.
6. The result shows **Import Complete** with **Total**, **Imported** and **Failed**, and any **Import Errors:**. The register refreshes.

Points to know:

- The dry run does not always check everything the real import checks. Rows that pass **Validate** can still fail on import; their errors then appear under **Import Errors:** and the other rows are imported. Each import notes below what the dry run checks.
- Rows are imported one by one. A failed row does not undo the rows before it.
- If the server cannot be reached or refuses the request, the error is shown in a red box at the top of the dialog.
- The file is read as UTF-8, one record per line. No import accepts a value that contains a line break.

The demo dialog (every other register)

On the registers marked “Demo dialog” above, the same dialog opens, but its address is `/api/v1/import-csv-demo`, which the web client prefixes a second time to `/api/v1/api/v1/import-csv-demo`. No such endpoint exists, so **Validate** always ends with an error in the red box and nothing is imported.

Users

Users does not use the dialog. After the message, a file chooser opens; the chosen file is imported immediately, without a dry run or preview. The page then shows *“Users imported.”* even when some rows were rejected (the server’s per-row report is not displayed), or *“CSV import failed.”* when the whole request fails. Check the list afterwards.

File formats of the working imports

Two ways of reading columns are used:

- **By position** (Compliance Hub imports): the first line is always skipped as a header, whatever it contains, and columns are read in a fixed order.
- **By header name** (Operations Center imports and Users): the first line names the columns, in any order. Unknown columns are ignored.

Users

Endpoint `POST /api/v1/organization/users/import-csv`. Needs Manage on Organization Hub › Users. Columns by header name (letter case ignored; spaces are not converted, so the names must be written exactly as below).

Column	Required	Format and rules
`firstname`	Yes	Text. *“Missing required field: firstName”*
`lastname`	Yes	Text. *“Missing required field: lastName”*
`email`	Yes	E-mail address, also the sign-in name; must be unique. *“Missing required field: email”*
`password`	No	At least 8 characters. If blank, a random 12-character password is set that nobody is told; an administrator must set a password through **Edit** before the person can sign in.

Column	Required	Format and rules
`department`	No	Department name, matched exactly. An unknown name is ignored.
`role`	No	Group name, matched exactly (for example `Read Only`). One group only. An unknown name is ignored.

Every imported user is **Active**. Values are split on every comma with no quote handling, so no value may contain a comma. An empty line counts as a row and fails.

```
firstname,lastname,email,password,department,role
Leyla,Aliyeva,leyla.aliyeva@company.com,ChangeMe2026!,Information Security,Read Only
```

Compliance Package Items

Endpoint `POST /api/v1/compliance/packages/{packageId}/import` (Import CSV on the items page of one package). Needs Manage on Compliance Packages › Items. Export: `GET /api/v1/compliance/packages/{packageId}/export` with the same eight columns, needs View on Compliance Packages. Columns by position; quoted values are supported.

#	Column	Required	Format and rules
1	chapterId	No	Text, for example `5`
2	chapterName	No	Text
3	chapterDescription	No	Text
4	itemNumber	Yes	Must not already exist in the package (letter case ignored)
5	itemName	Yes	Text
6	itemDescription	No	Text
7	itemAdditionalInfo	No	Text
8	category	No	Stored but not shown anywhere in the UI

Errors: *“Row n: Invalid column count. Requires chapterId,chapterName,chapterDescription,itemNumber,itemName”* (fewer than five columns), *“Row n: Item number and name cannot be empty”*, *“Row n: Item number ‘’ already exists in package”*. The dry run makes the same checks against existing items; two rows with the same item number in one file are not detected by the dry run. Imported items get sort order 0, and each one gets a Compliance Analysis row.

```
chapterId,chapterName,chapterDescription,itemNumber,itemName,itemDescription,itemAdditionalInfo,category
5,Organisational,,A.5.15,Access control,"Rules to control physical and logical access shall be
established.",,Annex A
```

Compliance Analysis (strategies)

Endpoint `POST /api/v1/compliance/assessments/import-csv` (dialog **Import CSV - Assessment Strategies**). Needs Manage on Compliance Hub › Compliance Analysis. It changes the Compliance Strategy of existing rows; it never creates rows. There is no export.

#	Column	Required	Format and rules
1	assessmentItemId	Yes	The analysis row’s internal id (UUID). The UI and the exports do not show it; it can only be read from the API.

#	Column	Required	Format and rules
2	strategy	Yes	Stored exactly as written, without checking. Use `COMPLIANT`, `NOT_APPLICABLE`, `NON_COMPLIANT` or `UNDER_REVIEW`; any other text (including lower case) is stored but not counted as any of them.

Values are split on every comma with no quote handling. The dry run checks only that column 1 is a valid UUID; whether the row exists is checked on import (*"Row n: Error processing row - Item not found"*).

```
assessmentItemId,strategy
3f2b8c1e-7a4d-4e1b-9c55-0d6f2a1b9e47,COMPLIANT
```

Obligations

Endpoint `POST /api/v1/compliance/obligations/import-csv`. Needs Manage on Compliance Hub › Obligations. Export `GET .../obligations/export-csv` downloads `obligations.csv` with the same seven columns. Columns by position; quoted values are supported.

#	Column	Required	Format and rules
1	legalActName	Yes	Text
2	articleOrClauseNo	Yes	Text
3	category	Yes	Stored in upper case. To match the drop-down use `KII_SECURITY`, `PERSONAL_DATA`, `CENTRAL_BANK`, `E_SIGNATURE` or `STATE_STANDARDS`; other text is kept as a free category.
4	requirementDescription	No	Text
5	regulatoryAuthority	No	Text
6	status	No	Stored in upper case; default `UNDER_REVIEW`. Use `COMPLIANT`, `PARTIALLY_COMPLIANT`, `UNDER_REVIEW` or `NON_COMPLIANT`. Not checked.
7	riskLevel	No	Stored in upper case; default `MEDIUM`. Use `HIGH`, `MEDIUM` or `LOW`. Not checked.

Errors: *"Row n: Requires legalActName,articleOrClauseNo,category"*, *"Row n: Required fields cannot be empty"*. The dry run makes the same checks. Imported obligations have no responsible contact and no Next Audit Date, so they read *Missing Date*.

```
legalActName,articleOrClauseNo,category,requirementDescription,regulatoryAuthority,status,riskLevel
Law on Personal Data,Article 8,PERSONAL_DATA,Obtain consent before processing personal data,Ministry of Digital Development and Transport,UNDER_REVIEW,HIGH
```

Compliance Exceptions

Endpoint `POST /api/v1/compliance/exceptions/import-csv`. Needs Manage on Compliance Hub › Compliance Exceptions. Export downloads `compliance-exceptions.csv` with the same six columns (the item columns hold the first linked item only). Columns by position; quoted values are supported.

#	Column	Required	Format and rules
1	name	Yes	*"Row n: Name cannot be empty"*
2	description	No	Text
3	status	No	Stored in upper case; default `OPEN`. Not checked. Note that only `APPROVED` reads *Active* in Dynamic Status.
4	expirationDate	Yes	`YYYY-MM-DD` (read as midnight UTC) or an ISO-8601 instant. *"Row n: Expiration date is required"*, *"Row n: Invalid expiration date ''. Use YYYY-MM-DD or an ISO-8601 instant"*
5	requirementItemNumber	No	Stored as text only; does not link the exception to an item
6	requirementItemName	No	Stored as text only

A row needs at least two columns. The dry run makes the same checks. Imported exceptions get today as start date and have no contacts, package or linked items.

```
name,description,status,expirationDate,requirementItemNumber,requirementItemName
Legacy VPN without MFA,Accepted until the VPN replacement goes live,OPEN,2027-03-31,A.8.5,Secure authentication
```

External Audit Findings

Endpoint `POST /api/v1/compliance/audit-findings/import-csv`. Needs Manage on Compliance Hub › External Audit Findings. Export downloads `audit-findings.csv` with the same six columns. Columns by position; quoted values are supported.

#	Column	Required	Format and rules
1	name	Yes	*"Row n: Name cannot be empty"*
2	description	No	Text
3	dueDate	No	`YYYY-MM-DD` or an ISO-8601 instant. *"Row n: Invalid due date ''. Use YYYY-MM-DD or an ISO-8601 instant"*
4	status	No	Stored in upper case; default `OPEN`. Not checked.
5	severity	No	Stored in upper case; default `MEDIUM`. Not shown in the UI.
6	source	No	Stored in upper case; default `EXTERNAL_AUDIT`. Not shown in the UI.

The dry run makes the same checks. Imported findings have no owners, collaborators, linked items or attachments. Because imported statuses are upper case and the demo data uses *Open*, the status filter behaves differently for imported and demo rows (see Known issues).

```
name,description,dueDate,status,severity,source
Incomplete access reviews,Quarterly access reviews missing for two systems,2026-12-15,OPEN,HIGH,EXTERNAL_AUDIT
```

Projects

Endpoint `POST /api/v1/operations/projects/import-csv`. Needs Manage on Operations Center › Projects. Columns by header name: letter case is ignored and spaces count as underscores (`Start Date` = `start_date`). Values are split on every comma with no quote handling.

Column	Required	Format and rules
`name`	Yes	Up to 255 characters. *"[name]: Name is required"*; a second row with the same name in the file fails (*"Duplicate row with project name"*).
`description`	No	Up to 2,000 characters
`grc_contact`	No	Stored as text only (no link to a user)
`project_owners`	No	Stored as text only
`start_date`	No	`YYYY-MM-DD`
`deadline`	No	`YYYY-MM-DD`
`status`	No	`PLANNED`, `ONGOING` or `CLOSED` (the values the form offers; the older `CONFIRMED`, `COMPLETED` and `DELAYED` are also accepted). Letter case is ignored; blank or anything else is stored as Planned.

The dry run checks the name only; date format errors appear on import. Export downloads `projects.csv` (*Tasks, Name, Description, Status, Start Date, Deadline, GRC Contact*); it can be re-imported when no value contains a comma.

```
name,description,grc_contact,project_owners,start_date,deadline,status
Deploy EDR on endpoints,Roll out endpoint detection to all laptops,Sara Johnson,Mike Brown,2026-11-01,2027-02-28,PLANNED
```

Project Tasks

Endpoint `POST /api/v1/operations/tasks/import-csv`. Needs Manage on Projects › Tasks. Columns by header name, as for Projects.

Column	Required	Format and rules
`project_id`	Yes (on import)	The project's internal id (UUID), readable only from the API. Not checked by the dry run.
`task_order`	Yes	Whole number, at least 1, unique within the project. The dry run checks presence and duplicates within the file; a clash with an existing task is reported on import.
`description`	No	Text
`task_owner`	Yes (on import)	Name as text (*"Task owner is required"*)
`deadline`	Yes (on import)	`YYYY-MM-DD` (*"Deadline is required"*)
`completion_rate`	No	Whole number 0 to 100; default 0

Export downloads `project-tasks.csv` (*Dynamic Status, Task Owner, Completion Rate, Deadline, Task Order, Description, Project Name*). It gives the project name, not the id, so it cannot be re-imported as it is.

```
project_id,task_order,description,task_owner,deadline,completion_rate
6b1d2f0a-3c4e-4f5a-8b9c-0d1e2f3a4b5c,1,Select EDR vendor,Mike Brown,2026-11-30,0
```

Project Expenses

Endpoint `POST /api/v1/operations/expenses/import-csv`. Needs Manage on Projects › Expenses. Columns by header name, as for Projects.

Column	Required	Format and rules
`project_id`	Yes (on import)	The project's internal id (UUID). Not checked by the dry run.
`expense_amount` (or `amount`)	No	Number, not negative (checked by the dry run). Without an amount the expense reads *Missing Amount*. No currency.
`description`	No	Text
`expense_date`	Yes (on import)	`YYYY-MM-DD` (*"Expense date is required"*)

Export downloads `project-expenses.csv` (*Status, Expense Amount, Description, Expense Date, Project Name*); it cannot be re-imported as it is (project name instead of id).

```
project_id,expense_amount,description,expense_date
6b1d2f0a-3c4e-4f5a-8b9c-0d1e2f3a4b5c,12500,EDR licences year 1,2026-11-15
```

Security Incidents

Endpoint `POST /api/v1/operations/security-incidents/import-csv`. Needs Manage on Operations Center › Security Incidents. Columns by header name, as for Projects.

Column	Required	Format and rules
`title`	Yes	Up to 255 characters. *"[title]: Title is required"*
`description`	No	Text
`type`	No	`POTENTIAL_INCIDENT`, `CONFIRMED_INCIDENT` or `EVENT` (spaces allowed, letter case ignored). Anything else, or blank, becomes Possible Incident.
`grc_contact`	No	Stored as text only
`status`	No	Ignored: every imported incident is created **Open** with all current stages
`open_date`	No	`YYYY-MM-DD`; a date in the future fails on import
`closure_date`	No	`YYYY-MM-DD`

The dry run checks the title only. Export downloads `security-incidents.csv` (*Dynamic Status, Stages, Title, Description, Open Date, Closure Date, Type, Status*).

```
title,description,type,grc_contact,open_date
Phishing campaign against finance,Credential phishing e-mails reported by three users,CONFIRMED_INCIDENT,Sara Johnson,2026-10-10
```

Incident stage definitions

Endpoint `POST /api/v1/operations/security-incident-stages/import-csv` (Import CSV inside the **Settings** dialog of Security Incidents). The server checks Manage on Security Incidents › Stages. Columns by header name.

Column	Required	Format and rules
`name`	Yes	*"[name]: Name is required"*

Column	Required	Format and rules
`description`	Yes	*"[description]: Description is required"*

The dry run makes both checks. Imported stages are not added to existing incidents; new incidents receive them. Export downloads `incident-stages.csv` (*Stage Name, Description*), which uses different header names and therefore cannot be re-imported as it is.

```
name,description
Lessons learned,Post-incident review and improvement actions
```

Related pages

- Working with registers › Importing from CSV
- Permission keys
- Known issues

Known issues

This list consolidates every known issue and limitation found while documenting this release (October 2026: frontend `main`, backend `develop`). It is written for the product team. Each issue appears once, under the module where the user meets it; issues that affect many pages are under Platform-wide.

Impact levels

Level	Meaning
High	Data loss, a wrong compliance or risk result, or a security weakness
Medium	A feature does not work as labelled or documented
Low	Cosmetic, confusing or minor

Evidence gives the source location. `FE` = `grc_frontend_code/src/`, `BE` = `grc_backend_code/src/main/java/com/strativu/grc360/`, `BE-res` = `grc_backend_code/src/main/resources/`. Items marked *(code reading)* follow from the code and were not reproduced, because the demo instance was used read-only.

High-impact issues at a glance

ID	Module	Issue
PW-08	Platform-wide	Global search shows records of modules the user cannot open
PD-01	Platform and deployment	Any organisation's administrator can list, create and suspend all organisations
PD-02	Platform and deployment	No database-level tenant isolation
PD-03	Platform and deployment	Default secrets are accepted by the Docker profile
PD-04	Platform and deployment	MFA is not enforced at sign-in
PD-07	Platform and deployment	Chaos endpoints open to any signed-in user under the dev profile
PD-08	Platform and deployment	Client-supplied X-Forwarded-For is trusted
GH-01	Governance Hub	Coverage status other than Draft is silently saved as Draft
GH-02	Governance Hub	Editing a coverage resets its type and clears its links
GH-06	Governance Hub	Editing an issue wipes priority, links and due date
GH-07	Governance Hub	Editing an External issue saves it as Internal
GH-11	Governance Hub	Editing an objective removes its target date and owner links
GH-14	Governance Hub	Audit result options can be changed with View access
OH-01	Organization Hub	Choosing a group on a user replaces all of their groups
OH-05	Organization Hub	The per-user REST API access switch is not enforced
AM-01	Asset Management	Deleting an asset silently deletes its reviews and data flows
CT-01	Control Center	Control audits and maintenances can never be completed from the screen

ID	Module	Issue
CT-02	Control Center	An audit result “Failed” is evaluated as a pass
CT-07	Control Center	Evidence and value lists accept a right on any Control Center page
CT-09	Control Center	A policy review’s attached file is not saved
CT-14	Control Center	Saving an Approved policy exception turns it into Open
RM-01	Risk Management	Risk scores are not recalculated when the settings change
RM-02	Risk Management	Above Appetite cannot occur with the default settings
RM-03	Risk Management	The stored risk status is stale and follows different rules from the register
RM-04	Risk Management	Saving a risk from the form clears its manual score override
RM-05	Risk Management	Closing a risk exception leaves the linked risks Exception Active
CH-01	Compliance Hub	Saving a risk marks linked requirements Compliant, including unjudged ones
CH-02	Compliance Hub	Deleted packages, items and assessments remain in Compliance Analysis
CH-03	Compliance Hub	Edit Action changes risks, findings and exceptions without their permissions
CH-04	Compliance Hub	Only the first owner of an analysis row is saved
ST-01	Settings	The System Log does not record who acted

Platform-wide

ID	Issue	What the user experiences	Impact	Evidence
PW-01	Import CSV fails on most registers	On every register without its own import (Assets, Data Flows, Controls, Policies, Policy Exceptions, Continuity Plans, all risk registers and their Reviews tabs, Risk Exceptions, Vendors, Service Agreements, Departments, Groups, Objective Audits, incident Stages, the Compliance Packages list, connector grids) the import dialog opens but **Validate** always fails. The dialog posts to `/api/v1/import-csv-demo`, which the API client prefixes again. Backend imports that exist for controls, policies, policy exceptions, continuity plans, the three risk registers and connectors are not wired. See CSV import and export.	Medium	FE shared/ui/DataTable.tsx:371-376, 829-835; FE shared/api/apiClient.ts:345-347
PW-02	“Not ready yet” message on every import	Every **Import CSV** click, including the working imports, first shows *“CSV Import (…): the import structure is not ready yet.”*	Low	FE shared/ui/DataTable.tsx:371

ID	Issue	What the user experiences	Impact	Evidence
PW-03	Scheduled jobs never run	The seven `@Scheduled` jobs are dormant because scheduling is not enabled: objective alerts, risk exception expiry, compliance exception expiry, exception request expiry, service agreement status, dashboard cache, data archiving. Stored statuses of exceptions and agreements never change by themselves; Dynamic Status still shows the dates. See Notifications and scheduled jobs.	Medium	BE Grc360Application.java:6 (only `@SpringBootApplication`); BE modules/notification/…/NotificationSweepScheduler.java:30-32
PW-04	Notification types that are never produced are offered	The Type filter on Notifications lists RISK_ALERT, INCIDENT_ALERT, COMPLIANCE_REMINDER, INFO, WARNING, ERROR, OBJECTIVE_AUDIT_DUE and OBJECTIVE_TARGET_OVERDUE, which nothing creates. Risk and incident domain-event listeners only write a log line.	Low	FE domain/notifications/NotificationsPage.tsx:22-27; BE modules/notification/service/impl/NotificationServiceImpl.java:39-41
PW-05	No notification when a person is assigned	Naming someone as owner, contact or assignee sends nothing, except on Continuity Plan task Awareness Role, although TASK_ASSIGNED is described as covering assignment fields. No reminders exist for due dates (audits, reviews, obligations, findings, tasks).	Medium	BE modules/notification/listener/ContinuityTaskNotificationListener.java:37-66; BE modules/notification/entity/NotificationType.java
PW-06	No @mentions in comments	The threaded comment UI has no way to notify a colleague.	Low	FE shared/ui/ActivityLog/*
PW-07	Global search opens the list, not the record	Clicking a search result, or **Open register** in a linked-records panel, opens the register list; types and statuses are shown raw (for example “Framework”, `IN_PROGRESS`).	Low	FE shared/ui/SearchResults.tsx:62-66; FE shared/ui/LinkedRecordsModal.tsx:132-146
PW-08	Global search ignores permissions and data visibility	Results for incidents, projects, issues, compliance packages and users are not filtered by page read permission or row visibility, so a user sees names of records in modules they cannot open; clicking leads to Access Denied.	High	BE modules/search/service/GlobalSearchService.java:141-161
PW-09	Frontend treats any group containing “admin” as administrator	A member of a group such as “IT Admins” sees every non-Settings button unlocked and the Account page says “Admin: every module and every setting”, while the server treats only the group named exactly Admin as administrator and refuses the actions.	Medium	FE shared/auth/AuthContext.tsx:243-245; FE domain/account/AccountPage.tsx:64-68
PW-10	Locked and hidden rules are inconsistent	Buttons and tabs are locked with Request Access; sidebar entries and **+ Add** in pickers are hidden; the Access Denied panel offers no Request Access, although the Account page says opening a page “shows a request you can send”.	Low	FE shared/auth/PageAccessGuard.tsx:48-64; FE domain/account/AccountPage.tsx:70-71

ID	Issue	What the user experiences	Impact	Evidence
PW-11	Users without dashboard access land on Access Denied	After sign-in everyone is sent to the Command Center; a user without View on it sees Access Denied and must use the sidebar.	Low	FE app/(public)/login/page.tsx:38-43, 110
PW-12	Session-ended dialog does not return to the page	The dialog says “you will be returned to this page”, but **Go to sign in** opens `/login` without the return address, so the user lands on the Command Center.	Low	FE shared/ui/SessionExpiryModal.tsx:131; FE shared/auth/AuthContext.tsx:331
PW-13	No proactive token refresh in a single tab	A single open tab never schedules a refresh and relies on the refresh-after-401 fallback.	Low	FE shared/auth/AuthContext.tsx:107-114, 176
PW-14	Uneven validation feedback	The “This form cannot be saved yet.” message exists in 17 forms only; Compliance Hub forms, Incidents, Groups, Authentication and Add User only mark fields, so an error outside the visible area looks like Save does nothing.	Low	FE shared/ui/FormLayout.tsx; forms listed
PW-15	No unsaved-changes guard	Clicking outside a dialog or pressing Escape discards a half-filled Add or Edit form without warning.	Medium	FE shared/ui/Modal.tsx:120-133
PW-16	Selection survives paging and filtering	In client-mode grids “1 selected” and bulk delete can act on rows that are no longer visible after paging, filtering or searching.	Medium	FE shared/ui/DataTable.tsx:142, 300
PW-17	Status filter shows raw values and ignores Dynamic Status	The **All items** drop-down lists raw values such as `IN_PROGRESS` and `NON_COMPLIANT` and filters on Status only.	Low	FE shared/ui/DataTable.tsx:186-190, 274, 519-523
PW-18	Client-mode search is shallow	Search matches ids and enum constants; linked names held in nested objects do not match.	Low	FE shared/ui/DataTable.tsx:276-279
PW-19	“… Views” is column visibility, and is not remembered	The button named Views only hides columns; real preset views exist only on Projects and Incidents. Column choice, sidebar collapse and group expansion reset on reload.	Low	FE shared/ui/DataTable.tsx:150, 562-580; FE shared/layouts/AppSidebar.tsx:14-15
PW-20	View item dialog lists hidden columns	The default View dialog includes columns the user hid and empty-label columns (for example the unread dot on Notifications).	Low	FE shared/ui/DataTable.tsx:826
PW-21	Double error on refused bulk delete	A 403 on bulk delete shows the permission dialog and an error inside the delete dialog.	Low	FE shared/ui/DataTable.tsx:333-335

ID	Issue	What the user experiences	Impact	Evidence
PW-22	Edit forms misdisplay stored values that are not in the drop-down	A stored value outside the list is shown as the first option or as **Choose one…**: obligation category, status and risk level; finding status (*Closed*, *In Progress* shown as Open); compliance exception status (*Approved* shown as Open); risk exception status (*Pending*, *Approved* shown as Open); data asset Supervisory Authority outside the EEA list (shown as Austria); control and maintenance results not in the catalogue (for example “PASS”). The stored value is kept unless the field is touched, but a user who saves after looking at the form believes it holds the displayed value. Policy exceptions are worse, see CT-14.	Medium	FE domain/control-center/ControlsPage.tsx:670-685; FE domain/compliance-hub/ComplianceExceptionsPage.tsx:528; FE domain/risk-management/RiskExceptionsPage.tsx:112; screenshots obligations-edit, audit-findings-edit, compliance-exceptions-edit
PW-23	People stored only as ids show as empty, and some forms then refuse to save	Records whose contacts were set by id without a stored name (all demo data and API-created records) show `--` or an empty cell in the grid and View, while Edit shows the people: vendors, service agreements, controls (Control Operator Contact), policies, policy exceptions, objectives (Goal Owner Contact), assets, data assets. Vendors and Service Agreements then fail to save with *“Required”* until the contacts are re-picked.	Medium	FE domain/third-parties/VendorsPage.tsx:186-187; FE domain/third-parties/ServiceAgreementsPage.tsx:158-159
PW-24	Labels of filled fields disappear	On Vendors and Service Agreements Edit, and in relation pickers (Processor Role, flow Departments and Third Parties), the label is a placeholder that vanishes once a value is present.	Low	Screenshots vendors-edit, data-flows-edit
PW-25	Exports ignore filters and search	Every Export CSV writes all records of the register.	Medium	BE modules/compliance/service/impl/ComplianceObligationHubServiceImpl.java (exportObligationsCsv), ComplianceExceptionHubServiceImpl.java (exportExceptionsCsv), ExternalAuditFindingServiceImpl.java (exportFindingsCsv)
PW-26	Import dialog: dropped files are not size-checked	The 10 MB limit is checked only for a file chosen by clicking.	Low	FE shared/ui/CsvImportModal.tsx:36-58
PW-27	Notification display	The Type column and filter show raw constants (for example `SERVICE_AGREEMENT_EXPIRING_WEEK`); access approval and rejection notifications have no link.	Low	FE domain/notifications/NotificationsPage.tsx:117, 132-134; BE modules/notification/listener/AccessRequestNotificationListener.java:54-89
PW-28	Partial translation	In AZ mode server texts (notifications, errors, Activity Log values) stay English, dates follow the browser locale, and the import message is not translated.	Low	FE shared/i18n/*

ID	Issue	What the user experiences	Impact	Evidence
PW-29	Terminology mismatches	Sidebar “Compliance Packages” vs search and quick-add “Framework”; “Groups” vs route `roles`; “Business Risks” vs route `operational-risks`.	Low	FE shared/ui/quickCreate/relationCreate.ts:89; BE modules/search/service/GlobalSearchService.java:159
PW-30	Sidebar details	The sidebar avatar is a button that does nothing; sidebar and top bar use different initials; the fallback e-mail `user@strativu.com` is hard-coded.	Low	FE shared/layouts/AppSidebar.tsx:49, 230; FE shared/layouts/AppTopbar.tsx:355
PW-31	Support e-mail draft encoding	The draft’s subject and body show `+` between words in many mail clients.	Low	FE shared/config/contact.ts:4-7
PW-32	Login form accessibility	The **Keep me signed in** checkbox is hidden from keyboard users and sits below the Sign in button.	Low	FE app/(public)/login/page.tsx:282-287

Platform and deployment

ID	Issue	What the user experiences	Impact	Evidence
PD-01	Tenant management is not tenant-scoped	Any organisation’s administrator can list, create, suspend and activate every organisation through `/api/v1/tenants`.	High	BE presentation/web/tenant/TenantController.java:28-188
PD-02	No database-level tenant isolation	The row-level security migration is not applied (no policies in the database) and the tenant-aware repository is not used; isolation depends entirely on every query filtering by tenant.	High	BE-res db/migration/V13__tenant_rls_policies.sql; BE infrastructure/persistence/repository/TenantAwareRepository.java
PD-03	Default secrets accepted	The Docker profile accepts the shipped JWT secret, database password `123456`, MinIO and Grafana `admin/password123`, because it is not treated as hardened.	High	BE-res application-docker.properties; docker-compose.yml
PD-04	MFA incomplete and not enforced	The MFA setup uses the code as the secret, `/verify` ignores the code, and sign-in never asks for a second factor.	High	BE modules/settings/api/MfaController.java:40-60

ID	Issue	What the user experiences	Impact	Evidence
PD-05	No password reset or self-registration	There is no Forgot password function; the paths exempted for it have no endpoints.	Medium	BE config/TenantContextFilter (exempt paths); FE app/(public)/login/page.tsx
PD-06	Invitations cannot be accepted	Invitations exist only in the API (admin); the e-mailed link `/invite/{token}` has no page and no accept endpoint, although the Integrations page says invitations are e-mailed.	Medium	BE modules/auth/service/impl/AuthServiceImpl.java:541-590
PD-07	Chaos endpoints open under the dev profile	`/api/chaos/*` is available to any signed-in user when the dev profile is active; the demo instance runs it.	High	BE chaos/controller/ChaosController.java:28-29
PD-08	X-Forwarded-For trusted	The first X-Forwarded-For value is used for rate limiting and logged IP addresses; with direct access to port 8080 a client can spoof it and evade login rate limits.	High	BE security/ratelimit/RateLimitFilter.java:97-108; BE modules/auth/api/AuthController.java:83
PD-09	Health check reports DOWN	`/actuator/health` returns 503 on any installation without an LDAP server on localhost:389 and SMTP, because of Spring's auto-configured checks; Docker marks the container unhealthy.	Medium	BE-res application*.properties; Dockerfile and docker-compose.yml healthchecks
PD-10	Schema migrations not used	Flyway is disabled in every profile, the scripts contain duplicate V2 and V3 versions, the schema comes from `ddl-auto=update` plus a repair runner, and About System shows a hard-coded schema version "V18".	Medium	BE-res application.properties:34; BE modules/settings/service/impl/SystemInfoAndHealthServiceImpl.java:59

ID	Issue	What the user experiences	Impact	Evidence
PD-11	docker-compose.yml incomplete	No frontend service; mounted nginx, SSL, Prometheus and Grafana files are not in the repository; Grafana port 3000 clashes with the frontend; access tokens last 24 h in the Docker profile; Redis is required but unused.	Medium	docker-compose.yml; BE-res application-docker.properties
PD-12	Fresh installation has no organisation or user	Outside the dev profile no tenant or user is created and creating one needs an existing administrator; the dummy data seeder writes into a tenant that does not exist; `db/seed-data.sql` does not match the schema.	Medium	BE DevDataInitializer (`@Profile("dev")`); DummyDataSeeder
PD-13	Frontend configuration documentation wrong	No `.env.example` although the README says to copy one; documented defaults are wrong; without a built-in tenant id the login request lacks X-Tenant-Id and fails with a server error (500).	Medium	grc_frontend_code/README.md
PD-14	Caching inactive	Caching is off in every profile, Redis is unused, **Clear Cache** in System Health does nothing and System Health reports “No cache manager configured”.	Low	BE-res application.properties:178; BE CacheConfig
PD-15	Logging gaps	The log pattern omits the correlation and tenant ids, the file appender has no rotation or retention, and the date folder is fixed at start-up.	Medium	BE-res logback-spring.xml

ID	Issue	What the user experiences	Impact	Evidence
PD-16	Metrics cannot be scraped as shipped	`/actuator/prometheus` requires an administrator's 15-minute token and no Prometheus configuration is provided.	Medium	BE config/SecurityConfig.java:93-185
PD-17	State kept in memory per server	Rate limits, login blocks, the live-refresh change tracker and the daily sweep marker live in one JVM; with several instances, limits are per instance and some live refreshes are missed.	Medium	BE doc/api/sync.md:115-117
PD-18	Unused WebSocket endpoints	`/ws` is registered twice with allowed origins `*` and is not used; the Integrations page says live refresh uses a WebSocket, but it is a 10 to 12 s poll.	Low	BE WebSocketConfiguration, WebSocketConfig; FE app/(app)/integrations-automation/page.tsx:78
PD-19	Backups	`scripts/backup.sh` uses a different database password from the compose file, is not scheduled, and does not back up object storage.	Medium	scripts/backup.sh; docker-compose.yml
PD-20	Legacy APIs and duplicate stores	174 of 619 API operations belong to older models the web client does not use (`/risks` , `/incidents` , `/issues` , `/exceptions` , `/evidence` , `/tasks` , `/frameworks` , …). Records created there never appear on screen (for example the second issue store and the older incident store). The `policies` table is mapped by two entity classes.	Low	BE modules/issue/**, modules/incident/**

ID	Issue	What the user experiences	Impact	Evidence
PD-21	Documentation drift	Error-response documentation shows fields the API does not return; a configuration message names `DB_PASSWORD` instead of `SPRING_DATASOURCE_PASSWORD`; static OpenAPI files and diagrams are outdated.	Low	BE doc/api/error-codes.md; BE SecurityValidationConfig
PD-22	CI runs no checks	The CI pipeline runs no tests, lint or type check; deployment scripts exist only on the servers.	Low	CI configuration

Command Center

See Command Center.

ID	Issue	What the user experiences	Impact	Evidence
CC-01	Completed tasks still listed	Tasks at 100% still appear under Expired, Today or Future tasks by their deadline.	Medium	BE modules/commandcenter/service/impl/DashboardServiceImpl.java:286-312
CC-02	Figures ignore permissions, visibility and department	Heat maps, Compliance Status and Overall Progress count every record of the organisation, also for users who cannot open those registers or are limited to their own records; the department scope is computed but not applied.	Medium	BE modules/commandcenter/service/impl/DashboardServiceImpl.java
CC-03	Package “audit date” is not an audit date	The date beside each package is its creation date plus one year.	Medium	BE modules/commandcenter/service/impl/DashboardServiceImpl.java:506-541
CC-04	Compliance percentage differs from Trust Center	The Command Center counts Partially Compliant as half, the Trust Center counts Compliant only, so the same package shows two percentages.	Medium	BE DashboardServiceImpl.java:598-613; BE modules/settings/api/TrustCenterPostureController.java:84-128

ID	Issue	What the user experiences	Impact	Evidence
CC-05	One period for three heat maps	Changing the period of one heat map changes all three.	Low	FE domain/command-center/pages/CommandCenterPage.tsx:306, 413-415
CC-06	Task rows are not links; only project tasks shown	Rows cannot be opened; continuity tasks, maintenances, audits and reviews are not included.	Low	FE domain/command-center/pages/CommandCenterPage.tsx:94
CC-07	Heat-map colours fixed	The colour bands do not follow the organisation's risk appetite settings.	Low	FE domain/command-center/pages/CommandCenterPage.tsx:154
CC-08	Demo tasks have no linked owner	Non-administrators see empty task columns on the demo data.	Low	BE DashboardServiceImpl.java:326-328

Governance Hub

See Coverage, Issues, Objectives.

ID	Issue	What the user experiences	Impact	Evidence
GH-01	Coverage status silently saved as Draft	The form offers Active, Archived and Superseded; the server knows only Current, Draft and Retired (Discarded) and stores Draft without an error.	High	FE domain/governance/CoveragePage.tsx:282; BE modules/governance/dto/CoverageRequest.java:44-60
GH-02	Editing a coverage resets its type and clears links	Each save from the page sets the type to Business Unit and clears the department, owner group and responsible team, which the form does not show.	High	BE modules/governance/dto/CoverageRequest.java (defaults); BE modules/governance/service/impl/CoverageServiceImpl.java
GH-03	Coverage hides load errors	While loading, and when loading fails (for example a permission error), the table says *"No records found."*	Medium	FE domain/governance/CoveragePage.tsx (errorMessage and loading not rendered)
GH-04	Coverage version defaults to 1.0	A blank version is displayed as 1.0 and written back on the next save.	Low	FE domain/governance/CoveragePage.tsx:56
GH-05	Coverage cannot be linked to objectives on screen	The link exists in the API only; coverage type is not shown anywhere.	Medium	BE modules/governance/entity/Objective.java (coverages)

ID	Issue	What the user experiences	Impact	Evidence
GH-06	Editing an issue wipes hidden fields	Each save from the page resets priority to Medium and clears the linked objective, risk, control, policy, owner department, assignee and due date.	High	BE modules/governance/service/impl/IssueServiceImpl.java:108-129
GH-07	Issue Source always opens as Internal	The Edit dialog shows Internal for every issue; saving an External issue without correcting the field stores Internal.	High	FE domain/governance/IssuesPage.tsx (source select bound to label); screenshot issues-edit
GH-08	Empty issue contacts saved as “–”	Editing an issue without contacts shows `--` chips; saving stores `--` as the contact name.	Medium	FE domain/governance/IssuesPage.tsx:30-36
GH-09	Issue workflow state invisible	Whether an issue is Open or Resolved cannot be seen or changed, yet it drives objective progress and the dashboard’s open-issue count.	Medium	BE modules/commandcenter/service/impl/DashboardServiceImpl.java:166
GH-10	Issue search covers the name only	Searching for a contact or description finds nothing.	Low	FE domain/governance/IssuesPage.tsx
GH-11	Editing an objective removes data	Each save clears the target date, owner and internal user links and sets manual progress to 0, because the form does not send them. Demo goals lose their target dates on first edit.	High	BE modules/governance/service/impl/ObjectiveServiceImpl.java:292-307
GH-12	Objective progress not shown	The server calculates progress, but no screen shows it.	Medium	BE ObjectiveProgressCalculator
GH-13	Audit result options always In Progress	Options created on screen get outcome In Progress and the outcome cannot be edited, so a custom “pass” option never reads Pass.	Medium	FE domain/governance/ObjectivesPage.tsx:478

ID	Issue	What the user experiences	Impact	Evidence
GH-14	Result options writable with View access	The server passes PUT requests on objective-audit paths to the service, which does not check result-option changes, so View on Objectives › Audits suffices to rename an option; the Settings button is checked against Objectives edit in the browser.	High	BE modules/organization/security/ModulePermissionInterceptor.java:142
GH-15	Audit tab label	The tab reads **Audit**; the permission settings call it **Audits**.	Low	FE domain/governance/ObjectivesPage.tsx:1474; FE shared/config/navigation.ts:74
GH-16	Objective alerts not sent, and would go to the wrong person	The alert job is dormant (PW-03). If enabled, it would address the owner user, which every UI save clears, or a random id when there is none.	Medium	BE modules/governance/scheduler/ObjectiveAlertScheduler.java:29, 74, 90

Organization Hub

See Users, Departments, Groups.

ID	Issue	What the user experiences	Impact	Evidence
OH-01	Choosing a group replaces all groups	The **Groups** field of a user is single-select; choosing a group removes the user from all other groups.	High	FE shared/ui/CreateUserModal.tsx:184-191
OH-02	User statuses collapsed	Passive, Suspended and Pending show as Inactive and are saved as Inactive.	Medium	FE domain/organization/UsersPage.tsx:395-396
OH-03	Users list hides “admin” groups by substring	Non-administrators do not see members of any group whose name contains “admin”; Group Overview’s Assigned Users can under-count.	Medium	BE modules/organization/repository/UserRepository.java:39

ID	Issue	What the user experiences	Impact	Evidence
OH-04	Users import reports success regardless	The page shows *“Users imported.”* even when rows failed; unknown departments and groups are ignored; a blank password becomes an unknown random one.	Medium	FE domain/organization/UsersPage.tsx:480-488; BE modules/organization/service/impl/UserServiceImpl.java (parseCsvRow)
OH-05	REST API access switch not enforced	The per-user API access setting is stored but nothing checks it.	High	BE modules/organization/entity/User.java:40 (no reader outside mapping)
OH-06	Admin group membership does not give the system ADMIN role	A user put into Admin through Organization Hub does not get the sign-in role ADMIN. Settings endpoints that accept only that role may answer 403, and the Command Center shows only their own tasks. *(code reading)*	Medium	BE modules/organization/service/impl/UserServiceImpl.java:457-467; BE modules/auth/security/JwtService.java:61-76; BE modules/commandcenter/api/DashboardController.java:36
OH-07	Clone Group fails	The page sends `newName`, the server requires `name`; every clone is refused. A clone would also not copy data visibility. *(code reading)*	Medium	FE domain/organization/RolesPage.tsx:1302; BE modules/organization/dto/request/RoleCloneRequest.java:12-14
OH-08	Duplicate group names on rename	Renaming on Edit does not check for an existing name.	Low	BE modules/organization/service/impl/RoleServiceImpl.java (updateRole)
OH-09	Full Control description incomplete	It says “View, plus create, edit and delete.” but also gives Manage Access Control and Manage Section Settings.	Low	FE domain/organization/RolesPage.tsx (LEVEL_TEXT); FE domain/organization/roleAccessModel.ts:96-124
OH-10	Level shown for read without export	Read Only holds read but not export and still shows View; grants and approved requests add single actions and may show Custom.	Low	FE domain/organization/roleAccessModel.ts (isCustom)
OH-11	No list of one’s own access requests	The requester relies on the notification.	Low	BE `/organization/access-requests/my` unused by FE

ID	Issue	What the user experiences	Impact	Evidence
OH-12	Department deletion ignores business risks	The delete check counts an older generic risk table; business risks naming the department do not block deletion and keep a dangling id.	Medium	BE modules/risk/repository/RiskRepository.java:20
OH-13	Departments cannot be deactivated	No status field; a department stored as Passive shows Active.	Low	FE domain/organization/DepartmentsPage.tsx:220
OH-14	Department Contact rules	Required in the form but not by the server; a group contact is stored as a name only.	Low	FE domain/organization/DepartmentsPage.tsx:164-184
OH-15	Legacy field in user View	**User Group** in the View dialog belongs to an older model and cannot be set.	Low	FE domain/organization/UsersPage.tsx

Third Parties

See Vendors, Service Agreements.

ID	Issue	What the user experiences	Impact	Evidence
TP-01	No status field on vendors and agreements	Under Review, Inactive, Terminated and Draft cannot be set; a terminated agreement still reads Active, Expiring or Expired by its dates.	Medium	FE domain/third-parties/VendorsPage.tsx; ServiceAgreementsPage.tsx
TP-02	Risks Open counts every risk	A vendor reads Risks Open while any non-deleted third party risk names it, including treated, accepted or closed risks.	Medium	BE modules/thirdparty/service/impl/VendorServiceImpl.java:329
TP-03	Vendor Role not editable but enforced	The field is no longer on the form but still confines group members to one vendor and blocks deletion of the group.	Medium	FE domain/third-parties/VendorsPage.tsx:128-135; BE modules/thirdparty/security/VendorRoleDeletionGuard.java:29

ID	Issue	What the user experiences	Impact	Evidence
TP-04	Renewal notices not re-sent	The “already sent” record is per agreement, milestone and recipient, not per end date; after extending an agreement the same milestones are not notified again.	Medium	BE modules/thirdparty/service/ServiceAgreementExpiryNotifier.java:169
TP-05	Currency fixed	New agreements are always in AZN.	Low	FE domain/third-parties/ServiceAgreementsPage.tsx
TP-06	Agreement documents not available	Backend fields for a contract document have no UI.	Low	BE modules/thirdparty/entity/ServiceAgreement.java
TP-07	Agreements not in global search	Service agreements cannot be found from the top-bar search.	Low	BE modules/search/service/GlobalSearchService.java

Asset Management

See Assets, Data Flows.

ID	Issue	What the user experiences	Impact	Evidence
AM-01	Deleting an asset deletes its reviews and data flows	The confirmation only says “Delete asset X?”; reviews and data flows are deleted with it (the Data Assets page comment claiming such deletes are refused is wrong).	High	BE modules/asset/service/impl/AssetServiceImpl.java:230-248
AM-02	Data Assets tab: two permissions	Buttons are locked according to Data Flows rights while the server checks Assets rights, so unlocked buttons can be refused and locked ones would be allowed.	Medium	FE domain/asset-management/DataMovementPage.tsx:1192-1220
AM-03	Asset Dynamic Status ignores reviews	An asset whose review was carried out still reads Expired until the Next Review Date is moved.	Medium	BE modules/asset/entity/Asset.java (dynamic status)
AM-04	Generated reviews have no reviewers	Generated asset reviews copy reviewer names at generation; later changes do not update them (demo reviews show `--`).	Medium	BE modules/asset/service/impl/AssetReviewScheduleService.java

ID	Issue	What the user experiences	Impact	Evidence
AM-05	Asset row click bypasses the Reviews lock	Clicking an asset opens the Reviews tab even when it is locked; the request then fails with the permission dialog.	Low	FE domain/asset-management/AssetsPage.tsx:819-822
AM-06	Data Owner always required	The data asset form requires Data Owner even with GDPR switched off.	Medium	FE domain/asset-management/DataMovementPage.tsx:1064
AM-07	Risk pickers stop at 200 records	Flows cannot be linked to risks beyond the first 200 of each register.	Medium	FE domain/asset-management/DataMovementPage.tsx
AM-08	Stage marked required but not checked	A flow can be saved without a stage and then has no GDPR section.	Low	FE domain/asset-management/DataMovementPage.tsx:622-626
AM-09	“Data Assets” column counts flows	The column of that name on the Data Assets tab shows the number of flows of the asset.	Low	FE domain/asset-management/DataMovementPage.tsx
AM-10	Flow order	Not shown, not unique, not renumbered after deletes.	Low	FE domain/asset-management/DataMovementPage.tsx
AM-11	Asset status always Active	No way to retire an asset other than deleting it.	Low	FE domain/asset-management/AssetsPage.tsx
AM-12	Type list	Types used only on other grid pages, or added with + Add, are not offered consistently.	Low	FE domain/asset-management/AssetsPage.tsx
AM-13	Contact length 200	Asset contact names are limited to 200 characters (500 elsewhere).	Low	BE modules/asset/dto/AssetRequest.java (contact, reviewerContact)

Control Center

See Controls, Policies & Standards, Policy Exceptions, Continuity Plans.

ID	Issue	What the user experiences	Impact	Evidence
CT-01	Control audits and maintenances cannot be completed	The audit and maintenance forms have no Status field, so they stay Planned or Pending. Their Dynamic Status never becomes Pass, Fail or Completed; a recorded audit still turns Overdue; a failed audit never makes the control Not Compliant; and Compliance Analysis keeps showing Control Last Audit Expired for the control.	High	FE domain/control-center/ControlsPage.tsx:854-858, 1324-1328; BE modules/control/repository/InternalControlAuditRepository.java:25-27
CT-02	“Failed” evaluated as a pass	A completed audit is Fail only if the result is exactly “fail”; the default list values are “Failed” and “Passed”, so “Failed” reads Pass.	High	BE modules/control/entity/InternalControlAudit.java:75
CT-03	Deleted generated rows come back	Deleting a generated audit or maintenance (or continuity audit) whose date is still in the plan re-creates it on the same save.	Medium	BE modules/control/service/impl/InternalControlServiceImpl.java (update: syncChildren then scheduleService.sync); ContinuityPlanServiceImpl.java (update)
CT-04	Moving a child record to another parent	Audits, maintenances, continuity audits and tasks: refused (“does not belong to the specified …”). Control issues: copied to the new control, original kept.	Medium	FE domain/control-center/ControlsPage.tsx (IssueForm onSave)
CT-05	Saving an issue can fail on an unrelated audit	Issues are saved as a whole-control update that re-validates all audits; a generated audit with empty methodology makes the save fail with “Audit methodology is required”. *(code reading)*	Medium	BE modules/control/dto/InternalControlAuditRequest.java (@NotBlank auditMethodology)

ID	Issue	What the user experiences	Impact	Evidence
CT-06	Tab buttons and server check different rights	Issue writes and deletes on the Audits, Maintenances, continuity Audits and Tasks tabs are checked by the server against edit on the parent page, while the buttons use the tab's rights.	Medium	BE modules/organization/security/ModulePermissionInterceptor.java:161-170
CT-07	Evidence and value lists checked at module level	Uploading or deleting evidence, and editing the Settings value lists, are allowed with the action on any Control Center page (for example Full Control on Policy Exceptions only), subject to record visibility; the Settings button is never locked.	High	BE modules/organization/security/ModulePermissionInterceptor.java:171
CT-08	Links that cannot be edited	The control's continuity plan link cannot be set anywhere; compliance packages only from Compliance Analysis; a policy's links to controls, risks, data flows and packages only from the other records; portal permission has no UI.	Medium	FE domain/control-center/ControlsPage.tsx:24-26, 172, 549; BE modules/control/entity/InternalControl.java
CT-09	Policy review attachment not saved	The review form uploads a file, but the server has no field for it: the column shows the policy's file, reopening shows URL Link, and the uploaded file is orphaned.	High	BE modules/control/entity/PolicyReview.java; BE modules/control/dto/PolicyReviewRequest.java; FE domain/control-center/PoliciesStandardsPage.tsx:823-834
CT-10	Review grid shows the policy's current values	Version and Document Type on the Reviews tab are the policy's current values, not those at review time.	Medium	FE domain/control-center/PoliciesStandardsPage.tsx:645-650
CT-11	Generated policy reviews have no reviewers	Generation copies reviewer names stored as text; policies with reviewers set by id produce empty Reviewers.	Medium	BE modules/control/service/PolicyReviewScheduleService.java (generate)

ID	Issue	What the user experiences	Impact	Evidence
CT-12	Policy delete and reviews	Deleting a policy does not delete its reviews; the delete may be refused or leave orphan reviews, while the backend documentation says reviews are deleted. *(code reading)*	Medium	BE modules/control/service/impl/PolicyStandardServiceImpl.java (delete); BE doc/api/policies-standards.md
CT-13	Policy Expired never produced	The policy Dynamic Status enum has Expired but it is never computed.	Low	BE modules/control/entity/PolicyStandard.java
CT-14	Saving an Approved policy exception turns it into Open	The form maps any status other than Closed to Open; saving an Approved exception (both demo exceptions) stores Open and its Dynamic Status changes from Active to Pending.	High	FE domain/control-center/ExceptionsPage.tsx:93
CT-15	Open policy exceptions read Pending	The form offers only Open and Closed, so an exception created on screen is Pending for its whole life; Active is unreachable.	Medium	FE domain/control-center/ExceptionsPage.tsx; BE modules/control/entity/ControlException.java
CT-16	Policy exception name uniqueness only on create	Renaming to an existing name is accepted.	Low	BE modules/control/service/impl/ControlExceptionServiceImpl.java
CT-17	Continuity plans with an older status open as Design	Plans stored as ACTIVE (the demo plans) show Design and hide the audit schedule; saving keeps ACTIVE, and because only Production plans keep their schedule, blank generated audits are withdrawn.	Medium	BE modules/control/service/ContinuityPlanAuditScheduleService.java (isInProduction)
CT-18	Continuity fields missing from forms	Task Status is not on the form (always Pending); the plan review date that drives Expired is not on the form; plan type is not shown.	Medium	FE domain/control-center/ContinuityRecoveryPage.tsx
CT-19	Continuity Frequency shows raw codes	WEEKLY, MONTHLY, QUARTERLY, TWICE_A_YEAR, YEARLY.	Low	FE domain/control-center/ContinuityRecoveryPage.tsx:1029-1035

ID	Issue	What the user experiences	Impact	Evidence
CT-20	Continuity audit results fixed	The tenant's result catalogue exists but has no Settings UI; the form offers Passed and Failed only.	Low	FE domain/control-center/ContinuityRecoveryPage.tsx:598
CT-21	Mandatory people checked only in the browser	Owner, Sponsor and Launch Initiator are not required by the server.	Low	FE domain/control-center/ContinuityRecoveryPage.tsx:774-776
CT-22	View dialog shows "-" for zero	Counts of 0 (for example Maintenances) show "-".	Low	FE shared/ui/RecordViewModal.tsx
CT-23	No client-side size check on evidence	Files over 25 MB are refused by the server (413) only after upload.	Low	FE shared/ui/EvidenceField.tsx

Risk Management

See Risk Management, Asset Risks, Third Party Risks, Business Risks, Risk Exceptions.

ID	Issue	What the user experiences	Impact	Evidence
RM-01	Scores not recalculated when settings change	Changing a calculation method, classification value or matrix cell score leaves every existing risk with its old score until it is saved again; the Calculation Methods notice says all risks are recalculated.	High	FE domain/risk-management/RiskSettingsModal.tsx:413; BE modules/risk/service/impl/RiskCalculationServiceImpl.java
RM-02	Above Appetite cannot occur with defaults	The flag compares with the numerical appetite (50 in a new organisation, also under the Threshold method), while the highest score on the default 5 × 5 scales is 25. The stored residual threshold (30) is not used anywhere.	High	BE modules/risk/service/impl/RiskSettingsServiceImpl.java:121

ID	Issue	What the user experiences	Impact	Evidence
RM-03	Stored risk status stale and inconsistent	Each risk stores a status on save (Exception Active before Above Appetite, default appetite 50), separate from the register's flags computed on read. Compliance Analysis and the Command Center use the stored value, so they can disagree with the register (for example "DDoS on customer portal" stored On Track while the register shows Review Expired).	High	BE modules/risk/service/impl/RiskCalculationServiceImpl.java:114; BE modules/risk/service/impl/RiskDynamicStatusServiceImpl.java:73-104
RM-04	Manual score override cleared by the form	The override is API-only; every save from the form clears it. Overridden-by and overridden-at are never set.	High	BE modules/risk/service/impl/AssetRiskServiceImpl.java:234
RM-05	Closing a risk exception leaves risks Exception Active	Updating an exception from the form does not recalculate its risks, so a closed exception stays in their treatment and their stored status stays Exception Active.	High	BE modules/risk/service/impl/RiskExceptionManagementServiceImpl.java:92 (update has no recalculateLinkedRisks; called at 154, 181, 198, 214)
RM-06	Hidden seeded calculation method	The seeded Threshold Matrix Method is enabled in every organisation but has no tab, so all three method tabs show Enable off while multiplication is used.	Medium	BE modules/risk/service/impl/RiskSettingsServiceImpl.java:62-69
RM-07	Method settings ignored	The classification types chosen for a method are stored but not used; Multiple Matrices calculates like multiplication.	Medium	BE modules/risk/service/impl/RiskCalculationServiceImpl.java:85-100

ID	Issue	What the user experiences	Impact	Evidence
RM-08	Pickers and matrix axes can diverge	The Likelihood and Impact pickers read types with codes LIKELIHOOD and IMPACT; the matrix uses the first two types by order.	Medium	BE modules/risk/service/impl/RiskReferenceDataServiceImpl.java:255-273; FE domain/risk-management/RiskSettingsModal.tsx:603-604
RM-09	Monitor treatment not offered	Risk Treatment offers Mitigate, Accept, Transfer and Avoid; risks stored with Monitor (two demo risks) show **Choose one…**.	Medium	FE shared/api/riskManagement.ts:92
RM-10	Exception workflow API-only	Submit, approve and deny exist only in the API; the form offers Open and Closed and an Open exception reads Pending until it expires.	Medium	FE shared/api/riskManagement.ts:103; BE modules/risk/api/RiskExceptionManagementController.java:95-108
RM-11	Review edit risk change ignored	The Edit form of a review lets the user pick another risk; the server ignores it.	Medium	BE modules/risk/service/impl/RiskReviewServiceImpl.java (update)
RM-12	Matrix cell score display	Cells always show likelihood × impact as “Score”, also with Addition.	Low	FE domain/risk-management/ThresholdMatrix.tsx:173
RM-13	New classifications sort first	They are created with sort order 0, before the seeded values.	Low	FE domain/risk-management/RiskSettingsModal.tsx
RM-14	Exception expiry off by one day	The Exception Expired flag uses “before today”, the dormant job “on or before today”.	Low	BE modules/risk/scheduler/RiskExceptionScheduler.java:20
RM-15	Risk exception View dialog	Shows the raw status (for example PENDING) and omits Dynamic Status and Closure Date; the Description label overlaps its text box.	Low	FE domain/risk-management/RiskExceptionsPage.tsx

ID	Issue	What the user experiences	Impact	Evidence
RM-16	Inconsistent labels	“Operational risk added / updated / deleted” on Business Risks; tab “Third-Party Risks”; “Treatment: Controls” vs grid “Treatment Internal Controls”; “Applicable Departments Units”.	Low	FE domain/risk-management/OperationalRisksPage.tsx:541, 802-823; ThirdPartyRisksPage.tsx:831; AssetRisksPage.tsx:552
RM-17	Hidden fields on risks	Lifecycle status, review fields of third party and business risks (reviewers affect visibility) and business processes are not on the forms; manually created reviews store no risk name.	Low	BE modules/risk/visibility/*Participants.java
RM-18	Linked-risk panel for third party risks	Shows Treatment Likelihood and Impact, which this register lacks, and omits the coefficient.	Low	FE shared/ui/LinkedRisks.tsx
RM-19	View item omits fields	Threat and vulnerability descriptions, coefficient and security incidents are missing from the risk View dialog.	Low	FE shared/ui/RecordViewModal.tsx
RM-20	Business risk treatment can exceed inherent	Nothing stops the treatment pair from scoring higher than the inherent pair.	Low	FE domain/risk-management/OperationalRisksPage.tsx
RM-21	Settings gear never locked	Everyone can open the settings; saves fail without Manage Section Settings.	Low	FE domain/risk-management/RiskSettingsModal.tsx

ID	Issue	What the user experiences	Impact	Evidence
RM-22	Demo data inconsistencies	Demo business risks have no Risk Originator Contact, so they cannot be saved until one is added (required by the form, not the server); the approved demo exception “Accept kiosk OS risk until refresh” is not in its risk’s treatment.	Low	FE domain/risk-management/OperationalRisksPage.tsx
RM-23	Risk import result format	The unwired risk import returns `successCount` / `errorCount`, not the fields the import dialog reads, so wiring it would show blank counts.	Low	BE modules/risk/dto/CsvImportResultDto.java:12-17; FE shared/ui/CsvImportModal.tsx:8-14

Compliance Hub

See Compliance Packages, Compliance Analysis, Obligations, Compliance Exceptions, External Audit Findings.

ID	Issue	What the user experiences	Impact	Evidence
CH-01	Saving a risk overwrites requirement verdicts	Saving a risk sets every analysis row of its Affected Compliance Items to Not Compliant if any linked risk’s stored status is Above Appetite, otherwise to Compliant, including rows still Under Review that nobody has judged. The verdict uses the stale stored status (RM-03).	High	BE modules/compliance/service/impl/ComplianceAssessmentServiceImpl.java:488-500

ID	Issue	What the user experiences	Impact	Evidence
CH-02	Deleted packages, items and assessments remain	Deletes are soft and do not touch analysis rows; the rows are returned without checking deletion. A deleted package's rows appear under All frameworks, a deleted item keeps its row, and deleted items are offered in the compliance exception picker (choosing one fails "Requirement item not found"). The package delete dialog says the items "will be removed from the Hub as well".	High	BE modules/compliance/repository/ComplianceAssessmentItemRepository.java:29, 37; FE domain/compliance-hub/FrameworksPage.tsx:787; FE shared/api (fetchAllRequirementItems)
CH-03	Edit Action bypasses other registers' permissions	Edit Action on an analysis row writes links on risks, findings and exceptions, checked only against edit on Compliance Analysis.	High	BE modules/compliance/service/impl/ComplianceAssessmentServiceImpl.java:257-303
CH-04	Only the first owner is saved	The analysis row's Owner picker accepts several people; only the first is stored.	High	FE domain/compliance-hub/AssessmentsPage.tsx:667
CH-05	Assessments cannot be created	There is no Add button; the empty text says "Import one via CSV." but the import only updates strategies; assessment status is always In Progress.	Medium	FE domain/compliance-hub/AssessmentsPage.tsx (no onAdd)
CH-06	Strategy import impractical and unchecked	It needs internal row ids that no screen shows and stores any strategy text; a value such as "compliant" in lower case is stored but counted as nothing.	Medium	BE modules/compliance/service/impl/ComplianceAssessmentServiceImpl.java:516-545
CH-07	Open compliance exceptions read Pending	The form offers Open and Closed only; Active is shown only for Approved, so UI-created exceptions are Pending for life.	Medium	FE domain/compliance-hub/ComplianceExceptionsPage.tsx:81; BE modules/compliance/entity/ComplianceExceptionEntity.java (getDynamicStatus)
CH-08	Exception status filter misses stored values	Approved, Under Review and Expired rows are not found by the Open or Closed filter, and there is no Expired choice.	Medium	FE domain/compliance-hub/ComplianceExceptionsPage.tsx:507-512

ID	Issue	What the user experiences	Impact	Evidence
CH-09	Exception package follows the first item	Items from two packages show only the first package; removing all items clears the package.	Medium	FE domain/compliance-hub/ComplianceExceptionsPage.tsx:272; BE ComplianceExceptionHubServiceImpl.java (updateException)
CH-10	Findings status filter is case-sensitive	The filter sends OPEN or CLOSED; demo values Open, In Progress, Closed are not found.	Medium	BE modules/compliance/repository (findings status query `e.status = :status`)
CH-11	Finding severity and source not in the UI	Stored, imported and exported, but cannot be seen or changed.	Medium	FE domain/compliance-hub/AuditFindingsPage.tsx
CH-12	Finding attachment button not locked	The paper clip is never locked; a refused upload fails only at the server.	Low	FE domain/compliance-hub/AuditFindingsPage.tsx:685
CH-13	Finding owner multiple	Owner accepts several people although treated as one.	Low	FE domain/compliance-hub/AuditFindingsPage.tsx
CH-14	Obligation categories garbled	Built-in category codes display a mis-encoded Azerbaijani label (for example “KÄ°Ä° TÉ™hlÃ¼kÉ™sizliyi”) instead of the English label.	Low	BE modules/compliance/service/impl/ComplianceObligationHubServiceImpl.java:47
CH-15	Two spellings of Non Compliant	Drop-down and filter “Non Compliant”, badge “Not Compliant”.	Low	FE shared/ui/StatusBadge.tsx:188-202
CH-16	Obligation mapping to requirements not in the UI	The backend supports it; no screen uses it.	Low	BE `POST /compliance/obligations/{id}/map-requirements`
CH-17	Package Active flag not editable	Dynamic Status is always Active for packages managed on screen.	Low	FE domain/compliance-hub/FrameworksPage.tsx (PackageFormModal)
CH-18	Item sort order and category	Items get sort order 0 (no field); the imported category is never shown.	Low	BE modules/compliance/service/impl/CompliancePackageServiceImpl.java:208-270
CH-19	Package GRC Contact required only in the form	API-created and demo packages show an empty GRC Contact.	Low	FE domain/compliance-hub/FrameworksPage.tsx
CH-20	Exception import links nothing	Imported item number and name are text only; no contacts or package.	Low	BE modules/compliance/service/impl/ComplianceExceptionHubServiceImpl.java:267-330

Operations Center

See Projects, Security Incidents.

ID	Issue	What the user experiences	Impact	Evidence
OC-01	Projects show only asset risks	Third party and business risks naming a project as treatment, and policies, data flows and objectives linking it, do not appear on the project.	Medium	FE domain/operations-center/ProjectsPage.tsx:975
OC-02	CSV import limitations	Values are split on every comma; Validate checks only names or task order; task and expense exports give project names while imports need project ids; the stage export uses different headers from the stage import.	Medium	BE modules/operations/service/impl/OperationsCsvServiceImpl.java:237, 269-283
OC-03	Incident import ignores status	Every imported incident is created Open; contacts are stored as text only.	Low	BE modules/operations/service/impl/OperationsCsvServiceImpl.java:167-190
OC-04	Incident stage permissions do not line up	Changing a stage row needs edit on both Security Incidents (server) and Stages (button); the Settings dialog's buttons use Security Incidents rights while the server checks Stages; the Settings button is never locked.	Medium	FE domain/operations-center/IncidentsPage.tsx:536; BE modules/organization/security/ModulePermissionInterceptor.java
OC-05	Stage definitions in use cannot be deleted	Also when every incident using the stage is closed.	Medium	BE modules/operations (existsByStageIdAndTenantIdAndDeletedFalse)
OC-06	Task automation writes Completed	A project finished through its tasks gets Completed, a value the Status list no longer offers.	Low	BE modules/operations/service/impl/ProjectTaskServiceImpl.java:186-200
OC-07	Deadline before start date accepted	A project can be saved with a deadline earlier than its start date.	Low	BE modules/operations/dto/OperationsProjectRequest.java

ID	Issue	What the user experiences	Impact	Evidence
OC-08	Project form validation	Only “Required” under fields, no summary message.	Low	FE domain/operations-center/ProjectsPage.tsx
OC-09	Incident contacts not visible	GRC Contact and Incident Contact appear only in Edit and are not searchable.	Low	FE domain/operations-center/IncidentsPage.tsx
OC-10	Expense amounts have no currency	Amounts are plain numbers; mixed currencies cannot be told apart.	Low	BE modules/operations/entity/ProjectExpense.java

Settings

See Settings.

ID	Issue	What the user experiences	Impact	Evidence
ST-01	System Log does not record who acted	The User column shows `--` for every entry made by a signed-in user and the export’s username is empty, because only the user id is stored.	High	BE modules/settings/service/impl/SystemLogHubServiceImpl.java:54-66
ST-02	System Log coverage limited	Only authentication settings, System Health and Compliance Hub actions are logged; sign-ins, permission changes and most register changes are not, although the Trust Center says they are. Portal is always ADMIN.	Medium	BE modules/settings/service/impl/SystemLogHubServiceImpl.java (logAction callers)
ST-03	OAuth and SAML sign-in not implemented	Connectors are stored but no login flow uses them and the login page has no SSO option; the OAuth success path returns a placeholder token string.	Medium	BE config/SecurityConfig.java (no oauth2Login or saml2); BE modules/auth/api/OAuthController.java:28-32

ID	Issue	What the user experiences	Impact	Evidence
ST-04	SAML settings not saved	The dialog sends the certificate fields and Sign SAML request under names the server does not read; authentication context and status are saved as display text.	Medium	FE domain/settings/AuthenticationPage.tsx:721-733, 771-776; BE modules/settings/dto/SamlConnectorRequest.java
ST-05	OAuth and SAML connectors cannot be edited, tested or deleted	Their grids have no Edit, Test or Delete action; a wrong connector cannot be corrected or removed on screen.	Medium	FE domain/settings/AuthenticationPage.tsx
ST-06	In Use never set	Always “false”; the main connector can be deleted.	Medium	BE (no caller of setInUse)
ST-07	Empty connector columns	OAuth Client Secret and SAML Identity Provider columns are always empty; LDAP Type is not saved.	Low	FE domain/settings/AuthenticationPage.tsx
ST-08	LDAP sign-in needs an existing account	LDAP does not create accounts; the e-mail must match an active local account.	Low	BE modules/settings/service/impl/DirectoryAuthenticatorImpl.java
ST-09	Reading authentication settings writes	The first read creates the settings row.	Low	BE modules/settings/service/impl/SettingsAuthHubServiceImpl.java (getAuthSettings)
ST-10	OAuth connector import stores a placeholder secret	The unwired import stores “imported-secret”.	Low	BE modules/settings/service/impl/SettingsAuthHubServiceImpl.java:379
ST-11	Send to Support sends nothing	It needs a setting that is not part of the standard configuration and even then only records the request (“queued for delivery”).	Medium	BE modules/settings/service/impl/SystemInfoAndHealthServiceImpl.java:225-227

ID	Issue	What the user experiences	Impact	Evidence
ST-12	System Health switches unused	Debug logging, Email debug and Share anonymous analytics are stored but nothing reads them; Download Logs is CSV named `.log`; the mail check needs host only while SMTP “Configured” needs host and sender.	Low	BE modules/settings/service/impl/SystemInfoAndHealthServiceImpl.java
ST-13	Maintenance mode does nothing	**Enable Maintenance Mode** has no action; the stored setting is not enforced and the public status is hard-coded.	Medium	FE domain/settings/UpdatesPage.tsx:47
ST-14	Updates page	The Changelog reads a field the server does not send; entries can only be added in the database.	Low	FE domain/settings/UpdatesPage.tsx
ST-15	Clear Data keeps uploaded files	Files in object storage are neither deleted nor backed up by a reset.	Medium	BE modules/settings/service/impl/TenantDataResetServiceImpl.java
ST-16	Clear Data details	No restore of the backup; clearing Settings without Registers leaves referenced tables; the page names `test@example.com` as kept account whatever the server setting.	Low	FE domain/settings/DataResetPage.tsx
ST-17	About System values fixed	All values except the version are fixed in the server; switching the Trust Center publishing leaves no System Log entry.	Low	BE modules/settings/service/impl/SystemInfoAndHealthServiceImpl.java

Trust Center and Integrations & Automation

See Trust Center, Integrations & Automation.

ID	Issue	What the user experiences	Impact	Evidence
TI-01	Trust Center requires sign-in	Its texts and About System call it public, but outside visitors cannot open it.	Medium	FE middleware.ts:5
TI-02	Trust Center statements broader than the product	Logging of sign-ins and changes, SSO, CSV export of every register and soft deletion are described but not delivered in this release.	Medium	FE domain/trust-center (fixed text)
TI-03	Trust Center content fixed	English only, not editable by the customer.	Low	FE domain/trust-center
TI-04	Webhooks effectively admin-only	The page can be granted to any group, but the API requires the system role ADMIN or a Settings authority; others see “Webhook list could not be loaded.”. No edit, no retry, no delivery history.	Medium	BE modules/settings/api/WebhookController.java:24-57
TI-05	Webhooks fire for few events	Only System Log entries (Settings and Compliance Hub actions) and legacy incident events; changes to assets, risks, controls, policies, vendors, objectives and projects send nothing.	Medium	BE modules/settings/service/impl/SystemLogHubServiceImpl.java:37; BE modules/audit/service/impl/AuditLogServiceImpl.java:38
TI-06	Integrations page overstates	“CSV Import & Export, 20 registers” and dry run, WebSocket live refresh, in-app notifications for system events, and e-mailed invitations are not what the product does; the SMTP relay sends only invitations and the test message.	Low	FE app/(app)/integrations-automation/page.tsx:78

Count by impact

Impact	Number
High	31
Medium	86
Low	95

Impact	Number
Total	**212**